
AI Governance Engineering

The Thesis & Body of Knowledge · v0.5.0 · September 2026

Body of Knowledge · Jorge García Aibar

Thesis · Jorge García Aibar & Aurélie Pols

aigovernanceengineer.com

Licensed CC BY 4.0

Contents

The Thesis

00 · Preface

01 · The definition

02 · Why now

03 · Values and principles

04 · The stack (five layers)

05 · Patterns

06 · The role

07 · Maturity model

08 · Regulatory map

09 · Glossary

10 · Reading list

11 · AI, defined for governance

12 · Running the AI governance program

13 · Where risk management sits

14 · Governing AI development

15 · Governing deployment and use

16 · Fairness and explainability for practitioners

17 · Incidents, issues and root causes

18 · The EU AI Act in one pass

19 · Privacy and data protection law applied to AI

20 · Other law that already applies to AI

21 · AI-specific laws around the world

22 · Principles, soft law and standards

23 · Governing AI agents

Contributors & signatories

Changelog

The AI Governance Engineering Thesis

Version 0.5.0 · 2026-09-25 · Jorge García Aibar and Aurélie Pols

AI governance engineering is the application of engineering practice (systems thinking, product thinking and code) to the governance of AI systems. It treats governance not as a document to be signed but as a system to be built, run and measured, with the same rigour engineers already apply to the models and agents it governs.

It is more than "AI governance plus a few scripts." It is a change in how the work is done. Legacy AI governance describes an AI system on paper and hopes the paper stays true. Engineering the governance means the policy is executable, the control runs in the pipeline, the evidence is produced as a by-product of the build, and the whole thing is judged by one test: did realised risk actually fall, and can a regulator or auditor read the proof? It is a capability, not a job title. Anyone close enough to the build can develop it. It is measured by realised risk reduction and by audit-ready evidence, never by how many frameworks appear on a slide.

The idea does not appear from nowhere. It inherits from a line of engineering movements that turned process into running systems: site reliability engineering, DevSecOps, policy-as-code and software supply-chain security. Most directly, it inherits from GRC engineering, which since about 2024 has turned governance, risk and compliance into a product built with code, tested in CI/CD and shipping evidence through APIs [1]. AI governance now needs the same step-change, because the thing being governed (models that retrain, prompts that change, agents that act on their own) moves faster than any document can follow.

Fundamental problems with legacy AI governance

- 1. Governance written for systems that no longer exist.** Legacy AI governance runs on PDF policies and spreadsheet inventories that describe an AI system as it was on the day it was reviewed. But models are retrained, prompts are rewritten and agents acquire new tools by the day. The artefact is stale before it is signed. It is no accident that the function still sits mostly with privacy, legal and IT and only 5% with security [3]: far from the pipeline where the system actually changes.
- 2. Point-in-time review of a continuously changing thing.** Annual assessments and committee sign-offs assume a system that holds still long enough to be judged. Frontier models and autonomous agents do not. Gartner expects more than 40% of agentic AI projects to be cancelled by the end of 2027, citing inadequate risk controls among the causes [4], and predicts that by 2029 more than half of successful attacks on AI agents will exploit access-control weaknesses and prompt injection [5]: runtime failure modes that a once-a-year review is structurally blind to.
- 3. Governance as a gate at the end, not a property of the build.** Governance arrives after the model is trained, as a checkpoint to clear before launch. Engineers experience it as a tax collected at the door, and nothing it produces is wired back into how the system is built. A policy that can only recommend cannot stop a bad release. An eval that can fail the build can. Governance placed at the end can only describe risk; governance built into the pipeline can prevent it.
- 4. Framework theatre.** Mapping to NIST AI RMF or ISO/IEC 42001 becomes the end state instead of the starting point. A green mapping matrix is mistaken for a working control. Yet as of 2026-09-24 no harmonised standard is cited in the EU's Official Journal, so even an ISO 42001 certificate confers no presumption of conformity with the AI Act [6]. Coverage is not assurance. A crosswalk proves you have read the framework, not that the control it points to actually fires; a green matrix over a broken control is "theatre with extra steps" [2].
- 5. No runtime data path.** The registry does not know what is running. Gartner asks AI governance platforms for "automated policy enforcement at runtime" [11], yet one vendor's comparison of the category, published by a competitor in it, finds that most of it "manages the program (inventories, assessments, framework mappings, evidence workflows) without any runtime data path" [7]. IBM's own account of being named a Leader in Gartner's first Magic Quadrant for AI Governance Platforms (June 2026) points the same way: it describes visibility into AI use cases and a roadmap of centralised AI asset inventory, lineage and use-case onboarding (the program layer), and does not mention runtime enforcement [10]. So the three questions that define the discipline (what AI is running, what is it allowed to do, what evidence proves it) go unanswered, because nothing is connected to production. Meanwhile a security vendor's 2026 survey reports that roughly one in eight AI breaches involved agentic systems [8]: exactly the layer the paper registry cannot see.

Values

Eight affirmations. Each states what we build toward and, by naming it, what we build away from. Not all are new: values 1, 5 and 7 (governance as code, machine-readable evidence and measured risk reduction) are inherited from GRC engineering; values 2 and 4 (evals that fail the build, and agent identity and scope) are what AI forces us to add. Chapter 03 expands each with an in-practice example and the anti-pattern it rejects.

- 1. Governance is code, not a document.** A policy in a PDF is a statement of intent a human must remember and apply; a policy as code is a control that executes, versioned in a repository and enforced without anyone remembering to. The document describes the rule; the code *is* the rule, and only what runs can be measured.
- 2. Evals fail builds; reviews only recommend.** A review produces a recommendation someone may act on, later, or not. An eval produces a verdict with consequences: the model or agent passed or failed a defined test, and a failure blocks the release. We

prefer controls that bite.

3. Evidence comes from runtime, not from a point-in-time attestation. An attestation says a control was in place when someone looked. Runtime evidence shows it working continuously, emitted by the system as it runs, because an AI system changes between reviews, and evidence gathered once decays immediately.

4. Every agent carries its own identity and scope. An actor on shared credentials is ungovernable: you cannot attribute its actions, revoke its access precisely, or bound what it may do. Identity is the precondition of accountability; scope is the precondition of containment, and both are established before the actor is allowed to act.

5. Evidence is machine-readable or it is not evidence. Evidence a human must produce, format and file by hand cannot be queried, diffed or verified at speed. Machine-readable artefacts (OSCAL, structured eval results, signed logs) turn the audit into a query and feed continuous assurance instead of a one-off binder.

6. Tooling must be inspectable and composable. You cannot trust a verdict you cannot trace. Tooling whose reasoning and data path you can open, bought or built, lets you follow a decision to the rule that produced it and the evidence it emitted, and wire it into the pipeline you already run rather than export into someone else's.

7. Success is measured in realised risk reduction, not framework coverage. Mapping every control to a framework proves you have read it, not that any risk fell. We measure the thing itself: did the rate of the failure mode drop, did the blast radius shrink, did the incident get caught earlier? Coverage is an input; realised risk reduction is the outcome.

8. Governance is owned with engineering, not enforced from outside. Governance that sits apart and grants or denies passage is a bottleneck engineers route around. Owned jointly with engineering, built into the paved path, adopted because it is the easiest way to ship, it becomes part of how things are made, not a meeting one side dreads.

Principles

The values say what we prefer; these principles say what we commit to *do*. They are rules of action, not restatements of the preferences above.

Build the control at the earliest point it can block. Put every control where it can still stop the thing going wrong, and no later: in the repository, the build and the runtime, not in a review after the fact. The earliest enforceable point is the cheapest and the strongest, so that is where we put it.

Give every control teeth, or call it a signal. A control has to be able to change what happens next: block a merge, fail a deploy, revoke access. Anything that can only inform a committee is a signal, and we label it honestly as one rather than dress it up as a control.

Register and bound every actor before it acts. Nothing, human or non-human, gets to act until it has an owner, a declared scope and a way to be stopped. Autonomy is granted only where it can be attributed, contained and withdrawn, never by default.

Instrument the build to produce its own proof. Wire each control to emit its own record as it runs, so assurance falls out of the system instead of being assembled by hand. If demonstrating a control needs a screenshot, we have not finished building it.

Start from a named failure mode or a named harm. Design each control against a specific way the system fails (prompt injection, tool misuse, agent identity abuse, data exfiltration) or a specific harm to a person's rights. If we cannot name the risk it answers, we do not build it.

Make the governed path the easiest path. Ship governance as tooling, templates and paved paths engineers adopt without asking permission, and measure adoption. If routing around the governance is easier than using it, we fix the product, not the people.

What AI governance engineers build

Not decks. Working artefacts, versioned in a repository and running in production:

- **Policy-as-code:** governance rules as executable policy (OPA/Rego, Cedar, Policy Cards) that evaluate in CI/CD and at runtime.
- **An agent registry:** the runtime-aware inventory of every model, service and agent, each with an owner, a scope and a status.
- **AIBOM and model/data cards:** the bill of materials for an AI system (CycloneDX ML-BOM, SPDX 3.0 AI profile) and structured transparency documentation.
- **Eval gates in CI:** adversarial and capability evals (Inspect, promptfoo, Garak, Giskard) wired into the pipeline so a failing eval blocks the release.
- **Runtime guardrails and kill switches:** input/output controls, tool-call mediation and a tested way to stop an agent, at the point of action.
- **Continuous assurance telemetry:** tracing and monitoring (OpenTelemetry, agent observability) that turns production behaviour into a live control signal.
- **Machine-readable evidence:** OSCAL and signed, structured artefacts that make the audit a query instead of a scramble.
- **Incident pipelines:** the plumbing to detect, triage and report serious incidents on the clock, including the EU AI Act's Article 73 reporting for high-risk systems.

- **FRIA and DPIA templates as code:** fundamental-rights and data-protection impact assessments maintained as versioned, reviewable artefacts, not one-off documents.

These artefacts map, layer by layer, onto the five-layer AI governance engineering stack: Govern-as- Code, Inventory & Transparency, Evals & Red Teaming as Evidence, Runtime Controls & Observability, and Assurance & Continuous Compliance.

We concede the inheritance plainly, because it is the honest defence against "this is just GRC with AI words." Three of the five layers (Govern-as-Code, Inventory & Transparency, and Assurance & Continuous Compliance, which carry policy as code, the asset inventory and machine-readable evidence) are inherited from GRC engineering and carried across almost unchanged. Two are what AI forces us to add: evals and red-teaming *as controls* (layer 03), because the thing being governed is a model whose behaviour can only be established by testing it; and agent identity and runtime control (layer 04), because an autonomous actor has no analogue in classic GRC. The new work of the discipline concentrates in those two layers.

A discipline, distinct from its neighbours

AI governance engineering is not AI safety research, MLOps, model risk management, AI compliance or legal work, or Responsible AI ethics; it is the engineering that turns all of those into running controls and readable evidence. It is the AI-era sibling of AI security engineering, the direct descendant of GRC engineering. One name clash is worth flagging: some vendors use the same words, "AI governance engineering", for the reverse problem, governing the AI tools that engineers use inside their own workflows [9]. That is governed AI engineering, not the discipline described here. Chapter 01 draws every one of these lines in full.

Authors

Jorge García Aibar (v0.1–v0.5.0), AI Governance & Privacy Engineer. LinkedIn: <https://www.linkedin.com/in/jorgara>

Aurélié Pols (v0.1–v0.5.0), Responsible AI (EU/Global), Privacy & Data Governance. LinkedIn: <https://www.linkedin.com/in/aureliepols>

Co-authors wanted. This is version 0.5.0: a public draft, deliberately incomplete. It was started by one practitioner and it needs many. If you build governance for AI systems (policy-as- code, agent registries, eval gates, runtime guardrails, continuous assurance) and you can bring a verified fact, a pattern that worked, or a sharper argument, you are invited to co-author. The discipline is a capability anyone can develop, and this text belongs to everyone who does the work.

Sign / get involved

- **Read it** at <https://aigovernanceengineer.com/thesis> and the Body of Knowledge at <https://aigovernanceengineer.com/bok>
- **Sign the Thesis** by opening a pull request that adds your name to `bok/CONTRIBUTORS.md` (SIGNATORIES section) in the repository, github.com/losanchos5/aige.
- **Contribute a chapter or a pattern** following `STYLEGUIDE.md`; every factual claim needs a sourced, verified citation.
- **Discuss it** on LinkedIn with Jorge García Aibar (<https://www.linkedin.com/in/jorgara>), naming the discipline, not the person.

Licence

This Thesis is licensed under **CC BY 4.0**. You may share and adapt it provided you give appropriate credit, link to the licence and indicate changes. Attribution: Jorge García Aibar and Aurélié Pols.

Sources

[1] GRC Engineering Manifesto. grcengineering. ~2024. <https://grc.engineering/> (verified: primary) [2] "What is GRC Engineering" (Ayoub Fandi). GRC Engineer. 2025. <https://grcengineer.com/what-is-grc-engineering/> (verified: primary) [3] AI Governance Profession Report 2025. IAPP (with Credo AI). 2025-04-16. <https://iapp.org/resources/article/ai-governance-profession-report/> (verified: primary) [4] "Gartner Predicts Over 40% of Agentic AI Projects Will Be Canceled by End of 2027". Gartner. 2025-06-25. <https://www.gartner.com/en/newsroom/press-releases/2025-06-25-gartner-predicts-over-40-percent-of-agentic-ai-projects-will-be-canceled-by-end-of-2027> (verified: primary) [5] "Gartner Forecasts the Market for Securing AI Will Reach Almost \$5 Billion in 2027". Gartner. 2026-08-26. <https://www.gartner.com/en/newsroom/press-releases/2026-08-26-gartner-forecasts-the-market-for-securing-ai-will-reach-almost-5-billion-in-2027> (verified: primary) [6] Standardisation of the AI Act (no harmonised standard yet referenced in the Official Journal, so no Art. 40 presumption of conformity from any standard, ISO/IEC 42001 included; page last updated 2026-08-03; no Commission implementing decision citing one found in the Publications Office index on 2026-09-24). European Commission. 2026-08-03. <https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation> (verified: primary) [7] "Best AI Governance Platforms in 2026: 14 Enterprise Vendors Compared" (vendor-published comparison of the 13 Magic Quadrant vendors plus its own product; runtime data path critique). Kosmoy. 2026-07-10. <https://www.kosmoy.com/resources/blog/best-ai-governance-platforms-2026/> (verified: secondary) [8] 2026 AI Threat Landscape Report (vendor survey; key finding stated on the report page: one in eight breaches were agentic). HiddenLayer. 2026. <https://www.hiddenlayer.com/report-and-guide/threatreport2026> (verified: primary) [9] "AI Governance Engineering" (governing AI used inside engineering workflows). Visure Solutions. 2026. <https://visuresolutions.com/ai-engineering/ai-governance-engineering/> (verified: primary) [10] "IBM recognized as a Leader in the Gartner Magic Quadrant for AI Governance Platforms"

(vendor announcement citing Gartner, Magic Quadrant for AI Governance Platforms, L. Kornutick et al., 17 June 2026, the first MQ for the category; visibility into AI use cases; roadmap: AI asset inventory and lineage, use-case onboarding). IBM. 2026-06-17. <https://www.ibm.com/new/announcements/ibm-recognized-as-a-leader-in-gartner-magic-quadrant-for-ai-governance-platforms> (verified: secondary) [11] "Global AI Regulations Fuel Billion-Dollar Market for AI Governance Platforms" (platforms should enable "automated policy enforcement at runtime"; AI governance spending USD 492M in 2026, over USD 1B by 2030). Gartner. 2026-02-17. <https://www.gartner.com/en/newsroom/press-releases/2026-02-17-gartner-global-ai-regulations-fuel-billion-dollar-market-for-ai-governance-platforms> (verified: primary)

00. Preface

Why this book exists, who it is for, and how to use it.

Why this exists

There is a manifesto for GRC engineering. There is a manifesto for agile software. There is a pattern catalogue for responsible AI and a twelve-factor guide for cloud applications. There is nothing that tells you how to *engineer* the governance of AI systems: how to turn an AI Act obligation or an ISO 42001 control into policy-as-code, an eval gate, an agent registry and machine-readable evidence that an auditor can read. This book is the first attempt to write that down.

It exists because the gap is now expensive. The thing being governed (models that retrain, prompts that change, agents that act on their own) moves faster than any document can follow. Governance written as PDFs and spreadsheets is stale before it is signed. The discipline that closes the gap is engineering, applied to governance. This book is its founding text and its working reference.

Who wrote it, and from what

The Body of Knowledge was written by Jorge García Aibar, an AI Governance & Privacy Engineer, drawing on two and a half years designing and operating an AI governance framework inside a large telco, sitting between Legal, Security and Engineering, and covering the governance, security, compliance, business and model-performance dimensions of AI risk. The Thesis is the sole co-authored part of the project, written by Jorge García Aibar and Aurélie Pols, who works in Responsible AI, Privacy and Data Governance. Nothing in this book discloses any employer's internal detail; where practice is described it is generic ("in a large telco").

It is built from three things. First, that operating experience: what actually held up when a model changed on a Friday and an agent gained a new tool over the weekend. Second, the **GRC Engineering** precedent: the community, manifesto and body of practice that, since about 2024, has turned governance, risk and compliance into a product built with code [1][2]. Third, the public record: the EU AI Act and its Digital Omnibus reform, ISO/IEC 42001, the NIST AI RMF, OWASP's GenAI and Agentic work, CSA, CSIRO's Responsible AI Pattern Catalogue, and the frontier labs' own safety frameworks. Every factual claim in the book carries a sourced, verified citation.

Who should read this

- **AI governance leads** who want to stop shipping documents and start shipping controls. Chapter 12 sets up [the governance program](#) that gives every control an owner.
- **Security engineers and AI security engineers** extending their threat models to models and agents. Start with [layer 04 of the stack](#) and [governing AI agents](#).
- **Privacy engineers and DPOs** who want FRIA and DPIA to live as code, not as one-off PDFs. Chapter 19 applies [data protection law to AI](#), and chapter 18 covers the [FRIA](#).
- **MLOps and platform engineers** who are being asked to make governance a property of the pipeline. Chapters 14 and 15 run [the build as a chain of gates](#) and [the deployment lifecycle](#).
- **Risk leads and CISOs** who own the enterprise view of AI risk. Chapter 13 compiles [risk appetite and tolerance into gates](#), and chapter 17 runs [the incident response lifecycle](#).
- **Executives and board members** who need to know whether governance works. Chapter 12 names [the KPIs and KRIs that reach the board](#).
- **Lawyers and compliance professionals who want to build**, to see the obligation turned into an executable control and readable evidence, and to help specify it. The last part reads [the EU AI Act](#), [the law that already applies](#) and [AI laws around the world](#) as artefacts to build.
- **Public-sector teams**, for whom several jurisdictions already publish dedicated instruments. Chapter 21 covers [the UK's public-sector records](#) and [Canada's Directive on Automated Decision-Making](#).
- **Small organisations and start-ups**, which carry the same duties with fewer people. Chapter 04 builds [the minimum viable stack for a team of one](#).

You do not need to write production code to use this book, but you should be comfortable near a pipeline. The discipline is a capability anyone close to the build can develop, whatever the title: an AI governance engineer is defined by the workflows they own, not by the name of the role.

The website adds [one landing page per audience](#) ([engineers](#), [CISOs and risk leads](#), [legal counsel and DPOs](#), [executives and boards](#), [the public sector](#) and [SMEs](#)) that puts the chapters, patterns, templates and tools in the order that job needs them.

How to use this book

The Body of Knowledge has 24 chapters in five parts. Read the first part in order: it sets the vocabulary every other chapter uses. After that, read by part, or follow the question in front of you.

1. **The discipline** (chapters 00–07): the definition, why the discipline is forming now, its values and principles, the five-layer stack, the pattern catalogue, the role and the maturity model.
2. **Reference** (08–10): the regulatory map that turns each obligation into an artefact and a layer, the glossary and the reading list. Most chapters point into these.
3. **Foundations** (11–13): what counts as an AI system, the governance program that gives every control an owner, and the risk loop that tells every control how hard to bite.
4. **The lifecycle** (14–17 and 23): development, deployment, fairness and explainability, incidents and agents, each stage leaving a record that a gate reads.
5. **Law and standards** (18–22): the EU AI Act, data protection, the other law that already applies, AI laws around the world, and the principles and standards.

Most chapters open with an "At a glance" summary and a list of key terms, each linked to its glossary page, and end with "What you can do this week". Chapters link to each other by section, so one topic can be followed across parts. On the website, the patterns, templates, obligation register and toolkit carry the same material in a form you can copy into a pipeline.

What this is not

This is not a compliance checklist, and it is not legal advice. It does not tell you whether your system is compliant; it tells you how to build the controls and the evidence that let someone qualified make that call. It is not an AI safety research agenda, an MLOps handbook, or a vendor buyer's guide; tools are named only as illustrative examples of a category, never as endorsements. And it is not finished. Version 0.5.0 is a public draft with deliberate gaps open to contributions.

How to cite

García Aibar, J. *AI Governance Engineering: The Body of Knowledge*, v0.5.0. 2026. <https://aigovernanceengineer.com/bok>. Licensed CC BY 4.0.

For the Thesis, cite both co-authors:

García Aibar, J., & Pols, A. *The AI Governance Engineering Thesis*, v0.5.0. 2026. <https://aigovernanceengineer.com/thesis>. Licensed CC BY 4.0.

Cite a specific chapter by its number and title (for example, "chapter 01, The definition"). The canonical home of the Thesis is <https://aigovernanceengineer.com/thesis> and of the Body of Knowledge <https://aigovernanceengineer.com/bok>. Each chapter carries its own numbered source list; the consolidated table lives in `sources/SOURCES.md`.

Versioning

This is **v0.5.0**, a public draft. Versioning is semantic in spirit: patch releases fix facts and typos, minor releases add chapters or patterns, and a 1.0 will mark the point at which the core chapters (00–10) are complete and reviewed. Every change is recorded in `bok/CHANGELOG.md`. Because the regulatory and standards landscape moves (the Digital Omnibus reform, harmonised standards under JTC 21, the OWASP and CSA releases), chapters carry a "current as of" date and are expected to be revised.

How to contribute

This book welcomes credited contributions. To contribute:

1. Read `STYLEGUIDE.md` and follow the chapter or pattern template exactly.
2. Source every factual claim. Use the `[n]` citation format, tag each source `primary`, `secondary` or `reported`, and add the row to `sources/SOURCES.md` under your chapter's section.
3. Open a pull request. To sign the Thesis, add your name to `bok/CONTRIBUTORS.md`.

The rules exist so that many hands produce one coherent book. Everything else (the arguments, the patterns, the mappings) is open for you to improve.

Maps to: this preface makes no normative claim; the standards it names are treated in full in chapters 04, 05, 08, 18 and 22.

Sources

[1] GRC Engineering Manifesto. grcengineering. ~2024. <https://grc.engineering/> (verified: primary) [2] "What is GRC Engineering" (Ayoub Fandi). GRC Engineer. 2025. <https://grcengineer.com/what-is-grc-engineering/> (verified: primary)

01. The definition

AI governance engineering is the application of engineering practice (systems thinking, product thinking and code) to the governance of AI systems; a capability, not a job title, measured by realised risk reduction and audit-ready evidence.

The definition

AI governance engineering is the application of engineering practice (systems thinking, product thinking and code) to the governance of AI systems.

Read the sentence in three parts. *Engineering practice* means we build, run and measure governance the way engineers build, run and measure anything else: as versioned systems with tests, telemetry and owners, not as documents. *Systems thinking and product thinking* mean we treat governance as a whole that spans data, model, pipeline, runtime and organisation, delivered as a product to the engineers who are its users. *The governance of AI systems* is the subject: the whole span of governance, risk and assurance for AI, including autonomous agents, not one narrow slice of it. Chapter 11 settles [what counts as an AI system](#) for governance purposes, and why that decision is itself the first control.

The framing is borrowed, deliberately. GRC engineering defines itself as "the application of software engineering practice, systems thinking and product thinking to governance, risk and compliance" [1]. AI governance engineering is that same move, aimed at the governance of AI. It is the parent discipline pointed at a faster, stranger target.

Three clarifiers

It covers governance, risk and assurance of AI systems, including agents. The scope is not "compliance." It runs from setting the rules (governance), through identifying and reducing what can go wrong (risk), to producing the evidence that the controls work (assurance). It explicitly includes autonomous and agentic AI, because that is where the hardest governance problems now live: an agent that browses, executes code, calls APIs and acts under delegated authority is the object that legacy governance can least see.

It is a capability, not a job title. You do not need "AI governance engineer" on your business card to do this work, and having the title does not mean you are doing it. It is a set of practices (policy-as-code, eval gates, agent registries, continuous assurance) that a security engineer, a privacy engineer, an MLOps engineer or a governance lead can each develop. The market is forming the role (technical AI-governance roles in the tech sector report a median near USD 221,000, the highest band in IAPP's survey [2], and Gartner forecasts AI governance spending of USD 492 million in 2026, passing USD 1 billion by 2030 [3]), but the discipline is defined by the capability, not by the vacancy.

It is measured by realised risk reduction and audit-ready evidence. There are exactly two tests. Did the risk actually fall, measurably, in production, not on a maturity slide? And can a regulator or auditor read the proof as machine-readable evidence, not a reassembled screenshot? A control that passes neither test is theatre. Framework coverage, number of policies written and committees held are inputs at best; they are never the measure.

The disambiguation cluster

The discipline is defined as much by what it is not as by what it is. Eight neighbours are routinely confused with it. Each shares a border; none is the same thing.

Neighbour	What it does	How AI governance engineering differs
AI safety research	Studies whether powerful models are safe in principle (alignment, dangerous capabilities).	Engineers the controls and evidence for AI systems in production; consumes safety research, does not conduct it.
MLOps / LLMOps	Builds, deploys and serves models and pipelines reliably.	Governs what MLOps ships: adds policy, evals-as-evidence, registry and assurance as gates on the same pipeline.
Model risk management (SR 11-7 style)	Validates models, checks for conceptual soundness and back-tests, in the banking tradition; in the US, SR 11-7 was superseded by SR 26-2 on 17 Apr 2026 [6].	Extends beyond model validation to runtime behaviour, agents, rights impact and continuous, machine-readable evidence.
AI compliance / legal	Interprets obligations (EU AI Act, GDPR) and advises on them.	Turns the obligation into an executable control and readable evidence; needs legal, does not replace it.
Responsible AI / AI ethics	Sets the values and principles (fairness, transparency, accountability).	Implements those values as running controls; ethics sets the target, engineering hits it and proves it.
GRC engineering (the parent)	Applies engineering practice to governance, risk and compliance generally.	Same method, specialised to AI: models, agents, evals, AIBOM, runtime AI controls.

Neighbour	What it does	How AI governance engineering differs
AI security engineering (the sibling)	Secures AI systems against attack (prompt injection, model theft, agent abuse); its deliverable is a defended system.	Overlaps heavily (often the same person), but its deliverable is a <i>governed and evidenced</i> system: the rights-and-obligations record and continuous assurance, not only defence.
Visure's "AI governance engineering"	Governs the AI that engineers <i>use inside</i> engineering workflows (requirements, MBSE).	The opposite direction: our subject is governing AI <i>systems</i> , not governing AI-assisted engineering [4].

In prose: the frontier lies where a discipline stops. **AI safety research** asks whether a model is safe; we ask whether the deployed system is governed, and prove it. **MLOps** answers "is the model serving?"; we answer "is it allowed to serve, and what evidence says so?" We govern the very pipeline MLOps runs. **Model risk management** in the SR 11-7 tradition validates a model at points in time; we govern the system continuously, including agents that have no analogue in a credit model. The tradition's US reference text changed on 17 Apr 2026, when the Federal Reserve, the OCC and the FDIC replaced SR 11-7 with SR 26-2 ([SR 11-7, now SR 26-2](#), in chapter 21) [6]. The new guidance places generative and agentic AI models outside its scope [7], so the systems this book cares most about are the ones bank model validation now leaves to other controls; chapter 13 sets out where [model risk management meets AI risk management](#). **AI compliance and legal** tell you what the law requires; we build the control that meets it and the evidence that shows it, and we depend on lawyers to tell us we got the obligation right. **Responsible AI and AI ethics** set the values; without engineering, those values stay on a poster (chapter 16 turns one of them, [fairness, into metrics and eval gates](#)). **GRC engineering** is the parent method, and we are its AI specialisation. We inherit three of the five stack layers almost unchanged (Govern-as-Code, Inventory & Transparency, and Assurance & Continuous Compliance, which carry policy as code, the asset inventory and machine-readable evidence) along with the "green dashboard over a broken control is theatre" test; what AI forces us to add is the other two, evals and red-teaming as controls and agent identity and runtime control, because a model whose behaviour must be tested and an autonomous actor that acts under delegated authority have no analogue in classic GRC. **AI security engineering** is the sibling we overlap with most, and the overlap is a feature, not a boundary dispute: the same person often wears both hats. The line is not "framing versus fences" but *deliverable*. Security engineering's deliverable is a defended system: it stops the attack. AI governance engineering's deliverable is a *governed and evidenced* system: the rights-and-obligations record (which control answers which article, with the proof attached) and continuous assurance as a product an auditor or regulator can query. A red-team eval is security work and governance work at once; it becomes governance when its result is filed as evidence against an obligation. Security asks "is it safe from attack?"; we ask "is it governed, and can we prove it?" We usually need the security answer as an input to ours. And **Visure's** use of the identical phrase points the other way entirely: governing the AI that assists engineering work, not engineering the governance of AI. We claim the second meaning and disambiguate the first on sight.

The object of governance

What, concretely, does this discipline govern? Five nested objects, each needing different controls:

- **Models.** The trained artefacts (foundation models, fine-tunes, classifiers), with their provenance, capabilities, evaluations and known failure modes. Governed with model cards, evals and AIBOM.
- **Systems.** The application around the model: prompts, retrieval, tools, orchestration, the human and machine users. Most risk is here, not in the raw model.
- **Agents.** Systems that act: browse, execute code, call APIs, move money, delegate to other agents. Governed with identity, bounded scope, tool mediation, runtime guardrails and kill switches. This is the hardest and newest object, and the one legacy governance cannot see; chapter 23 covers [governing agents](#) end to end.
- **Data.** Training data, retrieval corpora, prompts and outputs, with their lawful basis, rights, provenance and retention. Governed with data cards, DPIAs and lineage; chapter 19 applies [data protection law to AI](#).
- **The organisation.** The roles, decision rights, escalation paths and accountability that surround all of the above. Governed with an operating model, RACI and an incident pipeline (chapter 12 maps [the stakeholders and their duties](#)). A control with no owner is not a control.

The discipline is coherent only when it addresses all five. A model card with no agent registry, or an agent registry with no runtime data path, governs one object and leaves the others open.

The three questions

At any moment, an AI governance engineering function must be able to answer three questions about production, instantly, from live systems, not from a document last updated a quarter ago:

1. **What AI is running?** Which models, systems and agents are live, in which version, owned by whom. This is the job of the inventory and the agent registry, and it must be fed by a runtime data path, not typed into a spreadsheet.
2. **What is it allowed to do?** The scope, permissions, guardrails and policy that bound each system and agent. This is the job of governance-as-code and runtime controls: identity before autonomy, scope before action.

3. **What evidence proves it?** The machine-readable, audit-ready record that the controls fired and the risk fell. This is the job of evals-as-evidence and continuous assurance: evidence as a by-product of the build.

These three questions are the spine of the whole Body of Knowledge. The five-layer stack (chapter 04) is built to answer them: Inventory & Transparency answers *what is running*; Govern-as-Code and Runtime Controls & Observability answer *what it may do*, the first writing the bound as code and the second enforcing it on the live call; Evals & Red Teaming and Assurance & Continuous Compliance answer *what evidence proves it*. The threats those controls are built against (prompt injection, tool misuse, agent identity and privilege abuse, rogue agents) are catalogued in OWASP's Top 10 for Agentic Applications [5], and the patterns that answer them are in chapter 05.

The limits of the eval gate

This book leans hard on evals as controls, so it owes the reader the same "theatre" test it applies to everything else. An eval gate is necessary; it is not sufficient. Take it seriously and its limits follow directly:

- **It is point-in-time and sampling-bound.** An eval proves the system passed *these* cases at *this* version. It says nothing about the inputs it did not sample, and nothing about tomorrow's model.
- **It is Goodhartable.** The moment a threshold gates a release, there is pressure to tune the model to the suite or the threshold to the model. A gate optimised against becomes a number that rises while the risk it stood for does not move.
- **It catches regressions, not novelty.** A suite tests known failure modes. A novel jailbreak or an attack the suite never imagined passes green, because nothing in the gate was built to see it.

None of this argues against the gate; it argues for how the gate must be run. The eval suite is itself an artefact to be governed: its coverage measured, its cases maintained adversarially, its thresholds traced to named failure modes rather than round numbers, and its size set by the threshold it has to resolve (chapter 14 shows how to [size the suite from the threshold](#)). The same caution applies to [public benchmarks and leaderboards](#), which score a model on someone else's cases rather than on your task. And a passing gate *obliges* runtime monitoring (layer 04) rather than replacing it. An eval is the control at build time; the guardrail and the trace are the control at run time, against the inputs no eval anticipated. A discipline that treats a green gate as proof of safety has rebuilt framework theatre with a faster pipeline.

In practice Inside a large telco, the difference between "governed" and "documented" came down to those three questions. A model inventory maintained by hand answered question one on the day it was edited and was wrong within a week. Wiring the registry to the deployment pipeline (so a new model or agent registered itself, with an owner and a scope, at deploy time) was what made the three questions answerable on any given Tuesday. The document became a query.

Maps to: EU AI Act Art. 9 (risk management), Art. 11/49/71 (documentation and registration), Art. 55 (GPAI systemic-risk duties) · ISO/IEC 42001 (AI management system) · NIST AI RMF (Govern, Map, Measure, Manage) · OWASP Top 10 for Agentic Applications 2026. Mappings are illustrative, not a claim of conformity.

Sources

[1] "What is GRC Engineering" (Ayoub Fandi). GRC Engineer. 2025. <https://grcengineer.com/what-is-grc-engineering/> (verified: primary) [2] Salary & Jobs Report 2025-26. IAPP. 2025-08-03. <https://iapp.org/resources/article/salary-survey-summary/> (verified: primary) [3] "Global AI Regulations Fuel Billion-Dollar Market for AI Governance Platforms" (AI governance spending USD 492M in 2026, over USD 1B by 2030). Gartner. 2026-02-17. <https://www.gartner.com/en/newsroom/press-releases/2026-02-17-gartner-global-ai-regulations-fuel-billion-dollar-market-for-ai-governance-platforms> (verified: primary) [4] "AI Governance Engineering". Visure Solutions. 2026. <https://visuresolutions.com/ai-engineering/ai-governance-engineering/> (verified: primary) [5] Top 10 for Agentic Applications 2026. OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [6] SR 26-2, Revised Guidance on Model Risk Management (Federal Reserve, OCC and FDIC; supersedes SR 11-7 of 2011-04-04 and SR 21-8; most relevant to banking organisations above USD 30 billion in total assets). Board of Governors of the Federal Reserve System. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> (verified: primary) [7] Revised Guidance on Model Risk Management, attachment to SR 26-2 (footnote 3: generative AI and agentic AI models "are not within the scope of this guidance"; the principles apply to traditional statistical and quantitative models and non-generative, non-agentic AI models; effective challenge). Federal Reserve, OCC and FDIC. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602a1.pdf> (verified: primary)

02. Why now

AI governance engineering is forming now because the thing being governed changed shape, the market began hiring for engineering skills before the profession named itself, and the law began asking for engineered evidence, all between April 2025 and August 2026.

Disciplines do not appear on a schedule. They appear when an old way of working visibly stops holding and enough people, in enough places, start building the replacement at once. That is happening to AI governance now. The Thesis states five fundamental problems with legacy AI governance; this chapter takes each in turn, attaches the evidence, and then lays out the market, regulatory and technical signals that together explain the timing. The claim is narrow and falsifiable: not that governance suddenly matters, but that the *engineering* of governance has become the constraint, and that the data now says so. Dated statements are current as of 2026-09-24.

The five problems, with the evidence

1. Governance written for systems that no longer exist

Legacy governance describes an AI system as it was on the day it was reviewed, while models retrain, prompts change and agents gain tools by the day; the artefact is stale before it is signed. The structural tell is *where the function sits*. In IAPP's 2025 AI Governance Profession Report, the AI governance function is lodged mostly with privacy (22%), legal and compliance (22%) and IT (17%), and with only 5% in security [1], far from the pipeline where the system changes. A function in the review layer, not the build layer, cannot keep its description of production true, because nothing wires it to the deploy.

2. Point-in-time review of a continuously changing thing

Annual assessments and committee sign-offs assume a system that holds still long enough to be judged. Frontier models and autonomous agents do not. Gartner expects more than 40% of agentic AI projects to be cancelled by the end of 2027, naming inadequate risk controls among the causes [2], and predicts that by 2029 more than half of successful attacks on AI agents will exploit access-control weaknesses and prompt injection [3]. Both are runtime failure modes (the system misbehaving between reviews), and a once-a-year assessment is structurally blind to them. This is not the same work as model risk management in the SR 11-7 tradition, which validates a model at points in time; the object here never stops moving. The tradition's own US guidance agrees on the boundary: SR 26-2, which replaced SR 11-7 on 17 Apr 2026, leaves generative and agentic AI models outside its scope [22][23]. Chapter 11 lists [the traits of AI that break classic IT governance](#), each paired with the control that answers it.

3. Governance as a gate at the end, not a property of the build

Governance still tends to arrive after the model is trained, as a checkpoint to clear before launch, and nothing it produces is wired back into how the system is built. A policy that can only recommend cannot stop a bad release; an eval wired into an [eval gate](#) that can fail the build can: the difference between a control that describes risk and one that prevents it. Chapter 14 rebuilds [the build as a chain of gates](#).

4. Framework theatre

Mapping to NIST AI RMF or ISO/IEC 42001 becomes the end state instead of the starting point, and a green mapping matrix is mistaken for a working control. Yet as of 2026-09-24 no harmonised standard is cited in the EU's Official Journal, so there is no Article 40 presumption of conformity for the AI Act [4]. Even EN ISO/IEC 42001, the AI management-system standard, is not the Article 17 quality management system the Act requires and confers no presumption of conformity on its own [5]. Coverage is not assurance. A crosswalk proves you have read the framework; it does not prove the control it points to actually fires.

5. No runtime data path

The registry does not know what is running. One vendor's comparison of the AI governance platform category, published by a competitor in it, finds that most of the category "manages the program (inventories, assessments, framework mappings, evidence workflows) without any runtime data path" [6]. Treat that as a claim to test, not a settled fact; where it holds, the three questions that define the discipline (what AI is running, what is it allowed to do, what evidence proves it) go unanswered, because nothing is connected to production. Meanwhile a security vendor's 2026 survey reports that roughly one in eight AI breaches involved agentic systems [7]: exactly the layer the paper registry cannot see. A control with no telemetry is a claim, not a control.

The evidence

The profession is understaffed, and it knows it

The clearest signal that the work has outgrown its current form is that almost nobody thinks they have enough people to do it. In IAPP's 2025 report, of 671 respondents only 10 (1.5%) said they will not need additional AI governance staff in the next 12 months [1]. Some 77% of organisations report working on AI governance, rising to roughly nine in ten among those already using AI [1]. Demand is near-universal; capacity is not. When a function is wanted everywhere, under-resourced, and lodged outside the build

layer, the gap is not closed by hiring more reviewers. It is closed by turning the governance into a system that scales, which is an engineering problem.

The market is hiring for the engineering

The labour market is already hiring for this shift, and it is doing so in the vocabulary of engineering. An analysis of 1,997 United States AI-governance postings, updated in August 2026, found the most common skill demanded was observability platforms, in 41% of postings, followed by Python (28%) and NIST frameworks (27%) [8]. These are build-and-run skills, not review skills. At the frontier, Anthropic advertised in 2026 an Engineering Manager for GRC tasked with building an "AI-forward GRC engineering function", translating "policies into policy-as-code", and deploying agentic workflows that use Claude "to serve as a virtual GRC analyst" [9]. The postings describe the substance of AI governance engineering; they have not yet agreed on its name.

Registry versus runtime

The tooling market tells the same story from the supply side. Gartner published its first Magic Quadrant for AI Governance Platforms in June 2026, as one of the vendors named in it reported [10]. Gartner's own framing of the category asks for more than a register: its February 2026 analysis says these platforms should enable "automated policy enforcement at runtime" and continuous monitoring, and it expects AI governance spending to reach USD 492 million in 2026 and pass USD 1 billion by 2030 [11]. What the category is asked to do and what it ships are different questions. The vendor comparison cited above, which scores the thirteen vendors in the Magic Quadrant, finds most of them manage the program "without any runtime data path" [6], and the account one Leader gives of its own placement centres visibility into AI use cases and a roadmap of asset inventory, lineage and use-case onboarding [10]. The question to ask any platform is therefore concrete: was this policy decision made on a live call, and where is the record? The distance between the analyst's definition and that answer is the space the discipline occupies.

The standards gap

The framework-theatre problem has a hard deadline attached to it. As of 2026-09-24, zero harmonised standards are cited in the Official Journal, so Article 40's presumption of conformity is not yet available to anyone [4]. EN 18286, the quality-management standard aimed at Article 17, was published in July 2026, the first JTC 21 standard written for the AI Act to reach publication, but it is not yet cited in the Official Journal, so it carries no presumption of conformity [4][12]. The Article 9 risk-management, Article 12 logging and Article 15 cybersecurity standards were reported to be still at the Enquiry stage in mid-2026, targeting the end of 2026 [13]. EN ISO/IEC 42001:2026, the European adoption of the AI management-system standard, is not the Article 17 QMS and does not by itself evidence conformity [5]. The practical consequence for a governance function: for the period covered by this edition, there is no standard you can certify against to buy a legal presumption. You have to build the controls and the evidence yourself and be ready to defend them on their merits.

The regulatory wave: the Omnibus and GPAI enforcement

The law moved twice in the summer of 2026, in opposite directions, and both moves point at engineering. First, [the Digital Omnibus, Regulation \(EU\) 2026/1744](#), entered into force on 27 July 2026, six days before the 2 August high-risk deadline, and reset the clock: Annex III high-risk obligations moved from 2 August 2026 to 2 December 2027, and Annex I embedded high-risk from 2 August 2027 to 2 August 2028 [14][19]. The extra time is real, but it is not relief from the engineering; it is more runway to do it. Second, and unmoved by the Omnibus, GPAI enforcement went live on 2 August 2026: the AI Office can now demand documentation, evaluate models and require measures, and the Commission can fine providers of general-purpose models up to 3% of global annual turnover or EUR 15 million, whichever is higher, under Article 101 [15]. On 29 August 2026 Commission Executive Vice-President Henna Virkkunen announced that the AI Office had formally sent its first requests for information to a number of GPAI providers, covering model security, independent external evaluations and the monitoring of models once they are on the market [16]. What the enforceable obligations ask for (model evaluations, adversarial testing, incident reporting, weight security) is an engineering programme, not a policy binder.

The next flips are dated in the Omnibus itself [19]. On 2 December 2026 the new Article 5 bans on AI-generated non-consensual intimate imagery and child sexual abuse material apply, and providers of generative systems placed on the market before 2 August 2026 must meet the Article 50(2) marking duty. Annex III high-risk obligations follow on 2 December 2027 and Annex I on 2 August 2028; high-risk systems intended for public authorities that were already on the market must comply by 2 August 2030. [Chapter 08](#) maps each date to the artefact that answers it.

The same pull shows up outside the EU. [California's SB 53](#), the Transparency in Frontier Artificial Intelligence Act, signed on 29 September 2025 and in force since 1 January 2026, binds large frontier developers (models trained with more than 10^{26} operations; annual revenue above USD 500 million) to publish a frontier AI framework, and every frontier developer, large or not, to report critical safety incidents to the state's Office of Emergency Services within 15 days, with civil penalties of up to USD 1 million per violation recovered by the Attorney General [17][18]. Its scope is narrow ([chapter 08](#) sets it beside the other [US state laws](#)), but what it asks for, a published framework and [an incident pipeline that runs on a clock](#), is again an engineering deliverable.

The agent shift

The last signal is the object of governance itself. Agents that browse, execute code, call APIs and act under delegated authority are now the hardest and newest thing to govern, and the evidence that legacy controls cannot see them is mounting. Gartner's forecast that by 2029 more than half of successful attacks on AI agents will exploit access-control weaknesses and prompt injection [3] names identity and injection (runtime concerns) as the dominant attack surface. The identity problem is concrete: on 5

February 2026 NIST's National Cybersecurity Center of Excellence published a concept paper on how identification, authentication and authorisation apply so that agents are "known, trusted, and properly governed", asking how agent actions can be logged in a tamper-proof way and bound back to a human for non-repudiation [20]. An agent run on a generic, shared service account fails that test by construction: its actions cannot be traced or revoked precisely. OWASP's Top 10 for Agentic Applications 2026 catalogues the failure modes that follow, from agent goal hijack (ASI01) through tool misuse (ASI02) and agent identity and privilege abuse (ASI03) to rogue agents (ASI10) [21]. And the 2026 vendor survey cited above reports roughly one in eight AI breaches involving agentic systems [7]. The threat model has moved to the layer the paper registry cannot reach. Chapter 23 maps those threats to controls.

What changes when governance is engineered

The five problems share one root: governance that describes rather than runs. Engineering the governance changes the artefact, and changing the artefact changes what the function can promise. When the registry is fed by the deployment pipeline, "what AI is running?" is a live query, not a quarterly guess, and the staleness of problem 1 stops existing. When an `eval gate` fails the build on a dropped injection-resistance threshold and a policy compiled to code blocks an out-of-region deployment, the point-in-time review of problem 2 and the end-of-line gate of problem 3 give way to controls that fire where the system changes. When guardrail decisions, eval results and policy verdicts stream into an assurance store as machine-readable records, the framework theatre of problem 4 is answered by a measure that is a named failure mode's falling rate, not a count of green cells. And when identity precedes autonomy and telemetry becomes a live control signal, the runtime data path of problem 5 is the spine rather than an afterthought, so the three questions become answerable on any given Tuesday, from live systems.

None of this is a claim that engineered governance guarantees compliance; no artefact does, and no standard yet confers a presumption. The claim is narrower and more useful: measured against realised risk reduction and audit-ready evidence, a governance function that runs beats one that is written, and the market, the regulator and the threat model have all, between April 2025 and August 2026, started asking for the version that runs. That is why now.

In practice Inside a large telco, the shift from "documented" to "engineered" was visible in a single quarter's incident drill. The paper version answered "which agents can reach the payments API?" with a spreadsheet that was a week stale and missing two services stood up since the last review. After the registry was wired to the deploy pipeline and every agent was issued a scoped identity, the same question was a query that returned owners, scopes and last-seen timestamps in seconds, and a misbehaving agent could be revoked without breaking the others. The evidence for the drill was not assembled afterwards; it was already in the assurance store.

Maps to: EU AI Act Art. 4/4a (literacy, bias-detection data), Art. 15 (robustness, cybersecurity), Art. 17 (QMS), Art. 53/55 (GPAI), Art. 101 (GPAI fines) · ISO/IEC 42001 · NIST AI RMF (Govern, Map, Measure, Manage) · OWASP Top 10 for Agentic Applications 2026 (ASI01–ASI03, ASI10) · California SB 53 · five-layer stack, all layers. Mappings are illustrative, not a claim of conformity.

Sources

[1] AI Governance Profession Report 2025 (with Credo AI; 671 respondents; only 1.5% will not need more staff; 77% working on AI governance; 5% of the function in Security; still the current edition on 2026-09-24). IAPP. 2025-04-16. <https://iapp.org/resources/article/ai-governance-profession-report/> (verified: primary) [2] "Gartner Predicts Over 40% of Agentic AI Projects Will Be Canceled by End of 2027". Gartner. 2025-06-25. <https://www.gartner.com/en/newsroom/press-releases/2025-06-25-gartner-predicts-over-40-percent-of-agentic-ai-projects-will-be-canceled-by-end-of-2027> (verified: primary) [3] "Gartner Forecasts the Market for Securing AI Will Reach Almost \$5 Billion in 2027" (by 2029, >50% of successful attacks on AI agents exploit access control and prompt injection). Gartner. 2026-08-26. <https://www.gartner.com/en/newsroom/press-releases/2026-08-26-gartner-forecasts-the-market-for-securing-ai-will-reach-almost-5-billion-in-2027> (verified: primary) [4] Standardisation of the AI Act (no harmonised standard yet referenced in the Official Journal, so no Art. 40 presumption; page last updated 2026-08-03; no Commission implementing decision citing one found in the Publications Office index on 2026-09-24). European Commission. 2026-08-03. <https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation> (verified: primary) [5] "ISO/IEC 42001 and the AI Act: why certification is not yet a presumption of conformity" (ISO 42001 AIMS ≠ Art. 17 QMS). Law & Technology. 2026. <https://lawandtechnology.eu/en/iso-iec-42001-and-the-ai-act-why-certification-is-not-yet-a-presumption-of-conformity/> (verified: secondary) [6] "Best AI Governance Platforms in 2026: 14 Enterprise Vendors Compared" (vendor-published comparison of the 13 Magic Quadrant vendors plus its own product; most of the category "manages the program ... without any runtime data path"). Kosmoy. 2026-07-10. <https://www.kosmoy.com/resources/blog/best-ai-governance-platforms-2026/> (verified: secondary) [7] 2026 AI Threat Landscape Report (vendor survey; key finding stated on the report page: one in eight breaches were agentic). HiddenLayer. 2026. <https://www.hiddenlayer.com/report-and-guide/threatreport2026> (verified: primary) [8] "The State of the AI Governance Job Market in 2026" (1,997 US postings; observability platforms 41%, Python 28%, NIST frameworks 27%; updated 2026-08-04). Axial Search. 2026-08-04. <https://axialsearch.com/insights/ai-governance-jobs> (verified: secondary) [9] "Engineering Manager, GRC" (build an "AI-forward GRC engineering function"; "translate policies into policy-as-code"; Claude "as a virtual GRC analyst"; no longer accepting applications on 2026-09-24). Anthropic (via General Catalyst jobs). 2026. <https://jobs.generalcatalyst.com/companies/anthropic/jobs/78167778-engineering-manager-grc> (verified: primary) [10] "IBM recognized as a Leader in the Gartner Magic Quadrant for AI Governance Platforms" (vendor announcement citing Gartner, Magic

Quadrant for AI Governance Platforms, L. Kornutick et al., 17 June 2026, the first MQ for the category; visibility into AI use cases; roadmap: AI asset inventory and lineage, use-case onboarding). IBM. 2026-06-17. <https://www.ibm.com/new/announcements/ibm-recognized-as-a-leader-in-gartner-magic-quadrant-for-ai-governance-platforms> (verified: secondary) [11] "Global AI Regulations Fuel Billion-Dollar Market for AI Governance Platforms" (platforms should enable "automated policy enforcement at runtime"; AI governance spending USD 492M in 2026, over USD 1B by 2030). Gartner. 2026-02-17. <https://www.gartner.com/en/newsroom/press-releases/2026-02-17-gartner-global-ai-regulations-fuel-billion-dollar-market-for-ai-governance-platforms> (verified: primary) [12] "EN 18286 in the Spotlight: Supporting Compliance with the AI Act" (EN 18286:2026, Art. 17 QMS, published; the first standard in support of the AI Act). CEN-CENELEC. 2026-07-31. <https://www.cenelec.eu/news-events/news/2026/en-in-the-spotlight/2026-07-30-ai-quality-management/> (verified: primary) [13] JTC 21 standards tracker (risk, logging and cybersecurity standards at Enquiry, end-2026 target; a vendor-maintained tracker, not a CEN-CENELEC publication). kla.digital. 2026. <https://kla.digital/blog/jtc-21-standards-tracker> (verified: reported) [14] "AI Omnibus enters into force" (Reg. (EU) 2026/1744, in force 2026-07-27; Annex III high-risk → 2 Dec 2027; Annex I → 2 Aug 2028). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force> (verified: primary) [15] Commission enforcement powers over GPAI providers apply from 2 August 2026 (fines up to 3% of worldwide turnover or EUR 15M under Art. 101). European Commission, AI Act Service Desk. 2026-08-02. <https://ai-act-service-desk.ec.europa.eu/en/ai-act/faq/commissions-enforcement-powers-related-ai-act-obligations-providers-most-advanced-models> (verified: primary) [16] Statement announcing the AI Office's first formal requests for information to GPAI providers (model security, independent external evaluations, post-market monitoring; recipients not named). Henna Virkkunen, Executive Vice-President of the European Commission (LinkedIn). 2026-08-29. <https://www.linkedin.com/feed/update/urn:li:activity:7499411372032602112/> (verified: primary) [17] SB 53, Artificial intelligence models: large developers (Transparency in Frontier Artificial Intelligence Act; approved by the Governor 29 Sep 2025; frontier model > 10²⁶ operations; large frontier developer > USD 500M revenue; frontier AI framework; critical safety incidents to the Office of Emergency Services within 15 days; civil penalty up to USD 1M per violation, Attorney General only; a regular-session statute, in force from 1 Jan 2026 under Cal. Const. art. IV, §8(c)(1)). California Legislature. 2025-09-29. https://leginfo.ca.gov/faces/billTextClient.xhtml?bill_id=20250260SB53 (verified: primary) [18] "California's SB 53: the first frontier AI law explained" (frontier developers: trained a foundation model with more than 10²⁶ operations; large frontier developers: also more than USD 500M in annual gross revenue; up to USD 1M per violation; AG enforcement). Future of Privacy Forum. 2025-10-03. <https://fpf.org/blog/californias-sb-53-the-first-frontier-ai-law-explained/> (verified: secondary) [19] Regulation (EU) 2026/1744 (Digital Omnibus on AI), Art. 1: new Art. 5(1)(ba)–(bb) from 2 Dec 2026; new Art. 111(4) (Art. 50(2) marking for systems placed on the market before 2 Aug 2026, by 2 Dec 2026); Art. 111(2) (public-authority high-risk systems by 2 Aug 2030); Art. 113 (Annex III 2 Dec 2027; Annex I 2 Aug 2028). Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [20] "Accelerating the Adoption of Software and Artificial Intelligence Agent Identity and Authorization" (concept paper; agents "known, trusted, and properly governed"; tamper-proof logging and non-repudiation). NIST NCCoE. 2026-02-05. <https://www.nccoe.nist.gov/news-insights/new-concept-paper-identity-and-authority-software-agents> (verified: primary) [21] Top 10 for Agentic Applications 2026 (ASI01 Agent Goal Hijack, ASI02 Tool Misuse, ASI03 Agent Identity & Privilege Abuse, ... ASI10 Rogue Agents). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [22] SR 26-2, Revised Guidance on Model Risk Management (Federal Reserve, OCC and FDIC; supersedes SR 11-7 of 2011-04-04 and SR 21-8). Board of Governors of the Federal Reserve System. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> (verified: primary) [23] Revised Guidance on Model Risk Management, attachment to SR 26-2 (footnote 3: generative AI and agentic AI models "are not within the scope of this guidance"). Federal Reserve, OCC and FDIC. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602a1.pdf> (verified: primary)

03. Values and principles

The eight values and six principles of the Thesis, each expanded with what it means in practice and the anti-pattern it rejects.

The Thesis states eight values and six principles in one line each. This chapter expands them. The two are deliberately different kinds of thing, and the difference is what keeps them from being the same list told twice. A **value** is a preference: a trade-off, what we lean toward when we cannot have both; it is stated as an affirmation, and naming what we build *toward* also names what we build *away from*. A **principle** is a commitment to *act*: a rule of method, phrased as something we do, that holds regardless of preference. So the values name the artefacts and outcomes we build toward; the principles name how we work, and they carry no vocabulary borrowed from the values. Read the values to know which way to lean; read the principles to know what to do on Monday.

Not all of the values are new to AI. Governance as code (1), machine-readable evidence (5) and measured risk reduction (7) are inherited from GRC engineering, the parent discipline. Evals that fail the build (2) and agent identity and scope (4) are what AI forces us to add; the model that must be tested and the autonomous actor that must be bounded have no analogue in classic GRC.

These are the book's own values and principles. The principle sets published by others are treated elsewhere: chapter 11 traces [the published responsible-AI principle sets to artefacts](#), and chapter 22 has the [OECD AI Principles mapped to the stack](#).

The eight values

Each value is stated as an affirmation: what we build toward, which by naming it also names what we build away from. The values-and-principles form follows the GRC Engineering Manifesto that is this book's precedent [1].

1. Governance is code, not a document

A policy in a PDF is a statement of intent that a human must read, remember and apply. A policy as code is a control that executes: it evaluates a pull request, a deployment or a runtime call and returns a decision. The document describes the rule; the code *is* the rule, versioned in a repository, tested, and enforced without anyone remembering to. When the rule changes, you change one artefact and every enforcement point updates. When an auditor asks what the policy was on a given date, you show the commit. This is not "delete all documents." A policy still needs a human-readable statement of why it exists. The value is that the authoritative, enforced version is the executable one, and the prose is its documentation, not the other way around.

In practice A data-residency rule written as OPA/Rego blocks any deployment that would route inference outside the permitted region, in CI and at admission. The same rule, as a PDF, was "communicated" quarterly and violated monthly. **Anti-pattern** The "policy library" that is a folder of Word documents nobody can query, whose enforcement is an email and whose compliance is self-attested.

2. Evals fail builds; reviews only recommend

A review produces a recommendation; someone may act on it, later, or not. An eval produces a verdict with consequences: the model or agent passed or failed a defined test, and a failure blocks the release. In AI systems the most honest control is a test the system must pass, run automatically, whose result changes what happens next. We prefer controls that bite.

A review still has its place: for questions no test can settle. But when a property *can* be tested (a jailbreak resistance threshold, a PII-leakage bound, a tool-scope check), turning it into a review instead of an eval gate is a choice to be able to recommend but not to stop.

In practice A red-team eval suite (Inspect, Garak) runs in CI; if injection resistance drops below the agreed threshold, the pipeline fails and the release does not ship until it is fixed. **Anti-pattern** A "model risk review board" that meets monthly, writes findings rated low/medium/high, and has no mechanism to stop a launch already scheduled.

3. Evidence comes from runtime, not from a point-in-time attestation

An attestation says a control was in place when someone looked. Runtime evidence shows the control working continuously, from the system itself. AI systems change between reviews (a model is retrained, an agent gains a tool), so evidence gathered once decays immediately. We prefer evidence that is emitted as the system runs, so "is the control working?" is answered by live telemetry, not by a signature dated last quarter.

In practice Guardrail decisions, eval results and policy verdicts stream into an assurance store with timestamps; the control's status is a live query, not an annual sign-off. **Anti-pattern** A SOC-style attestation binder assembled the week before an audit, describing controls as they were imagined to be, not as production actually behaved.

4. Every agent carries its own identity and scope

An agent acting on a shared service account or a static key is ungovernable: you cannot attribute its actions, revoke its access precisely, or bound what it may do. We prefer every non-human actor to have its own identity, an owner, and a scope of permitted actions, established *before* it is allowed to act. Identity is the precondition of accountability; scope is the precondition of containment. Chapter 23 builds both for agents, starting from [identity and short-lived credentials](#).

In practice Each agent is issued a distinct workload identity, registered with an owner and a declared scope; a misbehaving agent is traced to its identity and its access revoked without touching the others. **Anti-pattern** A fleet of agents sharing one API key and one privileged service account, where an incident means rotating one secret and breaking everything, and attribution is impossible.

5. Evidence is machine-readable or it is not evidence

Evidence a human must produce, format and file by hand does not scale and cannot be verified at speed. Machine-readable evidence (`OSCAL` , structured eval results, signed logs) can be queried, diffed, aggregated and checked automatically. We prefer evidence a machine can read, because the audit then becomes a query and the same evidence feeds continuous assurance rather than a one-off binder.

In practice Control results are emitted as `OSCAL` component and assessment artefacts; an auditor's question is answered by running a query against the evidence store. **Anti-pattern** A shared drive of screenshots and exported spreadsheets, re-collected from scratch for every audit, unverifiable and out of date the moment it is saved.

6. Tooling must be inspectable and composable

The point is not who built the tool or whether it is open source; it is whether you can see inside it. You cannot trust a verdict you cannot trace. Inspectable tooling lets you follow a decision to the rule that produced it, the input it saw and the evidence it emitted; composable tooling lets you wire that decision into your own pipeline rather than export into someone else's. We prefer tooling whose reasoning and data path we can open, bought or built, because governance you cannot see inside is a control you cannot trust. One vendor's comparison of the AI-governance platform category, published by a competitor in it, finds that most of the category "manages the program (inventories, assessments, framework mappings, evidence workflows) without any runtime data path" [3]; where that holds, the objection is not that the tooling is commercial but that its verdict cannot be audited.

This is a lean, not an absolute. Closed and commercial tools have a place, including capable platforms. But the default is tooling the team can inspect and compose, over a black box the team must take on faith.

In practice The eval harness, policy library and registry expose how a verdict is reached (the rule, the input and the emitted evidence) and compose into the pipeline the team already runs, whether the components are open-source or a platform with an open data path. **Anti-pattern** A six-figure governance platform whose "compliance score" cannot be traced to a single running control, and whose data path stops at the spreadsheet import.

7. Success is measured in realised risk reduction, not framework coverage

Mapping every control to NIST AI RMF and ISO 42001 proves you have read the frameworks; it does not prove any risk fell. We prefer to measure the thing itself: did the rate of the failure mode drop, did the blast radius shrink, did the incident get caught earlier? Coverage is an input; realised risk reduction is the outcome. A green mapping matrix over a broken control is theatre with extra steps [2].

In practice Each control declares the failure mode it addresses and a metric for it (injection success rate, time-to-detect, unauthorised tool-calls blocked); the control is judged by the metric moving, not by the framework cell turning green. **Anti-pattern** A 300-row traceability matrix mapping controls to five frameworks, presented as maturity, with no measurement of whether any of the mapped controls actually reduces risk.

8. Governance is owned with engineering, not enforced from outside

Governance that sits apart and grants or denies passage is a bottleneck engineers route around. Governance owned jointly with engineering, built into the paved path, adopted because it is the easiest way to ship, becomes part of how things are made. We prefer shared ownership: the governance function builds the tooling, engineering builds on it, and the gate is a stage in a pipeline both own, not a meeting one side dreads. Chapter 12 describes the [governance culture](#) that shared ownership depends on.

In practice The eval gate and policy checks ship as part of the standard pipeline template; engineers adopt them because the paved path is also the fastest path, and governance co-maintains them. **Anti-pattern** A governance team that reviews and sign-offs releases from the outside, measured by how many it stops, while engineering builds a shadow process to avoid it.

We still use the practices each value builds away from; we build toward the affirmation.

The six principles

Build the control at the earliest point it can block

Put every control where it can still stop the thing going wrong, and no later. The earliest place a risk can be caught is the cheapest to fix and the strongest place to enforce: catching it in the repository beats catching it in production, which beats explaining it to a regulator. So a control is sited at the first gate that can refuse the change: a policy in CI, an eval before deploy, an identity check at admission, a guardrail at the point of action. The commitment is about *placement*: whatever the control, it belongs at the earliest enforceable point, not bolted on at the end.

In practice A new agent cannot be deployed until it has registered an owner and a scope and passed its eval gate; the pipeline enforces this at the earliest gate that can refuse it, not a person at the end. **Anti-pattern** A pre-launch "governance review" that happens after the system is built, changes nothing about how it was built, and can only delay or wave through.

Give every control teeth

A control must be able to change what happens next: block a merge, fail a deploy, revoke access. Anything that can only inform a committee is a *signal*, and we say so rather than dress it up as a control. This is the commitment that turns an eval from research into a gate, a policy from a PDF into a check, a threshold from a dashboard number into a release blocker. When a property can be tested, turning it into a review instead of a gate is a choice to be able to recommend but not to stop, and we make that choice consciously or not at all.

The teeth are not the whole animal. A gate that can fail the build is necessary and not sufficient: an eval is point-in-time and sampling-bound, it can be gamed by tuning the model to the suite or the threshold to the model, and it catches regressions against known cases, not the novel attack the suite never imagined. So a control with teeth carries obligations of its own (its coverage measured, its cases maintained adversarially, its thresholds traced to named failure modes), and a passing gate *obliges* the runtime monitoring of layer 04, it does not replace it. A green gate treated as proof of safety is framework theatre with a faster pipeline.

In practice Capability and adversarial evals are versioned alongside the model; the deploy depends on the eval job passing, its coverage is tracked as its own metric, and a runtime guardrail carries the same threshold into production against the inputs no eval sampled. **Anti-pattern** A one-off model evaluation run before launch, its results pasted into a slide, never re-run when the model or its prompts change; or a gate whose threshold is quietly lowered until the build goes green.

Register and bound every actor before it acts

Nothing, human or non-human, gets to act until it has an owner, a declared scope and a way to be stopped. Autonomy on shared credentials is ungovernable by construction: you cannot attribute, contain or revoke what you cannot trace to an actor. So registration is a precondition, not a follow-up: every actor is enrolled, scoped and given a kill switch *before* it does anything on its own. Autonomy is earned by being governable, not granted by default.

In practice The agent registry is the gate: an agent with no owner, no scope or no kill switch is denied a workload identity and cannot reach production. **Anti-pattern** Agents spun up ad hoc on a shared key, discovered only after one of them takes an action no one can explain or undo.

Instrument the build to produce its own proof

Wire each control to emit its own record as it runs, so assurance falls out of the system instead of being assembled by hand before an audit. If demonstrating a control needs a screenshot, we have not finished building it. The commitment is to instrumentation: every gate, guardrail and check writes a structured, signed record as it fires, so the audit is a query and the same records drive continuous assurance and incident response (chapter 17 specifies [the incident record](#)).

In practice Every gate and guardrail writes a structured, signed record; the audit trail builds itself, and the evidence store answers both the auditor and the on-call engineer. **Anti-pattern** An evidence-collection sprint before each audit, re-creating after the fact a record the systems never actually produced.

Start from a named failure mode or a named harm

Design each control against a specific way the system fails or a specific harm it can do to a person, and start there, not from a framework checklist. Threat models (prompt injection, tool misuse, agent identity abuse, data exfiltration) and [fundamental-rights impact assessments](#) are the inputs to design, not paperwork produced afterward. If we cannot name the risk a control answers, we do not build it. Chapter 13 shows how to go about [identifying risk sources, factors and stakeholders](#), and the [harms atlas](#) lists harms by level, each with the control that catches it.

In practice The agent's design starts from its OWASP Agentic threat model [4] and its FRIA; the controls that ship are exactly the ones those two documents demanded, and they map back to them. **Anti-pattern** A control catalogue assembled from a framework checklist, addressing risks the system does not have while missing the injection path an attacker actually uses.

Make the governed path the easiest path

Ship governance as tooling, templates and paved paths engineers adopt without asking permission (a policy library, a registry with an API, a gate they can run locally before they push), and measure adoption. The people governed are our users; the paved path has to be the fastest path or it will be routed around. If using the governance is harder than avoiding it, the governance is designed wrong, and we fix the product, not the people.

In practice An engineer scaffolds a new AI service from a template that already includes the registry hook, the policy checks and the eval gate; compliance is the default, not a request. **Anti-pattern** A governance intranet of forms and ticket queues, where doing the right thing takes a week and a meeting, so teams quietly do the fast thing instead.

Maps to: the values and principles are realised through the five-layer stack (chapter 04) and the pattern catalogue (chapter 05); the failure modes they target are OWASP Top 10 for Agentic Applications; the assurance they demand maps to ISO/IEC 42001, NIST AI RMF and EU AI Act Arts. 9, 15, 55 and 72. Mappings are illustrative, not a claim of conformity.

Sources

[1] GRC Engineering Manifesto (values and principles precedent). grcengineering. ~2024. <https://grc.engineering/> (verified: primary) [2] "What is GRC Engineering" (Ayoub Fandi; "theatre with extra steps"). GRC Engineer. 2025. <https://grcengineer.com/what-is-grc-engineering/> (verified: primary) [3] "Best AI Governance Platforms in 2026: 14 Enterprise Vendors Compared" (vendor-published comparison of the 13 Magic Quadrant vendors plus its own product; most of the category "manages the program ... without any runtime data path"). Kosmoy. 2026-07-10. <https://www.kosmoy.com/resources/blog/best-ai-governance-platforms-2026/> (verified: secondary) [4] Top 10 for Agentic Applications 2026. OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary)

04. The stack (five layers)

The reference architecture of AI governance engineering: five layers that answer the three questions, where evidence is produced at the bottom and proven at the top.

How to read the stack

The stack is not an org chart and not a maturity ladder. It is a build order. Each layer produces an artefact that the layer above consumes, so that governance stops being a set of parallel documents and becomes a single system with a data path from policy to proof.

Read it along one spine: **Policy** → **Inventory** → **Evals** → **Runtime** → **Assurance**. You write the rule as code (layer 01). You cannot enforce a rule against a system you cannot see, so you inventory what is running (layer 02). You cannot claim a system meets the rule without a test that can fail, so you run evals as evidence (layer 03). Rules and tests decay the moment the system changes, so you hold the line at runtime (layer 04). And none of it is worth anything to an auditor unless the evidence is emitted, signed and queryable, so you close with continuous assurance (layer 05).

Evidence flows up. A policy verdict from layer 01, a registry entry from layer 02, an eval result from layer 03 and a guardrail decision from layer 04 are not four disconnected records. Each is a structured artefact with a timestamp and an owner, and layer 05 is where they are aggregated into audit-ready evidence. The test of the whole stack is the test from the Thesis: as Ayoub Fandi puts it, a green dashboard over a broken control is "theatre with extra steps" [1]. The stack is the plumbing that makes the dashboard mean something: every green cell traces to a running control and the evidence it emitted.

The five layers, named exactly and in order, are: **01 Govern-as-Code** · **02 Inventory & Transparency** · **03 Evals & Red Teaming as Evidence** · **04 Runtime Controls & Observability** · **05 Assurance & Continuous Compliance**. They map onto the three questions the discipline must answer at any moment. Layer 02 answers *what AI is running*. Layers 01 and 04 answer *what it is allowed to do*: layer 01 writes the bound as code and layer 04 enforces it on the live call, under the agent's own identity and scope. Layers 03 and 05 answer *what evidence proves it*. The threats the controls are built against (goal hijack, tool misuse, agent identity and privilege abuse, rogue agents) are catalogued in OWASP's Top 10 for Agentic Applications 2026 [2].

Three of these layers are inherited, not invented. Govern-as-Code (01), Inventory & Transparency (02) and Assurance & Continuous Compliance (05) come almost unchanged from GRC engineering: policy as code, the asset inventory and machine-readable evidence are its established practice, and the AI-specific records (the agent registry, the AIBOM) extend them rather than replace them. Layers 03 and 04 (evals and red-teaming as controls, and agent identity and runtime control) are what AI forces the discipline to add, because a model whose behaviour must be tested and an autonomous actor that acts under delegated authority have no analogue in classic GRC. The new work concentrates there; the rest is a specialisation of a method that already works.

Every tool named below is an example of a category, not a recommendation. The categories are the substance; the brands are illustrative and interchangeable.

Layer 01: Govern-as-Code

What it proves. That a governance rule exists as an executable artefact, not a paragraph, and that it evaluated a specific change and returned a decision. The proof is a policy verdict tied to a commit, a pull request or a deploy, machine-readable and reproducible.

The artefacts. An AI governance engineer ships policy-as-code: rules written in a policy language that a pipeline evaluates. Typical artefacts are a policy library under version control, a set of crosswalks that map each policy to the frameworks it serves, and the CI/CD wiring that runs the policy at the right gate. A policy in this layer is small and testable: "inference for this data class may not route outside the permitted region", "no model deploys without a registered owner and a passed eval gate", "an agent may not be granted a tool scope it did not declare". Each rule carries a human-readable statement of intent as its documentation, but the enforced version is the code.

Reference tools and standards (illustrative). Policy engines express allow/deny logic. `OPA/Rego` is the general default for non-authorization policy (data residency, deploy gating, configuration constraints), while `Cedar` is narrower: an authorization language, strongest for "may this principal take this action on this resource?" and a poor fit for policy that is not an access decision. Choose by the shape of the rule, not the brand. Beyond general-purpose engines, one proposed approach is Policy Cards: a research proposal for a machine-readable, deployment-layer artefact that encodes operational, regulatory and ethical constraints for an agent and links them to enforcement and audit pipelines [3]; it is a single preprint, promising but not yet a standard, and the point it makes, that the rule should travel with the agent as data, stands whichever format wins. Crosswalks reference the frameworks themselves: ISO/IEC 42001 (the AI management system), NIST AI RMF and its four functions (Govern, Map, Measure, Manage [4]), the EU AI Act, and the CSA AI Controls Matrix (AICM) v1.1, which offers 247 control objectives across 18 domains as a control vocabulary to map against [5]. Vendors are illustrative; the standards are not.

Definition of done.

- Every policy exists as code in a repository, with a test that proves it fires on a violating input and passes a clean one.
- Each policy declares the framework clauses it maps to, so the crosswalk is generated from the code, not maintained beside it.

- At least one policy runs pre-merge and blocks the merge on failure; at least one runs at deploy or admission and blocks the release.
- A change to a policy is a reviewable diff with an owner and an effective date.
- The policy engine emits a structured verdict (allow/deny, rule id, input hash, timestamp) for every evaluation.

Anti-patterns.

- The "policy library" that is a folder of Word documents nobody can query, enforced by email and self-attested in a spreadsheet.
- The crosswalk maintained as a 300-row matrix in a separate tool, drifting from the policies it claims to describe: coverage presented as control.

Evidence to the next layer. The policy verdict is the first evidence artefact. But a verdict is only meaningful against a known object: "deny deploy of model X" presumes the stack knows model X exists, who owns it and what it is. That object is what layer 02 supplies.

In practice For `csa-01`, a customer-service assistant in a large telco, a data-residency rule written as `OPA/Rego` ran at both CI and admission and blocked any deployment routing its inference outside the permitted region. The value was not the rule but that the enforced version emitted a verdict every engineer could see before merge.

Maps to: EU AI Act Art. 9 (risk management) · ISO/IEC 42001 · NIST AI RMF (Govern) · CSA AICM · OWASP Agentic ASI02/ASI03. Mappings are illustrative, not a claim of conformity.

Layer 02: Inventory & Transparency

What it proves. That the organisation knows what AI is running (which models, systems and agents are live, in which version, owned by whom), and that each has the transparency documentation an obligation demands. The proof is a registry entry and its attached documents, ideally written by a deployment pipeline rather than typed by hand.

The artefacts. The core artefact is the **agent registry**: the runtime-aware inventory of every model, service and agent, each with an owner, a scope and a status. Around it sit the transparency documents (model cards and data cards) and the **AIBOM**, the bill of materials for an AI system. FRIA and DPIA references hang off the registry entry for systems that need them, so the inventory is also the index of which system has which impact assessment.

Reference tools and standards (illustrative). Registries range from ITSM and governance suites (for example ServiceNow, Credo AI) to agent-discovery tools (for example Zenity) that find AI the inventory did not know about. The AIBOM has standard formats: CycloneDX ML-BOM and the SPDX 3.0 AI profile, with the OWASP AIBOM generator producing CycloneDX output [6]. The distinction from a classic SBOM matters: an AIBOM records models, datasets, weights and their provenance, not only software dependencies. The registry is the object that layer 01's policies evaluate and layer 04's runtime controls attach to; without a runtime data path feeding it, it is a spreadsheet that was true on the day it was edited.

Definition of done.

- Every model, system and agent in production has a registry entry with an owner, a version and a declared scope; an unregistered artefact cannot reach production.
- The registry is fed by the deployment pipeline, not by manual entry; a new deploy registers itself.
- Each high-risk system links to its model card, data card and, where required, its FRIA/DPIA.
- An AIBOM is generated at build for each AI system and stored with the registry entry.
- A discovery mechanism periodically reconciles the registry against what is actually running and flags drift.

Anti-patterns.

- The hand-maintained model inventory that answers "what is running?" correctly on the day it is edited and is wrong within a week.
- Transparency documents written once at launch and never regenerated when the model, prompt or dataset changes: a model card describing a model that no longer exists.

Evidence to the next layer. The registry entry names the object under test. An eval in layer 03 is run *against a registered version* and its result is filed *against that entry*, so the question "was this model tested?" is answered by a join, not a search. The AIBOM tells the eval layer what to test: which model, which datasets, which provenance claims need adversarial probing.

In practice Wiring the registry to the deployment pipeline (so `csa-01` registered itself, with an owner and a scope, at deploy time) turned "documented" into "governed". Its registry entry became a query answered from production, not from a slide.

Maps to: EU AI Act Art. 11 (technical documentation), Art. 49/71 (registration and the EU database), Art. 50 (transparency) · ISO/IEC 42001 · NIST AI RMF (Map) · CSA AICM · OWASP Agentic ASI10.

Layer 03: Evals & Red Teaming as Evidence

What it proves. That the model or agent passed a defined test whose failure has consequences. This is the layer where the principle "give every control teeth" becomes concrete for evals: a benchmark that only informs a committee is not a control; an eval wired into an **eval gate** that can fail the build is. The proof is a structured eval result: pass or fail against a threshold, versioned alongside the model it tested.

The artefacts. An engineer ships eval suites and the gate that runs them. Three families recur: capability and quality evals (does the system do its job: groundedness, regression against a golden set), adversarial and red-team evals (does it resist jailbreaks, prompt injection, tool misuse), and safety-threshold evals tied to a policy from layer 01 (a PII-leakage bound, an injection-resistance floor). The gate is a pipeline stage: if the eval drops below the agreed threshold, the pipeline fails and the release does not ship.

Reference tools and standards (illustrative). Evaluation frameworks such as Inspect (maintained on behalf of the UK AI Security Institute [7]), promptfoo and DeepEval run capability and regression suites; Garak, Mindgard and Giskard run adversarial and vulnerability probes; Ragas covers retrieval-augmented quality. Adversarial testing is not only good practice: the GPAI Code of Practice lists adversarial testing and red-teaming among the evaluation approaches expected of GPAI models with systemic risk, though the Code is voluntary and scoped to those models [8]. The eval result is the evidence artefact that layer 05 will aggregate, which is why it must be machine-readable, not a screenshot pasted into a slide.

Definition of done.

- Each model or agent has an eval suite versioned in the same repository and updated when the system changes.
- At least one adversarial eval and one capability eval run in CI, with a documented threshold.
- A failing eval blocks the deploy; the gate has teeth, not just a report.
- Every eval run emits a structured result (suite id, model version, score, threshold, pass/fail, timestamp) filed against the registry entry.
- Thresholds trace to a named failure mode or obligation, not to a round number chosen for comfort, and the certainty they demand follows the risk tier (chapter 11 sets the [certainty required by risk tier](#); chapter 14 sizes the suite for the [statistical validity of evals](#)).

Anti-patterns.

- The one-off pre-launch evaluation whose results are pasted into a slide and never re-run when the model or its prompts change.
- The "risk review board" that rates findings low/medium/high monthly but has no mechanism to stop a launch already scheduled: recommendation without consequence. The fix is a committee that decides what code cannot while the gates enforce the decision ([the committee decides](#), [the gates enforce](#), chapter 12), with the risk appetite [compiled into gates](#) (chapter 13).

Evidence to the next layer. An eval proves the system was safe *at test time*. The system then meets inputs no eval anticipated. Layer 04 carries the same thresholds into production as runtime guardrails, and the eval result becomes the baseline that runtime telemetry is compared against. A drop in live injection-resistance against the tested baseline is a signal, not a surprise.

In practice A red-team eval suite combining Inspect and Garak ran in CI for `csa-01`; a release that dropped its injection resistance below the agreed floor failed the pipeline until fixed. The eval's output, not a reviewer's opinion, was the assurance evidence filed against the model version.

Maps to: EU AI Act Art. 15 (accuracy, robustness, cybersecurity), Art. 55 (GPAI systemic-risk evaluation) · ISO/IEC 42001 · NIST AI RMF (Measure) · CSA AICM · OWASP Agentic ASI01/ASI02.

Layer 04: Runtime Controls & Observability

What it proves. That the controls hold while the system is acting, and that its behaviour is observed. Policies and evals are point-in-time; agents act continuously, on inputs no one reviewed. This layer proves that a guardrail mediated a real call, that an agent acted under its own identity and scope, and that there is a tested way to stop it. The proof is a stream of runtime decisions and traces.

The artefacts. Three groups. Guardrails: input/output filters, tool-call mediation, the enforcement point where a policy from layer 01 fires against a live request. Observability: tracing and monitoring that turn agent behaviour into a control signal. Agent runtime identity: every non-human actor with its own workload identity, a bounded scope, and a **kill switch**, a tested way to revoke access and stop an agent without breaking the fleet. Register and bound every actor before it acts: no agent acts before it has an identity, an owner and a scope. A **guardian agent**, an agent whose job is to review, constrain or stop other agents at runtime, is one way to build the mediation point; it is itself an agent, so it needs its own identity, scope and kill switch, and its decisions are evidence like any other guardrail's [16]. Chapter 23 treats [governing AI agents](#) end to end, including [identity](#), [delegation](#) and [MCP authorization for agents](#).

Reference tools and standards (illustrative). Guardrail frameworks such as NVIDIA NeMo Guardrails, Meta LlamaFirewall and Lakera enforce input/output and tool-call policy; observability tools such as Langfuse and Arize Phoenix build on OpenTelemetry to trace agent runs. Agent identity has two distinct questions the tools should not be allowed to blur. The first is **channel**

authentication: how a client authenticates to a tool server on one hop. The Model Context Protocol specification of 2026-07-28 tightened exactly this: deprecating Dynamic Client Registration in favour of Client ID Metadata Documents and binding credentials to their issuer [9]. That hardens the MCP connection; it is not the identity model for the agent. The second is **agent workload identity:** a durable, attributable identity the agent carries across every hop, tool and protocol, under which its actions are logged and its access revoked. That is the job of a workload-identity system, such as SPIFFE/SPIRE or first-class agent identities from enterprise providers (for example Microsoft Entra Agent ID, Okta Agent SSO), not of MCP, which secures one channel. Conflating the two leaves an agent well-authenticated on the MCP hop and still unattributable everywhere else. NIST's NCCoE set out the open questions in its February 2026 concept paper on software and AI agent identity and authorization: how identification, authentication and authorization apply so each agent is "known, trusted, and properly governed", including non-repudiation and tamper-proof logging [10]. Gartner expects that by 2029 more than half of successful attacks on AI agents will exploit access-control weaknesses and prompt injection [11], the failure modes this layer exists to contain.

Definition of done.

- Every agent runs under its own identity with a declared scope; no agent shares a service account or a static key across functions.
- A guardrail mediates tool calls and input/output for each agent, enforcing the scope declared in the registry.
- A kill switch exists and has been tested: revoking one agent's access does not break the others.
- Every agent run is traced, and traces carry the agent identity, the tools called and the policy verdicts that fired.
- Runtime signals are compared against the eval baseline from layer 03, and a regression raises an alert.

Anti-patterns.

- A fleet of agents sharing one API key and one privileged service account: an incident means rotating one secret and breaking everything, and attribution is impossible.
- Guardrails that log but never block: observability mistaken for control, so the system watches itself fail in high resolution.

Evidence to the next layer. Every guardrail decision, trace and identity event is a timestamped, structured record. Layer 05 does not re-collect this evidence; it subscribes to it. Runtime is where continuous assurance gets its continuity: the difference between an attestation that a control existed and evidence that it fired, on a specific call, at a specific time.

In practice `csa-01` was issued a distinct workload identity with an owner and a declared scope, as was every other agent in the telco; when it misbehaved it was traced to its identity and revoked without touching the others. The kill switch was tested on a schedule. An untested kill switch is a claim, not a control.

Maps to: EU AI Act Art. 14 (human oversight), Art. 15 (robustness, cybersecurity), Art. 12 (logging) · ISO/IEC 42001 · NIST AI RMF (Manage) · CSA AICM · OWASP Agentic ASI02/ASI03/ASI10.

Layer 05: Assurance & Continuous Compliance

What it proves. That the controls below are working, continuously, and that the proof is machine-readable and audit-ready. This is where evidence stops being a by-product and becomes the product: the audit is a query, not a project. The proof is a live assurance store that any of the lower layers writes into and an auditor can read from.

The artefacts. Machine-readable evidence in a standard format; framework mappings generated from that evidence rather than maintained beside it; and the incident and reporting plumbing that turns a runtime signal into an obligation met on the clock. The organising format is `OSCAL`. Its stable substrate is NIST's native model: a control layer (`catalog` , `profile`), an implementation layer (`component-definition` , `system-security-plan`) and an assessment layer (`assessment-plan` , `assessment-results` , `POA&M`), with traceability from an assessment result back to the control it tested [15]. That model is the part to build on; the AI-specific additions on top are still forming. One proposed approach (a single 2026 preprint, not a standard) extends OSCAL with sixteen property extensions for lifecycle phase, enforcement semantics and risk traceability, in a three-layer compliance-as-code architecture that generates OSCAL assessment results automatically [12]. Treat it as an early answer to a real gap the authors name well: frameworks "such as the EU AI Act, ISO/IEC 42001, and NIST AI RMF specify what to assure but provide no executable format for how" [12]. The gap is what layer 05 closes; the native OSCAL assessment models close most of it today, with or without the extensions.

Reference tools and standards (illustrative). Evidence is emitted as OSCAL component and assessment artefacts; GRC and AI-governance suites (for example Vanta, Drata, OneTrust; `watsonx.governance`, Holistic AI, Saidot) aggregate and present it. Incident reporting maps to EU AI Act Art. 73 (serious incidents) and Art. 72 (post-market monitoring). As of 2026-09-24 no harmonised standard is cited in the EU's Official Journal [13], so an ISO/IEC 42001 certificate supports the Art. 17 quality management system but does not by itself satisfy it, and confers no presumption of conformity under Art. 40 [17].

Definition of done.

- Control results from layers 01–04 are emitted as machine-readable evidence (for example OSCAL) with timestamps and owners, continuously.

- Framework mappings are generated from the evidence, so a mapping cell that turns green points at a control that actually fired.
- An auditor's question is answered by a query against the evidence store, not an evidence-collection sprint.
- A serious-incident pipeline can detect, triage and report on the clock, with the Art. 73 timelines encoded, not remembered (chapter 17 walks [the response lifecycle](#)).
- The assurance store measures realised risk reduction (the failure-mode rate, the time-to-detect, the blast radius), not framework coverage.

Anti-patterns.

- The attestation binder assembled the week before an audit, describing controls as they were imagined to be, not as production behaved.
- A "compliance score" from a closed platform that cannot be traced to a single running control, whose data path stops at the spreadsheet import.

Evidence closes the loop. Assurance is not the top of a one-way ladder. A drop in a live metric feeds back to layer 03 as a new eval, to layer 01 as a tightened policy, and to layer 02 as a registry flag. The stack is a loop that happens to be drawn as a ladder.

In practice csa-01 's guardrail decisions, eval results and policy verdicts streamed into an assurance store with timestamps, so a control's status was a live query, not an annual sign-off. When an auditor asked what its data-residency control did in the second quarter, the answer was a filter over emitted evidence, produced in minutes.

Maps to: EU AI Act Art. 17 (quality management), Art. 72 (post-market monitoring), Art. 73 (serious incident reporting) · ISO/IEC 42001, ISO/IEC 42005 · NIST AI RMF (Govern, Manage) · CSA AICM.

Data governance across the stack

The five layers govern models and agents; they are only as sound as the data underneath them, and data governance is not one layer but a thread through all five. Training data, fine-tuning sets, retrieval corpora, prompts and outputs each carry a lawful basis, a provenance, a retention limit and a set of rights, and each is an object the stack must be able to name. In layer 02 this is the **data card** and the lineage record (where a dataset came from, what it may be used for, when it must be deleted), attached to the registry entry beside the model card. In layer 01 it is retention-and-residency policy as code, with [privacy by design and privacy-enhancing technologies](#) (chapter 19) where personal data is involved. In layer 03 it is data-quality and bias tests run against the set, not assumed of it, behind a [dataset admission gate](#) (chapter 14); chapter 16 sets out [the data you need to test for bias](#). The EU AI Act treats this as a first-class duty: Article 10 requires representative, relevant and error-checked datasets for high-risk systems, and the post-Omnibus Article 4a gives a narrow lawful basis to process special-category data *for bias detection*, conditioned on pseudonymisation and deletion once bias is corrected (see chapter 08). The engineering commitment is that a RAG corpus is governed like a model: versioned, its provenance and licence recorded in the AIBOM, its snapshot tied to the eval that tested the system on it, so "what was in the corpus when this answer was produced?" is a query, not a guess. Prompts, retrieved passages and outputs at run time need the same rules ([inference-time data governance](#), chapter 15). Data with no card, no lineage and no retention rule is the ungoverned object that makes every layer above it unprovable.

Designing human oversight (Article 14)

Human oversight is a control to be engineered, not a reassurance to be asserted. EU AI Act Article 14 requires that high-risk systems be designed so a person can *effectively* oversee them (understand the output, decide against it, and stop the system), and the hard part is that undifferentiated oversight fails in both directions. Human review of every action destroys the value of automation; nominal oversight of a firehose of actions is a rubber stamp, and a rubber stamp is worse than none because it launders the decision. Two failure modes have to be designed against explicitly. **Automation bias:** a reviewer who sees a confident machine output will tend to confirm it, so oversight that only offers "approve/reject" on the model's proposal is oversight in name only. **Oversight that degrades:** a gate that a person can clear in two seconds under load will be cleared in two seconds, and its quality falls silently as volume rises. The engineering answer is to classify actions by consequence and place a designed checkpoint only where the stakes justify the latency (the **Human-in-the-loop Gate** pattern in chapter 05), giving the reviewer enough context to disagree, logging the approver and the decision as evidence, and monitoring the oversight itself (approval rate, time-to-decide, override rate) as a signal that can degrade. Oversight you do not measure is oversight you cannot claim. The EU High-Level Expert Group's [human-in-the-loop, on-the-loop and in-command](#) approaches (chapter 22) name the placement choices, and chapter 16 tests whether explanations actually help reviewers resist automation bias ([testing explanation quality](#)).

Third-party and procured AI

Most organisations do not train the models they run. They buy SaaS with an embedded LLM, call an API-only foundation model, or inherit an agent inside a vendor's product; for those, the parts of the stack that assume you own the model degrade. You cannot red-team weights you cannot reach, and an **eval gate** (layer 03) can only test the vendor's system as a black box, at its

boundary, not its internals. Runtime control (layer 04) narrows to what the integration exposes: the tool scopes you grant, the identity you issue the vendor's agent, the traffic you can observe, not the model's own behaviour. The layers do not disappear, but layer 03 shrinks to boundary evals and reliance on the vendor's own evidence, and layer 04 shrinks to the perimeter you control. What grows to compensate is inventory and assurance: the vendor's system still needs a registry entry, an owner and a scope; its supplier documentation, model card and any AIBOM become evidence you collect rather than produce; and the due-diligence itself becomes a gate, written into a [third-party AI policy](#) (chapter 12). This is the **Vendor / Model Due-Diligence Gate** pattern (chapter 05), anchored in ISO/IEC 42001 Annex A.10 (third-party and customer relationships) and the EU AI Act's split of duties between provider and deployer (see chapter 08, and [who you are in the value chain](#) in chapter 18). The rule of thumb: the less of the model you own, the more of your control budget moves from testing it to bounding it and evidencing the supplier. Chapter 15 covers the [build, buy or adapt](#) decision and its evidence burden, and chapter 20 the [licences and indemnities of procured models](#).

The cost of the stack

None of this is free, and a FinOps line is part of governing it honestly. The recurring costs are compute for eval suites run on every change (adversarial suites are the expensive ones, and running them on each commit rather than each release is a real bill), storage and egress for traces and the evidence store (agent traces are verbose, and continuous assurance means keeping them long enough to answer an audit), and the engineering time to maintain suites, thresholds and integrations as the systems move. The costs scale with change frequency and trace volume, so the levers are obvious once named: sample or tier expensive evals by risk, set retention by obligation rather than by default, and push the cheapest controls (a policy check, an identity gate) to the front where they catch failures before an expensive eval runs. A stack whose running cost no one tracks is a stack that will be cut in the first budget round, which is its own governance failure.

The minimum viable stack for a team of one

Most AI governance functions are small, and many are a single person: in the adjacent GRC discipline, roughly half of teams are four people or fewer and nearly one in five (18.5%) is a team of one [14]. A team of one cannot build all five layers at depth, but it can build the spine thinly, end to end: one vertical slice that touches every layer beats one layer built out and four left on paper. Start where the leverage is highest and the cost is lowest:

- **Layer 02 first, minimally.** A registry that a deploy writes to, with an owner and a scope per entry. If you can answer "what is running and who owns it?" from a live source, you have more than most.
- **One policy in layer 01 with teeth.** A single rule that matters (no deploy without a registered owner, or a data-residency check), as code, in the pipeline, blocking on failure. One control that bites beats a hundred that recommend.
- **One eval gate in layer 03.** One adversarial eval against your highest-risk agent, wired so a regression fails the build. Reuse an open framework; do not write your own harness.
- **Identity and a kill switch in layer 04.** Every agent under its own identity with a scope, and a tested way to stop it. This is the cheapest control with the largest blast-radius reduction.
- **Evidence as a by-product in layer 05.** Have each of the above emit a structured, timestamped record into one store. You are not building an OSCAL pipeline yet; you are refusing to rely on screenshots.

The order is deliberate: see it, rule it, test it, contain it, prove it. A thin vertical slice answers all three questions for one system today and widens as the team grows. The alternative, a thick layer 01 of policies with no inventory beneath them, answers none of the three questions, and is exactly the framework theatre the discipline exists to end. How much of the risk loop a small function runs is set by chapter 13's [tailoring matrix](#).

One system through the five layers

`csa-01`, the customer-service assistant from the boxes above, is one system, not five. Below is the single artefact it produces at each layer: short excerpts of the schemas defined in chapter 05, each illustrative. Full JSON Schemas with filled examples for these records, and [how to use them](#), are on the templates page.

Layer 01: Govern-as-Code. A Policy Card verdict (illustrative):

```
{ "rule_id": "residency.eu-only.v3", "decision": "deny",  
  "input_hash": "sha256:9f2b...", "timestamp": "2026-09-18T14:07:11Z" }
```

Layer 02: Inventory & Transparency. Its registry entry (illustrative):

```
{ "id": "csa-01", "owner": "team-support-platform",  
  "scope": ["refunds:read", "orders:read"], "expiry": "2026-12-17" }
```

Layer 03: Evals & Red Teaming as Evidence. An eval-gate result (illustrative):

```
{ "suite_id": "injection-resistance.v4", "model_version": "csa-01@2026-09-18",  
  "score": 0.982, "threshold": 0.95, "result": "pass" }
```

Layer 04: Runtime Controls & Observability. A guardrail event (illustrative):

```
{ "agent": "csa-01", "direction": "output", "rule_id": "output.pii.v2",  
  "decision": "block", "timestamp": "2026-09-18T14:31:52Z" }
```

Layer 05: Assurance & Continuous Compliance. The evidence record it emits (illustrative):

```
{ "control_id": "guardrail.output.pii.v2", "subject": "csa-01@2026-09-18",  
  "decision": "alert", "obligation": "EU AI Act Art. 15",  
  "timestamp": "2026-09-18T14:31:52Z" }
```

The five excerpts are one data path from policy to proof, keyed on the same registry id.

What you can do this week

1. **Draw one slice.** Pick one system and write down, for each of the five layers, the one artefact it produces today and the one it lacks. The gaps are your backlog, in build order.
2. **Wire the registry to the deploy.** Make one deployment pipeline write the registry entry (id, owner, scope, expiry) and fail when a field is empty.
3. **Give one policy teeth.** Move one rule that matters, a registered owner or a data-residency check, into code in the pipeline, blocking on failure, and log every verdict with its rule id.
4. **Gate one release on one eval.** Put one adversarial eval against your highest-risk agent in CI, with a threshold traced to a named failure mode, so a regression fails the build.
5. **Drill one stop and keep the record.** Trip the kill switch on one agent in staging, time the stop, and check that the stop and the guardrail events reached one evidence store, keyed to the registry id.

Sources

[1] "What is GRC Engineering" (Ayoub Fandi; "theatre with extra steps"). GRC Engineer. 2025. <https://grcengineer.com/what-is-grc-engineering/> (verified: primary) [2] Top 10 for Agentic Applications 2026. OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [3] Policy Cards: Machine-Readable Runtime Governance for Autonomous AI Agents (arXiv 2510.24383). 2025-10. <https://arxiv.org/abs/2510.24383> (verified: primary) [4] AI Risk Management Framework (AI RMF 1.0). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary) [5] AI Controls Matrix (AICM) v1.1 (247 control objectives across 18 domains). Cloud Security Alliance. 2026-06-22. <https://cloudsecurityalliance.org/artifacts/ai-controls-matrix-v1-1> (verified: primary) [6] "Evolving AI Transparency: the AIBOM generator's new home at OWASP" (CycloneDX output). OWASP GenAI Security Project. 2025-12-18. <https://genai.owasp.org/2025/12/18/evolving-ai-transparency-the-journey-of-the-aibom-generator-and-its-new-home-at-owasp/> (verified: primary) [7] Inspect: a framework for large language model evaluations (UK AI Security Institute). GitHub. 2026. https://github.com/UKGovernmentBEIS/inspect_ai (verified: primary) [8] General-Purpose AI Code of Practice, Safety and Security chapter (examples of model evaluation methods include "red-teaming and other methods of adversarial testing"; systemic-risk models only; voluntary; published 10 Jul 2025). European Commission. 2025-07-10. <https://ec.europa.eu/newsroom/dae/redirection/document/118119> (verified: primary) [9] Model Context Protocol specification 2026-07-28 (DCR deprecated in favour of CIMD; issuer-bound credentials). MCP. 2026-07-28. <https://blog.modelcontextprotocol.io/posts/2026-07-28/> (verified: primary) [10] "Accelerating the Adoption of Software and AI Agent Identity and Authorization" (concept paper; "known, trusted, and properly governed"). NIST NCCoE. 2026-02-05. <https://www.nccoe.nist.gov/news-insights/new-concept-paper-identity-and-authority-software-agents> (verified: primary) [11] "Gartner Forecasts the Market for Securing AI Will Reach Almost \$5 Billion in 2027" (>50% of agent attacks exploit access-control and prompt injection by 2029). Gartner. 2026-08-26. <https://www.gartner.com/en/newsroom/press-releases/2026-08-26-gartner-forecasts-the-market-for-securing-ai-will-reach-almost-5-billion-in-2027> (verified: primary) [12] "Making AI Compliance Evidence Machine-Readable" (OSCAL + 16 property extensions; three-layer compliance-as-code) (arXiv 2604.13767). UC3M. 2026-04-15. <https://arxiv.org/abs/2604.13767> (verified: primary) [13] Standardisation of the AI Act (no harmonised standard yet referenced in the Official Journal; page last updated 2026-08-03; no Commission implementing decision citing one found in the Publications Office index on 2026-09-24). European Commission. 2026-08-03. <https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation> (verified: primary) [14] State of GRC 2026 (~51% of GRC teams ≤4 people; ~18.5% solo). GRC Engineer. 2026. <https://grcengineer.com/report/> (verified: primary) [15] OSCAL native model (control layer: catalog, profile; implementation: component-definition, system-security-plan; assessment: assessment-plan, assessment-results, POA&M). NIST. 2026. <https://pages.nist.gov/OSCAL/learn/concepts/layer/> (verified: primary) [16] "Gartner Predicts that Guardian Agents will Capture 10-15% of the Agentic AI Market by 2030" (guardian agents: AI-based technologies that review, monitor and redirect or block agent

actions). Gartner. 2025-06-11. <https://www.gartner.com/en/newsroom/press-releases/2025-06-11-gartner-predicts-that-guardian-agents-will-capture-10-15-percent-of-the-agentic-ai-market-by-2030> (verified: primary) [17] CSA research note on the EU AI Act, prEN 18286 and ISO/IEC 42001 (ISO/IEC 42001 alone does not satisfy the AI Act and is not a harmonised standard; EN 18286 targets the Art. 17 QMS). Cloud Security Alliance. 2026-04-28. <https://labs.cloudsecurityalliance.org/research/csa-research-note-eu-ai-act-pren-18286-iso-42001-20260428-cs/> (verified: secondary)

05. Patterns

A catalogue of reusable AI governance engineering patterns, each named to a layer of the stack, in the CSIRO Responsible AI Pattern Catalogue structure.

This chapter is the catalogue. Each pattern is a reusable solution to a problem that recurs when you engineer the governance of AI systems. The structure follows the CSIRO Responsible AI Pattern Catalogue, which applies software-engineering design patterns to responsible AI across governance, process and product levels [1]. We keep its fields (summary, objectives, target users, impacted stakeholders, relevant principles, context, problem, solution, consequences, related patterns) and add a **Maps to** line naming the standards, articles and stack layer (1–5) each pattern serves.

Every pattern names one of the five layers ([chapter 04](#)) so the catalogue and the stack stay consistent, and realises one or more of the six principles ([chapter 03](#)): *build the control at the earliest point it can block · give every control teeth · register and bound every actor before it acts · instrument the build to produce its own proof · start from a named failure mode or harm · make the governed path the easiest path*. Each **Maps to** line draws its threat IDs from the OWASP Top 10 for Agentic Applications 2026 [2] and its function labels from the NIST AI RMF [3]; the development-side patterns also name OWASP Top 10 for LLM Applications 2026 and MITRE ATLAS ids, each sourced on its own page. Each pattern carries a short example labelled **(illustrative)**: a plausible, de-identified sketch, not a claim about any named system. Mappings to the EU AI Act are illustrative, not a claim of conformity, and as of 2026-09-24 no harmonised standard under the Act is referenced in the Official Journal [4].

On the website each pattern has its own page, listed by layer at [/patterns](#), with the full text, its diagram and its own numbered sources; this chapter keeps the template, the pattern map and, under each pattern's heading, a short summary that links to the full pattern. The printed edition carries every pattern in full in this chapter.

The pattern template

Every pattern page uses the same fields, in this order, and ends with its own **Sources** list.

Field	What it answers
Summary	What the pattern is and when it applies.
Objectives	The governance outcome the pattern achieves.
Target users	Who implements it.
Impacted stakeholders	Who is affected by it.
Relevant principles	Which of the six principles it realises.
Context	The situation in which the problem arises.
Problem	The forces at play, and the failure mode if the pattern is not applied.
Solution	How to build it: the artefacts, where they sit in the pipeline, what runs when.
Consequences	Benefits and trade-offs: cost, latency, false positives, maintenance.
Related patterns	The patterns it depends on or feeds.
Maps to	The standards, articles and stack layer the pattern serves.

A pattern is not a policy. Each one names the artefact an engineer ships, the point in the lifecycle where it runs and the evidence it leaves behind, so the pattern can fail a build or block an action rather than describe an intention.

Pattern: Policy Card

Summary: Express a governance rule as a machine-readable artefact that travels with the model or agent and is evaluated in the pipeline and at runtime, rather than as prose a human must apply. The Policy Card encodes permitted and prohibited actions, obligations and evidentiary requirements for one AI system, and links to the enforcement and audit pipelines that act on it [1].

Objectives

Turn a policy from a statement of intent into an executing control, versioned and testable, so that a rule change is a reviewable diff and every evaluation leaves a verdict.

Target users

AI governance engineer, platform team, policy owner.

Impacted stakeholders

Model owners, deployers, auditors, regulators.

Relevant principles

Build the control at the earliest point it can block; make the governed path the easiest path.

Context

An organisation with more than a handful of AI systems and a governance function that cannot review every change by hand. Rules exist but live in documents no pipeline can read.

Problem

Prose policy cannot be enforced automatically, drifts from the systems it governs, and leaves no evidence that it was applied. A rule that can only be remembered is violated the moment someone forgets.

Solution

Write each rule as a Policy Card: a structured, machine-readable artefact (for example expressed for an `OPA/Rego` or `Cedar` engine, or as a Policy Cards document) that states allow/deny logic, the failure mode it addresses and the framework clauses it maps to. Store it with the system it governs. Evaluate it pre-merge, at deploy, and (where the rule is a runtime constraint) at the point of action. Emit a verdict (rule id, input hash, decision, timestamp) on every evaluation.

Illustrative schema for the verdict:

```
{
  "rule_id": "residency.eu-only.v3",
  "decision": "deny",
  "input_hash": "sha256:9f2b...",
  "timestamp": "2026-09-18T14:07:11Z"
}
```

Example (illustrative) A Policy Card for a customer-service agent declares that it may call the refunds tool only up to a bounded amount and never outside business hours; the same card is evaluated in CI against the agent's declared scope and at runtime by the tool-call guardrail.

Consequences

Rules become enforceable and auditable, and the crosswalk generates itself. The cost is authoring and maintaining cards, and the discipline to keep the executable version authoritative over the prose.

Related patterns

[Framework Crosswalk](#); [Eval Gate in CI](#); [Runtime Guardrail](#); [Machine-Readable Evidence \(OSCAL\)](#); [Agent Identity & Scoped Credentials](#).

Maps to: EU AI Act Art. 9 · ISO/IEC 42001 · NIST AI RMF (Govern) · CSA AICM · OWASP Agentic ASI02/ASI03 · Layer 01 Govern-as-Code.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [2] and function labels the NIST AI RMF [3]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Policy Cards: machine-readable, deployment-layer governance artefacts for AI agents, linked to enforcement and audit pipelines (arXiv 2510.24383). 2025-10. <https://arxiv.org/abs/2510.24383> (verified: primary) [2] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [3] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Eval Gate in CI

Summary: Wire an evaluation suite into the CI/CD pipeline so that a model or agent must pass a defined test, above a documented threshold, before it can ship. The eval run is the control and its result is the evidence; a failing eval blocks the build.

Objectives

Make "give every control teeth" concrete: give a testable property a consequence, so failure stops a release instead of filing a finding.

Target users

AI governance engineer, ML engineer, platform team.

Impacted stakeholders

Model owners, users exposed to the system, auditors.

Relevant principles

Give every control teeth; build the control at the earliest point it can block.

Context

A model or agent that changes (retrained, re-prompted, given a new tool) and a pipeline that already runs tests for functional correctness.

Problem

Evaluations run once before launch and pasted into a slide prove nothing after the next change. A review board that can only rate findings cannot stop a scheduled launch. Without a gate, evaluation is research, not control.

Solution

Version an eval suite alongside the model. Run at least one capability eval and one adversarial eval in CI (for example with Inspect, promptfoo, Garak or Giskard; illustrative). Set a threshold that traces to a named failure mode or obligation. Fail the pipeline below the threshold. Emit a structured result (suite id, model version, score, threshold, pass/fail, timestamp) filed against the registry entry.

Illustrative schema for the result:

```
{
  "suite_id": "injection-resistance.v4",
  "model_version": "csa-01@2026-09-18",
  "score": 0.982,
  "threshold": 0.95,
  "result": "pass",
  "timestamp": "2026-09-18T14:22:03Z"
}
```

Example (illustrative) An internal coding agent must clear an injection-resistance floor and a regression suite before deploy; a release that drops resistance below the floor fails the pipeline and does not ship until fixed.

Consequences

Regressions are caught before production and evidence accrues automatically. The trade-off is eval maintenance, run-time cost in CI, and the need to tune thresholds to avoid flaky gates.

Related patterns

[Policy Card](#); [Adversarial Red-Team Suite](#); [Continuous Assurance Telemetry](#); [Machine-Readable Evidence \(OSCAL\)](#); [Model Card as Control Evidence](#).

Maps to: EU AI Act Art. 15, Art. 55 · ISO/IEC 42001 · NIST AI RMF (Measure) · OWASP Agentic ASI01/ASI02 · Layer 03 Evals & Red Teaming as Evidence.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [1] and function labels the NIST AI RMF [2]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [2] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Adversarial Red-Team Suite

Summary: Maintain a versioned adversarial test suite, built from a threat taxonomy and run in CI or on a schedule, whose findings are triaged into fixes or accepted risks, recorded as evidence, and fed back into the suite. Where an Eval Gate proves a threshold still holds, the red-team suite is the standing adversary that keeps finding the inputs the threshold never anticipated.

Objectives

Turn adversarial testing from a one-off exercise into a maintained, versioned control that discovers failure modes before an attacker does and leaves a triaged, auditable record of every finding.

Target users

AI governance engineer, security engineer, ML engineer, red-team lead.

Impacted stakeholders

Model owners, users exposed to the system, incident responders, auditors, regulators.

Relevant principles

Start from a named failure mode or harm; give every control teeth.

Context

A model or agent whose exposure grows as it gains tools, prompts and reach, in an organisation that already runs an Eval Gate for regression and wants a standing adversary rather than a single pre-launch penetration test.

Problem

A one-off red-team is out of date the moment the system changes, and its findings, a slide of jailbreaks, leave no trace that they were fixed or accepted. Without a versioned suite and a triage record, the same attack is rediscovered every quarter and no one can prove which findings were closed.

Solution

Build the suite from a threat taxonomy rather than intuition: draw techniques from MITRE ATLAS's adversarial tactics and techniques for AI systems [1] and the agentic attack classes in the OWASP Top 10 for Agentic Applications [2], so each test traces to a named technique. Version the suite alongside the model and run it in CI or on a schedule against the registered version. Route each finding through triage (fix, or accept with a recorded rationale and owner) and file the outcome as a structured evidence record against the registry entry. Feed every confirmed finding back into the suite as a regression test, so a closed attack stays closed. The suite complements the Eval Gate: the gate enforces a threshold on each release, the suite is the adversary that generates the next one.

Example (illustrative) A red-team suite for a customer-service assistant runs a versioned set of prompt-injection and tool-abuse cases drawn from ATLAS and the OWASP agentic classes; a new tool-exfiltration finding is triaged, fixed and added to the suite, so the next release must pass it.

From threat model to test plan

A suite built from a taxonomy still needs a reason for each case. That reason is the threat model of the system as deployed, and the step that turns one into the other is written down, so a reviewer can see why the suite contains what it contains and what it leaves out.

1. **Decompose the system.** Draw the data flows as they run: users, the application, retrieval, the model, the tools and their credentials, memory, and every downstream consumer of outputs. Mark each trust boundary, and mark which components you own and which a provider runs.
2. **Enumerate threats per element, by id.** Walk each element against the AI-specific catalogues: the OWASP Top 10 for LLM Applications 2026 for the model as a component [3], the OWASP Top 10 for Agentic Applications for tools, memory and delegation [2], MITRE ATLAS techniques for the attacker's path [1] and the NIST adversarial machine learning taxonomy for attacks on predictive and generative models, such as evasion, poisoning and privacy attacks [4]. NIST's secure development profile for generative AI asks for exactly this: risk modelling that includes AI-specific vulnerability and threat types ([PW.1.1](#)) [5]. Record each threat with its external id, so the model reads `LLM01:2026` or `AML.T0051`, not "injection risk".
3. **Name the control and the test that proves it.** For each threat in scope, write the control expected to stop it and the test that would fail if the control did not work. The test becomes a suite entry in the release's test plan, which validates against `test-plan.v1.json`: a versioned suite id, the category (`adversarial`, `security`, `privacy`), the metric, a threshold fixed before testing, the failure mode it guards against and whether a failure blocks the release.
4. **Tag every case with its threat ids.** A case carries the ids of the threats it exercises, and a finding inherits them, so a finding traces from technique to control to the eval that now guards it, and a coverage report can list the in-scope threats that no case exercises yet.
5. **Record what is out of scope, and why.** A threat the system cannot face (no tools, no memory, no personal data) is closed with a reason; a threat you cannot test (a provider's weights) is routed to the [Vendor / Model Due-Diligence Gate](#) as provider-attested evidence. Re-run the step when the data flows change: a new tool, a new corpus, a new model.

The [threat bridge](#) holds the result of steps 2 and 3 as open data: each row takes an external threat id to the patterns that control it, an example eval that tests it and the obligations the evidence helps satisfy.

```
# one entry of the test plan's `suites`, derived from a threat (illustrative)
suite_id: indirect-injection.v4
category: adversarial
metric: attack success rate on planted instructions in retrieved documents
threshold: "<= 0.02"
direction: lower_is_better
```

```
failure_mode: >-
  agent follows instructions found in retrieved content
  (LLM01:2026, ASI01, AML.T0051.001, NISTAML.015)
blocking: true
```

Consequences

Adversarial coverage grows over time instead of resetting each launch, and the triage record shows what was found, fixed or accepted. The cost is maintaining the taxonomy and suite, the compute to run adversarial cases often, and the discipline to triage every finding rather than let it lapse. The threat-model step adds its own upkeep: the model goes stale the day a tool or a corpus is added, so it has to be re-run on change, not once a year.

Related patterns

[Eval Gate in CI](#); [Runtime Guardrail](#); [Continuous Assurance Telemetry](#); [Incident Pipeline](#); [Vendor / Model Due-Diligence Gate](#).

Maps to: EU AI Act Art. 9, Art. 15, Art. 55 (GPAL) · ISO/IEC 42001 · NIST AI RMF (Measure) · OWASP Agentic ASI01/ASI02 · Layer 03 Evals & Red Teaming as Evidence.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [2] and function labels the NIST AI RMF [6]. Mappings are illustrative, not a claim of conformity.

Sources

[1] MITRE ATLAS: adversarial tactics and techniques knowledge base for AI systems (incl. agents). MITRE. 2026. <https://atlas.mitre.org/> (verified: primary) [2] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [3] OWASP GenAI LLM Top 10 2026 (LLM01 Prompt Injection to LLM10 Improper Output Handling; published 3 Aug 2026; canonical Markdown in github.com/GenAI-Security-Project/GenAI-LLM-Top10_2026/final). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [4] NIST AI 100-2 E2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations (predictive and generative AI attack classes with NISTAML identifiers). NIST. 2025-03-24. <https://csrc.nist.gov/pubs/ai/100/2/e2025/final> (verified: primary) [5] NIST SP 800-218A, Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile (recommendation R1 on SSDF 1.1 task PW.1.1: include AI model-specific vulnerability and threat types in risk modelling). NIST. 2024-07. <https://csrc.nist.gov/pubs/sp/800/218/a/final> (verified: primary) [6] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Agent Registry

Summary: Maintain a runtime-aware inventory of every model, service and agent, each entry carrying an owner, a scope and an expiry, fed by the deployment pipeline rather than typed by hand. The registry is the object that policies evaluate and runtime controls attach to.

Objectives

Answer "what AI is running, and what is it allowed to do?" from a live source, and make registration a precondition of reaching production.

Target users

AI governance engineer, platform team, security engineer.

Impacted stakeholders

Model owners, deployers, auditors, incident responders.

Relevant principles

Register and bound every actor before it acts; make the governed path the easiest path.

Context

An organisation deploying models and agents across teams, where no single source knows what is live.

Problem

A hand-maintained inventory is correct on the day it is edited and wrong within a week. Without owner, scope and expiry, an action cannot be attributed, a scope cannot be enforced, and a stale agent lingers with standing access no one revisits.

Solution

Make the registry an API the deploy pipeline writes to: a new model or agent registers itself at deploy with an owner, a declared scope and an expiry after which the entry must be renewed or is deactivated. Deny production access to unregistered artefacts. Reconcile periodically against what is actually running (see [Shadow-AI Discovery](#)) and flag drift.

Illustrative schema for a registry entry:

```
{
  "id": "csa-01",
  "version": "2026-09-18",
  "owner": "team-support-platform",
  "scope": ["refunds:read", "orders:read"],
  "expiry": "2026-12-17"
}
```

Example (illustrative) Each agent's registry entry expires after 90 days; an owner who does not renew loses the agent's workload identity, so abandoned agents fall out of production automatically.

Consequences

Attribution, scope enforcement and lifecycle control become possible, and every other layer gets an object to anchor to. The cost is pipeline integration and the governance to enforce the expiry.

Related patterns

[Agent Identity & Scoped Credentials](#); [AIBOM](#); [Shadow-AI Discovery](#); [Kill Switch / Circuit Breaker](#).

Maps to: EU AI Act Art. 49/71, Art. 11 · ISO/IEC 42001 · NIST AI RMF (Map) · CSA AICM · OWASP Agentic ASI10 · Layer 02 Inventory & Transparency.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [1] and function labels the NIST AI RMF [2]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [2] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: AIBOM

Summary: Generate an AI bill of materials at build for each AI system, recording models, datasets, weights and their provenance in a standard format, and store it with the registry entry. The AIBOM is what the transparency and eval layers read to know what to document and what to test.

Objectives

Make the composition and provenance of an AI system machine-readable, so supply-chain risk and transparency obligations can be answered from an artefact, not reconstructed.

Target users

AI governance engineer, ML engineer, security engineer.

Impacted stakeholders

Model owners, downstream deployers, auditors, procurement.

Relevant principles

Instrument the build to produce its own proof; start from a named failure mode or harm.

Context

AI systems assembled from foundation models, fine-tunes, third-party datasets and libraries, where the classic SBOM captures software dependencies but not models or data.

Problem

Without a bill of materials for models and data, an organisation cannot answer which model version, from which provenance, trained on which data, is inside a given system, so it cannot assess supply-chain risk or produce transparency documentation on demand.

Solution

Emit an AIBOM at build in a standard format, CycloneDX ML-BOM or the SPDX 3.0 AI profile, for example with the OWASP AIBOM generator [1] (illustrative), covering models, datasets, weights, and their provenance and licences. Attach it to the registry entry

and regenerate it on each build so it never drifts from the deployed system.

Example (illustrative) A retrieval-augmented assistant's AIBOM lists the base model, the embedding model, the corpus snapshot and their licences; when a corpus licence changes, the diff surfaces in the next build's AIBOM.

Consequences

Supply-chain and provenance questions become queries; transparency documents can be generated from the AIBOM. The cost is toolchain integration and keeping provenance metadata accurate.

Related patterns

[Agent Registry](#); [Model Card as Control Evidence](#); [Machine-Readable Evidence \(OSCAL\)](#).

Maps to: EU AI Act Art. 11, Art. 53 (GPAI documentation) · ISO/IEC 42001 · NIST AI RMF (Map) · CSA AICM · Layer 02 Inventory & Transparency.

Function labels follow the NIST AI RMF [2]. Mappings are illustrative, not a claim of conformity.

Sources

[1] "Evolving AI Transparency: the AIBOM generator's new home at OWASP" (CycloneDX output). OWASP GenAI Security Project. 2025-12-18. <https://genai.owasp.org/2025/12/18/evolving-ai-transparency-the-journey-of-the-aibom-generator-and-its-new-home-at-owasp/> (verified: primary) [2] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Model Card as Control Evidence

Summary: Treat the model card and data card not as launch documentation written once, but as structured evidence regenerated from the pipeline, so that transparency documents describe the system as it is now and feed the assurance layer.

Objectives

Convert transparency documentation from a static PDF into a versioned artefact that is both human-readable and machine-consumable, and that counts as control evidence.

Target users

AI governance engineer, ML engineer, DPO.

Impacted stakeholders

Model owners, users, auditors, data subjects.

Relevant principles

Instrument the build to produce its own proof; make the governed path the easiest path.

Context

A system subject to transparency obligations, where cards are traditionally written at launch and never touched again.

Problem

A model card written once decays into fiction as the model, prompts and datasets change. A card that is not regenerated cannot be trusted as evidence and misleads the very auditor it was meant to satisfy.

Solution

Template the card and populate it from the pipeline: intended use, evaluation results (from the Eval Gate), datasets (from the AIBOM), known limitations and owner. Regenerate on each significant change and version it with the model. Store the card as structured data so it can be both read by a person and consumed by the assurance layer.

Example (illustrative) A classifier's card is rebuilt on every deploy, pulling its latest fairness-eval scores and dataset provenance automatically, so the card an auditor reads is the card production produced.

Consequences

Transparency stays true and doubles as evidence. The cost is templating and pipeline wiring, and agreeing what "significant change" triggers a regeneration.

Related patterns

[AIBOM](#); [Eval Gate in CI](#); [Machine-Readable Evidence \(OSCAL\)](#); [FRIA-as-Code](#).

Maps to: EU AI Act Art. 11, Art. 13 (transparency) · ISO/IEC 42001, ISO/IEC 42005 · NIST AI RMF (Map, Measure) · Layer 02 Inventory & Transparency.

Function labels follow the NIST AI RMF [1]. Mappings are illustrative, not a claim of conformity.

Sources

[1] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Continuous Assurance Telemetry

Summary: Stream control decisions (policy verdicts, eval results, guardrail actions, identity events) into an assurance store as they happen, so the status of a control is a live query rather than a point-in-time attestation. Trustworthiness becomes a continuously generated signal, not a static certificate [1].

Objectives

Replace periodic attestation with evidence emitted as the system runs, so "is the control working?" is answered by telemetry.

Target users

AI governance engineer, SRE/platform team, auditor.

Impacted stakeholders

Model owners, auditors, regulators, incident responders.

Relevant principles

Instrument the build to produce its own proof; give every control teeth.

Context

A stack whose lower layers already emit structured records, and an assurance function tired of assembling binders before each audit.

Problem

An attestation says a control existed when someone looked; it says nothing about the weeks in between, during which the model was retrained and an agent gained a tool. Point-in-time evidence decays immediately.

Solution

Have each control write a timestamped, structured record to a common assurance store, on one schema. Fix the schema first: a minimum useful evidence record is `{control_id, subject (model/agent/system id + version from the registry), decision (pass/fail/allow/deny/alert), metric + value + threshold, failure_mode/obligation ref, input_hash, actor, timestamp, signature}`. Normalise every tool's output into that shape on ingest, so heterogeneous sources compose into one queryable store keyed on the registry id.

Illustrative schema for the evidence record:

```
{
  "control_id": "guardrail.output.pii.v2",
  "subject": "csa-01@2026-09-18",
  "decision": "alert",
  "metric": "pii_leak_rate", "value": 0.004, "threshold": 0.0,
  "obligation": "EU AI Act Art. 15",
  "input_hash": "sha256:1c7d...",
  "actor": "csa-01",
  "timestamp": "2026-09-18T14:31:52Z",
  "signature": "ed25519:5a..."
}
```

Two research proposals point at the same idea and are worth watching, not adopting whole: TAIP treats NIST TEVV outputs as reusable AI Assurance Objects that compose across systems [1], and AAGATE operationalises a control plane aligning the NIST AI RMF functions for agents in production [2]; both are single preprints. Expose the current status of each control as a query over the store.

Example (illustrative) A dashboard tile for the data-residency control is backed by a live query over emitted guardrail decisions; if the control stops firing, the tile goes red within minutes, not at the next audit.

Consequences

The audit becomes a query and drift is visible in near real time. The cost is building the pipeline and storage, and defining a common evidence schema across tools.

Related patterns

[Machine-Readable Evidence \(OSCAL\)](#); [Eval Gate in CI](#); [Runtime Guardrail](#); [Incident Pipeline](#); [Kill Switch / Circuit Breaker](#).

Maps to: EU AI Act Art. 72 · ISO/IEC 42001 · NIST AI RMF (Manage, Govern) · CSA AICM · Layer 05 Assurance & Continuous Compliance.

Function labels follow the NIST AI RMF [3]. Mappings are illustrative, not a claim of conformity.

Sources

[1] TAIP: NIST TEVV outputs as reusable AI Assurance Objects; trustworthiness as a continuously generated signal (arXiv 2603.03340; submitted 15 Feb 2026). 2026-02. <https://arxiv.org/abs/2603.03340> (verified: primary) [2] AAGATE: NIST AI RMF-aligned, Kubernetes-native governance control plane for agentic AI (arXiv 2510.25863). 2025-10. <https://arxiv.org/abs/2510.25863> (verified: primary) [3] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Runtime Guardrail

Summary: Place input and output guardrails on the model or agent's runtime path that enforce its Policy Card on every live request and emit a decision to telemetry and to the circuit breaker. The guardrail is where a policy written in layer 01 and a threshold tested in layer 03 become an action taken on a real call, not a claim about one.

Objectives

Enforce policy at the point of action, on inputs and outputs no eval anticipated, and make each enforcement a structured event the assurance and incident layers can consume.

Target users

AI governance engineer, ML engineer, security engineer, platform team.

Impacted stakeholders

Users, model owners, affected persons, incident responders, auditors.

Relevant principles

Give every control teeth; instrument the build to produce its own proof.

Context

An agent or model in production, acting on live inputs, whose Policy Card and eval thresholds exist but have no runtime enforcement point, so a rule proven in CI is unguarded the moment the system meets an input no test covered.

Problem

Policies and evals are point-in-time; the system then meets prompt injection, unsafe outputs and tool calls no one reviewed. A guardrail that only logs is observability mistaken for control: the system watches itself fail in high resolution. Without an enforcement point that can block and emit, the runtime is the gap between a tested control and an uncontrolled action.

Solution

Put a guardrail on both sides of the model/agent path. The input guardrail screens prompts and retrieved context for injection and policy-violating requests before they reach the model; the output guardrail screens generations and tool calls for unsafe content, data leakage and out-of-scope actions before they take effect. Enforce the same Policy Card evaluated in CI [1], so the runtime decision and the pipeline decision share one rule. On every call emit a structured event, `{agent, direction (input/output), rule_id, decision (allow/block/redact), timestamp}`, to the assurance store ([Continuous Assurance Telemetry](#)) and, on a defined breach, signal the circuit breaker ([Kill Switch / Circuit Breaker](#)). Guardrail frameworks realise this as a category; the OWASP Agent Control Standard names the runtime-control surface [2]. This is distinct from the kill switch: the guardrail decides one call at a time and stays in the request path; the breaker withdraws the agent's autonomy wholesale when the guardrail's signals cross a threshold.

Example (illustrative) A customer-service assistant's input guardrail blocks a prompt-injection attempt and its output guardrail redacts an account number the model was about to return; both decisions are emitted to the assurance store, and a burst of blocks trips the circuit breaker.

Consequences

The tested control holds on live traffic and every enforcement leaves evidence; the guardrail is also the sensor the breaker and the incident pipeline read. The cost is per-call latency, false positives to tune, and keeping the runtime rule in sync with the Policy Card and eval thresholds.

Related patterns

[Policy Card](#); [Kill Switch / Circuit Breaker](#); [Agent Identity & Scoped Credentials](#); [Continuous Assurance Telemetry](#); [Human-in-the-loop Gate](#); [Eval Gate in CI](#).

Maps to: EU AI Act Art. 14, Art. 15 · ISO/IEC 42001 · NIST AI RMF (Manage) · OWASP Agentic ASI02/ASI03 · Layer 04 Runtime Controls & Observability.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [3] and function labels the NIST AI RMF [4]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Policy Cards: machine-readable, deployment-layer governance artefacts for AI agents, linked to enforcement and audit pipelines (arXiv 2510.24383). 2025-10. <https://arxiv.org/abs/2510.24383> (verified: primary) [2] OWASP GenAI Security Project unveils the Agent Control Standard (ACS) and 2026 Top 10 for LLM Applications. OWASP GenAI Security Project. 2026-09-01. <https://genai.owasp.org/2026/09/01/owasp-genai-security-project-unveils-2026-top-10-for-llm-applications-new-agent-control-standard-and-sponsors-as-community-tops-30000-members/> (verified: primary) [3] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [4] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Kill Switch / Circuit Breaker

Summary: Provide a tested mechanism to stop an agent or class of agents at the point of action, revoking access and halting tool calls, without breaking the rest of the fleet. Autonomy is granted only where it can be withdrawn.

Objectives

Bound the blast radius of a misbehaving or compromised agent, and make "stop it" a control that has been exercised, not a claim.

Target users

AI governance engineer, security engineer, SRE.

Impacted stakeholders

Model owners, users, incident responders, affected third parties.

Relevant principles

Register and bound every actor before it acts; start from a named failure mode or harm.

Context

Agents that act autonomously (calling tools, moving data or money), where a single failure can cascade. Gartner expects that by 2029 more than half of successful attacks on AI agents will exploit access-control weaknesses and prompt injection [1].

Problem

An agent that cannot be stopped precisely can only be stopped by breaking everything. A fleet on shared credentials means an incident forces a choice between leaving the agent running and rotating a secret that halts the whole fleet.

Solution

Bind each agent to its own identity (see [Agent Identity & Scoped Credentials](#)) so access can be revoked per agent. Implement a circuit breaker at the tool-call boundary that trips on a defined signal: a threshold breach, an anomaly, a manual pull. Test the kill switch on a schedule; an untested kill switch is not a control.

Example (illustrative) A payments agent's circuit breaker trips automatically when its unauthorised-tool-call rate crosses a threshold, revoking just that agent's scope while the rest of the fleet keeps running; the pull is drilled monthly.

Consequences

Incidents are contained to one agent and recovery is fast. The cost is per-agent identity plumbing and the engineering to make revocation instant and safe.

Related patterns

[Agent Identity & Scoped Credentials](#); [Agent Registry](#); [Human-in-the-loop Gate](#); [Incident Pipeline](#).

Maps to: EU AI Act Art. 14, Art. 15 · ISO/IEC 42001 · NIST AI RMF (Manage) · CSA AICM · OWASP Agentic ASI02/ASI10 · Layer 04 Runtime Controls & Observability.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [2] and function labels the NIST AI RMF [3]. Mappings are illustrative, not a claim of conformity.

Sources

[1] "Gartner Forecasts the Market for Securing AI Will Reach Almost \$5 Billion in 2027" (>50% of agent attacks exploit access-control and prompt injection by 2029). Gartner. 2026-08-26. <https://www.gartner.com/en/newsroom/press-releases/2026-08-26-gartner-forecasts-the-market-for-securing-ai-will-reach-almost-5-billion-in-2027> (verified: primary) [2] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [3] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Incident Pipeline

Summary: Build the plumbing to detect, triage and report serious AI incidents on the clock, with reporting timelines and templates encoded rather than remembered. For high-risk systems this includes EU AI Act Article 73 serious-incident reporting; for GPAI models it includes the systemic-incident reporting the Code of Practice expects [1]. The same pipeline serves the deployer of a system someone else built: it tells the provider, suspends use when the system presents a risk, and holds the reporting clock when the provider cannot be reached.

Objectives

Turn a runtime signal into a reported obligation within the legal window, and produce the incident record as structured evidence. Keep issues and incidents apart, rank severity on a written scale, find the cause without blame, and feed every closed incident back into the controls.

Target users

AI governance engineer, security/incident responder, legal/compliance, DPO, the provider liaison of a deployer.

Impacted stakeholders

Regulators, affected persons, deployers, providers, model owners.

Relevant principles

Instrument the build to produce its own proof; start from a named failure mode or harm.

Context

A high-risk or GPAI system in production, subject to serious-incident reporting duties, where detection lives in engineering and reporting lives in legal, with no wire between them. Most organisations meet AI incidents as deployers of a procured system, so the pipeline has to work for a model they do not own as well as for one they built.

Problem

When an incident is detected, the clock starts. If detection, triage and reporting are disconnected manual steps, the deadline is missed and the evidence of what happened is reconstructed after the fact. A single "priority" field read one way by engineering and another by legal hides the reportability decision, and a post-mortem that hunts for someone to blame teaches people to report less.

Solution

Connect runtime detection (from observability and guardrails) to a triage workflow that classifies severity and, on a reportable event, drafts the report against the required template and starts the statutory timer. Encode the EU AI Act Art. 73 timelines and the Art. 72 post-market monitoring feed [2]; hold the incident record as machine-readable evidence. The five steps below are the parts that fail most often in practice; [chapter 17](#) treats each in depth.

Example (illustrative) A guardrail flags a data-exfiltration attempt via an agent tool; the pipeline classifies it, opens an incident with the Art. 73 timer running, and pre-fills the report from the trace and registry entry.

Issue or incident: two queues, one record type

An **issue** is a defect or control weakness with no event behind it: an eval that regressed in staging, a drift alert, a model card that no longer matches the deployed version. It goes to an issue log with an owner and a due date, and in ISO/IEC 42001 terms most issues are nonconformities handled under clause 10.2 [3]. An **incident** is an event in which the system led to harm; a **hazard** (or near miss) is one that could plausibly have led to harm and did not [4]. A **serious incident** under [Art. 3\(49\)](#) is the top of that ladder: death or serious harm to health, serious and irreversible disruption of critical infrastructure, an infringement of obligations

protecting fundamental rights, or serious harm to property or the environment [2]. Keep severity (an internal judgement about harm) and reportability (a test run once per regime) in separate fields, each set by a named person with a timestamp. The full definitions are in [chapter 17](#).

A severity scale mapped to the Art. 73 classes

Write the scale as policy and evaluate it as code when an incident opens, so the first classification and the clocks it starts are reproducible. The levels below are illustrative; what matters is that each names a harm test and the legal class it can trigger.

Level	Harm test	Art. 73 class it can trigger [2]	Default response
SEV-1	Death; serious and irreversible disruption of critical infrastructure; widespread infringement	Art. 73(4) death: no later than 10 days; Art. 73(3) : no later than 2 days	Contain first; legal and DPO on the bridge
SEV-2	Infringement of fundamental-rights obligations; serious harm to property or the environment	Art. 73(2) : no later than 15 days	Same working day; reportability assessed per regime
SEV-3	Realised harm below the serious thresholds	None on its own; check GDPR and sector regimes	Contain the same day; review within five working days
SEV-4	Near miss: a path to harm was interrupted	None	Weekly review; regression eval added
Issue	Defect or weakness, no event	None	Issue log with owner and due date

Classify up and downgrade with evidence: the deadlines run from awareness, and a reasonable likelihood of a causal link is enough to start them [2]. One event can start several clocks. A personal data breach inside an AI incident adds the GDPR notification to the supervisory authority, within 72 hours where feasible [5], so the record carries one reportability flag per regime (see [the overlapping clocks](#)).

The record: one schema, many reports

Hold each event as an incident record that validates against `incident-record.v1.json` (a fillable [Markdown template](#) sits beside it). The schema's `severity` field takes the OECD values (hazard, serious hazard, incident, serious incident, disaster) [4]; keep the internal SEV level beside it. The `reporting` block records when the organisation became aware and one entry per regime assessed, so every clock is a query, not a memory; `containment` records whether the kill switch was used; `root_cause_analysis` and `actions_taken` close the loop. Regulator-facing reports are rendered from the record, never retyped.

Root cause, CAPA and blameless review

Run the review on a trigger set in advance (every SEV-1 and SEV-2, a sample of the rest) and write it blameless: the question is which conditions let a reasonable person act as they did, not who erred [6]. Name the method (five whys, fault tree, timeline review) and a cause category in the record. The output is **CAPA** (corrective and preventive action): the corrective action fixes this instance, the preventive action stops the class of failure recurring anywhere in the fleet. Every closed incident leaves a regression eval in the [Eval Gate](#), a risk-register change and an evidence record that the fix was verified, as [chapter 17](#) sets out.

Tabletop drills

An untested playbook is a claim, not a control. Rehearse on a schedule, rotating the failure modes (an indirect prompt injection that exfiltrates data, drift into discriminatory outcomes, a vendor that silently swaps the model behind an API, an agent loop that burns budget), and time the steps that matter: to classify, to contain, to a draft report for each clock. The drill produces the same records a real incident would, tagged as a drill, so "can you report on time?" is answered by a query over drill results ([playbooks, RACI and drills](#)).

The deployer side: inform the provider, suspend use

A deployer of a high-risk system has three duties under [Art. 26\(5\)](#) [2]. It monitors the system on the basis of the instructions for use and informs the provider where relevant. Where it has reason to consider that use as instructed may present a risk, it informs the provider or distributor and the market-surveillance authority without undue delay and suspends use. Where it identifies a serious incident, it immediately informs the provider first, then the importer or distributor and the authority; if it cannot reach the provider, [Art. 73](#) applies to the deployer. Engineer each duty:

- **A provider channel on the registry entry**, with the contractual notification terms the [Vendor / Model Due-Diligence Gate](#) negotiated, tested in drills.
- **A suspension path for a system you do not own**: a feature flag or traffic switch to a human or legacy path, wired to the [Kill Switch / Circuit Breaker](#) and timed in drills.

- **A provider-facing export of the record** with the timestamp of each notification, and a fallback clock that starts the **Art. 73** timers on the deployer's own record when the provider is silent.
- **Log retention** under the deployer's control for at least six months (**Art. 26(6)**), longer while an incident is open [2].

Consequences

Reporting happens on time and the record is audit-ready. Severity and reportability stay separate, reviews teach instead of blame, and each closed incident hardens the controls through CAPA. The cost is cross-functional integration, drills that take people off other work, contractual notification terms that must be won from providers, and keeping the severity criteria and templates current with the law.

Related patterns

[Continuous Assurance Telemetry](#); [Runtime Guardrail](#); [Kill Switch / Circuit Breaker](#); [Machine-Readable Evidence \(OSCAL\)](#); [Eval Gate in CI](#); [Vendor / Model Due-Diligence Gate](#).

Maps to: EU AI Act Art. 72, Art. 73, Art. 55 (GPAI) · ISO/IEC 42001 · NIST AI RMF (Manage) · Layer 05 Assurance & Continuous Compliance.

Function labels follow the NIST AI RMF [7]. Mappings are illustrative, not a claim of conformity.

Sources

[1] General-Purpose AI Code of Practice, Safety and Security chapter, Commitment 9 (serious incident reporting for GPAI models with systemic risk). European Commission. 2025-07-10. <https://ec.europa.eu/newsroom/dae/redirection/document/118119> (verified: primary) [2] Regulation (EU) 2024/1689 (AI Act): Art. 3(49) serious incident; Art. 26(5)–(6) deployer monitoring, suspension, serious-incident information and log retention; Art. 72 post-market monitoring; Art. 73 reporting of serious incidents (73(2) no later than 15 days, 73(3) no later than 2 days, 73(4) no later than 10 days). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [3] ISO/IEC 42001:2023, AI management systems (clause 10.2 nonconformity and corrective action). ISO/IEC. 2023. <https://www.iso.org/standard/81230.html> (verified: secondary) [4] Towards a common reporting framework for AI incidents (OECD Artificial Intelligence Papers No. 34; AI incident and AI hazard; severity values hazard, serious hazard, incident, serious incident, disaster). OECD. 2025-02. https://www.oecd.org/content/dam/oecd/en/publications/reports/2025/02/towards-a-common-reporting-framework-for-ai-incidents_8c488fdb/f326d4ac-en.pdf (verified: primary) [5] Regulation (EU) 2016/679 (GDPR), Art. 33 (notification of a personal data breach to the supervisory authority within 72 hours where feasible). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [6] "Postmortem Culture: Learning from Failure" (Site Reliability Engineering, ch. 15; blameless postmortems; postmortem triggers set in advance). Google. 2016. <https://sre.google/sre-book/postmortem-culture/> (verified: primary) [7] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: FRIA-as-Code

Summary: Maintain the fundamental-rights impact assessment as a versioned, reviewable artefact cross-referenced to the data-protection impact assessment, so that a rights assessment is an input to design that updates with the system, not a document produced once and filed. Generalised, this is **Impact-Assessment-as-Code**: every impact assessment a system triggers (the AI system impact assessment, or AIIA, that ISO/IEC 42005 describes, the GDPR DPIA and the EU AI Act FRIA) is one shared fact base with several views, each with its own trigger, reviewer and re-assessment rule. The pattern keeps its original name and address so that published links to it still resolve.

Objectives

Keep the FRIA and its DPIA cross-reference live and linked to the controls they demand, so a change in the system triggers a review of its rights impact. Extend the same discipline to the AIIA, so that one set of facts about affected groups, harms and controls feeds every assessment and no two assessments disagree about the same system.

Target users

AI governance engineer, DPO, legal/compliance, the model team that runs the AIIA.

Impacted stakeholders

Data subjects, affected persons (including people who never use the system), deployers, providers, regulators.

Relevant principles

Start from a named failure mode or harm; instrument the build to produce its own proof.

Context

A deployer of a high-risk AI system subject to the EU AI Act Art. 27 fundamental-rights impact assessment, where a DPIA under GDPR Art. 35 may already exist and overlap. On the provider side, an organisation running an AI management system assesses the

impact of each AI system on individuals, groups and society across its lifecycle, as ISO/IEC 42001 Annex A.5 asks and ISO/IEC 42005 guides. One system can sit under all three at once.

Problem

A FRIA written once as a Word document describes rights impact at a single moment and is never revisited when the system changes. Duplicated effort between FRIA and DPIA wastes work and leaves the two out of sync. Add a separate AIIA written by the model team and the organisation holds three accounts of the same harms, scored on different scales, reviewed by different people, and stale on different dates.

Solution

Template the FRIA as structured data covering intended use, affected groups, risks to rights, and the mitigating controls, with each mitigation linked to the control that implements it (a Policy Card, an Eval Gate, a guardrail). Cross-reference the DPIA so shared elements are written once. Store it with the registry entry and re-open it on significant change. The EU AI Act Art. 27 FRIA and its DPIA cross-reference define the scope [1].

Example (illustrative) A benefits-eligibility system's FRIA links each identified risk to people's rights to a specific eval and guardrail; when the model is retrained, the FRIA flags which mitigations need re-verification.

One fact base, three views

Hold one record per system with the facts every assessment needs: the intended purpose and out-of-scope uses, the affected groups, each harm scored on the same dimensions (severity, scale, reversibility, duration, likelihood), and each mitigation with the id of the control and eval that implement it. Render the three assessments as views of that record. The house schema `impact-assessment.v1.json` does this with one `type` field (`aiia`, `dpia_addendum`, `fria`), shared fields for risks, mitigations and outcome, and type-specific fields for what only one assessment asks; a fillable [Markdown template](#) sits beside it.

View	Who performs it	What triggers it	When	What it adds to the shared facts
AIIA (ISO/IEC 42005)	The organisation developing or providing the system	Its AI management system (ISO/IEC 42001 A.5.2 to A.5.5)	Throughout the lifecycle, from design [2][3]	Societal impacts; documentation of the assessment itself
DPIA (GDPR Art. 35)	The controller	Processing likely to result in a high risk	Before the processing [4]	Necessity and proportionality; the DPO's advice; prior consultation if high risk remains
FRIA (AI Act Art. 27)	Public-body and public-service deployers, and deployers of Annex III 5(b) and (c) systems	First use of an Annex III high-risk system (not point 2)	Before first use [1]	Affected categories, oversight measures, complaint arrangements; results notified to the market-surveillance authority

Two rules keep the views honest. A FRIA may build on a DPIA that already covers the same ground ([Art. 27\(4\)](#)) [1], so the shared fields are written once and referenced, never copied. And a view is never edited on its own: a change to the facts regenerates every view, so the DPIA cannot say one thing about the affected groups while the FRIA says another.

Re-assessment triggers as code

Write the triggers as conditions the registry evaluates, not as calendar reminders: a new or widened intended purpose; retraining on a new data source; a new affected population, language or jurisdiction; a changed threshold; an incident or near miss from the [Incident Pipeline](#); a monitoring signal outside its band; new law or guidance; and a scheduled review date. The AI Act asks the deployer to update the FRIA when any assessed element changes [1], and the GDPR asks for a review when the risk of the processing changes [4]; a single trigger reopens every view the change touches, and the reviewer sees a diff rather than three new documents. [Chapter 14](#) compares these assessments with the algorithmic impact assessments, bias audits and model validations that can join the same fact base.

Performing versus reviewing

The performer owns the facts; the reviewer challenges them. Before sign-off the reviewer checks that the scope matches the current use-case record, the affected groups include people who never use the system, every risk rating cites evidence (an eval id, a test report, a data profile), every mitigation links to a control that runs, residual risk is accepted by someone with the authority to accept it, and the triggers are written as conditions a pipeline can evaluate. Keep the verdict and the reviewer's name in the record, so an auditor can see who challenged what.

Consequences

Rights assessment stays current and traceable to controls, and overlaps with the DPIA are not duplicated. The AIIA, DPIA and FRIA agree because they read the same facts, and a system change reopens all of them at once. The cost is templating, agreeing one

scoring scale across legal, privacy and engineering, and the discipline to treat the assessment as living.

Related patterns

Model Card as Control Evidence; Policy Card; Runtime Guardrail; Machine-Readable Evidence (OSCAL); Human-in-the-loop Gate; Incident Pipeline.

Maps to: EU AI Act Art. 27 (FRIA), Art. 9 · GDPR Art. 35 (DPIA) · ISO/IEC 42005 · NIST AI RMF (Map) · Layer 01 Govern-as-Code / Layer 02 Inventory & Transparency.

Function labels follow the NIST AI RMF [5]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 (AI Act), Art. 27 (fundamental-rights impact assessment by deployers that are bodies governed by public law or private entities providing public services, and deployers of Annex III points 5(b) and (c) systems; before first use; update when an assessed element changes; results notified to the market-surveillance authority; 27(4) relationship with the DPIA). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] ISO/IEC 42005:2025, AI system impact assessment (guidance for assessing impacts on individuals, groups and society throughout the life cycle, updated as needed; complements ISO/IEC 42001 and ISO/IEC 23894). ISO/IEC. 2025-05. <https://www.iso.org/standard/44545.html> (verified: primary) [3] ISO/IEC 42001:2023, Annex A.5 (A.5.2 AI system impact assessment process; A.5.3 documentation of AI system impact assessments; A.5.4 impact on individuals or groups of individuals; A.5.5 societal impacts). ISO/IEC. 2023. <https://www.iso.org/standard/81230.html> (verified: secondary) [4] Regulation (EU) 2016/679 (GDPR), Art. 35 (data protection impact assessment: 35(2) DPO advice, 35(3) mandatory cases, 35(7) contents, 35(11) review when the risk changes) and Art. 36 (prior consultation). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [5] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Framework Crosswalk

Summary: Maintain a mapping from each control to the framework clauses it serves, generated from the controls themselves, as an index for navigation and reuse, never as the end state. A crosswalk proves you have read the framework; it does not prove the control fires.

Objectives

Let one control satisfy many frameworks and make coverage navigable, while refusing to mistake coverage for assurance.

Target users

AI governance engineer, compliance lead, auditor.

Impacted stakeholders

Auditors, regulators, model owners.

Relevant principles

Make the governed path the easiest path; instrument the build to produce its own proof.

Context

An organisation answering to several overlapping frameworks (EU AI Act, ISO/IEC 42001, NIST AI RMF, CSA AICM) that would otherwise implement the same control several times.

Problem

The crosswalk is where framework theatre begins. A green mapping matrix is mistaken for a working control; a 300-row spreadsheet mapping controls to five frameworks is presented as maturity while nothing measures whether any mapped control reduces risk. **The anti-pattern is treating coverage as control: a mapping cell is not evidence.**

Solution

Generate the crosswalk from the controls, not beside them: each Policy Card and Eval Gate declares the clauses it maps to, and the crosswalk is the aggregation. Use it to find gaps and reuse controls, not to report compliance. Every mapping cell must resolve to a running control and its emitted evidence; a cell with no evidence behind it is flagged, not counted. Reference vocabularies such as the CSA AICM (247 control objectives across 18 domains) [1] and the OWASP Agent Control Standard [2] anchor the mapping.

Example (illustrative) Clicking a green cell for "logging" opens the guardrail and the OSCAL evidence it emitted this week; a cell with no evidence renders amber, not green.

Consequences

Controls are reused across frameworks and gaps are visible, without inflating a matrix into false assurance. The trade-off is the discipline to keep cells honest and to resist reporting coverage as outcome.

Related patterns

[Policy Card](#); [Runtime Guardrail](#); [Machine-Readable Evidence \(OSCAL\)](#); [Continuous Assurance Telemetry](#).

Maps to: EU AI Act (cross-cutting) · ISO/IEC 42001 · NIST AI RMF (Govern) · CSA AICM · OWASP Agent Control Standard · Layer 01 Govern-as-Code / Layer 05 Assurance & Continuous Compliance.

Function labels follow the NIST AI RMF [3]. Mappings are illustrative, not a claim of conformity.

Sources

[1] AI Controls Matrix (AICM) v1.1 (247 control objectives across 18 domains). Cloud Security Alliance. 2026-06-22. <https://cloudsecurityalliance.org/artifacts/ai-controls-matrix-v1-1> (verified: primary) [2] OWASP GenAI Security Project unveils the Agent Control Standard (ACS) and 2026 Top 10 for LLM Applications. OWASP GenAI Security Project. 2026-09-01. <https://genai.owasp.org/2026/09/01/owasp-genai-security-project-unveils-2026-top-10-for-llm-applications-new-agent-control-standard-and-sponsors-as-community-tops-30000-members/> (verified: primary) [3] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Machine-Readable Evidence (OSCAL)

Summary: Emit control evidence in a machine-readable, standard format so that the audit is a query and the same evidence feeds continuous assurance. OSCAL, extended with properties for AI, is the organising format: frameworks specify what to assure but provide no executable format for how, and this pattern supplies it [1].

Objectives

Make evidence queryable, diffable and aggregatable, and eliminate the screenshot as an evidence artefact.

Target users

AI governance engineer, auditor, platform team.

Impacted stakeholders

Auditors, regulators, model owners.

Relevant principles

Instrument the build to produce its own proof; give every control teeth.

Context

A stack whose controls already produce structured records, and an assurance function that must answer auditors repeatedly and at speed.

Problem

Evidence a human must format and file by hand does not scale, cannot be verified quickly, and is out of date the moment it is saved. Every audit re-collects it from scratch.

Solution

Emit control results as OSCAL component-definition and assessment-results artefacts. OSCAL's native model is the stable substrate: a control layer (`catalog` , `profile`), an implementation layer (`component-definition` , `system-security-plan`) and an assessment layer (`assessment-plan` , `assessment-results` , `POA&M`), with traceability from a result back to the control it tested [2]. Build on it first. AI-specific extensions are still forming: one proposed approach, a single 2026 preprint, adds sixteen property extensions for lifecycle phase, enforcement semantics and risk traceability in a three-layer policy/evidence/enforcement architecture that generates OSCAL assessment results automatically and validates them against the NIST JSON schema [1]. Adopt the extensions if they fit, but the native assessment models carry most of the load today. Store the evidence so an auditor's question is answered by a query.

Example (illustrative) An eval gate writes an OSCAL assessment result on every run; the auditor's request for "all robustness evidence in Q3" is a filter over the store, returned in minutes.

Consequences

The audit becomes a query and evidence composes across tools and jurisdictions. The cost is adopting the schema and instrumenting controls to emit it.

Related patterns

Continuous Assurance Telemetry; Framework Crosswalk; Eval Gate in CI; Incident Pipeline.

Maps to: EU AI Act Art. 12, Art. 17, Art. 72 · ISO/IEC 42001 · NIST AI RMF (Manage, Govern) · Layer 05 Assurance & Continuous Compliance.

Function labels follow the NIST AI RMF [3]. Mappings are illustrative, not a claim of conformity.

Sources

[1] "Making AI Compliance Evidence Machine-Readable" (OSCAL + 16 property extensions; three-layer policy/evidence/enforcement; "specify what to assure but provide no executable format for how") (arXiv 2604.13767). UC3M. 2026-04-15. <https://arxiv.org/abs/2604.13767> (verified: primary) [2] OSCAL native model (control layer: catalog, profile; implementation: component-definition, system-security-plan; assessment: assessment-plan, assessment-results, POA&M). NIST. 2026. <https://pages.nist.gov/OSCAL/learn/concepts/layer/> (verified: primary) [3] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Agent Identity & Scoped Credentials

Summary: Give every agent its own identity, an owner, a bounded scope and an expiry, established before it acts, so that its actions can be attributed, its access revoked precisely and its scope contained. Identity is the precondition of accountability; scope is the precondition of containment.

Objectives

Make every non-human actor governable by construction: attributable, scopable, revocable, expiring.

Target users

AI governance engineer, security engineer, IAM/platform team.

Impacted stakeholders

Model owners, security operations, auditors, affected third parties.

Relevant principles

Register and bound every actor before it acts; start from a named failure mode or harm.

Context

Agents that act under delegated authority (calling APIs, tools and other agents), where the default is a shared service account or a static key.

Problem

An agent on borrowed credentials cannot be attributed, contained or revoked. NIST's NCCoE frames the open question directly: how do identification, authentication and authorization apply so each agent is "known, trusted, and properly governed", with non-repudiation and tamper-proof logging [1].

Solution

Issue each agent a distinct workload identity with a declared scope, an owner and an expiry, recorded in the Agent Registry. Keep two questions separate. **Channel authentication** secures one hop: how a client authenticates to a tool server; the MCP specification of 2026-07-28 tightened exactly this, deprecating Dynamic Client Registration in favour of Client ID Metadata Documents and binding credentials to their issuer [2]. That hardens the MCP connection but is not the agent's identity. **Agent workload identity** is the durable, attributable identity the agent carries across every hop and protocol, under which its actions are logged and its access revoked: the job of a workload-identity system (SPIFFE/SPIRE) or a first-class agent identity from an enterprise provider (for example Microsoft Entra Agent ID [3] or Okta Agent SSO [4]; illustrative), recorded in the registry, not of the transport protocol. Secure the channel *and* issue the workload identity; scope its credentials to the least privilege the agent's declared function needs.

Example (illustrative) A data-analysis agent authenticates with an issuer-bound credential and a scope limited to read-only access to one dataset; its every action is logged under its own identity, and its credential expires with its registry entry.

Consequences

Attribution, containment and precise revocation become possible, and the kill switch has something to act on. The cost is IAM integration and managing non-human identities at scale.

Related patterns

Agent Registry; Kill Switch / Circuit Breaker; Policy Card; Human-in-the-loop Gate.

Maps to: EU AI Act Art. 12, Art. 14, Art. 15 · ISO/IEC 42001 · NIST AI RMF (Manage) · CSA AICM · OWASP Agentic ASI03 · Layer 04 Runtime Controls & Observability.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [5] and function labels the NIST AI RMF [6]. Mappings are illustrative, not a claim of conformity.

Sources

[1] "Accelerating the Adoption of Software and AI Agent Identity and Authorization" (concept paper; "known, trusted, and properly governed"; non-repudiation, tamper-proof logging). NIST NCCoE. 2026-02-05. <https://www.nccoe.nist.gov/news-insights/new-concept-paper-identity-and-authority-software-agents> (verified: primary) [2] Model Context Protocol specification 2026-07-28 (DCR deprecated in favour of CIMD; issuer-bound credentials). MCP. 2026-07-28. <https://blog.modelcontextprotocol.io/posts/2026-07-28/> (verified: primary) [3] Microsoft Entra Agent ID (first-class agent identity; OAuth 2.0, MCP, A2A). Microsoft Learn. 2026-04. <https://learn.microsoft.com/en-us/entra/agent-id/what-is-microsoft-entra-agent-id> (verified: primary) [4] "Okta brings first-class identity to AI agents with Agent SSO" (GA 24 Aug 2026; Cross App Access as MCP EMA extension). Okta. 2026-08-24. <https://www.okta.com/newsroom/press-releases/okta-brings-first-class-identity-to-ai-agents-with-agent-sso/> (verified: primary) [5] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [6] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Human-in-the-loop Gate

Summary: Require human approval at a defined, high-consequence decision point before an agent's action takes effect, so that autonomy is bounded by a person exactly where the stakes justify the latency. Oversight is a designed checkpoint, not an afterthought.

Objectives

Insert meaningful human oversight where an action is irreversible or high-impact, and record the decision as evidence.

Target users

AI governance engineer, product owner, risk owner.

Impacted stakeholders

Affected persons, users, model owners, regulators.

Relevant principles

Start from a named failure mode or harm; register and bound every actor before it acts.

Context

An agent whose actions include some that are irreversible or affect people's rights (a payment, a denial, a publication) alongside many that are routine.

Problem

Full autonomy over a high-consequence action removes the human oversight the law and the risk both require; full manual review over every action destroys the value of the agent. Undifferentiated oversight fails in both directions.

Solution

Classify actions by consequence. For the high-consequence class, gate the action behind a human approval step with enough context to decide, and block the action until approval. Log the approver, the context and the decision as evidence. Keep the routine class autonomous under guardrails. This realises the EU AI Act Art. 14 human-oversight requirement [1] at the point of action.

Example (illustrative) An agent can draft and queue refunds autonomously, but any refund above a threshold is held for a named human approver, whose decision is logged against the transaction.

Consequences

Oversight lands where it matters without throttling routine work, and the approval is auditable. The cost is designing the consequence classification and the latency it adds to gated actions.

Related patterns

[Kill Switch / Circuit Breaker](#); [Runtime Guardrail](#); [Policy Card](#); [Agent Identity & Scoped Credentials](#); [FRIA-as-Code](#).

Maps to: EU AI Act Art. 14 · ISO/IEC 42001 · NIST AI RMF (Manage) · OWASP Agentic ASI02 · Layer 04 Runtime Controls & Observability.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [2] and function labels the NIST AI RMF [3]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 (AI Act), Art. 14 (human oversight of high-risk AI systems). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [3] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Shadow-AI Discovery

Summary: Continuously discover AI systems and agents that are running but not registered, and reconcile them against the registry, so the inventory reflects reality rather than only what teams remembered to declare. You cannot govern what you cannot see.

Objectives

Close the gap between the registry and production by finding unregistered models, agents and AI-enabled tools, and bringing them under governance.

Target users

AI governance engineer, security engineer, platform team.

Impacted stakeholders

Model owners, security operations, auditors.

Relevant principles

Register and bound every actor before it acts; make the governed path the easiest path.

Context

An organisation where teams adopt AI tools and spin up agents faster than any central inventory can track, and where, by one vendor's comparison of the category, much of the AI-governance platform market "manages the program ... without any runtime data path" [1].

Problem

A registry fed only by voluntary declaration is always behind. Unregistered agents, the shadow fleet, are exactly the layer a paper inventory cannot see, and a security vendor's 2026 survey reports that roughly one in eight AI breaches involved agentic systems [2].

Solution

Run discovery against the environments where AI appears (identity providers, cloud accounts, network egress, code repositories, SaaS integrations) using discovery tooling (illustrative) to find models and agents. Reconcile findings against the registry, open an entry for each unknown with an owner to claim it, and escalate the unclaimed. Feed the result back into the Agent Registry's drift check.

Example (illustrative) A weekly discovery sweep finds an agent calling an external API from a team's cloud account with no registry entry; it is auto-registered as unclaimed, its owner is notified, and its scope is frozen until claimed.

Consequences

The inventory converges on reality and the blind spot shrinks. The cost is discovery integration and the process to triage and claim what it finds.

Related patterns

[Agent Registry](#); [Agent Identity & Scoped Credentials](#); [Continuous Assurance Telemetry](#).

Maps to: EU AI Act Art. 49/71 · ISO/IEC 42001 · NIST AI RMF (Map) · CSA AICM · OWASP Agentic ASI10 · Layer 02 Inventory & Transparency.

Threat IDs follow the OWASP Top 10 for Agentic Applications 2026 [3] and function labels the NIST AI RMF [4]. Mappings are illustrative, not a claim of conformity.

Sources

[1] "Best AI Governance Platforms in 2026: 14 Enterprise Vendors Compared" (vendor-published comparison of the 13 Magic Quadrant vendors plus its own product; most of the category "manages the program ... without any runtime data path"). Kosmoy.

2026-07-10. <https://www.kosmoy.com/resources/blog/best-ai-governance-platforms-2026/> (verified: secondary) [2] 2026 AI Threat Landscape Report (vendor survey; key finding stated on the report page: one in eight breaches were agentic). HiddenLayer. 2026. <https://www.hiddenlayer.com/report-and-guide/threatreport2026> (verified: primary) [3] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [4] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Vendor / Model Due-Diligence Gate

Summary: Gate the procurement or integration of a third-party AI system (SaaS with an embedded LLM, an API-only foundation model, a vendor's agent) on a structured due-diligence assessment, so a model you do not own still enters through a control that records what you can and cannot verify about it. When you do not own the model, this gate is what replaces the red-team you cannot run.

Objectives

Bring bought and API-only AI under the same registry and assurance discipline as systems you build, and make the limits of your verification explicit rather than assumed away.

Target users

AI governance engineer, procurement, security engineer, DPO.

Impacted stakeholders

Deployers, model providers, data subjects, auditors, regulators.

Relevant principles

Register and bound every actor before it acts; start from a named failure mode or harm.

Context

An organisation that consumes far more AI than it trains: SaaS features with an embedded LLM, hosted foundation models reached only by API, agents shipped inside a vendor's product. The weights, training data and internal guardrails belong to someone else.

Problem

The parts of the stack that assume you own the model degrade when you do not. You cannot red-team weights you cannot reach, so an eval gate (layer 03) can only test the vendor's system as a black box at its boundary; runtime control (layer 04) narrows to the tool scopes, identity and traffic the integration exposes, not the model's own behaviour. Left ungoverned, procured AI becomes the shadow fleet with a contract: in production, unassessed, and outside the registry.

Solution

Make due diligence a gate a procured or integrated AI system must pass before it reaches production, and structure the assessment on a template rather than an ad-hoc questionnaire; the CSIRO Responsible AI Pattern Catalogue's supplier-assessment fields are a usable starting point [1]. Assess, at minimum: the provider's own evaluations and red-team evidence (what they will share, and its independence); the model card, supplier documentation and any AIBOM you can obtain; the lawful basis and data flows, including whether your inputs train their model; the tool scopes and identity you will grant the vendor's agent; the provider's incident-reporting commitments; and the contractual right to audit and to be notified of material change. Record the result as a registry entry with an owner and a scope, and re-open the gate on renewal or on a material model change. Anchor the assessment in ISO/IEC 42001 Annex A.10 (third-party and customer relationships) [2], the EU AI Act's allocation of duties along the value chain (provider obligations versus deployer obligations under Articles 25, 26 and 27 [3]) and, for general-purpose models, the transparency and documentation the GPAI Code of Practice expects providers to supply [4]. Where you cannot verify a control, record that you cannot, and compensate by bounding the integration: least-privilege scopes, boundary evals, and tighter runtime observation of the traffic you do control.

Example (illustrative) A team integrating an API-only foundation model cannot test its weights, so the gate captures the provider's published evaluations, restricts the model to a scoped service identity with no standing data access, adds a boundary eval on the team's own prompts, and files the whole assessment as the system's registry entry, flagged "provider-attested" where the team relied on the vendor's evidence rather than its own.

Operate: change notices, reassessment and fallback

Passing the gate once proves little about a system that keeps changing after the contract is signed. The operate step keeps the gate open for as long as the system runs.

- **Treat every change and deprecation notice as an event.** File each provider notice (a new model version, a changed default, a deprecation date, a new sub-processor, new data-use terms) against the registry entry, and re-run the boundary eval against the changed system before the change reaches users wherever the contract lets you pin a version. A deprecation date becomes a dated milestone on the entry, with an owner for the migration decision.
- **Detect the change nobody announced.** Run a small canary set from the boundary eval on a schedule against the live endpoint and alert when its results move outside their band. A change detected without a notice is a finding under the contract. MITRE ATLAS catalogues the adversarial form of the same risk, a supply-chain rug pull, in which a component earns trust and then ships a malicious update ([AML.T0109](#)) [5].
- **Reassess on triggers and by tier, not only at renewal.** Re-open the gate on a schedule set by the risk tier and on any trigger: an incident at the provider or in your own deployment, a change of ownership or of sub-processors, a regulatory change, a material model change. The NIST AI RMF asks that third-party risks be monitored regularly and that pre-trained models be monitored as part of the system's maintenance (MANAGE 3.1 and 3.2) [6].
- **Keep a fallback you have tested.** Keep an alternative model warm in the eval harness, a manual process staff have practised and the degraded modes the system can fall back to, and test the switch with a timer running. The NIST AI RMF asks for contingency processes for failures in third-party systems deemed high-risk (GOVERN 6.2) [7]. The same switch is how a deployer meets its duty to monitor a high-risk system on the basis of the instructions for use and to suspend use when it presents a risk ([Art. 26\(5\)](#)) [3]; the [Incident Pipeline](#) owns the notification to the provider.

The continuity and exit side of this step (outages, withdrawn models, forced migrations, contractual exit) is set out in [chapter 15](#).

Example (illustrative) A provider announces that the model version behind a claims-triage assistant will be retired in 90 days. The notice is filed on the registry entry with the date as a milestone; the boundary eval runs against the successor version the same week and shows a drop on two subgroup metrics; the team records a migration decision with a compensating threshold, and a scheduled drill proves the switch to the manual queue takes under ten minutes.

Consequences

Procured AI is inventoried and bounded, and the reliance on provider-supplied evidence is explicit rather than hidden. The cost is real: layers 03 and 04 give less assurance over a model you do not own, and the gate depends on provider cooperation and contract terms you may not fully win. The operate step adds a standing cost: canary runs against a live endpoint, a warm alternative that must be kept current, and drills that prove the fallback still works.

Related patterns

[Agent Registry](#); [AIBOM](#); [Adversarial Red-Team Suite](#); [Model Card as Control Evidence](#); [Agent Identity & Scoped Credentials](#); [Shadow-AI Discovery](#); [Incident Pipeline](#); [Kill Switch / Circuit Breaker](#).

Maps to: EU AI Act Art. 25 (value-chain responsibilities), Art. 26 (deployer duties), Art. 27 (FRIA), Art. 53 (GPAI documentation) · ISO/IEC 42001 Annex A.10 · GPAI Code of Practice · NIST AI RMF (Map, Govern) · Layer 02 Inventory & Transparency / Layer 05 Assurance & Continuous Compliance.

Function labels follow the NIST AI RMF [8]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Responsible AI Pattern Catalogue (template: summary, objectives, target users, impacted stakeholders, relevant principles, context, problem, solution, consequences; governance/process/product patterns). CSIRO. 2023–2024. <https://research.csiro.au/ss/science/projects/responsible-ai-pattern-catalogue/> (verified: primary) [2] ISO/IEC 42001:2023 Annex A.10 (third-party and customer relationships; supplier controls). ISO/IEC. 2023. <https://www.iso.org/standard/81230.html> (verified: secondary) [3] Regulation (EU) 2024/1689 (AI Act), Arts. 25 (value-chain responsibilities), 26 (deployer obligations, incl. 26(5) monitoring on the basis of the instructions for use, informing the provider and suspending use), 27 (FRIA): allocation of duties between provider and deployer. Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [4] The General-Purpose AI Code of Practice (published 10 Jul 2025; a voluntary tool; the Transparency chapter's Model Documentation Form for the documentation providers supply to downstream providers). European Commission. 2025-07-10. <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai> (verified: primary) [5] MITRE ATLAS data, release v2026.09 (AML.T0109 AI Supply Chain Rug Pull; AML.T0010 AI Supply Chain Compromise). MITRE. 2026-09-15. <https://github.com/mitre-atlas/atlas-data/releases/tag/v2026.09> (verified: primary) [6] NIST AI RMF Playbook, MANAGE (3.1 third-party risks monitored; 3.2 pre-trained models monitored; 2.4 supersede, disengage or deactivate). NIST. 2023. <https://airc.nist.gov/airmf-resources/playbook/manage/> (verified: primary) [7] NIST AI RMF Playbook, GOVERN (6.1 third-party risk policies; 6.2 contingency processes for failures in third-party systems deemed high-risk). NIST. 2023. <https://airc.nist.gov/airmf-resources/playbook/govern/> (verified: primary) [8] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary)

Pattern: Use-Case Intake & Risk Tiering

Summary: Route every proposed AI use case, built or bought, through one intake that writes a structured use-case record, screens it against prohibited practices and the EU AI Act risk ladder, and computes an internal risk tier from declared profile fields. The tier, not a meeting, decides which assessments, evals and approvals the system must clear before it ships, and the record becomes the registry entry every later gate reads.

Objectives

Make the first decision about an AI system a recorded, reproducible one: what it is for, what it must not be used for, how risky it is and, from that, how much governance it gets. Spend review effort where the risk is and let low-risk use cases through fast on a paved path.

Target users

AI governance engineer, product owner, platform team, legal and privacy reviewers.

Impacted stakeholders

People affected by the system's outputs, deployers and operators, the AI governance committee, auditors, market surveillance authorities.

Relevant principles

Build the control at the earliest point it can block; make the governed path the easiest path; register and bound every actor before it acts.

Context

An organisation where many teams propose AI features, and most of them buy or call models rather than train them. Requests arrive by email, in slide decks and in procurement tickets, and each is reviewed with whatever questions the reviewer remembers. The EU AI Act measures most duties against the **intended purpose**, which it defines to include the context and conditions of use stated in the instructions for use, "promotional or sales materials and statements" and the technical documentation (Art. 3(12)) [1]. The NIST AI RMF asks that intended purposes and settings are "understood and documented" (MAP 1.1) and that risk tolerances are "determined and documented" (MAP 1.5) [2].

Problem

Without one intake, governance starts too late and scales badly.

- **Forces.** Reviewers want every use case assessed in depth; teams want an answer in days. Classification depends on facts only the team knows: the purpose, the affected persons, whether the system profiles people. A tier negotiated in a meeting drifts with whoever attends. A tier that is not machine-readable cannot switch a gate on.
- **Failure mode.** A high-risk use slips through as "just a pilot" while low-risk requests queue behind it. Nobody can show which systems were classified, by whom, on which facts, or why an Annex III system was treated as not high-risk.

Solution

Build intake as a form-plus-code path that ends in a record and a tier, not in minutes.

1. **Capture the use-case record.** A short structured form (intended purpose, out-of-scope uses, users and affected persons, decision authority, success metrics, error appetite, data sources, jurisdictions) writes a registry stub keyed to one id. Reuse the published [use-case record schema](#) (`use-case-record.v1`) so the form, the registry and the gates share one shape.
2. **Screen before you score.** Run the prohibited-practice screen (Art. 5) first: a hit is blocked at intake and never tiered. Then place the system on the Act's ladder: an Annex III use, with the Art. 6(3) filter and its override (an Annex III system that profiles natural persons is always high-risk), transparency duties, or a general-purpose model. A provider that relies on the filter must document its assessment before placing the system on the market and register it (Art. 6(4) , Art. 49(2)) [1]; the intake record is that documentation. The Digital Omnibus moved the Annex III high-risk obligations to 2 Dec 2027 [3]: that changes when the duties bite, not whether the classification is recorded now.
3. **Compute the internal tier.** Declare profile fields (autonomy, decision impact, exposure, reversibility of the worst outcome, vulnerable groups, data class, third-party dependency) and let a versioned policy compute the tier. The AI RMF sets the level of risk-management activity by risk tolerance (GOVERN 1.3) and asks for the likelihood and magnitude of each identified impact (MAP 5.1) [2]. Canada's Directive on Automated Decision-Making applies the same idea in public administration, with four impact levels defined partly by reversibility and duration [4]. A team that disagrees with its tier changes a factor, with evidence, in a reviewed change; the tier follows.
4. **Bind the tier to gates.** The tier selects the required assessments (DPIA, FRIA, vendor due diligence), the eval categories and thresholds, the approvers and the review cadence, so the pipeline reads what it must enforce. Deployment refuses any system without an intake record ("no stub, no deploy"), which keeps the inventory complete by construction (GOVERN 1.6) [2].
5. **Re-open on change.** A new purpose, population, jurisdiction or data source, or a consumer that declares a use on the out-of-scope list, re-runs intake and may move the tier.

Illustrative use-case record at intake, valid against `use-case-record.v1` (the profile fields and the filter claim travel in `extensions`):

```
{
  "$schema": "https://aigovernanceengineer.com/schemas/use-case-record.v1.json",
  "record_id": "uc-2026-042",
  "title": "Payslip field extraction for mortgage applications",
  "business_owner": "head-of-mortgage-operations",
  "intended_purpose": "Extract income fields from uploaded payslips into the application form for an underwriter to confirm; the affordability assessment",
  "out_of_scope_uses": ["affordability scoring", "automatic decline", "employment verification"],
  "users": ["mortgage underwriters"],
  "affected_persons": ["mortgage applicants"],
  "decision_authority": "human_decides",
  "ai_justification": {
    "alternatives_considered": ["manual keying", "template-based OCR"],
    "why_ai": "Payslip layouts vary too much for templates; every extracted field is confirmed by an underwriter."
  },
  "success_metrics": [
    { "metric": "field-level exact match on a frozen sample", "target": ">= 0.98", "direction": "higher_is_better" }
  ],
  "error_appetite": "A wrong income figure can distort an affordability decision; low-confidence fields are routed to manual keying.",
  "data_sources": [{ "name": "applicant payslips", "personal_data": true, "special_category": false }],
  "jurisdictions": ["ES", "PT"],
  "preliminary_classification": {
    "eu_ai_act_category": "minimal",
    "internal_tier": "medium",
    "rationale": "Preparatory task to an Annex III 5(b) assessment (Art. 6(3) filter claimed, no profiling); assessment documented and registered"
  },
  "assessments_required": ["dpia"],
  "decision": {
    "outcome": "approved_with_conditions",
    "conditions": ["Art. 49(2) registration before go-live", "monthly 2% sample checked against source payslips"],
    "decided_by": "ai-governance-review",
    "decided_at": "2026-09-22"
  },
  "register_entry": "mortgage-extract-01",
  "extensions": {
    "risk_profile": { "autonomy": "suggests", "decision_impact": "informs", "exposure": "customers",
      "reversibility": "reversible", "vulnerable_groups": [], "data_class": "personal",
      "third_party": ["ocr-vendor-02"] },
    "tier_rule": "tiering-policy.v3",
    "annex_iii_point": "5(b)",
    "art_6_3_condition": "preparatory_task",
    "profiling": false
  }
}
```

Example (illustrative) A bank's intake form is short enough to finish in one sitting. The prohibited-practice screen and the Annex III questions run first; the tier rule then reads the profile. A payslip-extraction tool lands in the medium tier with its Art. 6(3) filter claim on record, so it gets a DPIA link, an extraction-accuracy eval and a monthly sample check, not a committee slot. A second request, to rank applicants by predicted default, trips the profiling override at the first question and is routed as high-risk before anyone books a meeting.

Consequences

Every system has a purpose, a class and a tier on record before it costs compute; review effort follows risk; the inventory is complete because deployment depends on it; and each classification is auditable down to the facts it rested on. The costs: the form must stay short or teams route around it; the tier rule needs calibration and an appeal path; and self-declared facts can be wrong, so intake needs spot checks against discovery and procurement.

Related patterns

[Agent Registry](#); [Policy Card](#); [FRIA-as-Code](#); [Vendor / Model Due-Diligence Gate](#); [Shadow-AI Discovery](#); [AI Threat Model](#); [Dataset Admission Gate](#).

Maps to: EU AI Act Art. 3(12), Art. 5, Art. 6(3)–(4), Art. 49(2), Annex III · ISO/IEC 42001 A.5.2, A.9.4 · NIST AI RMF (Govern 1.3, 1.6; Map 1.1, 1.5, 5.1) · Layer 01 Govern-as-Code / Layer 02 Inventory & Transparency.

Function and subcategory labels follow the NIST AI RMF [2]; ISO/IEC 42001 Annex A ids follow a published crosswalk, not the standard's text [5]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 (AI Act): Art. 3(12) intended purpose (incl. "promotional or sales materials and statements"); Art. 5 prohibited practices; Art. 6(3) filter and profiling override, Art. 6(4) documented assessment before placing on the market; Art. 49(2) registration of systems concluded not high-risk under Art. 6(3); Annex III (text read on the Commission's AI Act Service Desk, 2026-09-24). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (GOVERN 1.3 level of risk-management activity by risk tolerance; GOVERN 1.6 inventory of AI systems; MAP 1.1 intended purposes and settings "understood and documented"; MAP 1.5 risk tolerances "determined and documented"; MAP 5.1 likelihood and magnitude of each identified impact). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [3] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689; OJ L, 24 July 2026; in force 27 Jul 2026; Annex III high-risk obligations moved to 2 Dec 2027. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [4] Directive on Automated Decision-Making (algorithmic impact assessment before production; Appendix B impact levels I to IV defined by reversibility and duration). Treasury Board of Canada Secretariat. 2025-06-24. <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32592> (verified: primary) [5] NIST AI RMF to ISO/IEC FDIS 42001 crosswalk (provider: Microsoft; lists the Annex B implementation-guidance clauses, whose numbers mirror the Annex A control ids, e.g. B.5.2 AI system impact assessment process, B.9.4 intended use of the AI system; the ISO text was not opened). NIST AI Resource Center. 2023. https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf (verified: secondary)

Pattern: AI Threat Model

Summary: Threat-model every AI system at design review as a versioned data file, not a slide: decompose its data flows, enumerate threats per element with a classic checklist such as STRIDE extended with the AI-specific attacks that MITRE ATLAS, NIST AI 100-2 and the OWASP lists catalogue, and require every threat above tolerance to resolve to a mitigation and to the test that proves the mitigation works. The threat model decides what the red-team suite, the guardrails and the supply-chain controls cover, and it is reopened whenever the system or the threat catalogue changes.

Objectives

Turn "what can go wrong?" into a traceable chain of threat, mitigation and test, so the security controls of an AI system are chosen from its design rather than from habit, and an auditor can see that each known attack class was considered and either handled or accepted by a named owner.

Target users

AI governance engineer, security engineer, ML engineer, platform team.

Impacted stakeholders

Users and people affected by the system's outputs, data subjects whose data trained or feeds it, model owners, the CISO function, auditors and market surveillance authorities.

Relevant principles

Start from a named failure mode or harm; build the control at the earliest point it can block; give every control teeth.

Context

A design review for a system that trains or fine-tunes on external data, retrieves documents, calls tools or serves a model through an API. Security teams already threat-model software, often with STRIDE (spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege) as part of a secure development lifecycle [1]. AI adds attack surface those six words do not name: training data, pre-trained components, prompts, retrieval corpora and the inference API itself. Microsoft's guidance for AI and machine-learning systems puts the scope change plainly: "Training Data stores and the systems that host them are part of your Threat Modeling scope" [2].

Problem

The threats that matter most for an AI system are the ones a generic review does not ask about.

- **Forces.** Security wants depth, product wants speed. The AI attack catalogues are large and move: MITRE's ATLAS data shipped its 2026.09 release on 15 Sep 2026 [3]. A threat model written as a document is out of date at the next change. Red teams test what they think of, which is not always what the design exposes.
- **Failure mode.** The red-team suite and the guardrails are chosen by habit. Threats specific to the system (a poisoned corpus, tampered weights, extraction through the API, a tool granted more scope than the task needs) have no owner and no test. After an incident, nobody can show the threat was ever considered.

Solution

Keep the threat model next to the design record, as data, and make the design review fail when it is incomplete.

1. **Scope from the design.** Decompose the data flows (data sources, training pipeline, model artefact and registry, retrieval corpus, prompts, tools, inference API, downstream consumers) and mark the trust boundaries. Training data stores and the model registry are in scope [2].

2. **Ask the four questions.** The Threat Modeling Manifesto frames the work as "What are we working on?", "What can go wrong?", "What are we going to do about it?" and "Did we do a good enough job?" [4]. The first is the data-flow diagram; the next two are the rows below; the last is the gate.
3. **Enumerate per element, then extend.** Walk each element with STRIDE [1], then add the AI-specific classes: the evasion, poisoning, privacy and misuse attacks of NIST AI 100-2 E2025 [5], the techniques of MITRE ATLAS [3], and the OWASP Top 10 for LLM Applications 2026 [6] and for Agentic Applications 2026 [7] for generative and agentic systems. The table is a starting checklist, not a complete one.

STRIDE category	AI-specific reading	Catalogue ids (examples)
Spoofing	A forged model or dataset origin; an impersonated agent or tool server	AML.T0010.003 ; ASI03 , ASI04
Tampering	Poisoned training data; a manipulated model; instructions injected through retrieved content	AML.T0020 , AML.T0018 , AML.T0051.001 ; LLM05:2026 , LLM01:2026
Repudiation	An agent action with no attributable identity; a decision with no record	ASI03
Information disclosure	Membership inference, model inversion or model extraction through the inference API	AML.T0024.000 , AML.T0024.001 , AML.T0024.002
Denial of service	Unbounded consumption of tokens, compute or tool calls	LLM06:2026
Elevation of privilege	Excessive agency or tool misuse; a model file that executes code on load	LLM03:2026 , ASI02 ; AML.T0011.000

1. **Rate and decide.** Rate each threat on the organisation's likelihood and severity scales and decide: mitigate, avoid, transfer or accept. An accepted threat becomes a risk-register entry with a named acceptor; a mitigated one names its controls.
2. **Close the loop with a test.** Every mitigated threat carries the id of the test that proves the mitigation: a red-team case, an eval, a pipeline check (a signature or hash verification), a guardrail test. The design review is a gate: it fails while any threat above tolerance has no mitigation or no test.
3. **Reopen on triggers.** A new tool, data source, model or exposure, an incident or near miss, or a relevant new technique in the catalogues reopens the model. Because the file is versioned, the reopening is a diff with a reviewer.

For high-risk systems under the EU AI Act, the output is also evidence of Art. 15(5) : resilience against attempts by unauthorised third parties to exploit vulnerabilities, with technical solutions that include, where appropriate, measures against data poisoning, model poisoning through "pre-trained components used in training", adversarial examples, confidentiality attacks and model flaws [8]. Providers of general-purpose models with systemic risk must ensure "an adequate level of cybersecurity protection" for the model and its physical infrastructure (Art. 55(1)(d)) [8]. The AI RMF asks that security and resilience are "evaluated and documented" (MEASURE 2.7) [9].

Illustrative threat entry, one row of the model's data file:

```
{
  "threat_id": "TM-support-rag-07",
  "system": "support-rag@2026-09-20",
  "element": "retrieval corpus ingestion",
  "stride": "tampering",
  "ai_class": "indirect prompt injection through retrieved documents",
  "catalogue": ["AML.T0051.001", "LLM01:2026"],
  "likelihood": "likely",
  "severity": "major",
  "decision": "mitigate",
  "mitigations": ["source allow-list at ingestion", "input guardrail on retrieved chunks",
    "read-only tool scope for the answering step"],
  "tests": ["redteam.planted-instructions.v3", "canary-docs.never-retrieved.v1"],
  "owner": "team-support-platform",
  "reviewed": "2026-09-22"
}
```

Example (illustrative) A support assistant's first design review listed prompt injection and stopped there. Walking the data-flow diagram element by element added three rows: documents from a partner wiki entered the corpus unreviewed, the model weights were pulled from a public hub by tag rather than by digest, and the ticket tool could close any ticket, not only the requester's. Each row got a control and a test: an ingestion allow-list with planted-instruction cases, digest pinning with a pipeline check, and a scoped tool with a denial test. The design review gate now fails on any threat row whose tests list is empty.

Consequences

The red-team suite, the guardrails and the supply-chain checks trace back to named threats, and the security case for a release is a query over the file. The costs: threat modelling takes skilled time; the catalogues change monthly, so someone owns the delta review; and a threat model is only as good as the data-flow diagram, which drifts unless the design record is kept current.

Related patterns

[Adversarial Red-Team Suite](#); [Runtime Guardrail](#); [Model Artefact Integrity](#); [Dataset Admission Gate](#); [Agent Identity & Scoped Credentials](#); [Use-Case Intake & Risk Tiering](#).

Maps to: EU AI Act Art. 15(5), Art. 55(1)(d) · ISO/IEC 42001 A.6.2.2, A.6.2.4 · NIST AI RMF (Map 5.1; Measure 2.7) · OWASP LLM01:2026, LLM05:2026 · OWASP Agentic ASI02/ASI03/ASI04 · MITRE ATLAS · Layer 01 Govern-as-Code / Layer 03 Evals & Red Teaming as Evidence.

Threat IDs follow the OWASP Top 10 for LLM Applications 2026 [6] and for Agentic Applications 2026 [7] and MITRE ATLAS [3]; function and subcategory labels follow the NIST AI RMF [9]; ISO/IEC 42001 Annex A ids follow a published crosswalk, not the standard's text [10]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Threats: Microsoft Threat Modeling Tool (STRIDE model: spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege; a core element of the Security Development Lifecycle). Microsoft Learn. 2017-08-17. <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats> (verified: primary) [2] Threat Modeling AI/ML Systems and Dependencies (A. Marshall, J. Parikh, E. Kiciman, R. Shankar Siva Kumar; supplements SDL threat modelling; "Training Data stores and the systems that host them are part of your Threat Modeling scope"). Microsoft Learn. 2019-11 (page dated 2025-03-12). <https://learn.microsoft.com/en-us/security/engineering/threat-modeling-aiml> (verified: primary) [3] MITRE ATLAS data, release 2026.09 (modified 2026-09-15; AML.T0010.003 AI Supply Chain Compromise: Model; AML.T0011.000 User Execution: Unsafe AI Artifacts; AML.T0018 Manipulate AI Model; AML.T0020 Training Data Poisoning; AML.T0024.000 Infer Training Data Membership, .001 Invert AI Model, .002 Extract AI Model; AML.T0051.001 LLM Prompt Injection: Indirect). MITRE (atlas-data repository). 2026-09-15. <https://github.com/mitre-atlas/atlas-data> (verified: primary) [4] Threat Modeling Manifesto (definition: "analyzing representations of a system to highlight concerns about security and privacy characteristics"; four key questions). Threat Modeling Manifesto working group. n.d. (accessed 2026-09-24). <https://www.threatmodelingmanifesto.org/> (verified: primary) [5] NIST AI 100-2 E2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations (attack classes incl. evasion, poisoning, privacy compromises and misuse enablement). NIST. 2025-03. <https://csrc.nist.gov/pubs/ai/100/2/e2025/final> (verified: primary) [6] OWASP Top 10 for LLM Applications 2026 (LLM01:2026 Prompt Injection, LLM03 Excessive Agency, LLM04 Supply Chain, LLM05 Data and Model Poisoning, LLM06 Unbounded Consumption). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [7] Top 10 for Agentic Applications 2026 (ASI01 to ASI10; ASI02 Tool Misuse and Exploitation, ASI03 Identity and Privilege Abuse, ASI04 Agentic Supply Chain Vulnerabilities). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [8] Regulation (EU) 2024/1689 (AI Act): Art. 15(5) resilience against exploitation of vulnerabilities (data poisoning, model poisoning through pre-trained components, adversarial examples or model evasion, confidentiality attacks, model flaws); Art. 55(1)(d) cybersecurity protection for GPAI models with systemic risk (text read on the Commission's AI Act Service Desk, 2026-09-24). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [9] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MAP 5.1 likelihood and magnitude of each identified impact; MEASURE 2.7 security and resilience "evaluated and documented"). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [10] NIST AI RMF to ISO/IEC FDIS 42001 crosswalk (provider: Microsoft; lists the Annex B implementation-guidance clauses, whose numbers mirror the Annex A control ids, e.g. B.6.2.2 AI system requirements and specification, B.6.2.4 AI system verification and validation; the ISO text was not opened). NIST AI Resource Center. 2023. https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf (verified: secondary)

Pattern: Training-Data Rights Ledger

Summary: Keep one ledger row per training source (not per merged dataset) that records how the data was acquired, on what licence or legal basis, whether rights reservations were checked and how, and which uses are permitted; then join the ledger to lineage so every model version lists the rows it was trained on. The ledger answers "did we have the right to use this?" per source, and "which models are affected?" when a licence, an opt-out or an order changes the answer.

Objectives

Make the right to train a recorded, queryable fact before training, and keep it true afterwards, so that a withdrawal, an erasure request or a court order can be met for the affected models only, and proven.

Target users

AI governance engineer, data acquisition and licensing leads, data stewards, legal and privacy counsel, ML platform team.

Impacted stakeholders

Rightholders and publishers, data subjects, model providers and downstream deployers, the AI Office and other authorities, courts and regulators.

Relevant principles

Instrument the build to produce its own proof; build the control at the earliest point it can block; start from a named failure mode or harm.

Context

A provider that trains or fine-tunes models on a mix of internal data, licensed corpora, open datasets, crawled web content and user data, assembled by different teams at different times. Rights attach per source and sometimes per record, but training consumes merged corpora.

Problem

The legal questions are decided per source; the evidence is usually kept, if at all, per project.

- **Forces.** For content made publicly available online, the EU text-and-data-mining exception holds only where the rightholder has not reserved its rights "in an appropriate manner, such as machine-readable means" (DSM Directive Art. 4(3)) [1], and a Hamburg court held in December 2025 that a reservation written in natural-language terms of use did not meet that bar, with a further appeal allowed [2]. A general-purpose model provider must keep a copyright policy that identifies and complies with such reservations and must publish a sufficiently detailed summary of the training content (Art. 53(1)(c) and (d)) [3]. How data was acquired matters as well as its licence: in *Bartz v. Anthropic* the court separated lawfully purchased and scanned books from pirated downloads [4]. Personal data brings purpose limitation and the compatibility test for further processing (GDPR Art. 5(1)(b) , Art. 6(4)) [5].
- **Failure mode.** Nobody can say which sources trained which model version, or on what terms. A single unlicensed or unlawfully obtained source contaminates every model trained on it, and remedies can reach the model itself: the FTC's Everalbum order required the deletion of "any models or algorithms developed in whole or in part using" the unlawfully used data [6]. Without per-source lineage, the only safe response is to delete everything.

Solution

Make the ledger the admission ticket for every training source, and make lineage point back to it.

1. **One row per source.** Record the source id and version, the acquisition channel (licensed delivery, API, crawl, user upload, internal system), the licensor, the licence reference and its terms for training, commercial use and distribution of derived models, the legal basis where the data is personal, and the permitted uses. For crawled content, record the crawler identity, the window and the rights-reservation check: the method (for example `robots.txt` and page metadata read at fetch time), the result and the date. The EU AI Act's data-governance duties for high-risk systems name the same facts: "data collection processes and the origin of data" and, for personal data, "the original purpose of the data collection" (Art. 10(2)(b)) [3].
2. **Gate on the row.** The corpus build and the [Dataset Admission Gate](#) fail when a source has no ledger row, when its terms do not permit the declared use, or when its reservation check is missing or stale.
3. **Join the ledger to lineage.** Each training run records the ledger rows (id and version) it read, and the [AIBOM](#) lists the datasets by version. Backward lineage answers "what trained this model?"; forward lineage answers "which models used this source?", which is the question a withdrawal or an order asks.
4. **Generate the disclosures.** Build the GPAI training-content summary on the Commission's template (mandatory under Art. 53(1)(d) , applicable from 2 Aug 2025, with models already on the market by 2 Aug 2027) [7] and California's AB 1033 documentation (operative since 1 Jan 2026, including sources, personal information and the use of synthetic data) [8] as queries over the ledger, not as documents written from memory.
5. **Handle change as an event.** A licence expiry or withdrawal, a new reservation, an erasure request or an order marks the affected rows; forward lineage lists the affected models; and the remediation (retrain without the source, retire the model, or a documented decision to rely on another basis) is recorded against the same rows with a date and an approver.

The AI RMF asks for policies on third-party risks, "including risks of infringement of a third-party's intellectual property or other rights" (GOVERN 6.1), and for mapping the legal risks of components, "including the use of third-party data or software" (MAP 4.1) [9].

Illustrative ledger row for a crawled source:

```
{
  "source_id": "src-crawl-techdocs-2026q2",
  "version": "2026-06-30",
  "acquisition_channel": "crawl",
  "crawl": { "user_agent": "corp-trainbot/2.1", "window": "2026-04-01/2026-06-30" },
  "legal_basis": { "copyright": "DSM Directive Art. 4 (commercial TDM exception)",
    "personal_data": "GDPR Art. 6(1)(f); assessment LIA-2026-019" },
  "reservation_check": { "method": "robots.txt and page metadata at fetch time",
    "result": "412 domains excluded", "checked_at": "2026-06-30" },
  "licence": { "ref": null, "training": "exception_relied_on", "derived_model_distribution": "permitted" },
  "permitted_uses": ["pre-training of the doc-lm model family"],
  "trained_models": ["doc-lm@1.4.0"],
```

```

"owner": "data-acquisition-lead",
"reviewed": "2026-09-15"
}

```

Example (illustrative) A publisher's retrieval assistant was built on a corpus three teams had assembled. The ledger was added after the fact, one row per source: two sources had no licence on record and one had been crawled from a site whose robots.txt disallowed the crawler. The corpus build now fails on a source without a row, the two unlicensed sources were removed and the index rebuilt, and the rebuild is recorded against the same registry id. When a licensor later withdrew one archive, forward lineage named the two fine-tuned models that had read it.

Consequences

The right to train becomes evidence that exists before training, disclosures are generated rather than drafted, and a change in rights hits only the models that used the source. The costs: a row per source is real work for large crawls, so the crawl pipeline must write rows itself; reservation checks are only as good as the method recorded; and the ledger records the organisation's position, it does not settle open legal questions.

Related patterns

[Dataset Admission Gate](#); [AIBOM](#); [Model Card as Control Evidence](#); [Policy Card](#); [Machine-Readable Evidence \(OSCAL\)](#); [Vendor / Model Due-Diligence Gate](#).

Maps to: EU AI Act Art. 10(2)(b), Art. 53(1)(c)–(d) · Directive (EU) 2019/790 Art. 4(3) · GDPR Art. 5(1)(b), Art. 6(4) · ISO/IEC 42001 A.7.3, A.7.5 · NIST AI RMF (Govern 6.1; Map 4.1) · Layer 02 Inventory & Transparency.

Function and subcategory labels follow the NIST AI RMF [9]; ISO/IEC 42001 Annex A ids follow a published crosswalk, not the standard's text [10]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Directive (EU) 2019/790 on copyright in the Digital Single Market, Art. 4 (text and data mining exception; 4(3) reservation of rights by machine-readable means for content made publicly available online). Publications Office of the EU (EUR-Lex). 2019-05-17. <https://eur-lex.europa.eu/eli/dir/2019/790/oj/eng> (verified: primary) [2] "Machine-readable opt-outs and AI training: Hamburg Court clarifies copyright exceptions" (Kneschke v. LAION, OLG Hamburg 5 U 104/24, 10 Dec 2025; natural-language reservations in terms of use insufficient; further appeal to the BGH allowed). Norton Rose Fulbright, Inside Tech Law. 2025-12. <https://www.insidetechlaw.com/blog/2025/12/machine-readable-opt-outs-and-ai-training-hamburg-court-clarifies-copyright-exceptions> (verified: secondary) [3] Regulation (EU) 2024/1689 (AI Act): Art. 10(2)(b) data collection processes, origin of data and original purpose of collection; Art. 53(1)(c) copyright policy identifying reservations under Art. 4(3) of Directive (EU) 2019/790; Art. 53(1)(d) public summary of training content on the AI Office template (text read on the Commission's AI Act Service Desk, 2026-09-24). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [4] Bartz v. Anthropic PBC, No. 4:24-cv-05417 (N.D. Cal.): Order on Fair Use (Alsup, J., 23 Jun 2025, ECF 231) and Order Granting Final Approval of Class Action Settlement (Martínez-Olguín, J., 20 Jul 2026, ECF 680). CourtListener (court docket). 2026-07-20. <https://www.courtlistener.com/docket/69058235/bartz-v-anthropic-pbc/> (verified: primary) [5] Regulation (EU) 2016/679 (GDPR): Art. 5(1)(b) purpose limitation; Art. 6(4) compatibility of further processing. Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [6] In the Matter of Everalbum, Inc., Decision and Order ("Affected Work Product": models or algorithms developed using users' biometric information, to be deleted within 90 days with a sworn statement). Federal Trade Commission. 2021-05-07. https://www.ftc.gov/system/files/documents/cases/1923172_-_everalbum_decision_final.pdf (verified: primary) [7] Template for general-purpose AI model providers to summarise their training content (template mandatory under Art. 53(1)(d); applicable from 2 Aug 2025, legacy models by 2 Aug 2027; sources incl. scraped, user and synthetic data). European Commission. 2025-07-24. <https://digital-strategy.ec.europa.eu/en/faqs/template-general-purpose-ai-model-providers-summarise-their-training-content> (verified: primary) [8] AB 2013, Generative artificial intelligence: training data transparency (chaptered 2024-09-28; operative 2026-01-01; developers post training-data documentation incl. sources, personal information, copyright status and use of synthetic data). California Legislature. 2024-09-28. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202320240AB2013 (verified: primary) [9] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (GOVERN 6.1 third-party risks incl. infringement of intellectual property or other rights; MAP 4.1 legal risks of components incl. third-party data or software). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [10] NIST AI RMF to ISO/IEC FDIS 42001 crosswalk (provider: Microsoft; lists the Annex B implementation-guidance clauses, whose numbers mirror the Annex A control ids, e.g. B.7.3 acquisition of data, B.7.5 data provenance; the ISO text was not opened). NIST AI Resource Center. 2023. https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf (verified: secondary)

Pattern: Dataset Admission Gate

Summary: Put a gate in front of every job that reads data to train, fine-tune, validate, test, evaluate or build a retrieval index: the job may read a dataset version only if an admission record exists for it, names the job's use case among its permitted uses, and

shows that the rights, quality, representativeness, bias and integrity checks passed or were waived by someone entitled to waive them. The check is policy-as-code in the pipeline, so a missing field fails the run instead of a reminder in a wiki.

Objectives

Decide whether data may be used, and whether it is fit for the purpose, before a model learns from it, because a quality problem can be fixed later and a rights or poisoning problem often cannot.

Target users

AI governance engineer, data owners and stewards, ML platform team, privacy counsel, security engineer.

Impacted stakeholders

Data subjects and rightholders, people affected by the model's outputs (especially groups the data under-represents), model owners, auditors and notified bodies.

Relevant principles

Build the control at the earliest point it can block; give every control teeth; instrument the build to produce its own proof.

Context

Data platforms that let any team read any table they can reach, feature stores shared across models, and training jobs launched from notebooks. For high-risk systems the EU AI Act turns data governance into requirements: training, validation and testing sets must be subject to practices that cover, among others, their origin, preparation, the "examination in view of possible biases" and "appropriate measures to detect, prevent and mitigate possible biases" (Art. 10(2)(f) and (g)), and must be "relevant, sufficiently representative, and to the best extent possible, free of errors and complete in view of the intended purpose" (Art. 10(3)) [1]. After the Digital Omnibus, the narrow basis for processing special categories of personal data to detect and correct bias sits in a new Art. 4a [2].

Problem

Data enters models through the path of least resistance, and the reasons it should not have are discovered after training.

- **Forces.** Data scientists need data quickly and iterate often. The person who wants a dataset used should not be the only person who decides it may be. Rights, quality and bias checks sit with different owners. Unlawful processing at the development stage can affect the lawfulness of the model's later use: the EDPB said as much in its Opinion 28/2024 [3]. Training data is also an attack surface: ATLAS catalogues training data poisoning (AML.T0020) [4] and OWASP lists data and model poisoning as LLM05:2026 [5].
- **Failure mode.** A model trains on data outside its consent scope, on a sample that misses the population it will serve, on labels nobody audited or on a snapshot someone altered. The problem surfaces in production or in an audit, and the fix is a retrain on data that should have been refused in the first place.

Solution

Give every dataset version an admission record, and make every data-reading job present one.

1. **Write the admission record.** Per dataset version and per permitted pipeline, reuse the published [dataset admission record schema](#) (`dataset-admission-record.v1`): the subject, the pipeline (training, fine-tuning, validation, testing, evaluation or retrieval index), the target system, the linked data card, the decision (admit, admit with conditions, reject), the checks with the obligation each enforces, the content hash of the admitted snapshot, the actor and a signature.
2. **Check rights first.** The lawful basis and purpose compatibility for personal data, the licence and the rights-reservation check come from the [Training-Data Rights Ledger](#); a source without a ledger row fails admission.
3. **Check fitness for the purpose.** Quality measures (label accuracy, completeness, consistency, timeliness) on the vocabulary of the ISO/IEC 5259 series [6]; quantity per class and per group against the minimum cell sizes in the test plan; representativeness against the deployment population stated in the use-case record; a proxy and bias examination with the result recorded; and, where special-category data is used for bias detection, the Art. 4a conditions [2].
4. **Check integrity.** Admit a content-addressed, signed snapshot; re-verify the hash when the job reads it; run anomaly checks on new or appended data. ATLAS lists "Sanitize Training Data" (AML.M0007) and "Maintain AI Dataset Provenance" (AML.M0025) among its mitigations [4]. Record provenance in W3C PROV terms (entities, activities and agents) [7] and emit lineage events (datasets, jobs and runs) so each training run names the admission records it read [8].
5. **Separate the duties.** The data owner is accountable and signs; the data steward operates the checks; a small review board settles contested admissions. The minimum checklist lives as code, so adding a check is a reviewed change.
6. **Enforce at read time.** The job presents its use-case id and target system; the policy denies the read unless the record admits that pipeline for that use. A human-readable datasheet travels with the record, covering motivation, composition, collection, preprocessing, uses, distribution and maintenance [9].
7. **Re-admit on change.** A new version, a new source, quality drift, a licence change, an erasure request or a new use case reopens admission.

The AI RMF asks that data collection and selection considerations (availability, representativeness, suitability) are "identified and documented" (MAP 2.3) and that the legal risks of third-party data are mapped (MAP 4.1) [10].

Illustrative admission record, valid against `dataset-admission-record.v1`:

```
{
  "$schema": "https://aigovernanceengineer.com/schemas/dataset-admission-record.v1.json",
  "control_id": "data.admission.v2",
  "subject": "claims-2019-2025@v4",
  "pipeline": "training",
  "target_system": "fraud-triage@3.0.0",
  "dataset_card": "https://evidence.example.org/cards/claims-2019-2025/v4",
  "decision": "admit_with_conditions",
  "checks": [
    { "check_id": "ledger.rows_present", "requirement": "Training-data rights ledger", "result": "pass" },
    { "check_id": "lawful_basis.compatible", "requirement": "GDPR Art. 6(4)", "result": "pass",
      "detail": "compatibility assessment CA-2026-014" },
    { "check_id": "use_case.permitted", "requirement": "uc-fraud-triage-03", "result": "pass" },
    { "check_id": "quality.label_agreement", "requirement": "EU AI Act Art. 10(3)", "result": "pass",
      "detail": "0.91 inter-annotator agreement" },
    { "check_id": "representativeness.region", "requirement": "EU AI Act Art. 10(3)", "result": "waived",
      "detail": "islands region below minimum cell; waiver W-2026-007 signed by data owner" },
    { "check_id": "bias.examination", "requirement": "EU AI Act Art. 10(2)(f)-(g)", "result": "pass" },
    { "check_id": "integrity.snapshot_hash", "result": "pass" }
  ],
  "conditions": ["collect islands-region claims before the next retrain", "report the islands cell as insufficient data"],
  "input_hash": "sha256:3b7e9c2a41f08d6e5c1b2a9f7e3d4c5b6a8f9e0d1c2b3a4f5e6d7c8b9a0f1e2d",
  "actor": "ci-data-gate",
  "timestamp": "2026-09-20T10:12:00Z",
  "signature": "ed25519:Hk3v8QpZ2sL7dT4rW9xY1aB6cE0fG5jM"
}
```

Example (illustrative) A fraud-triage team pointed a training job at the full claims warehouse. The gate refused it: the warehouse had no admission record for training, and two of its sources had no ledger row. The team admitted a narrower snapshot instead, with one representativeness check waived in writing and a condition to collect data for the missing region before the next retrain. The waiver and the condition now appear in the model card, and the next retrain cannot start until the condition is closed.

Consequences

No model learns from data that was never admitted for its use; rights, quality and bias checks leave evidence before training rather than explanations after it; and forward lineage can find every model a bad dataset reached. The costs: the gate slows exploratory work unless a sandbox pipeline with its own lighter admission exists; waivers need an owner and an expiry or they become the norm; and checks are only as good as the thresholds behind them.

Related patterns

[Training-Data Rights Ledger](#); [Use-Case Intake & Risk Tiering](#); [Fairness Eval Suite](#); [AIBOM](#); [Model Card as Control Evidence](#); [Policy Card](#); [AI Threat Model](#).

Maps to: EU AI Act Art. 10(2)–(4), Art. 4a · GDPR Art. 5(1)(b), Art. 6(4) · ISO/IEC 42001 A.7.2, A.7.4, A.7.5, A.7.6 · NIST AI RMF (Map 2.3, 4.1) · OWASP LLM05:2026 · Layer 01 Govern-as-Code / Layer 02 Inventory & Transparency.

Threat IDs follow the OWASP Top 10 for LLM Applications 2026 [5] and MITRE ATLAS [4]; function and subcategory labels follow the NIST AI RMF [10]; ISO/IEC 42001 Annex A ids follow a published crosswalk, not the standard's text [11]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 (AI Act), Art. 10 (data and data governance: 10(2)(f) examination in view of possible biases, 10(2)(g) measures to detect, prevent and mitigate them; 10(3) relevant, sufficiently representative, free of errors and complete; 10(4) setting of use) (text read on the Commission's AI Act Service Desk, 2026-09-24). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 (new Art. 4a on processing special categories of personal data for bias detection and correction, replacing Art. 10(5)); OJ L, 24 July 2026; in force 27 Jul 2026. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [3] Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (anonymity of models; legitimate interest; consequences of unlawful processing in development). European Data Protection Board. 2024-12. <https://www.edpb.europa.eu/documents/opinion-of-the-board-art-64/opinion-282024-on-certain-data-protection-aspects->

related-to_en (verified: primary) [4] MITRE ATLAS data, release 2026.09 (modified 2026-09-15; AML.T0020 Training Data Poisoning; mitigations AML.M0007 Sanitize Training Data and AML.M0025 Maintain AI Dataset Provenance). MITRE (atlas-data repository). 2026-09-15. <https://github.com/mitre-atlas/atlas-data> (verified: primary) [5] OWASP Top 10 for LLM Applications 2026 (LLM05:2026 Data and Model Poisoning). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [6] ISO/IEC 5259 series, Data quality for analytics and machine learning (ML): Part 1 overview, terminology and examples (2024); Part 2 data quality measures (2024); Part 3 data quality management requirements and guidelines (2024); Part 4 data quality process framework (2024); Part 5 data quality governance framework (2025). ISO/IEC. 2024–2025. <https://www.iso.org/standard/81088.html> (verified: primary) [7] PROV Overview (PROV-DM and PROV-O W3C Recommendations of 30 April 2013; provenance as information about entities, activities and people involved in producing data). W3C. 2013-04-30. <https://www.w3.org/TR/prov-overview/> (verified: primary) [8] OpenLineage: an open platform for collection and analysis of data lineage (standard API for lineage events over datasets, jobs and runs, with facets). OpenLineage project (The Linux Foundation). 2026. <https://openlineage.io/> (verified: primary) [9] Datasheets for Datasets (Gebru et al.; arXiv 1803.09010). arXiv. 2018-03-23. <https://arxiv.org/abs/1803.09010> (verified: primary) [10] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MAP 2.3 data collection and selection considerations "identified and documented"; MAP 4.1 legal risks of components incl. third-party data). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [11] NIST AI RMF to ISO/IEC FDIS 42001 crosswalk (provider: Microsoft; lists the Annex B implementation-guidance clauses, whose numbers mirror the Annex A control ids, e.g. B.7.2 data for development and enhancement, B.7.4 quality of data, B.7.5 data provenance, B.7.6 data preparation; the ISO text was not opened). NIST AI Resource Center. 2023. https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf (verified: secondary)

Pattern: Fairness Eval Suite

Summary: Version a fairness suite with the model and run it behind the eval gate: group and intersectional metrics with confidence intervals, an "insufficient data" outcome for small cells, a proxy scan and a counterfactual flip test, each judged against a fairness policy (metric, threshold, minimum cell size, approver) written down before the run. The suite emits one structured result per metric and slice, fails the build when the policy is not met, and runs again on live decisions so a system that was fair at release cannot drift out of it unseen.

Objectives

Turn "is it fair?" into a small set of chosen, testable properties with consequences, so a release that treats a group worse than the policy allows does not ship, and the evidence shows which metric was chosen, why, and what it measured.

Target users

AI governance engineer, ML engineer, data scientist, legal and equality counsel.

Impacted stakeholders

People subject to the system's decisions, especially protected and intersectional groups, deployers, model owners, auditors, equality bodies and regulators.

Relevant principles

Start from a named failure mode or harm; give every control teeth; instrument the build to produce its own proof.

Context

A system that allocates something to people (credit, jobs, housing, benefits, prices) or serves them with a quality that can differ by group (recognition, transcription, answers in a dialect). For high-risk systems the EU AI Act requires the data to be examined "in view of possible biases" and measures "to detect, prevent and mitigate" them (Art. 10(2)(f) and (g)), systems that keep learning to address biased "feedback loops" (Art. 15(4)), and the instructions for use to state, when appropriate, performance "regarding specific persons or groups of persons" (Art. 13(3)(b)(v)) [1]. The AI RMF asks that fairness and bias "are evaluated and results are documented" (MEASURE 2.11) [2].

Problem

Fairness is measured once, on the aggregate, with a metric picked after seeing the results.

- **Forces.** The common criteria conflict: when base rates differ between groups, a score cannot be calibrated and have equal error rates across groups at once [3], and the three conditions of calibration and balance for both classes cannot hold together except in highly constrained special cases [4]. So a metric must be chosen for the use case, and the choice is a decision with an owner. Aggregate numbers hide the intersections: the Gender Shades audit found error rates of up to 34.7% for darker-skinned women against a maximum of 0.8% for lighter-skinned men [5], and a classifier can look fair on every predefined group while failing structured subgroups [6]. Small cells make point estimates noisy. The legal weight of familiar thresholds moves: the four-fifths rule of the US Uniform Guidelines is a screen with statistical and practical-significance caveats [7], and in June 2026 the US Justice Department announced an opinion concluding that the EEOC's disparate-impact guidelines are unconstitutional [8].
- **Failure mode.** A dashboard marks 0.81 green and 0.79 red with no interval and no minimum sample; the worst-served intersection is averaged away; the release ships on a metric chosen because it passed; and production drift goes unmeasured

because the test ran only at launch.

Solution

Write the policy first, then build the suite that can fail against it.

1. **Fairness policy as data.** Per system: the protected attributes that apply in each jurisdiction and where their values come from, the chosen metric and the reason (selection-rate ratio for allocation, error-rate gaps for quality of service), the threshold, the minimum cell size, the multiple-comparison correction and the approver. Commit it before looking at the next run.
2. **Group and intersectional metrics with intervals.** Compute rates and ratios per group and per intersectional cell, each with a confidence interval, and judge the gate on the interval, not the point. Cells below the minimum report "insufficient data" and are listed, never counted as passes. Search for the worst slice as well as the listed ones.
3. **Proxy scan.** Train a model to predict the protected attribute from the features; a strong predictor flags proxies to justify or remove, and the result goes into the data card.
4. **Counterfactual flip test.** Change only the protected attribute, or for a language model swap identity terms in otherwise identical prompts, and measure how often the outcome or the answer quality changes.
5. **Lawful test data.** Where special-category data is needed for bias detection, use it only on the basis and under the conditions of Art. 4a, which the Digital Omnibus inserted in place of the old Art. 10(5) [9]; otherwise record how group membership was estimated and the error that adds.
6. **Gate and file.** Emit one structured result per metric and slice, reusing the published [eval result schema](#) (`eval-result.v1`), file it against the registry entry and feed the disaggregated numbers into the model card. A failing cell fails the build unless a signed justification is attached to the release.
7. **Run it live.** Compute the same metrics on production decisions on a rolling window, with the same thresholds, so drift raises an alert before a complaint does. Where a regime requires publication, such as the independent bias audits of New York City's Local Law 144 with impact ratios across sex, race/ethnicity and intersectional categories [10], the suite's results are the input, not a separate exercise.

NIST SP 1270 is a useful frame for what the suite cannot see: bias is systemic and human as well as statistical, and it is "not possible to achieve zero risk of bias" [11].

Illustrative result for one slice, valid against `eval-result.v1` (the interval and the policy travel in `extensions`):

```
{
  "$schema": "https://aigovernanceengineer.com/schemas/eval-result.v1.json",
  "suite_id": "fairness.credit-dfc.v3",
  "model_version": "credit-dfc@2026-09-01",
  "score": 0.81,
  "threshold": 0.80,
  "result": "pass",
  "timestamp": "2026-09-18T09:40:12Z",
  "direction": "higher_is_better",
  "metric": "approval adverse-impact ratio, lower 95% bound, age 65+ against age 35-49",
  "failure_mode": "older applicants declined at a disproportionate rate",
  "obligation": "EU AI Act Art. 10(2)(f)-(g)",
  "sample_size": 1840,
  "extensions": {
    "point_estimate": 0.86,
    "ci95": [0.81, 0.91],
    "reference_group": "age_35_49",
    "min_cell": 200,
    "policy": "fairness-policy.credit.v2",
    "insufficient_data_cells": ["age_65_plus x region_islands"]
  }
}
```

Example (illustrative) A lender's suite judged approval rates by age band on the lower confidence bound of the adverse-impact ratio, with a minimum cell of 200. The first run passed every band on the point estimate and failed one on the bound; the second, on a larger frozen test set, passed it. One intersection stayed below the minimum cell, so the release notes list it as "insufficient data" and the data owner carries a condition to collect more before the next retrain. The same metrics now run weekly on live decisions.

Consequences

Fairness claims become specific, reproducible and dated; the metric choice and its trade-offs are on record; and small or intersectional groups are reported rather than averaged away. The costs: lawful access to protected attributes is hard and sometimes impossible, so estimates carry error; intervals widen with small samples, so suites need larger test sets; a passing suite

does not prove the system is fair outside what it measured; and the mitigation it prompts can itself be unlawful in some settings, so fixes go to legal review with the evidence attached.

Related patterns

[Eval Gate in CI](#); [Dataset Admission Gate](#); [Explanation Artefact](#); [Model Card as Control Evidence](#); [Continuous Assurance Telemetry](#); [Claims Substantiation Gate](#).

Maps to: EU AI Act Art. 10(2)(f)–(g), Art. 13(3)(b)(v), Art. 15(4), Art. 4a · NYC Local Law 144 · 29 CFR 1607.4(D) · ISO/IEC 42001 A.5.4, A.6.2.4 · ISO/IEC TR 24027 · NIST AI RMF (Measure 2.11) · Layer 03 Evals & Red Teaming as Evidence.

Function and subcategory labels follow the NIST AI RMF [2]; ISO/IEC 42001 Annex A ids follow a published crosswalk, not the standard's text [12]; ISO/IEC TR 24027 is referenced by identifier and title only [13]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 (AI Act): Art. 10(2)(f)–(g) examination for and mitigation of possible biases; Art. 13(3)(b)(v) performance regarding specific persons or groups in the instructions for use; Art. 15(4) feedback loops in systems that continue to learn (text read on the Commission's AI Act Service Desk, 2026-09-24). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MEASURE 2.11 fairness and bias "evaluated and results are documented"). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [3] "Fair prediction with disparate impact: A study of bias in recidivism prediction instruments" (A. Chouldechova; criteria cannot all hold when prevalence differs across groups). arXiv 1703.00056. 2017-02-28. <https://arxiv.org/abs/1703.00056> (verified: primary) [4] "Inherent Trade-Offs in the Fair Determination of Risk Scores" (J. Kleinberg, S. Mullainathan, M. Raghavan; three fairness conditions cannot hold together except in highly constrained special cases). arXiv 1609.05807. 2016-09-19. <https://arxiv.org/abs/1609.05807> (verified: primary) [5] "Gender Shades: Intersectional Accuracy Disparities in Commercial Gender Classification" (J. Buolamwini, T. Gebru; error rates up to 34.7% for darker-skinned females; maximum 0.8% for lighter-skinned males). Proceedings of Machine Learning Research 81:77-91. 2018. <https://proceedings.mlr.press/v81/buolamwini18a.html> (verified: primary) [6] "Preventing Fairness Gerrymandering: Auditing and Learning for Subgroup Fairness" (M. Kearns, S. Neel, A. Roth, Z. S. Wu). arXiv 1711.05144. 2017-11-14. <https://arxiv.org/abs/1711.05144> (verified: primary) [7] 29 CFR 1607.4(D), Uniform Guidelines on Employee Selection Procedures (1978): adverse impact and the "four-fifths rule", with the statistical and practical significance and small-numbers caveats. eCFR (text as of 2026-09-01). 2026-09-01. <https://www.ecfr.gov/current/title-29/subtitle-B/chapter-XIV/part-1607/section-1607.4> (verified: primary) [8] "Justice Department Concludes EEOC Disparate-Impact Guidelines Violate the Constitution" (Office of Legal Counsel opinion). US Department of Justice. 2026-06-09. <https://www.justice.gov/opa/pr/justice-department-concludes-eec-disparate-impact-guidelines-violate-constitution> (verified: primary) [9] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 (new Art. 4a on processing special categories of personal data for bias detection and correction, replacing Art. 10(5)); OJ L, 24 July 2026; in force 27 Jul 2026. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [10] Automated Employment Decision Tools: Frequently Asked Questions (Local Law 144 of 2021: independent bias audit within the past year; selection or scoring rates and impact ratios across sex, race/ethnicity and intersectional categories; published summary). NYC Department of Consumer and Worker Protection. 2023-06-29. <https://www.nyc.gov/assets/dca/downloads/pdf/about/DCWP-AEDT-FAQ.pdf> (verified: primary) [11] NIST SP 1270, Towards a Standard for Identifying and Managing Bias in Artificial Intelligence (three categories: systemic, statistical and human; "not possible to achieve zero risk of bias"). NIST. 2022-03-15. <https://doi.org/10.6028/NIST.SP.1270> (verified: primary) [12] NIST AI RMF to ISO/IEC FDIS 42001 crosswalk (provider: Microsoft; lists the Annex B implementation-guidance clauses, whose numbers mirror the Annex A control ids, e.g. B.5.4 assessing AI system impact on individuals and groups, B.6.2.4 AI system verification and validation; the ISO text was not opened). NIST AI Resource Center. 2023. https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf (verified: secondary) [13] ISO/IEC TR 24027:2021, Bias in AI systems and AI aided decision making (referenced by identifier and title only). ISO/IEC JTC 1/SC 42. 2021. <https://www.iso.org/standard/77607.html> (verified: secondary)

Pattern: Explanation Artefact

Summary: For every consequential decision a system makes or supports about a person, write one structured **explanation record** at decision time: the model version, the explanation method with its version and baseline, the reason codes drawn from the factors the model actually scored, a valid counterfactual where one helps, the notice template and the contest route. Test the explanations for fidelity in CI, keep the records in the evidence store, and answer every explanation duty (an adverse-action notice, a data-subject access request, an AI Act explanation request, an internal appeal) from the same record.

Objectives

Make every explanation reproducible, checkable and reusable: reproducible because what produced it is pinned, checkable because its reasons can be recomputed and compared, and reusable because one record serves several legal and internal duties instead of each team writing its own letter.

Target users

AI governance engineer, ML engineer, product and operations teams that send notices, privacy and consumer-law counsel.

Impacted stakeholders

People subject to decisions and their representatives, operators and reviewers who rely on the explanation, deployers, auditors, data protection and market surveillance authorities.

Relevant principles

Instrument the build to produce its own proof; give every control teeth; start from a named failure mode or harm.

Context

A system that declines, prices, ranks, flags or scores people, where the person, an operator or an authority will ask why. The duties overlap. Under the EU AI Act, a person subject to a decision taken by a deployer on the basis of the output of an Annex III high-risk system (except point 2), with legal or similarly significant adverse effects, has the right to obtain "clear and meaningful explanations of the role of the AI system in the decision-making procedure and the main elements of the decision taken" (Art. 86(1)); deployers must inform people that they are subject to such a system (Art. 26(11)); and the instructions for use must describe, where applicable, the system's capabilities "to provide information that is relevant to explain its output" (Art. 13(3)(b)(iv)) [1]. The GDPR gives data subjects meaningful information about the logic involved in automated decisions (Art. 15(1)(h) , Art. 22) [2], which the Court of Justice read in C-203/22 as an explanation of "the procedure and principles actually applied" [3]. In US credit, Regulation B requires the specific principal reasons for adverse action, and they must relate to the factors actually considered or scored [4].

Problem

Explanations are generated on the fly, sent and forgotten.

- **Forces.** Post-hoc attribution methods can diverge from the model they explain, and they can be manipulated: a biased classifier can be wrapped so that LIME and SHAP report innocuous features [5]. Reasons written for the data scientist do not help the recipient. Each duty has its own audience and wording. Where stakes are high, an interpretable model can be its own explanation, and Rudin argues it should be preferred to explaining a black box after the fact [6].
- **Failure mode.** Nobody can reproduce the explanation a customer received last year, because the model, the method or the baseline changed. Reason codes name factors the model did not use. Every access request and every appeal becomes a forensic project, and the organisation cannot show that its explanations were accurate.

Solution

Treat the explanation as an artefact with a schema, a test and a retention rule.

1. **Decide the explanation per use case.** An explanation policy (layer 01) states, per use case, the explanation types required (reason codes, a counterfactual, source citations for retrieval-based answers, a description of the procedure and principles applied), the audience and language, the method allowed, and whether an interpretable model is required.
2. **Write the record at decision time.** The runtime (layer 04) writes one record per explained decision, keyed to the registry id and the decision id: model version; method, version and baseline; whether the output was determinative or advisory; reason codes from scored factors, ranked; a counterfactual that changes only mutable features, where helpful; the notice template, language, channel and delivery time; and the contest route. Pinning the method and baseline is what makes the record reproducible.
3. **Test the explanations.** In CI (layer 03), an explanation suite checks fidelity (the reasons predict the model's behaviour), stability (near-identical inputs get near-identical reasons), sanity (the method is sensitive to the model and the data) and reason-code consistency (every sampled reason is a scored factor). NIST names "explanation accuracy" as one of four principles of explainable AI [7]. Recompute a sample of stored records against the pinned model to catch drift or tampering.
4. **Reuse the record.** The same record renders the adverse-action notice, answers an access request and an Art. 86 request, and gives a human reviewer the context for an appeal. In the UK, the safeguards for significant automated decisions include information about the decision, the chance to make representations, human intervention and a way to contest it [8]; the record carries what each of those steps needs.
5. **Retain and query.** Records stream into the evidence store (layer 05) with a retention period set by the longest obligation they serve. Appeals and their outcomes are logged against the record and counted by group, which feeds the fairness monitoring.

The AI RMF asks that "the AI model is explained, validated, and documented" and its output "interpreted within its context" (MEASURE 2.9), and that transparency and accountability risks are "examined and documented" (MEASURE 2.8) [9].

Illustrative explanation record for a declined credit-limit increase:

```
{
  "record_id": "exp-2026-09-21-118204",
  "decision_id": "cl-2026-09-21-118204",
  "subject": "credit-limit@4.2.1",
  "registry_id": "clm-07",
  "outcome": "limit_increase_declined",
```

```

"decision_role": "determinative",
"method": { "name": "treeshap", "version": "0.46", "baseline": "bg-sample.v14" },
"fidelity_suite": { "suite_id": "explain.fidelity.v2", "result": "pass" },
"reason_codes": [
  { "code": "R07", "text": "Debt-to-income ratio too high", "factor": "dti", "rank": 1 },
  { "code": "R12", "text": "Recent missed payments", "factor": "missed_payments_6m", "rank": 2 }
],
"counterfactual": { "feature": "monthly_debt", "change": "-150", "result": "approve", "mutable_only": true },
"notice": { "template": "adverse-action.en.v6", "language": "en", "channel": "app+letter",
  "delivered": "2026-09-21T10:04:51Z" },
"contest_route": "appeal-flow.v3",
"retention_until": "2031-09-21"
}

```

Example (illustrative) A handset retailer's credit check generated reason codes from SHAP values at request time. A reason-code consistency test found that, for a slice of declines, the top factor was an engineered interaction no notice could describe in plain words. The team moved to a monotone scorecard within a small margin of the complex model, pinned the method in the record, and now answers "why was this customer declined?" with the stored record and a fresh recomputation side by side.

Consequences

Explanations become evidence: reproducible, testable and reusable across duties, with their accuracy checked rather than assumed. The costs: storage and retention for a record per decision; an explanation suite to maintain alongside the model; plain-language templates that need testing with real recipients; and, for complex models, the risk that no faithful explanation is simple enough, which is a design finding, not a documentation one.

Related patterns

[Human-in-the-loop Gate](#); [Fairness Eval Suite](#); [Model Card as Control Evidence](#); [Continuous Assurance Telemetry](#); [Machine-Readable Evidence \(OSCAL\)](#); [Eval Gate in CI](#).

Maps to: EU AI Act Art. 86, Art. 26(11), Art. 13(3)(b)(iv) · GDPR Art. 15(1)(h), Art. 22 · Regulation B (12 CFR 1002.9) · ISO/IEC 42001 A.8.2 · NIST AI RMF (Measure 2.8, 2.9) · Layer 04 Runtime Controls & Observability / Layer 05 Assurance & Continuous Compliance.

Function and subcategory labels follow the NIST AI RMF [9]; ISO/IEC 42001 Annex A ids follow a published crosswalk, not the standard's text [10]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 (AI Act): Art. 86(1) right to explanation of individual decision-making (Annex III systems except point 2); Art. 26(11) deployers inform natural persons subject to Annex III systems; Art. 13(3)(b)(iv) capabilities to provide information relevant to explain the output (text read on the Commission's AI Act Service Desk, 2026-09-24). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] Regulation (EU) 2016/679 (GDPR), Arts. 13(2)(f), 14(2)(g), 15(1)(h), 22 and Recital 71 ("an explanation of the decision reached"). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [3] CJEU, 27 February 2025, CK v Magistrat der Stadt Wien and Dun & Bradstreet Austria GmbH, C-203/22 (Art. 15(1)(h): explain "the procedure and principles actually applied"; a complex mathematical formula is not a sufficiently concise and intelligible explanation). JuLIA project case-law database. 2025-02-27. <https://www.julia-project.eu/database/case-law/319> (verified: secondary) [4] 12 CFR 1002.9 (Regulation B, notifications; 1002.9(b)(2) specific principal reasons) and Supplement I, comment 9(b)(2) (reasons must relate to factors actually considered or scored). eCFR (text as of 2026-09-01). 2026-09-01. <https://www.ecfr.gov/current/title-12/chapter-X/part-1002/section-1002.9> (verified: primary) [5] "Fooling LIME and SHAP: Adversarial Attacks on Post hoc Explanation Methods" (D. Slack, S. Hilgard, E. Jia, S. Singh, H. Lakkaraju). arXiv 1911.02508. 2019-11-06. <https://arxiv.org/abs/1911.02508> (verified: primary) [6] "Stop Explaining Black Box Machine Learning Models for High Stakes Decisions and Use Interpretable Models Instead" (C. Rudin; Nature Machine Intelligence 1:206-215, May 2019). arXiv 1811.10154. 2018-11-26. <https://arxiv.org/abs/1811.10154> (verified: primary) [7] NIST IR 8312, Four Principles of Explainable Artificial Intelligence (explanation, meaningful, explanation accuracy, knowledge limits). NIST. 2021-09-29. <https://doi.org/10.6028/NIST.IR.8312> (verified: primary) [8] Data (Use and Access) Act 2025, s. 80 (replaces UK GDPR Art. 22 with Arts. 22A-22D; Art. 22C safeguards: information, representations, human intervention, contest; in force 5 Feb 2026). legislation.gov.uk. 2025. <https://www.legislation.gov.uk/ukpga/2025/18/section/80> (verified: primary) [9] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MEASURE 2.8 transparency and accountability risks "examined and documented"; MEASURE 2.9 model "explained, validated, and documented" and output "interpreted within its context"). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [10] NIST AI RMF to ISO/IEC FDIS 42001 crosswalk (provider: Microsoft; lists the Annex B implementation-guidance clauses, whose numbers mirror the Annex A control ids, e.g. B.8.2 system documentation and information for users; the ISO text was not opened). NIST AI Resource Center. 2023. https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf (verified: secondary)

Pattern: Model Artefact Integrity

Summary: Treat model weights and their companion files as supply-chain artefacts. Sign a manifest of every file and its digest when the build produces them, attach build provenance that says what built them from which inputs, prefer serialisation formats that cannot execute code and scan the ones that can, and make every runtime verify the signature, the digests and the provenance against the registry entry before it loads a model. The verification writes an evidence record, so "which bytes ran, and who produced them?" has an answer.

Objectives

Guarantee that the model a service loads is the model the pipeline built, evaluated and registered, from a known producer, and that loading it cannot run an attacker's code.

Target users

ML platform team, security engineer, AI governance engineer, MLOps engineer.

Impacted stakeholders

Users and people affected by the system's outputs, model owners, downstream deployers, auditors and market surveillance authorities.

Relevant principles

Register and bound every actor before it acts; build the control at the earliest point it can block; instrument the build to produce its own proof.

Context

Models move from training jobs to registries to serving clusters, are fine-tuned from bases pulled from public hubs, and are copied between environments and regions. The files are large binaries nobody reads. Common formats are not inert: the Python documentation warns that "The pickle module is not secure. Only unpickle data you trust." [1], and Hugging Face describes "dangerous arbitrary code execution attacks" that can run when a pickle file is loaded [2].

Problem

The pipeline evaluates one model and production may load another.

- **Forces.** Teams pull weights by name or tag, and a tag can be moved. Scanning helps but, as Hugging Face says of its own pickle-import scanner, it "is not 100% foolproof" [2]. The EU AI Act expects high-risk systems to resist attacks on "pre-trained components used in training (model poisoning)" (Art. 15(5)) [3]. MITRE ATLAS catalogues supply-chain compromise of the model itself (AML.T0010.003) and user execution of unsafe AI artefacts (AML.T0011.000) [4], and OWASP lists supply chain as LLM04:2026 [5] and agentic supply-chain vulnerabilities as ASI04 [6].
- **Failure mode.** A tampered or malicious model file loads with the privileges of the serving process. Or a model that skipped the eval gate reaches production through a manual copy. After an incident, nobody can prove which weights produced the outputs in question.

Solution

Sign at build, prove how it was built, load only safe formats, and verify before load.

1. **Sign at build.** Produce a manifest listing every model file and its cryptographic digest and sign the manifest. The OpenSSF Model Signing (OMS) specification, introduced by OpenSSF in June 2025, does exactly this: a detached signature over a manifest of file hashes, in the Sigstore bundle format, and PKI-agnostic (enterprise PKI, self-signed certificates, bare keys or keyless Sigstore) [7]; its reference implementation is the `model-signing` library and CLI in the sigstore model-transparency repository, whose verification recomputes the hashes [8].
2. **Attach build provenance.** Record what built the artefact, by what process and from which top-level inputs, as SLSA provenance (<https://slsa.dev/provenance/v1>). SLSA v1.2 defines Build L1 (provenance exists), L2 (a hosted build platform, so forging provenance takes an explicit attack) and L3 (hardened builds, where forging it requires exploiting a vulnerability "beyond the capabilities of most adversaries") [9]. Include the base model's digest and the dataset admission records among the inputs, and list the same artefacts in the AIBOM.
3. **Prefer safe formats; scan the rest.** Store weights as safetensors, "a new simple format for storing tensors safely (as opposed to pickle)" [10]. Where a framework still loads pickle, keep its restrictions on: PyTorch's `torch.load` defaults to `weights_only=True` in its current documentation and warns "Never load data from an untrusted source" [11]. Scan every serialised file for code-executing imports before it reaches a registry, and quarantine what fails.
4. **Pin third-party models by digest.** Pull by content digest, not by tag; verify the publisher's signature where one exists; scan and re-host the artefact in the internal registry; and record the upstream source and digest in the registry entry.
5. **Verify before load.** The serving platform's admission control refuses a model whose signature, signer identity, file digests or provenance do not match the registry entry for the version being deployed, and writes an evidence record either way. ATLAS

lists code signing (AML.M0013), verifying AI artefacts (AML.M0014), vulnerability scanning (AML.M0016) and an AI bill of materials (AML.M0023) among its mitigations [4].

The AI RMF asks that pre-trained models used for development are "monitored as part of AI system regular monitoring and maintenance" (MANAGE 3.2) and that security and resilience are "evaluated and documented" (MEASURE 2.7) [12]. Providers of general-purpose models with systemic risk must ensure "an adequate level of cybersecurity protection" for the model and its physical infrastructure (Art. 55(1)(d)) [3].

Illustrative verification at load, valid against the published [evidence record schema](#) (evidence-record.v1):

```
{
  "$schema": "https://aigovernanceengineer.com/schemas/evidence-record.v1.json",
  "control_id": "model.integrity.verify-at-load.v2",
  "subject": "support-rag-llm@2026-09-20",
  "decision": "allow",
  "obligation": "EU AI Act Art. 15(5)",
  "failure_mode": "tampered or malicious model weights loaded into serving",
  "input_hash": "sha256:8c1f4e2d7a9b3c6e5f0a1b2c3d4e5f6a7b8c9d0e1f2a3b4c5d6e7f8a9b0c1d2e",
  "actor": "serving-admission-controller",
  "timestamp": "2026-09-20T07:31:05Z",
  "signature": "ed25519:Tq5w2Lr8Zk1Xv7Nc4Pb9Hs6Gd3Fa0Jm",
  "extensions": {
    "signature_bundle": "model.sig",
    "signer": "build-pipeline@models.example.org",
    "files_verified": 7,
    "formats": ["safetensors", "json"],
    "pickle_files": 0,
    "provenance": { "predicate_type": "https://slsa.dev/provenance/v1", "build_level": "L3",
      "builder": "ci.example.org/model-builds" },
    "registry_entry": "support-rag-llm"
  }
}
```

Example (illustrative) A platform team found that three services loaded the "same" fine-tuned model from three different buckets, one copied by hand months earlier. They moved signing into the training pipeline, made the serving admission controller verify the manifest and the provenance against the registry entry, and converted the remaining pickle checkpoints to safetensors. The first week's evidence records showed one deployment refused on a digest mismatch: the hand-copied model, which had never passed the current eval gate.

Consequences

What runs is provably what was built and evaluated, supply-chain attacks on the model have to defeat a signature and a provenance check instead of a file copy, and every load leaves evidence. The costs: key management or a Sigstore dependency; build-platform work to reach higher SLSA levels; conversion of legacy checkpoints; and verification latency at load, which is small next to model load times but must be budgeted for fast scale-out.

Related patterns

[AIBOM](#); [Agent Registry](#); [AI Threat Model](#); [Vendor / Model Due-Diligence Gate](#); [Eval Gate in CI](#); [Continuous Assurance Telemetry](#).

Maps to: EU AI Act Art. 15(5), Art. 55(1)(d) · ISO/IEC 42001 A.6.2.5, A.10.3 · NIST AI RMF (Govern 6.1; Manage 3.2; Measure 2.7) · OWASP LLM04:2026 · OWASP Agentic ASI04 · MITRE ATLAS · Layer 02 Inventory & Transparency / Layer 04 Runtime Controls & Observability.

Threat IDs follow the OWASP Top 10 for LLM Applications 2026 [5] and for Agentic Applications 2026 [6] and MITRE ATLAS [4]; function and subcategory labels follow the NIST AI RMF [12]; ISO/IEC 42001 Annex A ids follow a published crosswalk, not the standard's text [13]. Mappings are illustrative, not a claim of conformity.

Sources

[1] pickle: Python object serialization ("The pickle module is not secure. Only unpickle data you trust."). Python Software Foundation. 2026. <https://docs.python.org/3/library/pickle.html> (verified: primary) [2] Pickle Scanning (arbitrary code execution when loading pickle files; the Hub's pickle-import scan "is not 100% foolproof"; safetensors). Hugging Face Hub documentation. n.d. (accessed 2026-09-24). <https://huggingface.co/docs/hub/security-pickle> (verified: primary) [3] Regulation (EU) 2024/1689 (AI Act): Art. 15(5) resilience against exploitation of vulnerabilities, incl. model poisoning through pre-trained components used in training; Art. 55(1)(d) cybersecurity protection for GPAI models with systemic risk and their physical infrastructure (text read on the Commission's AI Act Service Desk, 2026-09-24). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [4] MITRE ATLAS data, release 2026.09 (modified 2026-09-15; AML.T0010.003 AI Supply Chain Compromise: Model; AML.T0011.000 User Execution: Unsafe AI Artifacts; mitigations AML.M0013 Code Signing, AML.M0014 Verify AI Artifacts, AML.M0016 Vulnerability Scanning, AML.M0023 AI Bill of Materials). MITRE (atlas-

data repository). 2026-09-15. <https://github.com/mitre-atlas/atlas-data> (verified: primary) [5] OWASP Top 10 for LLM Applications 2026 (LLM04:2026 Supply Chain). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [6] Top 10 for Agentic Applications 2026 (ASI04 Agentic Supply Chain Vulnerabilities). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [7] "An Introduction to the OpenSSF Model Signing (OMS) Specification" (detached signature over a manifest of file hashes; Sigstore bundle format; PKI-agnostic: private or enterprise PKI, self-signed certificates, bare keys, keyless Sigstore; `pip install model-signing`). OpenSSF. 2025-06-25. <https://openssf.org/blog/2025/06/25/an-introduction-to-the-openssf-model-signing-oms-specification/> (verified: primary) [8] model-transparency: supply chain security for ML (OpenSSF-linked model signing; signs an in-toto statement of file paths and digests through Sigstore or conventional keys; verification recomputes the hashes). Sigstore (GitHub). 2026. <https://github.com/sigstore/model-transparency> (verified: primary) [9] SLSA specification v1.2, Build track basics (Build L1 provenance exists; L2 hosted build platform; L3 hardened builds; provenance describes what built the artefact, by what process and from which top-level inputs; predicate type <https://slsa.dev/provenance/v1>). OpenSSF SLSA project. n.d. (accessed 2026-09-24). <https://slsa.dev/spec/v1.2/build-track-basics> (verified: primary) [10] Safetensors ("a new simple format for storing tensors safely (as opposed to pickle)"). Hugging Face documentation. n.d. (accessed 2026-09-24). <https://huggingface.co/docs/safetensors/index> (verified: primary) [11] torch.load (default `weights_only=True`; "Never load data from an untrusted source"). PyTorch documentation (2.14). n.d. (accessed 2026-09-24). <https://docs.pytorch.org/docs/stable/generated/torch.load.html> (verified: primary) [12] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (GOVERN 6.1 third-party risks; MANAGE 3.2 pre-trained models "monitored as part of AI system regular monitoring and maintenance"; MEASURE 2.7 security and resilience "evaluated and documented"). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [13] NIST AI RMF to ISO/IEC FDIS 42001 crosswalk (provider: Microsoft; lists the Annex B implementation-guidance clauses, whose numbers mirror the Annex A control ids, e.g. B.6.2.5 AI system deployment, B.10.3 suppliers; the ISO text was not opened). NIST AI Resource Center. 2023. https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf (verified: secondary)

Pattern: Claims Substantiation Gate

Summary: Keep a register of every public statement about what an AI system does and how well: accuracy, fairness, safety, autonomy, "AI-powered" capability. Each claim is a row that cites the eval run supporting it, the population and conditions it was measured on, and the date. A gate blocks publication of a claim without live evidence, and every model release reruns the cited evals and flags any claim the new version no longer supports. It is an eval gate pointed at marketing copy, sales material and the accuracy figures declared in the instructions for use.

Objectives

Say only what the evidence supports, for the population the claim describes, and keep saying it only while it stays true; and be able to show, for any claim, what supported it on the day it was made.

Target users

AI governance engineer, product marketing, sales enablement, ML engineer, legal and consumer-law counsel, investor relations.

Impacted stakeholders

Customers and consumers, deployers who rely on the provider's figures, investors, consumer-protection and financial regulators, market surveillance authorities.

Relevant principles

Give every control teeth; instrument the build to produce its own proof; start from a named failure mode or harm.

Context

Product pages, sales decks, tenders, investor materials, model cards and instructions for use all say how accurate, fair, safe or autonomous a system is. The copy is written once and owned by marketing; the evidence is produced by ML and changes with every release. Regulators read that copy. The FTC's Operation AI Comply announced that "there is no AI exemption from the laws on the books" [1]; its Workado order followed a claim of 98% accuracy for an AI-content detector that testing put at 53% on general-purpose content, and requires competent and reliable evidence for such claims [2]. The SEC settled with two investment advisers over false and misleading statements about their use of AI [3]. Under the EU AI Act, the intended purpose itself is defined partly by the provider's "promotional or sales materials and statements" (Art. 3(12)), and for high-risk systems the "levels of accuracy and the relevant accuracy metrics" must be declared in the instructions for use (Art. 15(3)), stating the level "against which the high-risk AI system has been tested and validated" (Art. 13(3)(b)(ii)) [4].

Problem

Claims outlive the evidence that once supported them, or never had any.

- **Forces.** Marketing wants a simple number; the honest number has an interval and a population. Evals are run on the data at hand, not on the population the claim describes: Workado's detector was trained on academic text, and the claim failed on everything else [2]. Vendor figures get repeated as if measured in-house. Deception, in the FTC's policy statement, is a

representation, omission or practice likely to mislead a consumer acting reasonably, and material [5]; the EU's Unfair Commercial Practices Directive and the UK's Digital Markets, Competition and Consumers Act 2024 prohibit unfair commercial practices in general terms [6] [7].

- **Failure mode.** A regression ships and the old accuracy claim stays on the website. A fairness claim rests on a vendor brochure. An authority asks what supported a statement made last year, and the only answer is the slide it appeared on.

Solution

Register the claim, bind it to evidence, and gate both publication and release on the binding.

1. **Register every claim.** One row per claim: the exact text, every place it appears (URLs, documents, the instructions for use, the model card), the system and version, the metric, the claimed value, the owner and the status. "AI-powered" and "autonomous" are claims too: the row points at the registry entry that shows what the system actually does.
2. **Bind each claim to evidence.** The row cites the eval suite and run, the measured value with its interval, and the population and conditions of measurement. The AI RMF's test is the right one: performance "demonstrated for conditions similar to deployment setting(s)" (MEASURE 2.3), with the limits of generalisation documented (MEASURE 2.5) [8]. Substantiation rules run as code: the measurement population must match the claim's scope; a point figure is claimed only if the lower interval bound supports it; a comparative claim needs a paired comparison on the same data; a figure supplied by a vendor is marked provider-attested until re-measured.
3. **Gate publication.** Copy that carries a registered claim cannot be published, or sent in a tender, while the claim's evidence is missing, stale or failing. Unregistered quantitative claims are caught in review by the same rule that blocks unregistered systems.
4. **Gate the release.** Every model release reruns the cited suites. A claim whose evidence falls below the claimed value fails the release or opens a withdrawal task with a deadline and an owner; the declared accuracy in the instructions for use is regenerated from the same rows.
5. **Keep the history.** Withdrawn and amended claims keep their record (what was said, where, on which evidence, until when), so the organisation can show what it knew and when.

Illustrative claims-register row:

```
{
  "claim_id": "CLM-2026-017",
  "text": "Catches 95% of card-not-present fraud",
  "locations": [ "https://www.example.com/product/fraud-shield", "sales-deck-2026Q3#slide-4",
    "instructions-for-use/fraud-cnp/5.3#accuracy" ],
  "system": "fraud-cnp@5.3.0",
  "metric": "recall on confirmed card-not-present fraud",
  "claimed_value": 0.95,
  "evidence": { "suite_id": "fraud.recall.cnp.v7", "run": "ci-run-99812", "value": 0.962,
    "ci95": [0.953, 0.970], "population": "EU card-not-present, 2026-Q2, n=4120 confirmed fraud",
    "timestamp": "2026-09-12T08:00:00Z" },
  "scope_match": "pass",
  "status": "substantiated",
  "owner": "product-marketing-fraud",
  "revalidate_on": [ "model_release", "2026-12-31" ]
}
```

Example (illustrative) A fraud product's website claimed a detection rate measured two model versions earlier on one country's traffic. Registering the claim showed both gaps: the evidence was stale and the population narrower than the copy implied. The claim was rewritten to name the region, the next release reran the suite, and a later retrain that dipped below the claimed value opened a withdrawal task before the new model shipped.

Consequences

Public statements become evidenced, scoped and dated, stale claims are pulled by the pipeline rather than by a regulator, and the declared accuracy in the instructions for use stays consistent with marketing. The costs: marketing and legal must accept a register and a review step; honest claims are narrower and carry intervals; and the rule on scope-matching needs judgement for qualitative claims, which stay with legal review.

Related patterns

[Eval Gate in CI](#); [Fairness Eval Suite](#); [Model Card as Control Evidence](#); [Machine-Readable Evidence \(OSCAL\)](#); [Use-Case Intake & Risk Tiering](#); [Vendor / Model Due-Diligence Gate](#).

Maps to: EU AI Act Art. 3(12), Art. 13(3)(b)(ii), Art. 15(3) · FTC Act s. 5 · Directive 2005/29/EC Art. 5 · DMCC Act 2024 s. 225 · ISO/IEC 42001 A.8.2, A.8.5 · NIST AI RMF (Measure 2.3, 2.5) · Layer 05 Assurance & Continuous Compliance / Layer 03 Evals & Red Teaming as Evidence.

Function and subcategory labels follow the NIST AI RMF [8]; ISO/IEC 42001 Annex A ids follow a published crosswalk, not the standard's text [9]. Mappings are illustrative, not a claim of conformity.

Sources

[1] "FTC Announces Crackdown on Deceptive AI Claims and Schemes" (Operation AI Comply; "there is no AI exemption from the laws on the books"). Federal Trade Commission. 2024-09-25. <https://www.ftc.gov/news-events/news/press-releases/2024/09/ftc-announces-crackdown-deceptive-ai-claims-schemes> (verified: primary) [2] "FTC Order Requires Workado to Back Up Artificial Intelligence Detection Claims" (claimed 98% accuracy; 53% on general-purpose content; trained on academic text; competent and reliable evidence required). Federal Trade Commission. 2025-04-28. <https://www.ftc.gov/news-events/news/press-releases/2025/04/ftc-order-requires-workado-back-artificial-intelligence-detection-claims> (verified: primary) [3] "SEC Charges Two Investment Advisers with Making False and Misleading Statements About Their Use of Artificial Intelligence" (Delphia and Global Predictions; USD 400,000 combined penalties). US Securities and Exchange Commission. 2024-03-18. <https://www.sec.gov/newsroom/press-releases/2024-36> (verified: primary) [4] Regulation (EU) 2024/1689 (AI Act): Art. 3(12) intended purpose incl. "promotional or sales materials and statements"; Art. 13(3)(b)(ii) level of accuracy, incl. its metrics, against which the system has been tested and validated; Art. 15(3) accuracy levels and metrics declared in the instructions for use (text read on the Commission's AI Act Service Desk, 2026-09-24). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [5] FTC Policy Statement on Deception (representation, omission or practice likely to mislead a consumer acting reasonably; materiality). Federal Trade Commission. 1983-10-14. <https://www.ftc.gov/legal-library/browse/ftc-policy-statement-deception> (verified: primary) [6] Directive 2005/29/EC (Unfair Commercial Practices Directive), Art. 5 (general prohibition; professional diligence; average and vulnerable consumer). Official Journal of the EU. 2005-05-11. <https://eur-lex.europa.eu/eli/dir/2005/29/oj> (verified: primary) [7] Digital Markets, Competition and Consumers Act 2024, s. 225 (unfair commercial practices prohibited; in force 6 Apr 2025). legislation.gov.uk. 2024. <https://www.legislation.gov.uk/ukpga/2024/13/section/225> (verified: primary) [8] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MEASURE 2.3 performance "demonstrated for conditions similar to deployment setting(s)"; MEASURE 2.5 validity and reliability, limits of generalisability documented). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [9] NIST AI RMF to ISO/IEC FDIS 42001 crosswalk (provider: Microsoft; lists the Annex B implementation-guidance clauses, whose numbers mirror the Annex A control ids, e.g. B.8.2 system documentation and information for users, B.8.5 information for interested parties; the ISO text was not opened). NIST AI Resource Center. 2023. https://airc.nist.gov/docs/NIST_AI_RMF_to_ISO_IEC_42001_Crosswalk.pdf (verified: secondary)

Pattern: Decision Notice & Contest Path

Summary: When an AI system makes or shapes a decision about a person, send a notice at the point of decision, generated from the decision record, that says a system was involved, gives the principal reasons and says how to contest; and run a contest path to a reviewer with the authority and the information to change the outcome. The notice, the contest and the review outcome are all records, so the right to contest is evidenced decision by decision instead of asserted in a policy.

Objectives

Make every consequential automated decision explainable to, and contestable by, the person it affects, and leave a record showing that the notice went out, that the contest was heard and that the outcome stood or changed for a stated reason.

Target users

AI governance engineer, product engineer, DPO, the operations owner of the decision (credit, claims, hiring).

Impacted stakeholders

Applicants, customers, employees and other affected persons; human reviewers; supervisory and market-surveillance authorities; auditors.

Relevant principles

Start from a named failure mode or harm; instrument the build to produce its own proof; give every control teeth.

Context

A deployed system decides, or shapes a decision, about a person: credit, insurance, a job, access to a service. Several regimes attach duties to that same moment. Under GDPR Article 22 a solely automated decision with legal or similarly significant effects is allowed only on a narrow basis, and then with at least the right to obtain human intervention, to express a point of view and to contest the decision; Articles 13(2)(f) and 15(1)(h) add meaningful information about the logic involved [1]. The Court of Justice has held that a credit score is itself such a decision when lenders give it a determining role [2]. In the UK, Articles 22A to 22D, in force since 5 Feb 2026, require information about the decision, the chance to make representations, human intervention and a way to contest [3].

Under the EU AI Act, deployers of Annex III high-risk systems that make or assist decisions about people must tell them that the system is used (Art. 26(11)), and an affected person may obtain a clear and meaningful explanation of the system's role and the main elements of the decision (Art. 86), a right that applies only where Union law does not already provide it [4]. As of 2026-09-24 the Annex III requirements apply from 2 Dec 2027 [5]. Art. 86 itself has applied since 2 Aug 2026 (Art. 113) [4], but it

attaches to decisions based on Annex III high-risk systems, so on this site's reading it has work to do only from 2 Dec 2027. A US creditor that takes adverse action must notify the applicant within 30 days of a completed application, with the specific principal reasons [6]. The CFPB said in 2022 that a complex algorithm does not excuse vague reasons [7], but withdrew that circular on 12 May 2025; the Regulation B duty itself is unchanged [6][12]. Colorado adds, from 1 Jan 2027, a notice of use, a plain-language explanation of an adverse outcome and human review for automated decisions in consequential areas [8].

Problem

Each regime tends to be answered on its own: a letter template owned by operations, an appeal inbox owned by customer service, an explanation page owned by legal. None of them is tied to the decision record, so nobody can show which notice a given person received, which reasons it gave, whether those reasons were the factors the model actually used, or what the reviewer did with the contest. A contest path that ends at a reviewer who confirms almost every output in seconds is not meaningful human involvement; it is a queue.

Forces

- **Fidelity against readability.** The reasons must be the factors the model actually used, yet short and plain enough for a person to act on.
- **Clocks against capacity.** Notices run on deadlines (30 days under Regulation B), and a real review costs staff time that scales with the contest rate.
- **Disclosure against protection.** Meaningful information about the logic has to coexist with trade secrets and with not teaching people to game the model; the Court of Justice leaves that balance to the authority or court, not to the controller alone [9].
- **One decision, many regimes.** The same decline can fall under the GDPR, the AI Act, a sector law and a US state law at once, each with its own content, audience and clock.

Solution

Build the notice and the contest as two services around one decision record.

1. **Decision record first.** At runtime, write one record per decision: system and model version, inputs by reference, outcome, reason codes, whether the decision was solely automated, the legal basis and the regimes that apply. The review side follows the [Human-in-the-loop Gate](#).
2. **Notice from versioned templates.** A notice service reads the record and renders the notice from a template per regime and language: that a system was used, the principal reasons, what the person can do and by when. The template version and the send time are written back to the record. A reason-code fidelity eval, run as an [Eval Gate in CI](#), checks that the reasons a notice gives are the factors the model used.
3. **A contest path with authority.** A contest opens a case linked to the decision id and routed to a reviewer who did not take the original decision, who sees the inputs, the reasons and the person's representations, and who can change the outcome. Time to decide and reversal rates are monitored by group: a reviewer who confirms nearly everything is a signal, not a safeguard.
4. **Close the loop.** The review outcome, its reason and any correction are written to the record. Contest and reversal rates feed the [Drift & Fairness Monitor](#), and a cluster of overturned decisions on one reason code opens an issue against the model.

Illustrative decision notice record, written by the notice service and completed by the contest path:

```
{
  "decision_id": "cc4-2026-09-18-0192",
  "subject": "credit-check-04@3.2",
  "solely_automated": true,
  "regimes": ["GDPR Art. 22", "Regulation B 1002.9"],
  "outcome": "declined",
  "reason_codes": ["R07 payment arrears", "R12 short credit history"],
  "notice": {
    "template": "adverse-action.en.v5",
    "sent_at": "2026-09-18T10:02:11Z",
    "due_by": "2026-10-18"
  },
  "contest": {
    "opened_at": "2026-09-20T08:14:00Z",
    "reviewer_role": "credit-review-12",
    "outcome": "overturned",
    "reason": "Arrears cleared; the applicant supplied the settlement statement.",
    "closed_at": "2026-09-23T15:40:00Z"
  }
}
```

Example (illustrative) A telco's handset-financing check declines an applicant. The notice service sends the decline with two reason codes and a contest link within the hour. The applicant contests with a settlement statement, a second-line reviewer overturns the decline, and the overturn rate for reason code R07 enters the next threshold review of the model.

Consequences

Each person's notice and contest can be produced on request, and the contest channel becomes a sensor for model error and unfairness. The cost is a notice service with per-regime templates to keep current, reviewer capacity with real authority, and a reason-code fidelity eval. Faithful but unhelpful reasons still fail the person, so test the notices with the people who receive them.

Related patterns

[Human-in-the-loop Gate](#); [Eval Gate in CI](#); [Drift & Fairness Monitor](#); [Disclosure & Notification Pipeline](#); [Rights Requests Against Models](#).

Maps to: EU AI Act Art. 26(11), Art. 86 · GDPR Art. 13(2)(f), Art. 15(1)(h), Art. 22 · UK GDPR Arts. 22A–22D · ECOA / Regulation B 12 CFR 1002.9 · ISO/IEC 42001 A.8.2, A.9.2 · NIST AI RMF MEASURE 3.3, MANAGE 4.1, MAP 3.5 · Layer 04 Runtime Controls & Observability / Layer 05 Assurance & Continuous Compliance.

Control ids follow ISO/IEC 42001 Annex A [10] and subcategory ids the NIST AI RMF [11]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2016/679 (General Data Protection Regulation; Arts. 13(2)(f), 14(2)(g), 15(1)(h), 22). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [2] Press release No 186/23: judgment in Case C-634/21, SCHUFA Holding (Scoring) (a credit score is an automated individual decision where lenders give it a determining role). Court of Justice of the EU. 2023-12-07. <https://curia.europa.eu/jcms/upload/docs/application/pdf/2023-12/cp230186en.pdf> (verified: primary) [3] Data (Use and Access) Act 2025, s. 80 (replaces UK GDPR Art. 22 with Arts. 22A–22D; Art. 22C safeguards: information, representations, human intervention, contest; in force 5 Feb 2026). legislation.gov.uk. 2025. <https://www.legislation.gov.uk/ukpga/2025/18/section/80> (verified: primary) [4] Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), of 13 June 2024; OJ L, 2024/1689, 12.7.2024 (Art. 26(11) informing persons subject to Annex III decisions; Art. 86(1) and (3) right to explanation, subsidiary to other Union law; Art. 113, general application from 2 Aug 2026). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [5] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 (Annex III high-risk requirements from 2 Dec 2027); OJ L, 2026/1744, 24.7.2026. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [6] 12 CFR 1002.9 (Regulation B, notifications: 1002.9(a)(1) action taken notified within 30 days of a completed application; 1002.9(b)(2) specific principal reasons). eCFR (text as of 2026-09-01). 2026-09-01. <https://www.ecfr.gov/current/title-12/chapter-X/part-1002/section-1002.9> (verified: primary) [7] Consumer Financial Protection Circular 2022-03, Adverse action notification requirements in connection with credit decisions based on complex algorithms (ECOA and Regulation B; withdrawn by the CFPB on 2025-05-12, 90 FR 20084, FR Doc. 2025-08286, item 14, although the page shows no withdrawal banner as of 2026-09-24). Consumer Financial Protection Bureau. 2022-05-26. <https://www.consumerfinance.gov/compliance/circulars/circular-2022-03-adverse-action-notification-requirements-in-connection-with-credit-decisions-based-on-complex-algorithms/> (verified: primary) [8] SB26-189, Automated Decision-Making Technology (repeals and re-enacts SB 24-205; signed 2026-05-14; effective 2027-01-01; deployer notice, 30-day explanation, human review, three-year records). Colorado General Assembly. 2026-05-14. <https://leg.colorado.gov/bills/sb26-189> (verified: primary) [9] Press release No 22/25: judgment in Case C-203/22, Dun & Bradstreet Austria (explanation of the procedure and principles actually applied; an algorithm alone is not an explanation; trade secrets balanced by the authority or court). Court of Justice of the EU. 2025-02-27. <https://curia.europa.eu/site/upload/docs/application/pdf/2025-02/cp250022en.pdf> (verified: primary) [10] ISO/IEC 42001:2023, AI management system, Annex A controls referenced by identifier and short title only (A.8.2 system documentation and information for users; A.9.2 processes for responsible use of AI systems). ISO/IEC (titles checked via a secondary listing). 2023-12. <https://www.iso.org/standard/42001> (verified: secondary) [11] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MAP 3.5 human oversight processes; MEASURE 3.3 feedback and appeal processes for end users and impacted communities; MANAGE 4.1 post-deployment monitoring plans, including appeal and override). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [12] Withdrawn guidance (Circular 2022-03 on adverse-action notices for credit decisions based on complex algorithms, 87 FR 35864, withdrawn on 12 May 2025 by the notice at 90 FR 20084). Consumer Financial Protection Bureau. 2025-05-12. <https://www.consumerfinance.gov/compliance/guidance/withdrawn-guidance/> (verified: primary)

Pattern: Rights Requests Against Models

Summary: Route each data-subject request (access, rectification, erasure, objection) to every place the person's data sits in an AI system: source systems, training and fine-tuning snapshots, retrieval indexes, prompt and output logs, eval sets and, where the model is not anonymous, the weights. Each location has a pre-agreed response on a ladder from immediate deletion to scheduled retraining, and the request closes with a fulfilment record that says what was done where, and when the remaining gap closes.

Objectives

Honour data-subject rights inside the deadline across the whole AI data estate, not only the database, and be able to show per request which locations were reached, what was done in each and which model versions still carry the person's data until the next retrain.

Target users

DPO, AI governance engineer, data platform team, ML engineer.

Impacted stakeholders

Data subjects, controllers and processors in the AI supply chain, supervisory authorities, model owners.

Relevant principles

Register and bound every actor before it acts; instrument the build to produce its own proof; build the control at the earliest point it can block.

Context

The GDPR gives people rights of access, rectification, erasure and objection, and the controller must act on a request within one month, extendable by two further months for complex requests [1]. In an AI system the person's data no longer sits in one table. Whether a trained model is anonymous is assessed case by case: the EDPB's opinion on AI models sets out when a model trained on personal data can be considered anonymous and what evidence the controller needs, and a model that fails the test is in scope of the rights [2]. The CNIL's guidance adds that a controller that cannot identify a person in a training set may say so, that the person may supply information that makes identification possible, that retraining answers a request where the data is still held, and that output filters are acceptable where retraining is disproportionate, if shown to be effective [3]. The Hamburg data protection authority starts elsewhere, taking the view that storing a large language model is not processing and that rights attach to the system's inputs and outputs [4]. A deployer has to work under either reading.

Problem

Request tooling built for databases stops at the CRM. The same person's record also sits in a fine-tuning snapshot, a retrieval index, three months of prompt logs and an eval set, and a model tuned on that snapshot can reproduce it. Without a map from the person to those locations, an erasure closes on time and is still incomplete; without a record per location, nobody can say why output suppression was chosen over retraining, or when the retrain that closes the gap will ship.

Forces

- **Completeness against cost.** Deleting a row is cheap; retraining a large model for one request is not, so the response to the weights is usually staged.
- **Deadline against batch.** The one-month clock favours fast partial measures now and complete ones on a schedule.
- **Retention against erasure.** High-risk deployers keep automatically generated logs for at least six months unless other law provides otherwise [5], while storage limitation pushes the other way.
- **Verifiability.** Approximate unlearning methods are hard to verify, so a claim that a record's influence is gone needs a test, not an assertion.

Solution

Treat the request as a fan-out job over a data map, and the model as one more location.

1. **A data map keyed by subject.** Build the map from lineage you already keep: data cards, dataset admission records and the AIBOM say which snapshots fed which model version, and the registry says which indexes and logs each system writes. Keep a pseudonymous subject key so a request can be matched without copying identities into the map.
2. **One request, many handlers.** The router opens one ticket and fans it out to a handler per location, each with a pre-agreed response: delete from source systems and snapshots; delete or re-index retrieval chunks at once; delete or pseudonymise logs within the retention rule; replace eval records with synthetic ones; flag every model version trained on an affected snapshot.
3. **A ladder for the weights.** Output suppression first, as a filter built on general rules rather than a list of names, tested like any control. Then retraining without the data, on a schedule that batches requests. Machine unlearning only as a claim to test: exact methods such as sharded training limit what must be retrained [6], and a membership-inference test on the removed records checks the result [7].
4. **Gate the next release.** The release gate checks that pending erasures are applied to the training set of the candidate version, so a retrain cannot quietly reintroduce the data.
5. **A fulfilment record per request.** The workflow writes it, not the DPO: every location, the action taken, the model versions affected, the scheduled retrain and whether the deadline was met.

Illustrative fulfilment record for an erasure request against `csa-01` :


```
{
  "request_id": "dsr-2026-0412",
  "right": "erasure",
  "subject_key": "hash:7c1e09b4",
  "received_at": "2026-09-02",
  "due_by": "2026-10-02",
  "locations": [
    { "store": "crm", "action": "deleted" },
    { "store": "rag_index:csa-kb@2026-09", "action": "deleted_and_reindexed" },
    { "store": "fine_tune_set:csa-ft-07", "action": "deleted" },
    { "store": "logs:csa-01", "action": "deleted" },
    { "store": "eval_set:csa-regression-v9", "action": "replaced_with_synthetic" },
    { "store": "weights:csa-01@2026-08-30", "action": "output_suppression", "rule": "dsr-0412" }
  ],
  "models_flagged": ["csa-01@2026-08-30"],
  "retrain_scheduled": "csa-01@2026-10-15",
  "closed_at": "2026-09-30",
  "within_deadline": true
}
```

Example (illustrative) A customer asks a support assistant's operator to erase their data. The router finds the person in the CRM, a retrieval index, a fine-tuning snapshot and 90 days of logs. Four handlers delete within a day; the weights get an output filter, tested against the customer's own records, and the next scheduled retrain drops the snapshot. The fulfilment record goes to the customer's file and to the assurance store.

Consequences

Requests close on time with evidence per location, and the gap between suppression and retraining is visible and dated rather than hidden. The cost is lineage good enough to build the data map, handlers for every store, and retraining capacity. Suppression filters leak under adversarial prompting, so they are an interim measure with an expiry, not the answer.

Related patterns

AIBOM; Model Card as Control Evidence; Eval Gate in CI; Decision Notice & Contest Path; Continuous Assurance Telemetry.

Maps to: GDPR Art. 12(3), Arts. 15–17, Art. 21 · EU AI Act Art. 26(6) · ISO/IEC 42001 A.7 · NIST AI RMF MEASURE 2.10, GOVERN 1.1 · OWASP LLM02:2026 · Layer 02 Inventory & Transparency / Layer 05 Assurance & Continuous Compliance.

Threat ids follow the OWASP Top 10 for LLM Applications 2026 [8], control ids ISO/IEC 42001 Annex A [9] and subcategory ids the NIST AI RMF [10]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2016/679 (General Data Protection Regulation; Art. 12(3) one month, extendable by two further months; Arts. 15, 16, 17, 21). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [2] Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (anonymity test at para 43; elements and documentation for the controller's evidence at paras 49–58). European Data Protection Board. 2024-12-17. https://www.edpb.europa.eu/system/files/2024-12/edpb_opinion_202428_ai-models_en.pdf (verified: primary) [3] "Ensuring and facilitating the exercise of data subjects' rights" (AI how-to sheet; identification in training sets; retraining; output filters based on general rules; one month plus two). CNIL. 2026-01-05. <https://www.cnil.fr/en/respect-and-facilitate-exercise-data-subjects-rights> (verified: primary) [4] Discussion Paper: Large Language Models and Personal Data (storing an LLM is not processing; rights attach to system inputs and outputs). Hamburg Commissioner for Data Protection and Freedom of Information. 2024-07-15. https://datenschutz-hamburg.de/fileadmin/user_upload/HmbBfDI/Datenschutz/Informationen/240715_Discussion_Paper_Hamburg_DPA_KI_Models.pdf (verified: primary) [5] Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), of 13 June 2024; OJ L, 2024/1689, 12.7.2024 (Art. 26(6) deployers keep automatically generated logs for at least six months, unless Union or national law provides otherwise). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [6] Bourtole et al., "Machine Unlearning" (SISA training; arXiv 1912.03817). arXiv. 2019-12-09. <https://arxiv.org/abs/1912.03817> (verified: primary) [7] Shokri et al., "Membership Inference Attacks against Machine Learning Models" (arXiv 1610.05820). arXiv. 2016-10-18. <https://arxiv.org/abs/1610.05820> (verified: primary) [8] OWASP Top 10 for LLM Applications 2026 (LLM02 Sensitive Information Disclosure). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [9] ISO/IEC 42001:2023, AI management system, Annex A controls referenced by identifier and short title only (A.7 data for AI systems). ISO/IEC (titles checked via a secondary listing). 2023-12. <https://www.iso.org/standard/42001> (verified: secondary) [10] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (GOVERN 1.1 legal and regulatory requirements understood, managed and documented; MEASURE 2.10 privacy risk examined and documented). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary)

Pattern: Sanctioned AI Gateway

Summary: Put the organisation's approved AI tools and model APIs behind single sign-on and one gateway that applies the acceptable-use policy as code: data-class rules on what may be sent, redaction or blocking where the class requires it, a decision event per call, and access conditional on a current acceptable-use attestation. The gateway is the sanctioned path, and it is built to be the easiest one; discovery finds what goes around it.

Objectives

Let staff use AI tools productively while keeping regulated, confidential and secret data out of tools that are not approved for it, and turn the acceptable-use policy from a handbook page into a control that decides and leaves evidence.

Target users

AI governance engineer, security engineer, platform team, procurement.

Impacted stakeholders

Employees and contractors, customers whose data staff handle, works councils or employee representatives, the DPO, AI tool suppliers.

Relevant principles

Make the governed path the easiest path; build the control at the earliest point it can block; register and bound every actor before it acts.

Context

Staff adopt AI tools faster than procurement can approve them. In a 2024 vendor survey of 31,000 knowledge workers in 31 countries, 78% of AI users said they bring their own AI tools to work [1]. The organisation already has an acceptable-use policy that lists approved tools and prohibited inputs by data class (see [acceptable use of AI by staff](#)), and the EU AI Act, as amended by the Digital Omnibus, asks providers and deployers to take measures to support the AI literacy of the staff who use AI on their behalf [2]. The failure mode is known: the case file on [source code pasted into a public chatbot](#) (reported) is the everyday version, and sensitive information disclosure is a named risk class for LLM applications [3].

Problem

A policy that lives in a handbook has no teeth: it is read once, attested once and never evaluated at the moment someone pastes a customer file into a public tool. Blocking every public tool pushes use onto personal devices, where nothing is seen. Discovery alone finds the leak after it happened.

Forces

- **Convenience against control.** Every extra step on the approved path sends people back to the unapproved one.
- **Inspection against privacy.** Logging staff prompts is itself processing of employees' personal data, so the gateway keeps what the control needs, for as long as it needs it [4].
- **Latency against redaction.** Content classification and redaction add time to every call.
- **Supplier terms against drift.** An approved tool is only safe on the terms it was approved under, such as no training on customer inputs, and those terms change.

Solution

Make one gateway the sanctioned route to AI, and make it the fastest route.

1. **An approved-tool catalogue as a Policy Card.** Each entry names the tool, the contract terms it was approved on, the data classes and use cases it is allowed for, and its review date. The [Vendor / Model Due-Diligence Gate](#) feeds it.
2. **One route in.** Model APIs are reached through an AI gateway or LLM proxy, and browser-based tools through single sign-on and a secure web gateway or browser policy (illustrative categories, not a product list). Personal accounts on approved tools are replaced by enterprise tenancies.
3. **Data-class rules at the gateway.** A content classifier tags each request by data class and the card decides: allow, allow with redaction, or block with a reason and a route to the right tool. The matrix of data class against tool comes from the acceptable-use policy.
4. **Access on attestation.** The identity provider grants the gateway role only while a current acceptable-use attestation and its training module are on record (the [training record schema](#)).
5. **A decision event per call.** The gateway writes a signed evidence record (decision, data class, tool, redactions, a hash of the input rather than the input) to the assurance store, in the shape of the [evidence record schema](#).
6. **Discovery as the feedback loop.** [Shadow-AI Discovery](#) reads identity, network and expense data for tools outside the gateway; each find becomes an intake request (register, tier, approve or replace) before it becomes a sanction.

Illustrative gateway decision event, as an evidence record:

```
{
  "$schema": "https://aigovernanceengineer.com/schemas/evidence-record.v1.json",
  "control_id": "gateway.data-class.confidential.v4",
  "subject": "genai-gateway@2026.09.2",
  "decision": "allow",
  "obligation": "ISO/IEC 42001 A.9.2",
  "failure_mode": "customer data sent to a tool not approved for it",
  "input_hash": "sha256:4be1c07e9d52",
  "actor": "user:pseudo-8841",
  "timestamp": "2026-09-18T09:12:44Z",
  "signature": "ed25519:MEUCIQDx3k",
  "extensions": {
    "tool": "drafting-assistant@enterprise",
    "data_class": "confidential",
    "action": "allowed_with_redaction",
    "redactions": 2,
    "attestation": "tr-2026-0877"
  }
}
```

Example (illustrative) A legal team starts using a public drafting assistant for contract summaries. Discovery flags the traffic; rather than block the domain, the governance program signs an enterprise agreement with no training on customer data, adds the tool to the catalogue for confidential data with redaction of personal identifiers, and routes it through the gateway. Usage moves to the sanctioned route within weeks because it is now the easiest one.

Consequences

Acceptable use becomes enforceable and measurable: the organisation can show what was sent where, under which rule, and how much use happens outside the gateway. The cost is the gateway itself, classifier tuning (false blocks erode trust fast), catalogue upkeep as supplier terms change, and the privacy work to log proportionately. The gateway covers the tools it fronts; local models and personal devices stay a discovery problem.

Related patterns

[Shadow-AI Discovery](#); [Policy Card](#); [Runtime Guardrail](#); [Vendor / Model Due-Diligence Gate](#); [Continuous Assurance Telemetry](#).

Maps to: EU AI Act Art. 4 · GDPR Art. 5(1)(c) · ISO/IEC 42001 A.2, A.9.2, A.10.3 · NIST AI RMF GOVERN 2.2, GOVERN 6.1, MANAGE 3.1 · OWASP LLM02:2026 · Layer 04 Runtime Controls & Observability / Layer 02 Inventory & Transparency.

Threat ids follow the OWASP Top 10 for LLM Applications 2026 [3], control ids ISO/IEC 42001 Annex A [5] and subcategory ids the NIST AI RMF [6]. Mappings are illustrative, not a claim of conformity.

Sources

[1] "AI at Work Is Here. Now Comes the Hard Part" (2024 Work Trend Index; 31,000 people in 31 countries; 78% of AI users bring their own AI tools to work). Microsoft and LinkedIn. 2024-05-08. <https://www.microsoft.com/en-us/worklab/work-trend-index/ai-at-work-is-here-now-comes-the-hard-part> (verified: primary) [2] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 (Art. 4 replaced: providers and deployers take measures to support the development of AI literacy); OJ L, 2026/1744, 24.7.2026. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [3] OWASP Top 10 for LLM Applications 2026 (LLM02 Sensitive Information Disclosure; ids used in the Maps to line). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [4] Regulation (EU) 2016/679 (General Data Protection Regulation; Art. 5(1)(c) data minimisation). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [5] ISO/IEC 42001:2023, AI management system, Annex A controls referenced by identifier and short title only (A.2 policies related to AI; A.9.2 processes for responsible use of AI systems; A.10.3 suppliers). ISO/IEC (titles checked via a secondary listing). 2023-12. <https://www.iso.org/standard/42001> (verified: secondary) [6] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (GOVERN 2.2 personnel and partners receive AI risk management training; GOVERN 6.1 policies for third-party AI risks; MANAGE 3.1 third-party risks regularly monitored). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary)

Pattern: Staged Rollout with Rollback Criteria

Summary: Take every change to a deployed AI system (a new model, a retrain, a prompt or corpus change, a new vendor model version) to production in stages that limit exposure while evidence accumulates: shadow, pilot, canary, then general availability. Each stage has rollback criteria written into the rollout plan before it starts and evaluated by the pipeline, versions are pinned in the registry, and the path back has been tested. A criterion invented after the metric moved is a negotiation, not a control.

Objectives

Bound the harm a bad change can do to the share of traffic or cases exposed to it, and make "roll it back" a decision the pipeline takes on a pre-agreed signal rather than a meeting.

Target users

AI governance engineer, ML platform team, SRE, system owner.

Impacted stakeholders

Users and affected persons of the system, operators and reviewers, the go-live panel, deployers downstream of a provider's change.

Relevant principles

Give every control teeth; build the control at the earliest point it can block; instrument the build to produce its own proof.

Context

AI systems change more often than their approvals do. A retrain, a prompt edit, a refreshed retrieval corpus and a vendor's new model version can each move quality, safety or fairness without a line of the deployer's code changing. Site reliability engineering already has the mechanics: canarying is a partial and time-limited deployment of a change and its evaluation [1], blue-green deployment keeps a tested way back [2], and operational feature toggles switch exposure per cohort without a deploy [3]. The EU AI Act asks deployers of high-risk systems to monitor operation and to suspend use when they have reason to consider the system presents a risk [4], and a provider or prospective provider that pilots an Annex III system with real users before placing it on the market is testing in real-world conditions, which Article 60 governs [4]. The NIST AI RMF expects a determination of whether deployment should proceed and mechanisms to supersede or deactivate a system whose outcomes are inconsistent with intended use [5].

Problem

Without stages, a change goes from the eval harness to everyone at once, and the first evidence about live behaviour is the harm itself. With stages but no pre-registered criteria, each rollback becomes a debate about whether a moved metric matters, held after the fact by the people who wanted the release. A vendor model update that nobody treated as a release skips every stage.

Forces

- **Speed against evidence.** Each stage delays value; too short a stage proves nothing.
- **Statistical power against exposure.** A small canary exposes few people but needs time to detect a real regression, especially per group.
- **Late labels.** Outcome labels often arrive after the stage ends, so criteria lean on proxies: disagreement, overrides, complaints, groundedness.
- **Changes you did not make.** A provider's version change arrives on its schedule, not yours.

Solution

Write the rollout plan as data, register it before the first stage, and let the pipeline enforce it.

1. **Stages with a purpose.** Shadow (live inputs, outputs logged not used) proves behaviour on real traffic; a pilot with trained users proves oversight works; a canary against a control group proves no regression at scale; general availability keeps the criteria as live monitors.
2. **Pre-registered rollback criteria.** Each stage lists metric, comparison, threshold, window and the group breakdowns that matter. The plan is committed and signed before the stage starts; a change to a threshold is a reviewed diff with an approver, never an edit on a dashboard.
3. **Pinned versions.** The registry pins model, prompt, retrieval corpus and guardrail versions for the baseline and the candidate. An unpinned change detected at runtime is itself a rollback trigger.
4. **A tested path back.** Blue-green switching or a feature flag returns traffic to the baseline, and the switch is exercised in the shadow stage, before anyone depends on it.
5. **Automatic evaluation.** A canary analysis job compares candidate and control per metric and per group and writes a stage verdict (promote, hold, roll back) to the assurance store. The go/no-go record summarises the rollout in its `rollout` field (see the [go/no-go schema](#)).
6. **Vendor versions are releases.** A new provider model version runs in shadow and canary against the pinned version before it takes traffic.

Illustrative rollout plan, registered before the shadow stage:

```
{
  "plan_id": "ro-csa-01-2026-09",
  "subject": "csa-01@2026-09-18",
  "baseline": "csa-01@2026-08-30",
  "registered_at": "2026-09-15T09:00:00Z",
```

```

"pinned": {
  "model": "vendor-model@2026-08-01",
  "prompt": "csa-prompt@41",
  "corpus": "csa-kb@2026-09",
  "guardrails": "gr-csa@12"
},
"stages": [
  {
    "stage": "shadow",
    "min_days": 7,
    "rollback_if": [{ "metric": "disagreement_with_baseline", "op": ">", "value": 0.08 }]
  },
  {
    "stage": "pilot",
    "exposure": "40 trained agents",
    "min_days": 14,
    "rollback_if": [
      { "metric": "override_rate", "op": ">", "value": 0.15 },
      { "metric": "complaints_per_1000", "op": ">", "value": 2.0 }
    ]
  },
  {
    "stage": "canary",
    "exposure_percent": 10,
    "control_group": true,
    "min_days": 14,
    "rollback_if": [
      { "metric": "groundedness", "op": "<", "value": 0.92 },
      { "metric": "resolution_rate_ratio_min_by_language", "op": "<", "value": 0.9 },
      { "metric": "severity_1_events", "op": ">", "value": 0 }
    ]
  },
  { "stage": "general_availability", "exposure_percent": 100 }
],
"rollback_path": "blue-green switch to csa-01@2026-08-30; flag csa01.candidate off",
"go_no_go": "gng-csa-01-2026-09-18"
}

```

Example (illustrative) A support assistant's new prompt passes its eval gate and enters shadow. In the canary, groundedness holds overall but the resolution rate for Portuguese-language chats falls below 90% of the Spanish rate. The pre-registered criterion trips, the flag returns the canary cohort to the baseline within minutes, and the stage verdict and the rollback event land in the assurance store before anyone has called a meeting.

Consequences

Regressions are caught while they affect a few users, and every promotion or rollback leaves a record tied to criteria set in advance. The cost is slower releases, canary infrastructure, the statistical work to size stages and groups, and the discipline to treat vendor updates and prompt edits as releases. Criteria that are too tight produce rollback fatigue; review them with their owners on the maintenance calendar.

Related patterns

[Eval Gate in CI](#); [Drift & Fairness Monitor](#); [Kill Switch / Circuit Breaker](#); [Agent Registry](#); [Deactivation, Localisation & Retirement Runbook](#).

Maps to: EU AI Act Art. 26(5), Art. 60 · ISO/IEC 42001 A.6.2.5, A.6.2.6 · NIST AI RMF MANAGE 1.1, MEASURE 2.3, MANAGE 2.4 · Layer 04 Runtime Controls & Observability.

Control ids follow ISO/IEC 42001 Annex A [6] and subcategory ids the NIST AI RMF [5]. Mappings are illustrative, not a claim of conformity.

Sources

[1] The Site Reliability Workbook, ch. 16 "Canarying Releases" ("a partial and time-limited deployment of a change in a service and its evaluation"). Google (O'Reilly). 2018. <https://sre.google/workbook/canarying-releases/> (verified: primary) [2] "BlueGreenDeployment" (two identical production environments; switch back on failure). Martin Fowler. 2010-03-01. <https://martinfowler.com/bliki/BlueGreenDeployment.html> (verified: primary) [3] "Feature Toggles (aka Feature Flags)" (release, experiment, ops and permissioning toggles; ops kill switches for graceful degradation). Pete Hodgson, martinfowler.com. 2017-10-09. <https://martinfowler.com/articles/feature-toggles.html> (verified: primary) [4] Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), of 13 June 2024; OJ L, 2024/1689, 12.7.2024 (Art. 26(5))

monitor, suspend and inform; Art. 60 testing of high-risk AI systems in real-world conditions outside sandboxes). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [5] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MANAGE 1.1 determination whether deployment should proceed; MEASURE 2.3 performance demonstrated for conditions similar to deployment; MANAGE 2.4 supersede, disengage or deactivate). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [6] ISO/IEC 42001:2023, AI management system, Annex A controls referenced by identifier and short title only (A.6.2.5 AI system deployment; A.6.2.6 AI system operation and monitoring). ISO/IEC (titles checked via a secondary listing). 2023-12. <https://www.iso.org/standard/42001> (verified: secondary)

Pattern: Drift & Fairness Monitor

Summary: Watch a deployed system for the ways it moves away from the state in which it was approved: input, label, concept, pipeline, vendor-model and usage drift, and quality and fairness by group. Every signal has a threshold, an owner and a pre-agreed consequence (an issue, a retrain, a degraded mode, an incident, a tripped breaker), and every evaluation writes an evidence record, so "the model is still fit and fair" is a query over telemetry rather than a belief from launch day.

Objectives

Detect loss of performance or fairness in production before the people affected detect it, route each breach to someone who can act, and keep a continuous record that the system was watched against the floors its deployment decision set.

Target users

AI governance engineer, ML platform on-call, data scientist, system owner.

Impacted stakeholders

Affected persons, especially groups the system may disadvantage; operators and reviewers; the risk function; providers and deployers who share the monitoring duty.

Relevant principles

Start from a named failure mode or harm; give every control teeth; instrument the build to produce its own proof.

Context

A system that passed its evals at go-live can drift into error or unfairness without any code change. Concept drift, a change over time in the relationship a model learned, is a studied problem whose work divides into detection, understanding and adaptation [1]. The EU AI Act asks providers of high-risk systems to run post-market monitoring and deployers to monitor operation on the basis of the instructions for use, suspending use and informing the provider where the system presents a risk (Art. 72 , Art. 26(5)), and asks systems that keep learning to address biased feedback loops (Art. 15(4)) [2]. Where monitoring for bias needs special categories of personal data, the Digital Omnibus sets the conditions in a new Art. 4a [3]. Some law requires periodic audits outright: New York City's Local Law 144 requires a bias audit within one year before an automated employment decision tool is used [4]. The NIST AI RMF asks that functionality and behaviour be monitored in production and that fairness and bias be evaluated and documented [5].

Problem

Dashboards without thresholds are watched by nobody. Labels arrive late or never, so accuracy cannot be measured when it matters. The group attribute needed to measure fairness is usually absent at runtime. A generative system can degrade (more ungrounded answers, more refusals in one language) while every infrastructure metric stays green. And a breach that pages no one is only a chart.

Forces

- **Label delay against timeliness.** Outcome-free proxies (input drift, selection rates, overrides, complaints) arrive now; performance on fresh labels arrives later and is what matters.
- **Sensitivity against alert fatigue.** Tight thresholds catch drift early and page people for noise.
- **Fairness measurement against privacy.** Measuring by group needs the group attribute, which is often special-category data with its own legal conditions.
- **Shared duty.** Provider and deployer each monitor part of the system and see different data.

Solution

Run the monitor as a layer 04 signal path that writes layer 05 evidence, driven by a monitoring plan that is data.

1. **Name what can move.** For each system, list the drift classes that apply: data (input distribution), label (base rate), concept (input-to-outcome relationship), pipeline (upstream schema or retrieval step), vendor model (the model behind the API) and usage (who uses it, for what). Pick a statistic per class: a stability index or two-sample test on features or embeddings against a

reference window; predicted against observed positive rate; performance on fresh labels with change-point detection; data contracts; version-pin checks; topic classification of traffic against the negative space.

2. **Fairness by group, with and without labels.** Monitor selection or approval rates by group with no label needed; error and calibration rates by group once outcomes land, with the label delay stated; override, complaint and contest rates by group from the [Decision Notice & Contest Path](#); and, for generative systems, groundedness and refusal rates by topic and language. Where the group attribute is not held at runtime, use a consented sample or a periodic audit in a secured environment.
3. **Threshold, owner, consequence.** Every metric in the plan carries a threshold, a window, a named owner who can be paged, and the action a breach fires: open an issue, schedule a retrain, switch a degraded mode, open an incident through the [Incident Pipeline](#), or trip the [Kill Switch / Circuit Breaker](#).
4. **Evidence on every evaluation.** Each check writes an evidence record to the assurance store through [Continuous Assurance Telemetry](#), pass or fail, so the absence of breaches is itself evidenced.
5. **The plan as data.** The deployer's monitoring plan reuses the [post-market monitoring plan schema](#), and a threshold change is a reviewed diff, like any change to a control.

Illustrative monitoring plan for a support assistant, as a post-market monitoring plan record:

```
{
  "$schema": "https://aigovernanceengineer.com/schemas/post-market-monitoring-plan.v1.json",
  "plan_id": "mon-csa-01",
  "subject": "csa-01@2026-09-18",
  "scope": "All chats in ES and PT, including escalations to human agents and customer complaints.",
  "data_sources": [
    { "source": "chat telemetry with groundedness scores", "type": "telemetry", "owner": "ml-platform" },
    { "source": "agent overrides and escalations", "type": "deployer_feedback", "owner": "contact-centre-ops" },
    { "source": "complaints that mention the assistant", "type": "user_complaint", "owner": "customer-care" },
    { "source": "monthly re-run of the regression suite on sampled chats", "type": "eval_rerun", "owner": "model-validation" }
  ],
  "metrics": [
    {
      "metric": "groundedness of sampled answers",
      "threshold": "< 0.90 over 7 days",
      "cadence": "daily",
      "failure_mode": "ungrounded answers",
      "alert_route": "ml-platform"
    },
    {
      "metric": "resolution-rate ratio, lowest language to highest",
      "threshold": "< 0.90 over 14 days",
      "cadence": "weekly",
      "failure_mode": "worse service for one language group",
      "alert_route": "ai-governance"
    },
    {
      "metric": "share of chats classified outside the intended topics",
      "threshold": "> 5% over 7 days",
      "cadence": "daily",
      "failure_mode": "usage drift into unapproved use",
      "alert_route": "system-owner"
    }
  ],
  "drift_signals": ["embedding drift on user turns", "topic mix", "vendor model version pin"],
  "triggers": [
    { "condition": "groundedness breach for two consecutive windows", "action": "rollback", "owner": "system-owner" },
    { "condition": "language resolution ratio breach", "action": "investigate", "owner": "ai-governance" },
    { "condition": "unpinned vendor model version detected", "action": "suspend", "owner": "ml-platform" }
  ],
  "feedback_channels": ["in-chat feedback", "complaint form", "contest path for account decisions"],
  "retraining_policy": "A retrain, prompt change or corpus refresh is a release and goes through the staged rollout.",
  "review_cadence": "Thresholds reviewed quarterly with their owners",
  "owner": "system-owner",
  "effective_from": "2026-09-18"
}
```

Example (illustrative) Three weeks after a vendor model update passed its canary, the usage drift metric rises: staff have started asking the customer assistant HR questions. The breach opens an issue for the system owner, who adds HR topics to the prohibited-use list and routes them to the HR portal; the metric falls back under threshold, and the issue, the change and the recovery are all in the assurance store.

Consequences

Drift and unfairness are caught as signals with owners rather than discovered as incidents, and periodic audits become cheap because the telemetry already exists. The cost is labelling and sampling capacity, statistical care in thresholds (per-group metrics on small groups are noisy), the privacy work for group attributes, and on-call coverage for every signal that can page.

Related patterns

[Continuous Assurance Telemetry](#); [Staged Rollout with Rollback Criteria](#); [Incident Pipeline](#); [Kill Switch / Circuit Breaker](#); [Decision Notice & Contest Path](#).

Maps to: EU AI Act Art. 4a, Art. 15(4), Art. 26(5), Art. 72 · NYC Local Law 144 · ISO/IEC 42001 A.5.4, A.6.2.6 · NIST AI RMF MEASURE 2.4, MEASURE 2.11, MEASURE 3.1, MANAGE 4.1 · Layer 04 Runtime Controls & Observability / Layer 05 Assurance & Continuous Compliance.

Control ids follow ISO/IEC 42001 Annex A [6] and subcategory ids the NIST AI RMF [5]. Mappings are illustrative, not a claim of conformity.

Sources

[1] "Learning under Concept Drift: A Review" (IEEE TKDE 31(12); detection, understanding and adaptation) (arXiv 2004.05785). Lu et al. 2018. <https://arxiv.org/abs/2004.05785> (verified: primary) [2] Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), of 13 June 2024; OJ L, 2024/1689, 12.7.2024 (Art. 15(4) feedback loops in systems that continue to learn; Art. 26(5) deployer monitoring, suspension and information; Art. 72 post-market monitoring by providers). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [3] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 (new Art. 4a on special categories of personal data for bias detection and correction); OJ L, 2026/1744, 24.7.2026. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [4] Automated Employment Decision Tools (NYC Local Law 144 of 2021: bias audit within one year before use, public summary, candidate notices; enforced from 5 Jul 2023). NYC Department of Consumer and Worker Protection. 2023. <https://www.nyc.gov/site/dca/about/automated-employment-decision-tools.page> (verified: primary) [5] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MEASURE 2.4 functionality and behaviour monitored in production; MEASURE 2.11 fairness and bias evaluated and documented; MEASURE 3.1 existing, unanticipated and emergent risks tracked; MANAGE 4.1 post-deployment monitoring plans). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [6] ISO/IEC 42001:2023, AI management system, Annex A controls referenced by identifier and short title only (A.5.4 assessing AI system impact on individuals or groups of individuals; A.6.2.6 AI system operation and monitoring). ISO/IEC (titles checked via a secondary listing). 2023-12. <https://www.iso.org/standard/42001> (verified: secondary)

Pattern: Downstream Use Register

Summary: Record, against each system's registry entry, what its outputs may and may not be used for and who actually consumes them: other systems, teams, partners and models trained on them. Intended and prohibited uses are written as a Policy Card; each consumer is registered with its use, its approval and the re-test that cleared it; outputs carry provenance and caveats so a consumer knows what it is using; and off-purpose use is monitored at runtime. Secondary use, function creep and downstream harm become visible, and a change or retirement can reach everyone it affects.

Objectives

Forecast and bound the uses a system was not approved for, make every downstream consumer of its outputs known and accountable, and give change, incident and retirement processes a list of whom to tell.

Target users

AI governance engineer, system owner, data platform team, product manager.

Impacted stakeholders

People affected by downstream decisions, consuming teams and partners, deployers of a provider's system, auditors and market-surveillance authorities.

Relevant principles

Register and bound every actor before it acts; start from a named failure mode or harm; make the governed path the easiest path.

Context

Systems are used for more than they were approved for. The EU AI Act names the concept: reasonably foreseeable misuse is use not in accordance with the intended purpose that may result from reasonably foreseeable human behaviour or interaction with other systems (Art. 3(13)), providers must assess risks under it (Art. 9(2)(b)), and a deployer that changes the intended purpose of a system so that it becomes high-risk takes on the provider's duties (Art. 25(1)(c)) [1]. Providers of generative systems must mark synthetic outputs in a machine-readable way (Art. 50(2)) [1], which is provenance a consumer can read. Outputs that feed other components are an attack surface as well: improper output handling, where model outputs pass downstream without validation, is a named risk class [2], and in agentic systems one agent's error can cascade through others [3].

Governing deployment and use now includes forecasting and reducing secondary and downstream harms; the IAPP AIGP Body of Knowledge lists it under competency IV.C [4].

Problem

An inventory records systems, not what their outputs turn into. A risk score approved to prioritise manual review becomes, a year later, an automatic decline in another team's pipeline; a summary model's outputs are harvested as training data; a partner receives outputs under a contract nobody connected to the registry. None of these consumers was assessed, none is told when the model changes, and the retirement runbook cannot find them. Where outputs shape the data the next version learns from, the feedback loop is invisible too.

Forces

- **Reuse against purpose.** Reusing a good model is cheap and useful; every reuse can also be a new, unassessed purpose.
- **Openness against control.** Outputs published through an API or a data platform are easy to consume and hard to trace.
- **Caveats against usability.** Stamping provenance and limits on every output adds weight that consumers may strip.
- **Forecasting against certainty.** Misuse has to be imagined before it happens, with no data to prove the forecast.

Solution

Give downstream use a register, and make registration the only way to get the outputs.

1. **Uses as a Policy Card.** The system's intended uses and its negative space (prohibited uses, populations and contexts it was not validated for) are rules on a card stored with the registry entry of the [Agent Registry](#), not a paragraph in a model card.
2. **Forecast before go-live.** Run a premortem ("a year from now this caused harm: how?"), abuse cases written next to the user stories, and a stakeholder impact map that includes people who never touch the interface. Each plausible misuse becomes a prohibited-use rule or a monitor.
3. **Consumers as entries.** Every consumer (a system, a team, a partner, a training pipeline) is registered against the producing system with its purpose, its approval, the re-test that cleared the outputs for that new context and the contract that binds an external party. Access to the output API or table is granted per registered consumer, so an unregistered consumer has no credential.
4. **Provenance on outputs.** Outputs carry the producing system and version, the intended use and a caveat, as metadata a consumer can read (for generative content, the marking the AI Act requires of providers).
5. **Off-purpose use as a signal.** Classify traffic and consumer requests against the negative space and alert on what falls outside it; watch for outputs that return as training data (feedback loops).
6. **Fan-out on change.** A model change, an incident or a retirement reads the register and notifies every consumer through the [Disclosure & Notification Pipeline](#).

Illustrative downstream use register entry:

```
{
  "subject": "risk-score-02@4.1",
  "policy_card": "uses.risk-score-02.v3",
  "intended_uses": ["prioritise claims for manual review"],
  "prohibited_uses": ["automatic decline of a claim", "pricing", "use on commercial policies"],
  "consumers": [
    {
      "consumer": "claims-triage-service",
      "type": "system",
      "use": "queue ordering for human review",
      "approved_at": "2026-03-02",
      "retest": "eval:rs2-claims-triage-v3",
      "credential": "svc-claims-triage"
    },
    {
      "consumer": "reinsurance-partner-a",
      "type": "partner",
      "use": "aggregate statistics only, no row-level scores",
      "approved_at": "2026-05-11",
      "contract": "dpa-2026-017 schedule 3"
    }
  ],
  "output_stamp": ["producer", "version", "intended_use", "caveat"],
  "feedback_loop_check": "scores excluded from the training labels of risk-score-03",
  "reviewed_at": "2026-09-10"
}
```

Example (illustrative) A fraud team asks for row-level risk scores to decline claims automatically. The request arrives as a consumer registration, meets a prohibited-use rule on the card and goes to the committee as a new purpose, where it is refused; the team gets a review-priority feed instead. When the model is retrained, both registered consumers receive the change notice and re-run their acceptance tests.

Consequences

Secondary use is decided rather than discovered, consumers are known when the model changes or retires, and feedback loops are checked on purpose. The cost is the register itself, per-consumer access control on outputs, re-testing for new contexts and the friction of saying no to useful reuse. Registration binds internal consumers well; external ones depend on contract terms and audit rights.

Related patterns

[Policy Card](#); [Agent Registry](#); [Disclosure & Notification Pipeline](#); [Drift & Fairness Monitor](#); [Deactivation, Localisation & Retirement Runbook](#).

Maps to: EU AI Act Art. 3(13), Art. 9(2)(b), Art. 25(1)(c), Art. 50(2) · ISO/IEC 42001 A.8.2, A.9.4, A.10.4 · NIST AI RMF MAP 1.1, MAP 3.3, MANAGE 1.4 · OWASP LLM10:2026, OWASP Agentic ASI08 · Layer 02 Inventory & Transparency / Layer 01 Govern-as-Code.

Threat ids follow the OWASP Top 10 for LLM Applications 2026 [2] and the OWASP Top 10 for Agentic Applications 2026 [3], control ids ISO/IEC 42001 Annex A [5] and subcategory ids the NIST AI RMF [6]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), of 13 June 2024; OJ L, 2024/1689, 12.7.2024 (Art. 3(13) reasonably foreseeable misuse; Art. 9(2)(b) risks under reasonably foreseeable misuse; Art. 25(1)(c) changed intended purpose; Art. 50(2) machine-readable marking of synthetic outputs). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] OWASP Top 10 for LLM Applications 2026 (LLM10 Improper Output Handling). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [3] Top 10 for Agentic Applications 2026 (ASI08 Cascading Failures). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [4] AIGP Body of Knowledge and Exam Blueprint, version 2.1 (competency IV.C, governing AI deployment and use: forecast and reduce risks of secondary or unintended uses and downstream harms; approved 9 Sep 2025, effective 2 Feb 2026; cited by competency code and paraphrased; this site is not affiliated with or endorsed by IAPP). IAPP. 2025-09-09. https://prod.iapp.org/media/pdf/certification/AIGP_Cert_BOK_2025_FINAL_v2.1.0.pdf (verified: primary) [5] ISO/IEC 42001:2023, AI management system, Annex A controls referenced by identifier and short title only (A.8.2 system documentation and information for users; A.9.4 intended use of the AI system; A.10.4 customers). ISO/IEC (titles checked via a secondary listing). 2023-12. <https://www.iso.org/standard/42001> (verified: secondary) [6] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (MAP 1.1 intended purposes and prospective settings documented; MAP 3.3 targeted application scope specified; MANAGE 1.4 negative residual risks to downstream acquirers and end users documented). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary)

Pattern: Disclosure & Notification Pipeline

Summary: Generate every outward-facing statement about an AI system from one source of truth, the registry: the proactive disclosures (an AI-interaction notice, content labels, the transparency page and plain-language system card, notices to workers and to people subject to decisions) and the reactive notifications (to the provider, authorities, affected people, customers and the public) that a trigger starts on a clock. Templates are versioned like code, approvals are recorded, and every notice sent is an evidence record with its audience, template version and timestamp.

Objectives

Make sure the people and bodies who must hear about an AI system hear the right thing, on time, from one voice, and be able to prove what was said to whom and when.

Target users

AI governance engineer, communications owner, legal and compliance, DPO, product engineer.

Impacted stakeholders

Users, workers and their representatives, affected persons, business customers and partners, providers and deployers up and down the chain, supervisory and market-surveillance authorities, the public and media.

Relevant principles

Instrument the build to produce its own proof; make the governed path the easiest path; give every control teeth.

Context

Transparency duties now attach to specific surfaces and clocks. Under the EU AI Act, providers must design systems that interact with people so that they know it is an AI system, and must mark synthetic outputs; deployers must inform people exposed to emotion recognition or biometric categorisation and disclose deep fakes; and the information must reach people at the latest at first interaction or exposure (Art. 50(1) – (5)) [1]. Article 50 has applied since 2 Aug 2026, and generative systems already on the market before that date have until 2 Dec 2026 to mark outputs [2]. High-risk deployers must also inform workers before workplace use, inform people subject to Annex III decisions, and inform the provider and authorities when a system presents a risk (Art. 26(5) , (7) , (11)) [1]. The GDPR adds breach notification to the authority within 72 hours where feasible and to affected people without undue delay when the risk to them is high [3]. Outside the EU, Korea's AI Basic Act has required prior notice of generative and high-impact AI and labels on generated outputs since 22 Jan 2026 [4]; California's AI Transparency Act, operative since 2 Aug 2026, asks large generative-AI providers for latent and optional manifest disclosures [5]; and Utah requires a clear answer when a consumer asks whether they are talking to AI [6]. Establishing external communication plans is part of governing deployment and use in the IAPP AIGP Body of Knowledge (competency IV.C) [7].

Problem

Disclosures are written once, by hand, per surface, and drift from what is running: the transparency page describes last year's model, the chat widget's notice disappeared in a redesign, and nobody can say which workers were told before the system went live. Reactive notices are drafted under pressure when the clock is already running, by whoever is available, without a record of what went out. Each jurisdiction's duty is handled by a different team with a different template.

Forces

- **One voice against many audiences.** A regulator, a customer and the press need different content from the same facts.
- **Speed against accuracy.** Clocks run from awareness, while facts arrive late; a holding statement must say only what is known.
- **Consistency against localisation.** Duties and languages differ by jurisdiction, yet the facts must not.
- **Proactive against reactive.** Disclosure duties are continuous; notification duties fire on events.

Solution

Treat disclosure as a pipeline from the registry to each audience, with evidence at the end.

1. **One source of truth.** The registry entry holds the facts disclosures draw on: purpose, provider, model version, jurisdictions, whether the system interacts with people, generates content, makes decisions about people or is used at work. The transparency page and the plain-language system card are generated from it on every release, so they cannot drift from what runs.
2. **A duty matrix per system.** A rule set maps registry facts to duties: interaction disclosure, content marking and labels, worker information, decision notices (see [Decision Notice & Contest Path](#)), local notices per jurisdiction. Each duty names a surface, a template and a test that the notice renders there.
3. **Templates as code.** Templates per audience and language live in version control with an owner and an approval rule; a template change is a reviewed diff. Holding statements exist in skeleton before any incident.
4. **Triggers with clocks.** An incident, a breach, a material change, a deprecation or a retirement emits a trigger; the pipeline selects the audiences from the matrix and the [Downstream Use Register](#), starts each clock and drafts each notice. Incidents arrive from the [Incident Pipeline](#).
5. **Evidence per notice.** Each notice sent writes a record: audience, trigger, template version, approver, channel, timestamp. The deployment decision record points at the proactive ones (its `workers_informed` and `affected_persons_informed` duties, in the [deployment decision record schema](#)), and the incident record's reporting block points at the reactive ones.

Illustrative disclosure manifest generated from the registry, with one notice sent:

```
{
  "subject": "csa-01@2026-09-18",
  "generated_at": "2026-09-18T07:00:00Z",
  "proactive": [
    { "duty": "EU AI Act Art. 50(1)", "surface": "chat widget", "template": "ai-disclosure.es-en.v3", "test": "e2e:disclosure-renders" },
    { "duty": "Korea AI Basic Act Art. 31(1)", "surface": "terms of service (KR)", "template": "kr-prior-notice.ko.v1", "test": "e2e:kr-terms-noti" },
    { "duty": "transparency page", "surface": "/ai/csa-01", "template": "system-card.v2", "test": "build:card-matches-registry" }
  ],
  "reactive": [
    { "trigger": "serious_incident", "audience": "provider", "clock": "immediately", "template": "si-notice.v2" },
    { "trigger": "personal_data_breach", "audience": "supervisory_authority", "clock": "72h where feasible", "template": "breach-art33.v4" },
    { "trigger": "material_change", "audience": "business_customers", "clock": "30 days before, per contract", "template": "change-notice.v2" }
  ],
  "sent": [
    {
      "notice_id": "ntc-2026-0091",
      "trigger": "material_change",
```

```

    "audience": "business_customers",
    "template": "change-notice.v2",
    "approved_by": "communications-owner",
    "sent_at": "2026-09-01T10:00:00Z"
  }
]
}

```

Example (illustrative) A support assistant moves to a new vendor model. The release regenerates the system card and the transparency page from the registry, the pipeline sends the contractual change notice to business customers 30 days ahead from the approved template, and a check in CI fails the build when a redesigned chat widget no longer renders the AI-interaction notice.

Consequences

What the organisation says about its AI matches what runs, notices go out on time from approved templates, and each one is provable. The cost is the duty matrix to maintain as laws change, template ownership across legal, communications and product, and rendering tests on every surface. The pipeline produces the notice; whether the notice is understood still needs testing with its readers.

Related patterns

[Decision Notice & Contest Path](#); [Incident Pipeline](#); [Downstream Use Register](#); [Model Card as Control Evidence](#); [Deactivation, Localisation & Retirement Runbook](#).

Maps to: EU AI Act Art. 26(5), Art. 26(7), Art. 26(11), Art. 50 · GDPR Art. 33, Art. 34 · Korea AI Basic Act Art. 31 · ISO/IEC 42001 A.8.2, A.8.3, A.8.4, A.8.5 · NIST AI RMF MANAGE 4.3, GOVERN 4.2, GOVERN 5.1 · Layer 05 Assurance & Continuous Compliance / Layer 02 Inventory & Transparency.

Control ids follow ISO/IEC 42001 Annex A [8] and subcategory ids the NIST AI RMF [9]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), of 13 June 2024; OJ L, 2024/1689, 12.7.2024 (Art. 26(5), (7) and (11) deployer information duties; Art. 50(1)–(5) transparency obligations). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 (Art. 111(4): Art. 50(2) marking for generative systems placed on the market before 2 Aug 2026 from 2 Dec 2026); OJ L, 2026/1744, 24.7.2026. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [3] Regulation (EU) 2016/679 (General Data Protection Regulation; Art. 33 notification to the supervisory authority within 72 hours where feasible; Art. 34 communication to the data subject). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [4] Basic Act on the Development of Artificial Intelligence and the Establishment of a Foundation for Trust (Act No. 20676, in force 2026-01-22; Art. 31 prior notice, output labelling and realistic synthetic content). Korean Law Information Center (MOLEG). 2026-01-22. <https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=268543> (verified: primary) [5] AB-853, California AI Transparency Act (amends SB 942; chaptered 2025-10-13, Chapter 674; operative 2026-08-02; platform duties 2027-01-01; capture devices 2028-01-01). California Legislative Information. 2025-10-13. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202520260AB853 (verified: primary) [6] S.B. 226, Artificial Intelligence Consumer Protection Amendments, enrolled copy (disclosure on clear request; high-risk AI interaction; effective 2025-05-07). Utah State Legislature. 2025. <https://le.utah.gov/Session/2025/bills/enrolled/SB0226.pdf> (verified: primary) [7] AIGP Body of Knowledge and Exam Blueprint, version 2.1 (competency IV.C, governing AI deployment and use: establish external communication plans; approved 9 Sep 2025, effective 2 Feb 2026; cited by competency code and paraphrased; this site is not affiliated with or endorsed by IAPP). IAPP. 2025-09-09. https://prod.iapp.org/media/pdf/certification/AIGP_Cert_BOK_2025_FINAL_v2.1.0.pdf (verified: primary) [8] ISO/IEC 42001:2023, AI management system, Annex A controls referenced by identifier and short title only (A.8.2 system documentation and information for users; A.8.3 external reporting; A.8.4 communication of incidents; A.8.5 information for interested parties). ISO/IEC (titles checked via a secondary listing). 2023-12. <https://www.iso.org/standard/42001> (verified: secondary) [9] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (GOVERN 4.2 impacts documented and communicated more broadly; GOVERN 5.1 feedback from those external to the team; MANAGE 4.3 incidents and errors communicated to relevant AI actors, including affected communities). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary)

Pattern: Deactivation, Localisation & Retirement Runbook

Summary: Write down, before it is needed, how an AI system is degraded, switched off, restricted to the jurisdictions where it may run, and finally retired: the threshold and legal triggers, the role that decides, the evidence preserved first, the graduated modes

short of shutdown, the per-jurisdiction switches, and the retirement steps from dependency analysis to a retired registry entry. Build the switches as tested toggles, drill them on a calendar, and record every decision and step as evidence.

Objectives

Make stopping, restricting and retiring an AI system an executable, tested procedure with a named decision owner, so that a regulatory or performance trigger leads to a bounded action within hours, and a retirement leaves no running copy, no live credential and no lost evidence.

Target users

AI governance engineer, system owner, SRE, security engineer, legal.

Impacted stakeholders

Users and affected persons, workers who depend on the system, downstream consumers, providers and deployers in the chain, market-surveillance authorities.

Relevant principles

Give every control teeth; register and bound every actor before it acts; instrument the build to produce its own proof.

Context

Some triggers to stop a system are legal, not technical. Under the EU AI Act a high-risk deployer that has reason to consider the system presents a risk must inform the provider and the authority and suspend use ([Art. 26\(5\)](#)); a provider must take corrective action, including withdrawing, disabling or recalling a non-conforming system ([Art. 20](#)); an authority can require the same for a system that presents a risk ([Art. 79](#)); and a practice can become prohibited ([Art. 5](#)) [1]. The NIST AI RMF asks for mechanisms, with assigned responsibilities, to supersede, disengage or deactivate systems whose performance or outcomes are inconsistent with intended use, and for processes to decommission systems safely, in a way that does not increase risk [2]. Records outlive the system: providers keep documentation for ten years and deployers keep logs for at least six months [1]. Creating a policy and controls to deactivate or localise a system when regulation or performance requires it is part of governing deployment and use in the IAPP AIGP Body of Knowledge (competency IV.C) [3]. For agents, the [Kill Switch / Circuit Breaker](#) is the instant form of this runbook.

Problem

Most systems have an on switch and a hope. When a trigger fires, nobody knows who may decide, logs are overwritten while the meeting runs, and the only available action is to turn off everything, everywhere, which is often worse than the fault. A classifier embedded in a vendor product has no switch at all. At retirement, an entry is deleted from the inventory while a copy keeps serving, a service account stays live and the evidence that the system was ever governed is lost with it.

Forces

- **Speed against deliberation.** A legal trigger demands prompt action; a shutdown with dependants needs a fallback ready.
- **Precision against simplicity.** Switching off one region, language or group limits harm and adds switches to build and test.
- **Preservation against disposal.** Evidence must be frozen before anything is stopped, while data protection pushes to delete what is no longer needed.
- **Vendor-embedded systems.** Where the model sits inside a supplier's product, the switch depends on the contract.

Solution

Keep one runbook per system, stored with its registry entry and exercised on the maintenance calendar.

1. **Triggers and authority.** List threshold triggers (a floor breached and not recovered in a window, a fairness gap above its limit, an incident severity) and legal triggers (the [Art. 26\(5\)](#) duty, a provider's corrective action, an authority's measure, a newly prohibited practice), each with the role that decides and the time allowed. Breaches arrive from the [Drift & Fairness Monitor](#).
2. **Preserve first.** The first step of every path freezes the logs, applies a legal hold and snapshots the pinned versions, so the evidence survives the stop.
3. **Graduated modes.** Build the intermediate modes as operational toggles and test them: advice-only, raised confidence thresholds with abstention to a person, grounded-only answers, scoped off for one group, language, region or function, back to the pilot cohort, and off with the fallback process.
4. **Localisation by jurisdiction.** Keep the jurisdiction as a policy input: per-jurisdiction rule sets as code, regional instances where residency requires them, and flags by region so one market can be switched off without touching the others. Launch in a jurisdiction only when its duties are shown to be met.
5. **Retirement as a runbook.** Analyse dependencies (the [Downstream Use Register](#) lists consumers), move users to the fallback, send sunset notices through the [Disclosure & Notification Pipeline](#), archive the final evidence snapshot, keep or dispose of weights, corpora and logs as licence, lawful basis and retention decide, revoke every identity and credential, set the registry

entry to `retired`, and let [Shadow-AI Discovery](#) confirm that no copy still runs. The record uses the [decommissioning runbook schema](#).

6. **Drill it.** Run a deactivation drill at least yearly per system: time to decide, time to the degraded mode, time to off, and whether the evidence was preserved.

Illustrative retirement record, as a decommissioning runbook:

```
{
  "$schema": "https://aigovernanceengineer.com/schemas/decommissioning-runbook.v1.json",
  "runbook_id": "rb-retire-csa-01",
  "subject": "csa-01@2026-09-18",
  "reason": "replaced",
  "replaced_by": "csa-02",
  "decision_ref": "ddr-csa-02-v1",
  "dependencies": ["contact-centre routing", "weekly quality report"],
  "notifications": [
    { "party": "users", "method": "Release note to contact-centre agents", "sent_at": "2027-03-01" },
    { "party": "deployers", "method": "Change notice to the PT business unit", "sent_at": "2027-03-01" }
  ],
  "steps": [
    { "step_id": "S1", "action": "archive_evidence", "detail": "Freeze logs and snapshot pinned versions.", "owner": "ai-governance", "status": "done" },
    { "step_id": "S2", "action": "disable_traffic", "detail": "Flag csa01.serve off in every region.", "owner": "ml-platform", "status": "done" },
    { "step_id": "S3", "action": "revoke_identity", "detail": "Revoke the workload identity and API keys.", "owner": "platform-identity", "status": "done" },
    { "step_id": "S4", "action": "retire_register_entry", "detail": "Set status to retired; keep the entry.", "owner": "ai-governance", "status": "done" },
    { "step_id": "S5", "action": "other", "detail": "Discovery sweep confirms no copy still serves.", "owner": "security-operations", "status": "done" }
  ],
  "data_disposition": [
    { "dataset": "chat logs", "action": "retain", "basis": "log retention rule and open complaints", "until": "2027-09-30" },
    { "dataset": "retrieval index csa-kb", "action": "delete" }
  ],
  "evidence_archive": { "location": "https://archive.example.org/ai/csa-01", "retain_until": "2033-03-31" },
  "status": "in_progress"
}
```

Example (illustrative) A newly applicable national rule restricts automated answers on health topics in one market. The runbook's legal trigger names the head of the business unit as decision owner; within the day the evidence is frozen, the regional flag switches the assistant to grounded-only answers there with health topics scoped off, other markets are untouched, and the decision, the toggles and the notices are in the assurance store.

Consequences

Stopping becomes proportionate and fast, localisation is a switch rather than a redeploy, and retirement leaves a complete, retained record instead of a gap. The cost is building and testing the modes and flags, per-jurisdiction rule sets to keep current, contract terms that give a switch over vendor-embedded AI, and drill time. An untested mode is not a control: the drill is what makes it one.

Related patterns

[Kill Switch / Circuit Breaker](#); [Drift & Fairness Monitor](#); [Downstream Use Register](#); [Disclosure & Notification Pipeline](#); [Shadow-AI Discovery](#); [Staged Rollout with Rollback Criteria](#).

Maps to: EU AI Act Art. 5, Art. 18, Art. 20, Art. 26(5), Art. 26(6), Art. 79 · ISO/IEC 42001 A.6.2.5, A.6.2.6 · NIST AI RMF GOVERN 1.7, MANAGE 2.4, MANAGE 4.1 · OWASP Agentic ASI10 · Layer 04 Runtime Controls & Observability / Layer 02 Inventory & Transparency.

Threat ids follow the OWASP Top 10 for Agentic Applications 2026 [4], control ids ISO/IEC 42001 Annex A [5] and subcategory ids the NIST AI RMF [2]. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), of 13 June 2024; OJ L, 2024/1689, 12.7.2024 (Art. 5 prohibited practices; Art. 18(1) documentation kept ten years; Art. 20 corrective actions; Art. 26(5) suspend and inform; Art. 26(6) logs kept at least six months; Art. 79 systems presenting a risk). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (GOVERN 1.7 decommissioning and phasing out safely; MANAGE 2.4 supersede, disengage or deactivate; MANAGE 4.1 post-deployment monitoring plans, including decommissioning). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [3] AIGP Body of Knowledge and Exam Blueprint, version 2.1 (competency IV.C, governing AI deployment and use: a policy and controls to deactivate or localise an AI system as necessary; approved 9 Sep 2025, effective 2 Feb 2026; cited by competency code and paraphrased; this site is not affiliated with or endorsed by IAPP). IAPP. 2025-09-09. https://prod.iapp.org/media/pdf/certification/AIGP_Cert_BOK_2025_FINAL_v2.1.0.pdf

(verified: primary) [4] Top 10 for Agentic Applications 2026 (ASI10 Rogue Agents). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [5] ISO/IEC 42001:2023, AI management system, Annex A controls referenced by identifier and short title only (A.6.2.5 AI system deployment; A.6.2.6 AI system operation and monitoring). ISO/IEC (titles checked via a secondary listing). 2023-12. <https://www.iso.org/standard/42001> (verified: secondary)

Sources

[1] Responsible AI Pattern Catalogue (template: summary, objectives, target users, impacted stakeholders, relevant principles, context, problem, solution, consequences; governance/process/product patterns). CSIRO. 2023–2024. <https://research.csiro.au/ss/science/projects/responsible-ai-pattern-catalogue/> (verified: primary) [2] Top 10 for Agentic Applications 2026 (ASI IDs). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [3] AI Risk Management Framework (AI RMF 1.0; Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary) [4] Standardisation of the AI Act (no harmonised standard yet referenced in the Official Journal; prEN 18286 entered public enquiry on 30 Oct 2025; page last updated 2026-08-03). European Commission. 2026-08-03. <https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation> (verified: primary) [5] Regulation (EU) 2024/1689 (AI Act), Art. 72 (post-market monitoring) and Art. 73 (reporting of serious incidents). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary)

06. The role

The AI governance engineer as a concrete role: a capability first and a job title second, defined by the workflows it owns and the evidence it produces, not by the certifications on its holder.

Capability first, title second

The Thesis insists that AI governance engineering is a capability, not a job title (the same claim the parent discipline makes for GRC engineering, a capability anyone close to the build can develop [8]). This chapter makes it concrete without contradicting that: a capability still lives in someone's week: the tickets they own, the pipelines they maintain, the incidents they are paged for. So we describe the **AI governance engineer** as the person, on whatever org chart, who holds that capability and is accountable for the three questions in production: what AI is running, what it is allowed to do, and what evidence proves it.

The distinction matters because the title is still forming. The same work is advertised as "AI Governance Engineer", "AI Risk Engineer", "AI Evaluation & Governance Engineer" [1], "Responsible AI Engineer" and, inside GRC teams building the AI-forward version of their function, "GRC Engineer" with an AI mandate [2]. A security engineer who writes the eval gate, a privacy engineer who turns a FRIA into code, an MLOps engineer who wires the registry to the deploy: each is doing AI governance engineering under a different title. We define the role by what it owns, not by what HR called the requisition.

One line separates it from its analyst neighbour, and the rest of the chapter earns that line: the AI governance analyst describes the system from the outside and files the description; the AI governance engineer reads the system directly and ships the control that changes what it does.

What the role owns, by workflow

The engineer owns workflows, not documents. Each workflow below is a running system with inputs, artefacts and evidence, and each maps to one of the five layers of the stack (chapter 04). Grouping responsibilities this way keeps the role honest: you own a workflow when you can be paged for it, not when your name is on a policy.

Intake and classification

Every AI system, model and agent enters through an intake that classifies it: by risk tier, by regulatory exposure (EU AI Act high-risk, GPAI, out of scope), by data sensitivity and by autonomy. The engineer builds intake as a form-plus-code path, not a meeting: a request that scaffolds a registry entry, triggers the right impact assessment (FRIA, DPIA), and routes the system to the controls its class requires. The NIST AI RMF's Map function is the natural vocabulary for the classification step. Intake asks, in order: whether the problem needs AI at all ([strategy, value and whether to use AI at all](#), chapter 12); whether the system counts as AI ([the definitional decision and its registry fields](#), chapter 11); what the [use-case record](#) says about purpose and decision authority (chapter 14); which risk tier the [use-case risk profile](#) gives it (chapter 13); and where it sits on [the AI Act risk ladder](#) (chapter 18). A system that is bought rather than built enters with a [Deployment Decision Record](#) (chapter 15). The [Use-Case Intake & Risk Tiering](#) pattern builds the intake, and the [AI Act triage](#) drafts the classification decision record. **Maps to** Inventory & Transparency.

Inventory and registry

The engineer owns the inventory of models and the **agent registry**, the runtime-aware record of every non-human actor, each with an owner, a declared scope, a status and a kill switch. The capability that distinguishes the engineer here is the runtime data path: the registry is fed by the deployment pipeline and by discovery against production, not typed into a spreadsheet, and every non-human actor in it carries its own identity; chapter 23 sets out what [an agent's registry entry](#) has to carry. **Maps to** Inventory & Transparency.

Evals and red teaming as evidence

The engineer builds and maintains the eval suites (capability, safety and adversarial) and wires them into an **eval gate** so a failing eval blocks the release. This is the workflow that most sharply separates the engineer from the analyst: the analyst reviews a model report; the engineer writes the test the model must pass and owns the harness that runs it (Inspect AI, promptfoo, Garak, Giskard, DeepEval, Ragas as category examples, illustrative not endorsed). The "AI Evaluation & Governance Engineer" role is defined around "automated testing harnesses and safety guardrails" and adversarial red-teaming [1]. **Maps to** Evals & Red Teaming as Evidence.

Policy-as-code and gates

The engineer expresses governance rules as executable policy ([OPA/Rego](#) , Cedar, Policy Cards) that evaluate in CI/CD and at admission, and maintains the gates that enforce them. A public GRC engineering-manager posting frames the mandate as "translate policies into policy-as-code" [3]. The engineer's output here is a merge that is blocked or allowed, with a logged reason, not a recommendation in a review. **Maps to** Govern-as-Code.

Runtime monitoring and incidents

The engineer instruments runtime: guardrail decisions, tool-call mediation, drift signals and agent behaviour stream into observability (Langfuse, Arize Phoenix over OpenTelemetry as examples). They own the detection-to-report path for serious incidents, including the EU AI Act's Article 73 clock for high-risk systems, and they own the tested **kill switch** for agents, with the threat model that says which runtime failures the controls are built against [5]. Chapter 17 covers [incident response](#) and [root-cause analysis](#). **Maps to** Runtime Controls & Observability.

Assurance and audit evidence

The engineer emits **audit-ready evidence** as a by-product of the build (`OSCAL` component and assessment artefacts, signed logs, structured eval results) so the audit is a query, not a project. This is **continuous assurance**: the control's status is a live signal, not a point-in-time attestation. **Maps to** Assurance & Continuous Compliance.

Regulatory translation

The engineer reads the obligation well enough to build the control that meets it: turning an AI Act article, an ISO/IEC 42001 control or a NIST AI RMF subcategory into a gate, a registry field or an evidence artefact, and back, so an auditor can trace the control to the obligation. This is translation, not legal advice; the engineer depends on Legal to confirm the obligation is read right. **Maps to** all five layers; it is the spine that chapter 08 indexes, and chapter 18 reads [the EU AI Act in one pass](#) for the engineer who has to translate it.

Skills, by workflow

Skills are grouped by the workflow they serve, not by the certificate that teaches them. The table is a capability map: it says what you must be able to do, in rough order of how load-bearing it is for each workflow. It is illustrative, not a checklist to pass.

Workflow	Core skills	Supporting skills
Intake & classification	Risk taxonomy design; reading the EU AI Act risk tiers; requirements analysis	Form/workflow tooling; light data modelling
Inventory & registry	Non-human identity and scoped access; API integration to CI/CD; data modelling	Cloud IAM; discovery tooling; SPIFFE/SPIRE concepts
Evals & red teaming	Eval harness engineering; adversarial prompting; statistical literacy; Python	LLM/agent internals; benchmark design; threat modelling (STRIDE/PASTA)
Policy-as-code & gates	<code>OPA/Rego</code> or Cedar; CI/CD pipeline engineering; Git	Policy schema design (Policy Cards); admission control
Runtime monitoring & incidents	Observability/OpenTelemetry; guardrail configuration; incident response	Detection engineering; MCP and agent-protocol security
Assurance & audit evidence	<code>OSCAL</code> and machine-readable evidence; logging and signing; audit fluency	Cryptographic attestation; evidence-store design
Regulatory translation	Reading regulation and standards (AI Act, ISO/IEC 42001, NIST AI RMF); mapping	Legal English; DPIA/FRIA methodology

Two cross-cutting skills sit under all seven: enough **Python** to glue systems together (postings put Python in roughly one in four AI-governance listings [4]), and enough **law-reading** to parse an article without mistaking it for advice. Neither is optional; neither is the whole job.

Analyst versus engineer

The clearest way to define the role is against the analyst it grows from. The contrast below is written for AI governance and modelled on the analyst-vs-engineer table that the GRC Engineer literature uses for its parent discipline [2]. Both roles are needed; the engineer is not "better", but does different work and is measured differently.

Dimension	AI governance analyst	AI governance engineer
Evidence artefact	A point-in-time artefact (an attestation, a questionnaire, an exported report) compiled for a review	A continuously emitted artefact (a query result, an eval run, a signed log) produced as the pipeline runs
Primary source	Works from the system's reported description: documentation, summaries and vendor answers	Works from the running system: the registry and production telemetry, the same signals the build emits
Toolset	Spreadsheets, a GRC/AI-governance platform, ticketing	Python, <code>OPA/Rego</code> , Git, CI/CD, eval harnesses, <code>OSCAL</code> , plus the platform
Cadence	Periodic: quarterly reviews, annual assessments	Continuous: every commit, deploy and runtime call
Output	A report, a mapping matrix, a risk rating	A merged-or-blocked build, a registered agent, a machine-readable evidence artefact

Dimension	AI governance analyst	AI governance engineer
Success metric	Audit passed, framework coverage complete	Control failures caught before the auditor arrives, and realised risk measurably reduced

The distinction is cadence and artefact, not competence or clearance. It is not that the analyst cannot read a registry or the engineer cannot write a report; it is that the analyst's deliverable is a periodic description and the engineer's is a continuous control. A good analyst reads systems closely; a good engineer writes clearly. The failure modes differ too, and naming them keeps both honest. The analyst's failure mode is compliance theatre: documentation that runs ahead of reality. The engineer's failure mode is over-engineering: automating a control for a process nobody agreed to fix, or building a gate so brittle that engineers route around it. Neither role is safe from its own failure mode by title alone.

The career ladder

The role has observable rungs, each defined by what the person can be trusted to own end to end, not by years served, and verifiable by looking at the systems, not a self-assessment.

1. **Associate.** Runs existing controls: adds an eval to a suite, registers an agent correctly, produces evidence from a control someone else built.
2. **AI governance engineer.** Builds a control end to end (one obligation into a gate, an eval suite for a system class, wired into CI/CD) and owns at least one workflow for a product area.
3. **Senior.** Owns a full workflow across the organisation and designs the paved path others adopt; the registry, eval gate or evidence pipeline they built is the standard template.
4. **Staff / principal.** Owns the reference architecture (how the five layers fit together) and the cross-cutting decisions (identity model, evidence format, incident path).
5. **Head of AI governance engineering.** Owns the function and its shared ownership with engineering, measured by realised risk reduction, not by controls stopped. A public engineering-manager posting scoped to "build an AI-forward GRC engineering function" sits at this rung [3].

A person can hold the capability at rung two while the title lags at "analyst", or hold the title without the capability. The ladder describes the work, and the work is visible in the systems.

Three ways in

Nobody starts as an AI governance engineer; everyone converts from an adjacent discipline, keeping its strength and adding what it lacks.

- **From Legal or privacy.** Your edge is regulatory translation; your gap is the build. Turn one assessment into a versioned, executable artefact (a FRIA-as-code template, a policy in `OPA/Rego`), and learn enough pipeline to see where the control fires. Start at policy-as-code and intake.
- **From Security or GRC.** Your edge is the control mindset; your gap is the model layer. GRC engineering already taught the parent moves: policy-as-code, continuous assurance, evidence as a by-product [2]. Add the AI-specific objects: evals as controls, agent identity and scope, and the model and agent failure modes of the OWASP Agentic Top 10 [5]. Start at evals-as-evidence and the agent registry.
- **From MLOps or ML engineering.** Your edge is the runtime data path everyone else lacks; your gap is the obligation. Add the eval *gate* rather than the eval report, the registry field for owner and scope, the evidence artefact the audit needs. Start at eval gates in CI and runtime monitoring.

The market

The role is defined by the workflows above, not by the vacancies. But the market is forming and the evidence is public, and it corroborates the shape of the work. Treat every figure as sourced; salary points are survey medians or posting ranges, not guarantees.

Survey bands. The IAPP Salary & Jobs Report 2025-26 (1,600+ respondents, 60+ countries) puts technical AI-governance roles in the tech sector at a median of USD 221,000 (its highest band) against USD 151,800 for AI-governance work generally and USD 169,700 for combined privacy-and-AI- governance roles [6]. The premium is for the technical, build-the-control end of the discipline, which is exactly the role this chapter describes.

Skills in demand. Analysis of US postings since January 2026 (Axial Search) reports observability/monitoring in 41-42% of AI-governance listings, Python in 27-28%, NIST frameworks in about 27%, foundation-model familiarity in 25.6% and cloud in 18.2%; median advertised pay was USD 169,000 and median required experience five years [4]. And the demand signal is broad: LinkedIn's 2026 Skills on the Rise lists governance and responsible-AI skills among its fastest-rising clusters, alongside the technical AI capabilities [7]. The load-bearing signal is the skills mix (observability, Python, the runtime data path), not the salary headline.

Postings (footnote). Individual postings mark the top of the range: a GRC engineering-manager role at a frontier lab was advertised in 2026 at USD 405,000 [3]. But named vacancies are a lagging, noisy signal, kept here as corroboration and out of the argument; this edition cites no job-board listing whose URL expires or is reassigned once the vacancy closes. The role is the workflows, not the requisition.

What employers get wrong in the job description

Reading the postings against the workflows above, three mistakes recur.

- **Certifications as a proxy for capability.** Descriptions list AIGP, CIPP, CISSP and CISM as if a certificate produced a control. The Axial data shows certs appear in under 11% of postings each [4]; the load-bearing skills (eval harnesses, policy-as-code, the runtime data path) are the ones the JD under-specifies. Ask for the workflow, then the cert if it helps. What each scheme assesses, and how this book relates to it, is set out neutrally on the [certifications page](#).
- **Analyst work under an engineer title.** In our reading of the postings, "AI Governance Engineer" titles often describe intake, mapping and reporting (analyst work) at engineer pay. The tell is the absence of any build: no eval gate, no registry integration, no evidence pipeline.
- **Everything, in one hire.** A single posting asks for policy-as-code, red teaming, identity, observability, incident response, regulatory translation and stakeholder management. That is a function, not a person: the seven workflows are owned across a team, and a first hire owns two or three and builds the paved path for the rest.

In practice In a large telco, the role arrived before the title. The first version of the work sat inside a privacy team and looked like DPIAs and reviews. What turned it into AI governance engineering was owning two workflows outright: wiring the model and agent registry to the deployment pipeline so it was true on any Tuesday, and putting an eval gate in CI so a regression in injection resistance failed the build. The job description caught up a year later. The capability was visible in the systems long before it was visible on the org chart.

Maps to: EU AI Act Art. 9 (risk management), Art. 26/27 (deployer duties, FRIA), Art. 72 (post-market monitoring), Art. 73 (serious-incident reporting) · ISO/IEC 42001 (roles, responsibilities and competence) · NIST AI RMF (Govern) · OWASP Top 10 for Agentic Applications 2026. Mappings are illustrative, not a claim of conformity.

What you can do this week

1. **Map the seven workflows.** Write down who owns intake, inventory, evals, policy-as-code, runtime and incidents, assurance and regulatory translation today, and mark the ones nobody owns.
2. **Own one workflow outright.** Pick the one with the least build in it (often the registry or the eval gate) and ship one control there that blocks or records, not one that recommends.
3. **Rewrite one job description.** Replace the list of certifications with the workflows the hire will own and the artefacts they will ship in their first quarter.
4. **Practise one core skill on a real system.** From the skills table, take the core skill your workflow lacks and use it once on a live pipeline: one policy in `OPA/Rego`, one eval in a harness, one trace in OpenTelemetry.
5. **Translate one article in a pair.** Sit a lawyer or DPO with an engineer and turn one AI Act article into a gate, a registry field or an evidence artefact, and back again.

Sources

[1] "How the AI Engineer role is unbundling in 2026" (names the AI Evaluation & Governance Engineer). AI Journal. 2026-08-26. <https://aijourn.com/how-the-ai-engineer-role-is-unbundling-in-2026/> (verified: secondary) [2] "The GRC Engineer role" (analyst-vs-engineer table; career paths). GRC Engineer. 2025. <https://grcengineer.com/grc-engineer/> (verified: primary) [3] "Engineering Manager, GRC" posting (AI-forward GRC engineering function; policies into policy-as-code), USD 405,000. Anthropic (via General Catalyst jobs). 2026. <https://jobs.generalcatalyst.com/companies/anthropic/jobs/78167778-engineering-manager-grc> (verified: secondary) [4] AI governance jobs analysis (US postings since Jan 2026: observability 41-42%, Python 27-28%, NIST ~27%, foundation models 25.6%, cloud 18.2%; median pay USD 169,000; median 5 yrs). Axial Search. 2026-08-04. <https://axialsearch.com/insights/ai-governance-jobs> (verified: secondary) [5] Top 10 for Agentic Applications 2026. OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [6] Salary & Jobs Report 2025-26 (technical AI-gov in tech median USD 221,000; AI governance only 151,800; privacy + AI governance 169,700). IAPP. 2025-08-03. <https://iapp.org/resources/article/salary-survey-summary/> (verified: primary) [7] LinkedIn 2026 Skills on the Rise (governance and responsible-AI skills among the fastest-rising clusters; no per-skill percentage published). LinkedIn, via EdTech Innovation Hub. 2026. <https://www.edtechinnovationhub.com/news/linkedin-2026-skills-on-the-rise-shows-global-ai-driving-hiring-shifts> (verified: secondary) [8] "What is GRC Engineering" (capability, not a job title). GRC Engineer. 2025. <https://grcengineer.com/what-is-grc-engineering/> (verified: primary)

07. Maturity model (five levels)

A ladder from paper to production (Documented, Inventoried, Tested, Enforced, Continuous), where each level is proven by what the running systems can show, not by what a document claims.

Why a maturity model, and how to read this one

Maturity models fail when they measure paperwork. This one measures the systems. A level is not a score you award yourself; it is a state you can demonstrate by querying the registry, running the gate and reading the evidence store. The ladder runs from governance that exists only on paper to governance that runs continuously off the runtime data path.

The five levels answer the three questions with rising confidence. **Documented** and **Inventoried** answer *what AI is running*, first on paper, then from a live inventory. **Tested** and **Enforced** answer *what it is allowed to do*, first by measuring, then by blocking. **Continuous** answers *what evidence proves it*, continuously, from telemetry. Each level is assessed across all five layers of the stack (chapter 04); you are at a level only when every layer has reached it, because a chain is as strong as its weakest layer.

The five levels

Level 1: Documented. Governance exists as artefacts a human maintains: a policy PDF, a spreadsheet inventory, a risk register, a review that happens before launch. The rules are written and someone is accountable, but nothing executes. Typical evidence: policy documents, a populated spreadsheet, meeting minutes. Typical failure that moves you back: the document was last edited a quarter ago and no longer matches production; the artefact is stale before it is signed. Chapter 13 shows what the risk register looks like at each level ([risk practice by maturity level](#)).

Level 2: Inventoried. There is a real inventory of models and an [agent registry](#), and it is fed by a runtime data path rather than typed by hand: a deploy registers a system with an owner, a scope and a status. You can answer *what is running* on any given day. Typical evidence: a registry with an owner and a class for every system; a discovery job reconciling registry against production. Typical failure: [shadow AI](#). A system or agent reaches production without registering, so the inventory is complete only for the honest.

Level 3: Tested. Systems are evaluated against defined tests (capability, safety and adversarial evals) and the results are recorded as evidence. Failures are visible, but a failing eval does not yet stop anything. You know which systems fall short; you have not yet made falling short have consequences. Typical evidence: versioned eval suites; stored, timestamped eval results; red-team findings. Typical failure: the eval is run once before launch, pasted into a slide, and never re-run when the model or its prompts change.

Level 4: Enforced. The tests bite. [Policy-as-code](#) and [eval gates](#) run in CI/CD and at admission, and a failing control blocks the merge or the deploy. Identity precedes autonomy: an agent with no owner, scope or [kill switch](#) is denied a [workload identity](#). Governance is now a property of the build, not a checkpoint after it. But a blocking gate is only as good as the test behind it, so Level 4 has a second condition that is easy to skip: the eval suite's own *quality* is assessed, not just its existence and its teeth. A gate that blocks on a trivial or stale suite is Level 4 by the letter and framework theatre in fact: a green build that proves nothing. So the enforcement claim requires that coverage is measured, adversarial cases are maintained against current threats, and thresholds trace to named failure modes rather than round numbers (see chapter 01, "the limits of the eval gate"). Typical evidence: pipeline logs showing blocked releases with reasons; admission-control denials; the registry acting as a deploy gate; a tracked coverage or adversarial-quality metric for the suites that gate. Typical failure: brittle gates that engineers route around; a gate maintained by governance alone that engineering does not own; or a gate whose suite is trivial or unmaintained, so the block is real but the assurance is not.

Level 5: Continuous. Assurance is produced continuously from the runtime data path. Guardrail decisions, tool-call mediation, drift and agent behaviour stream into observability; [continuous assurance](#) turns production behaviour into a live control signal; evidence is emitted as [machine-readable artefacts](#) ([OSCAL](#), signed logs) as the pipeline and runtime operate. The audit is a query. On one vendor's comparison of the AI-governance platform category, most of it does not reach this end state, because it "manages the program ... without any runtime data path" [1]. Typical evidence: a live assurance store; streaming eval and guardrail telemetry; an audit answered by running a query. Typical failure: telemetry that is collected but never wired to a decision; observability without enforcement decays back to Level 3 dressed up as Level 5.

Observable criteria, by layer and level

Read each row as one layer maturing left to right. You are at a level only when every row has reached its column.

Layer	1 Documented	2 Inventoried	3 Tested	4 Enforced	5 Continuous
1 Govern-as-Code	Policies written as prose	Policies indexed, mapped to systems	Policy checks run and report, non-blocking	Policy-as-code blocks merge/deploy	Policy verdicts stream to assurance, versioned

Layer	1 Documented	2 Inventoried	3 Tested	4 Enforced	5 Continuous
2 Inventory & Transparency	Spreadsheet inventory	Registry fed by deploy; owner + scope per system	Registry reconciled against production	Registry gates deployment ; no entry, no identity	Registry live off runtime discovery ; drift auto-flagged
3 Evals & Red Teaming as Evidence	Evals described in a plan	Eval suites exist and are versioned	Evals run, results stored, non-blocking	Eval gate fails the build on regression; suite coverage and adversarial quality assessed	Evals run continuously; results are live evidence
4 Runtime Controls & Observability	Guardrails named in a design	Guardrails deployed, not measured	Guardrail decisions logged	Kill switch tested; tool-calls mediated and enforced	Runtime signals drive control decisions in real time
5 Assurance & Continuous Compliance	Evidence gathered by hand for audit	Evidence templated per control	Structured evidence produced per run	Evidence required to pass the gate	Machine-readable evidence emitted continuously; audit = query

Partial maturity is the normal state. Almost no real function sits at one clean level across all five layers; the usual picture is a ragged line: inventory at Level 4, evals at Level 2, assurance at Level 3. That is not a failure of the model, it is the point of reading it by layer. The single overall level is the weakest layer, and it is a *floor* for planning, not a verdict on the whole function. Two readings follow: report the per-layer profile, not just the floor, because it shows where the leverage is; and expect the profile to stay ragged, because layers mature at the speed of the work they gate, not in lockstep. A function that is Level 4 on identity and Level 2 on evals is doing better than the overall "Level 2" suggests, and its next move is obvious from the profile.

Metrics per level

Each level has metrics you can read off the systems. Track the trend, not the single number.

- **Level 1 → 2:** percentage of AI systems and agents in the registry with a named owner and a class; registry-to-production reconciliation gap (systems in production but not registered).
- **Level 2 → 3:** percentage of registered systems with a versioned eval suite; percentage with a recorded, timestamped eval result in the last release.
- **Level 3 → 4:** percentage of releases passing through an [eval gate](#) (versus bypassing it); percentage of agents with a tested kill switch and a scoped, non-shared identity; number of releases blocked with a logged reason.
- **Level 4 → 5:** mean time to detect an unauthorised agent action (an agent doing something outside its declared scope, OWASP Agentic ASI03/ASI10 territory [2]); [evidence freshness](#) (age of the most recent evidence artefact per control); percentage of controls whose status is answerable by a live query rather than a manual pull.

The single most telling cross-level metric is evidence freshness. At Level 1 the freshest evidence is a quarter old; at Level 5 it is as old as the last pipeline run. If your evidence ages in months, you are not yet continuous, whatever the dashboard says. These are engineering metrics; the board-level set that reports them upward is in chapter 12 ([KPIs and KRIs for leadership and the board](#)).

Self-assessment checklist

Answer each with the system, not the intention. A "no" caps you at the level below.

- **Documented:** Is every AI system covered by a written policy with a named owner? Is there a risk register that a person maintains?
- **Inventoried:** Does the registry get an entry automatically at deploy, with owner, scope and status? Can you list every model and agent running today, from the system of record, in under a minute?
- **Tested:** Does every registered system have a versioned eval suite? Are results stored with timestamps? Do you run red-team evals against your agents?
- **Enforced:** Does a failing eval or policy check actually block a release? Is an agent without an owner, scope and kill switch prevented from reaching production? Can you show a release that was blocked, with the reason logged?
- **Continuous:** Is runtime telemetry wired to control decisions, not just dashboards? Is evidence emitted as machine-readable artefacts continuously? Would an audit question be answered by a query rather than a collection sprint?

If you can say yes to a whole level and to every layer within it, you are at that level. The first "no" is your next piece of work, and the smallest step to the next level is almost always to close the weakest layer, not to add a sixth control to the strongest one. Run the checklist as a tool: the [maturity self-check](#) draws your per-layer profile, names the floor and the next move, and exports it.

How this relates to certification and other assessments

This maturity model is not a certification and does not confer one. It relates to three external schemes; the relationship is one of support and overlap, not equivalence.

ISO/IEC 42001 certification. ISO/IEC 42001 certifies that an AI management system (AIMS) exists and is operated, a Level 1-2 proof of *process*: that governance is documented, owned and reviewed. It says little about whether an **eval gate** blocks a build or whether evidence is machine-readable, the Level 4-5 properties. And it is not a harmonised standard: the certificate confers no presumption of conformity with the EU AI Act, because none is yet cited in the Official Journal [3]. Reaching Level 5 supports a 42001 audit by producing evidence continuously; it does not replace the certificate, and the certificate does not prove you are past Level 2. Whatever the scheme, run [an audit programme](#), not a single audit (chapter 15).

OWASP AI Maturity Assessment (AIMA). OWASP's GenAI Security Project publishes an AI Maturity Assessment reported at v1.0 (Aug 2025) [4]. It is complementary: where AIMA scores the *breadth* of an AI security programme, this model scores the *depth* of the runtime data path. Use AIMA to find gaps in coverage; use this ladder to find whether the covered controls actually fire.

CSA STAR for AI. CSA's STAR for AI is a certification programme built on the AI Controls Matrix (AICM), with a self-assessment tier, an automated "Valid-AI-ted" tier and a Level 2 combining third-party ISO/IEC 42001 certification with the validated assessment [1][5]. Its Level 2 aligns with the *Enforced* end of this ladder, but, like 42001, it attests a programme rather than measuring the freshness of runtime evidence, the property continuous assurance (Level 5) makes cheap to produce and hard to fake. Certificates of persons (AIGP, ISO/IEC 42001 Lead Implementer and Lead Auditor, AAISM, AAIA) are a different thing again: see the [certifications page](#).

In practice A function in a large telco assessed itself honestly and landed at Level 2 for inventory but Level 1 for evals: the registry was live off the deploy pipeline, but evals were still run by hand before launch and pasted into slides. The chain was only as strong as its weakest layer, so the function was Level 1 overall. The smallest step was not a new framework mapping; it was versioning one eval suite and storing its timestamped results, moving the eval layer to Level 3, before wiring it into a gate. Evidence freshness fell from a quarter to a release cycle within two sprints.

Maps to: EU AI Act Art. 9 (risk management), Art. 17 (quality management system), Art. 72 (post-market monitoring) · ISO/IEC 42001 (AIMS) and ISO/IEC 42005 (impact assessment) · NIST AI RMF (Govern, Measure, Manage) · OWASP Top 10 for Agentic Applications 2026 · CSA AICM / STAR for AI. Mappings are illustrative, not a claim of conformity.

What you can do this week

1. **Score each layer, not the function.** Answer the self-assessment checklist per layer, from the systems rather than the intention, and take the lowest level as your overall level.
2. **Measure evidence freshness.** For each control, record the age of its most recent evidence artefact. The oldest one is where the next sprint starts.
3. **Reconcile the registry once.** Compare what the registry lists with what is running in production, and count the systems and agents that never registered.
4. **Raise the weakest layer by one level.** Ship the smallest step there (a versioned eval suite with stored results, or a registry that gates a deploy) before adding a control to the strongest layer.
5. **Find one blocked release.** Show a release that a failing eval or policy check stopped, with the reason logged. If there is none, you are not yet at Enforced, whatever the dashboard says.

Sources

[1] "Best AI Governance Platforms in 2026: 14 Enterprise Vendors Compared" (vendor-published comparison of the 13 Magic Quadrant vendors plus its own product; most of the category "manages the program ... without any runtime data path"). Kosmoy. 2026-07-10. <https://www.kosmoy.com/resources/blog/best-ai-governance-platforms-2026/> (verified: secondary) [2] Top 10 for Agentic Applications 2026 (ASI03 Agent Identity & Privilege Abuse; ASI10 Rogue Agents). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [3] ISO/IEC 42001 certification is not yet a presumption of conformity with the EU AI Act (no harmonised standard cited in the OJ). Law & Technology. 2026. <https://lawandtechnology.eu/en/iso-iec-42001-and-the-ai-act-why-certification-is-not-yet-a-presumption-of-conformity/> (verified: secondary) [4] OWASP AI Maturity Assessment (AIMA), reported at v1.0 (Aug 2025); Secure Governance initiative. OWASP GenAI Security Project. 2025. <https://genai.owasp.org/initiatives/> (verified: reported) [5] STAR for AI (three certification levels; Level 2 = third-party ISO/IEC 42001 + Valid-AI-ted; built on the AI Controls Matrix). Cloud Security Alliance. 2026. <https://cloudsecurityalliance.org/star/ai> (verified: primary)

08. Regulatory map (obligation → artefact → layer)

This chapter is the reverse index of every "Maps to" line in the book: for each obligation it names the engineering artefact that satisfies or supports it and the stack layer the artefact lives in.

Every other chapter maps *forward*: a capability, then the obligations it touches. This chapter maps *backward*: an obligation, then the artefact and the layer that answer it. The unit of the map is a row: an obligation, the engineering artefact that produces the evidence for it, and one of the five stack layers (chapter 04): **1 Govern-as-Code · 2 Inventory & Transparency · 3 Evals & Red Teaming as Evidence · 4 Runtime Controls & Observability · 5 Assurance & Continuous Compliance**. The map is a crosswalk for finding the artefact that answers a question, not a certificate that the artefact makes you compliant. It indexes the AI-specific instruments first and then the data-protection, cyber-security, liability, consumer and sector law an AI system meets on day one, so that every row of the [obligation register](#) resolves to a table in this chapter. Chapter 19 teaches the data-protection rows in its [obligation to artefact map](#), and chapter 20 the [other law that already applies to AI](#) (copyright, anti-discrimination, consumer protection and product liability).

How to read this map

Read each row as a sentence: *this obligation is answered by this artefact, which lives in this layer*. Three cautions apply throughout.

- **Mappings are illustrative, not a claim of conformity.** No artefact in this book guarantees compliance, and no standard cited here confers a presumption of conformity (see "What is NOT harmonised yet"). An artefact *supports* and *evidences* an obligation; the legal judgement of conformity stays with lawyers, notified bodies and authorities.
- **Dates are the post-Omnibus dates.** Every EU AI Act date below reflects Regulation (EU) 2026/1744, the Digital Omnibus on AI, of 8 July 2026 (OJ L, 24 July 2026), in force 27 July 2026 [1][2][22]. Where the Omnibus moved a date, the moved date is shown; where it did not, the row says so.
- **The competent authority differs by regime.** For general-purpose AI (GPAI) the supervisor is the **AI Office**, and GPAI fines are formal Commission decisions under Article 101 [3][4]. For high-risk systems the supervisors are **national market-surveillance authorities**, whose penalties run under Article 99 [4]. Member States choose their own; Spain, for example, set up a dedicated agency, **AESIA** (Agencia Española de Supervisión de Inteligencia Artificial), whose statute was approved by Royal Decree 729/2023 [52]. The map states the authority per row so the reader knows who asks.

EU AI Act, post-Omnibus

For a teaching walk-through of the Act before this reverse index maps it (scope, the risk ladder, value-chain roles, deployer duties, enforcement and the full post-Omnibus timeline), see [chapter 18](#), which walks the Act end to end.

High-risk obligations (Articles 9–15, 17, 25, 26, 27, 49, 71, 72, 73) apply to Annex III systems from **2 December 2027** and to Annex I embedded systems from **2 August 2028**, both deferred by the Omnibus from 2 August 2026 and 2 August 2027 respectively [1] [2]. The amended [Art. 113\(c\)](#) defers Chapter III, Sections 1 to 3: classification, the requirements of Articles 8 to 15 and the duties of providers, deployers and other operators in Articles 16 to 27 [22]. The high-risk duties that sit elsewhere (conformity assessment, the declaration, CE marking and registration in Articles 43 to 49 and 71, post-market monitoring and incident reporting in Articles 72, 73 and 75(1a), and the right to explanation in Article 86) belong to chapters that formally apply from 2 August 2026, but they have work to do only once a system is classified high-risk, so the map dates them by the classification date. That is this map's reading; confirm it with counsel (verify) [22][63]. Articles 26(11), 27, 49, 71 and 86 concern Annex III systems only, so the 2 August 2028 date does not reach them. The GPAI obligations (Articles 53, 55) have applied since 2 August 2025, with Commission enforcement powers live since 2 August 2026 [3]; providers of models placed on the market before 2 August 2025 comply by 2 August 2027 ([Art. 111\(3\)](#)) [63]. Transparency (Article 50) went live on 2 August 2026 and was not moved [5]. Legacy public-authority high-risk systems keep their original 2 August 2030 date [2].

The **Duty holder** column names who the obligation binds, which is a different axis from who enforces it. The high-risk design-and-build duties (Articles 9 to 15 and 17) fall on the **provider**; Articles 26 and 27 fall on the **deployer**; Articles 4, 5 and 50 bind **both**; and Articles 53 and 55 bind the **GPAI provider**. Article 25 sits across the value chain: it sets the conditions under which a distributor, importer or deployer itself becomes a **provider** and inherits the provider duties. Articles 22 to 24 bind the **authorised representative** of a non-EU provider, the **importer** and the **distributor**, and Article 54 the authorised representative of a non-EU GPAI provider. This matters for the engineer because the artefacts you can produce depend on which hat your organisation wears: a deployer cannot draw up the provider's technical documentation, but it must run the Article 26 monitoring and the Article 27 FRiA; and when the model is procured, most of the provider-side evidence becomes something you collect rather than produce (see the Vendor / Model Due-Diligence Gate in chapter 05).

Article 16 is the umbrella for the provider's high-risk duties. Apart from point (l), accessibility, which has its own row, it adds no artefact of its own; it gathers the obligations the rows below break out article by article: the requirements of Articles 9 to 15 and 17, documentation keeping and logs (Articles 18 and 19), corrective action (Article 20), the conformity assessment (Article 43), the EU declaration of conformity and CE marking (Articles 47 and 48), registration (Articles 49 and 71), post-market monitoring (Article 72) and serious-incident reporting (Article 73). So it reads here as a cross-reference, not a row [22][63].

Article	Obligation	Engineering artefact	Layer	Duty holder	Applies (post-Omnibus)	Authority
Art. 3(1)	Scope: decide, system by system, whether it is an AI system under the Art. 3(1) definition before any other duty is assessed	Definitional decision record in the registry: definition applied, elements found, excluded family if any, reason, decider, date	2	Provider + deployer (scoping)	2025-02-02 (Chapter I) [63]	National MSA
Art. 4	AI literacy: take measures to support the development of AI literacy among staff and operators	Literacy programme as code; role-based training records; onboarding gates	1	Provider + deployer	2025-02-02; reworded 2026-07-27 (in force) [6][22][63]	Provider/deployer duty; national MSA
Art. 4a	Lawful basis to process special-category data for bias detection in high-risk systems, with pseudonymisation and deletion once bias is corrected	Data governance controls; pseudonymisation and retention-as-code; data card noting basis and deletion	2	Provider	2026-07-27 (new, in force) [2]	National MSA / DPAs
Art. 5	Prohibited practices; new bans on AI-generated non-consensual intimate imagery (NCII) and CSAM	Policy-as-code blocklist; input/output guardrails; refusal and abuse detection	1 · 4	Provider + deployer	2026-12-02 (new bans); earlier prohibitions from 2025-02-02 [2]	National MSA
Art. 6	Classification rules for high-risk AI systems, incl. the Annex III (standalone) route and Annex I (safety-component) route	Risk-tiering as code; high-risk classification decision record; register entry flagging Annex III status	1 · 2	Provider	2027-12-02 (Annex III) [1] [22]	National MSA
Art. 6(3)–(4)	A provider that finds an Annex III system not high-risk under the Art. 6(3) filter documents the assessment before placing it on the market and registers it under Art. 49(2); a system that profiles natural persons is always high-risk	Classification decision record (Annex III point, Art. 6(3) condition, explicit profiling flag); Art. 49(2) registration entry pushed from the registry	1 · 2	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 9	Risk management system across the high-risk lifecycle	Risk register as code; threat models; linkage to FRIA and eval results	1 · 3	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 10	Data and data governance; representative, relevant, error-checked datasets	Data cards; lineage; bias and quality tests in CI	2 · 3	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 11	Technical documentation (Annex IV) drawn up and kept up to date	AIBOM (CycloneDX ML-BOM , SPDX 3.0 AI); auto-generated technical documentation; model cards	2	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 12	Record-keeping: automatic logging of events over the system's lifetime	Structured, signed logs; OpenTelemetry traces; tamper-evident event store	4	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 13	Transparency and provision of information to deployers	Instructions for use as code; model and data cards; capability and limitation notes	2	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 14	Human oversight designed into the system	Human-in-the-loop checkpoints; kill switch; override and escalation paths	4	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 15	Accuracy, robustness and cybersecurity	Eval gate; adversarial red-team suite; robustness and security controls; regression evals	3 · 4	Provider	2027-12-02 (Annex III) [1]	National MSA

Article	Obligation	Engineering artefact	Layer	Duty holder	Applies (post-Omnibus)	Authority
Art. 15(4)	Systems that continue to learn after placing on the market are built to eliminate or reduce the risk of biased outputs feeding future inputs (feedback loops), with mitigation measures	Feedback-loop fairness monitor; retraining-data bias check; agent memory write gate with provenance and rollback to a known-good snapshot	3 · 4	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 16(1)	Providers ensure the high-risk system complies with the accessibility requirements of Directives (EU) 2016/2102 and (EU) 2019/882	Accessibility test results for every notice, instruction and explanation shown to people, run in the pipeline; accessible explanation templates	2 · 3	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 17	Quality management system	QMS-as-code; versioned policies; pipeline controls and change management	1 · 5	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 17(1) (m)	The QMS includes an accountability framework setting out the responsibilities of management and other staff for every aspect of the QMS	RACI as code compiled into registry owner fields and code-owner rules; committee decision records	1 · 2	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 18	Keep the technical documentation, the QMS documentation, notified-body changes and decisions and the EU declaration at the disposal of national authorities for 10 years after placing on the market	Retention-as-code for the technical file, QMS records, notified-body decisions and the EU declaration (10 years); write-once evidence store	2 · 5	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 19	Keep the automatically generated logs under the provider's control for a period appropriate to the intended purpose, at least six months unless other law provides otherwise	Log-retention policy as code (at least six months, set by intended purpose); tamper-evident log store	4 · 5	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 20	A provider with reason to consider a high-risk system non-conforming immediately brings it into conformity, withdraws, disables or recalls it and informs distributors and deployers; where the system presents a risk, it investigates and informs the market-surveillance authority	CAPA record; withdraw, disable or recall runbook; notification of distributors and deployers	1 · 5	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 22	A provider established outside the Union appoints, by written mandate, an authorised representative in the Union before making the system available; the representative keeps the declaration, documentation and certificate for 10 years	Written mandate; 10-year copies of the declaration, technical documentation and certificate; authority contact route	5	Non-EU provider + authorised representative	2027-12-02 (Annex III) [63]	National MSA

Article	Obligation	Engineering artefact	Layer	Duty holder	Applies (post-Omnibus)	Authority
Art. 23	Before placing a high-risk system on the market, the importer verifies the conformity assessment, the Annex IV documentation, the CE marking, the declaration and instructions and the authorised representative, and keeps copies for 10 years	Import verification record against each check; 10-year document copies	2 · 5	Importer	2027-12-02 (Annex III) [63]	National MSA
Art. 24	Before making a high-risk system available, the distributor verifies the CE marking, the declaration and the instructions, and holds back, withdraws or recalls a system it considers non-conforming	Distribution check record; hold, withdraw or recall workflow	2 · 5	Distributor	2027-12-02 (Annex III) [63]	National MSA
Art. 25	Responsibilities along the AI value chain: when a distributor, importer or deployer becomes a provider, and the information a provider must pass to actors downstream	Value-chain due-diligence gate; provider/deployer responsibility allocation; AIBOM and model/data cards collected from upstream providers	2 · 5	Provider + value-chain actors	2027-12-02 (Annex III) [23]	National MSA
Art. 26	Deployer obligations for high-risk systems: use per the instructions for use (Art. 26(1)); the paragraph rows below break out oversight, input data, monitoring, logs and notices	Deployment registry; monitoring hooks; assigned oversight and logging retention	2 · 4	Deployer	2027-12-02 (Annex III) [1]	National MSA
Art. 26(2)	Deployers assign human oversight to natural persons with the necessary competence, training and authority, and the necessary support	Oversight assignment in the registry; role-based training records with expiry; approver roster per checkpoint class with authority to pause or refuse	1 · 4	Deployer	2027-12-02 (Annex III) [63]	National MSA
Art. 26(4)	To the extent the deployer controls the input data, it ensures the data are relevant and sufficiently representative for the intended purpose	Input-data checks against the population in the deployment record; drift monitors on inputs	2 · 3	Deployer	2027-12-02 (Annex III) [63]	National MSA
Art. 26(5)	Deployers monitor operation per the instructions; on reason to consider a risk they inform the provider or distributor and the authority and suspend use; a serious incident goes to the provider first, and Art. 73 applies to the deployer if the provider cannot be reached	Monitoring plan with signal owners; tested suspension path (feature flag, traffic switch); provider incident contact in the registry; pre-filled risk and serious-incident notices	2 · 4 · 5	Deployer	2027-12-02 (Annex III) [63] [57]	National MSA
Art. 26(6)	Deployers keep the logs under their control for a period appropriate to the intended purpose, at least six months unless other law provides otherwise	Retention-as-code schedule; tamper-evident log store; legal hold while an incident is open	4 · 5	Deployer	2027-12-02 (Annex III) [63]	National MSA
Art. 26(7)	Before putting a high-risk system into service at the workplace, deployers who are employers inform workers' representatives and the affected workers	Worker-information record dated before first use and linked to the registry entry; HR intake trigger for Annex III point 4 systems	2	Deployer (employer)	2027-12-02 (Annex III) [63]	National MSA

Article	Obligation	Engineering artefact	Layer	Duty holder	Applies (post-Omnibus)	Authority
Art. 26(11)	Deployers of Annex III systems that make or assist decisions about natural persons inform those persons that they are subject to the system	AI-use notice at the decision point; notice templates versioned as code; notice delivery log	2 · 4	Deployer	2027-12-02 (Annex III) [63]	National MSA
Art. 27	Fundamental Rights Impact Assessment (FRIA) for deployers of Annex III systems	FRIA-as-code from a template; cross-reference to a GDPR Art. 35 DPIA	1 · 2	Deployer	2027-12-02 (Annex III) [7]	National MSA
Art. 43	Conformity assessment before placing on the market (internal control, or a notified body for Annex III point 1 biometrics)	Conformity-assessment workflow; internal-control or notified-body evidence pack; traceability to Annex IV documentation	1 · 5	Provider	2027-12-02 (Annex III) [1] [22]	National MSA
Art. 43(4)	A system already assessed undergoes a new conformity assessment on substantial modification; changes pre-determined in the technical documentation of a system that continues to learn are not substantial modifications	Change-classification policy on merge; pre-determined change envelope as code; reassessment trigger in the registry	1 · 5	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 47	EU declaration of conformity drawn up on completing the assessment	Auto-generated EU declaration of conformity from the evidence; CE-marking record	2 · 5	Provider	2027-12-02 (Annex III) [1] [22]	National MSA
Art. 48	Affix the CE marking visibly, legibly and indelibly (a digital marking for digitally provided systems), followed by the notified body's number where applicable	CE-marking record (physical or digital) generated with the EU declaration; notified-body number where applicable	2 · 5	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 49 / Art. 71	Registration of high-risk systems in the EU database	Agent/model registry with an API that feeds registration; owner and status per entry	2	Provider; public-authority deployer	2027-12-02 (Annex III) [1]	National MSA; Commission (database)
Art. 50	Transparency for certain AI systems: chatbot disclosure; marking and labelling of synthetic content	Content labelling and machine-readable marking (e.g. C2PA-style); chatbot disclosure banner	4 · 2	Provider + deployer	2026-08-02; marking grace for existing systems to 2026-12-02 [2] [5]	National MSA
Art. 52	Notify the Commission without delay, and within two weeks, once a GPAI model meets the Art. 51(1)(a) condition or it becomes known that it will	Compute ledger per model lineage with a planned-compute threshold alert; notification record filed within two weeks	2 · 5	GPAI provider	Obligations from 2025-08-02; enforcement from 2026-08-02 [63][3]	AI Office
Art. 53	GPAI provider obligations, incl. a public summary of training content on an AI Office template	Model cards; training-content summary; AIBOM and dataset provenance	2	GPAI provider	Obligations from 2025-08-02; enforcement from 2026-08-02 [3]	AI Office
Art. 53(1) (c)	GPAI providers put in place a policy to comply with Union copyright law, incl. identifying and complying with reservations of rights under Art. 4(3) of Directive (EU) 2019/790	Versioned copyright policy; crawler decision logs; training-data rights ledger with the reservation-check result	1 · 2 · 5	GPAI provider	Obligations from 2025-08-02; enforcement from 2026-08-02 [63][73]	AI Office

Article	Obligation	Engineering artefact	Layer	Duty holder	Applies (post-Omnibus)	Authority
Art. 54	A GPAI provider established outside the Union appoints, by written mandate, an authorised representative before placing the model on the Union market; the representative keeps the Annex XI documentation for 10 years	Written mandate; Annex XI documentation copy kept 10 years; AI Office contact route	5	Non-EU GPAI provider + authorised representative	Obligations from 2025-08-02; enforcement from 2026-08-02 [63]	AI Office
Art. 55	GPAI models with systemic risk: model evaluation incl. adversarial testing; Union-level risk assessment; serious-incident reporting; cybersecurity of the model	Eval and red-team suite; incident pipeline on the Commission serious-incident reporting template; weight-security controls; threat model	3 · 4 · 5	GPAI provider (systemic risk)	Obligations from 2025-08-02; enforcement from 2026-08-02 [3][26]	AI Office
Art. 60	Testing of high-risk (Annex III) AI systems in real-world conditions outside AI regulatory sandboxes	Real-world testing plan; Art. 61 informed-consent records; test monitoring, logging and incident hooks	3 · 4	Provider / prospective provider	2026-08-02 [22]	National MSA
Art. 72	Post-market monitoring for high-risk systems	Continuous assurance telemetry; monitoring plan; drift and performance signals	5	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 73	Serious-incident reporting for high-risk systems (deadlines in the reporting-clock table below)	Incident detection and triage pipeline; reporting-clock automation; evidence capture	5 · 4	Provider	2027-12-02 (Annex III) [1]	National MSA
Art. 73(6)	After reporting a serious incident the provider investigates without delay (risk assessment, corrective action) and does not alter the system in a way that may affect the evaluation of causes before informing the authorities	Evidence-preservation step: model, prompt, policy and retrieval-index snapshots; sealed traces; fix shipped on a new version	4 · 5	Provider	2027-12-02 (Annex III) [63]	National MSA
Art. 75(1a)	Providers of high-risk systems under the AI Office's exclusive competence (systems built on their own GPAI model, and systems in designated very large online platforms or search engines) report serious incidents to the AI Office, with Art. 73(2) to (9) applying mutatis mutandis	Incident pipeline routing by a registry competence flag (national MSA or AI Office)	2 · 5	Provider (systems under AI Office competence)	2027-12-02 (Annex III); new by the Omnibus (reading, verify) [22]	AI Office
Art. 86	A person subject to a deployer's decision based on an Annex III system (except point 2) with legal or similarly significant adverse effects may obtain clear and meaningful explanations of the system's role and the main elements of the decision, where Union law does not already give the right	Explanation record per decision (system and model version, reason codes, determinative or advisory role, human decider); request-handling workflow and response log	2 · 4 · 5	Deployer	2027-12-02 (Annex III); Chapter IX applies from 2026-08-02 (reading, verify) [63][22]	National MSA
Art. 87	Directive (EU) 2019/1937 applies to reports of AI Act infringements and to the protection of the people who make them	Internal reporting channel run as a case system with the directive's clocks encoded; sealed reporter identity; retaliation monitoring; routing to the incident pipeline	1 · 5	Legal entities with internal reporting channels under Directive (EU) 2019/1937	2026-08-02 [63] [64]	Authorities designated under Directive (EU) 2019/1937

Several rows are built out in full elsewhere in the book:

- Art. 4 : the literacy programme as code is [AI literacy as code](#) in chapter 12, and the role-based training records have a [literacy curriculum template](#).
- Art. 4a and Art. 10 : the lawful basis for [special-category data for bias detection](#) is in chapter 19; the data needed to test for bias, and [where bias enters the lifecycle](#), are in chapter 16 ([protected characteristics, proxies and the data you need to test](#)).
- Art. 6 : the [Article 6\(3\) filter and the profiling override](#) are walked through in chapter 18.
- Art. 9 : the risk register as code is [the risk register as an evidence record](#) in chapter 13; the same artefact answers the ISO/IEC 23894 row below.
- Art. 11, Art. 43 and Art. 47 : [Annex IV, element by element](#) and [conformity, in order](#) are in chapter 14.
- Art. 13 : instructions for use as code have a [JSON Schema and filled example](#); what they must say to deployers and affected people is in [the EU AI Act, Articles 13 and 86](#) (chapter 16).
- Art. 25 : [when a value-chain actor becomes a provider](#) is set out in chapter 18.
- Art. 26 : the [deployer duties in operation](#) are in chapter 15.
- Art. 27 : the FRIA's cross-reference to a GDPR Art. 35 DPIA is developed in [the DPIA for AI systems](#) (chapter 19).
- Art. 72 : the monitoring plan has a [post-market monitoring plan schema](#).
- Art. 3(1) : the definitional decision record is built field by field in [from definition element to registry field](#) (chapter 11).
- Art. 15(4) : feedback loops are monitored in [monitoring fairness in production](#) (chapter 16), and for agents in [memory and context governance](#) (chapter 23); Art. 16(1) has [accessible explanations](#).
- Art. 17(1)(m) : the accountability framework is a [lifecycle RACI](#) (chapter 12); Art. 43(4) is [substantial modification](#) in chapter 14; Arts. 22 to 24 are [the EU operator roles](#) in chapter 18.
- Art. 26(2) to 26(11) : the deployer's paragraphs run through chapter 15, from [checking the data and the people](#) to [records retention](#) and [external communications](#); chapter 17 covers [informing the provider and suspending use](#) (Art. 26(5)) and [freezing before fixing](#) (Art. 73(6)), and chapter 23 [approval design for agent checkpoints](#).
- Art. 52 : the compute ledger and the two-week notification are in [systemic risk: threshold, notification, designation](#) (chapter 18); Art. 53(1)(c) is [copyright and training data](#) (chapter 20).
- Art. 86 : the explanation record is specified in [the EU AI Act, Articles 13 and 86](#) (chapter 16) and [explanation and notice to affected people](#) (chapter 18); Art. 87 is met by a [channel for raising concerns](#) (chapter 12).

The Omnibus also changed rows the table compresses to one line [22]. For Art. 6, a **safety component** must now have the purpose of preventing or mitigating risks to health and safety, or be one whose failure endangers them (Art. 3(14), Art. 6(1a) to 6(1c)); that narrowing applies to the Annex I route from 2 August 2028, and machinery moved from Section A to Section B of Annex I. The Annex VIII, Section B registration record for systems that rely on the Art. 6(3) filter lost the summary of grounds and the list of Member States. For Art. 25, the initial provider's duty to cooperate now names documentation sufficient to assess compliance, known limitations and failure modes, and targeted technical access for testing (Art. 25(2)); the information and access must be fixed in a written agreement (Art. 25(4)), and breaches of both paragraphs are fined under Art. 99(4)(da) .

The Article 73 clock runs by incident class. The provider notifies the market-surveillance authority of the Member State where the incident occurred immediately once it establishes a causal link between the system and the incident, or the reasonable likelihood of one, and in any event within an outer deadline that runs from the moment the provider or, where applicable, the deployer **becomes aware** of the incident, not from the causal finding [57]. A deployer that identifies a serious incident informs the provider first, then the importer or distributor and the market-surveillance authority; if it cannot reach the provider, Article 73 applies to the deployer mutatis mutandis (Art. 26(5)) [57]:

Incident class	Reporting deadline	Who reports	Artefact
Serious incident (general)	Immediately on a causal link or its reasonable likelihood; no later than 15 days after awareness	Provider → national MSA; the deployer if it cannot reach the provider (Art. 26(5))	Incident triage pipeline; reporting-clock automation
Widespread infringement, or serious and irreversible disruption of critical infrastructure	Immediately; no later than 2 days after awareness	Provider → national MSA; the deployer if it cannot reach the provider (Art. 26(5))	Same pipeline, escalated-severity path
Death of a person	Immediately on establishing or suspecting a causal link; no later than 10 days after awareness	Provider → national MSA; the deployer if it cannot reach the provider (Art. 26(5))	Same pipeline, priority path

The Omnibus left these deadlines unchanged. For high-risk systems under the AI Office's exclusive competence, its new Art. 75(1a) sends the report to the AI Office instead, with Art. 73(2) to (9) applying mutatis mutandis, and the AI Office passes it on to the market-surveillance authority of the Member State where the provider is established [22]. An incident rarely starts only one clock: chapter 17 lays the Article 73 clock beside the GDPR, NIS2, DORA, CRA and GPAI clocks in [the overlapping clocks](#), and the [incident record schema](#) holds the timestamps each one needs.

Two cross-cutting provisions frame the penalties. Under [Art. 101](#), the Commission may fine GPAI providers up to 3% of worldwide annual turnover or EUR 15 million, whichever is higher [3][4]. Under the Omnibus's new [Art. 75a – 75d](#), the AI Office gains investigation powers, binding commitments and non-compliance decisions over the AI systems for which the amended [Art. 75\(1\)](#) makes it exclusively competent (systems built on a GPAI model by the same provider or undertaking, and systems in designated very large online platforms or search engines), not over GPAI models in general. Periodic penalty payments reach up to 5% of average daily income or worldwide annual turnover per day for a continuing breach ([Art. 75c\(5\)](#)). The Omnibus entered into force on 27 July 2026, and Chapter IX, where these articles sit, applies from 2 August 2026 under [Art. 113](#) [8][22]. High-risk administrative fines run under [Art. 99](#) (ceilings of 7%, 3% and 1% of turnover depending on the breach), imposed by national authorities [4]. Chapter 18 sets out [who supervises what](#) and [the AI Office's direct powers](#).

GPAI Code of Practice

The GPAI Code of Practice, published 10 July 2025, is the voluntary instrument providers use to demonstrate compliance with the GPAI obligations until harmonised standards exist. It has three chapters [9][10].

Chapter	What it asks for	Engineering artefact	Layer
Safety and Security (systemic-risk models only)	A Safety and Security Framework; model evaluations incl. adversarial testing; systemic-risk assessment and mitigation; serious-incident reporting; model and infrastructure security	Eval and red-team suite; adversarial testing harness; incident pipeline; weight-security controls	3 · 4 · 5
Transparency	Up-to-date model documentation for the AI Office and downstream deployers	Model cards; structured model documentation; AIBOM	2
Copyright	A policy to comply with Union copyright law, incl. respecting reservations of rights	Training-data provenance and licence records; policy-as-code for source filtering	1 · 2
Safety and Security, Commitment 9 (serious-incident reporting)	Report serious incidents to the AI Office within 2, 5, 10 or 15 days by incident class, with intermediate reports at least every four weeks while unresolved and a final report within 60 days of resolution; keep the records at least five years [65]	Incident pipeline on the Commission template fields; per-class clocks; five-year retention policy; downstream reporting channel	4 · 5
Safety and Security, Appendix 1.3 and 1.4 (autonomy, tool use, loss of control)	Sources of systemic risk to consider include the capability to operate autonomously, propensities such as colluding with other AI systems, and affordances such as access to tools and physical systems and the level of human oversight; loss of control is a specified systemic risk [65]	Provider evaluations of autonomy and tool use, requested at the vendor due-diligence gate and filed with the agent registry entry	3 · 5

The Code is voluntary; signing it is one route to demonstrating compliance, not a legal presumption of conformity [9]. Signatory status is dynamic and counted per the Commission's official list [10].

For serious-incident reporting specifically, the Commission published a reporting template on 4 November 2025 for serious incidents involving GPAI models with systemic risk. It aligns to the Article 55 reporting duty and to Commitment 9 of the Code's Safety and Security chapter, and is the concrete artefact the incident pipeline emits, the same template named in the Article 55 row above [26]. One internal [incident record](#) can feed this template and every other regime's report. Commitment 9 of the Safety and Security chapter sets the clocks (2, 5, 10 or 15 days by incident class, intermediate reports at least every four weeks, a final report within 60 days of resolution) and a retention of at least five years, and its Appendix 1 lists the capability to operate autonomously and access to tools among the sources of systemic risk and loss of control among the specified risks, which is why the two rows above matter to anyone who deploys agents on a GPAI model [65]. Chapter 17 sets Commitment 9 beside the other regimes in [the overlapping clocks](#), and chapter 23 reads Appendix 1 for agents in [EU AI Act hooks for agents](#).

Data protection and other EU law

An AI system placed on the EU market meets more law than the AI Act on day one. The rows below index the obligations the v0.5.0 chapters teach: the GDPR, the cyber-security and incident-reporting regimes, and the liability, copyright, consumer and sector law that already reaches AI. They answer to their own supervisors (data protection authorities, CSIRTs and financial supervisors, courts and consumer authorities), not to the AI Act's market-surveillance authorities, and several apply through national transposition, so the "Applies" column says so. Mappings are illustrative, not a claim of conformity.

The GDPR

The GDPR has applied since 25 May 2018 [66]. Chapter 19 walks every row below, with the EDPB's anonymity test for trained models [67], in [privacy and data protection law applied to AI](#); chapter 16 builds the explanation and contest records of [Arts. 15\(1\)\(h\)](#) and [22](#) in [data protection: the GDPR and the UK regime](#).

Article	What it asks for	Engineering artefact	Layer	Who is bound	Applies
Art. 5(1)(b) and 6(4)	Personal data are collected for specified, explicit and legitimate purposes and not further processed incompatibly; Art. 6(4) sets the compatibility test for reuse, such as training on data collected for another purpose [66]	Purpose tags on datasets; purpose-match policy in training and indexing pipelines; compatibility assessment record	1 · 2	Controller	2018-05-25
Art. 6	A lawful basis for each processing operation, assessed separately for training, fine-tuning, retrieval and inference [66][67]	Basis registry per dataset and stage; versioned legitimate-interest assessment	2	Controller	2018-05-25
Art. 7	Where consent is the basis, the controller can demonstrate it, and withdrawing consent is as easy as giving it [66]	Consent-purpose log joined to datasets and model versions; withdrawal propagated to the pipelines	2 · 5	Controller	2018-05-25
Art. 9	Processing special-category data, incl. biometric data for unique identification, is prohibited unless an Art. 9(2) condition applies, which reaches sensitive data a model infers [66]	Proxy test in CI; inference policy with a runtime output classifier; Art. 9(2) condition record	1 · 3 · 4	Controller	2018-05-25
Arts. 13–14	Inform data subjects of purposes, bases, recipients and retention and, for automated decision-making, give meaningful information about the logic involved (Arts. 13(2)(f), 14(2)(g)) [66]	Notice generated from the registry entry; model card; automated-decision notice per system	2	Controller	2018-05-25
Art. 15(1)(h)	On request, confirm automated decision-making and give meaningful information about the logic involved and its significance and envisaged consequences [66]	Per-request explanation generated from the decision record; system-level automated-decision notice	4 · 5	Controller	2018-05-25
Arts. 15–17 and 21	Access, rectification, erasure and objection requests reach every place the data lives: corpus, snapshots, retrieval index, logs and, where it holds personal data, the model [66]	Request workflow across corpus, snapshots, retrieval index, logs and weights; fulfilment record	4 · 5	Controller	2018-05-25
Art. 22	A right not to be subject to a decision based solely on automated processing with legal or similarly significant effects, except on contract, law or explicit consent; then human intervention, the right to express a view and to contest (Art. 22(3)) [66]	Decision record with reason codes; contest channel and human review log; appeal outcomes by group	4 · 5	Controller	2018-05-25
Art. 5(1)(c) and 25	Adequate, relevant and limited data, with technical and organisational measures built in at design and set by default [66]	Feature justification record; PII and special-category filters; retention as code	1 · 3	Controller	2018-05-25
Art. 5(2)	A controller that claims a trained model holds no personal data must be able to demonstrate it; the EDPB sets an anonymity test and the evidence it expects [66] [67]	Anonymity evidence pack; membership-inference and extraction evals in the eval gate	3 · 5	Controller (model developer)	2018-05-25
Art. 28	Use only processors with sufficient guarantees, under a contract that fixes instructions, sub-processors, security, assistance and deletion [66]	AI vendor clause checklist in the due-diligence gate (no training, retention, region, sub-processors, change notice)	2 · 5	Controller; processor	2018-05-25
Art. 30	Controllers and processors keep a record of the processing activities under their responsibility [66]	Records generated per processing moment from the registry and data cards	2 · 5	Controller; processor	2018-05-25
Arts. 33–34	Notify the supervisory authority without undue delay and, where feasible, within 72 hours of awareness; tell data subjects without undue delay when the breach is likely to result in a high risk [66]	Personal-data-breach branch of the incident pipeline with its own 72-hour timer; data-subject notice template	4 · 5	Controller (the processor notifies the controller)	2018-05-25
Arts. 35–36	Assess the impact before processing likely to result in a high risk, and consult the supervisory authority where the residual risk stays high [66]	AI DPIA template with AI-specific fields, cross-referenced by the FRIA; recorded decision when no DPIA is needed	1 · 2	Controller	2018-05-25
Arts. 44–49	Transfers outside the EEA only on an adequacy decision, appropriate safeguards (such as standard contractual clauses or binding corporate rules) or a narrow derogation; sending personal data to a model hosted outside the EEA can be a transfer [66]	Transfer register; residency and routing policy as code; transfer impact assessment	1 · 4 · 5	Controller; processor	2018-05-25

Cyber-security and incident-reporting law

NIS2 binds essential and important entities through national law, which Member States apply from 18 October 2024 [68]; DORA has applied to financial entities since 17 January 2025 [69], with the incident time limits fixed in Delegated Regulation (EU) 2025/301 [70]; and the Cyber Resilience Act's reporting duty applies from 11 September 2026, ahead of the rest of that Regulation on 11 December 2027 [71]. An AI incident can start several of these clocks at once: chapter 17 lays them side by side in [the overlapping clocks](#), and chapter 15 covers [continuity when the provider fails](#).

Article	What it asks for	Engineering artefact	Layer	Who is bound	Applies
NIS2 Art. 21(2) (c)–(d)	Risk-management measures include business continuity (backup, disaster recovery, crisis management) and supply-chain security with direct suppliers and service providers, which covers AI and model services [68]	Continuity plan for AI dependencies with tested fallbacks; supplier assessments for model and platform providers	4 · 5	Essential and important entities	2024-10-18, through national law
NIS2 Art. 23	An early warning within 24 hours of becoming aware of a significant incident, an incident notification within 72 hours and a final report within one month of the notification, incl. the root cause [68]	Per-regime clock on the incident record; significance determination with an owner; cause coding reused in the final report	5	Essential and important entities	2024-10-18, through national law
DORA Art. 19	Report major ICT-related incidents: initial notification within 4 hours of classification as major and no later than 24 hours from awareness (within 4 hours of a classification made after those 24 hours), intermediate report within 72 hours of the initial notification, final report within one month of the latest intermediate report [69][70]	Classification record with a timestamp; per-regime clock; consistent cause coding for recurring-incident aggregation	5	Financial entities	2025-01-17
DORA Art. 28(3) , 28(8)	Keep a register of information on all contractual arrangements for ICT services from third-party providers, and exit strategies for ICT services that support critical or important functions [69]	Register entries for AI and model services; exit plan and exit-drill record	2 · 5	Financial entities	2025-01-17
CRA Art. 14	Notify actively exploited vulnerabilities and severe incidents through the single reporting platform: early warning within 24 hours, notification within 72 hours, final report 14 days after a fix is available (vulnerability) or one month after the notification (incident) [71]	Vulnerability and incident clocks on the incident record; submission through the single reporting platform	4 · 5	Manufacturers of products with digital elements	2026-09-11; the rest from 2027-12-11

Liability, copyright, consumer and sector law

The revised Product Liability Directive treats software, AI systems included, as a product and applies to products placed on the market after 9 December 2026 [72]. The text-and-data-mining exception of the DSM Directive yields to a rightholder's reservation [73], which is the rule [Art. 53\(1\)\(c\)](#) of the AI Act points to. The Digital Services Act, the Unfair Commercial Practices Directive, the Platform Work Directive and the revised Consumer Credit Directive add duties for platforms, traders, digital labour platforms and creditors [74][75][76][77]. Chapter 20 teaches them: [copyright and training data](#), [the EU Product Liability Directive](#), [duty to warn after updates](#), [the EU: UCPD, DSA and the AI Act](#), [employment](#) and [credit and lending](#).

Article	What it asks for	Engineering artefact	Layer	Who is bound	Applies
PLD Art. 4(1)	Software is a product, so the manufacturer of an AI system is strictly liable for damage caused by a defect in a product placed on the market or put into service after 2026-12-09 [72]	Defect-liability review at design; contractual recourse; residual risk in the register	1 · 5	Manufacturers and other economic operators	Products placed on the market after 2026-12-09
PLD Arts. 9–10	A court can order the defendant to disclose relevant evidence at its disposal; failing to disclose it is one of the conditions under which the product is presumed defective [72]	Defence file per release: AIBOM with hashes, eval history, failure-mode analysis, signed logs, instructions for use, kept for the liability period	2 · 3 · 5	Manufacturers, incl. providers of AI systems and substantial modifiers	Products placed on the market after 2026-12-09
PLD Art. 11(2)	The manufacturer cannot rely on the defect arising after placing on the market where it is due to software, incl. its updates or upgrades, or to missing safety updates, that remain within its control [72]	Change log; regression evals per release; patch decision records; versioned warnings	3 · 4 · 5	Manufacturers	Products placed on the market after 2026-12-09

Article	What it asks for	Engineering artefact	Layer	Who is bound	Applies
DSM Directive Art. 4(3)	The general text-and-data-mining exception applies only where rightholders have not expressly reserved use in an appropriate manner, such as machine-readable means for content made publicly available online [73]	Crawler policy-as-code honouring reservations; training-data rights ledger with the reservation-check result, method and date	1 · 2	Anyone mining works, incl. model developers	Transposition deadline 2021-06-07
DSA Art. 25	Online platforms do not design, organise or operate their interfaces in a way that deceives or manipulates users or impairs their free and informed decisions [74]	Interface review record; red-team eval for manipulative outputs	3 · 5	Providers of online platforms	2024-02-17
DSA Art. 27	Online platforms set out in their terms the main parameters of their recommender systems and any options users have to modify them [74]	Recommender parameter card generated from the ranking configuration; log of the options offered to users	2 · 4	Providers of online platforms	2024-02-17
UCPD Arts. 5–7, Annex I	No commercial practice contrary to professional diligence, or misleading, that distorts the average consumer's decisions, incl. AI-generated claims and chatbot answers; stating that reviews are genuine without reasonable checks, and false reviews, are blacklisted (Annex I points 23b and 23c) [75]	Claims register linked to eval results; review-provenance checks; chatbot answer evals on product claims	1 · 3 · 4	Traders dealing with consumers	2007-12-12; review points since Directive (EU) 2019/2161
Platform Work Directive Arts. 7, 9–11	Limits on the personal data platforms may process through automated systems, transparency about those systems, human oversight with an impact evaluation at least every two years, and explanation and human review of decisions [76]	Registry of automated systems with their main parameters; data-category deny list; two-yearly impact evaluation; explanation and human review log	1 · 2 · 3 · 5	Digital labour platforms	Transposition by 2026-12-02
CCD2 Art. 18(8)	Where the creditworthiness assessment involves automated processing, the consumer may request human intervention, a clear explanation of the assessment and its logic, and a review of the decision [77]	Explanation artefact per model version; review path and log	3 · 4 · 5	Creditors	2026-11-20

ISO/IEC 42001, 42005 and 42006

ISO/IEC 42001:2023 is the AI management-system (AIMS) standard; its Annex A groups control objectives into nine areas (A.2 – A.10). It is a management-system standard, not the Article 17 QMS, and its European adoption (EN ISO/IEC 42001:2026) confers no presumption of conformity [11][12].

Annex A area	Focus	Engineering artefact	Layer
A.2 Policies related to AI	AI policy set and its governance	Policy-as-code library; versioned policy repository	1
A.3 Internal organization	Roles, responsibilities, reporting	Operating model; RACI; ownership in the registry	1 · 2
A.4 Resources for AI systems	Data, tooling, compute, human resources documented	Resource inventory; AIBOM; environment manifests	2
A.5 Assessing impacts of AI systems	Impact assessment process	Impact assessment as code; FRIA/DPIA linkage (ISO/IEC 42005)	1 · 3
A.6 AI system life cycle	Responsible design, development, deployment	Pipeline controls; eval gates; change management	1 · 3 · 4
A.7 Data for AI systems	Data quality, provenance, preparation	Data cards; lineage; data quality tests	2 · 3
A.8 Information for interested parties	Transparency and reporting to stakeholders	Model/data cards; machine-readable disclosures	2
A.9 Use of AI systems	Responsible-use controls and monitoring	Runtime guardrails; usage telemetry	4
A.10 Third-party and customer relationships	Managing supplier and customer responsibilities	Supplier AIBOM; contractual and technical control mapping	2 · 5

ISO/IEC 42005:2025 provides guidance for AI system impact assessment and is the natural companion to Article 27 (FRIA) and Annex A.5 [13]. The operating model and RACI of the [A.3](#) row are built in a [lifecycle RACI](#) (chapter 12), and chapter 22 places these standards in [the ISO/IEC family](#) as a whole.

Two further ISO/IEC standards sit alongside the AIMS. **ISO/IEC 42006:2025** sets the requirements for the bodies that audit and certify AI management systems: building on ISO/IEC 17021-1, it is the answer to "who may credibly certify you to 42001", since it fixes the competence and consistency a certification body must show. **ISO/IEC 23894:2023** gives guidance on AI risk management, adapting ISO 31000 to AI; it is the risk-process companion to Article 9 and to the NIST AI RMF [27][28]. The table also carries ISO/IEC 42005:2025, the impact-assessment guidance [13], and **ISO/IEC 22989:2022**, the concepts and terminology standard whose AI stakeholder roles and life-cycle vocabulary a registry can reuse field for field [78].

Standard	What it is	Engineering artefact	Layer
ISO/IEC 42006:2025	Requirements for bodies auditing and certifying AI management systems (who may credibly certify you to 42001)	Accredited certification scope; auditor-competence evidence; certificate register	5
ISO/IEC 23894:2023	Guidance on AI risk management (companion to ISO 31000)	Risk register as code; AI risk taxonomy; linkage to EU AI Act Art. 9 and the NIST AI RMF	1 · 3
ISO/IEC 42005:2025	Guidance for assessing the impacts of an AI system on individuals, groups and society across its life cycle (companion to Art. 27 and Annex A.5) [13]	Impact assessment as code from a template; FRIA and DPIA cross-references; re-assessment triggers	1 · 3
ISO/IEC 22989:2022	A shared vocabulary for AI concepts, the AI system life cycle and AI stakeholder roles [78]	Registry field names and role vocabulary aligned to the standard's terms; glossary cross-references	2

Maps to: these controls are realised through layers 1, 2, 3 and 5 of the stack; the impact-assessment control (A.5 / ISO 42005) supports EU AI Act Art. 27. Mappings are illustrative, not a claim of conformity.

NIST AI RMF

The NIST AI Risk Management Framework 1.0 (January 2023; there is no 2.0) organises risk work into four functions. It is voluntary and US-origin, and it maps cleanly onto the five-layer stack [14]. As of 2026-09-24, NIST's framework page states that AI RMF 1.0 "is being revised as part of the White House AI Action Plan"; no revised text had been published, so 1.0 remains the version to cite and to pin in control metadata [59]. Chapter 22 covers [the NIST AI RMF in depth](#): the seven trustworthy characteristics, the 19 categories of the Core, the Playbook and the profiles.

Function	What it asks for	Engineering artefact	Layer
GOVERN	A culture and structure for managing AI risk	Policy-as-code; operating model; registry ownership	1 · 2
MAP	Context and risk framing for each AI system	Threat models; use-case and impact mapping; data/model cards	2 · 3
MEASURE	Analyse, benchmark and monitor risk	Eval gates; adversarial red-team suite; metrics per failure mode	3
MANAGE	Prioritise, respond and recover	Runtime guardrails; incident pipeline; continuous assurance	4 · 5

Newer NIST AI work

Beyond the RMF, three newer NIST efforts bear on the stack. Two are still in draft, and the copy says so. The **AI Agent Standards Initiative**, launched by NIST's Center for AI Standards and Innovation (CAISI) on 17 February 2026, targets interoperable, secure standards for AI agents: identity, authentication, authorisation and agent security [29]. The draft **IR 8596 Cyber AI Profile** (initial preliminary draft, 16 December 2025; comments closed 30 January 2026, and still the current version as of 2026-09-24) is a Cybersecurity Framework (CSF 2.0) profile for AI, organised around Secure, Defend and Thwart [30]. The draft **AI 800-1** (Managing Misuse Risk for Dual-Use Foundation Models; second public draft, January 2025; no final version published as of 2026-09-24) is voluntary guidance for identifying, measuring and mitigating misuse risk across the AI lifecycle [31]. The older **Generative AI Profile**, NIST AI 600-1 (26 July 2024), is the RMF's companion for generative AI: 12 risks and suggested actions coded to the four functions, and the table carries it too [79].

NIST item	What it is	Engineering artefact	Layer
AI Agent Standards Initiative (2026)	CAISI initiative on interoperable, secure AI agents: identity, authentication, agent security	Agent registry; non-human-identity controls; agent authentication and authorisation; adversarial agent evals	3 · 4
IR 8596 Cyber AI Profile (draft)	CSF 2.0 profile for AI (Secure / Defend / Thwart)	AI-system security controls; runtime observability; threat detection mapped to CSF 2.0	3 · 4
AI 800-1 (draft)	Managing Misuse Risk for Dual-Use Foundation Models (voluntary guidance)	Misuse red-team suite; capability and dangerous-capability evals; safety framework	3

NIST item	What it is	Engineering artefact	Layer
AI 600-1 Generative AI Profile (2024)	Suggested actions for 12 risks that generative AI creates or exacerbates, coded to the Govern, Map, Measure and Manage functions [79]	Generative-AI eval suites named after the profile's action ids (e.g. confabulation, information integrity); a risk-register entry per profile risk	1 · 3

CSA AICM and STAR for AI

The Cloud Security Alliance's AI Controls Matrix (AICM) v1.1, published 22 June 2026, defines 247 control objectives across 18 domains, and the STAR for AI programme provides the assurance scheme around it, in three levels: a Level 1 self-assessment, a Level 1 "Valid-AI-ted" automated validation, and a Level 2 that adds ISO/IEC 42001 certification [15][83].

CSA artefact	What it is	Engineering artefact	Layer
AICM v1.1	247 control objectives across 18 domains, spanning governance, data, model and runtime	Control catalogue mapped to policy-as-code and evals; crosswalk to ISO 42001 / NIST AI RMF	1 · 3 · 5
STAR for AI	Assurance and certification programme on the AICM: Level 1 self-assessment, Level 1 Valid-AI-ted (automated validation) and Level 2 (ISO/IEC 42001 certification plus the validated assessment) [83]	Machine-readable evidence submission; continuous assurance telemetry	5
Agent controls (AICM v1.1, ATF, AARM)	Agent-specific AICM controls (e.g. IAM-18 Agent Access Restriction, AIS-11 Agents Security Boundaries), with the Agentic Trust Framework v1 (earned autonomy tiers) and the AARM runtime-interception specification [80][81][82]	Agent-specific control definitions; policy-as-code for agent scope and tools; runtime guardrails	1 · 4
Catastrophic Risk Annex	Enhanced AICM controls for high-autonomy systems with catastrophic-risk potential	Enhanced controls for high-autonomy systems; kill switch and oversight controls; pilot-audit evidence	4 · 5

Two lines of work push the AICM toward agents and frontier risk. For agents, the controls sit inside the matrix itself (for example IAM-18 Agent Access Restriction and AIS-11 Agents Security Boundaries) [80], and the CSA's agentic control-plane programme adds two published specifications, the **Agentic Trust Framework** (zero trust for agents with earned autonomy tiers) and **AARM** (interception of agent actions before they execute) [32][81][82]. Earlier editions of this map listed a proposed "Agentic Control Supplement" to the AICM; it could not be matched to a CSA primary document as of 2026-09-24, so the row now names what is published (verify). For frontier risk, the **Catastrophic Risk Annex** adds a set of enhanced controls for high-autonomy systems, meant to be proven through pilot audits rather than asserted [33].

OWASP GenAI Security Project

OWASP's GenAI Security Project supplies the threat vocabulary the controls are built against, plus two formats (the Agent Control Standard and an AIBOM) that the stack consumes directly [16][17][54]. Chapter 23 maps each agentic entry to its controls in [threats mapped to controls](#).

OWASP artefact	What it is	Engineering artefact	Layer
Top 10 for Agentic Applications 2026	Agent threat catalogue (ASI01 Agent Goal Hijack ... ASI10 Rogue Agents)	Agent threat model; adversarial evals; runtime guardrails; kill switch	3 · 4
Top 10 for LLM Applications 2026	LLM threat catalogue (incl. Excessive Agency at #3)	Prompt-injection and output-handling controls; eval gate	3 · 4
Agent Control Standard (ACS)	A standard for expressing agent controls	Machine-readable control definitions for agents	1 · 4
AIBOM	AI bill-of-materials format and generator	AIBOM at build (Cyc1oneDX ML-BOM , SPDX 3.0 AI)	2

US federal and state laws

The United States has no horizontal federal AI statute; the binding AI-specific rules are state laws, and they differ in scope. Two bind only frontier developers, with the heaviest duties on the large ones; the rest reach ordinary developers, deployers and operators, and federal law that predates AI (fair lending, credit reporting, employment discrimination, the FTC Act) already reaches AI decisions. The tables below carry them all as rows. Chapter 21 teaches them: [the federal layer](#) (executive orders, the OMB memoranda that bind agencies and their vendors, and the federal push against state AI laws) and the [state laws that bind private organisations](#), each with its scope, dates, duties and enforcement.

Frontier-developer laws

Two US state laws bind only frontier developers, with the heaviest duties on the large ones, not general deployers: a narrower scope than the EU AI Act's risk-tiering. They ask large frontier developers to publish safety frameworks and every frontier developer to report critical safety incidents to the state [18][19][25]. California's whistleblower protection is met in practice by [a channel for raising concerns](#) (chapter 12).

Law	Scope	Obligation	Engineering artefact	Layer
California SB 53 (TFAIA), in force 2026-01-01	Frontier developers (models trained above $\sim 10^{26}$ FLOP); the framework duty binds large frontier developers (developer revenue over USD 500M)	Publish a frontier AI framework; report critical safety incidents to the Office of Emergency Services within 15 days; whistleblower protection; up to USD 1M per violation, AG-enforced [56]	Published safety framework; incident pipeline reporting to the state; transparency artefacts	5 · 4
California SB 53 whistleblower protections (Labor Code 1107–1107.2), in force 2026-01-01	Frontier developers; the anonymous process binds large frontier developers	No rule, policy or contract that prevents covered employees from disclosing catastrophic-risk concerns, and no retaliation; notice of rights; large frontier developers run an anonymous internal process with monthly updates to the reporter, shared with officers and directors at least quarterly [56]	Anonymous internal reporting channel with status updates; notice acknowledgment records; quarterly summary to officers and directors	1 · 5
New York RAISE Act (S6953B), signed 2025-12-19	Frontier developers (models trained above 10^{26} operations) report incidents within 72 hours; the framework duty binds large frontier developers (annual revenue over USD 500M); thresholds of the chapter amendment signed 2026-03-27	Publish a frontier AI safety and security framework; disclose safety incidents within 72 hours. A chapter amendment signed 2026-03-27 sets the effective date at 2027-01-01 and creates an oversight office within the New York Department of Financial Services (DFS) [19][24][25]	Published frontier AI safety framework; 72-hour incident and disclosure pipeline reporting to the DFS oversight office	5 · 4

Other state AI laws

These state laws reach beyond frontier developers to ordinary developers, deployers and operators: Texas and Colorado; California's training-data, provenance and companion-chatbot laws; New York's companion rules; Illinois; New York City's Local Law 144; and Utah [55][84][85][86][88][89][90][91]. Chapter 21 sets each one out with its enforcement in its [table of state laws](#), and compares the hiring rules in [one hiring tool, four regimes](#).

Law	Scope	Obligation	Engineering artefact	Layer
Texas TRAIGA (HB 149), in force 2026-01-01	Developers and deployers doing business in Texas	Intent-based prohibitions on developing or deploying AI (behaviour manipulation, unlawful discrimination); social scoring banned for governmental entities; AI-use disclosure by government agencies and health care providers; a regulatory sandbox; Attorney-General enforcement; local AI rules preempted [35]	Prohibited-use policy-as-code; AI-use disclosure controls; complaint and incident handling	1 · 4
Colorado SB 26-189 (automated decision-making technology), effective 2027-01-01, replacing SB 24-205	Developers and deployers of ADMT in consequential decisions	Developer documentation to deployers and notice of material updates; deployer notice of ADMT use; a plain-language explanation within 30 days of an adverse outcome; correction, human review and reconsideration; records kept at least three years. SB 26-189 (signed 2026-05-14) repealed and re-enacted SB 24-205, whose duty of care against algorithmic discrimination had been delayed to 2026-06-30 and whose enforcement a federal court had blocked [36][55]	ADMT inventory; developer documentation pack; notice and adverse-outcome explanation templates; human-review queue; three-year record store	2 · 4 · 5
California AB 2013 (training-data transparency), due 2026-01-01	Developers of generative AI systems released since 2022-01-01	Developers post a summary of the datasets used to train a generative AI system made available to Californians (sources, size, data types, IP and personal information, synthetic data) on or before 2026-01-01 and on each substantial modification [84]	Data card per dataset, published at release; training-data rights ledger	2
California AI Transparency Act (SB 942 as amended by AB 853), operative 2026-08-02	Covered providers of public generative AI systems; large online platforms; capture-device makers	Covered providers offer a free AI-detection tool and embed latent disclosures, with an optional manifest disclosure, in generated image, video and audio; large online platforms and capture devices follow later [85]	Provenance pipeline writing latent metadata; public detection endpoint; platform-side provenance display	3 · 4

Law	Scope	Obligation	Engineering artefact	Layer
California SB 243 (companion chatbots), chaptered 2025-10-13	Operators of companion chatbots	Disclose AI where a reasonable person could be misled; for known minors, remind at least every three hours and prevent sexually explicit content; run a suicide and self-harm protocol with crisis referral; annual reports from 2027-07-01 [86]	Companion-mode policy; reminder timer; crisis-referral classifier and log; annual report	1 · 4 · 5
New York GBL Article 47 (AI companion models), in force 2025-11-05 (verify)	Operators of AI companions	Detect suicidal ideation and self-harm and refer users to crisis services; tell users they are not talking to a human at the start and at least every three hours [88]	Crisis-referral classifier and log; notice timer	4 · 5
Illinois HB 3773 (Human Rights Act amendment), effective 2026-01-01	Employers	Employers may not use AI with a discriminatory effect on protected classes in recruitment, hiring, promotion, discipline or other terms of employment, nor ZIP codes as a proxy, and must notify employees and applicants [89][118]	AI-in-HR inventory; adverse-impact eval per protected class; notice record	2 · 3 · 4
NYC Local Law 144 (automated employment decision tools), enforced since 2023-07-05	Employers and employment agencies using AEDTs for New York City roles	An independent bias audit within one year before use, a published summary of the results, and notice to candidates and employees 10 business days before use [90]	Impact-ratio eval by sex, race/ethnicity and intersectional category; published audit summary; notice record	3 · 5
Utah AI disclosure law (SB 226), effective 2025-05-07	Suppliers using generative AI in consumer transactions; regulated occupations	Disclose generative AI when a person clearly and unambiguously asks; regulated occupations disclose it prominently in a high-risk AI interaction; clear disclosure at the outset is a safe harbour [91]	Disclosure component with an interaction-risk flag; conversation log showing the disclosure	4

State privacy and sector laws

State privacy statutes reach AI through profiling opt-outs, assessments, consent and review rights, and one sector law reaches insurers' models. Chapter 19 compares them in [the United States](#) and chapter 20 covers [housing, insurance and public services](#).

Law	Scope	Obligation	Engineering artefact	Layer
California CPPA regulations (ADMT), duties from 2027-01-01	Businesses subject to the CCPA	Businesses using ADMT for significant decisions give a pre-use notice, an opt-out or a human appeal, and access to information about the ADMT [87]	ADMT register; pre-use notice; opt-out or appeal workflow; ADMT access response	2 · 4 · 5
California CPPA regulations (risk assessments), effective 2026-01-01	Businesses subject to the CCPA	A risk assessment before processing that presents significant risk, incl. using ADMT for significant decisions; attestations and summaries submitted to the Agency [87]	Risk assessment per triggering activity; submission record	5
Virginia CDPA (§ 59.1-580), from 2023-01-01	Controllers	Controllers document data protection assessments for targeted advertising, sale, profiling that presents a reasonably foreseeable risk, and sensitive data, for processing created after 2023-01-01, and give them to the Attorney General on request [93]	Assessment template per processing activity; profiling register	1 · 5
Colorado Privacy Act (SB21-190), effective 2023-07-01	Controllers	Consumers may opt out of profiling in furtherance of decisions with legal or similarly significant effects, incl. through a universal opt-out mechanism; controllers run data protection assessments for processing that presents a heightened risk [94]	Opt-out flag honoured at inference; assessment template; intake data-class flags	1 · 2 · 4 · 5
Minnesota CDPA (§ 325M.14), effective 2025-07-31	Controllers	A consumer may question the result of profiling, be told the reason, review the personal data used, correct it and have the decision re-evaluated [95]	Reason-and-review workflow with re-evaluation on corrected data	4 · 5
Illinois BIPA (740 ILCS 14), in force 2008-10-03	Private entities	Informed written consent before collecting biometric identifiers, a retention and destruction schedule, and secure storage; a private right of action with statutory damages [96][119]	Written-consent capture; retention schedule as code; destruction log	1 · 2
Washington My Health My Data Act (RCW 19.373), from 2024-03-31	Regulated entities	Consent to collect and separate consent to share consumer health data, incl. data derived or extrapolated by algorithms or machine learning, and a signed authorisation for any sale [97]	Separate consent records for collection and sharing; signed sale authorisation; intake flags for derived health data	1 · 2

Law	Scope	Obligation	Engineering artefact	Layer
Colorado SB21-169 (insurers), effective 2021-09-07	Insurers	Insurers may not unfairly discriminate through external consumer data, algorithms or predictive models; they keep a risk-management framework, test for unfair discrimination and file a chief-risk-officer attestation under rules adopted per line of insurance [92]	Inventory of external data sources and models; disparity testing; chief-risk-officer attestation record	2 · 3 · 5

Federal law that already reaches AI

Federal agencies are bound by OMB memoranda [98][99]. For private organisations the federal rules that reach AI are older, technology-neutral law: adverse-action notices in lending and credit reporting, disparate impact in employment, the FTC Act's ban on deceptive practices, and the TAKE IT DOWN Act's removal duty [100][101][102][103][104][105][106]. Chapter 21 covers [the federal layer](#); chapter 16 builds the reason codes of [credit adverse-action notices](#) and the [four-fifths rule](#); chapter 20 covers [claims substantiation](#) and [deepfakes and synthetic media](#).

Law	Scope	Obligation	Engineering artefact	Layer
OMB M-25-21 (federal use of AI), issued 2025-04-03	US federal agencies (their AI vendors by contract)	Federal agencies apply minimum practices to high-impact AI: pre-deployment testing, an AI impact assessment, ongoing monitoring, operator training, human oversight with a fail-safe where practicable, remedies or appeals, and consultation of end users, documented within 365 days [98]	Use-case inventory entry; pre-deployment test report; AI impact assessment; monitoring plan; appeal path	2 · 3 · 4 · 5
OMB M-26-04 (LLM procurement), issued 2025-12-11	US federal agencies and LLM vendors	Solicitations for large language models request, as a minimum, the vendor's acceptable use policy, model, system or data cards, end-user resources and a feedback mechanism [99]	Acceptable use policy; model, system or data cards; end-user resources; feedback channel	2 · 5
EOCA Regulation B (12 CFR 1002.9)	Creditors	A creditor that takes adverse action gives a statement of specific principal reasons, or the right to one within 30 days; citing internal standards or a failed score is insufficient, whatever model made the decision [100]	Reason-code service versioned with the model; reason-code fidelity eval; notice template	3 · 4 · 5
FCRA (15 U.S.C. 1681m(a))	Users of consumer reports	A user of a consumer report that takes adverse action gives notice, discloses the numerical credit score used and its key factors, names the reporting agency and states the right to a free report and to dispute [101]	Score and key-factor record per adverse decision; notice template	4
Title VII s. 703(k) and UGESP (29 CFR 1607.4(D))	Employers	A selection procedure with disparate impact is unlawful unless job-related and consistent with business necessity, and a less discriminatory alternative can still be required; a selection rate under four-fifths of the highest group's rate is generally regarded as evidence of adverse impact [102][103]	Adverse-impact-ratio eval per group with counts and confidence intervals; job-relatedness validation; alternatives search log	3 · 5
FTC Act s. 5 (15 U.S.C. 45)	Businesses making AI claims	Deceptive acts or practices are unlawful: claims about an AI system's accuracy, performance or fairness need competent and reliable evidence before they are made [104][105]	Claims register linked to current eval runs; substantiation gate on release copy	1 · 3 · 5
TAKE IT DOWN Act (Public Law 119-12), process due 2026-05-19	Covered platforms	Covered platforms run a notice-and-removal process and remove reported non-consensual intimate images, incl. AI-generated forgeries, and known identical copies within 48 hours of a valid request [106]	Takedown pipeline with a 48-hour clock, owner and log; matching of identical copies	4 · 5

Other jurisdictions

The map's spine is the EU AI Act, but a governance function working across borders answers to more than one regime. These rows are stamped as of 2026-09-24; where a rule is still moving, the copy says so.

Jurisdiction / instrument	Status (as of 2026-09-24)	What it asks for	Engineering artefact	Layer
South Korea: AI Basic Act	In force 2026-01-22 [34], with its Enforcement Decree [62]; the ministry (MSIT) announced a guidance period of at least one year in which fact-finding and fines are held back except in exceptional cases, while the duties apply [58]; detail in chapter 21	Baseline duties for AI operators, heightened duties for "high-impact" AI in sensitive sectors, and AI-content labelling	Risk register for high-impact AI; AI-use notification; AI-content labelling	1 · 2 · 4

Jurisdiction / instrument	Status (as of 2026-09-24)	What it asks for	Engineering artefact	Layer
Singapore: IMDA Model AI Governance Framework for Generative AI	Voluntary; published May 2024 [39]	Governance dimensions incl. testing, transparency, incident reporting, security and content provenance	Eval suite; model cards; content provenance and watermarking	2 · 3 · 4
ETSI EN 304 223 (Securing AI)	Published (V2.1.1, Dec 2025) [40]	Baseline cyber-security requirements across the AI lifecycle (13 principles over five stages)	AI-system security controls across the lifecycle; supply-chain and AIBOM checks; runtime hardening	4
Singapore: IMDA Model AI Governance Framework for Agentic AI (identity and authorisations)	Voluntary; version 1.5 published 2026-05-20 [107]	Each agent has a unique, accounted-for identity, catalogued and centrally managed; authorisations are scoped, time- or session-bound, non-transferable and bounded by the authorising human	Agent registry with a workload identity per agent; delegated, short-lived credentials never broader than the user	2 · 4
Singapore: IMDA Model AI Governance Framework for Agentic AI (human checkpoints)	Voluntary; version 1.5 published 2026-05-20 [107]	Significant checkpoints for high-stakes, irreversible, outlier and user-defined actions, with approvals that are contextual and digestible and enforced through system-level controls	Checkpoint classes in the tool gateway; approval log; oversight metrics	4 · 5
Canada: Directive on Automated Decision-Making (federal institutions)	In effect since 2019-04-01; modified 2025-06-24 [108]	Complete, approve and publish an algorithmic impact assessment before production; apply the Appendix C requirements for the impact level (notice, explanation, peer review, human intervention); offer recourse and report on effectiveness	Published AIA rendered from a shared impact fact base; notice and explanation templates; peer-review record; recourse path; re-assessment triggers as code	1 · 2 · 5
Brazil: LGPD Art. 20 (review of automated decisions)	In force 2020-09-18 (verify); sanctions from 2021-08-01 [109]	A data subject may request review of decisions taken solely on automated processing that affect their interests, incl. profiling, and the controller gives clear information on the criteria and procedures used	Review workflow; statement of criteria and procedures per system	4 · 5

South Korea, article by article

The AI Basic Act's operator duties sit in Articles 31 to 36, with the mechanics in the Enforcement Decree [34][62]. All of them have applied since 22 January 2026; what MSIT holds back during its guidance period of at least one year is fact-finding and fines, not the duties [58]. Chapter 21 walks each article in [South Korea: the AI Basic Act](#).

Article	Who is bound	What it asks for	Engineering artefact	Layer
Art. 31(1)	AI business operators	Tell users in advance that a product or service runs on high-impact or generative AI, in the product, the terms, the screen or the place of supply (Decree Art. 23(1)); a missing notice is finable (Art. 43) [34][62]	Notice component in UI, terms and contracts; notice inventory per user surface	2 · 4
Art. 31(2)–(3)	Operators providing generative AI	Indicate that outputs are AI-generated, and notify or label realistic synthetic sound, images or video so users can recognise them; a machine-readable mark alone needs at least one text or voice notice (Decree Art. 23(2)–(3)) [34][62]	Provenance pipeline: visible label or machine-readable mark plus at least one text or voice notice	3 · 4
Art. 32	Operators of qualifying high-compute systems	Systems with at least 10^{26} FLOP of cumulative training compute, built with the most advanced technology and posing broad and serious risk (Decree Art. 24), identify, assess and mitigate risks across the lifecycle and report the results to MSIT [34][62]	Lifecycle risk register; safety-incident monitoring; results report to MSIT	3 · 4 · 5
Art. 33	AI business operators	Review in advance whether a system is high-impact AI and optionally ask MSIT to confirm; MSIT replies within 30 days, extendable once (Decree Art. 25) [34][62]	Classification decision record per system: Art. 2(4) area, risk rationale, training-data overview, MSIT reply	1 · 2

Article	Who is bound	What it asks for	Engineering artefact	Layer
Art. 34	Operators of high-impact AI	A risk management plan, an explanation plan, a user-protection plan, human management and supervision, and documents showing the measures; publish the main content and keep the evidence for five years (Decree Art. 27) [34][62]	Risk management, explanation and user-protection plans; named human overseer; published summary; five-year evidence store	1 · 2 · 4 · 5
Art. 35	Operators of high-impact AI	Endeavour to assess the effect on fundamental rights before providing high-impact AI, covering the seven elements of Decree Art. 28 [34][62]	Impact assessment carrying the seven decree elements	1 · 5
Art. 36	Foreign AI business operators above a threshold	An operator with no address or establishment in Korea that meets a decree threshold (revenue, AI-service revenue, daily users or a past fine; Decree Art. 29) designates a domestic representative in writing and reports it to MSIT [34][62]	Designation filed with MSIT; evidence-access runbook for the representative	5

United Kingdom

The UK has no horizontal AI act. It governs AI through existing sector regulators (the ICO, the FCA, the MHRA and others), coordinated centrally, plus the **AI Security Institute** (renamed from the AI Safety Institute in February 2025) for frontier-model evaluation [38]. For automated decision-making, the Data (Use and Access) Act 2025 replaced UK GDPR Article 22 with new **Articles 22A–22D** (in force 5 February 2026): a permission-plus-safeguards model for significant, solely automated decisions, with tighter conditions where special-category data is used. The safeguards (a meaningful-human-review path, a channel to make representations and to contest, and a decision notice) are the artefact the engineer builds [37]. Chapter 19 sets Articles 22A–22D beside the GDPR and the US regimes in [the regimes side by side](#), and chapter 16 turns the safeguards into explanation and contest records in [data protection: the GDPR and the UK regime](#). UK consumer law reaches AI-generated reviews: the Digital Markets, Competition and Consumers Act 2024 bans fake and concealed-incentive reviews from 6 April 2025 [111], taught in chapter 20 under [the United Kingdom: DMCC Act](#).

Jurisdiction / instrument	Status (as of 2026-09-24)	What it asks for	Engineering artefact	Layer
UK: Data (Use and Access) Act 2025, UK GDPR Arts. 22A–22D	In force 2026-02-05 [37]	A permission-plus-safeguards model for significant, solely automated decisions, with tighter conditions where special-category data is used	ADM safeguards: meaningful-human-review path, contest and representation channel, decision notice	4 · 2
UK: Digital Markets, Competition and Consumers Act 2024, s. 225 and Sch. 20 para. 13	In force 2025-04-06 [111]	Unfair commercial practices are prohibited, and Schedule 20 bans submitting or commissioning fake consumer reviews and concealed-incentive reviews, which reaches reviews generated by AI	Policy blocking review generation; review-provenance log	1 · 4

China

China governs AI in two tiers, and this map keeps them apart. The binding tier is a set of departmental rules issued by the Cyberspace Administration of China (CAC) with co-issuers, on algorithmic recommendation (2022), deep synthesis (2023), generative AI services (2023) and the labelling of AI-generated synthetic content (2025); several are territorial, and the Interim Measures for Generative AI Services apply only to services offered "to the public within the PRC" [43][44][45]. The labelling duty is backed by a mandatory national standard, GB 45438-2025, that carries the metadata fields the measure requires [46][47]. The voluntary tier is the recommended standard GB/T 45654-2025 [48] and the TC260 AI Safety Governance Framework [41][42]. The Cybersecurity Law, amended by the NPC Standing Committee on 2025-10-28 and in force 2026-01-01, adds a programmatic Article 20 on AI that does not by itself create operator duties [49]; the most recent binding rule, the Interim Measures for Anthropomorphic Interaction Services (in force 2026-07-15), is narrow in scope (services that offer sustained emotional interaction); it has a row below and chapter 21 sets it out under [China: what chapter 08 does not already cover](#) [50]. Personal information is governed by the Personal Information Protection Law, whose Article 24 on automated decision-making also has a row [110]. The framework 3.0 (14 September 2026) is a TC260 technical document published under CAC guidance and described as "a reference for developers, providers and users": it sets a three-block risk taxonomy (inherent, application and secondary), grades risk qualitatively by scenario, intelligence level and scale with no compute or parameter threshold, treats open-source models as a distinct risk profile and names computing-power security as a risk category, and its Appendix 2 walks the agent lifecycle from design to decommissioning [42]. Practitioner commentary reported agents and physically interactive systems as the headline change in the new version [51].

The instruments above resolve to obligation-to-artefact rows in the same shape as the other jurisdictions:

Jurisdiction / instrument	Status (as of 2026-09-20)	What it asks for	Engineering artefact	Layer
China: Provisions on the Administration of Algorithmic Recommendation in Internet Information Services (CAC, MIIT, MPS and SAMR Order No. 9)	Binding; in force 2022-03-01 [43]	Algorithm filing for services with public-opinion attributes or social-mobilisation capacity, security assessment, display of the filing number, and a user option to switch off personalised recommendation	Algorithm inventory with filing record and number; security-assessment evidence pack; opt-out control at runtime	1 · 2 · 4
China: Provisions on the Administration of Deep Synthesis in Internet Information Services (CAC, MIIT and MPS Order No. 12)	Binding; in force 2023-01-10 [44]	Conspicuous labels where synthetic content could mislead the public and non-removable technical marks; training-data management; separate consent for face and voice editing; filing and security assessment for opinion-shaping functions	Content-provenance pipeline (visible label plus metadata mark); training-data governance record; consent gate; pre-release security assessment	2 · 3 · 4
China: Interim Measures for the Administration of Generative AI Services (CAC and six other bodies, Order No. 15)	Binding; in force 2023-08-15; applies to services offered to the public within the PRC [45]	Lawful-source training data and foundation models; content labelling under the deep-synthesis rules; security assessment and algorithm filing for opinion-shaping services; stop, remove, retrain and report on illegal content	Data-lineage and licensing record; eval gate on generated content; incident pipeline with a retraining loop; filing record	2 · 3 · 4 · 5
China: Measures for Labelling AI-Generated Synthetic Content, with mandatory standard GB 45438-2025	Binding; in force 2025-09-01, the standard implemented the same day [46][47]	Explicit labels (text, audio or graphic) and implicit metadata labels carrying the provider's name or code and a content number; distribution platforms verify metadata and flag suspected AI content	Provenance and watermarking pipeline emitting the GB 45438 metadata fields; platform-side detection and flagging	3 · 4
China: GB/T 45654-2025 Basic security requirements for generative AI services	Recommended (voluntary) national standard; implemented 2025-11-01 [48]	Training-corpus source and content screening, model-safety requirements and the evaluation methods that underpin the security assessment	Corpus-screening record; eval question banks; security-assessment report	3 · 5
China: TC260 AI Safety Governance Framework 3.0	Voluntary; published 2026-09-14, building on 1.0 (2024) and 2.0 (2025) [41][42]	A three-block risk taxonomy (inherent, application, secondary), technological and governance countermeasures and role-based guidelines; operators keep logs for at least six months and audit them, monitor risk in real time, keep a traceable chain of responsibility and assess resilience (§5.3)	Risk register keyed to the framework's taxonomy; log-retention policy (six months) with audit; real-time risk monitoring; resilience assessment	1 · 4 · 5
China: Personal Information Protection Law, Arts. 24 and 55–56	Binding; in force 2021-11-01 [110]	Automated decisions stay transparent and fair, with no unreasonable differential treatment in prices or terms; targeted pushes offer a non-personalised option or an easy refusal; individuals may request an explanation and refuse solely automated decisions with a significant impact; an impact assessment beforehand, kept at least three years	Explanation service and manual-decision route; non-personalised option at runtime; impact assessment record kept three years	2 · 4 · 5
China: Interim Measures for the Administration of Anthropomorphic Interaction Services (CAC, NDRC, MIIT, MPS and SAMR)	Binding; in force 2026-07-15 [50]	A minors' mode; AI signals and a reminder after two hours of continuous use; an easy exit; a security assessment at 1 million registered or 100,000 monthly active users; filing	Minors'-mode configuration; reminder timer; user-count threshold monitor; security-assessment report; filing record	1 · 2 · 4 · 5
China: TC260 Framework 3.0, Appendix 2 (agentic AI risk management)	Voluntary; published 2026-09-14 [42]	Unique identity and least-privilege permissions per agent by decision mode; human checkpoints with tamper-proof approval logs and deny-by-default; tool and skill verification; runtime guardrails (alert, restrict, intercept, suspend, terminate); memory isolation with no credentials in memory; mutual authentication; sandbox validation, red teaming and re-validation on major change; controlled decommissioning	Agent registry with identity and scope; approval-log store; tool allow-list with integrity checks; runtime guardrails and kill switch; memory-scope policy; decommissioning runbook	2 · 3 · 4 · 5

Appendix 2's agent controls line up with the two agentic references this chapter already carries, the OWASP Top 10 for Agentic Applications [16] and the NIST AI Agent Standards Initiative [29]:

Agent control	TC260 Framework 3.0, Appendix 2 [42]	OWASP Top 10 for Agentic Applications 2026 [16]	NIST AI Agent Standards Initiative [29]	Layer
Identity and least privilege	II.2: unique identity per agent, permissions by decision mode, credentials revoked at task end	ASI03 Identity and Privilege Abuse	Agent identity, authentication, authorisation	2 · 4
Human checkpoints and approval logs	II.3: tiered controls, human control checkpoints, tamper-proof approval logs, deny by default	ASI09 Human-Agent Trust Exploitation; ASI01 Agent Goal Hijack	None	4 · 5
Tools, skills and supply chain	II.4: tool verification, fair tool selection, anomaly detection, skill management	ASI02 Tool Misuse and Exploitation; ASI04 Agentic Supply Chain Vulnerabilities	Agent security	2 · 4
Runtime guardrails and execution limits	II.5(1)(2)(5)(6): input control, guardrails, step/frequency/duration limits, sandbox isolation	ASI01 Agent Goal Hijack; ASI05 Unexpected Code Execution (RCE); ASI08 Cascading Failures; ASI10 Rogue Agents	None	4
Memory	II.5(3): retention windows, isolation across users and tasks, no credentials in memory	ASI06 Memory & Context Poisoning	None	3 · 4
Agent-model-tool communication	II.5(4): mutual authentication, integrity, replay resistance	ASI07 Insecure Inter-Agent Communication	Authentication	4
Monitoring, audit, sandbox, red teaming, incident response	II.6: anomaly blocking, log management, security auditing, sandbox validation, red teaming, emergency plans, re-validation on major change	Cross-cutting	Adversarial agent evals	3 · 5
Decommissioning	II.7: complete shutdown, data backup, environment cleanup	ASI10 Rogue Agents (residual agents)	None	2 · 4

Chapter 23 compares these agent-control sources with the CSA's and Singapore's in [frameworks written for agents](#).

Treaty and international soft law

Three international instruments carry duties an engineer can evidence. The Council of Europe Framework Convention (CETS No. 225) binds Parties, not companies, and is not yet in force; inside the EU it is implemented through the AI Act [112][113]. The OECD AI Principles, revised on 3 May 2024, and the G7 Hiroshima Code of Conduct of 30 October 2023 are voluntary [114][115]. Chapter 22 teaches them in [what the Convention asks for, the five principles and five recommendations](#) and [the G7 Hiroshima Process](#).

Instrument and clause	Status (as of 2026-09-24)	What it asks for	Engineering artefact	Layer
Council of Europe Convention Art. 14(2)(a)–(b)	Not in force (as of 2026-09-24) [112][113]	Document relevant information about systems that can significantly affect human rights, sufficient for affected people to contest the decisions	Decision record per consequential output; contest path with the record attached	2 · 5
Council of Europe Convention Art. 15(2)	Not in force (as of 2026-09-24) [112][113]	Notify people that they are interacting with an AI system, as appropriate	Interaction disclosure enforced at runtime	4
Council of Europe Convention Art. 16(1)–(2)(a)–(f)	Not in force (as of 2026-09-24) [112][113]	Iterative, graduated risk and impact management: context, severity and probability, stakeholder views, monitoring and documentation	Risk register as code; impact assessment linked to the registry; monitoring against a baseline	1 · 2 · 4
Council of Europe Convention Art. 16(2)(g)	Not in force (as of 2026-09-24) [112][113]	Test systems before first use and when they are significantly modified, where appropriate	Eval gate on release and on material change	3
OECD AI Principles, principle 1.4(b)	Non-binding; revised 2024-05-03 [114]	Mechanisms let AI systems that risk undue harm be overridden, repaired and/or decommissioned safely	Tested kill switch; decommissioning record in the registry	2 · 4
OECD AI Principles, principle 1.5(b)–(c)	Non-binding; revised 2024-05-03 [114]	Traceability of datasets, processes and decisions, and systematic risk management at each phase of the lifecycle	Evidence store keyed to registry ids; risk register as code; supplier records	1 · 5

Instrument and clause	Status (as of 2026-09-24)	What it asks for	Engineering artefact	Layer
G7 Hiroshima Code of Conduct, action 1	Voluntary; agreed 2023-10-30 [115]	Identify, evaluate and mitigate risks across the lifecycle, incl. testing before deployment	Adversarial red-team suite; eval gate	3
G7 Hiroshima Code of Conduct, actions 2 and 4	Voluntary; agreed 2023-10-30 [115]	Identify and mitigate vulnerabilities, incidents and misuse after deployment, and share information and report incidents responsibly	Runtime monitoring; incident pipeline with an external-sharing branch	4 · 5
G7 Hiroshima Code of Conduct, action 3	Voluntary; agreed 2023-10-30 [115] [116]	Publicly report capabilities, limitations and appropriate and inappropriate uses; the OECD reporting framework has collected such reports since 2025	Model card published from the registry	2
G7 Hiroshima Code of Conduct, action 7	Voluntary; agreed 2023-10-30 [115]	Deploy content authentication and provenance mechanisms where feasible	Provenance marking at output; verification test	4

Mappings are illustrative, not a claim of conformity.

What is NOT harmonised yet

The map has a hole, and it is important to state it plainly rather than paper over it.

- **No harmonised standard is cited in the Official Journal.** As of 2026-09-24, Article 40's presumption of conformity is available to no one, because no harmonised standard has been OJ-cited [20].
- **EN 18286 is published but not cited.** The Article 17 QMS standard EN 18286:2026 was published in July 2026 (the first JTC 21 AI Act standard to reach publication), but it is not yet cited in the Official Journal, so it carries no presumption of conformity [20][21].
- **The other JTC 21 drafts are at or before Enquiry.** As of 2026-09-24, as reported by a pan-European standards information point, the Enquiry votes on prEN 18228 (Art. 9 , risk management) and prEN 18282 (Art. 15 , cybersecurity) closed on 30 Jul 2026 and on prEN 18229-1 (Art. 12 , logging) on 20 Aug 2026; prEN 18229-3 (Art. 14 , human oversight) entered Enquiry on 30 Jul 2026; and prEN 18229-4 and -5 (Art. 15 , accuracy and robustness) were approved as new projects on 24 Jun 2026 [60], consistent with the public tracker that had them at Enquiry in mid-2026 [53]. CEN and CENELEC may publish a priority deliverable directly after a positive Enquiry vote and target them for Q4 2026 [61]; publication would still not be an OJ citation. Chapter 22 tracks every deliverable and the [status of the JTC 21 harmonised standards](#), and explains [how the presumption of conformity works](#).
- **ISO/IEC 42001 is not the Article 17 QMS.** Certifying to EN ISO/IEC 42001:2026 evidences an AI management system; it does not confer an AI Act presumption of conformity, because it is not a harmonised standard and its scope differs from the Article 17 QMS [11][12].
- **The Code of Practice is voluntary.** Signing the GPAI Code is a way to demonstrate compliance with GPAI obligations; it is not a legal presumption of conformity [9].
- **China's framework does not cross-reference the Western instruments.** The TC260 AI Safety Governance Framework 3.0 cites no ISO/IEC 42001, ISO/IEC 23894, NIST AI RMF or EU AI Act (its named reference points are the Global AI Governance Initiative and UN-centred channels), and it does not name China's own binding rules either [42]. A crosswalk between the two stacks is something the engineer builds; neither side's documents supply it.

The register carries the three JTC 21 deliverables the book relies on, with their status as of 2026-09-24 [20][21][60]:

Deliverable	What it is	Status (as of 2026-09-24)	Engineering artefact	Layer
EN 18286:2026	Quality-management-system requirements supporting Art. 17; published but not cited in the Official Journal, so it carries no presumption of conformity	Published July 2026; not OJ-cited [21][20]	QMS processes run as pipeline stages; design and change-control evidence	1 · 5
prEN 18228	Draft harmonised standard for the risk management system of Art. 9	Draft; Enquiry vote closed 2026-07-30, as reported [60]	Provider risk file per system; acceptability criteria as code; control monitoring	1 · 3 · 5
prEN 18229-1	Draft harmonised standard for the record-keeping of Art. 12	Draft; Enquiry vote closed 2026-08-20, as reported [60]	Logging specification per system; structured, signed event logs mapped to the draft	4

The practical reading: for the period this edition covers, you cannot buy a presumption of conformity off the shelf. The obligation-to-artefact rows above are how a governance function evidences the obligation on its own merits while the harmonised standards are still being written.

In practice (illustrative) A governance team maintained this map not as a slide but as a machine-readable crosswalk: a versioned file linking each obligation ID to the artefact that produced its evidence and the layer it lived in, emitted as OSCAL component definitions. When the Omnibus moved the high-risk dates, the change was a diff to one field per affected row, and every "Maps to" line downstream re-resolved from the same file. The audit question "show me what answers Article 15" became a query against the crosswalk, not a hunt through a wiki.

Maps to: this chapter is the reverse index for the whole book; every EU AI Act article, the GPAI Code of Practice, the GDPR, NIS2, DORA, the CRA, the Product Liability, DSM, Unfair Commercial Practices, Platform Work and Consumer Credit Directives, the DSA, ISO/IEC 42001, 42005, 42006, 23894 and 22989, NIST AI RMF and the newer NIST AI work, CSA AICM, OWASP GenAI/Agentic, the CEN-CENELEC JTC 21 deliverables, the US federal and state laws, the other jurisdictions and the treaty and soft-law instruments named above map onto the five-layer stack (chapter 04) and the pattern catalogue (chapter 05). Mappings are illustrative, not a claim of conformity.

What you can do this week

1. **Find your rows.** For one system, list the rows of this map that apply to it, by role and risk class, with the date from which each applies.
2. **Name one artefact per row.** Next to each row, write the artefact that evidences it today, or mark the gap.
3. **Put the dates in the pipeline.** Store each applicable date as data that your policy checks read, so an obligation that starts to apply shows up as a failing check, not a surprise.
4. **Evidence one obligation on its merits.** For the obligation you most expected a harmonised standard to cover, write down how you evidence it today without a presumption of conformity.
5. **Re-read on change.** When a date or a row in this map changes, re-run the first step for your systems and record the difference.

Sources

[1] "AI Omnibus enters into force" (Reg. (EU) 2026/1744, in force 2026-07-27; Annex III high-risk → 2 Dec 2027; Annex I → 2 Aug 2028; legacy public-authority → 2 Aug 2030). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force> (verified: primary) [2] Regulation (EU) 2026/1744 (Digital Omnibus on AI), Art. 1 amendments to Reg. (EU) 2024/1689: new Art. 4a (special-category data for bias detection, pseudonymisation, deletion once bias is corrected); new Art. 5(1)(ba)–(bb) NCII and CSAM bans from 2 Dec 2026; Art. 111(2) public-authority systems by 2 Aug 2030; new Art. 111(4) Art. 50(2) marking by 2 Dec 2026 for systems placed on the market before 2 Aug 2026; Art. 113 dates. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [3] Commission enforcement powers over GPAI providers apply from 2 August 2026; obligations since 2 August 2025 (fines up to 3% of worldwide turnover or EUR 15M under Art. 101). European Commission, AI Act Service Desk. 2026-08-02. <https://ai-act-service-desk.ec.europa.eu/en/ai-act/faq/commissions-enforcement-powers-related-ai-act-obligations-providers-most-advanced-models> (verified: primary) [4] Regulation (EU) 2024/1689 (AI Act), Art. 101 (Commission fines for GPAI providers: up to 3% or EUR 15M) and Art. 99 (penalties by national authorities: 7% / 3% / 1% ceilings). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [5] "Safer and more transparent AI" (Art. 50 transparency live 2 Aug 2026). European Commission. 2026-08-02. https://commission.europa.eu/news-and-media/news/safer-and-more-transparent-ai-2026-08-02_en (verified: primary) [6] "AI literacy, the Digital Omnibus and Article 4 of the AI Act" (Art. 4 reworded to "support the development of" AI literacy; the reworded text applies from 27 Jul 2026). Law & Technology. 2026. <https://lawandtechnology.eu/en/ai-literacy-digital-omnibus-article-4-ai-act/> (verified: secondary) [7] Regulation (EU) 2024/1689 (AI Act), Art. 27 (FRIA for deployers of Annex III high-risk; Art. 27(4) cross-reference to a GDPR Art. 35 DPIA). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [8] Regulation (EU) 2026/1744 (Digital Omnibus on AI), new Arts. 75a–75d of the AI Act: AI Office investigation powers, binding commitments, non-compliance decisions and periodic penalty payments up to 5% of average daily income or worldwide annual turnover per day (Art. 75c(5)). Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [9] The General-Purpose AI Code of Practice (published 10 Jul 2025; a voluntary tool; three chapters: Transparency, Copyright, Safety and Security). European Commission. 2025-07-10. <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai> (verified: primary) [10] GPAI Code of Practice: contents and signatories (Safety & Security applies to systemic-risk models; official signatory list). European Commission. 2026. <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai> (verified: primary) [11] "ISO/IEC 42001 and the AI Act: why certification is not yet a presumption of conformity" (ISO 42001 AIMS ≠ Art. 17 QMS). Law & Technology. 2026. <https://lawandtechnology.eu/en/iso-iec-42001-and-the-ai-act-why-certification-is-not-yet-a-presumption-of-conformity/> (verified: secondary) [12] CSA research note on EU AI Act, prEN 18286 and ISO/IEC 42001 (scope difference; EN ISO/IEC 42001:2026 not a harmonised standard). Cloud Security Alliance. 2026-04-28. <https://labs.cloudsecurityalliance.org/research/csa-research-note-eu-ai-act-pren-18286-iso-42001-20260428-cs/> (verified: secondary) [13] ISO/IEC 42005:2025, AI system impact assessment (companion to Art. 27 and ISO 42001 Annex A.5). ISO/IEC. 2025-05. <https://www.iso.org/standard/44545.html> (verified: secondary) [14] AI Risk Management Framework 1.0 (functions: Govern, Map, Measure, Manage). NIST. 2023-01-26. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary) [15] AI Controls Matrix (AICM) v1.1 (247 control objectives, 18 domains) and STAR for AI. Cloud Security Alliance. 2026-06-22. <https://cloudsecurityalliance.org/artifacts/ai-controls-matrix-v1-1> (verified: primary) [16] OWASP Top 10 for Agentic Applications

for 2026 (ASI01 Agent Goal Hijack; ASI02 Tool Misuse and Exploitation; ASI03 Identity and Privilege Abuse; ASI04 Agentic Supply Chain Vulnerabilities; ASI05 Unexpected Code Execution (RCE); ASI06 Memory & Context Poisoning; ASI07 Insecure Inter-Agent Communication; ASI08 Cascading Failures; ASI09 Human-Agent Trust Exploitation; ASI10 Rogue Agents; names as in the document's contents, read 2026-09-24). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [17] 2026 Top 10 for LLM Applications (released 3 Aug 2026; Excessive Agency is LLM03:2026) and the Agent Control Standard (ACS), donated to the project. OWASP GenAI Security Project. 2026-09-01. <https://genai.owasp.org/2026/09/01/owasp-genai-security-project-unveils-2026-top-10-for-llm-applications-new-agent-control-standard-and-sponsors-as-community-tops-30000-members/> (verified: primary) [18] "California's SB 53: the first frontier AI law explained" (frontier developers: trained a foundation model with more than 10^{26} operations; large frontier developers: also more than USD 500M in annual gross revenue; up to USD 1M per violation; AG enforcement). Future of Privacy Forum (Justine Gluck). 2025-10-03. <https://fpf.org/blog/californias-sb-53-the-first-frontier-ai-law-explained/> (verified: secondary) [19] "Governor Hochul Signs Nation-Leading Legislation to Require AI Frameworks for AI Frontier Models" (RAISE Act, S6953B/A6453B, signed 19 Dec 2025; agreed chapter amendment; creates an oversight office within the Department of Financial Services; 72-hour incident reporting). Governor Kathy Hochul (New York State). 2025-12-19. <https://www.governor.ny.gov/news/governor-hochul-signs-nation-leading-legislation-require-ai-frameworks-ai-frontier-models> (verified: primary) [20] Standardisation of the AI Act (no harmonised standard yet referenced in the Official Journal, so no Art. 40 presumption; page last updated 2026-08-03; no Commission implementing decision citing one found in the Publications Office index on 2026-09-24). European Commission. 2026-08-03. <https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation> (verified: primary) [21] "EN 18286 in the Spotlight: Supporting Compliance with the AI Act" (EN 18286:2026, Art. 17 QMS, published; the first standard in support of the AI Act). CEN-CENELEC. 2026-07-31. <https://www.cencenelec.eu/news-events/news/2026/en-in-the-spotlight/2026-07-30-ai-quality-management/> (verified: primary) [22] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 et al.; OJ L, 24 July 2026; in force 27 Jul 2026; amends Art. 3(14), 6(1a)–(1c), 25(2) and (4), 75(1), new 75(1a) (serious incidents of systems under the AI Office's competence reported to the AI Office), 99(4)(da), Annex I (machinery to Section B) and Annex VIII Section B (points 7 and 9 deleted); Art. 73 not amended; Art. 113(a) Chapters I and II apply from 2 Feb 2025; Art. 113(c) as replaced: Chapter III, Sections 1, 2 and 3, except Art. 6(5), apply from 2 Dec 2027 (Annex III) and 2 Aug 2028 (Annex I). Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [23] Regulation (EU) 2024/1689 (AI Act), Art. 25 (responsibilities along the AI value chain; conditions under which a value-chain actor becomes a provider; information flow to downstream actors). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [24] NY State Senate Bill 2025-S6953B (RAISE Act; signed 19 Dec 2025 as Chapter 699; frontier model = trained with over 10^{26} operations costing over USD 100M; safety protocols and 72-hour incident disclosure; Attorney General and Division of Homeland Security and Emergency Services; superseded in scope by the 2026 chapter amendment, which drops the cost test, adds a USD 500M revenue test and moves oversight to the DFS [25]). New York State Senate. 2025-12-19. <https://www.nysenate.gov/legislation/bills/2025/S6953/amendment/B> (verified: primary) [25] "New York Finalizes RAISE Act for Frontier AI Models; Law Takes Effect January 1, 2027" (chapter amendment introduced 6 Jan 2026, passed 11 Mar 2026, signed 27 Mar 2026; effective 1 Jan 2027; SB 53's thresholds: frontier model above 10^{26} operations, large frontier developer above USD 500M annual revenue; large frontier developers publish the framework, all frontier developers report critical safety incidents; DFS oversight office). Wiley. 2026-04-03. <https://www.wiley.law/alert-New-York-Finalizes-RAISE-Act-for-Frontier-AI-Models-Law-Takes-Effect-January-1-2027> (verified: secondary) [26] "AI Act: Commission publishes a reporting template for serious incidents involving general-purpose AI models with systemic risk" (template for serious-incident reporting under Art. 55; aligned to Commitment 9 of the GPAI Code). European Commission. 2025-11-04. <https://digital-strategy.ec.europa.eu/en/library/ai-act-commission-publishes-reporting-template-serious-incidents-involving-general-purpose-ai> (verified: primary) [27] ISO/IEC 42006:2025, Requirements for bodies providing audit and certification of AI management systems (builds on ISO/IEC 17021-1; who may credibly certify to 42001). ISO/IEC. 2025. <https://www.iso.org/standard/42006> (verified: secondary) [28] ISO/IEC 23894:2023, Guidance on AI risk management (adapts ISO 31000 to AI). ISO/IEC. 2023-02. <https://www.iso.org/standard/77304.html> (verified: secondary) [29] "Announcing the AI Agent Standards Initiative for Interoperable and Secure Innovation" (CAISI initiative; agent identity, authentication and security). NIST. 2026-02-17. <https://www.nist.gov/news-events/news/2026/02/announcing-ai-agent-standards-initiative-interoperable-and-secure> (verified: primary) [30] NIST IR 8596 (initial preliminary draft; comments closed 2026-01-30; no later version on CSRC on 2026-09-24): Cybersecurity Framework Profile for Artificial Intelligence (Cyber AI Profile); Secure / Defend / Thwart. NIST. 2025-12-16. <https://csrc.nist.gov/pubs/ir/8596/iprd> (verified: primary) [31] NIST AI 800-1 (second public draft): Managing Misuse Risk for Dual-Use Foundation Models (voluntary; still in draft, no final version on NIST's publication server on 2026-09-24). NIST. 2025-01. <https://www.nist.gov/news-events/news/2025/01/updated-guidelines-managing-misuse-risk-dual-use-foundation-models> (verified: primary) [32] "Securing the Agentic Control Plane: Key Progress at the CSAI Foundation" (names the Agentic Trust Framework, AARM, the Catastrophic Risk Annex and STAR for AI; no "Agentic Control Supplement" is named, checked 2026-09-24). Cloud Security Alliance. 2026-04-29. <https://cloudsecurityalliance.org/blog/2026/04/29/securing-the-agentic-control-plane-key-progress-at-the-csai-foundation> (verified: primary) [33] AICM Catastrophic Risk Annex: enhanced AICM controls for high-autonomy systems with catastrophic-risk potential. Cloud Security Alliance. 2026-08-05. <https://cloudsecurityalliance.org/csai-foundation/catastrophic-risk-annex> (verified: primary) [34] Basic Act on the Development of Artificial Intelligence and the Establishment of a Foundation for Trust (인공지능 발전과 신뢰 기반 조성 등에 관한 기본법; Act No. 20676, promulgated 2025-01-21, in force 2026-01-22; high-impact AI duties in Arts. 31 to 36; fact-finding in Art. 40; fines in Art. 43). Korean Law Information Center (MOLEG). 2026-01-22. <https://www.law.go.kr/LSW/lsInfoP.do?lsSeq=268543> (verified: primary) [35] Texas Responsible Artificial Intelligence Governance Act (HB 149), enrolled text; effective 1 Jan 2026. Texas Legislature (89R). 2025. <https://capitol.texas.gov/tlodocs/89R/billtext/pdf/HB00149F.pdf> (verified: primary) [36] "Colorado AI law in flux:

comprehensive replacement bill signed after federal court blocks predecessor's enforcement" (SB 24-205 delayed to 30 Jun 2026, then replaced by SB 26-189, effective 1 Jan 2027). McDermott Will & Emery. 2026. <https://www.mcdermottlaw.com/insights/colorado-ai-law-in-flux-comprehensive-replacement-bill-signed-after-federal-court-blocks-predecessors-enforcement/> (verified: secondary) [37] Data (Use and Access) Act 2025, s. 80 (replaces UK GDPR Art. 22 with Arts. 22A–22D; in force 5 Feb 2026). legislation.gov.uk. 2025. <https://www.legislation.gov.uk/ukpga/2025/18/section/80> (verified: primary) [38] "AI Security Institute" (written statement announcing the rename of the AI Safety Institute). UK Parliament. 2025-02-24. <https://questions-statements.parliament.uk/written-statements/detail/2025-02-24/hlws454> (verified: primary) [39] Model AI Governance Framework for Generative AI (voluntary). IMDA / AI Verify Foundation. 2024-05. <https://aiverifyfoundation.sg/wp-content/uploads/2024/05/Model-AI-Governance-Framework-for-Generative-AI-May-2024-1-1.pdf> (verified: primary) [40] ETSI EN 304 223: Securing Artificial Intelligence (SAI); Baseline Cyber Security Requirements for AI Models and Systems (V2.1.1, Dec 2025; 13 principles across five lifecycle stages). ETSI. 2025-12. <https://www.etsi.org/newsroom/press-releases/2627-etsi-releases-world-leading-standard-for-securing-ai/> (verified: primary) [41] 《人工智能安全治理框架3.0》发布: announcement of the AI Safety Governance Framework 3.0 (TC260 under CAC guidance; released 2026-09-14 at the 2026 National Cybersecurity Publicity Week). Cyberspace Administration of China. 2026-09-14. https://www.cac.gov.cn/2026-09/14/c_1791137092283345.htm (verified: primary) [42] AI Safety Governance Framework 3.0 (人工智能安全治理框架3.0), bilingual PDF; English text printed pp. 49–130; §2.1.1(b) open-source models p. 55; §2.1.4(a) computing power p. 59; §5.3 operators' guidelines pp. 101–104; Appendix 2 agentic AI risk management pp. 113–126; no reference to ISO/IEC 42001, NIST AI RMF or the EU AI Act. TC260 / CAC. 2026-09-14. <https://www.cac.gov.cn/rootimages/uploadimg/1791137114683961/1791137114683961.pdf> (verified: primary) [43] Provisions on the Administration of Algorithmic Recommendation in Internet Information Services (互联网信息服务算法推荐管理规定; CAC, MIIT, MPS and SAMR Order No. 9; promulgated 2021-12-31; in force 2022-03-01; Art. 17 opt-out, Art. 24 algorithm filing, Art. 27 security assessment). Cyberspace Administration of China. 2022-01-04. https://www.cac.gov.cn/2022-01/04/c_1642894606364259.htm (verified: primary) [44] Provisions on the Administration of Deep Synthesis in Internet Information Services (互联网信息服务深度合成管理规定; CAC, MIIT and MPS Order No. 12; promulgated 2022-11-25; in force 2023-01-10; Arts. 14 training data and separate consent, 16–17 marks and labels, 19 filing, 15/20 security assessment). Cyberspace Administration of China. 2022-12-11. https://www.cac.gov.cn/2022-12/11/c_1672221949354811.htm (verified: primary) [45] Interim Measures for the Administration of Generative AI Services (生成式人工智能服务管理暂行办法; CAC and six other bodies, Order No. 15; published 2023-07-13; in force 2023-08-15; Art. 2 scope: services to the public within the PRC; Art. 7 lawful-source data; Art. 12 labelling; Art. 14 stop-remove-retrain-report; Art. 17 security assessment and filing). Cyberspace Administration of China. 2023-07-13. https://www.cac.gov.cn/2023-07/13/c_1690898327029107.htm (verified: primary) [46] Measures for Labelling AI-Generated Synthetic Content (人工智能生成合成内容标识办法; CAC, MIIT, MPS and NRTA; published 2025-03-14; in force 2025-09-01; explicit and implicit labels; platform verification duty). Cyberspace Administration of China. 2025-03-14. https://www.cac.gov.cn/2025-03/14/c_1743654684782215.htm (verified: primary) [47] GB 45438-2025 Cybersecurity technology: Labeling method for content generated by artificial intelligence (网络安全技术 人工智能生成合成内容标识方法; mandatory national standard; issued 2025-02-28; implemented 2025-09-01). SAMR / SAC (drafted by TC260). 2025-02-28. <https://std.samr.gov.cn/gb/search/gbDetailed?id=301E0388CB75788DE06397BE0A0AE1B4> (verified: primary) [48] GB/T 45654-2025 Cybersecurity technology: Basic security requirements for generative artificial intelligence service (网络安全技术 生成式人工智能服务安全基本要求; recommended national standard; issued 2025-04-25; implemented 2025-11-01). SAMR / SAC (drafted by TC260). 2025-04-25. <https://openstd.samr.gov.cn/bzgk/std/newGbInfo?hcno=F67D3F376E0A0A0FF5317FB36B32A30A> (verified: primary) [49] Cybersecurity Law of the PRC as amended by the NPC Standing Committee decision of 2025-10-28 (in force 2026-01-01; new Article 20 on AI: state support for AI research, training-data and computing infrastructure, AI ethics norms, risk monitoring, assessment and safety supervision). Cyberspace Administration of China (consolidated text). 2025-12-29. https://www.cac.gov.cn/2025-12/29/c_1768735112911946.htm (verified: primary) [50] Interim Measures for the Administration of Anthropomorphic Interaction Services (人工智能拟人化互动服务管理暂行办法; CAC, NDRC, MIIT, MPS and SAMR; published 2026-04-10; in force 2026-07-15). Cyberspace Administration of China. 2026-04-10. https://www.cac.gov.cn/2026-04/10/c_1777558395078289.htm (verified: primary) [51] "China's TC260 released Version 3.0 of the AI Safety Governance Framework" (LinkedIn post; agents and physically interactive systems as the headline change). Barbara Li (Reed Smith). 2026-09. https://www.linkedin.com/posts/barbara-li-67532067_tc260-ai-governance-share-7505863215600308224-Xlyo/ (verified: reported) [52] Real Decreto 729/2023, de 22 de agosto, por el que se aprueba el Estatuto de la Agencia Española de Supervisión de Inteligencia Artificial (Royal Decree approving the AESIA statute; seat in A Coruña; BOE no. 210, 2 Sep 2023). Boletín Oficial del Estado. 2023-09-02. <https://www.boe.es/eli/es/rd/2023/08/22/729> (verified: primary) [53] JTC 21 standards tracker (risk, logging and cybersecurity standards at Enquiry, end-2026 target; a vendor-maintained tracker, not a CEN-CENELEC publication). kla.digital. 2026. <https://kla.digital/blog/jtc-21-standards-tracker> (verified: reported) [54] "Evolving AI Transparency: the AIBOM generator's new home at OWASP" (CycloneDX output). OWASP GenAI Security Project. 2025-12-18. <https://genai.owasp.org/2025/12/18/evolving-ai-transparency-the-journey-of-the-aibom-generator-and-its-new-home-at-owasp/> (verified: primary) [55] SB26-189 Automated Decision-Making Technology (signed by the Governor 14 May 2026; Session Laws chapter 131). Colorado General Assembly. 2026-05-14. <https://leg.colorado.gov/bills/sb26-189> (verified: primary) [56] SB 53, Artificial intelligence models: large developers (Transparency in Frontier Artificial Intelligence Act; approved by the Governor 29 Sep 2025; frontier AI framework; critical safety incidents to the Office of Emergency Services within 15 days; civil penalty up to USD 1M per violation, Attorney General only). California Legislature. 2025-09-29. https://leginfo.ca.gov/faces/billTextClient.xhtml?bill_id=20250260SB53 (verified: primary) [57] Regulation (EU) 2024/1689 (AI Act): Art. 26(5) (a deployer that identifies a serious incident informs the provider first, then the importer or distributor and the market-surveillance authority; Art. 73 applies mutatis mutandis if it cannot reach the provider) and Art. 73(1)–(4) (report immediately on a causal link or its reasonable likelihood, and no later than 15, 2 or 10 days after the provider or, where

applicable, the deployer becomes aware). Publications Office of the EU (EUR-Lex). 2024-06-13. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [58] "AI Basic Act Update: Enforcement and Key Implications" (MSIT guidance period of at least one year for fact-finding and fines; exceptions for loss of life or human-rights violations). Shin & Kim. 2026-02-11. <https://www.shinkim.com/eng/media/newsletter/3117> (verified: secondary) [59] AI Risk Management Framework ("The AI RMF 1.0 is being revised as part of the White House AI Action Plan"; no revised version published as of 2026-09-24). NIST. 2026-09-24. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary) [60] Project stages for JTC 21 deliverables read on 2026-09-24 (prEN 18228 and prEN 18282 Enquiry votes closed 2026-07-30; prEN 18229-1 closed 2026-08-20; prEN 18229-3 at Enquiry from 2026-07-30; prEN 18229-4 and -5 new projects 2026-06-24). Genorma (pan-European standards information point with national standards bodies). 2026-09-24. <https://genorma.com/en/standards/pren-18228> (verified: secondary) [61] "Update on CEN and CENELEC's decision to accelerate the development of standards for artificial intelligence" (direct publication after a positive Enquiry vote; Q4 2026 target). CEN-CENELEC. 2025-10-23. <https://www.cencenelec.eu/news-events/news/2025/brief-news/2025-10-23-ai-standardization/> (verified: primary) [62] Enforcement Decree of the AI Basic Act (Presidential Decree No. 36053, promulgated 2026-01-21, in force 2026-01-22). Korean Law Information Center (MOLEG). 2026-01-21. <https://www.law.go.kr/LSW/lsInfoP.do?efYd=20260122&lsiSeq=282879> (verified: primary) [63] Regulation (EU) 2024/1689 (AI Act), consolidated text of 27 July 2026 incorporating Regulation (EU) 2026/1744 (Art. 3(1) AI system; Art. 6(3)–(4) documented non-high-risk assessment and Art. 49(2) registration; Art. 15(3)–(4) declared accuracy metrics and feedback loops; Art. 16(l) accessibility; Art. 17(1)(m) accountability framework; Art. 18 documentation kept 10 years; Art. 19 logs kept at least six months; Art. 20 corrective actions; Arts. 22–24 authorised representatives, importers and distributors; Art. 26(1)–(11) deployer duties; Art. 43(4) new assessment on substantial modification; Art. 48 CE marking; Art. 52 notification within two weeks; Art. 53(1)(c) copyright policy; Art. 54 authorised representative of GPAI providers; Art. 73(6) investigation without altering the system; Art. 86 right to explanation; Art. 87 Directive (EU) 2019/1937 applies; Art. 111(3) GPAI models placed on the market before 2 August 2025 comply by 2 August 2027; Art. 113). Publications Office of the EU (EUR-Lex). 2026-07-27. <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng> (verified: primary) [64] Directive (EU) 2019/1937 on the protection of persons who report breaches of Union law (internal reporting channels for private legal entities with 50 or more workers, Art. 8(3); acknowledgment within seven days and feedback within three months, Art. 9(1)). Publications Office of the EU (EUR-Lex). 2019-11-26. <https://eur-lex.europa.eu/eli/dir/2019/1937/oj/eng> (verified: primary) [65] General-Purpose AI Code of Practice, Safety and Security chapter (Commitment 9, Measure 9.3: 2, 5, 10 and 15 days by incident class, intermediate reports at least every four weeks, final report within 60 days of resolution; Measure 9.4: records kept at least five years; Appendix 1.3 sources of systemic risk incl. the capability to operate autonomously, colluding with other AI systems, access to tools and the level of human oversight; Appendix 1.4 specified systemic risks incl. loss of control). European Commission. 2025-07-10. <https://ec.europa.eu/newsroom/dae/redirection/document/118119> (verified: primary) [66] Regulation (EU) 2016/679 (General Data Protection Regulation; Arts. 5(1)(b)–(c), 5(2), 6, 6(4), 7, 9, 13, 14, 15(1)(h), 16, 17, 21, 22, 25, 28, 30, 33–36, 44–49; applies from 25 May 2018, Art. 99(2)). Publications Office of the EU (EUR-Lex). 2016-05-04. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [67] Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (legitimate-interest test; anonymity test and the evidence expected for a claim that a model is anonymous). European Data Protection Board. 2024-12-17. https://www.edpb.europa.eu/system/files/2024-12/edpb_opinion_202428_ai-models_en.pdf (verified: primary) [68] Directive (EU) 2022/2555 (NIS2) (Art. 21(2)(c) business continuity and (d) supply-chain security; Art. 23(4) early warning within 24 hours, incident notification within 72 hours, final report within one month; Art. 41(1) measures applied from 18 October 2024). Publications Office of the EU (EUR-Lex). 2022-12-27. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng> (verified: primary) [69] Regulation (EU) 2022/2554 (DORA) (Art. 19 reporting of major ICT-related incidents; Art. 28(3) register of information; Art. 28(8) exit strategies; Art. 64 applies from 17 January 2025). Publications Office of the EU (EUR-Lex). 2022-12-27. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng> (verified: primary) [70] Commission Delegated Regulation (EU) 2025/301, RTS on the content and time limits of major ICT-related incident reports (Art. 5(1): initial notification within four hours of classification and no later than 24 hours from awareness; Art. 5(2): within four hours of a classification made after those 24 hours; intermediate report within 72 hours of the initial notification; final report no later than one month after the latest intermediate report). Publications Office of the EU (EUR-Lex). 2025-02-20. https://eur-lex.europa.eu/eli/reg_del/2025/301/oj/eng (verified: primary) [71] Regulation (EU) 2024/2847 (Cyber Resilience Act) (Art. 14 reporting of actively exploited vulnerabilities and severe incidents: early warning within 24 hours, notification within 72 hours, final reports; Art. 71(2) applies from 11 December 2027, Art. 14 from 11 September 2026). Publications Office of the EU (EUR-Lex). 2024-11-20. <https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng> (verified: primary) [72] Directive (EU) 2024/2853 on liability for defective products (Art. 2(1) products placed on the market or put into service after 9 December 2026; Art. 4(1) software is a product; Art. 9 disclosure of evidence; Art. 10 presumption of defectiveness; Art. 11(2) no exemption for defects due to software, its updates or the lack of safety updates within the manufacturer's control; Art. 22 transposition by 9 December 2026). Publications Office of the EU (EUR-Lex). 2024-11-18. <https://eur-lex.europa.eu/eli/dir/2024/2853/oj/eng> (verified: primary) [73] Directive (EU) 2019/790 on copyright and related rights in the Digital Single Market (Art. 4(3) text-and-data-mining exception subject to an express reservation, by machine-readable means for content made publicly available online; Art. 29 transposition by 7 June 2021). Publications Office of the EU (EUR-Lex). 2019-05-17. <https://eur-lex.europa.eu/eli/dir/2019/790/oj/eng> (verified: primary) [74] Regulation (EU) 2022/2065 (Digital Services Act) (Art. 25 online interface design and organisation; Art. 27 recommender system transparency; applies from 17 February 2024). Publications Office of the EU (EUR-Lex). 2022-10-27. <https://eur-lex.europa.eu/eli/reg/2022/2065/oj/eng> (verified: primary) [75] Directive 2005/29/EC (Unfair Commercial Practices Directive) (Art. 5 general prohibition; Arts. 6–7 misleading actions and omissions; Art. 19 measures applied by 12 December 2007), with Directive (EU) 2019/2161 adding Annex I points 23b and 23c on consumer reviews. Publications Office of the EU (EUR-Lex). 2005-06-11. <https://eur-lex.europa.eu/eli/dir/2005/29/oj/eng> (verified: primary) [76] Directive (EU) 2024/2831 on improving working conditions

in platform work (Art. 7 limits on processing by automated systems; Art. 9 transparency; Art. 10 human oversight and an impact evaluation at least every two years; Art. 11 explanation and human review; Art. 29 transposition by 2 December 2026). Publications Office of the EU (EUR-Lex). 2024-11-11. <https://eur-lex.europa.eu/eli/dir/2024/2831/oj/eng> (verified: primary) [77] Directive (EU) 2023/2225 on credit agreements for consumers (Art. 18(8) human intervention, explanation and review where the creditworthiness assessment involves automated processing; Art. 48 measures applied from 20 November 2026). Publications Office of the EU (EUR-Lex). 2023-10-30. <https://eur-lex.europa.eu/eli/dir/2023/2225/oj/eng> (verified: primary) [78] ISO/IEC 22989:2022, Information technology: Artificial intelligence: AI concepts and terminology (AI stakeholder roles; AI system life cycle). ISO/IEC. 2022-07. <https://www.iso.org/standard/74296.html> (verified: primary) [79] NIST AI 600-1, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (12 risks; suggested actions coded GV, MP, MS and MG). NIST. 2024-07-26. <https://doi.org/10.6028/NIST.AI.600-1> (verified: primary) [80] AICM v1.1.1 and AI-CAIQ machine-readable bundle (JSON, YAML, OSCAL; control ids and titles incl. IAM-18 Agent Access Restriction and AIS-11 Agents Security Boundaries). Cloud Security Alliance. 2026-08-04. <https://cloudsecurityalliance.org/artifacts/aicm-machine-readable-bundle-json-yaml-oscal> (verified: primary) [81] Agentic Trust Framework, v1 (zero-trust governance for AI agents; autonomy tiers and promotion criteria; CC BY 4.0). CSAI Foundation / Cloud Security Alliance. 2026-02. <https://agentictrustframework.ai/> (verified: primary) [82] Autonomous Action Runtime Management (AARM) specification (pre-execution interception with identity binding; policy evaluation before execution). Cloud Security Alliance. 2026. <https://aarm.dev/> (verified: primary) [83] STAR for AI (Level 1 self-assessment; Level 1 Valid-AI-ted automated validation; Level 2 with ISO/IEC 42001 certification plus the Valid-AI-ted assessment; read 2026-09-24). Cloud Security Alliance. 2026-09-24. <https://cloudsecurityalliance.org/star/ai> (verified: primary) [84] AB-2013, Generative artificial intelligence: training data transparency (chaptered 2024-09-28, Chapter 817; documentation on or before 2026-01-01 for systems released since 2022-01-01). California Legislative Information. 2024-09-28. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202320240AB2013 (verified: primary) [85] AB-853, California AI Transparency Act (amends SB 942; chaptered 2025-10-13, Chapter 674; operative 2026-08-02; platform duties 2027-01-01; capture devices 2028-01-01). California Legislative Information. 2025-10-13. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202520260AB853 (verified: primary) [86] SB-243, Companion chatbots (chaptered 2025-10-13, Chapter 677; AI disclosure; reminders at least every three hours for known minors; suicide and self-harm protocol; annual reports to the Office of Suicide Prevention beginning 2027-07-01). California Legislative Information. 2025-10-13. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202520260SB243 (verified: primary) [87] "California Finalizes Regulations to Strengthen Consumers' Privacy" (regulations on ADMT, risk assessments and cybersecurity audits approved 2025-09-23; effective 2026-01-01; ADMT requirements from 2027-01-01; risk-assessment attestations and summaries due 2028-04-01). California Privacy Protection Agency. 2025-09-23. <https://cppa.ca.gov/announcements/2025/20250923.html> (verified: primary) [88] New York General Business Law Article 47, Artificial Intelligence Companion Models (§§ 1700–1704; self-harm protocol; notice at the start and at least every three hours; Attorney General, up to USD 15,000 per day; most recent revision shown 2025-11-07). New York State Senate. 2025-11-07. <https://www.nysenate.gov/legislation/laws/GBS/A47> (verified: primary) [89] "Illinois Adopts New AI-in-Employment Regulations: What Employers Need to Know for 2026" (HB 3773 effective 2026-01-01; notice duty; ZIP codes as a proxy; IDHR draft rules). Hinshaw & Culbertson. 2026. <https://www.hinshawlaw.com/en/insights/blogs/employment-law-observer/illinois-adopts-new-ai-in-employment-regulations-what-employers-need-to-know-for-2026> (verified: secondary) [90] Automated Employment Decision Tools (Local Law 144 of 2021; bias audit within one year; public summary; notices; enforcement from 2023-07-05). NYC Department of Consumer and Worker Protection. 2023. <https://www.nyc.gov/site/dca/about/automated-employment-decision-tools.page> (verified: primary) [91] S.B. 226, Artificial Intelligence Consumer Protection Amendments, enrolled copy (Utah Code 13-75, effective 2025-05-07; disclosure on a clear and unambiguous request; prominent disclosure in high-risk interactions by regulated occupations; safe harbour; Title 13, Chapter 72, Artificial Intelligence Policy Act, repealed 2027-07-01). Utah State Legislature. 2025. <https://le.utah.gov/Session/2025/bills/enrolled/SB0226.pdf> (verified: primary) [92] SB21-169, Restrict Insurers' Use of External Consumer Data (signed 2021-07-06; effective 2021-09-07; risk-management framework, testing and chief-risk-officer attestation; rules per type of insurance, none effective before 2023-01-01). Colorado General Assembly. 2021-07-06. <https://leg.colorado.gov/bills/sb21-169> (verified: primary) [93] Code of Virginia § 59.1-580, Data protection assessments (targeted advertising, sale, profiling with a reasonably foreseeable risk, sensitive data; processing activities created after 2023-01-01; available to the Attorney General). Virginia General Assembly. 2023. <https://law.lis.virginia.gov/vacode/title59.1/chapter53/section59.1-580/> (verified: primary) [94] SB21-190, Protect Personal Data Privacy (Colorado Privacy Act; opt-outs incl. profiling; data protection assessments; universal opt-out mechanism; effective 1 July 2023). Colorado General Assembly. 2021-07-07. <https://leg.colorado.gov/bills/sb21-190> (verified: primary) [95] Minnesota Statutes § 325M.14, Consumer personal data rights, subd. 1(g) (question the result of profiling, be informed of the reason, review and correct the data, have the decision re-evaluated; effective 31 July 2025). Office of the Revisor of Statutes, Minnesota. 2025. <https://www.revisor.mn.gov/statutes/cite/325M.14> (verified: primary) [96] "Biometric Information Privacy Act" (signed 3 October 2008; consent, timely destruction and secure storage of biometric identifiers; USD 1,000 or 5,000 per violation). Wikipedia. 2026-09-24. https://en.wikipedia.org/wiki/Biometric_Information_Privacy_Act (verified: reported) [97] Chapter 19.373 RCW, Washington My Health My Data Act (consumer health data incl. data derived or extrapolated by algorithms or machine learning; consent, separate sharing consent, signed authorisation for sale; 31 March 2024, small businesses 30 June 2024). Washington State Legislature. 2023. <https://app.leg.wa.gov/RCW/default.aspx?cite=19.373&full=true> (verified: primary) [98] OMB Memorandum M-25-21, Accelerating Federal Use of AI through Innovation, Governance, and Public Trust (high-impact AI; minimum practices; 365 days to document). Office of Management and Budget. 2025-04-03. <https://www.whitehouse.gov/wp-content/uploads/2025/02/M-25-21-Accelerating-Federal-Use-of-AI-through-Innovation-Governance-and-Public-Trust.pdf> (verified: primary) [99] OMB Memorandum M-26-04, Increasing Public Trust in Artificial Intelligence Through Unbiased AI Principles (policies updated by 2026-03-11; minimum LLM transparency in solicitations). Office of Management and Budget. 2025-

12-11. <https://www.whitehouse.gov/wp-content/uploads/2025/12/M-26-04-Increasing-Public-Trust-in-Artificial-Intelligence-Through-Unbiased-AI-Principles-1.pdf> (verified: primary) [100] 12 CFR § 1002.9, Notifications (statement of specific reasons, or the right to one within 30 days; internal standards or a failed score are insufficient; source 76 FR 79445, 21 December 2011, as amended 20 March 2023). Legal Information Institute, Cornell Law School. 2026-09-24.

<https://www.law.cornell.edu/cfr/text/12/1002.9> (verified: secondary) [101] 15 U.S.C. § 1681m, Requirements on users of consumer reports (adverse-action notice; numerical credit score and key factors added by Pub. L. 111-203, s. 1100F, effective on the designated transfer date, 21 July 2011 per 12 U.S.C. § 5582 note). Legal Information Institute, Cornell Law School. 2026-09-24.

<https://www.law.cornell.edu/uscode/text/15/1681m> (verified: secondary) [102] 42 U.S.C. § 2000e-2(k), Burden of proof in disparate impact cases (business necessity; alternative employment practice; added by the Civil Rights Act of 1991, 21 November 1991). Legal Information Institute, Cornell Law School. 2026-09-24.

<https://www.law.cornell.edu/uscode/text/42/2000e-2> (verified: secondary) [103] 29 CFR § 1607.4(D), Uniform Guidelines on Employee Selection Procedures: adverse impact and the four-fifths rule (43 FR 38295, 25 August 1978). Legal Information Institute, Cornell Law School. 2026-09-24.

<https://www.law.cornell.edu/cfr/text/29/1607.4> (verified: secondary) [104] 15 U.S.C. § 45(a)(1), Unfair methods of competition and unfair or deceptive acts or practices unlawful (deceptive-practices prong added by the Wheeler-Lea Act of 21 March 1938). Legal Information Institute, Cornell Law School. 2026-09-24.

<https://www.law.cornell.edu/uscode/text/15/45> (verified: secondary) [105] "FTC Order Requires Workado to Back Up Artificial Intelligence Detection Claims" (competent and reliable evidence required for AI accuracy claims). Federal Trade Commission. 2025-04-28. <https://www.ftc.gov/news-events/news/press-releases/2025/04/ftc-order-requires-workado-back-artificial-intelligence-detection-claims> (verified: primary) [106] TAKE IT DOWN Act, Public Law 119-12 (enacted 19 May 2025; s. 3: covered platforms establish a notice-and-removal process within one year of enactment and remove reported images, and known identical copies, within 48 hours; enforced by the FTC). US Government Publishing Office, GovInfo. 2025-05-19. <https://www.govinfo.gov/content/pkg/PLAW-119publ12/html/PLAW-119publ12.htm> (verified: primary) [107] Model AI Governance Framework for Agentic AI, version 1.5 (agent identity unique, accounted for and centrally managed; authorisations scoped, time- or session-bound, non-transferable and bounded by the authorising human; significant checkpoints for high-stakes, irreversible, outlier and user-defined actions; approvals enforced through system-level controls). IMDA. 2026-05-20. <https://www.imda.gov.sg/-/media/imda/files/about/emerging-tech-and-research/artificial-intelligence/mgf-for-agentic-ai.pdf> (verified: primary) [108] Directive on Automated Decision-Making (in effect 1 April 2019; systems procured before 24 June 2025 comply by 24 June 2026; 6.1 algorithmic impact assessment published before production; Appendix C requirements by impact level; notice, explanation, peer review, recourse, reporting). Treasury Board of Canada Secretariat. 2025-06-24. <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32592> (verified: primary) [109] Lei Geral de Proteção de Dados Pessoais, Lei n. 13.709/2018, compiled text (Art. 20 review of decisions taken solely on automated processing; Art. 65 entry into force, incl. Arts. 52 to 54 from 1 August 2021). Presidência da República (Brazil). 2026-09-24. https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709compilado.htm (verified: primary) [110] Personal Information Protection Law of the People's Republic of China, English translation for reference (Art. 24 automated decision-making; Arts. 55–56 personal information protection impact assessment kept at least three years; in force 1 November 2021). National People's Congress. 2021-12-29. http://en.npc.gov.cn.cdurl.cn/2021-12/29/c_694559.htm (verified: primary) [111] Digital Markets, Competition and Consumers Act 2024, s. 225 (unfair commercial practices prohibited; in force 6 April 2025) and Sch. 20, para. 13 (fake and concealed-incentive consumer reviews). legislation.gov.uk. 2024. <https://www.legislation.gov.uk/ukpga/2024/13/section/225> (verified: primary) [112] Council of Europe Framework Convention on Artificial Intelligence and Human Rights, Democracy and the Rule of Law (CETS No. 225), text (Arts. 14–15 remedies and safeguards; Art. 16 risk and impact management; Art. 30 entry into force). Council of Europe. 2024-09-05. <https://rm.coe.int/1680afae3c> (verified: primary) [113] The Framework Convention on Artificial Intelligence (Parties: the European Union; not yet in force; read on 2026-09-24). Council of Europe. 2026-09-24. <https://www.coe.int/en/web/artificial-intelligence/the-framework-convention-on-artificial-intelligence> (verified: primary) [114] Recommendation of the Council on Artificial Intelligence, OECD/LEGAL/0449 (principles 1.4(b) override, repair or decommission safely and 1.5(b)–(c) traceability and systematic risk management; revised 3 May 2024). OECD. 2024-05-03. <https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449> (verified: primary) [115] Hiroshima Process International Code of Conduct for Organizations Developing Advanced AI Systems (11 actions; voluntary). G7 / European Commission. 2023-10-30. <https://digital-strategy.ec.europa.eu/en/library/hiroshima-process-international-code-conduct-advanced-ai-systems> (verified: primary) [116] "OECD launches global framework to monitor application of G7 Hiroshima AI Code of Conduct" (reporting framework launched 7 February 2025; first reports by 15 April 2025). OECD. 2025-02-07. <https://www.oecd.org/en/about/news/press-releases/2025/02/oecd-launches-global-framework-to-monitor-application-of-g7-hiroshima-ai-code-of-conduct.html> (verified: primary) [118] Public Act 103-0804, HB 3773 (amends the Illinois Human Rights Act, 775 ILCS 5/2-102(L): no AI with a discriminatory effect on protected classes, no ZIP codes as a proxy, notice of AI use; IDHR to adopt rules; approved 9 Aug 2024, effective 1 Jan 2026; text and bill status read from Web Archive captures of 2025-03-29 and 2025-06-17, as ilga.gov refused connections on 2026-09-25). Illinois General Assembly. 2024-08-09. <https://www.ilga.gov/legislation/publicacts/fulltext.asp?Name=103-0804> (verified: primary) [119] 740 ILCS 14, Biometric Information Privacy Act (Source: P.A. 95-994, eff. 10-3-08; s. 15 retention schedule, written release, secure storage; s. 20 right of action, USD 1,000 negligent or USD 5,000 intentional or reckless per violation; text read from the Web Archive capture of 2025-06-18, as ilga.gov refused connections on 2026-09-25). Illinois General Assembly. 2008-10-03. <https://www.ilga.gov/legislation/ilcs/ilcs3.asp?ActID=3004&ChapterID=57> (verified: primary)

09. Glossary

The canonical definitions for the book: every term defined once, alphabetically, and cross-referenced to the chapter that treats it in full.

Terms are listed alphabetically under letter headings, and each definition is at most 60 words. Where a term has a canonical spelling in the style guide (§8), that spelling is used here and everywhere in the book. A term taken from a law, a standard or a paper carries a [n] citation to its source; a term the book coins carries none, and its chapter is its source. Legal definitions are paraphrased, and the cited text governs. "Contrast with" names the terms it is most often confused with, "See" links the section that develops it, and the parenthesis lists the chapters that treat it. Every term also has its own page, linked from its name, with its sources, the chapters that use it and a ready-made citation.

Commonly confused pairs

Ten pairs are confused often enough in reviews to be worth fixing in a team's vocabulary. Each term's page carries the same comparison.

Pair	The difference	Why it matters for controls
Transparency and explainability	What happened, from records of what ran, against how one decision was made	Two artefacts: registry, cards and logs for the first; an explanation method with a fidelity test for the second
Data provenance and data lineage	Where the data came from and on what terms, against the path it took through your own pipelines	Perfect lineage over unknown provenance is still ungoverned; erasure and disgorgement need both
Data drift and concept drift	The inputs change, against the relationship between inputs and the right answer changing	The first shows in input monitors before labels arrive; the second only in outcomes on fresh labels
AI incident and issue (versus incident)	Harm has happened, against a defect or deviation that has not produced a harmful event	Incidents start reporting clocks and CAPA; issues go to a tracked backlog with an owner and a due date
Provider and deployer	Develops the system and places it on the market under its own name, against uses it under its own authority	Different duties and different evidence; a substantial modification can turn a deployer into the provider
Human-in-the-loop (HITL) and human-on-the-loop (HOTL)	A person approves each consequential decision, against a person monitors and can stop the system	HITL is evidenced by approval logs and override rates; HOTL by alerting and a tested stop path
Risk appetite and risk tolerance	How much risk the organisation will take on overall, against the residual band one system may carry	Appetite is a board statement compiled to data; tolerance is the threshold a deploy gate reads
Model card and system card	One model's documentation, against the deployed system's: models, prompts, retrieval, tools, guardrails and oversight	Deployers and authorities need the system view; a model card alone misses the controls around the model
Prompt injection and jailbreak	Any input that alters behaviour in unintended ways, direct or hidden in processed content, against inputs aimed at dropping the safety rules	Jailbreak evals test refusals; injection also needs least-privilege tools and isolation of untrusted content
Pseudonymisation and anonymous data	Re-attributable with separately kept information, so still personal data, against not relating to an identifiable person at all	Pseudonymised data keeps every GDPR duty; an anonymity claim needs a dated assessment

A

A2A (Agent2Agent protocol). An open protocol for agents to hand tasks to one another, at version 1.0 since March 2026 [129] and a Growth Stage project of the Linux Foundation-directed Agentic AI Foundation since August 2026 [130]. Servers must authenticate every request, but authorisation, and the scope and revocation of authority granted mid-task, are left to the implementer [129]. Contrast with MCP. See [ch. 23, Multi-agent systems and delegation chains](#). (ch. 23)

Abstention band. A range of scores in which a system does not act on its own but routes the case to a human reviewer. Its width is set by risk tier; the band size and the reviewers' override rate are monitored as signals. Conformal prediction gives one way to size it [20]. See [ch. 11, Certainty required by risk tier](#). (ch. 11)

Acceptable-use policy (AUP). The staff-facing rules for using AI tools: which tools are approved, which data classes may go where, duties to review and disclose outputs, logging, attestation before access and consequences. It is enforced through a sanctioned gateway and discovery, not the handbook alone. See [ch. 12, Acceptable use of AI by staff](#); [ch. 05, Pattern: Sanctioned AI Gateway](#). (ch. 05, 12)

Adaptiveness. The ability of an AI system to change its behaviour while in use, through learning after deployment; optional under the EU AI Act definition [21]. For governance it is one change trigger among several: most behaviour change in practice comes from vendor updates, drift, prompt edits or corpus refreshes. See [ch. 11, From definition element to registry field](#). (ch. 11)

ADMT (California). Automated decisionmaking technology under the California CCPA regulations: technology that processes personal information and uses computation to replace, or substantially replace, human decision-making. Using it for significant decisions triggers pre-use notice, opt-out or appeal, access and risk-assessment duties [22]. Contrast with [Automated decision-making \(ADM\)](#). See [ch. 19, United States](#). (ch. 19)

Adverse action notice. The notice a US creditor must give when it denies or worsens credit, stating the specific principal reasons [23]. The reasons must be accurate even when the decision comes from a complex model, so reason codes need a fidelity test. Contrast with [Decision notice](#). See [ch. 20, Credit and lending](#). (ch. 16, 20)

Adverse-impact ratio (AIR). The selection rate of a group divided by the selection rate of the most-selected group. Under the US Uniform Guidelines a ratio below four-fifths is generally treated as evidence of adverse impact [24]; engineering practice reads it as a trigger for investigation, reported with counts and a confidence interval. See [ch. 16, The four-fifths rule and the adverse-impact ratio](#). (ch. 16)

AESIA. Spain's Agencia Española de Supervisión de Inteligencia Artificial, a state agency based in A Coruña whose statute was approved by Royal Decree 729/2023, created to act as Spain's national supervisory authority for the AI Act [1]. See [ch. 21, Spain: AESIA, the sandbox and a bill](#). (ch. 08, 21)

Agent (agentic AI). An AI system that acts (browses, executes code, calls APIs, moves data or delegates to other agents) under delegated authority, rather than only producing text. Agents are the hardest object to govern because their behaviour is emergent and their actions have external effects. See [ch. 23, What makes an agent a governance object](#); [ch. 11, Agentic systems](#). (ch. 01, 11, 23)

Agent Card. The JSON document an A2A agent publishes, usually at `/.well-known/agent-card.json`, describing its identity, skills, service endpoint and the authentication schemes it accepts. It can be signed with JWS over a canonicalised form, so a client can check that the card is untampered and comes from the claimed provider [129]. A peer allow-list admits only registered agents with verified cards. See [ch. 23, Multi-agent systems and delegation chains](#). (ch. 23)

Agent registry. The runtime-aware inventory of every non-human actor (model, service and agent), each with an owner, a declared scope, a status and a kill switch, fed by a runtime data path rather than typed by hand. It is the artefact that answers "what AI is running?". See [ch. 23, The agent registry](#); [ch. 05, Pattern: Agent Registry](#). (ch. 04, 05, 06, 23)

AI Act (EU). Regulation (EU) 2024/1689, the EU's horizontal, risk-tiered law for AI, amended by the Digital Omnibus [2]. It classifies systems by risk (prohibited, high-risk, limited, minimal) and imposes obligations accordingly. See [ch. 18, The Act and the Omnibus](#). (ch. 08, 18)

AI business operator (Korea). Under the Korean AI Basic Act, a legal person, organisation, individual or state body doing AI business, split into development business operators, who develop and provide AI, and utilisation business operators, who offer products or services built on it [25]. See [ch. 18, The same roles across regimes](#). (ch. 18, 21)

AI governance committee. The cross-functional body that takes the decisions a gate cannot: accepting residual risk above a product owner's authority, granting exceptions, weighing value trade-offs and approving the policy set. It decides; the pipeline's gates enforce its decisions and record the evidence. US federal agencies run such boards by mandate [26]. See [ch. 12, The committee decides, the gates enforce](#). (ch. 12)

AI governance engineer. The person who holds the capability of AI governance engineering and is accountable for the three questions in production; a capability and a role, not necessarily a job title. See [ch. 06, Capability first, title second](#). (ch. 06)

AI governance engineering. The application of engineering practice (systems thinking, product thinking and code) to the governance of AI systems; measured by realised risk reduction and audit-ready evidence. Contrast with [Trustworthy AI](#). See [ch. 01, The definition](#). (ch. 01)

AI harm. A negative consequence of building or using an AI system for a person, a group, an organisation, society or the environment. The book names each harm by the level it lands on, its mechanism, a testable failure mode and the control that catches it, mapped to the MIT AI Risk Repository taxonomy [27]. See [Harms atlas](#). (ch. 03)

AI hazard. In the OECD's definition, an event or series of events where the development, use or malfunction of an AI system could plausibly lead to an AI incident [28]. A hazard is harm that has not happened yet; a near miss is a hazard a control interrupted. Contrast with [AI incident](#). See [ch. 17, Incident, hazard, issue and serious incident](#). (ch. 17)

AI incident. In the OECD's definition, an event or series of events where the development, use or malfunction of one or more AI systems directly or indirectly leads to harm to health, critical infrastructure, human or fundamental rights, property, communities or the environment [28]. Contrast with [Issue \(versus incident\)](#), [AI hazard](#) and [Serious incident](#). See [ch. 17, Incident, hazard, issue and serious incident](#). (ch. 17)

AI literacy. Under the EU AI Act, the skills, knowledge and understanding that let providers, deployers and affected persons use AI in an informed way and grasp its opportunities, risks and possible harm. Article 4, as amended in 2026, requires providers and deployers to take measures to support it, without guaranteeing any individual level [2]. See [ch. 18, AI literacy and bias-detection data](#); [ch. 12, AI literacy as code](#). (ch. 12, 18)

AI Office. The European Commission body that supervises general-purpose AI and coordinates AI Act enforcement, with investigation powers and the ability to levy penalties on GPAI providers [2]. See [ch. 18, Who supervises what](#). (ch. 08, 18)

AI regulatory sandbox. Under the EU AI Act, a controlled framework set up by a competent authority in which providers develop, train, test and validate innovative AI systems for a limited time under a sandbox plan, possibly with real-world testing. Each Member State must have one operational by 2 Aug 2027 [2]. Contrast with [Testing in real-world conditions](#). See [ch. 18, Sandboxes and real-world testing](#). (ch. 18, 21)

AI RMF functions. The four core functions of the NIST AI Risk Management Framework (**Govern, Map, Measure, Manage**), used throughout the book as a mapping target for controls [3]. See [ch. 22, The Core: 19 categories](#). (ch. 08, 22)

AI RMF Playbook. NIST's online companion to the AI RMF. For each subcategory it gives an About note, suggested actions, transparency and documentation questions and references [29]. It is voluntary material to tailor, not a checklist; its documentation questions work well as acceptance criteria. See [ch. 22, How a Playbook entry is structured](#). (ch. 22)

AI RMF profile. An application of the AI RMF Core to a context. NIST describes use-case profiles, temporal profiles (a current and a target profile whose gap guides the work) and cross-sectoral profiles such as NIST AI 600-1 for generative AI [30]. See [ch. 22, Profiles and the Generative AI Profile](#). (ch. 22)

AI system. For governance, the object the AI definition brings into scope. Under the EU AI Act, a machine-based system designed to operate with some autonomy, possibly adaptive after deployment, that infers from its input how to generate outputs that can influence physical or virtual environments [2][21]. Inference separates it from rule-based software. See [ch. 11, Four definitions, compared](#); [ch. 18, What counts as an AI system](#). (ch. 11, 18)

AI system impact assessment. An assessment of how an AI system and its foreseeable applications may affect individuals, groups and society, performed across the lifecycle and updated as needed; ISO/IEC 42005:2025 gives the guidance [17]. Contrast with [FRIA](#). See [ch. 14, Impact assessments compared](#). (ch. 14)

AI system lifecycle (OECD). The OECD's iterative phases of an AI system: plan and design; collect and process data; build or adapt models; test, evaluate, verify and validate; deploy; operate and monitor; retire or decommission [31]. Retirement can happen at any point during operation. See [ch. 22, The OECD AI system definition and lifecycle](#). (ch. 22)

AI washing. Overstating or inventing the use or capability of AI in marketing or investor communications. US regulators treat it as deception; the SEC settled charges against two investment advisers over such claims in March 2024 [32]. See [ch. 20, Unfair and deceptive practices in the United States](#); [ch. 05, Pattern: Claims Substantiation Gate](#). (ch. 05, 20)

AIBOM. AI bill of materials: the machine-readable inventory of an AI system's components (models, datasets, dependencies) in formats such as CycloneDX ML-BOM or the SPDX 3.0 AI profile. See [ch. 05, Pattern: AIBOM](#). (ch. 04, 05)

AICM. The CSA AI Controls Matrix, a control framework (v1.1, 247 control objectives across 18 domains) that maps to ISO 42001, ISO 27001 and NIST AI RMF and underpins STAR for AI [4]. See [ch. 08, CSA AICM and STAR for AI](#). (ch. 08)

AIMA. The OWASP AI Maturity Assessment, reported at v1.0 (Aug 2025), which scores the breadth of an AI security and governance programme across domains [5]. See [ch. 07, How this relates to certification and other assessments](#). (ch. 07)

AIMS. An AI management system: the governance structure, roles, controls and continual-improvement loop that ISO/IEC 42001 certifies. An AIMS is not the AI Act's Article 17 quality management system. Contrast with [QMS \(Art. 17\)](#). See [ch. 22, The management-system trio](#). (ch. 07, 08, 22)

Algorithmic disgorgement. A remedy that orders deletion of models or algorithms developed with unlawfully obtained data, not only the data itself [33]. Complying, and proving it, requires lineage from each dataset to every model trained on it. See [ch. 20, Claims substantiation and algorithmic disgorgement](#); [ch. 05, Pattern: Training-Data Rights Ledger](#). (ch. 05, 20)

Algorithmic Impact Assessment (AIA). The assessment Canada's Directive on Automated Decision-Making requires before a federal automated decision system goes into production. It sets an impact level from I to IV that scales the required safeguards, is published on the Open Government Portal and is updated when the system changes [34]. See [ch. 21, Canada: after AIDA, the Directive on Automated Decision-Making](#); [ch. 14, Impact assessments compared](#). (ch. 14, 21)

Algorithmic management. The use of automated monitoring and decision systems to direct, evaluate or sanction workers. The EU Platform Work Directive limits the data such systems may process and requires transparency, human oversight and a right to human review [35]. See [ch. 20, Employment](#). (ch. 20)

Algorithmic Transparency Recording Standard (ATRS). The UK's standard template for public-sector bodies to publish how and why they use algorithmic tools; mandatory for government departments and for arm's-length bodies that deliver public or frontline services [36]. See [ch. 21, United Kingdom: principles, regulators and public-sector records](#). (ch. 21)

ALTAI. The Assessment List for Trustworthy AI, published by the EU High-Level Expert Group on AI in July 2020: a self-assessment checklist that turns the seven requirements of the 2019 Ethics Guidelines into questions [37]. Useful as a source of candidate controls; answered once, it is only an attestation. See [ch. 22, EU HLEG guidelines and ALTAI](#). (ch. 11, 22)

Annex I (EU AI Act). The AI Act annex listing the Union harmonisation legislation under which AI is embedded in regulated products (machinery, medical devices, toys and the like); obligations for these high-risk embedded systems phase in from 2 August 2028 under the Digital Omnibus timeline [2]. Contrast with [Annex III](#). See [ch. 18, High-risk through products \(Annex I\)](#). (ch. 08, 18)

Annex III. The AI Act annex listing high-risk use cases (biometrics, critical infrastructure, education, employment, essential services, law enforcement, migration, justice); obligations for these phase in under the Digital Omnibus timeline [2]. Contrast with [Annex I \(EU AI Act\)](#). See [ch. 18, High-risk through use \(Annex III\)](#). (ch. 08, 18)

Anonymous data. Information that does not relate to an identifiable person, judged against all the means reasonably likely to be used by anyone to identify them [38]. It falls outside the GDPR, but the claim decays as auxiliary data and re-identification techniques improve, so it needs a dated assessment. Contrast with [Pseudonymisation](#). See [ch. 19, Anonymisation versus pseudonymisation](#). (ch. 19)

Article 6(3) filter. The derogation under which an Annex III system is not high-risk when it poses no significant risk of harm and meets one of four conditions (narrow procedural task, improving completed human work, detecting patterns, preparatory task). Profiling of natural persons always defeats it; the provider documents and registers the assessment [2]. Contrast with [Profiling override](#). See [ch. 18, The Annex III filter and the profiling override; Toolkit: EU AI Act role and risk-class triage](#). (ch. 18)

ASI01–ASI10. The ten risks of the OWASP Top 10 for Agentic Applications 2026 [6]: ASI01 Agent Goal Hijack, ASI02 Tool Misuse and Exploitation, ASI03 Identity and Privilege Abuse, ASI04 Agentic Supply Chain Vulnerabilities, ASI05 Unexpected Code Execution (RCE), ASI06 Memory & Context Poisoning, ASI07 Insecure Inter-Agent Communication, ASI08 Cascading Failures, ASI09 Human-Agent Trust Exploitation and ASI10 Rogue Agents. See [ch. 23, Threats mapped to controls](#); [ch. 08, OWASP GenAI Security Project](#). (ch. 05, 08, 23)

ATLAS. MITRE's Adversarial Threat Landscape for Artificial-Intelligence Systems, a knowledge base of adversary tactics and techniques against AI, including agent-specific techniques [7]. See [ch. 15, Threat modelling the deployed system](#); [ch. 23, Threats mapped to controls](#). (ch. 05, 10, 15, 23)

Audit-ready evidence. Evidence emitted as a by-product of the build in a form an auditor can read directly (machine-readable, signed, timestamped), so the audit is a query, not a collection project. See [ch. 01, Three clarifiers](#). (ch. 01, 04)

Authorised representative. Under the EU AI Act, a person established in the Union with a written mandate from a non-EU provider of a high-risk AI system or general-purpose AI model to carry out that provider's obligations on its behalf, including keeping documentation available to authorities [2]. See [ch. 18, The EU operator roles](#). (ch. 18)

Automated decision-making (ADM). A decision about a person taken by automated means. GDPR Article 22 restricts decisions based solely on automated processing with legal or similarly significant effects [38]; after the SCHUFA judgment, a score that lenders treat as determining is itself such a decision [39]. See [ch. 19, GDPR Article 22 after SCHUFA](#). (ch. 16, 19)

Automation bias. The tendency of a person to over-rely on an automated system's output. EU AI Act Article 14 asks that people overseeing high-risk systems stay aware of it [2]; the human gate logs approver, time to decide and override rate so that degrading oversight is visible. See [ch. 11, Certainty required by risk tier](#); [ch. 04, Designing human oversight \(Article 14\)](#); [ch. 23, What a good approval looks like](#). (ch. 04, 11, 23)

Autonomy. In the EU AI Act and OECD texts, some degree of independence of action from human involvement, which almost every AI system has. ISO/IEC 22989 uses the word for a much stronger property, a system that can change its own goal or domain of use, and calls the ordinary case automation [40]. Contrast with [Autonomy level](#). See [ch. 11, ISO/IEC 22989](#). (ch. 11, 23)

Autonomy level. How far an agent acts without a person between its steps, set by the deployer as a design decision rather than taken as a property of the model; one research scale names five levels by the user's role, from operator to observer [122]. It is a registry field tied to a minimum control set, and raising it is a reviewed change. Contrast with [Autonomy](#). See [ch. 23, Autonomy is a design decision](#). (ch. 15, 17, 23)

B

Bias. A systematic error that favours or disadvantages some people or outcomes. NIST sorts AI bias into three categories: systemic, statistical and computational, and human [41]. Bias can enter at any lifecycle stage, so it is tested per stage rather than once. Contrast with [Fairness](#). See [ch. 16, Where bias enters the lifecycle](#). (ch. 16)

Bias audit (NYC Local Law 144). An independent audit, required within the year before an employer uses an automated employment decision tool in New York City, that reports selection or scoring rates and impact ratios by sex, race and ethnicity and their intersections; its summary must be published [42]. See [ch. 20, Employment](#); [ch. 14, Impact assessments compared](#). (ch. 14, 20)

Biometric data. Personal data from the technical processing of physical, physiological or behavioural traits that allows or confirms a person's unique identification, such as facial images or fingerprints [38]. Identification, verification and categorisation are treated differently across the GDPR, the AI Act and other laws. See [ch. 19, Biometrics](#). (ch. 19)

Blameless post-mortem. An incident review that identifies contributing causes without indicting any individual or team, on the premise that people acted reasonably on what they knew and that systems and processes are what can be fixed [43]. Its triggers are set in advance. See [ch. 17, Techniques](#). (ch. 17)

Blue-green deployment. Two identical production environments with traffic switched between them, so a release can be rolled back by switching back [44]. It gives an AI system a tested, instant path to the previous version. Contrast with [Canary release](#). See [ch. 15, Progressive delivery as a control](#); [ch. 05, Pattern: Staged Rollout with Rollback Criteria](#). (ch. 05, 15)

Build provenance (SLSA). A verifiable record, in the SLSA format, of what built an artefact, by what process and from which top-level inputs. Its build levels run from L1, provenance exists, through L2, signed by a hosted build platform, to L3, hardened builds whose provenance is very hard to forge [136]. For a model, inputs include the base model's digest and dataset admission records. Contrast with [Model signing](#). See [ch. 05, Pattern: Model Artefact Integrity](#). (ch. 05)

C

CAC (Cyberspace Administration of China). China's internet regulator (国家互联网信息办公室), lead issuer of the binding AI rules (algorithmic recommendation, deep synthesis, generative AI services and AI-content labelling) and the body under whose guidance TC260 publishes the AI Safety Governance Framework [18]. See [ch. 21, China: what chapter 08 does not already cover](#). (ch. 08, 21)

Calibration. The property that a model's confidence matches its accuracy: of the cases scored 0.9, about nine in ten are right. Modern neural networks are often poorly calibrated [45], so calibration is measured in the eval gate per version and subgroup before any threshold is trusted. Contrast with [Calibration within groups](#). See [ch. 11, Calibration before thresholds](#). (ch. 11)

Calibration within groups. The fairness property that, in every group, the people given a score s turn out positive at rate s , so a score means the same thing for everyone. It generally conflicts with equal error rates when base rates differ [46]. Contrast with [Calibration](#) and [Equalised odds](#). See [ch. 16, The impossibility results](#). (ch. 16)

Canary release. A partial, time-limited deployment of a change to a small share of production traffic, evaluated against a control group before the rollout continues [47]. For AI systems the evaluation compares live quality, safety and fairness metrics with pre-registered rollback criteria. Contrast with [Shadow deployment](#) and [Blue-green deployment](#). See [ch. 15, Progressive delivery as a control](#); [ch. 05, Pattern: Staged Rollout with Rollback Criteria](#). (ch. 05, 14, 15, 23)

CAPA. Corrective and preventive action, the output of an incident review. The corrective action fixes this instance; the preventive action stops the class of failure recurring across the fleet, typically as a regression eval, a policy change and a risk-register update, verified before the incident closes [48]. See [ch. 17, CAPA: from incident to risk register and eval suite](#). (ch. 17)

Catastrophic forgetting. The tendency of neural networks to lose earlier competence when trained on new tasks [49]. It is a reason every retraining is a change event that re-runs the full eval suite, not only the tests for the new capability. See [ch. 11, Eight characteristics that break classic IT governance](#). (ch. 11)

Catastrophic-severity override. The rule that any scenario rated at the top severity level is Critical whatever its likelihood, cannot be accepted by the delivery team, and must be eliminated, reduced in severity or accepted explicitly by the governing body for a fixed period. NIST asks that such risks can be ceased safely [30]. See [ch. 13, The catastrophic-severity override](#). (ch. 13)

CE marking. The mark showing a high-risk AI system's conformity with the EU AI Act, affixed visibly, legibly and indelibly, or digitally for systems provided digitally, with the notified body's number where one was involved [2]. Contrast with [EU declaration of conformity](#). See [ch. 18, Conformity assessment, declaration, marking and registration](#); [ch. 14, EU AI Act conformity, in order](#). (ch. 14, 18)

Cedar. An open-source policy language for fine-grained authorization, used as a policy-as-code engine for runtime access decisions; a schema-typed, analysable alternative to [OPA/Rego](#). Contrast with [OPA/Rego](#). See [ch. 06, Policy-as-code and gates](#). (ch. 04, 05, 06)

CEN-CENELEC JTC 21. The joint technical committee of the European standardisation organisations CEN and CENELEC that drafts the AI Act harmonised standards, including EN 18286 on quality management and the drafts on risk management, trustworthiness and cybersecurity [50]. See [ch. 22, The JTC 21 programme](#). (ch. 22)

CIMD. Client ID Metadata Document: the mechanism by which an OAuth client identifies itself with a URL, used as its client ID, that points to its metadata document. The MCP specification of 2026-07-28 has clients and authorisation servers support it and deprecates Dynamic Client Registration [8]; the IETF specification is still an Internet-Draft (revision 02, 6 Jul 2026) as of 2026-09-24 [132]. See [ch. 23, MCP authorization as of 2026-07-28](#); [ch. 04, Layer 04: Runtime Controls & Observability](#). (ch. 04, 05, 23)

Claims register. The record of every public statement about an AI system's accuracy, fairness, safety or capability: the exact wording, where it appears, and the eval run, measured value, interval and population behind it. Copy carrying a claim whose evidence is missing, stale or failing is not published; the FTC requires competent and reliable evidence for such claims when they are made [139]. See [ch. 20, Claims substantiation and algorithmic disorgement](#); [ch. 05, Pattern: Claims Substantiation Gate](#). (ch. 05, 20)

Classification decision record. A versioned registry record of why a system sits on a given rung of the AI Act risk ladder: the Annex III point, any Article 6(3) condition relied on, an explicit profiling flag, the reviewer and the date [2]. It is re-evaluated whenever the intended purpose changes. Contrast with [Profiling override](#). See [ch. 18, The Annex III filter and the profiling override; Toolkit: EU AI Act role and risk-class triage](#). (ch. 18)

Common specifications. Technical specifications the Commission may adopt by implementing act under AI Act Article 41 when a standardisation request is not accepted, the standards are late or they insufficiently address fundamental-rights concerns;

conforming with them also gives a presumption of conformity [2]. Contrast with [Harmonised standard](#). See [ch. 22, How presumption of conformity works](#). (ch. 22)

Concept drift. A change in the relationship between a system's inputs and the correct output, so the same input should now get a different answer [51]. Unlike data drift, it shows only in outcomes: in production it appears in performance on fresh labels and in change-point tests on the error rate. Contrast with [Data drift](#). See [ch. 11, Contrast pairs](#); [ch. 15, Drift: what moves and how to see it](#). (ch. 11, 15)

Conformal prediction. A distribution-free method that turns a trained model's output into a set of candidate answers that contains the right one with a chosen probability [20]. A large set signals uncertainty that a governance rule can route on. See [ch. 11, Calibration before thresholds](#). (ch. 11)

Conformity assessment. The procedure by which a provider shows a high-risk AI system meets the EU AI Act before placing it on the market: internal control for most Annex III systems, a notified body for some biometric systems, and the sectoral procedure for Annex I products [2]. It precedes the declaration, CE marking and registration. See [ch. 18, Conformity assessment, declaration, marking and registration](#); [ch. 14, EU AI Act conformity, in order](#). (ch. 14, 18)

Content provenance (C2PA). Signed, tamper-evident information about where a piece of content came from and how it was edited, bound to the asset. The C2PA specification packages it as a manifest of assertions, a claim and a claim signature [52]; NIST treats provenance tracking as one approach to synthetic-content transparency [53]. Contrast with [Watermarking](#) and [Data provenance](#). See [ch. 20, Deepfakes and synthetic media](#). (ch. 18, 20)

Contest path. The route by which a person affected by an automated decision reaches a reviewer who did not take the original decision, sees the inputs, the reasons and the person's representations, and can change the outcome, with the result written back to the decision record. It is how the right to contest in GDPR Article 22(3) is honoured in practice [38]. Contrast with [Contestability](#). See [ch. 19, GDPR Article 22 after SCHUFA](#); [ch. 05, Pattern: Decision Notice & Contest Path](#). (ch. 05, 19, 22)

Contestability. The ability of a person affected by an AI-supported decision to challenge it and obtain a response that can change it. GDPR Article 22(3) gives a right to contest solely automated decisions [38], and the OECD principles ask that people adversely affected can challenge an output [31]. Contrast with [Recourse](#) and [Contest path](#). See [ch. 16, The legal hooks for explanations](#); [ch. 05, Pattern: Decision Notice & Contest Path](#). (ch. 05, 12, 16)

Continuous assurance. Assurance produced continuously from telemetry rather than at a point in time; the control's status is a live query, not an annual sign-off. It is Level 5 of the maturity model. See [ch. 05, Pattern: Continuous Assurance Telemetry](#). (ch. 04, 05, 07)

Contributing factor. A property of a system or its context (autonomy, exposure, reversibility, vulnerable groups, data sensitivity, opacity) that moves the likelihood or severity of a risk without creating it [30]. It is captured as registry fields at intake so a policy can compute the tier. Contrast with [Risk source](#). See [ch. 13, Contributing factors and the use-case risk profile](#). (ch. 13)

Controller and processor. Under the GDPR the controller decides the purposes and means of processing and carries most duties; the processor acts on its documented instructions [38]. An AI vendor serving your inference is usually a processor, but becomes a controller for any use of your data it decides on, such as training. Contrast with [Sub-processor](#). See [ch. 19, Controller, processor or joint controller](#). (ch. 19)

Counterfactual explanation. An explanation that states the smallest change to the input that would have changed the outcome, restricted to features the person can actually change [54]. It is the natural basis for recourse. Contrast with [Counterfactual fairness](#). See [ch. 16, Counterfactual explanations](#). (ch. 16)

Counterfactual fairness. The requirement that a decision about an individual be the same in a counterfactual world where the individual belonged to a different group, defined through a causal model [55]; approximated in practice by counterfactual flip tests. Contrast with [Counterfactual explanation](#) and [Counterfactual flip test](#). See [ch. 16, Individual and counterfactual fairness](#). (ch. 16)

Counterfactual flip test. A test that changes only a protected attribute in an input, or swaps identity terms in otherwise identical prompts, and measures how often the outcome or the answer quality changes. It is the practical approximation of counterfactual fairness [55] and runs in the fairness eval suite. Contrast with [Counterfactual fairness](#). See [ch. 16, Individual and counterfactual fairness](#); [ch. 05, Pattern: Fairness Eval Suite](#). (ch. 05, 16)

D

Data card. Structured, versioned documentation of a dataset (provenance, lawful basis, rights, composition and known limitations) maintained as code alongside the system. Contrast with [Datasheet for datasets](#). See [ch. 04, Data governance across the stack](#). (ch. 04)

Data drift. A change in the distribution of the inputs a system sees in production relative to the data it was validated on, such as a new customer segment or a changed upstream form [51]. It shows in the inputs before any label arrives, so it is monitored directly. Contrast with [Concept drift](#). See [ch. 11, Contrast pairs](#). (ch. 11, 15)

Data lineage. The record of how data moved and changed through an organisation's pipelines. Backward lineage shows what fed a model; forward lineage shows which models used a dataset, which erasure requests and licence withdrawals need. OpenLineage is an open standard for emitting it [56]. Contrast with [Data provenance](#). See [ch. 14, Provenance versus lineage](#). (ch. 14)

Data minimisation. The GDPR principle that personal data must be adequate, relevant and limited to what the purpose needs [38]. For AI it is argued feature by feature, applied to training snapshots, retrieval indexes, logs and eval sets, and evidenced by feature justifications and filter logs. See [ch. 19, Minimisation, privacy by design and PETs](#). (ch. 19)

Data provenance. Information about the entities, activities and people involved in producing data, used to judge its quality and trustworthiness [57]. In practice: where a dataset originally came from and on what terms (source, licence, lawful basis). Perfect lineage over unknown provenance is still ungoverned. Contrast with [Data lineage](#). See [ch. 14, Provenance versus lineage](#); [ch. 12, Updating the policies you already have](#). (ch. 12, 14)

Dataset admission gate. A pipeline control that lets a training job read only datasets whose admission record is complete and signed by the data owner: lawful basis or licence, reservation checks, quality results, provenance, permitted uses and retention. It evidences the data-governance practices of AI Act Article 10 [2]. See [ch. 14, Owners, stewards and the admission gate](#); [ch. 05, Pattern: Dataset Admission Gate](#). (ch. 05, 14)

Datasheet for datasets. Documentation that accompanies a dataset with its motivation, composition, collection process, preprocessing, uses, distribution and maintenance, as proposed by Gebru and colleagues [58]; the human-readable companion to the dataset admission record and the data card. Contrast with [Data card](#). See [ch. 14, Model cards, system cards and datasheets](#). (ch. 14)

Decision notice. The notice a person receives at the point of an automated or AI-assisted decision, rendered from a versioned template and the decision record: that a system was used, the principal reasons and what the person can do by when. Content follows each regime, such as notice of use under AI Act Article 26(11) or reasons under US Regulation B [2][23]. Contrast with [Adverse action notice](#). See [ch. 18, Deployer duties \(Article 26\)](#); [ch. 05, Pattern: Decision Notice & Contest Path](#). (ch. 05, 08, 18)

Decision threshold. The score above or below which an AI output triggers an action. It is where risk appetite becomes behaviour, so it is governed as a policy with an owner, version and effective date, tested in the eval gate and logged with every decision; the AI Act asks for declared accuracy metrics [2]. See [ch. 11, A score is not a decision](#). (ch. 11)

Decommissioning. The planned retirement of an AI system: dependency analysis, fallback and transition, sunset notices, a final evidence snapshot, archive or disposal of weights and data, revocation of every identity, and a registry entry marked retired rather than deleted. NIST asks that systems be phased out safely [29]. See [ch. 15, Retirement and decommissioning](#); [ch. 05, Pattern: Deactivation, Localisation & Retirement Runbook](#). (ch. 05, 15)

Deepfake. Under the EU AI Act, a deep fake is AI-generated or manipulated image, audio or video content that resembles existing persons, objects, places, entities or events and would falsely appear to a person to be authentic; deployers must disclose it, with lighter duties for evident art or satire [2]. Contrast with [Content provenance \(C2PA\)](#). See [ch. 20, Deepfakes and synthetic media](#); [ch. 18, Transparency cases \(Article 50\)](#). (ch. 18, 20)

Delegation (OAuth token exchange). In RFC 8693, the mode in which one party acts for another while both stay identifiable: the token names the subject and, in its act claim, the current actor, with nested act claims for earlier actors [123]. Under impersonation the actor becomes indistinguishable from the subject. An agent should hold a delegated, narrower token, never the user's own. Contrast with [Delegation chain](#) and [Token passthrough](#). See [ch. 23, Delegation without impersonation](#). (ch. 23)

Delegation chain. The sequence of agents a task passes through from the person or system that started it. It is governed so that each hop authenticates as itself, scope narrows or stays equal but never widens, the purpose travels with the task, depth and fan-out are bounded, and one trace spans every hop. Contrast with [Delegation \(OAuth token exchange\)](#). See [ch. 23, Accountability across hops](#). (ch. 23)

Demographic parity. A group fairness criterion that holds when the rate of positive decisions is equal across groups; the adverse-impact ratio is its ratio form. It ignores differences in base rates [59]. Contrast with [Equalised odds](#). See [ch. 16, Group fairness metrics](#). (ch. 16)

Deployer. Under the EU AI Act, whoever uses an AI system under its own authority, other than in a purely personal, non-professional activity [2]. For high-risk systems it follows the instructions for use, staffs oversight, monitors, keeps logs, informs affected people and, in listed cases, performs the FRIA. The label names a task, not a kind of organisation. Contrast with [Provider](#). See [ch. 18, The EU operator roles](#); [ch. 18, Deployer duties \(Article 26\)](#). (ch. 15, 18)

Deployment Decision Record (DDR). The artefact that records the decision to deploy an AI system: objective, the people it acts on, negative space, risk tier and obligations, per-group performance floors, retirement conditions, owner and approver. It is committed with the system's code; its floors become eval-gate thresholds. See [ch. 15, The Deployment Decision Record](#). (ch. 15)

Design defect. In product liability, a defect inherent in the design of every unit, judged by consumer expectations or by weighing risk against utility [60]. For AI: untested operating conditions, a missing guardrail or missing oversight where a safer alternative was reasonably available. Contrast with [Manufacturing defect](#). See [ch. 20, Defect types mapped to AI failure modes](#). (ch. 20)

Differential privacy. A mathematical guarantee that bounds how much any single person's record can change the output of an analysis or a trained model, tuned by a privacy budget. Its strength depends on the budget and on implementation choices that NIST calls privacy hazards [61]. See [ch. 19, Privacy-enhancing technologies and their honest limits](#). (ch. 19)

Digital Omnibus. The 2026 reform package amending the EU AI Act (in force 27 Jul 2026), which adjusted the high-risk timeline, added AI Office investigation powers and reworked several articles [2]. See [ch. 18, The Act and the Omnibus](#). (ch. 08, 18)

Disparate impact. A facially neutral practice that falls harder on a protected group. Under US Title VII the employer must show the practice is job related and consistent with business necessity, and loses if it refuses a less discriminatory alternative [62]. The

EU counterpart is indirect discrimination. Contrast with [Disparate treatment](#) and [Indirect discrimination](#). See [ch. 16, Disparate treatment and disparate impact](#); [ch. 20, Disparate treatment, disparate impact and proxies](#). (ch. 16, 20)

Disparate treatment. Treating a person less favourably because of a protected characteristic such as race, sex or age, including through a feature or rule that deliberately stands in for it [62]. The EU counterpart is direct discrimination [63]. Contrast with [Disparate impact](#). See [ch. 16, Disparate treatment and disparate impact](#); [ch. 20, Disparate treatment, disparate impact and proxies](#). (ch. 16, 20)

Distributor. Under the EU AI Act, a person in the supply chain, other than the provider or the importer, who makes an AI system available on the Union market. It checks the marking and documents and holds back high-risk systems it believes do not conform [2]. Contrast with [Importer](#). See [ch. 18, The EU operator roles](#). (ch. 18)

Domestic representative (Korea). A person with an address or office in Korea whom a foreign AI business operator above thresholds set by decree must designate in writing. It submits safety results, files high-impact confirmation requests and supports the high-impact measures [25][64]. See [ch. 21, Domestic representative](#). (ch. 21)

Downstream modifier (GPAI). An actor that fine-tunes or otherwise modifies a general-purpose AI model that someone else placed on the market. The Commission treats it as the provider of the modified model only when the modification uses more than one third of the original training compute, and limits its documentation, copyright-policy and training-summary duties to the modification; if the original model has systemic risk, the modified model is presumed to have it too, with the systemic-risk duties [65][76]. Contrast with [Downstream provider](#). See [ch. 15, When a deployer becomes a provider](#); [ch. 18, When a fine-tuner becomes a GPAI provider](#). (ch. 15, 18)

Downstream provider. Under the EU AI Act, the provider of an AI system that integrates an AI model, its own or one supplied by another entity. It relies on the model information that general-purpose AI model providers must hand downstream [2]. Contrast with [Downstream modifier \(GPAI\)](#). See [ch. 18, The EU operator roles](#). (ch. 18)

Downstream use register. The record of every consumer of an AI system's outputs (a system, team, partner or training pipeline), each with its approved use, the re-test that cleared the outputs for that context and any contract, held against the producing system's registry entry. Access is granted per registered consumer, and a model change or retirement is notified to all of them. See [ch. 15, Secondary use and downstream harm](#); [ch. 05, Pattern: Downstream Use Register](#). (ch. 05, 15)

DPIA. Data Protection Impact Assessment: the GDPR Article 35 assessment of processing likely to result in high risk to individuals [38], maintained in this discipline as a versioned artefact, not a one-off document. Contrast with [FRIA](#). See [ch. 19, The DPIA for AI systems](#). (ch. 04, 05, 19)

Drift. The gradual divergence of a model's inputs, outputs or performance from its validated baseline over time; a runtime signal that a control or eval must catch. The two kinds to tell apart are data drift, in the inputs, and concept drift, in the input-to-answer relationship. Contrast with [Data drift](#) and [Concept drift](#). See [ch. 15, Drift: what moves and how to see it](#); [ch. 05, Pattern: Drift & Fairness Monitor](#); [ch. 17, AI-specific failure modes](#). (ch. 04, 05, 11, 15, 16, 17)

Dual use. The capacity of the same AI capability to serve harmful ends as well as legitimate ones, for example a toxicity model inverted to propose toxic molecules [66]. It is answered with misuse threat models, red-team cases for harmful uses of legitimate capability and runtime detection. See [ch. 11, Eight characteristics that break classic IT governance](#). (ch. 11)

Duty holder. Who an obligation legally binds (under the EU AI Act, the provider, the deployer or both), as distinct from who enforces it; chapter 08 carries a duty-holder column so an engineer can tell which artefacts their organisation is responsible for producing. See [ch. 18, Who you are in the value chain](#). (ch. 08, 18)

E

Effective challenge. Critical analysis of a model by objective experts with the expertise, independence and organisational standing to force change. The term comes from US model-risk guidance, now SR 26-2 [67], and is borrowed for independent validation of AI systems. See [ch. 14, Independent validation and model risk management](#). (ch. 14)

EN 18286. The European standard for the AI Act's Article 17 quality management system, published by CEN-CENELEC in July 2026 (the first JTC 21 AI Act standard to reach publication), but not yet cited in the Official Journal as of 2026-09-24, so it confers no presumption of conformity [10]. See [ch. 22, The JTC 21 programme](#). (ch. 08, 22)

Equalised odds. A group fairness criterion that holds when true-positive and false-positive rates are both equal across groups; equal opportunity is the weaker version that equalises only true-positive rates [68]. Contrast with [Demographic parity](#). See [ch. 16, Group fairness metrics](#). (ch. 16)

EU declaration of conformity. The provider's signed statement, following AI Act Annex V, that a high-risk AI system meets the Act's requirements; drawn up after the conformity assessment and kept for 10 years [2]. Contrast with [CE marking](#). See [ch. 18, Conformity assessment, declaration, marking and registration](#). (ch. 18)

Eval gate. A pipeline stage that fails the build when an eval fails; the mechanism that turns an evaluation into an enforced control rather than a report. See [ch. 05, Pattern: Eval Gate in CI](#). (ch. 04, 05)

Eval. Automated tests of a model's or agent's behaviour (capability, safety and adversarial), run as controls, not as one-off research. See [ch. 04, Layer 03: Evals & Red Teaming as Evidence](#). (ch. 04)

Evals as evidence. The principle that the eval run is the assurance evidence: a failing eval blocks the build and its structured result is stored as proof the control fired. See [ch. 03, 2. Evals fail builds; reviews only recommend.](#) (ch. 03, 04)

Evidence record. The signed, structured record a control writes each time it decides: which control, about which system version, what it decided, against which metric, threshold and obligation, on which input, when and by whom. One shape for every control lets an audit run as a query over one store [69]. See [ch. 05, Pattern: Continuous Assurance Telemetry; Templates and schemas.](#) (ch. 05)

Exception register. A version-controlled list of approved exceptions, each tied to one rule and one system, with justification, compensating controls, approver and expiry. The policy engine reads it, so a release can pass under a live exception, the verdict says so, and the rule fails again once the exception expires. Contrast with [Risk register.](#) See [ch. 12, Risk acceptance and exceptions.](#) (ch. 12)

Explainability. In NIST's framing, a representation of the mechanisms behind a system's operation: how a decision was made [30]. In practice a per-decision explanation such as feature attributions, reason codes or a counterfactual. Contrast with [Transparency](#) and [Interpretability.](#) See [ch. 16, Transparency, interpretability and explainability;](#) [ch. 11, Contrast pairs.](#) (ch. 11, 16)

Explanation record. The evidence artefact for one explained decision: model version, explanation method and version, baseline, reason codes, counterfactual, template, audience and delivery, written at decision time so the explanation can be reproduced when a person invokes a right to explanation [2]. See [ch. 16, Explanation artefacts as evidence records;](#) [ch. 05, Pattern: Explanation Artefact.](#) (ch. 05, 16)

F

Failure posture. What a guardrail, guardian agent or tool gateway does when it cannot reach a decision: fail open lets the call through, fail closed blocks it. The reference guardian of the OWASP Agent Control Standard starts at proceed unless set to deny [127]. The posture is a governance decision, set per operation class and recorded in the agent's Policy Card. See [ch. 23, Runtime guardrails for tool calls.](#) (ch. 23)

Failure to warn. In product liability, a defect in instructions or warnings about non-obvious dangers [60]. For AI: undisclosed limitations or out-of-scope uses, which is why model cards and instructions for use are versioned with each release. See [ch. 20, Duty to warn after updates.](#) (ch. 20)

Fair use. The US copyright defence that weighs four factors: purpose and transformativeness, nature of the work, amount used and market effect [70]. Courts apply it to AI training case by case; results so far turn on how the data was acquired and on each record. Contrast with [TDM exception.](#) See [ch. 20, US training cases, dated.](#) (ch. 20)

Fairness. The property that a system's outcomes and errors do not unjustifiably disadvantage people or groups. NIST lists "fair, with harmful bias managed" among its trustworthy characteristics [30]; in practice fairness is a chosen, recorded metric (group, individual or counterfactual) with a threshold, not a general claim. Contrast with [Bias.](#) See [ch. 16, Choosing a fairness metric by use case.](#) (ch. 16)

Fairness gerrymandering. The failure in which a model satisfies a fairness constraint on each predefined group but violates it on subgroups defined by combinations of attributes [71]; the reason intersectional testing is needed. See [ch. 16, Intersectional and subgroup testing.](#) (ch. 16)

Fairness policy. The per-system record, fixed before results are seen, of what fairness means for that system: the protected attributes in each jurisdiction and where their values come from, the chosen metric and why, the threshold, the minimum cell size, the multiple-comparison correction and the approver. The fairness eval suite is judged against it. Contrast with [Fairness.](#) See [ch. 16, Fairness and explainability in the stack;](#) [ch. 05, Pattern: Fairness Eval Suite.](#) (ch. 05, 16)

Federated learning. Training a model across devices or sites where the data lives, sharing model updates instead of raw records [72]. It limits data movement but does not by itself hide personal data, because shared updates can leak training examples. See [ch. 19, Privacy-enhancing technologies and their honest limits.](#) (ch. 19)

Fine-tuning. Further training of an existing model on new data to adapt it to a task or domain. It changes the model, so it is a change event with its own evals; for general-purpose AI models, the Commission treats a modifier as a provider only above one third of the original training compute [65]. See [ch. 15, How it is adapted;](#) [ch. 18, When a fine-tuner becomes a GPAI provider.](#) (ch. 15, 18)

Foundation model. A model trained on broad data at scale and adaptable to a wide range of downstream tasks [73]. Its defects are inherited by every system built on it, so organisations that call or adapt one collect the provider's evidence and manage the pinned version as a change. Contrast with [GPAI](#) and [Frontier model.](#) See [ch. 11, Foundation models and GPAI.](#) (ch. 11)

Four-fifths rule. The US Uniform Guidelines rule of thumb that a group selection rate below 80% of the highest group's rate will generally be regarded as evidence of adverse impact, qualified by statistical and practical significance [24]. It is not a safe harbour: smaller gaps can still count. See [ch. 16, The four-fifths rule and the adverse-impact ratio;](#) [ch. 20, Fairness measures the law recognises.](#) (ch. 16, 20)

Framework Convention on AI (CETS No. 225). The Council of Europe's treaty on AI and human rights, democracy and the rule of law, opened for signature in September 2024. It binds its Parties, which decide how to reach private actors, and asks for risk and impact management and remedies [74]. See [ch. 22, Council of Europe Framework Convention \(CETS No. 225\).](#) (ch. 22)

Framework crosswalk. A mapping of one framework's controls onto another's; useful as an index, but a crosswalk proves you read the framework, not that the mapped control fires. See [ch. 05, Pattern: Framework Crosswalk](#). (ch. 05, 08)

FRIA. Fundamental Rights Impact Assessment: the AI Act Article 27 assessment of a high-risk system's impact on rights [2], maintained here as a versioned, reviewable artefact. Contrast with [DPIA](#) and [AI system impact assessment](#). See [ch. 18, Fundamental rights impact assessment \(Article 27\)](#); [ch. 05, Pattern: FRIA-as-Code](#). (ch. 04, 05, 18)

Frontier model. A general-purpose model at or near the capability frontier. Laws draw the line by training compute: California's SB 53, for example, covers models trained with more than 10^{26} operations [14]. Frontier-developer laws ask for a published safety framework and incident reporting [12]. Contrast with [Foundation model](#). See [ch. 21, Provenance, training data and frontier developers](#); [ch. 08, Frontier-developer laws](#). (ch. 08, 21)

Fulfilment record. The per-request record of how a data-subject request was honoured wherever the person's data sits, from source systems, snapshots, retrieval indexes, logs and eval sets to model weights: the action in each, the model versions affected, any scheduled retrain and whether the GDPR deadline of one month, extendable by two, was met [38]. See [ch. 19, Recording how a request was honoured](#); [ch. 05, Pattern: Rights Requests Against Models](#). (ch. 05, 08, 19)

Function creep. The gradual reuse of personal data or an AI system for purposes nobody approved, usually by configuration rather than a new release. For personal data it breaches purpose limitation unless a compatibility assessment or new basis covers the new use [38]; negative space in the deployment record makes it detectable. See [ch. 19, Purpose limitation and function creep](#); [ch. 15, Secondary use and downstream harm](#); [ch. 05, Pattern: Downstream Use Register](#). (ch. 05, 14, 15, 19)

G

Generative AI. AI that outputs new content (text, images, audio, video, code) rather than an estimate about something that exists. Its distinctive risks include confabulation, information integrity, intellectual property and abusive synthetic content [75]; its evidence is groundedness, refusal and red-team evals and content marking. Contrast with [Predictive AI](#). See [ch. 11, Predictive versus generative](#). (ch. 11)

Go/no-go decision. The signed release decision for one system version, taken by named reviewer roles against a checklist whose items each link the record that answers them. NIST frames it as the determination whether development or deployment should proceed [30]; the pipeline deploys only on a go. See [ch. 14, The go/no-go gate](#). (ch. 14)

Governance-as-code. Governance rules expressed as executable code that evaluates pull requests, deployments and runtime calls and returns a decision; the umbrella term of which policy-as-code is the CI/CD subset. Contrast with [Policy-as-code](#). See [ch. 04, Layer 01: Govern-as-Code](#). (ch. 03, 04)

GPAI. General-purpose AI model: under the AI Act, a model that shows significant generality, can competently perform a wide range of distinct tasks and can be integrated into many downstream systems [2]. The Commission's indicative criterion is training compute above 10^{23} FLOP [76]. The AI Office enforces GPAI duties from 2 Aug 2026. Contrast with [Foundation model](#). See [ch. 18, General-purpose AI models](#); [ch. 11, Foundation models and GPAI](#). (ch. 08, 11, 18)

GPAI Code of Practice. The voluntary instrument (published 10 July 2025) that general-purpose-AI providers use to demonstrate compliance with their AI Act obligations until harmonised standards exist; three chapters: Transparency, Copyright, and Safety and Security (the last for systemic-risk models) [16]. See [ch. 08, GPAI Code of Practice](#); [ch. 18, The Code of Practice and enforcement](#). (ch. 08, 18)

Graduated degradation. Pre-built, tested operating modes short of switching an AI system off: advice-only, raised confidence thresholds, grounded-only answers, disabling for one group, language or region, and a return to the pilot cohort. Each is an operational toggle with a named trigger [77]. Contrast with [Kill switch](#). See [ch. 15, Graduated degradation](#); [ch. 05, Pattern: Deactivation, Localisation & Retirement Runbook](#). (ch. 05, 15, 23)

Guardian agent. An AI agent whose job is to supervise, check or constrain other agents at runtime; Gartner predicts guardian-agent technologies will account for at least 10 to 15% of agentic AI markets by 2030 [9]. Contrast with [Guardrail](#). See [ch. 04, Layer 04: Runtime Controls & Observability](#); [ch. 23, Runtime guardrails for tool calls](#). (ch. 04, 23)

Guardrail. A runtime control that inspects or mediates a model's or agent's inputs, outputs or tool calls and blocks, rewrites or escalates what breaks a policy, logging each decision as evidence. Guardrails are deterministic code or classifiers in the call path, unlike a guardian agent, which is itself an AI system. Contrast with [Guardian agent](#). See [ch. 05, Pattern: Runtime Guardrail](#); [ch. 23, Runtime guardrails for tool calls](#). (ch. 04, 05, 23)

H

Hallucination. Generative output that is stated confidently but is false or unsupported by its sources; NIST's generative AI profile calls it confabulation and lists it among the risks generative AI creates or worsens [75]. Groundedness and citation checks are the usual evidence against it. Contrast with [Regurgitation](#). See [ch. 17, AI-specific failure modes](#); [ch. 11, Predictive versus generative](#). (ch. 11, 17)

Harmonised standard. A European standard adopted on a Commission standardisation request. Under the AI Act, conformity with one whose reference is published in the Official Journal gives a presumption of conformity with the requirements it covers;

publication by CEN-CENELEC alone does not [2]. As of 2026-09-24, none is yet cited [10]. Contrast with [Common specifications and Harmonized Structure \(ISO\)](#). See [ch. 22, How presumption of conformity works](#). (ch. 08, 22)

Harmonized Structure (ISO). The common clause layout and core text shared by ISO management-system standards such as ISO/IEC 42001, 27001 and 27701 and ISO 9001, which lets one integrated management system meet several of them [78]. Not to be confused with an EU harmonised standard. Contrast with [Harmonised standard](#). See [ch. 22, Integrating with 27001, 27701 and 9001](#). (ch. 22)

Hidden Context Exposure. LLM08:2026 in the OWASP LLM Top 10, which replaced System Prompt Leakage: extracting, inferring or reconstructing the hidden context a model sees, such as system prompts, developer instructions, retrieved policy text and tool schemas [128]. The advice is to assume hidden context is discoverable, keep credentials out of it and never rely on it as a security boundary. Contrast with [Prompt injection](#). See [ch. 23, Prompts as configuration under change control](#). (ch. 23)

High-impact AI (Korea). Under Korea's AI Basic Act, an AI system that may significantly affect life, physical safety or fundamental rights and is used in a listed area such as health care, hiring and loan screening, biometric analysis, transport or public-service decisions. It triggers risk-management, explanation, human-oversight and record-keeping duties [25]. Contrast with [High-risk AI system](#). See [ch. 21, High-impact AI and how it is confirmed](#). (ch. 21)

High-risk AI system. Under the EU AI Act, an AI system that is a safety component of, or itself, a product under Annex I legislation needing third-party conformity assessment, or that is used in an Annex III area, unless the Article 6(3) filter applies. It carries the Articles 8 to 15 requirements and provider and deployer duties [2]. Contrast with [Prohibited practice](#), [High-impact AI \(Korea\)](#) and [Risk tier](#). See [ch. 18, The risk ladder](#). (ch. 18)

Hiroshima Code of Conduct. The G7's voluntary International Code of Conduct for Organizations Developing Advanced AI Systems (October 2023): 11 actions covering lifecycle risk evaluation, post-deployment monitoring, public reporting, incident sharing, governance policies, security, provenance and data protection [79]. See [ch. 22, G7 Hiroshima Process](#). (ch. 22)

Holding statement. A short public statement prepared in skeleton before any incident: what happened as far as it is known, what has been done to contain it, what affected people should do, and when the next update will come. It never speculates about cause. See [ch. 15, External communications](#); [ch. 05, Pattern: Disclosure & Notification Pipeline](#). (ch. 05, 15)

HUDERIA. The Council of Europe's non-binding methodology for assessing the risks and impacts of AI systems on human rights, democracy and the rule of law [80]. Parties to the Framework Convention may use or adapt it. See [ch. 22, What the Convention asks for, and what it changes in the stack](#). (ch. 22)

Human oversight. The measures that let natural persons understand, monitor and, when needed, override or stop a high-risk AI system, required by AI Act Article 14, including awareness of automation bias and a way to halt the system safely [2]. Engineered as gates, review tooling and override drills that leave records. See [ch. 04, Designing human oversight \(Article 14\)](#); [ch. 23, What a good approval looks like](#). (ch. 04, 11, 23)

Human-in-command (HIC). The oversight mode, named by the EU High-Level Expert Group, in which people oversee the overall activity of an AI system and decide when and whether to use it in a given situation [81]. Contrast with [Human-on-the-loop \(HOTL\)](#). See [ch. 11, From definition element to registry field](#). (ch. 11)

Human-in-the-loop (HITL). The oversight mode in which a person can intervene in every decision cycle of an AI system [81]; in engineering terms, a gate that holds each consequential action until a named approver decides, logging approver, time to decide and override. Contrast with [Human-on-the-loop \(HOTL\)](#). See [ch. 05, Pattern: Human-in-the-loop Gate](#); [ch. 11, From definition element to registry field](#); [ch. 23, Human checkpoints and approval design](#). (ch. 05, 11, 23)

Human-on-the-loop (HOTL). The oversight mode in which a person can intervene in the design cycle and monitors the system's operation, rather than approving each decision [81]. The system acts; people watch the signals and can stop it, so the stop path and the alerting are what must be tested. Contrast with [Human-in-the-loop \(HITL\)](#) and [Human-in-command \(HIC\)](#). See [ch. 11, From definition element to registry field](#). (ch. 11)

I

Implicit deny. The authorisation rule that a request no policy explicitly permits is refused. Cedar denies by default and lets any matching forbid override every permit [141]; an agent's tool allow-list works the same way, so an unlisted tool is blocked without a rule of its own. See [ch. 23, The tool allow-list](#); [Toolkit: Policy Card builder](#). (ch. 08, 23)

Importer. Under the EU AI Act, a person established in the Union who places on the market an AI system bearing the name or trademark of a provider established outside the Union. It must verify the provider's conformity work before placing a high-risk system on the market [2]. Contrast with [Distributor](#). See [ch. 18, The EU operator roles](#). (ch. 18)

Indirect discrimination. The EU counterpart of disparate impact: an apparently neutral criterion that puts a protected group at a particular disadvantage, unlawful unless objectively justified by a legitimate aim pursued by appropriate and necessary means [63]. Contrast with [Disparate impact](#). See [ch. 20, Disparate treatment, disparate impact and proxies](#). (ch. 20)

Inference (AI Act sense). The capability to derive outputs from input by learning from data or reasoning over encoded knowledge, rather than by executing rules people wrote. The Commission treats it as the indispensable condition that separates an AI system from conventional software [21]. See [ch. 11, EU AI Act Article 3\(1\) and the Commission guidelines](#). (ch. 11)

Inferred sensitive data. Sensitive information a system derives from ordinary inputs (health from purchases, beliefs from behaviour) or carries through a proxy feature. Washington's My Health My Data Act covers health data derived by algorithms or machine learning [82]; proxy tests and inference policies make it checkable. Contrast with [Special category data](#). See [ch. 19, Inferred and proxy sensitive data](#). (ch. 19)

Inherent risk. The likelihood and severity rating of a risk scenario before any control is counted. The gap between inherent and residual risk is the value claimed for the controls, and must be backed by their evidence [30]. Contrast with [Residual risk](#). See [ch. 13, Inherent risk, residual risk and who accepts it](#). (ch. 13)

Instructions for use. The information a provider of a high-risk AI system must give deployers: intended purpose, declared accuracy and robustness, known risks, how to read the output, human oversight measures, maintenance and logging [2]. Best generated from the registry entry and test report, so the numbers match the evidence. See [ch. 14, The technical file](#). (ch. 14, 18)

Intended purpose. The use for which the provider intends an AI system, including its specific context and conditions of use [2]. Most high-risk duties are measured against it, so it is a field of the use-case record that classification, tests and instructions for use read. A model moved to a new purpose is, for risk, a new system. Contrast with [Reasonably foreseeable misuse](#). See [ch. 14, The use-case record](#); [ch. 11, From definition element to registry field](#). (ch. 11, 14)

Internal reporting channel. A confidential route for staff and contractors to raise concerns about AI systems outside the chain of command, with statutory clocks encoded (under the EU Whistleblower Directive, acknowledgment within seven days and feedback within three months) and protection against retaliation [83]. See [ch. 12, A channel for raising concerns](#). (ch. 12)

Interpretability. In NIST's framing, the meaning of a system's output in the context of its purpose: why a decision was made and what it means to the user [30]. An inherently interpretable model, such as a scorecard or a shallow tree, is its own explanation. Contrast with [Explainability](#). See [ch. 16, Transparency, interpretability and explainability](#); [ch. 16, Interpretable by design or explained after the fact](#). (ch. 16)

ISO/IEC 22989. The ISO/IEC standard (2022) that establishes AI concepts and terminology for use by other standards and by diverse stakeholders [40]. Naming registry fields after its vocabulary reduces translation when auditing against the SC 42 family. See [ch. 22, Foundations and vocabulary](#). (ch. 11, 22)

ISO/IEC 42001. The ISO/IEC standard (2023) that specifies requirements for an AI management system, certifiable by accredited bodies [48]. As of 2026-09-24 it is not a harmonised standard under the AI Act, so certification gives no presumption of conformity [10]. See [ch. 22, The management-system trio](#); [ch. 08, ISO/IEC 42001, 42005 and 42006](#). (ch. 07, 08, 22)

ISO/IEC 42005. ISO/IEC 42005:2025, the AI system impact-assessment standard (a companion to the AI Act's Article 27 FRIA and to ISO/IEC 42001 Annex A.5), giving a structured method for assessing an AI system's impacts on people and society [17]. See [ch. 08, ISO/IEC 42001, 42005 and 42006](#); [ch. 14, Impact assessments compared](#). (ch. 08, 14)

Issue (versus incident). A defect, deviation or control weakness that has not produced a harmful event, such as an eval regression in staging or a drift alert. It is tracked to closure with an owner and a due date and starts no legal clock; most issues are nonconformities in management-system terms [48]. Contrast with [AI incident](#). See [ch. 17, Incident, hazard, issue and serious incident](#). (ch. 17)

J

Jailbreak. A prompt crafted to make a model disregard its safety instructions entirely. OWASP treats jailbreaking as a form of prompt injection [84]; it is tested with red-team suites in the eval gate and contained at runtime by guardrails that do not depend on the model's own refusals. Contrast with [Prompt injection](#). See [ch. 14, The test-type matrix](#). (ch. 14, 17)

JSON Schema. A vocabulary for describing the structure of JSON documents so a validator can check them: which fields exist, which are required, their types and allowed values [85]. The templates library publishes one draft 2020-12 schema per governance record, so a record either validates or fails the build. See [ch. 05, Pattern: Machine-Readable Evidence \(OSCAL\); Templates and schemas](#). (ch. 05)

Justification memo. The intake record for an AI use case: the problem, the non-AI alternative, the measurable benefit, who bears errors and how they contest them, reversibility and kill criteria. It answers "should AI be used at all" before a system reaches a gate, the go/no-go determination NIST places early [30]. See [ch. 12, Strategy, value and whether to use AI at all](#). (ch. 12)

K

Key risk indicator (KRI). A metric that shows whether a risk is moving towards the edge of appetite (unregistered AI found, open exceptions by age, override rates), as distinct from a key performance indicator, which shows whether the programme is doing its job. See [ch. 12, KPIs and KRIs for leadership and the board](#). (ch. 12)

Kill switch. A tested mechanism to stop an agent or system from acting; a precondition of granting autonomy, registered against the agent's identity. Contrast with [Graduated degradation](#). See [ch. 05, Pattern: Kill Switch / Circuit Breaker](#); [ch. 23, Kill switch and per-agent circuit breakers](#). (ch. 03, 05, 23)

L

Large language model (LLM). A foundation model for language, usually served from a data centre behind an API. Because calls pass through a gateway, runtime controls (tracing, filtering, stopping) can sit centrally [86]. Contrast with [Small language model \(SLM\)](#). See [ch. 11, LLMs and SLMs](#). (ch. 11)

Latent disclosure. Under California's AI Transparency Act, provenance information embedded in AI-generated image, video or audio so that it persists and can be read by a detection tool, as opposed to a visible label shown to the user [87]. Contrast with [Watermarking](#). See [ch. 21, Provenance, training data and frontier developers](#). (ch. 21)

Lawful basis. One of the six grounds in GDPR Article 6 that make processing of personal data lawful: consent, contract, legal obligation, vital interests, public task and legitimate interests [38]. For AI, each processing moment (training, retrieval, inference, logging) needs its own basis, recorded per dataset and stage. See [ch. 19, Lawful basis for training versus inference](#). (ch. 19)

Least agency. The principle, in the OWASP agentic list, of giving an agent no more autonomy than its task needs: agentic behaviour deployed where it is not needed widens the attack surface without adding value [6]. The cheapest agent control is the agent not built, such as a fixed workflow with one model call in place of a planner. Contrast with [Autonomy level](#). See [ch. 23, Governing AI agents](#). (ch. 23)

Legitimate-interest assessment (LIA). The documented three-step test for relying on legitimate interests: a lawful, precise and present interest; processing necessary for it; and a balance not overridden by people's rights and reasonable expectations [88]. Kept as a versioned artefact that points each mitigation at the control implementing it. See [ch. 19, Legitimate interests and the three-step test](#). (ch. 19)

LIME. Local Interpretable Model-agnostic Explanations: explains one prediction by fitting a simple interpretable model to the black box's behaviour on perturbed samples around the input [89]; vulnerable to off-manifold manipulation. Contrast with [SHAP](#). See [ch. 16, Feature attribution: SHAP, LIME and integrated gradients](#). (ch. 16)

Localisation (by jurisdiction). Controlling where an AI system runs and which features it offers in each jurisdiction, with per-jurisdiction rule sets as code, regional instances where residency requires them and feature flags by region, so one market can be switched off without touching the others. A system launches in a jurisdiction only once its duties there are shown to be met. See [ch. 15, Localisation by jurisdiction](#); [ch. 05, Pattern: Deactivation, Localisation & Retirement Runbook](#). (ch. 05, 12, 15)

Loss of control. One of the systemic risks the GPAI Code of Practice specifies: risks from humans losing the ability to reliably direct, modify or shut down a model, which may emerge from misalignment, self-replication, deception, resistance to goal modification or power-seeking [95]. Signatories assess it for models with systemic risk; a deployer of agents asks how autonomy and tool use were evaluated. See [ch. 23, EU AI Act hooks for agents](#); [ch. 08, GPAI Code of Practice](#). (ch. 08, 23)

M

Machine learning. The branch of AI in which a system improves at a task by learning patterns from data rather than by following rules people wrote. ISO/IEC 22989 groups its approaches into supervised, unsupervised, semi-supervised and reinforcement learning [40]. See [ch. 11, By learning paradigm](#). (ch. 11)

Machine unlearning. Techniques that remove a training record's influence from a model without full retraining. Exact methods retrain an affected shard [90]; approximate methods adjust weights and are hard to verify, so an unlearning claim is tested with membership-inference or extraction evals. Contrast with [Output suppression](#). See [ch. 19, Suppression, retraining and unlearning](#); [ch. 05, Pattern: Rights Requests Against Models](#). (ch. 05, 19)

Machine-readable evidence. Evidence a machine can query, diff and aggregate ([OSCAL](#) artefacts, structured eval results, signed logs), as opposed to screenshots and exported spreadsheets. See [ch. 05, Pattern: Machine-Readable Evidence \(OSCAL\)](#). (ch. 03, 04, 05)

Major ICT-related incident (DORA). Under the EU Digital Operational Resilience Act, an ICT-related incident at a financial entity that meets the classification criteria for a major incident. It is reported within 4 hours of classification and no later than 24 hours from awareness (within 4 hours of a classification made after those 24 hours), then in intermediate and final reports [91]. See [ch. 17, The overlapping clocks](#). (ch. 17)

Manufacturing defect. In product liability, a departure of a unit from its own design [60]. For AI: the wrong model version, corrupted weights, a misconfigured guardrail or a broken data pipeline in the deployed system. Contrast with [Design defect](#). See [ch. 20, Defect types mapped to AI failure modes](#). (ch. 20)

Market surveillance authority. The national authority designated to enforce the AI Act for products placed on its market, with powers to investigate, demand documentation and require corrective action. See [ch. 18, Who supervises what](#). (ch. 08, 18)

Maturity floor. The single overall maturity level of an AI governance function: the level of its weakest stack layer. It is a floor for planning, not a verdict on the whole function. The per-layer profile shows where the leverage is, and the next move is the next criterion in the weakest layer. See [ch. 07, Observable criteria by layer and level](#); [Toolkit: Maturity self-check](#). (ch. 07)

MCP. Model Context Protocol: an open protocol for connecting AI applications to tools and data sources; its 2026 specification adds OAuth 2.1 resource-server patterns and issuer-bound credentials for agent authorisation [8]. It secures the hop between one client and one server; which agent sits behind the client is for a workload identity to say. Contrast with [A2A \(Agent2Agent protocol\)](#). See [ch. 23, MCP authorization as of 2026-07-28](#); [ch. 04, Layer 04: Runtime Controls & Observability](#). (ch. 04, 05, 23)

Membership inference. An attack that determines whether a specific person's record was in a model's training set from the model's behaviour [92]. The EDPB counts resistance to it among the evidence for claiming a model is anonymous. Contrast with [Model inversion](#). See [ch. 19, AI-specific privacy breaches](#). (ch. 19)

Memory poisoning. An injection that writes to an agent's long-term memory, a retrieval corpus, a vector store or a hosted memory service, and so taints every later session that reads from that store [128]. OWASP's agentic list has it as ASI06 Memory & Context Poisoning [6] and MITRE ATLAS as AI Agent Context Poisoning (AML.T0080) [126]. Contrast with [Prompt injection](#). See [ch. 23, Memory and context governance](#). (ch. 23)

Mitigation hierarchy. The order in which risk treatments are tried: eliminate, substitute, engineer, administrative, then accept and monitor. Borrowed from the occupational-safety hierarchy of controls [93] and mirrored in AI Act Article 9(5) [2]; higher rungs first, with the reason recorded when they are infeasible. See [ch. 13, Treating risk: the mitigation hierarchy](#). (ch. 13)

Model anonymity. The EDPB's test for when a trained model falls outside the GDPR: both direct extraction of training subjects' data and obtaining it through queries must be insignificant, given all means reasonably likely to be used [88]. Evidenced by design records and attack evals. See [ch. 19, The EDPB anonymity test](#). (ch. 19)

Model card. Structured, versioned documentation of a model (provenance, intended use, capabilities, evaluations and known failure modes) maintained as code. Contrast with [System card](#) and [Data card](#). See [ch. 14, Model cards, system cards and datasheets](#); [ch. 05, Pattern: Model Card as Control Evidence](#). (ch. 04, 05, 14)

Model inversion. An attack that reconstructs features of training subjects, such as a face, from a model's outputs and confidence scores [94]. It can turn a deployed model into a channel for disclosing personal data. Contrast with [Membership inference](#). See [ch. 19, AI-specific privacy breaches](#). (ch. 19)

Model risk management. The banking-supervision practice of validating models for conceptual soundness, monitoring and outcomes analysis under effective challenge. SR 11-7 set the US tradition until SR 26-2 superseded it on 17 Apr 2026 [67], and SR 26-2 leaves generative and agentic AI models out of its scope [121]. A neighbour of this discipline, extended here to runtime behaviour and agents. Contrast with [Risk management](#). See [ch. 14, Independent validation and model risk management](#); [ch. 21, Sector rules that already reach AI](#); [ch. 01, The disambiguation cluster](#). (ch. 01, 02, 13, 14, 21)

Model signing. Signing a model's files at build: a manifest lists every file with its cryptographic digest and a detached signature covers the manifest, so any changed file fails verification. The OpenSSF Model Signing specification uses the Sigstore bundle format and supports keyless signing, private PKI, self-signed certificates or bare keys [135]. Serving verifies the signature before it loads a model. Contrast with [Build provenance \(SLSA\)](#). See [ch. 14, Reproducibility and linked versioning](#); [ch. 05, Pattern: Model Artefact Integrity](#). (ch. 05, 14, 15)

Multimodal model. A model that takes or produces more than one modality (text, image, audio, video). Each modality is a new channel for personal data, injected instructions and synthetic content that may need marking [2], so guardrails and evals are needed per modality. See [ch. 11, Multimodal models](#). (ch. 11)

N

Near miss. A hazard that a control, or luck, interrupted before harm occurred: the guardrail blocked the exfiltration, the reviewer caught the invented dosage. Near-miss data is evidence; the GPAI Code of Practice asks providers to report connected near-miss patterns with serious incidents [95]. Contrast with [AI hazard](#). See [ch. 17, Incident, hazard, issue and serious incident](#). (ch. 17)

Negative space. The uses an AI system is explicitly not for, written into its Deployment Decision Record. It sits inside the provider's intended purpose and makes function creep detectable, because an unapproved use has somewhere to be recorded as out of scope. See [ch. 15, Start from the use case, not the model](#). (ch. 15)

Neural data. Information generated by measuring the activity of a person's central or peripheral nervous system. California treats it as sensitive personal information [96], which switches on consent and assessment duties for AI systems that read wearables or brain-computer interfaces. See [ch. 19, Consumer-health and neural data](#). (ch. 19)

NHI. Non-human identity: the identity of an agent, service account or machine actor. Every NHI gets a registry entry, an owner and a scope before it is allowed to act. Contrast with [Workload identity](#). See [ch. 05, Pattern: Agent Identity & Scoped Credentials](#); [ch. 23, Identity and short-lived credentials](#). (ch. 04, 05, 23)

NIST AI RMF. The NIST Artificial Intelligence Risk Management Framework 1.0 (NIST AI 100-1, January 2023): voluntary guidance organised as a Core of four functions (Govern, Map, Measure, Manage) with categories and subcategories, plus profiles and a companion Playbook [3][30]. See [ch. 22, NIST AI RMF 1.0 in depth](#); [ch. 08, NIST AI RMF](#). (ch. 08, 22)

Notified body. A conformity assessment body designated under the EU AI Act to carry out third-party conformity assessment of high-risk AI systems. Under the notified-body procedure it assesses a provider's quality management system and technical documentation, with access to training, validation and testing data [2]. See [ch. 18, Conformity assessment, declaration, marking and registration](#); [ch. 14, EU AI Act conformity, in order](#). (ch. 14, 18)

O

OECD AI Principles. The five values-based principles (inclusive growth and well-being; human rights, fairness and privacy; transparency and explainability; robustness, security and safety; accountability) and five policy recommendations of the OECD

Recommendation on AI, adopted in 2019 and revised in 2024 [31]. A commitment by adhering governments, not a binding rule for companies. See [ch. 22, OECD AI Principles](#). (ch. 11, 22)

OECD Framework for the Classification of AI Systems. An OECD tool (2022) for characterising an AI system from a policy perspective along five dimensions: People & Planet, Economic Context, Data & Input, AI Model, and Task & Output [97]. In engineering practice its dimensions become groups of registry fields that route controls. See [ch. 22, The Framework for the Classification of AI Systems](#). (ch. 22)

OPA/Rego. The Open Policy Agent and its Rego policy language, a general-purpose policy-as-code engine that evaluates governance rules in CI/CD and at runtime admission; the canonical example of executable policy-as-code. Contrast with [Cedar](#). See [ch. 06, Policy-as-code and gates](#). (ch. 04, 05, 06)

Opacity. The inability of a person to follow how a system reached an output. It has three sources (secrecy, technical illiteracy, and the nature and scale of machine learning) [98], each with a different fix: disclosure, literacy, and explanation methods plus behavioural evals. Contrast with [Explainability](#). See [ch. 11, Eight characteristics that break classic IT governance](#); [ch. 11, Contrast pairs](#). (ch. 11)

Open-weight model. A model whose trained weights are published for download under a licence that may be permissive, copyleft, use-restricted or custom [99]. Open weights are not open source; the deployer produces almost all the evidence (hashes, scans, evals, red team) and must honour the licence and any acceptable-use policy. Contrast with [Responsible-AI licence \(OpenRAIL\)](#). See [ch. 15, Open-weight licences](#); [ch. 18, Open-source carve-outs and their limits](#). (ch. 15, 18)

Operator (EU AI Act). The umbrella term for the actors the AI Act binds: provider, product manufacturer, deployer, authorised representative, importer and distributor [2]. The same organisation can be several operators for different systems, or for the same one. See [ch. 18, The EU operator roles](#). (ch. 18)

OSCAL. The Open Security Controls Assessment Language, a NIST machine-readable format for controls, assessments and evidence, used here as the format for audit-ready evidence [3]. See [ch. 05, Pattern: Machine-Readable Evidence \(OSCAL\)](#). (ch. 04, 05, 10)

Output suppression. A filter around a model that stops it producing a person's data: the fast first answer to an erasure or objection request when the data sits in the weights and retraining is disproportionate. The CNIL accepts filters shown to be effective and robust and prefers general rules to a list of names [140]. The data stays in the model. Contrast with [Machine unlearning](#). See [ch. 19, Suppression, retraining and unlearning](#); [ch. 05, Pattern: Rights Requests Against Models](#). (ch. 05, 19)

P

Paved path. A supported, low-friction default route (a template, library or pipeline) that makes the governed way the easiest way to ship, so engineers adopt governance without asking permission. See [ch. 03, Make the governed path the easiest path](#). (ch. 03, 06)

Personal data breach. A breach of security leading to the accidental or unlawful destruction, loss, alteration or unauthorised disclosure of, or access to, personal data, notified to the authority within 72 hours unless unlikely to result in a risk [38]. AI adds regurgitation, inversion and prompt-injection exfiltration as routes. See [ch. 19, AI-specific privacy breaches](#). (ch. 19)

PIPIA. China's personal information protection impact assessment under PIPL Articles 55 and 56, required in advance for sensitive data, automated decision-making, entrusted processing and cross-border provision, with the report kept for at least three years [100]. Contrast with [DPIA](#). See [ch. 19, Brazil and China](#). (ch. 19)

Placing on the market. Under the EU AI Act, the first making available of an AI system or general-purpose AI model on the Union market; later supplies in the course of a commercial activity are making available [2]. For a high-risk system, the conformity assessment and the technical documentation come before it, or before putting into service. Contrast with [Putting into service](#). See [ch. 18, The EU operator roles; Toolkit: EU AI Act role and risk-class triage](#). (ch. 08, 14, 15, 18, 20)

Policy Card. A JSON-schema, machine-readable governance artefact that declares an agent's allowed and forbidden behaviours for runtime enforcement [11]. See [ch. 05, Pattern: Policy Card](#). (ch. 04, 05, 10, 23)

Policy verdict. The structured record a policy engine emits each time it evaluates a rule: allow or deny, the versioned rule id, a hash of the input and a timestamp, signed and written to the evidence store. A release or tool call without a verdict is an audit finding, and one that passed under an exception names it in its verdict. See [ch. 04, Layer 01: Govern-as-Code; Toolkit: Policy Card builder](#). (ch. 04, 05, 12, 23)

Policy-as-code. Governance policy expressed in an executable policy language ([OPA/Rego](#) , [Cedar](#)) that evaluates in CI/CD and at admission; the narrower, pipeline subset of governance-as-code. Contrast with [Governance-as-code](#). See [ch. 06, Policy-as-code and gates](#). (ch. 04, 05, 06)

Post-market monitoring. The AI Act Article 72 duty to actively monitor a high-risk system's performance and risks after deployment, throughout its lifetime [2]. See [ch. 18, Post-market monitoring and serious incidents \(Articles 72 and 73\)](#). (ch. 08, 18)

Pre-determined changes. Changes to a high-risk system that continues to learn, planned by the provider at the initial conformity assessment and described in the technical documentation; they are not substantial modifications [2]. Engineered as a change envelope written in code. Contrast with [Substantial modification](#). See [ch. 14, Substantial modification](#). (ch. 14)

Predictive AI. AI that outputs an estimate about something that exists: a score, class or forecast [21]. Its harms are mostly allocation harms, and its evidence is accuracy, calibration and error rates by subgroup, with a decision threshold someone owns. Also called discriminative AI. Contrast with [Generative AI](#). See [ch. 11, Predictive versus generative](#). (ch. 11)

Presumption of conformity. The legal effect under AI Act Article 40: a high-risk system or GPAI model that conforms with OJ-cited harmonised standards is presumed to meet the requirements those standards cover, and no others [2]. Unavailable until a standard is cited, which as of 2026-09-24 none is [10]. See [ch. 22, How presumption of conformity works](#). (ch. 08, 22)

Privacy by design and by default. The GDPR Article 25 duty to build data protection principles into processing through technical and organisational measures, and to process by default only the personal data each purpose needs [38]. In an AI stack it shows up as filters, retention rules and access limits enforced as code. See [ch. 19, Minimisation, privacy by design and PETs](#). (ch. 19)

Privacy-enhancing technology (PET). A technique that reduces what an attacker, vendor or insider can learn from personal data, such as differential privacy, federated learning, synthetic data, masking or trusted execution [61]. None makes a system compliant alone; each has a known failure mode and is evidenced by a test. See [ch. 19, Privacy-enhancing technologies and their honest limits](#). (ch. 19)

Product Liability Directive (PLD). Directive (EU) 2024/2853, which treats software, including AI, as a product; judges defect with learning and updates in view; lets courts order disclosure and presume defect; and applies to products placed on the market after 9 Dec 2026 [101]. See [ch. 20, The EU Product Liability Directive](#). (ch. 20)

Profiling override. The rule in the third subparagraph of AI Act Article 6(3) that an Annex III system which performs profiling of natural persons is always high-risk, whichever filter condition it meets [2]. A classification decision record therefore carries an explicit profiling flag, so a filter claim the override defeats is visible. Contrast with [Article 6\(3\) filter](#). See [ch. 18, The Annex III filter and the profiling override; Toolkit: EU AI Act role and risk-class triage](#). (ch. 08, 18)

Progressive delivery. Releasing a change to a small, growing share of real traffic in stages (shadow, pilot, canary, general availability), each with rollback criteria registered before it starts and a tested path back to the previous version, so evidence about live behaviour arrives before full exposure. For AI systems it covers model, prompt, corpus and vendor-version changes alike. See [ch. 15, Progressive delivery as a control](#); [ch. 05, Pattern: Staged Rollout with Rollback Criteria](#). (ch. 05, 14, 15, 23)

Prohibited practice. An AI practice banned outright by AI Act Article 5, such as manipulative techniques that cause significant harm, social scoring, untargeted scraping of facial images, emotion recognition at work or school, and most real-time remote biometric identification in public for law enforcement [2]. No risk acceptance can cover one. Contrast with [High-risk AI system](#). See [ch. 18, Prohibited practices \(Article 5\)](#). (ch. 18)

Prompt injection. An input that alters a model's behaviour or output in ways its designers did not intend. It is direct when the user supplies it and indirect when it arrives inside content the model processes, such as a web page, file or tool result [84]. Contained by guardrails, least-privilege tools and evals. Contrast with [Jailbreak](#) and [Hidden Context Exposure](#). See [ch. 04, Layer 04: Runtime Controls & Observability](#). (ch. 01, 04, 17, 23)

Proportionate governance. Running the same risk loop at an intensity set by organisation size, sector, maturity and risk tolerance, above a floor of controls that never tailors away. The AI Act itself scales documentation and quality-management duties for smaller firms [2]. It lowers the cost of governance, not the protection owed. See [ch. 13, Proportionate governance: tailoring the loop](#). (ch. 13)

Provider. Under the EU AI Act, whoever develops an AI system or general-purpose AI model, or has one developed, and places it on the market or puts it into service under its own name or trademark, whether for payment or free [2]. It carries the design, documentation, conformity and monitoring duties for high-risk systems. Contrast with [Deployer](#). See [ch. 18, The EU operator roles](#). (ch. 15, 18)

Proxy label. A training target that stands in for the construct a decision is meant to capture, such as health-care cost standing in for health need [102]. When the proxy is shaped by unequal treatment, a model can be accurate on the proxy and biased on the construct. Contrast with [Proxy variable](#). See [Case: a health risk score with a proxy label](#). (ch. 16)

Proxy scan. A test that trains a model to predict a protected attribute from a system's features; features that predict it strongly are flagged as proxies to justify or remove, and the result is recorded in the data card. It finds proxy variables before an outcome metric shows their effect. See [ch. 16, Fairness and explainability in the stack](#); [ch. 05, Pattern: Fairness Eval Suite](#). (ch. 05, 16)

Proxy variable. A feature that carries the information of a protected characteristic, such as postcode for ethnicity, so that a model can discriminate without using the attribute itself. Proxy tests look for features that predict the protected attribute [102]. Contrast with [Proxy label](#). See [ch. 16, Protected characteristics, proxies and the data you need to test](#). (ch. 16, 20)

Pseudonymisation. Processing personal data so it can no longer be attributed to a person without additional information kept separately and protected [38]. Pseudonymised data stays personal data for whoever can re-attribute it; it is a security measure, not anonymisation. Contrast with [Anonymous data](#). See [ch. 19, Anonymisation versus pseudonymisation](#). (ch. 19)

Purpose limitation. The GDPR principle that personal data collected for a specified purpose may not be further processed in an incompatible way; Article 6(4) sets the compatibility test [38]. Enforced in AI pipelines by purpose tags on datasets and a policy that denies runs whose declared purpose does not match. See [ch. 19, Purpose limitation and function creep](#). (ch. 19)

Putting into service. Under the EU AI Act, the supply of an AI system for first use directly to the deployer, or for the provider's own use, in the Union for its intended purpose [2]. Own use counts: an organisation that builds a system and runs it itself is its

provider and its deployer, with no sale involved. Contrast with [Placing on the market](#). See [ch. 18, Roles name tasks, not organisations](#); [Toolkit: EU AI Act role and risk-class triage](#). (ch. 15, 18)

Q

QMS (Art. 17). The quality management system that AI Act Article 17 requires of high-risk providers; distinct from an ISO/IEC 42001 AIMS, which certifies a management system but is not harmonised [2][10]. Contrast with [AIMS](#). See [ch. 18, Article 16 and the quality management system \(Article 17\)](#). (ch. 08, 18)

R

RAISE Act. New York's Responsible AI Safety and Education Act, a frontier-AI safety law binding large frontier developers to publish a safety framework and every frontier developer to report critical safety incidents; signed 19 December 2025 and taking effect 1 January 2027 after a March 2026 chapter amendment that placed oversight in an office within the Department of Financial Services (DFS) [12][15]. See [ch. 08, Frontier-developer laws](#). (ch. 08, 21)

Realised risk reduction. The measured drop in a named failure mode's rate or blast radius in production; one of the two tests of the discipline, against framework coverage. See [ch. 03, 7. Success is measured in realised risk reduction, not framework coverage](#). (ch. 01, 03)

Reason code. A stable, human-readable statement of a principal factor behind an adverse decision, mapped from the factors the model actually scored and versioned with the model; required in substance by US adverse-action rules [23]. See [ch. 16, Credit: adverse-action notices and reason codes](#); [ch. 05, Pattern: Decision Notice & Contest Path](#); [ch. 05, Pattern: Explanation Artefact](#). (ch. 05, 16, 20)

Reasonably foreseeable misuse. Use of an AI system not in accordance with its intended purpose that may result from reasonably foreseeable human behaviour or interaction with other systems, including other AI systems [2]. Distinct from an attack; kept in a misuse register that feeds tests, runtime policy and the instructions for use. Contrast with [Intended purpose](#). See [ch. 14, Reasonably foreseeable misuse](#); [ch. 15, Secondary use and downstream harm](#). (ch. 14, 15)

Records of processing activities (ROPA). The GDPR Article 30 record of each processing activity: purposes, categories of data and people, recipients, transfers, retention and security [38]. For AI it is best generated per processing moment from the registry and data cards, so it does not go stale. See [ch. 19, Records of processing](#). (ch. 19)

Recourse. The ability of a person to obtain a different decision by changing inputs they can actually act on, such as income rather than age [103]. Counterfactual explanations restricted to actionable features are its usual engineering form; a system can offer contestation and still leave no recourse. Contrast with [Contestability](#). See [ch. 16, Counterfactual explanations](#). (ch. 16, 21)

Red teaming. Structured adversarial testing of a model or agent to elicit failures (jailbreaks, injection, tool misuse) before an attacker does; treated here as an evidence-producing control. See [ch. 05, Pattern: Adversarial Red-Team Suite](#). (ch. 04, 05, 15)

Regurgitation. A model reproducing memorised training data verbatim, including personal data, whether prompted deliberately (training-data extraction) or not [104]. Detected by output checks and canaries, and tested by extraction evals. Contrast with [Hallucination](#). See [ch. 19, AI-specific privacy breaches](#). (ch. 19, 20)

Reinforcement learning. Learning to maximise a reward signal through trial and feedback [40]. Its characteristic failure is reward hacking, so the reward is recorded as the system's objective and evals look for unintended strategies. See [ch. 11, By learning paradigm](#). (ch. 11)

Reinforcement learning from human feedback (RLHF). A way to align a pre-trained model: supervised fine-tuning on human demonstrations, then reinforcement learning against a reward model trained on human rankings of outputs [105]. The raters' instructions and the reward model become governed artefacts, because they shape what the model refuses and prefers. Contrast with [Fine-tuning](#). See [ch. 11, By learning paradigm](#). (ch. 11)

Reporting clock. A statutory deadline for an incident notification, defined by its trigger (awareness, classification, causal link or determination), recipient, content and follow-ups, as in AI Act Article 73 [2]. One event can start several clocks, so each is held as its own timer on a single incident record. See [ch. 17, The overlapping clocks](#). (ch. 17)

Residual risk. What is left of a risk once treatment is applied [30]. The EU AI Act requires residual risk per hazard and overall to be judged acceptable for high-risk systems [2]. A residual rating credits only controls whose evidence is current. Contrast with [Inherent risk](#) and [Risk tolerance](#). See [ch. 13, Inherent risk, residual risk and who accepts it](#). (ch. 13)

Responsible-AI licence (OpenRAIL). A licence that grants open, royalty-free access to an AI artefact while attaching prohibited uses that every redistribution and derivative must carry forward [106]. The restrictions travel with the model, so a deployer's own terms of use must repeat them. Contrast with [Open-weight model](#). See [ch. 15, Open-weight licences](#). (ch. 15)

Responsible-AI principle set. A published set of normative targets for AI, such as the OECD AI Principles [31], the UNESCO Recommendation, the HLEG requirements or the G7 Hiroshima principles. Not the house "principle", which is a rule of method; a principle set counts as applied only when an artefact evidences it. Contrast with [Trustworthy AI](#). See [ch. 11, Responsible-AI principle sets, engineered](#). (ch. 11)

Retrieval-augmented generation (RAG). A system that combines a model's learned memory with a retrievable store of documents at answer time [107]. The corpus becomes behaviour, so it is governed like a model: versioned, carded, tied to the eval

that tested it, with an entitlement check on what each user may retrieve. See [ch. 11, RAG systems](#). (ch. 11, 16)

Reward hacking. A system finding an unintended way to maximise its reward or objective without doing what its designers meant [108]. Answered by recording the objective and testing for unintended strategies, not only for the intended task. See [ch. 11, By learning paradigm](#). (ch. 11)

Right to explanation (AI Act Art. 86). The right of a person affected by a deployer's decision based on an Annex III high-risk system's output, with legal or similarly significant adverse effects, to clear and meaningful explanations of the system's role and the main elements of the decision, where Union law does not already provide it [2]. Contrast with [Explainability](#). See [ch. 18, Explanation and notice to affected people](#). (ch. 16, 18, 19)

Rights reservation (TDM opt-out). A rightholder's express reservation of text and data mining under Article 4(3) of the DSM Directive, which takes the content out of the general mining exception; for content made publicly available online it must be made in an appropriate manner, such as machine-readable means [115]. General-purpose AI model providers must identify and comply with such reservations [2]. Contrast with [TDM exception](#). See [ch. 20, Artefacts that evidence IP compliance](#); [ch. 05, Pattern: Training-Data Rights Ledger](#). (ch. 05, 08, 12, 20)

Risk acceptance. A named, signed and expiring decision by someone with the authority a residual band requires, that a risk may remain for a bounded period under named compensating controls and a monitoring signal that voids it [30]. Authority rises with the rating; a prohibited use cannot be accepted by anyone. Contrast with [Exception register](#). See [ch. 13, Who may accept](#); [ch. 12, Risk acceptance and exceptions](#). (ch. 12, 13)

Risk appetite. How much risk, and of which kinds, an organisation is prepared to take on in pursuit of its objectives [109]. In this book it is compiled from an approved statement into a versioned data file that gates read, rather than left in a board paper. Contrast with [Risk tolerance](#). See [ch. 13, Risk appetite and tolerance, compiled into gates](#). (ch. 13)

Risk management. The organised practice of steering an organisation's decisions with its risks in view [109]: identify, assess, treat and monitor, in a loop. For high-risk systems the AI Act requires a documented risk management system across the lifecycle [2]. Contrast with [Model risk management](#). See [ch. 13, The loop: identify, assess, treat, monitor](#). (ch. 13)

Risk matrix. A grid that turns a likelihood rating and a severity rating, each on defined scales, into a band that triggers a treatment, a gate and a review cadence. Useful for consistency, not precision [110]; keep the numbers behind each cell. See [ch. 13, Assessing risk: the likelihood-by-severity matrix](#). (ch. 13)

Risk register. The evidence record of the risk loop: one versioned file per risk, keyed to a registry id, with ratings, treatment, controls that resolve to evidence, owner, acceptance, review cadence and links to evals, incidents and obligations. Deploy gates read it; it evidences an Article 9 risk management system [2]. Contrast with [Exception register](#). See [ch. 13, The risk register as an evidence record](#). (ch. 13)

Risk source. Anything that can give rise to risk alone or in combination, such as a dataset, a tool grant, an adversary or a user group [111]. Internal sources sit inside the organisation's control; external ones arise outside it and are mostly engineered against and monitored. Contrast with [Contributing factor](#). See [ch. 13, Internal and external risk sources](#). (ch. 13)

Risk tier. An organisation's own rating of an AI use case, computed at intake by a versioned policy from declared profile fields such as autonomy, decision impact, exposure, reversibility, vulnerable groups, data class and third parties. The tier selects the assessments, evals, thresholds, approvers and review cadence a system must pass; it sits beside the legal classification, not in place of it. Contrast with [High-risk AI system](#). See [ch. 13, Contributing factors and the use-case risk profile](#); [ch. 05, Pattern: Use-Case Intake & Risk Tiering](#). (ch. 05, 06, 12, 13)

Risk tolerance. The readiness to bear a given risk in order to achieve objectives [30]. Engineered as the highest residual band a system tier may carry before a deploy gate requires a signed acceptance. Contrast with [Risk appetite](#). See [ch. 13, Risk appetite and tolerance, compiled into gates](#). (ch. 13)

Rollback criteria. The conditions, written into the rollout plan before a release stage starts, under which the pipeline returns to the previous version automatically: a floor breached against the control group, a disagreement or override rate above a threshold, a severity-1 event. A criterion set after the metric moved is a negotiation, not a control. Contrast with [Kill switch](#). See [ch. 15, Progressive delivery as a control](#); [ch. 05, Pattern: Staged Rollout with Rollback Criteria](#). (ch. 05, 15)

Root-cause analysis (RCA). The review that answers why an incident happened and why the controls did not stop it, using techniques such as five whys, fault tree analysis [112] and blameless post-mortems, and codes each confirmed cause against a taxonomy that names the control that should have caught it. See [ch. 17, Root-cause analysis](#). (ch. 17)

Runtime data path. The live connection between production and the governance function (discovery, telemetry and enforcement), without which a registry or dashboard describes the program but cannot see what is running [13]. See [ch. 02, 5. No runtime data path](#). (ch. 02, 04, 07)

S

Safetensors. A file format for storing a model's tensors safely, as opposed to Python pickle [137], whose loading can run arbitrary code and which the Python documentation calls not secure [138]. Storing weights as safetensors, and scanning any remaining pickle files for code-executing imports before they reach a registry, closes a common supply-chain route into serving. See [ch. 14, Reproducibility and linked versioning](#); [ch. 05, Pattern: Model Artefact Integrity](#). (ch. 05, 14)

Safety component. Under the AI Act as amended in 2026, a component of a product or AI system whose intended purpose is to prevent or mitigate risks to the health and safety of persons or property, or whose failure endangers them. AI used solely for convenience, efficiency or quality control is excluded unless its failure would endanger safety [2]. See [ch. 18, High-risk through products \(Annex I\)](#). (ch. 18)

Sanctioned AI gateway. The single approved route by which staff reach AI tools and model APIs: approved tools behind single sign-on and a gateway that classifies each request by data class, allows, redacts or blocks it under the acceptable-use policy, checks for a current attestation and logs a decision per call. It works by being the easiest route. Contrast with [Shadow AI](#). See [ch. 12, Acceptable use of AI by staff](#); [ch. 05, Pattern: Sanctioned AI Gateway](#). (ch. 05, 12)

SB 53. California's frontier-AI transparency law (TFAIA), in force 1 Jan 2026, covering frontier developers training models above 10^{26} FLOP: all of them publish transparency reports and report critical safety incidents, and large frontier developers also publish a safety framework [14][142]. See [ch. 08, Frontier-developer laws](#). (ch. 08, 21)

Self-supervised learning. Learning by predicting parts of the input itself, such as the next token, over large corpora; the AI Act's definition of a general-purpose model names self-supervision at scale [2]. Corpus provenance, rights and memorisation are hard to trace, which is why the AIBOM records dataset provenance. See [ch. 11, By learning paradigm](#). (ch. 11)

Serious incident. Under AI Act Article 3(49), an incident or malfunction of an AI system that directly or indirectly leads to (a) a death or serious harm to health, (b) serious and irreversible disruption of critical infrastructure, (c) infringement of Union-law obligations protecting fundamental rights, or (d) serious harm to property or the environment, triggering Article 73 reporting [2]. Contrast with [AI incident](#). See [ch. 17, Incident, hazard, issue and serious incident](#); [ch. 18, Post-market monitoring and serious incidents \(Articles 72 and 73\)](#). (ch. 04, 08, 17, 18)

Shadow AI. An AI system, model or agent running without registration, including staff use of unapproved AI tools; the failure mode that makes an inventory complete only for the honest. It is found by discovery and answered with a sanctioned route, not a ban. Contrast with [Sanctioned AI gateway](#). See [ch. 05, Pattern: Shadow-AI Discovery](#); [ch. 12, Acceptable use of AI by staff](#). (ch. 05, 07, 12)

Shadow deployment. A release stage in which a new model or system receives live inputs but its outputs are not used, so its behaviour on real traffic can be compared with the incumbent or with human decisions before any exposure. The disagreement log is its evidence. Contrast with [Canary release](#). See [ch. 15, Progressive delivery as a control](#); [ch. 05, Pattern: Staged Rollout with Rollback Criteria](#). (ch. 05, 14, 15)

SHAP. SHapley Additive exPlanations: a feature-attribution method that assigns each input feature a share of a particular prediction, based on Shapley values [113]; its explanations depend on the chosen baseline or background data. Contrast with [LIME](#). See [ch. 16, Feature attribution: SHAP, LIME and integrated gradients](#). (ch. 16)

Small language model (SLM). A language model small enough to run close to the user, for example on a phone [86]. Its controls must ship with it: guardrails on the device, a version inventory across the fleet and a kill switch delivered as a remote flag or app update. Contrast with [Large language model \(LLM\)](#). See [ch. 11, LLMs and SLMs](#). (ch. 11)

Small mid-cap enterprise (SMC). An enterprise that has outgrown the SME definition but falls within the EU small mid-cap definition. The Digital Omnibus extends some SME relief under the AI Act to SMCs, such as simplified technical documentation and a proportionate quality management system [2]. See [ch. 18, The Act and the Omnibus](#). (ch. 18)

Special category data. The GDPR Article 9 categories whose processing is prohibited unless a condition applies: data revealing racial or ethnic origin, political opinions, beliefs or union membership, and genetic, biometric (for identification), health, sex-life and sexual-orientation data [38]. AI can create it by inference. Contrast with [Inferred sensitive data](#). See [ch. 19, Special categories, inferred data and biometrics](#). (ch. 19)

Stakeholder mapping. Naming who is affected by or holds a view on an AI system (users, affected non-users, deployers, providers, internal functions, regulators, the governing body) and how each view enters the risk loop, with the consultation logged. A FRIA names the affected groups too [2]. See [ch. 13, Stakeholder mapping](#). (ch. 13)

STAR for AI. CSA's security assurance and certification programme for AI, built on the AICM, with a self-assessment tier, an automated "Valid-AI-ted" tier and a Level 2 combining ISO/IEC 42001 with the validated assessment [4]. See [ch. 08, CSA AICM and STAR for AI](#). (ch. 07, 08)

STRIDE. A threat-classification checklist from Microsoft's Security Development Lifecycle: spoofing, tampering, repudiation, information disclosure, denial of service and elevation of privilege [133]. For an AI system it is walked per element of the data-flow diagram and then extended with AI-specific catalogues such as MITRE ATLAS and the OWASP lists. Contrast with [ATLAS](#). See [ch. 15, Threat modelling the deployed system](#); [ch. 05, Pattern: AI Threat Model](#). (ch. 05, 06, 15)

Sub-processor. A processor that another processor engages to carry out processing for a controller, such as the model host behind an AI vendor. Under GDPR Article 28 it needs the controller's prior written authorisation, specific or general with notice of changes and a chance to object, and the same data protection obligations flow down to it by contract [38]. Contrast with [Controller and processor](#). See [ch. 19, AI vendor DPAs and no-training clauses](#); [ch. 15, Vendor contracts and licence terms](#). (ch. 08, 12, 15, 19)

Substantial modification. Under the EU AI Act, a change after placing on the market that the initial conformity assessment did not foresee and that affects compliance or changes the intended purpose [2]. It triggers a new conformity assessment and can turn a deployer or distributor into the provider; pre-determined changes are exempt. Contrast with [Pre-determined changes](#). See

ch. 18, Article 25: when someone else becomes the provider; ch. 14, Substantial modification; ch. 15, When a deployer becomes a provider. (ch. 14, 15, 18)

Supervised learning. Learning from labelled examples [40]. Labels encode past human decisions with their errors and bias, so the data card records label provenance and the eval gate tests error rates by subgroup. Contrast with [Unsupervised learning](#). See [ch. 11, By learning paradigm](#). (ch. 11)

SVID. SPIFFE Verifiable Identity Document: a short-lived cryptographic identity document, either an X.509 certificate or a JWT, that proves a workload's SPIFFE ID and is issued and rotated through the SPIFFE Workload API, which SPIRE implements [124]. A credential that expires in minutes need not be hunted down after an incident, only not reissued. Contrast with [Workload identity](#). See [ch. 23, Short-lived, attested credentials](#). (ch. 23)

Synthetic data. Data generated by a model or simulation rather than collected from people or events, used to augment training sets, test edge cases or reduce exposure of personal data. It inherits the biases of its generator and can leak the records it was fitted on, so it is tested like any other dataset. See [ch. 14, Synthetic data, augmentation and privacy-enhancing technologies](#). (ch. 14, 19)

System card. Documentation of a deployed AI system as a whole (models, prompts, retrieval, tools, guardrails and oversight), where a model card documents one model [114]. Its audience is deployers, authorities and the public; its evidence is the registry entry, the guardrail configuration and red-team results. Contrast with [Model card](#). See [ch. 14, Model cards, system cards and datasheets](#). (ch. 14, 15)

Systemic risk. Under the AI Act, the risk posed by the most capable general-purpose AI models, triggering extra evaluation, adversarial-testing and incident-reporting duties on their providers [2]. See [ch. 18, Systemic risk: threshold, notification, designation](#). (ch. 08, 18)

T

Tabletop exercise. A scheduled, scored rehearsal of an incident playbook against a named failure mode, producing the same records a real incident would (record, clocks, draft reports, containment events) tagged as a drill. The playbook is the claim; the drill result is the evidence. See [ch. 17, Playbooks, RACI and drills](#). (ch. 17)

TC260. The National Technical Committee 260 on Cybersecurity of the Standardization Administration of China (全国网络安全标准化技术委员会), which drafts China's cybersecurity and AI national standards (GB and GB/T) and publishes the voluntary AI Safety Governance Framework (1.0 in 2024, 2.0 in 2025, 3.0 on 14 September 2026) [19]. See [ch. 21, China: what chapter 08 does not already cover](#). (ch. 08, 21)

TDM exception. The EU copyright exception for text and data mining (DSM Directive Articles 3 and 4) that lets anyone copy lawfully accessible works for mining, including AI training, unless the rightholder has reserved that use; for content made publicly available online the reservation must be made in an appropriate manner, such as machine-readable means [115]. Contrast with [Fair use](#) and [Rights reservation \(TDM opt-out\)](#). See [ch. 20, Copyright and training data](#). (ch. 20)

Technical documentation (Annex IV). The provider's technical file for a high-risk AI system, drawn up before placing on the market and kept up to date under Article 11: description, development process, data, testing, oversight, risk management, standards, declaration and post-market monitoring plan [2]. Most items can be generated from pipeline records. See [ch. 14, Annex IV, element by element](#). (ch. 14)

Test-set contamination. The presence of evaluation items in a model's training data, which inflates its scores; it can be demonstrated even for black-box language models [116]. Mitigated with private held-out sets, rotated items and dated test items. See [ch. 14, Statistical validity of evals](#). (ch. 14)

Testing in real-world conditions. Under the EU AI Act, temporary testing of an AI system for its intended purpose outside a laboratory, under a plan approved by the market surveillance authority, with registration, informed consent of subjects, effective oversight and reversible outputs, for a limited period [2]. Contrast with [AI regulatory sandbox](#). See [ch. 18, Sandboxes and real-world testing](#). (ch. 18)

Threat model (AI). A versioned record of what can go wrong with an AI system and what is done about it: data flows and trust boundaries, threats per element from STRIDE and AI-specific catalogues, a decision on each, and the test that proves each mitigation. It answers the four threat-modelling questions, ending with whether the job was done well enough [134]. Contrast with [Red teaming](#). See [ch. 15, Threat modelling the deployed system](#); [ch. 05, Pattern: AI Threat Model](#). (ch. 05, 14, 15, 23)

Three Lines Model. The Institute of Internal Auditors' 2020 update of the "three lines of defense": the governing body oversees; management holds first-line roles (delivering products and services) and second-line roles (risk expertise, support and challenge); internal audit gives independent third-line assurance [117]. See [ch. 12, The three lines, applied to AI](#). (ch. 12)

Token passthrough. The anti-pattern in which a server accepts a token that was not issued to it and forwards it, unmodified, to a downstream API, which may then trust it as if the server had validated it. The MCP specification forbids it: a server must not accept any token not explicitly issued for it, and so checks each token's audience [125]. Contrast with [Delegation \(OAuth token exchange\)](#). See [ch. 23, MCP authorization as of 2026-07-28](#). (ch. 23)

Tool allow-list. The deny-by-default list of tools an agent may call, each entry pinned by a hash of the tool's definition and bounded by resource scope, operation class, rate, egress destinations, data classes and a checkpoint rule, evaluated by the tool gateway on every call. OWASP asks for such per-tool least-privilege profiles [6]. See [ch. 23, The tool allow-list](#). (ch. 23)

Tool poisoning. Tampering with a tool an agent uses, through its model-visible definition (description, schema, metadata) or its behaviour, so the agent acts on false premises. OWASP files manipulation of a legitimate tool's interface under ASI02 and a tool compromised at the source under ASI04 [6]; MITRE ATLAS lists AI Agent Tool Poisoning (AML.T0110) [126]. Contrast with [Prompt injection](#). See [ch. 23, Admitting an MCP server](#). (ch. 23)

Training-content summary. The public summary of the content used to train a general-purpose AI model, required by AI Act Article 53(1)(d) on a mandatory Commission template covering data sources, including the most-scraped domains, and data processing [118]. See [ch. 14, The GPAI provider side](#). (ch. 14)

Training, validation and testing data. The three data sets the AI Act defines for high-risk systems: training data fits the model, validation data tunes it and guards against overfitting, and testing data gives an independent check before release [2]. Keeping them separate, and proving it, is what stops test-set contamination. Contrast with [Test-set contamination](#). See [ch. 14, Data for training and testing](#). (ch. 14)

Trajectory (agent). The sequence of plans, tool calls and memory operations that led an agent to an effect. Agents are evaluated on their trajectories as well as their final outputs, because a right result reached through a tool the agent should never have held is still a failure. See [ch. 23, What makes an agent a governance object](#). (ch. 14, 23)

Transaction token (Txn-Token). A short-lived, signed token, specified in an IETF OAuth working group draft, that carries user identity, workload identity and authorisation context through a call chain within one trusted domain, so downstream services can decide on protected context [131]. Still a draft (revision 11, 30 Jul 2026) as of 2026-09-24. Contrast with [Delegation \(OAuth token exchange\)](#). See [ch. 23, Accountability across hops](#). (ch. 23)

Transfer impact assessment (TIA). The data exporter's assessment of whether the law of a third country lets the importer honour the transfer tool, such as standard contractual clauses, and which supplementary measures are needed [119]. Remote inference endpoints and vendor telemetry outside the EEA can trigger it. See [ch. 19, Transfers, remote inference and TIAs](#). (ch. 19)

Transparency. In NIST's framing, how far information about an AI system and its outputs reaches the people who interact with it: what happened [30]. Evidenced by records of what ran (registry, model and system cards, logs) and by the disclosures the law requires. Contrast with [Explainability](#) and [Interpretability](#). See [ch. 16, Transparency, interpretability and explainability](#); [ch. 11, Contrast pairs](#). (ch. 11, 16)

Trustworthy AI. A banner used by other people's frameworks, notably the EU High-Level Expert Group [81] and NIST, whose seven trustworthy characteristics make it concrete [30]. This book cites it rather than adopting it: the discipline is measured by realised risk reduction and evidence, not by the label. Contrast with [AI governance engineering](#) and [Responsible-AI principle set](#). See [ch. 22, EU HLEG guidelines and ALTAI](#). (ch. 01, 22)

Trustworthy characteristics (NIST). The seven characteristics of trustworthy AI in the NIST AI RMF: valid and reliable; safe; secure and resilient; accountable and transparent; explainable and interpretable; privacy-enhanced; fair with harmful bias managed [30]. Valid and reliable is the base; accountable and transparent spans the others. See [ch. 22, The seven trustworthy characteristics](#). (ch. 22)

U

UDAP. Unfair or deceptive acts or practices, prohibited by section 5 of the FTC Act and by state laws [120]. Deception is a material representation likely to mislead; unfairness is substantial, unavoidable injury not outweighed by benefits. Unsubstantiated AI performance claims fall under it. See [ch. 20, Unfair and deceptive practices in the United States](#). (ch. 20)

Unsupervised learning. Learning structure (clusters, anomalies) from data without labels [40]. With no ground truth to test against, controls rely on stability tests and human review of the segments before they are used in decisions. Contrast with [Supervised learning](#). See [ch. 11, By learning paradigm](#). (ch. 11)

Use-case record. The intake record for a proposed AI use: business context, intended purpose and the uses ruled out, affected persons, decision authority, success metrics and error appetite, stored as fields on the registry entry so classification, thresholds, tests and impact assessments read the same facts [30]. See [ch. 14, The use-case record](#); [ch. 06, Intake and classification](#); [ch. 05, Pattern: Use-Case Intake & Risk Tying](#). (ch. 05, 06, 14)

V

Version pinning. Fixing, in the registry entry, the exact versions of the model, prompts, retrieval corpus and guardrails a deployed system uses, so what ran is known and any unpinned change, including a vendor's model update, is detected and treated as a release. See [ch. 15, Progressive delivery as a control](#); [ch. 05, Pattern: Staged Rollout with Rollback Criteria](#). (ch. 05, 15)

W

Watermarking. Embedding a signal in generated content (image, audio, video or text) that a detector can later read to identify it as AI-generated. The AI Act asks providers of generative systems for machine-readable, detectable marking [2]; NIST reviews watermarking alongside provenance tracking and detection [53]. Marks can degrade under ordinary transformations, so their survival is tested. Contrast with [Content provenance \(C2PA\)](#) and [Latent disclosure](#). See [ch. 18, Transparency cases \(Article 50\)](#). (ch. 18, 20)

Widespread infringement. Under AI Act Article 3(61), an act or omission contrary to Union law protecting individuals' interests that harms, or is likely to harm, the collective interests of individuals across several Member States. It shortens the Article 73 serious-incident deadline to two days [2]. Contrast with [Serious incident](#). See [ch. 17, Incident, hazard, issue and serious incident](#). (ch. 17)

Workload identity. The attributable identity a workload such as an agent carries across every hop, under which its actions are logged and its access is revoked, typically a short-lived, attested credential such as an SVID [124]. It differs from channel authentication, which secures a single hop, such as a client talking to an MCP server. Contrast with [NHI](#) and [SVID](#). See [ch. 23, Channel authentication is not agent identity](#); [ch. 04, Layer 04: Runtime Controls & Observability](#). (ch. 03, 04, 05, 23)

Sources

[1] Real Decreto 729/2023, de 22 de agosto, por el que se aprueba el Estatuto de la Agencia Española de Supervisión de Inteligencia Artificial (Royal Decree approving the AESIA statute; seat in A Coruña; BOE no. 210, 2 Sep 2023). Boletín Oficial del Estado. 2023-09-02. <https://www.boe.es/eli/es/rd/2023/08/22/729> (verified: primary) [2] Regulation (EU) 2024/1689 (AI Act), consolidated text as amended by Regulation (EU) 2026/1744 (Digital Omnibus on AI, in force 27 Jul 2026; definitions in Art. 3, incl. 3(1), 3(3) to 3(14), 3(14b), 3(20), 3(22), 3(23), 3(29) to 3(32), 3(49), 3(55) to 3(57), 3(60), 3(61), 3(63), 3(68); Arts. 4, 5, 6 (incl. 6(3) third subparagraph, profiling), 9, 10, 11, 13, 14, 15, 17, 22 to 27 (incl. 26(11)), 40, 41, 43, 47, 48, 50, 53 (incl. 53(1)(c)), 55, 57, 60, 72, 73, 86; Annexes I, III, IV). Publications Office of the EU (EUR-Lex). 2026-07-27. <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng> (verified: primary) [3] NIST AI Risk Management Framework 1.0 (Govern, Map, Measure, Manage); OSCAL. NIST. 2023. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary) [4] AI Controls Matrix v1.1 (247 control objectives, 18 domains) and STAR for AI. Cloud Security Alliance. 2026-06-22. <https://cloudsecurityalliance.org/star/ai> (verified: primary) [5] OWASP AI Maturity Assessment (AIMA), reported at v1.0 (Aug 2025). OWASP GenAI Security Project. 2025. <https://genai.owasp.org/initiatives/> (verified: reported) [6] Top 10 for Agentic Applications 2026 (ASI01 Agent Goal Hijack; ASI02 Tool Misuse and Exploitation; ASI03 Identity and Privilege Abuse; ASI04 Agentic Supply Chain Vulnerabilities; ASI05 Unexpected Code Execution (RCE); ASI06 Memory & Context Poisoning; ASI07 Insecure Inter-Agent Communication; ASI08 Cascading Failures; ASI09 Human-Agent Trust Exploitation; ASI10 Rogue Agents; Least-Agency; per-tool least-privilege profiles; tool poisoning of a legitimate tool's interface under ASI02, a tool compromised at the source under ASI04). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [7] MITRE ATLAS (adversarial threat knowledge base for AI). MITRE. 2026. <https://atlas.mitre.org/> (verified: primary) [8] Model Context Protocol specification 2026-07-28 (OAuth 2.1 resource servers; Client ID Metadata Documents; issuer-bound credentials). Anthropic / MCP. 2026-07-28. <https://blog.modelcontextprotocol.io/posts/2026-07-28/> (verified: primary) [9] "Gartner Predicts that Guardian Agents will Capture 10-15% of the Agentic AI Market by 2030" (at least 10 to 15% of agentic AI markets by 2030). Gartner. 2025-06-11. <https://www.gartner.com/en/newsroom/press-releases/2025-06-11-gartner-predicts-that-guardian-agents-will-capture-10-15-percent-of-the-agentic-ai-market-by-2030> (verified: primary) [10] Standardisation of the AI Act (no harmonised standard yet referenced in the Official Journal, so no presumption of conformity from any standard, ISO/IEC 42001 included; page last updated 2026-08-03; none found in the Publications Office index on 2026-09-24). European Commission. 2026-08-03. <https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation> (verified: primary) [11] Policy Cards: machine-readable runtime governance artefacts for agents. arXiv 2510.24383. 2025-10. <https://arxiv.org/abs/2510.24383> (verified: primary) [12] "Governor Hochul Signs Nation-Leading Legislation to Require AI Frameworks for AI Frontier Models" (RAISE Act, S6953B/A6453B, signed 19 Dec 2025; oversight office within the Department of Financial Services). Governor Kathy Hochul (New York State). 2025-12-19. <https://www.governor.ny.gov/news/governor-hochul-signs-nation-leading-legislation-require-ai-frameworks-ai-frontier-models> (verified: primary) [13] "Best AI Governance Platforms in 2026: 14 Enterprise Vendors Compared" (vendor-published comparison of the 13 Magic Quadrant vendors plus its own product; most of the category "manages the program ... without any runtime data path"). Kosmoy. 2026-07-10. <https://www.kosmoy.com/resources/blog/best-ai-governance-platforms-2026/> (verified: secondary) [14] California SB 53 / TFAIA (models above 10²⁶ FLOP; transparency reports and incident reports by all frontier developers; frameworks by large frontier developers). Future of Privacy Forum. 2025-10-03. <https://fpf.org/blog/californias-sb-53-the-first-frontier-ai-law-explained/> (verified: secondary) [15] "New York Finalizes RAISE Act for Frontier AI Models; Law Takes Effect January 1, 2027" (chapter amendment signed 27 Mar 2026; effective 1 Jan 2027; framework for large frontier developers, critical safety incident reports for every frontier developer; DFS oversight office). Wiley. 2026-04-03. <https://www.wiley.law/alert-New-York-Finalizes-RAISE-Act-for-Frontier-AI-Models-Law-Takes-Effect-January-1-2027> (verified: secondary) [16] The General-Purpose AI Code of Practice (published 10 Jul 2025; a voluntary tool; three chapters: Transparency, Copyright, Safety and Security). European Commission. 2025-07-10. <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai> (verified: primary) [17] ISO/IEC 42005:2025, AI system impact assessment (companion to Art. 27 and ISO 42001 Annex A.5). ISO/IEC. 2025-05. <https://www.iso.org/standard/44545.html> (verified: secondary) [18] 《人工智能安全治理框架3.0》发布: announcement of the AI Safety Governance Framework 3.0 (TC260 under CAC guidance). Cyberspace Administration of China. 2026-09-14. https://www.cac.gov.cn/2026-09/14/c_1791137092283345.htm (verified: primary) [19] AI Safety Governance Framework 3.0 (人工智能安全治理框架3.0), bilingual PDF. TC260 / CAC. 2026-09-14. <https://www.cac.gov.cn/rootimages/uploadimg/1791137114683961/1791137114683961.pdf> (verified: primary) [20] A Gentle Introduction to Conformal Prediction and Distribution-Free Uncertainty Quantification (prediction sets with user-specified coverage; arXiv 2107.07511). Angelopoulos and Bates. 2021-07-15. <https://arxiv.org/abs/2107.07511> (verified: primary) [21] Commission Guidelines on the definition of an artificial intelligence system established by Regulation (EU) 2024/1689 (C(2025) 5053 final; non-binding; seven elements of Art. 3(1), inference as the indispensable condition; exclusions). European Commission.

2025-02-06. <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-guidelines-ai-system-definition-facilitate-first-ai-acts-rules-application> (verified: primary) [22] CCPA regulations on automated decisionmaking technology, risk assessments and cybersecurity audits (approved 22 Sep 2025; effective 1 Jan 2026; ADMT definition § 7001(e); opt-out and appeal § 7221). California Privacy Protection Agency. 2025-09-22. https://cpa.ca.gov/regulations/ccpa_updates.html (verified: primary) [23] 12 CFR 1002.9 (Regulation B, notifications) (1002.9(b)(2) statement of specific principal reasons for adverse action; Supplement I commentary; text as of 2026-09-01). eCFR. 2026-09-01. <https://www.ecfr.gov/current/title-12/chapter-X/part-1002/section-1002.9> (verified: primary) [24] 29 CFR 1607.4(D), Uniform Guidelines on Employee Selection Procedures (1978) (adverse impact and the "four-fifths rule", with statistical-significance and small-numbers caveats; text as of 2026-09-01). eCFR. 2026-09-01. <https://www.ecfr.gov/current/title-29/subtitle-B/chapter-XIV/part-1607/section-1607.4> (verified: primary) [25] Basic Act on the Development of Artificial Intelligence and the Establishment of a Foundation for Trust (Korea AI Basic Act) (Act No. 20676, in force 2026-01-22; Art. 2 as amended 2026-01-20; Arts. 2(4) high-impact areas, 2(7) AI business operators, 33 confirmation, 34 high-impact duties, 36 domestic representative). Korean Law Information Center (MOLEG). 2026-01-22. <https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=268543> (verified: primary) [26] OMB Memorandum M-25-21, Accelerating Federal Use of AI through Innovation, Governance, and Public Trust (agency AI Governance Boards chaired at Deputy Secretary level with IT, cybersecurity, data, budget, legal, privacy, civil rights and civil liberties representation). Office of Management and Budget, The White House. 2025-04-03. <https://www.whitehouse.gov/wp-content/uploads/2025/02/M-25-21-Accelerating-Federal-Use-of-AI-through-Innovation-Governance-and-Public-Trust.pdf> (verified: primary) [27] The AI Risk Repository: a meta-review, database, and taxonomy of risks from artificial intelligence (Domain Taxonomy of 7 domains and 24 subdomains; CC BY 4.0). Slattery, Saeri, Grundy et al., Patterns (Cell Press). 2026. <https://doi.org/10.1016/j.patter.2026.101517> (verified: primary) [28] "Name it to tame it: defining AI incidents and hazards" (summary of the OECD paper "Defining AI incidents and related terms", doi 10.1787/d1a8d965-en). OECD.AI. 2024-05-17. <https://oecd.ai/en/wonk/defining-ai-incidents-and-hazards> (verified: primary) [29] NIST AI RMF Playbook, GOVERN (per subcategory: About, Suggested Actions, Transparency and Documentation, References; GOVERN 1.7 decommissioning and phasing out safely). NIST Trustworthy and Responsible AI Resource Center. 2026. <https://airc.nist.gov/airmf-resources/playbook/govern/> (verified: primary) [30] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (risk tolerance and residual risk; seven trustworthy characteristics; transparency answers "what happened", explainability "how", interpretability "why"; MAP 1.1 intended purposes; MANAGE 1.1 go/no-go determination; profiles). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [31] Recommendation of the Council on Artificial Intelligence, OECD/LEGAL/0449 (adopted 22 May 2019; AI-system definition revised 8 Nov 2023; revised 3 May 2024; five principles and five recommendations; 1.3 enables people adversely affected to challenge an output; definitions of AI system, lifecycle and AI actors). OECD. 2024-05-03. <https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449> (verified: primary) [32] "SEC Charges Two Investment Advisers with Making False and Misleading Statements About Their Use of Artificial Intelligence" (Delphia and Global Predictions). US Securities and Exchange Commission. 2024-03-18. <https://www.sec.gov/newsroom/press-releases/2024-36> (verified: primary) [33] In the Matter of Everalbum, Inc., Decision and Order ("Affected Work Product": models or algorithms developed with users' biometric information, to be deleted). Federal Trade Commission. 2021-05-07. https://www.ftc.gov/system/files/documents/cases/1923172_-_everalbum_decision_final.pdf (verified: primary) [34] Directive on Automated Decision-Making (algorithmic impact assessment completed and published before production; Appendix B and C impact levels; recourse; modified 2025-06-24). Treasury Board of Canada Secretariat. 2025-06-24. <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32592> (verified: primary) [35] Directive (EU) 2024/2831 on improving working conditions in platform work (Arts. 7 limits on processing, 9 transparency, 10 human oversight, 11 human review; transposition by 2 Dec 2026). Official Journal of the EU (EUR-Lex). 2024-10-23. <https://eur-lex.europa.eu/eli/dir/2024/2831/oj> (verified: primary) [36] Algorithmic Transparency Recording Standard Hub (mandatory for government departments and for arm's-length bodies delivering public or frontline services). Government Digital Service. 2025-05-08. <https://www.gov.uk/government/collections/algorithmic-transparency-recording-standard-hub> (verified: primary) [37] Assessment List for Trustworthy Artificial Intelligence (ALTAI) for self-assessment (final list presented 17 Jul 2020 after a pilot; document and web tool). High-Level Expert Group on AI / European Commission. 2020-07-17. <https://digital-strategy.ec.europa.eu/en/library/assessment-list-trustworthy-artificial-intelligence-altai-self-assessment> (verified: primary) [38] Regulation (EU) 2016/679 (General Data Protection Regulation) (Arts. 4(1), 4(5), 4(7), 4(8), 4(12), 4(14), 5, 6, 9, 12(3), 22, 25, 28(2) and 28(4), 30, 33, 35; Recital 26). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [39] Press release No 186/23: judgment in Case C-634/21, SCHUFA Holding (Scoring) (a credit score is an automated individual decision where lenders give it a determining role). Court of Justice of the EU. 2023-12-07. <https://curia.europa.eu/jcms/upload/docs/application/pdf/2023-12/cp230186en.pdf> (verified: primary) [40] ISO/IEC 22989:2022, Artificial intelligence concepts and terminology (referenced by identifier only; autonomy and heteronomy; clause 5.11 machine learning approaches: supervised, unsupervised, semi-supervised, reinforcement). ISO/IEC. 2022-07. <https://www.iso.org/standard/74296.html> (verified: secondary) [41] NIST SP 1270, Towards a Standard for Identifying and Managing Bias in Artificial Intelligence (three categories of AI bias: systemic, statistical and computational, and human). NIST. 2022-03-15. <https://doi.org/10.6028/NIST.SP.1270> (verified: primary) [42] Automated Employment Decision Tools: Frequently Asked Questions (Local Law 144 of 2021; bias audit by an independent auditor within the past year; selection rates and impact ratios by sex, race/ethnicity and intersectional categories; public summary; notice before use). NYC Department of Consumer and Worker Protection. 2023. <https://www.nyc.gov/assets/dca/downloads/pdf/about/DCWP-AEDT-FAQ.pdf> (verified: primary) [43] "Postmortem Culture: Learning from Failure" (Site Reliability Engineering, ch. 15). Google. 2016. <https://sre.google/sre-book/postmortem-culture/> (verified: primary) [44] "BlueGreenDeployment" (two identical production environments; switch back on failure). Martin Fowler. 2010-03-01. <https://martinfowler.com/bliki/BlueGreenDeployment.html> (verified: primary) [45] On Calibration of Modern Neural Networks (modern networks poorly calibrated; ICML 2017; arXiv 1706.04599). Guo, Pleiss, Sun and Weinberger. 2017-06-14. <https://arxiv.org/abs/1706.04599> (verified: primary) [46] "Inherent Trade-Offs in the Fair Determination of

Risk Scores" (Kleinberg, Mullainathan and Raghavan; three fairness conditions cannot hold together except in special cases; arXiv 1609.05807). arXiv. 2016-09-19. <https://arxiv.org/abs/1609.05807> (verified: primary) [47] The Site Reliability Workbook, ch. 16 "Canarying Releases" ("a partial and time-limited deployment of a change in a service and its evaluation"). Google (O'Reilly). 2018. <https://sre.google/workbook/canarying-releases/> (verified: primary) [48] ISO/IEC 42001:2023, AI management systems (referenced by identifier only; requirements for an AI management system; clause 10.2 nonconformity and corrective action). ISO/IEC. 2023. <https://www.iso.org/standard/81230.html> (verified: secondary) [49] Overcoming catastrophic forgetting in neural networks (networks lose earlier competence when trained on new tasks; arXiv 1612.00796). Kirkpatrick et al.. 2016-12-02. <https://arxiv.org/abs/1612.00796> (verified: primary) [50] Working groups and projects of CEN-CENELEC JTC 21 (WG 2 operational aspects, WG 3 engineering aspects, WG 4 foundational and societal aspects, WG 5 cybersecurity). JTC 21 website. 2026. <https://jtc21.eu/working-groups/> (verified: secondary) [51] "Learning under Concept Drift: A Review" (IEEE TKDE 31(12); detection, understanding and adaptation; arXiv 2004.05785). Lu et al.. 2018. <https://arxiv.org/abs/2004.05785> (verified: primary) [52] Content Credentials: C2PA Technical Specification, version 2.2 (a manifest of assertions, a claim and a claim signature bound to an asset). Coalition for Content Provenance and Authenticity (C2PA). 2025-05. https://spec.c2pa.org/specifications/specifications/2.2/specs/C2PA_Specification.html (verified: primary) [53] NIST AI 100-4, Reducing Risks Posed by Synthetic Content: An Overview of Technical Approaches to Digital Content Transparency (provenance data tracking, watermarking, metadata recording and synthetic-content detection). NIST. 2024-11-20. <https://doi.org/10.6028/NIST.AI.100-4> (verified: primary) [54] "Counterfactual Explanations without Opening the Black Box: Automated Decisions and the GDPR" (Wachter, Mittelstadt and Russell; Harvard Journal of Law & Technology, 2018; arXiv 1711.00399). arXiv. 2017-11-01. <https://arxiv.org/abs/1711.00399> (verified: primary) [55] "Counterfactual Fairness" (Kusner, Loftus, Russell and Silva; arXiv 1703.06856). arXiv. 2017-03-20. <https://arxiv.org/abs/1703.06856> (verified: primary) [56] OpenLineage: an open platform for collection and analysis of data lineage (standard API for lineage events over datasets, jobs and runs). OpenLineage project (The Linux Foundation). 2026. <https://openlineage.io/> (verified: primary) [57] PROV Overview (PROV-DM and PROV-O W3C Recommendations of 30 April 2013; provenance as information about the entities, activities and people involved in producing data). W3C. 2013-04-30. <https://www.w3.org/TR/prov-overview/> (verified: primary) [58] Datasheets for Datasets (Gebru et al.; arXiv 1803.09010). arXiv. 2018-03-23. <https://arxiv.org/abs/1803.09010> (verified: primary) [59] "Fairness Through Awareness" (Dwork, Hardt, Pitassi, Reingold and Zemel; individual fairness; limits of statistical parity; arXiv 1104.3913). arXiv. 2011-04-20. <https://arxiv.org/abs/1104.3913> (verified: primary) [60] "Products liability" (design, manufacturing and marketing defects, incl. failure to warn; consumer-expectation and risk-utility tests). Legal Information Institute, Wex. 2026. https://www.law.cornell.edu/wex/products_liability (verified: secondary) [61] NIST SP 800-226, Guidelines for Evaluating Differential Privacy Guarantees (differential privacy pyramid; privacy hazards). NIST. 2025-03. <https://csrc.nist.gov/pubs/sp/800/226/final> (verified: primary) [62] 42 U.S.C. § 2000e-2 (Title VII: unlawful employment practices; 2000e-2(k) burden of proof in disparate-impact cases, business necessity and less discriminatory alternatives). Legal Information Institute, Cornell Law School. 2026. <https://www.law.cornell.edu/uscode/text/42/2000e-2> (verified: secondary) [63] Council Directive 2000/43/EC (Racial Equality Directive) (Art. 2(2)(a) direct and 2(2)(b) indirect discrimination, with objective justification). Official Journal of the EU (EUR-Lex). 2000-06-29. <https://eur-lex.europa.eu/eli/dir/2000/43/oj/eng> (verified: primary) [64] Enforcement Decree of the AI Basic Act (Presidential Decree No. 36053, in force 2026-01-22; Art. 29 domestic-representative thresholds). Korean Law Information Center (MOLEG). 2026-01-21. <https://www.law.go.kr/LSW/lsInfoP.do?efYd=20260122&lsiSeq=282879> (verified: primary) [65] Guidelines on obligations for general-purpose AI providers, FAQ (a modifier becomes a provider only when the modification uses more than one third of the original model's training compute; obligations limited to the modification). European Commission. 2025. <https://digital-strategy.ec.europa.eu/en/faqs/guidelines-obligations-general-purpose-ai-providers> (verified: primary) [66] "Dual use of artificial-intelligence-powered drug discovery" (an inverted toxicity model proposed about 40,000 candidate toxic molecules in under six hours; Nature Machine Intelligence). Urbina, Lentzos, Invernizzi and Ekins (PubMed Central). 2022-03-07. <https://pmc.ncbi.nlm.nih.gov/articles/PMC9544280/> (verified: primary) [67] SR 26-2, Revised Guidance on Model Risk Management (issued 17 Apr 2026 by the Federal Reserve, OCC and FDIC; supersedes and replaces SR 11-7 of 4 Apr 2011 and SR 21-8; effective challenge). Board of Governors of the Federal Reserve System. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> (verified: primary) [68] "Equality of Opportunity in Supervised Learning" (Hardt, Price and Srebro; equalised odds and equal opportunity; arXiv 1610.02413). arXiv. 2016-10-07. <https://arxiv.org/abs/1610.02413> (verified: primary) [69] Evidence-record schema v1 (evidence-record.v1.json) (AI Governance Engineer templates and schemas library). aigovernanceengineer.com. 2026-09-24. <https://aigovernanceengineer.com/schemas/evidence-record.v1.json> (verified: primary) [70] 17 U.S.C. § 107, Limitations on exclusive rights: fair use (the four factors). Legal Information Institute, Cornell Law School. 2026. <https://www.law.cornell.edu/uscode/text/17/107> (verified: secondary) [71] "Preventing Fairness Gerrymandering: Auditing and Learning for Subgroup Fairness" (Kearns, Neel, Roth and Wu; arXiv 1711.05144). arXiv. 2017-11-14. <https://arxiv.org/abs/1711.05144> (verified: primary) [72] "Communication-Efficient Learning of Deep Networks from Decentralized Data" (McMahan et al.; federated learning; arXiv 1602.05629). arXiv. 2016-02-17. <https://arxiv.org/abs/1602.05629> (verified: primary) [73] On the Opportunities and Risks of Foundation Models ("trained on broad data at scale"; defects inherited downstream; arXiv 2108.07258). Bommasani et al. (Stanford CRFM). 2021-08-16. <https://arxiv.org/abs/2108.07258> (verified: primary) [74] Council of Europe Framework Convention on Artificial Intelligence and Human Rights, Democracy and the Rule of Law (CETS No. 225) (Art. 3 scope and private-actor declaration; Arts. 14 and 15 remedies and safeguards; Art. 16 risk and impact management). Council of Europe. 2024-09-05. <https://rm.coe.int/1680afae3c> (verified: primary) [75] Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1 (twelve risks unique to or exacerbated by generative AI; confabulation defined). NIST. 2024-07. <https://doi.org/10.6028/NIST.AI.600-1> (verified: primary) [76] Commission Guidelines on the scope of the obligations for providers of general-purpose AI models (content approved 18 July 2025 by C(2025)

5045 final; formal text C(2025) 7719 final of 19 Nov 2025; paras. 65 to 68 on modifiers; non-binding; indicative criterion of training compute above 10^{23} FLOP with the ability to generate language, images or video). European Commission. 2025-11-19. <https://digital-strategy.ec.europa.eu/en/library/guidelines-scope-obligations-providers-general-purpose-ai-models-under-ai-act> (verified: primary) [77] "Feature Toggles (aka Feature Flags)" (release, experiment, ops and permissioning toggles; ops kill switches for graceful degradation). Pete Hodgson, martinowler.com. 2017-10-09. <https://martinowler.com/articles/feature-toggles.html> (verified: primary) [78] Management system standards (Harmonized Structure; Annex SL common text; integrated management systems). ISO. 2026. <https://www.iso.org/management-system-standards.html> (verified: primary) [79] Hiroshima Process International Code of Conduct for Organizations Developing Advanced AI Systems (11 actions; voluntary; builds on the OECD AI Principles). G7 / European Commission. 2023-10-30. <https://digital-strategy.ec.europa.eu/en/library/hiroshima-process-international-code-conduct-advanced-ai-systems> (verified: primary) [80] HUDERIA: risk and impact assessment of AI systems (HUDERIA Methodology approved 26 Feb 2025; non-binding). Council of Europe. 2026. <https://www.coe.int/en/web/artificial-intelligence/huderia-risk-and-impact-assessment-of-ai-systems> (verified: primary) [81] Ethics Guidelines for Trustworthy AI (four ethical principles; seven requirements; human-in-the-loop, human-on-the-loop and human-in-command oversight). High-Level Expert Group on AI / European Commission. 2019-04-08. <https://digital-strategy.ec.europa.eu/en/library/ethics-guidelines-trustworthy-ai> (verified: primary) [82] Chapter 19.373 RCW, Washington My Health My Data Act (consumer health data includes data derived or extrapolated from non-health information, incl. by algorithms or machine learning). Washington State Legislature. 2023. <https://app.leg.wa.gov/RCW/default.aspx?cite=19.373&full=true> (verified: primary) [83] Directive (EU) 2019/1937 on the protection of persons who report breaches of Union law (Art. 8 internal channels for private entities with 50 or more workers; Art. 9 acknowledgment within seven days and feedback within three months; Art. 19 no retaliation). Publications Office of the EU (EUR-Lex). 2019-10-23. <https://eur-lex.europa.eu/eli/dir/2019/1937/oj/eng> (verified: primary) [84] LLM01:2025 Prompt Injection (OWASP Top 10 for LLM Applications 2025; direct and indirect injection; jailbreaking as a form of prompt injection that makes the model disregard its safety protocols). OWASP GenAI Security Project. 2025. <https://genai.owasp.org/llmrisk/llm01-prompt-injection/> (verified: primary) [85] JSON Schema Draft 2020-12. JSON Schema. 2022-06-16. <https://json-schema.org/draft/2020-12> (verified: primary) [86] Phi-3 Technical Report: A Highly Capable Language Model Locally on Your Phone (3.8-billion-parameter model deployable on a phone; arXiv 2404.14219). Abidin et al. (Microsoft). 2024-04-22. <https://arxiv.org/abs/2404.14219> (verified: primary) [87] AB-853, California AI Transparency Act (amends SB 942; chaptered 2025-10-13; operative 2026-08-02; latent disclosures in generated content). California Legislative Information. 2025-10-13. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202520260AB853 (verified: primary) [88] Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (three-step legitimate-interest test; anonymity test and evidence). European Data Protection Board. 2024-12-17. https://www.edpb.europa.eu/system/files/2024-12/edpb_opinion_202428_ai-models_en.pdf (verified: primary) [89] "Why Should I Trust You?": Explaining the Predictions of Any Classifier" (Ribeiro, Singh and Guestrin; LIME; arXiv 1602.04938). arXiv. 2016-02-16. <https://arxiv.org/abs/1602.04938> (verified: primary) [90] "Machine Unlearning" (Bourtoulet et al.; SISA training; arXiv 1912.03817). arXiv. 2019-12-09. <https://arxiv.org/abs/1912.03817> (verified: primary) [91] Commission Delegated Regulation (EU) 2025/301 (Art. 5, time limits for major ICT-related incident reports under DORA; Art. 5(2) late classification). Publications Office of the EU (EUR-Lex). 2024-10-23. https://eur-lex.europa.eu/eli/reg_del/2025/301/oj/eng (verified: primary) [92] "Membership Inference Attacks against Machine Learning Models" (Shokri et al.; arXiv 1610.05820). arXiv. 2016-10-18. <https://arxiv.org/abs/1610.05820> (verified: primary) [93] Hierarchy of Controls (elimination, substitution, engineering controls, administrative controls, PPE). CDC / NIOSH. 2024-04-10. <https://www.cdc.gov/niosh/hierarchy-of-controls/about/index.html> (verified: primary) [94] "Model Inversion Attacks that Exploit Confidence Information and Basic Countermeasures" (Fredrikson, Jha and Ristenpart; CCS 2015). ACM. 2015-10-12. <https://doi.org/10.1145/2810103.2813677> (verified: primary) [95] General-Purpose AI Code of Practice, Safety and Security chapter (Commitment 9, serious incident reporting, Measure 9.2; Appendix 1.4 specified systemic risks, incl. loss of control). European Commission. 2025-07-10. <https://ec.europa.eu/newsroom/dae/redirection/document/118119> (verified: primary) [96] SB 1223, Consumer privacy: sensitive personal information: neural data (neural data added to sensitive personal information under the CCPA; Chapter 887, Statutes of 2024). California Legislature. 2024-09-28. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202320240SB1223 (verified: primary) [97] OECD Framework for the Classification of AI Systems (OECD Digital Economy Papers No. 323; People & Planet, Economic Context, Data & Input, AI Model, Task & Output). OECD. 2022-02-22. <https://doi.org/10.1787/cb6d9eca-en> (verified: primary) [98] "How the machine thinks: Understanding opacity in machine learning algorithms" (three forms of opacity; Big Data & Society 3(1)). SAGE (Jenna Burrell). 2016-01-06. <https://doi.org/10.1177/2053951715622512> (verified: primary) [99] Llama 3.1 Community License Agreement (an example of an open-weight licence with an incorporated acceptable-use policy and attribution terms). Meta. 2024-07-23. https://github.com/meta-llama/llama-models/blob/main/models/llama3_1/LICENSE (verified: primary) [100] Personal Information Protection Law of the People's Republic of China (Arts. 55 and 56 personal information protection impact assessment, records kept three years; official English translation). National People's Congress. 2021-08-20. http://en.npc.gov.cn.cdurl.cn/2021-12/29/c_694559.htm (verified: primary) [101] Directive (EU) 2024/2853 on liability for defective products (software as a product; defectiveness incl. the ability to continue to learn; substantial modification; transposition by 9 Dec 2026). Official Journal of the EU (EUR-Lex). 2024-10-23. <https://eur-lex.europa.eu/eli/dir/2024/2853/oj> (verified: primary) [102] "Dissecting racial bias in an algorithm used to manage the health of populations" (Obermeyer, Powers, Vogeli and Mullainathan; Science 366(6464):447-453; cost as a proxy for need). Science. 2019-10-25. <https://doi.org/10.1126/science.aax2342> (verified: primary) [103] "Actionable Recourse in Linear Classification" (Ustun, Spangher and Liu; recourse as the ability to change a model's decision by altering actionable inputs; arXiv 1809.06514). arXiv. 2018-09-18. <https://arxiv.org/abs/1809.06514> (verified: primary) [104] "Extracting Training Data from Large Language Models" (Carlini et al.; verbatim training sequences extracted, incl. personal data; arXiv 2012.07805). arXiv. 2020-12-14. <https://arxiv.org/abs/2012.07805> (verified: primary) [105] "Training language models to follow

instructions with human feedback" (Ouyang et al.; supervised fine-tuning on demonstrations, then reinforcement learning from human feedback on ranked outputs; arXiv 2203.02155). arXiv. 2022-03-04. <https://arxiv.org/abs/2203.02155> (verified: primary) [106] "OpenRAIL: Towards open and responsible AI licensing frameworks" (use-based restrictions that redistributions and derivatives must carry). Hugging Face. 2022-08-31. https://huggingface.co/blog/open_rail (verified: primary) [107] Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks (parametric and non-parametric memory; arXiv 2005.11401). Lewis et al. 2020-05-22. <https://arxiv.org/abs/2005.11401> (verified: primary) [108] Concrete Problems in AI Safety (reward hacking among five practical problems; arXiv 1606.06565). Amodei et al. 2016-06-21. <https://arxiv.org/abs/1606.06565> (verified: primary) [109] ISO 31073:2022, Risk management: Vocabulary (replaced ISO Guide 73:2009, withdrawn; referenced by identifier only). ISO/TC 262. 2022-02. <https://www.iso.org/standard/79637.html> (verified: primary) [110] What's Wrong with Risk Matrices? (L. A. Cox Jr.; Risk Analysis 28(2) 497-512). Wiley. 2008-04. <https://doi.org/10.1111/j.1539-6924.2008.01030.x> (verified: primary) [111] Crosswalk: AI RMF (1.0) and ISO/IEC FDIS 23894 (function-to-clause mapping, incl. risk sources). NIST. 2023-01-26. https://www.nist.gov/system/files/documents/2023/01/26/crosswalk_AI_RMF_1_0_ISO_IEC_23894.pdf (verified: primary) [112] IEC 61025:2006, Fault tree analysis (FTA) (edition 2.0). IEC. 2006-12-13. <https://webstore.iec.ch/en/publication/4311> (verified: primary) [113] "A Unified Approach to Interpreting Model Predictions" (Lundberg and Lee; SHAP; arXiv 1705.07874). arXiv. 2017-05-22. <https://arxiv.org/abs/1705.07874> (verified: primary) [114] "System Cards, a new resource for understanding how AI systems work" (documents a whole system of models, AI and non-AI components, where a model card documents one model). Meta AI. 2022-02-23. <https://ai.meta.com/blog/system-cards-a-new-resource-for-understanding-how-ai-systems-work/> (verified: primary) [115] Directive (EU) 2019/790 on copyright and related rights in the Digital Single Market (Arts. 3 and 4: text and data mining for research and a general exception subject to a machine-readable reservation). Official Journal of the EU (EUR-Lex). 2019-04-17. <https://eur-lex.europa.eu/eli/dir/2019/790/oj> (verified: primary) [116] Proving Test Set Contamination in Black Box Language Models (Oren et al.; arXiv 2310.17623). arXiv. 2023-10-26. <https://arxiv.org/abs/2310.17623> (verified: primary) [117] The IIA's Three Lines Model: an update of the Three Lines of Defense (governing body; management's first- and second-line roles; internal audit as third line; third-line independence). The Institute of Internal Auditors. 2020-07. <https://www.theiia.org/en/content/position-papers/2020/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense/> (verified: primary) [118] Template for general-purpose AI model providers to summarise their training content (mandatory under Art. 53(1)(d); applicable from 2 Aug 2025, legacy models by 2 Aug 2027). European Commission. 2025-07-24. <https://digital-strategy.ec.europa.eu/en/faqs/template-general-purpose-ai-model-providers-summarise-their-training-content> (verified: primary) [119] Recommendations 01/2020 on measures that supplement transfer tools to ensure compliance with the EU level of protection of personal data (version 2.0). European Data Protection Board. 2021-06-18. https://www.edpb.europa.eu/our-work-tools/our-documents/recommendations/recommendations-012020-measures-supplement-transfer_en (verified: primary) [120] 15 U.S.C. § 45 (FTC Act section 5) (unfair or deceptive acts or practices; 45(n) standard for unfairness). Legal Information Institute, Cornell Law School. 2026. <https://www.law.cornell.edu/uscode/text/15/45> (verified: secondary) [121] Revised Guidance on Model Risk Management, attachment to SR 26-2 (footnote 3: generative AI and agentic AI models "are not within the scope of this guidance"; the principles apply to traditional statistical and quantitative models and non-generative, non-agentic AI models). Federal Reserve, OCC and FDIC. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602a1.pdf> (verified: primary) [122] "Levels of Autonomy for AI Agents" (K. J. Kevin Feng, David W. McDonald, Amy X. Zhang; arXiv 2506.12469; autonomy as a deliberate design decision separate from capability and operational environment; five levels by user role: operator, collaborator, consultant, approver, observer). arXiv. 2025-06-14 (v2 2025-07-28). <https://arxiv.org/abs/2506.12469> (verified: primary) [123] RFC 8693, OAuth 2.0 Token Exchange (impersonation versus delegation semantics; the act (actor) claim; nested act claims record prior actors). IETF. 2020-01. <https://www.rfc-editor.org/rfc/rfc8693.html> (verified: primary) [124] SPIFFE overview (short-lived cryptographic identity documents called SVIDs, as X.509 certificates or JWTs; the Workload API issues and rotates them; SPIRE implementation). SPIFFE project. 2026. <https://spiffe.io/docs/latest/spiffe-about/overview/> (verified: primary) [125] Model Context Protocol, Security Best Practices, version 2026-07-28 (token passthrough defined and explicitly forbidden; servers MUST NOT accept any tokens not explicitly issued for them; audience validation). Model Context Protocol. 2026-07-28. https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices (verified: primary) [126] MITRE ATLAS data, release v2026.09 (AML.T0080 AI Agent Context Poisoning, .000 Memory; AML.T0110 AI Agent Tool Poisoning). MITRE. 2026-09-15. <https://github.com/mitre-atlas/atlas-data/releases/tag/v2026.09> (verified: primary) [127] Agent Control Standard (ACS) repository (a wire specification that lets a separate guardian agent permit, deny or modify an agent's action before it happens; the reference guardian's failure posture defaults to proceed, overridable to deny; donated to the OWASP GenAI Security Project, announced 1 Sep 2026). OWASP GenAI Security Project (GitHub). 2026-09-01. <https://github.com/GenAI-Security-Project/agent-control-standard> (verified: primary) [128] OWASP GenAI LLM Top 10 2026 (published 3 Aug 2026; LLM01:2026 Prompt Injection, incl. memory persistence; LLM08:2026 Hidden Context Exposure, which replaced System Prompt Leakage: assume hidden context is discoverable, no credentials in it, not a security boundary; final text in github.com/GenAI-Security-Project/GenAI-LLM-Top10, 2026/final). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [129] Agent2Agent (A2A) Protocol Specification, v1.0 (v1.0.0 released 2026-03-12 and v1.0.1 on 2026-05-28 in github.com/a2aproject/A2A; Agent Card at [/.well-known/agent-card.json](https://well-known.agent-card.json), signed with JWS over JCS-canonicalised JSON; servers authenticate every request; authorisation implementation-specific; scope and revocation of in-task authorisation not defined). A2A Project (Linux Foundation). 2026-05-28. <https://a2a-protocol.org/latest/specification/> (verified: primary) [130] "A New Chapter for A2A: Joining the Agentic AI Foundation" (A2A accepted as a Growth Stage project of the Linux Foundation-directed Agentic AI Foundation, alongside MCP). A2A Project. 2026-08-27. <https://a2a-protocol.org/latest/blog/2026/08/27/a-new-chapter-for-a2a-joining-the-agentic-ai-foundation/> (verified: primary) [131] draft-ietf-oauth-transaction-tokens-11, Transaction Tokens (Internet-Draft, OAuth working group, revision 11 of 30 Jul 2026, WG state "Waiting for Write-Up"; short-lived signed tokens that propagate user identity, workload identity and authorisation context through a call chain within a trusted domain). IETF. 2026-07-30. <https://datatracker.ietf.org/doc/draft-ietf->

oauth-transaction-tokens/ (verified: primary) [132] draft-ietf-oauth-client-id-metadata-document-02, OAuth Client ID Metadata Document (Internet-Draft, OAuth working group, revision 02 of 6 Jul 2026; a URL used as client_id that refers to the client's metadata document). IETF. 2026-07-06. <https://datatracker.ietf.org/doc/draft-ietf-oauth-client-id-metadata-document/> (verified: primary) [133] Threats: Microsoft Threat Modeling Tool (the STRIDE model: spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege; the tool is a core element of the Security Development Lifecycle). Microsoft Learn. 2017-08-17. <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats> (verified: primary) [134] Threat Modeling Manifesto (threat modelling as analysing representations of a system to highlight concerns about security and privacy characteristics; four key questions). Threat Modeling Manifesto working group. n.d. (accessed 2026-09-25). <https://www.threatmodelingmanifesto.org/> (verified: primary) [135] "An Introduction to the OpenSSF Model Signing (OMS) Specification" (detached signature over a manifest of file hashes; Sigstore bundle format; PKI-agnostic: private PKI, self-signed certificates, bare keys, keyless Sigstore). OpenSSF. 2025-06-25. <https://openssf.org/blog/2025/06/25/an-introduction-to-the-openssf-model-signing-oms-specification/> (verified: primary) [136] SLSA specification v1.2, Build track basics (provenance: what built the artefact, by what process and from which top-level inputs; Build L1 provenance exists, L2 hosted build platform, L3 hardened builds). OpenSSF SLSA project. n.d. (accessed 2026-09-25). <https://slsa.dev/spec/v1.2/build-track-basics> (verified: primary) [137] Safetensors ("a new simple format for storing tensors safely (as opposed to pickle)"). Hugging Face documentation. n.d. (accessed 2026-09-25). <https://huggingface.co/docs/safetensors/index> (verified: primary) [138] pickle: Python object serialization ("The pickle module is not secure. Only unpickle data you trust."). Python Software Foundation. 2026. <https://docs.python.org/3/library/pickle.html> (verified: primary) [139] "FTC Order Requires Workado to Back Up Artificial Intelligence Detection Claims" (claimed 98% accuracy, 53% on general-purpose content; competent and reliable evidence required at the time a claim is made). Federal Trade Commission. 2025-04-28. <https://www.ftc.gov/news-events/news/press-releases/2025/04/ftc-order-requires-workado-back-artificial-intelligence-detection-claims> (verified: primary) [140] "Ensuring and facilitating the exercise of data subjects' rights" (AI how-to sheet; retraining; output filters accepted if shown sufficiently effective and robust, based on general rules rather than lists of people). CNIL. 2026-01-05. <https://www.cnil.fr/en/respect-and-facilitate-exercise-data-subjects-rights> (verified: primary) [141] Authorization (Cedar Policy Language Reference Guide) (no request is allowed unless a permit policy grants it, so the default decision is Deny; any satisfied forbid overrides every permit). Cedar. n.d. (accessed 2026-09-25). <https://docs.cedarpolicy.com/auth/authorization.html> (verified: primary) [142] SB 53, Transparency in Frontier Artificial Intelligence Act (Chapter 138, Statutes of 2025, approved and filed 29 Sep 2025; a regular-session statute, in force from 1 Jan 2026 under Cal. Const. art. IV, §8(c)(1); frontier model > 10²⁶ operations; large frontier developer > USD 500M revenue; frontier AI framework; transparency report; critical safety incidents to the Office of Emergency Services within 15 days). California Legislature. 2025-09-29. https://leginfo.legislature.ca.gov/faces/billTextClient.xhtml?bill_id=202520260SB53 (verified: primary)

10. Reading list

The sources that formed the discipline, curated and annotated, each with a verified URL and a one-line note on why it matters.

This is a working bibliography, not a canon. Entries are grouped by theme and annotated in one line. URLs are given inline with a verification tag (`primary` , `secondary` , `reported`) so the chapter is self-documenting; every URL is either drawn from the book's research digest or verified for this edition. Tools are named as category examples, illustrative and not endorsements.

Every entry also carries two tags: the **audience** it serves best (`engineering` , `governance` , `legal` , `leadership` , `research`) and the **jurisdiction** it speaks to (`global` when it is not tied to one legal order). The tags are a reading aid, not a ranking. The same list, filterable by both tags, is on the site's resources page. No commercial study guide for any certification is listed.

Foundational texts (the form and the method)

- **GRC Engineering Manifesto**: the parent discipline's founding statement; the structural and philosophical model for this book. <https://grc.engineering/> (verified: primary) (audience: governance, engineering; jurisdiction: global)
- **"What is GRC Engineering" (Ayoub Fandi)**: the clearest definition of the parent method and the source of the "green dashboard over a broken control is theatre" test. <https://grcengineer.com/what-is-grc-engineering/> (verified: primary) (audience: governance, engineering; jurisdiction: global)
- **The Agile Manifesto**: the numbered values-and-principles form and the signatory model this book borrows. <https://agilemanifesto.org/> (verified: primary) (audience: engineering, leadership; jurisdiction: global)
- **The Twelve-Factor App**: the template for a numbered, practitioner-facing body of practice with a "who should read this" framing. <https://12factor.net/> (verified: primary) (audience: engineering; jurisdiction: global)
- **CSIRO Responsible AI Pattern Catalogue**: the pattern template (chapter 05) and proof that responsible-AI practice can be written as reusable patterns. <https://research.csiro.au/ss/science/projects/responsible-ai-pattern-catalogue/> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **privacypatterns.org**: the precedent for translating a legal principle (privacy by design) into engineering patterns under CC BY. <https://privacypatterns.org/> (verified: primary) (audience: engineering, legal; jurisdiction: global)

Regulation and standards

- **EU AI Act, consolidated text (EUR-Lex)**: Regulation (EU) 2024/1689 as amended by the Digital Omnibus (Regulation (EU) 2026/1744), consolidated on 27 July 2026; the primary obligation source for chapter 08. <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng> (verified: primary) (audience: legal, governance, engineering; jurisdiction: EU)
- **Digital Omnibus on AI, Regulation (EU) 2026/1744 (EUR-Lex)**: the amending act as published in the Official Journal on 24 July 2026, with the new dates and the new Articles 4a and 75a-75d. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) (audience: legal, governance; jurisdiction: EU)
- **AI Act Explorer (Future of Life Institute)**: a navigable, article-by-article reading of the Act and the Omnibus changes; commentary and navigation, not the legal text. <https://artificialintelligenceact.eu/ai-act-explorer/digital-omnibus/> (verified: secondary) (audience: legal, governance, engineering; jurisdiction: EU)
- **GPAI Code of Practice**: the Commission's voluntary code for general-purpose AI, including the safety and security chapter whose signatories commit to model evaluations. <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai> (verified: primary) (audience: legal, engineering; jurisdiction: EU)
- **Standardisation of the AI Act (European Commission)**: the Commission's own status page for the harmonised standards that would grant a presumption of conformity; as of 2026-09-24, none is OJ-cited. <https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation> (verified: primary) (audience: governance, legal; jurisdiction: EU)
- **"ISO/IEC 42001 and the AI Act: why certification is not yet a presumption of conformity"**: the key relationship between the AIMS standard (and 42005/42006) and the Act. <https://lawandtechnology.eu/en/iso-iec-42001-and-the-ai-act-why-certification-is-not-yet-a-presumption-of-conformity/> (verified: secondary) (audience: governance, legal; jurisdiction: EU)
- **JTC 21 harmonised-standards tracker**: a vendor-maintained tracker of the stage each JTC 21 deliverable has reached; useful for dates, read against the Commission's page above. <https://kla.digital/blog/jtc-21-standards-tracker> (verified: secondary) (audience: governance; jurisdiction: EU)
- **NIST AI Risk Management Framework 1.0**: the Govern/Map/Measure/Manage functions used as a mapping target throughout. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary) (audience: governance, engineering; jurisdiction: US)
- **NIST NCCoE, "Software and AI Agent Identity and Authorization" (concept paper)**: the emerging reference for non-human identity, the precondition of agent governance. <https://www.nccoe.nist.gov/news-insights/new-concept-paper-identity-and-authority-software-agents> (verified: primary) (audience: engineering; jurisdiction: US)

- **NIST CAISI AI Agent Standards Initiative:** the effort to make agent interoperability and security standard, not per-vendor. <https://www.nist.gov/news-events/news/2026/02/announcing-ai-agent-standards-initiative-interoperable-and-secure> (verified: primary) (audience: engineering, governance; jurisdiction: US)
- **OWASP GenAI Security Project:** the home of the Top 10 for LLM Applications, the Top 10 for Agentic Applications, the AIBOM project and the AI Maturity Assessment. <https://genai.owasp.org/> (verified: primary) (audience: engineering; jurisdiction: global)
- **CSA AI Controls Matrix and STAR for AI:** the control framework and assurance programme mapped to ISO 42001 and NIST AI RMF (chapters 07-08). <https://cloudsecurityalliance.org/star/ai> (verified: primary) (audience: governance, engineering; jurisdiction: global)
- **MITRE ATLAS:** the adversarial tactics-and-techniques knowledge base for AI, including agent techniques, that threat models draw on. <https://atlas.mitre.org/> (verified: primary) (audience: engineering; jurisdiction: global)
- **NSA CSI, "MCP: Security Design Considerations":** government guidance on securing the Model Context Protocol that connects agents to tools. <https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4496698/> (verified: primary) (audience: engineering; jurisdiction: US)
- **"California's SB 53: the first frontier-AI law explained" (FPF):** the clearest read on California's SB 53 (TFAIA), the first US frontier-AI transparency law. <https://fpf.org/blog/californias-sb-53-the-first-frontier-ai-law-explained/> (verified: secondary) (audience: legal, governance; jurisdiction: US)
- **New York RAISE Act (Governor's signing announcement):** New York's frontier-AI safety law (S6953B), signed 19 December 2025 and effective 1 January 2027 after a March 2026 chapter amendment, with an oversight office in the Department of Financial Services. <https://www.governor.ny.gov/news/governor-hochul-signs-nation-leading-legislation-require-ai-frameworks-ai-frontier-models> (verified: primary) (audience: legal, governance; jurisdiction: US)
- **NIST AI 800-1, "Managing Misuse Risk for Dual-Use Foundation Models" (second public draft):** US NIST/CAISI voluntary guidance on identifying, measuring and mitigating misuse risk across the model lifecycle; still a draft. <https://www.nist.gov/news-events/news/2025/01/updated-guidelines-managing-misuse-risk-dual-use-foundation-models> (verified: primary) (audience: engineering, governance; jurisdiction: US)
- **NIST ARIA (Assessing Risks and Impacts of AI):** NIST's evaluation environment that tests model risks and impacts through model testing, red teaming and field testing; a reference for layer 03. <https://ai-challenges.nist.gov/aria> (verified: primary) (audience: engineering, research; jurisdiction: US)
- **UK AI Security Institute:** the UK government institute that evaluates advanced-AI risks and publishes the Inspect eval framework this book uses as the layer-03 reference. <https://www.aisi.gov.uk/> (verified: primary) (audience: engineering, research; jurisdiction: UK)
- **US Center for AI Standards and Innovation (CAISI):** NIST's center for AI standards, testing and security, formerly the US AI Safety Institute; the US government's point of contact for industry. <https://www.nist.gov/caisi> (verified: primary) (audience: governance, research; jurisdiction: US)
- **AI Safety Governance Framework 3.0 (TC260, under CAC guidance):** China's voluntary framework, bilingual PDF; Appendix 2 is the agentic AI risk-management framework (identity, human checkpoints, guardrails, memory, decommissioning). <https://www.cac.gov.cn/rootimages/uploadimg/1791137114683961/1791137114683961.pdf> (verified: primary) (audience: governance, engineering; jurisdiction: China)
- **Interim Measures for the Administration of Generative AI Services:** China's binding rule for generative AI offered to the public within the PRC, in force 2023-08-15; official Chinese text. https://www.cac.gov.cn/2023-07/13/c_1690898327029107.htm (verified: primary) (audience: legal; jurisdiction: China)
- **Provisions on the Administration of Deep Synthesis in Internet Information Services:** labelling, training-data and consent duties for deep synthesis, in force 2023-01-10; official Chinese text. https://www.cac.gov.cn/2022-12/11/c_1672221949354811.htm (verified: primary) (audience: legal; jurisdiction: China)
- **Provisions on the Administration of Algorithmic Recommendation in Internet Information Services:** algorithm filing, security assessment and user opt-out, in force 2022-03-01; official Chinese text. https://www.cac.gov.cn/2022-01/04/c_1642894606364259.htm (verified: primary) (audience: legal; jurisdiction: China)
- **Measures for Labelling AI-Generated Synthetic Content:** explicit and implicit labels, in force 2025-09-01 alongside the mandatory standard GB 45438-2025; official Chinese text. https://www.cac.gov.cn/2025-03/14/c_1743654684782215.htm (verified: primary) (audience: legal, engineering; jurisdiction: China)
- **South Korea AI Basic Act:** the framework Act in force 2026-01-22, with heightened duties for high-impact AI; the source chapter 08 already cites. <https://www.trade.gov/market-intelligence/south-korea-ai-basic-act> (verified: secondary) (audience: legal, governance; jurisdiction: South Korea)
- **Model AI Governance Framework for Generative AI (IMDA / AI Verify Foundation):** Singapore's voluntary framework (May 2024): testing, transparency, incident reporting, security and content provenance. <https://aiverifyfoundation.sg/wp-content/uploads/2024/05/Model-AI-Governance-Framework-for-Generative-AI-May-2024-1-1.pdf> (verified: primary) (audience: governance, engineering; jurisdiction: Singapore)

International principles and frameworks

- **OECD Recommendation of the Council on Artificial Intelligence (OECD/LEGAL/0449)**: the AI Principles as revised in 2024, and the source of the AI-system definition and lifecycle that the AI Act and the Council of Europe Convention follow. <https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449> (verified: primary) (audience: governance, leadership, legal; jurisdiction: global)
- **Explanatory memorandum on the updated OECD definition of an AI system**: why the 2023 definition changed and how autonomy and adaptiveness are meant. https://www.oecd.org/en/publications/explanatory-memorandum-on-the-updated-oecd-definition-of-an-ai-system_623da898-en.html (verified: primary) (audience: governance, legal; jurisdiction: global)
- **HUDERIA: risk and impact assessment of AI systems (Council of Europe)**: the human-rights impact methodology and its context model, to reconcile with an existing FRIA. <https://www.coe.int/en/web/artificial-intelligence/huderia-risk-and-impact-assessment-of-ai-systems> (verified: primary) (audience: governance, legal; jurisdiction: global)
- **Towards a common reporting framework for AI incidents (OECD, 2025)**: the 29 criteria an incident record can be aligned with across jurisdictions; the basis of the incident-record field names in the templates library. https://www.oecd.org/content/dam/oecd/en/publications/reports/2025/02/towards-a-common-reporting-framework-for-ai-incidents_8c488fdb/f326d4ac-en.pdf (verified: primary) (audience: governance, engineering; jurisdiction: global)
- **"Defining AI incidents and related terms" (OECD.AI)**: the shared vocabulary of AI incident, AI hazard and their serious variants. <https://oecd.ai/en/wonk/defining-ai-incidents-and-hazards> (verified: primary) (audience: governance, legal; jurisdiction: global)

EU guidance, codes and adjacent law

- **Commission Guidelines on the definition of an AI system**: the operative EU test for scope: the seven elements, the low autonomy bar and the excluded families of software. <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-guidelines-ai-system-definition-facilitate-first-ai-acts-rules-application> (verified: primary) (audience: legal, governance, engineering; jurisdiction: EU)
- **Commission Guidelines on the scope of obligations for providers of general-purpose AI models**: the compute criteria for GPAI models, when fine-tuning or modifying a model makes you its provider, and the open-source monetisation test. <https://digital-strategy.ec.europa.eu/en/library/guidelines-scope-obligations-providers-general-purpose-ai-models-under-ai-act> (verified: primary) (audience: legal, engineering; jurisdiction: EU)
- **Draft Commission guidelines on the classification of high-risk AI systems**: practical examples for Art. 6 and the Art. 6(3) filter; still a draft as of 2026-09-24. <https://digital-strategy.ec.europa.eu/en/library/draft-commission-guidelines-classification-high-risk-ai-systems> (verified: primary) (audience: legal, governance; jurisdiction: EU)
- **AI Literacy: Questions & Answers (European Commission)**: the Commission's own reading of Article 4 after the Omnibus: no certificate required, internal records, and who counts as "other persons". <https://digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers> (verified: primary) (audience: governance, leadership; jurisdiction: EU)
- **Code of Practice on Transparency of AI-generated Content**: the voluntary route to the Art. 50 marking and labelling duties. <https://digital-strategy.ec.europa.eu/en/policies/code-practice-ai-generated-content> (verified: primary) (audience: engineering, legal; jurisdiction: EU)
- **GPAI serious-incident reporting template (European Commission, 4 Nov 2025)**: the fields a GPAI serious-incident report carries, including root-cause analysis and near-miss patterns. <https://digital-strategy.ec.europa.eu/en/library/ai-act-commission-publishes-reporting-template-serious-incidents-involving-general-purpose-ai> (verified: primary) (audience: governance, engineering; jurisdiction: EU)
- **Updated EU AI model contractual clauses (MCC-AI)**: the reference contract text for buying AI, in a high-risk and a light version, with a commentary; usable beyond public procurement. <https://public-buyers-community.ec.europa.eu/communities/procurement-ai/resources/updated-eu-ai-model-contractual-clauses> (verified: primary) (audience: legal, governance; jurisdiction: EU)
- **EDPB Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models**: the EU data protection authorities' reference on model anonymity, legitimate interest for AI and what unlawful training means for deployers. https://www.edpb.europa.eu/documents/opinion-of-the-board/art-64/opinion-282024-on-certain-data-protection-aspects-related-to_en (verified: primary) (audience: legal, governance; jurisdiction: EU)
- **EDPB Guidelines 05/2021 on the interplay between Article 3 and Chapter V of the GDPR**: the three criteria that decide whether a remote inference call or a support access is an international transfer. https://www.edpb.europa.eu/system/files/documents/2023-02/edpb_guidelines_05-2021_interplay_between_the_application_of_art3-chapter_v_of_the_gdpr_v2_en_0.pdf (verified: primary) (audience: legal; jurisdiction: EU)
- **CNIL, "Ensuring and facilitating the exercise of data subjects' rights" (AI how-to sheet)**: the most practical regulator text on rights against trained models: retraining, output filters and their limits. <https://www.cnil.fr/en/ensuring-and-facilitating-exercise-data-subjects-rights> (verified: primary) (audience: legal, engineering; jurisdiction: EU, France)

- **CNIL, "Relying on the legal basis of legitimate interests to develop an AI system"**: a step-by-step balancing test and the additional safeguards for AI training. <https://www.cnil.fr/en/relying-legal-basis-legitimate-interests-develop-ai-system> (verified: primary) (audience: legal; jurisdiction: EU, France)
- **AEPD guidance on agentic AI from a data protection perspective (press release)**: a regulator's analysis of agents: autonomy, memory, threats and controller measures; in Spanish. <https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/la-agencia-publica-unas-orientaciones-sobre-inteligencia> (verified: primary) (audience: legal, engineering; jurisdiction: EU, Spain)
- **Hamburg DPA, "Discussion Paper: Large Language Models and Personal Data"**: the view that LLMs do not store personal data; read it beside the EDPB opinion. https://datenschutz-hamburg.de/fileadmin/user_upload/HmbBfDI/Datenschutz/Informationen/240715_Discussion_Paper_Hamburg_DPA_KI_Models.pdf (verified: primary) (audience: legal; jurisdiction: EU, Germany)
- **AESIA guides from the Spanish AI sandbox**: sixteen non-binding guides with checklists for the EU high-risk requirements, produced in a regulatory sandbox; in Spanish. <https://aesia.digital.gob.es/es/guias> (verified: primary) (audience: governance, engineering; jurisdiction: EU, Spain)
- **Directive (EU) 2024/2853 on liability for defective products**: the text that makes software a product, sets disclosure duties and presumptions, and ties liability to updates. <https://eur-lex.europa.eu/eli/dir/2024/2853/oj> (verified: primary) (audience: legal, leadership; jurisdiction: EU)

Government and regulator guidance beyond the EU

- **NIST AI 600-1, Generative Artificial Intelligence Profile**: twelve risks that generative AI creates or worsens, with suggested actions keyed to AI RMF subcategories, usable as eval-suite names. <https://doi.org/10.6028/NIST.AI.600-1> (verified: primary) (audience: governance, engineering; jurisdiction: US)
- **NIST AI RMF Playbook**: suggested actions and documentation questions per subcategory; the documentation questions make good acceptance criteria for controls. <https://airc.nist.gov/airmf-resources/playbook/govern/> (verified: primary) (audience: governance, engineering; jurisdiction: US)
- **NIST AI RMF Playbook: MANAGE**: post-deployment monitoring, third-party risk and deactivation, subcategory by subcategory. <https://airc.nist.gov/airmf-resources/playbook/manage/> (verified: primary) (audience: governance, engineering; jurisdiction: US)
- **Crosswalk: AI RMF (1.0) and ISO/IEC FDIS 23894 (NIST, 2023)**: a two-page map from the four AI RMF functions to ISO/IEC 23894 clauses; the quickest way to see they describe one process. https://www.nist.gov/system/files/documents/2023/01/26/crosswalk_AI_RMF_1_0_ISO_IEC_23894.pdf (verified: primary) (audience: governance; jurisdiction: US)
- **NIST SP 1270, "Towards a Standard for Identifying and Managing Bias in Artificial Intelligence"**: the shortest authoritative map of where AI bias comes from (systemic, statistical, human). <https://doi.org/10.6028/NIST.SP.1270> (verified: primary) (audience: engineering, governance; jurisdiction: US)
- **NIST IR 8312, "Four Principles of Explainable Artificial Intelligence"**: four principles, including explanation accuracy and knowledge limits, that translate into eval criteria for explanations. <https://doi.org/10.6028/NIST.IR.8312> (verified: primary) (audience: engineering, research; jurisdiction: US)
- **NIST AI 100-2 E2025, "Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations"**: the shared vocabulary of attacks on predictive and generative AI that red-team plans and threat models can cite. <https://doi.org/10.6028/NIST.AI.100-2e2025> (verified: primary) (audience: engineering, research; jurisdiction: US)
- **NIST SP 800-61 Rev. 3, "Incident Response Recommendations and Considerations for Cybersecurity Risk Management"**: incident response recast around the CSF 2.0 functions; the base the AI-specific lifecycle adapts. <https://csrc.nist.gov/pubs/sp/800/61/r3/final> (verified: primary) (audience: engineering, governance; jurisdiction: US)
- **NIST SP 800-226, "Guidelines for Evaluating Differential Privacy Guarantees"**: how to evaluate a differential-privacy claim and the hazards that break it in practice. <https://csrc.nist.gov/pubs/sp/800/226/final> (verified: primary) (audience: engineering, legal; jurisdiction: US)
- **OMB Memorandum M-25-21**: the US federal definition of high-impact AI, its minimum practices and a public template for a Chief AI Officer's duties and an AI governance board. <https://www.whitehouse.gov/wp-content/uploads/2025/02/M-25-21-Accelerating-Federal-Use-of-AI-through-Innovation-Governance-and-Public-Trust.pdf> (verified: primary) (audience: governance, leadership; jurisdiction: US)
- **SR 26-2, Revised Guidance on Model Risk Management (Federal Reserve, OCC, FDIC)**: supersedes SR 11-7; effective challenge and validation, tailored to risk profile, with generative and agentic AI explicitly out of scope. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> (verified: primary) (audience: governance, legal; jurisdiction: US)
- **CFPB Circular 2022-03: adverse action and complex algorithms**: why model complexity does not excuse inaccurate adverse-action reasons; withdrawn by the CFPB on 12 May 2025, while the Regulation B duty it read stands. <https://www.consumerfinance.gov/compliance/circulars/circular-2022-03-adverse-action-notification-requirements-in->

[connection-with-credit-decisions-based-on-complex-algorithms/](#) (verified: primary) (audience: legal, engineering; jurisdiction: US)

- **NAIC Model Bulletin: Use of Artificial Intelligence Systems by Insurers:** a regulator-written template for an AI governance programme in a regulated industry, including third-party AI. https://content.naic.org/sites/default/files/inline-files/2023-12-4%20Model%20Bulletin_Adopted_0.pdf (verified: primary) (audience: governance, legal; jurisdiction: US)
- **Copyright and Artificial Intelligence (U.S. Copyright Office):** the Office's position on authorship of AI outputs and on training, with the registration guidance. <https://copyright.gov/ai/> (verified: primary) (audience: legal; jurisdiction: US)
- **ICO, Guidance on AI and data protection:** the UK view on lawfulness, inferences, fairness and individual rights in AI; under review after the Data (Use and Access) Act as of 2026-09-24. <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/> (verified: primary) (audience: legal, governance; jurisdiction: UK)
- **ICO and The Alan Turing Institute, "Explaining decisions made with AI":** six explanation types and a task-by-task method for explaining AI decisions to affected people; under review as of 2026-09-24. <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/explaining-decisions-made-with-artificial-intelligence/> (verified: primary) (audience: engineering, legal; jurisdiction: UK)
- **General Understanding on AI and Copyright in Japan (Japan Copyright Office):** a short official reading of Article 30-4 that shows where the Japanese training exception ends. https://www.bunka.go.jp/english/policy/copyright/pdf/94055801_01.pdf (verified: primary) (audience: legal; jurisdiction: Japan)
- **Directive on Automated Decision-Making (Treasury Board of Canada Secretariat):** a mature, published impact-assessment regime with requirements scaled by impact level. <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32592> (verified: primary) (audience: governance, legal; jurisdiction: Canada)
- **Model AI Governance Framework for Agentic AI, v1.5 (IMDA):** a government framework for agents organised in four practical dimensions, from bounding risk to end-user responsibility. <https://www.imda.gov.sg/-/media/imda/files/about/emerging-tech-and-research/artificial-intelligence/mgf-for-agentic-ai.pdf> (verified: primary) (audience: governance, engineering; jurisdiction: Singapore)
- **Korea AI Basic Act and Enforcement Decree (Korean Law Information Center):** the primary text of the non-EU horizontal AI act with the most operator duties; the decree carries the thresholds; in Korean. <https://www.law.go.kr/LSW/lsInFoP.do?lsiSeq=268543> (verified: primary) (audience: legal; jurisdiction: South Korea)

Frontier safety frameworks (the labs' own commitments)

- **Anthropic Responsible Scaling Policy:** Anthropic's own frontier-safety framework of capability thresholds and required safeguards; the page states version 3.4, effective 8 July 2026. <https://www.anthropic.com/responsible-scaling-policy> (verified: primary) (audience: governance, research; jurisdiction: global)
- **OpenAI Preparedness Framework:** OpenAI's own framework for tracking and preparing for frontier capabilities that could cause severe harm; the document states Version 2, last updated 15 April <https://cdn.openai.com/pdf/18a02b5d-6b67-4cec-ab64-68cdfbdebcd/preparedness-framework-v2.pdf> (verified: primary) (audience: governance, research; jurisdiction: global)
- **Google DeepMind Frontier Safety Framework:** DeepMind's own framework of critical capability levels and mitigations; the page states version 3.1, updated 17 April 2026. <https://deepmind.google/discover/blog/strengthening-our-frontier-safety-framework/> (verified: primary) (audience: governance, research; jurisdiction: global)

Papers (machine-readable evidence and agent governance)

- **"Making AI Compliance Evidence Machine-Readable" (arXiv 2604.13767):** extends OSCAL for AI and argues frameworks specify *what* to assure but no executable *how*. <https://arxiv.org/html/2604.13767v1> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"Audit-as-code" (Frontiers in AI):** an assured-readiness score with proceed/remediate/block gates; audit output as a build artefact. <https://pubmed.ncbi.nlm.nih.gov/41837238/> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **Policy Cards (arXiv 2510.24383):** JSON-schema, machine-readable runtime governance artefacts for agents. <https://arxiv.org/abs/2510.24383> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **TAIP (arXiv 2603.03340):** treats NIST TEVV outputs as AI assurance objects. <https://arxiv.org/abs/2603.03340> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **AI Trust OS (arXiv 2604.04749):** an operating-system framing for continuous AI trust and assurance. <https://arxiv.org/abs/2604.04749> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **AAGATE (arXiv 2510.25863):** a NIST AI RMF-aligned agent governance platform design. <https://arxiv.org/abs/2510.25863> (verified: primary) (audience: engineering, research; jurisdiction: global)

- **"Toward Trustworthy AI Development: Mechanisms for Supporting Verifiable Claims" (Brundage et al., 2020):** institutional, software and hardware mechanisms that turn a developer's claim into something an outsider can check; the argument behind evidence over assertion. <https://arxiv.org/abs/2004.07213> (verified: primary) (audience: governance, research; jurisdiction: global)
- **"Practices for Governing Agentic AI Systems" (Shavit et al., OpenAI, 2023):** a definition of agentic systems, the parties in their lifecycle and baseline practices such as constraining the action space, legibility of activity and the ability to interrupt. <https://cdn.openai.com/papers/practices-for-governing-agentic-ai-systems.pdf> (verified: primary) (audience: engineering, governance; jurisdiction: global)
- **"Visibility into AI Agents" (Chan et al., 2024):** agent identifiers, real-time monitoring and activity logging as the three measures that make deployed agents visible. <https://arxiv.org/abs/2401.13138> (verified: primary) (audience: engineering, governance; jurisdiction: global)

Canonical papers: documentation, audit and accountability

- **"Datasheets for Datasets" (Gebru et al.):** the origin of structured dataset documentation; the human-readable half of a dataset admission record. <https://arxiv.org/abs/1803.09010> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"Model Cards for Model Reporting" (Mitchell et al., 2018):** intended use and evaluation across groups and conditions, reported beside the model; the template behind every model card since. <https://arxiv.org/abs/1810.03993> (verified: primary) (audience: engineering, governance; jurisdiction: global)
- **"Closing the AI Accountability Gap: Defining an End-to-End Framework for Internal Algorithmic Auditing" (Raji et al., 2020):** an internal audit run alongside development, stage by stage, with a documented artefact at each step. <https://arxiv.org/abs/2001.00973> (verified: primary) (audience: governance, engineering; jurisdiction: global)
- **"Actionable Auditing" (Raji and Buolamwini, 2019):** what happened after publicly naming the performance gaps of commercial systems; evidence that external audits move vendors. <https://doi.org/10.1145/3306618.3314244> (verified: primary) (audience: governance, research; jurisdiction: global)
- **"Auditing large language models: a three-layered approach" (Mökander et al., 2023):** governance, model and application audits as three complementary layers. <https://arxiv.org/abs/2302.08500> (verified: primary) (audience: governance, research; jurisdiction: global)
- **"The Gradient of Generative AI Release" (Irene Solaiman, 2023):** a vocabulary for release decisions, from fully closed to fully open. <https://arxiv.org/abs/2302.04844> (verified: primary) (audience: governance, leadership; jurisdiction: global)
- **"How the machine 'thinks': Understanding opacity in machine learning algorithms" (Burrell, 2016):** three sources of opacity, each needing a different fix. <https://doi.org/10.1177/2053951715622512> (verified: primary) (audience: governance, research; jurisdiction: global)
- **"Fairness and Abstraction in Sociotechnical Systems" (Selbst et al., 2019):** five traps a technical fairness intervention falls into when it abstracts away the social context. <https://doi.org/10.1145/3287560.3287598> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"On the Dangers of Stochastic Parrots" (Bender, Gebru et al., 2021):** the costs and risks of ever larger language models, from undocumented training data to environmental cost. <https://doi.org/10.1145/3442188.3445922> (verified: primary) (audience: research, leadership; jurisdiction: global)
- **"Ethical and social risks of harm from Language Models" (Weidinger et al., 2021):** a structured taxonomy of language-model harms, a ready starting list for a risk register. <https://arxiv.org/abs/2112.04359> (verified: primary) (audience: governance, research; jurisdiction: global)
- **"Concrete Problems in AI Safety" (Amodei et al., 2016):** five practical failure modes (side effects, reward hacking, oversight, safe exploration, distributional shift) stated as engineering problems. <https://arxiv.org/abs/1606.06565> (verified: primary) (audience: engineering, research; jurisdiction: global)

Canonical papers: measurement, fairness and evaluation

- **"Gender Shades: Intersectional Accuracy Disparities in Commercial Gender Classification" (Buolamwini and Gebru, 2018):** the audit that made disaggregated, intersectional evaluation the norm. <https://proceedings.mlr.press/v81/buolamwini18a.html> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"Dissecting racial bias in an algorithm used to manage the health of populations" (Obermeyer et al., Science, 2019):** the canonical proxy-label failure: a model accurate on cost and biased on need; the reason a model card must state the construct. <https://doi.org/10.1126/science.aax2342> (verified: primary) (audience: engineering, governance; jurisdiction: US)
- **"Racial disparities in automated speech recognition" (Koenecke et al., PNAS, 2020):** why one average hides a group's worse service; the argument for disaggregated evals. <https://doi.org/10.1073/pnas.1915768117> (verified: primary) (audience: engineering, research; jurisdiction: US)

- **"Inherent Trade-Offs in the Fair Determination of Risk Scores" (Kleinberg, Mullainathan and Raghavan):** the impossibility result that makes the choice of fairness metric a governance decision rather than a technical one. <https://arxiv.org/abs/1609.05807> (verified: primary) (audience: governance, research; jurisdiction: global)
- **"Stop Explaining Black Box Machine Learning Models for High Stakes Decisions and Use Interpretable Models Instead" (Rudin):** the case for interpretable-by-design models in high-stakes decisions. <https://arxiv.org/abs/1811.10154> (verified: primary) (audience: engineering, governance; jurisdiction: global)
- **"The Mythos of Model Interpretability" (Lipton, 2016):** why "interpretable" names several different properties, and which one a requirement should ask for. <https://arxiv.org/abs/1606.03490> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"On Calibration of Modern Neural Networks" (Guo et al., 2017):** why a model score is not a probability until calibration is measured. <https://arxiv.org/abs/1706.04599> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"A Gentle Introduction to Conformal Prediction and Distribution-Free Uncertainty Quantification" (Angelopoulos and Bates):** a practical, distribution-free way to turn scores into sets with a coverage guarantee. <https://arxiv.org/abs/2107.07511> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"What's Wrong with Risk Matrices?" (L. A. Cox Jr., Risk Analysis, 2008):** the standard critique of likelihood-by-severity matrices and why a catastrophic track is needed. <https://doi.org/10.1111/j.1539-6924.2008.01030.x> (verified: primary) (audience: governance, research; jurisdiction: global)
- **"Adding Error Bars to Evals" (Evan Miller, 2024):** evals treated as experiments: standard errors, model comparison and sample-size planning for eval gates. <https://arxiv.org/abs/2411.00640> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"Holistic Evaluation of Language Models" (Liang et al., 2022):** many metrics across many scenarios, reported together, instead of one leaderboard number. <https://arxiv.org/abs/2211.09110> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"Model evaluation for extreme risks" (Shevlane et al., 2023):** dangerous-capability and alignment evaluations as inputs to training, deployment and security decisions. <https://arxiv.org/abs/2305.15324> (verified: primary) (audience: governance, research; jurisdiction: global)
- **"Red Teaming Language Models with Language Models" (Perez et al., 2022):** automated red teaming, one model generating test cases for another. <https://arxiv.org/abs/2202.03286> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection" (Greshake et al., 2023):** the paper that named indirect prompt injection, the core threat to agents that read untrusted content. <https://arxiv.org/abs/2302.12173> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **"Extracting Training Data from Large Language Models" (Carlini et al.):** the canonical demonstration that language models regurgitate training data, and why extraction evals belong in the gate. <https://arxiv.org/abs/2012.07805> (verified: primary) (audience: engineering, legal; jurisdiction: global)
- **"Power Hungry Processing: Watts Driving the Cost of AI Deployment?" (Luccioni, Jernite, Strubell):** measures the inference energy gap between general-purpose generative and task-specific models. <https://arxiv.org/abs/2311.16863> (verified: primary) (audience: engineering, leadership; jurisdiction: global)
- **"The Leaderboard Illusion" (Singh et al., 2025):** why a public leaderboard cannot decide a model choice. <https://arxiv.org/abs/2504.20879> (verified: primary) (audience: engineering, leadership; jurisdiction: global)
- **"Hidden Technical Debt in Machine Learning Systems" (Sculley et al., NeurIPS 2015):** why the model is the small box in a production ML system, and where the debt accumulates around it. https://papers.nips.cc/paper_files/paper/2015/hash/86df7dcfd896fcfa2674f757a2463eba-Abstract.html (verified: primary) (audience: engineering; jurisdiction: global)

Reports (the market and the profession)

- **IAPP AI Governance Profession Report 2025 (with Credo AI):** where the function sits and how it is staffed; the profession's baseline census. <https://iapp.org/resources/article/ai-governance-profession-report/> (verified: primary) (audience: leadership, governance; jurisdiction: global)
- **IAPP Salary & Jobs Report 2025-26:** the salary bands that anchor chapter 06, including the technical-AI-governance premium. <https://iapp.org/resources/article/salary-survey-summary/> (verified: primary) (audience: leadership, governance; jurisdiction: global)
- **IAPP AI Governance Vendor Report 2026:** the four vendor categories and the claim that AI governance "is not a single function, discipline or technology". <https://iapp.org/resources/article/ai-governance-vendor-report> (verified: primary) (audience: governance, leadership; jurisdiction: global)
- **State of GRC 2026:** the practitioner survey behind the "spreadsheet is still the #1 GRC tool" reality the discipline reacts against. <https://grcengineer.com/report/> (verified: primary) (audience: governance; jurisdiction: global)

- **"Global AI Regulations Fuel Billion-Dollar Market for AI Governance Platforms" (Gartner):** the analyst's own framing of the platform category, including runtime policy enforcement, and its spend forecast. <https://www.gartner.com/en/newsroom/press-releases/2026-02-17-gartner-global-ai-regulations-fuel-billion-dollar-market-for-ai-governance-platforms> (verified: primary) (audience: leadership; jurisdiction: global)
- **Gartner Magic Quadrant for AI Governance Platforms, June 2026 (via IBM):** one named vendor's account of the first MQ for the category; the report itself is licensed, so read this as a vendor's summary. <https://www.ibm.com/new/announcements/ibm-recognized-as-a-leader-in-gartner-magic-quadrant-for-ai-governance-platforms> (verified: secondary) (audience: leadership; jurisdiction: global)
- **HiddenLayer 2026 AI Threat Landscape Report:** a security vendor's survey and the source of the "one in eight breaches were agentic" finding; read it as a vendor survey. <https://www.hiddenlayer.com/report-and-guide/threatreport2026> (verified: primary) (audience: engineering, leadership; jurisdiction: global)
- **International AI Safety Report 2026:** the second edition (3 February 2026) of the scientific assessment of general-purpose AI capabilities, risks and risk management, chaired by Yoshua Bengio and backed by more than 30 countries and international organisations. <https://internationalaisafetyreport.org/publication/international-ai-safety-report-2026> (verified: primary) (audience: leadership, research, governance; jurisdiction: global)
- **The 2026 AI Index Report (Stanford HAI):** the annual data record of AI across research, technical performance, responsible AI, the economy, policy and public opinion; the place to check a trend before quoting it. <https://hai.stanford.edu/ai-index/2026-ai-index-report> (verified: primary) (audience: leadership, research; jurisdiction: global)

Incident and risk repositories (the empirical record)

- **AI Incident Database:** the Responsible AI Collaborative's catalogue of real-world AI harms and near-harms; a reference corpus for threat modelling and post-market monitoring. <https://incidentdatabase.ai/> (verified: primary) (audience: governance, engineering, research; jurisdiction: global)
- **AIAAIC Repository:** an independent, open register of AI, algorithmic and automation incidents and controversies across sectors. <https://www.aiaaic.org/aiaaic-repository> (verified: primary) (audience: governance, research; jurisdiction: global)
- **OECD.AI Incidents & Hazards Monitor (AIM):** the OECD's live monitor of AI incidents and hazards drawn from global media, built to inform policy. <https://oecd.ai/en/incidents> (verified: primary) (audience: governance, leadership; jurisdiction: global)
- **AI Vulnerability Database (AVID):** the AI Risk and Vulnerability Alliance's open knowledge base of failure modes for general-purpose AI systems. <https://avidml.org/> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **MIT AI Risk Repository:** MIT FutureTech's living database of 1,700+ AI risks classified across 65 frameworks; a taxonomy for intake and risk tiers. <https://airisk.mit.edu/> (verified: primary) (audience: governance, research; jurisdiction: global)
- **NJCM et al. v. The State of the Netherlands (SyRI), The Hague District Court, 5 Feb 2020:** a court striking down a risk-scoring system because it was not transparent and verifiable enough to weigh. <https://uitspraken.rechtspraak.nl/details?id=ECLI:NL:RBDHA:2020:1878> (verified: primary) (audience: legal, governance; jurisdiction: EU, Netherlands)
- **"Xenophobic machines" (Amnesty International, 2021):** the fullest public account of how a nationality indicator entered the Dutch childcare-benefits risk system. <https://www.amnesty.org/en/documents/eur35/4686/2021/en/> (verified: primary) (audience: governance, legal; jurisdiction: EU, Netherlands)

Engineering and assurance practice

- **The IIA's Three Lines Model (2020):** the split between governing body, management's first and second lines and independent internal audit, which an AI governance programme has to map onto, including who accepts residual risk. <https://www.theiaa.org/en/content/position-papers/2020/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense/> (verified: primary) (audience: governance, leadership; jurisdiction: global)
- **"Postmortem Culture: Learning from Failure" (Google SRE book):** the reference text for blameless post-mortems and for setting post-mortem triggers in advance, which AI incident and near-miss reviews should borrow. <https://sre.google/sre-book/postmortem-culture/> (verified: primary) (audience: engineering, governance; jurisdiction: global)
- **"Canarying Releases" (The Site Reliability Workbook, Google):** the engineering basis for progressive delivery as a governance control. <https://sre.google/workbook/canarying-releases/> (verified: primary) (audience: engineering; jurisdiction: global)
- **Fairlearn user guide, "Fairness in machine learning":** a practitioner's introduction to allocation and quality-of-service harms and to disparity metrics, with runnable examples. https://fairlearn.org/main/user_guide/fairness_in_machine_learning.html (verified: primary) (audience: engineering; jurisdiction: global)
- **"Responsible Sourcing of Data Enrichment Services" (Partnership on AI):** practical guidance on annotator conditions (pilots, instructions, pay, communication, quality assurance), the labour side of data governance. <https://partnershiponai.org/paper/responsible-sourcing-considerations/> (verified: primary) (audience: governance, leadership; jurisdiction: global)

- **JSON Schema Draft 2020-12**: the specification the templates library is written in; any conforming validator checks the records. <https://json-schema.org/draft/2020-12> (verified: primary) (audience: engineering; jurisdiction: global)

Tools (illustrative categories, not endorsements)

- **Inspect AI (UK AI Security Institute)**: an open eval framework, the reference example for evals-as-evidence and eval gates. https://github.com/UKGovernmentBEIS/inspect_ai (verified: primary) (audience: engineering; jurisdiction: global)
- **Awesome Responsible AI (AthenaCore)**: a broad, maintained index of responsible-, trustworthy- and human-centred-AI resources spanning every layer of the stack. <https://github.com/AthenaCore/AwesomeResponsibleAI> (verified: primary) (audience: engineering, governance; jurisdiction: global)
- **Awesome Production Machine Learning (EthicalML)**: the reference index of open-source libraries to deploy, monitor, version and scale ML; the tooling map for layers 02 and 04. <https://github.com/EthicalML/awesome-production-machine-learning> (verified: primary) (audience: engineering; jurisdiction: global)
- **awesome-opa (Open Policy Agent)**: the OPA ecosystem's own index of policy-as-code tools and integrations for layer 01. <https://github.com/open-policy-agent/awesome-opa> (verified: primary) (audience: engineering; jurisdiction: global)
- **Awesome OSCAL (OSCAL Club)**: a curated index of OSCAL tools and resources for the machine-readable evidence of layer 05. <https://github.com/oscal-club/awesome-oscal> (verified: primary) (audience: engineering, governance; jurisdiction: global)
- **awesome-ml-security (Trail of Bits)**: a curated index of machine-learning security resources feeding layer 03 red teaming and layer 04 runtime controls. <https://github.com/trailofbits/awesome-ml-security> (verified: primary) (audience: engineering; jurisdiction: global)

Books

- **Fairness and Machine Learning: Limitations and Opportunities (Barocas, Hardt and Narayanan; MIT Press, 2023)**: the standard text on what fairness criteria can and cannot say; readable in full online. <https://fairmlbook.org/> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **Interpretable Machine Learning (Christoph Molnar)**: a practical guide to interpretable models and post-hoc explanation methods, with their limits; readable in full online. <https://christophm.github.io/interpretable-ml-book/> (verified: primary) (audience: engineering; jurisdiction: global)
- **Patterns, Predictions, and Actions (Hardt and Recht; Princeton University Press)**: machine learning from prediction to action, including the datasets and benchmarks the field relies on; a full preprint is online. <https://mlstory.org/> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **Introduction to AI Safety, Ethics and Society (Dan Hendrycks; Taylor & Francis, 2024)**: a broad textbook on AI risk, from single-system failures to governance; readable online. <https://www.aisafetybook.com/> (verified: primary) (audience: governance, leadership, research; jurisdiction: global)
- **The Algorithmic Foundations of Differential Privacy (Dwork and Roth, 2014)**: the formal reference behind every differential-privacy claim a vendor makes. <https://www.cis.upenn.edu/~aaroth/Papers/privacybook.pdf> (verified: primary) (audience: engineering, research; jurisdiction: global)
- **Site Reliability Engineering (Google)**: the operating discipline that runtime controls, incident response and error budgets borrow from; readable in full online. <https://sre.google/sre-book/table-of-contents/> (verified: primary) (audience: engineering; jurisdiction: global)
- **Designing Machine Learning Systems (Chip Huyen; O'Reilly, 2022)**: the production lifecycle of ML systems, from data to monitoring; linked here through the author's companion repository. <https://github.com/chiphuyen/dmls-book> (verified: primary) (audience: engineering; jurisdiction: global)
- **AI Engineering (Chip Huyen, 2025)**: building applications on foundation models, with a long treatment of evaluation; linked here through the author's companion repository. <https://github.com/chiphuyen/aie-book> (verified: primary) (audience: engineering; jurisdiction: global)
- **Responsible AI: Best Practices for Creating Trustworthy AI Systems (Lu, Zhu, Whittle and Xu; Addison-Wesley, 2023)**: the CSIRO team's book-length treatment of responsible-AI patterns and governance mechanisms. <https://www.informit.com/store/responsible-ai-best-practices-for-creating-trustworthy-9780138073923> (verified: primary) (audience: engineering, governance; jurisdiction: global)

Courses

- **Elements of AI (University of Helsinki and MinnaLearn)**: free online courses that introduce AI to non-experts; one way to start the AI-literacy programme Article 4 asks for. <https://www.elementsofai.com/> (verified: primary) (audience: leadership, governance; jurisdiction: global)
- **Practical Data Ethics (fast.ai)**: a course first taught at the University of San Francisco Data Institute in 2020, on disinformation, bias and fairness, privacy and surveillance, and metrics. <https://ethics.fast.ai/> (verified: primary) (audience: engineering, governance; jurisdiction: global)

- **Made With ML (Goku Mohandas)**: a course on designing, developing, deploying and iterating on production ML, the pipeline that governance gates plug into. <https://madewithml.com/> (verified: primary) (audience: engineering; jurisdiction: global)
- **Frontier AI Governance (BlueDot Impact)**: a cohort-based course on the policy and governance of frontier AI. <https://bluedot.org/courses/ai-governance> (verified: primary) (audience: governance, leadership; jurisdiction: global)
- **AI Safety, Ethics and Society virtual course (Center for AI Safety)**: the course that follows the Hendrycks textbook above. <https://www.aisafetybook.com/virtual-course> (verified: primary) (audience: governance, research; jurisdiction: global)
- **Red Teaming LLM Applications (DeepLearning.AI, with Giskard)**: a short, hands-on course on finding and scripting LLM application failures. <https://www.deeplearning.ai/courses/red-teaming-llm-applications> (verified: primary) (audience: engineering; jurisdiction: global)
- **Secure AI/ML-Driven Software Development, LFEL1012 (Linux Foundation)**: a short, self-paced course on the security of software built with and around AI. <https://training.linuxfoundation.org/express-learning/secure-ai-ml-driven-software-development-lfel1012/> (verified: primary) (audience: engineering; jurisdiction: global)
- **Machine Learning Crash Course: Fairness (Google for Developers)**: a short module on types of bias and on identifying, mitigating and evaluating for bias. <https://developers.google.com/machine-learning/crash-course/fairness> (verified: primary) (audience: engineering; jurisdiction: global)

Communities and newsletters

- **GRC Engineer (grcengineer.com)**: the parent community's hub; the analyst-vs-engineer framing and the role definitions this book adapts. <https://grcengineer.com/> (verified: primary) (audience: governance, engineering; jurisdiction: global)
- **blog.grc.engineering, "GRC Engineering in 2026" (Justin Pagano)**: the forward view: policy-as- code guardrails in CI/CD, trust operations centres, agentic extensions. <https://blog.grc.engineering/p/grc-engineering-in-2026> (verified: primary) (audience: governance, engineering; jurisdiction: global)
- **IAPP (iapp.org)**: the professional body whose reports, certifications and events map the AI governance profession. <https://iapp.org/> (verified: primary) (audience: governance, legal, leadership; jurisdiction: global)

Maps to: this chapter makes no normative claim; the standards and frameworks it lists are treated in full in chapters 04, 05, 07 and 08. Mappings elsewhere in the book are illustrative, not a claim of conformity.

Sources

The reading list is its own source set: each entry above carries its URL and a verification tag inline, and every URL is recorded as a row in this chapter's section of [sources/SOURCES.md](#). Items whose URL could not be drawn from the research digest or verified for this edition were left out. The v0.5.0 additions were checked on 2026-09-24: each URL answered, arXiv entries were matched against the arXiv API and DOIs against Crossref.

11. AI, defined for governance

What an AI system is for governance purposes: the definitions that set scope, the kinds of AI and the traits that break classic governance, each turned into a registry field, a control and evidence.

A governance function cannot govern what it has not defined. Before a registry can list AI systems, before an intake can classify them and before a policy can bind them, someone has to decide which systems count. That decision is not a glossary exercise. It is the first control in the stack: it decides what enters the **agent registry** (layer 02), which obligations the intake routes a system to, and which systems are left outside every other control in this book. Get it wrong in one direction and a scoring model escapes review because someone called it "just statistics". Get it wrong in the other and the registry fills with spreadsheet macros, the signal drowns and the owners stop reading it.

This chapter compares the four definitions that set scope, turns each of their elements into a registry field, separates AI from deterministic software, sorts the kinds of AI by the controls they change and names the traits that make classic IT governance fail. It closes with two things usually left as prose: governing probabilistic outputs, and tracing the published responsible-AI principle sets to artefacts. It is not a machine-learning primer: a technique matters here only when it changes a control, an owner or a piece of evidence.

Why the definition is a control

Two decisions sit at the front of every intake, and they are different decisions. The first is **definitional**: is this an AI system at all? The second is **classificatory**: given that it is, which obligations and which controls apply? Most law and most governance programmes treat the first as a gate to the second. Under the EU AI Act the definition is literally the scope of the regulation: the Act applies only to systems that meet the definition in Article 3(1), and that definition has applied since 2 Feb 2025 [1]. The same Commission guidance is careful to add that "the vast majority of systems, even if they qualify as AI systems", will carry no obligations under the Act [1]. So a system can be inside the definition and outside every duty; a governance engineer needs both answers, recorded separately, with the reasoning attached.

Treat the definitional answer as a control like any other in this book. It has an owner (the [intake workflow](#)). It runs at the earliest point it can block: at intake, not at the pre-launch review. It leaves evidence: a decision record naming the definition applied, the elements found, who or what decided and when. And it is revisited when the system changes, because a rules engine that gains a learned component crosses the line without anyone filing a ticket.

In practice (illustrative) In a large telco, the first intake pass asked teams to self-declare "AI or not". Self-declaration produced both failure modes at once: a churn-propensity model registered as "analytics" and a keyword-routing macro registered as "AI". Replacing the yes/no question with the element questions below, each answered in the registry with a one-line reason, moved the decision from opinion to record. Disagreements became diffs on the decision record, reviewed like any other change.

Four definitions, compared

Four texts set scope for most organisations: the OECD definition, the EU AI Act definition with the Commission's guidance on it, ISO/IEC 22989 and NIST AI 100-1. They are closer than their authors' jurisdictions suggest, by design, and the differences that remain are exactly the ones that change a scoping decision.

The OECD definition (2023 revision)

Chapter 22 places [the OECD definition and lifecycle](#) in the wider OECD instruments. The OECD Council revised its definition on 8 Nov 2023, ahead of the wider five-year review of the AI Principles, partly to support alignment with definitions then being written in the EU, Japan and elsewhere [2][3]. It now reads: "An AI system is a machine-based system that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments. Different AI systems vary in their levels of autonomy and adaptiveness after deployment." [3]

Against the 2019 text, the revision made four changes that matter to scope: it dropped "human-defined" from the objectives (objectives may now be implicit), it made **inference** the defining act, it added **content** as an output (the generative case) and it added **adaptiveness** after deployment [3]. Its explanatory memorandum (which is not part of the Recommendation) reads autonomy as the degree to which a system can "learn or act without human involvement" once people have delegated to it, and adaptiveness as the continued change of machine-learning systems after initial development, such as a speech recogniser adapting to one voice [3].

EU AI Act Article 3(1) and the Commission guidelines

Chapter 18 sets [the legal definition of an AI system](#) in the Act's scope. Article 3(1) of the AI Act follows the OECD text closely: "AI system' means a machine-based system that is designed to operate with varying levels of autonomy and that may exhibit

adaptiveness after deployment, and that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments" [4]. Recital 12 explains the intent: the definition should distinguish AI from "simpler traditional software systems or programming approaches" and should not cover systems based on rules defined solely by natural persons to execute operations automatically [5]. The techniques that enable inference include machine learning and "logic- and knowledge-based approaches" [5].

The Commission's guidelines on the definition break it into seven elements: (1) a machine-based system; (2) designed to operate with varying levels of autonomy; (3) that may exhibit adaptiveness after deployment; (4) for explicit or implicit objectives; (5) infers, from the input it receives, how to generate outputs; (6) such as predictions, content, recommendations or decisions; (7) that can influence physical or virtual environments [1]. Five of their readings change how an intake should work:

- **Inference is the indispensable condition;** the guidelines call it "a key, indispensable condition that distinguishes AI systems from other types of systems" [1].
- **Autonomy is necessary but the bar is low.** Only systems designed to operate "solely with full manual human involvement and intervention" are excluded; a system that produces an output from manually supplied input without that output being specified by a human already has "some degree of independence of action" [1].
- **Adaptiveness is optional.** The word "may" makes self-learning after deployment "a facultative and thus not a decisive condition" [1]. A frozen model is still an AI system.
- **Objectives are not the intended purpose.** Objectives are internal to the system; the intended purpose (Art. 3(12)) is the external context of use [1], and context is what a risk tier is built on.
- **The elements need not all be present in both phases.** The definition takes a lifecycle view: some elements may appear in the building phase and not in the use phase [1].

The guidelines also name four families that fall outside the definition despite some capacity to infer: systems that improve or accelerate classical mathematical optimisation; **basic data processing** (database queries, spreadsheets without AI functions, descriptive dashboards); systems based on **classical heuristics** (a chess engine using minimax with a hand-written evaluation function); and **simple prediction systems** whose performance a basic statistical rule could match, such as a baseline that always predicts the historical mean [1]. They are explicit that "no automatic determination or exhaustive lists" are possible and that each system is assessed on its architecture and functionality [1]. They are also not binding; only the Court of Justice of the EU can give an authoritative interpretation [1].

ISO/IEC 22989

ISO/IEC 22989:2022 is the terminology standard the rest of the ISO/IEC AI family builds on [6]. Its definition of an AI system (term 3.1.4) is shorter and older in shape: an engineered system whose outputs, from content to decisions, serve objectives people set [6]. Inference and adaptiveness are not part of it. Its most useful contribution for governance is vocabulary the other texts lack. It separates **automation**, which varies by degree, from **autonomy**, a much stronger property it keeps for systems that can change their own goal or domain of use with no one steering them; the opposite of autonomy is **heteronomy**, and clause 5.13 treats the three together [6]. It also names the stakeholder roles around an AI system (provider, producer, customer, partner, subject and relevant authorities, clause 5.19) [6]. An amendment on generative AI (ISO/IEC 22989:2022/FDAMD 1) is at final-draft stage: its FDIS was registered for formal approval on 18 September 2026, and it is not published as of 2026-09-24 [7].

The word "autonomy" therefore means two different things across the texts. In the AI Act and the OECD text it is a degree of independence of action, and almost every system has some. In ISO/IEC 22989 it is a strong property most deployed systems do not have. A registry that records "autonomous: yes" has recorded nothing until it says whose sense it means.

NIST AI 100-1

The NIST AI Risk Management Framework (NIST AI 100-1, January 2023) "refers to an AI system as an engineered or machine-based system that can, for a given set of objectives, generate outputs such as predictions, recommendations, or decisions influencing real or virtual environments", designed to operate with varying levels of autonomy, and states that it adapts the 2019 OECD text and ISO/IEC 22989 [8]. It predates the OECD revision, so it has no "infers", no "content" and no adaptiveness. Its weight for governance lies elsewhere: Appendix B lists how AI risks differ from traditional software risks, which is the backbone of the characteristics table later in this chapter [8].

The definitions side by side

Element	OECD (2023)	EU AI Act Art. 3(1)	ISO/IEC 22989:2022	NIST AI 100-1 (2023)
Substrate	Machine-based	Machine-based	Engineered system	Engineered or machine-based
Objectives	Explicit or implicit	Explicit or implicit	Human-defined	"A given set of objectives"
Inference	Defining act	Defining act; indispensable per guidelines	Not in the definition	Not in the definition

Element	OECD (2023)	EU AI Act Art. 3(1)	ISO/IEC 22989:2022	NIST AI 100-1 (2023)
Outputs	Predictions, content, recommendations, decisions	Same four	Content, forecasts, recommendations, decisions	Predictions, recommendations, decisions
Effect	Physical or virtual environments	Physical or virtual environments	Not in the definition	Real or virtual environments
Autonomy	Varies by system	Designed for varying levels; necessary	Automation varies; autonomy is a strong, separate property	Varying levels
Adaptiveness	Varies by system	"May"; not decisive	Not in the definition	Not in the definition

Sources: [3][4][1][6][8].

Two practical conclusions follow. With any EU exposure, the AI Act text read with the Commission guidelines is the operative test, and the OECD text is its twin elsewhere. And the tests are not interchangeable: a system that ISO/IEC 22989 or NIST vocabulary would call AI can still sit in one of the guidelines' excluded families. Record which test you applied.

From definition element to registry field

Each element of the definition is a question the intake asks and a field the registry keeps. The answer to the element also drives a later decision, which is why the field earns its place: a field no decision reads is a field no one will maintain.

Element	Intake question	Registry field (illustrative)	Scoping or control decision it drives
Machine-based	Where does it run and who operates the runtime?	<code>substrate (cloud-api , self-hosted , on-device , embedded)</code>	Which runtime controls are even possible (layer 04); whether the product-safety route may apply
Objectives	What is the system optimising for?	<code>objective</code>	Which eval measures success; where reward hacking or proxy targets can hide
Intended purpose	In what context, for whom, is it used?	<code>intended_purpose</code>	Risk tier and obligations; the FRIA or DPIA trigger
Inference	Does it derive outputs by learning or by encoded knowledge, rather than by rules people wrote?	<code>inference_technique (ml.supervised , ml.self-supervised , logic-based , none ...)</code>	In or out of the AI definition; which excluded family, if any
Outputs	Prediction, content, recommendation or decision?	<code>output_types</code>	Content: marking and disclosure analysis (Art. 50); decision: explanation and human-review duties (Art. 86, GDPR Art. 22)
Effect	Does it change a physical or virtual environment, and through what?	<code>effect_surface (display , tools , actuator)</code>	Tools: agent registry, scoped credentials; actuator: stop in a safe state
Autonomy	What happens between output and effect without a person?	<code>autonomy_level</code> (0–4, below)	Human-oversight design, gate placement, kill switch
Adaptiveness	Can behaviour change in use without a release?	<code>adapts_in_use , change_triggers</code>	Re-evaluation triggers; drift monitoring ; feedback-loop controls (Art. 15(4))

Sources for the legal hooks: [9][10][11][12].

Two rows deserve a note. Teams most often collapse **objective** into **intended purpose**. The guidelines' own example is a corporate assistant whose objective is to answer questions over a document set accurately and whose intended purpose is to support one department's tasks [1]. The first tells you what to evaluate; the second tells you what the law thinks the system is for. An unchanged model moved to a new intended purpose is, for risk purposes, a new system. And the **outputs** row records the output *as used*: the guidelines note that a recommendation "automatically applied" becomes a decision [1], so a model that recommends plus a pipeline that auto-approves is, together, a decision system.

An autonomy field needs a scale. There is no standard one; the scale below is illustrative and maps onto the oversight vocabulary of the EU High-Level Expert Group (human-in-the-loop, human-on-the-loop, human-in-command) [13].

Level	Name	What happens between output and effect	Oversight mode
0	Advisory	A person reads the output and decides	Human-in-command
1	Assisted	The system drafts; a person approves each action	Human-in-the-loop
2	Bounded action	The system acts within a declared scope; consequential actions pass a gate	In the loop for gated actions
3	Supervised autonomy	The system acts; people monitor and can stop it	Human-on-the-loop

Level	Name	What happens between output and effect	Oversight mode
4	Unsupervised	The system acts with no routine oversight	None routine; kill switch only

Example (illustrative) The scoping fields of `csa-01`, the customer-service assistant used across this book, as its registry entry records them. The definitional decision and the risk tier are separate records.

```
id: csa-01
definition_basis: eu-ai-act-art-3-1+commission-guidelines
definition_decision: in_scope # in_scope | out_of_scope | undecided
definition_reason: "LLM infers replies from customer messages; generates content and
  recommendations; calls tools. Not basic data processing or classical heuristics."
decided_by: intake-pipeline + ai-governance-review
decided_on: 2026-09-18
substrate: cloud-api
objective: "answer order and refund questions accurately from the knowledge base"
intended_purpose: "first-line support for retail customers in the EU"
inference_technique: [ml.self-supervised, ml.rlhf, retrieval]
output_types: [content, recommendation]
effect_surface: tools
tools: [refunds:read, orders:read]
autonomy_level: 2
adapts_in_use: false
change_triggers: [vendor-model-version, prompt-change, corpus-snapshot]
kind: [generative, rag, agentic]
```

The out-of-scope decisions matter as much as the in-scope ones. A refund-eligibility rules engine whose every branch a person wrote gets a registry entry too, marked `out_of_scope` with the reason ("basic data processing; rules defined solely by people"). That entry is what lets you show an auditor you looked, and what makes a later change (someone adds a learned fraud score to the engine) visible as a diff.

AI versus conventional software

The line between AI and conventional software is the line between behaviour someone specified and behaviour someone induced. Recital 12 draws it in the same place: rules defined solely by people are not AI; inference from data or from encoded knowledge is [5]. For governance, the difference is not philosophical. Each row below is a control that classic IT governance runs and that stops working.

Property	Conventional deterministic software	AI system	Consequence for governance
Where behaviour comes from	Rules written by people	Learned from data or inferred from encoded knowledge	Review the data and the evals, not only the code
Same input, same output	Yes, by construction	Not guaranteed; generative serving can vary even at temperature zero [14]	Evidence pins version and sampling settings; evals repeat
What "correct" means	Matches a specification	Meets an error rate on a distribution	Thresholds replace pass/fail; thresholds need owners
How it is tested	Unit and integration tests against the spec	Evals over samples; coverage is statistical	The eval suite is itself a governed artefact
What changes behaviour	A code diff	A code diff, new weights, new data, a prompt edit, a corpus refresh, a vendor update	Change management triggers on all of them
How it fails	A reproducible bug	A failure mode that shows up on some inputs, sometimes, at scale	Monitor rates in production, not only incidents
How you explain it	Read the code	Internals are not human-readable	Explanations are produced, logged and tested

Two cautions keep the table honest. First, the boundary is legal as well as technical, and the law draws it with some untidiness: a logic-based expert system that infers conclusions from encoded medical knowledge is inside the AI Act definition, while a heuristic chess engine is outside it [1]. Record the reasoning, because the next reviewer will draw the line again. Second, "not AI" is not "not governed". Deterministic automation can harm at scale on its own, and data-protection law gives people the right not to be subject to a decision "based solely on automated processing" with legal or similarly significant effects, whether or not any AI definition is met [11]. The definitional decision routes a system to the AI-specific controls; it does not exempt anything else (see [Privacy and AI](#)).

Note A **model** is not a **system**, and neither is an **agent**. The AI Act defines the AI system (Art. 3(1)) and, separately, the general-purpose AI model (Art. 3(63)) and the general-purpose AI system built on one (Art. 3(66)) [4]. The registry keeps both levels and links them: one model can sit inside many systems, and chapter 01's **five objects of governance** each need their own entry.

Kinds of AI that change the governance problem

Taxonomies of AI are plentiful. The test applied here is narrow: does knowing the kind change a control, an owner or the evidence? Where it does not, the taxonomy is mentioned and set aside.

By capability and by functionality

The capability ladder (narrow AI, artificial general intelligence, superintelligence) is the most quoted and the least useful for controls. Every deployed system is narrow in the sense that matters; there is no agreed definition of general intelligence, and research proposals to operationalise it do so through levels of performance, generality and autonomy rather than a single threshold [15]. Law has sidestepped the question with proxies it can measure. The AI Act regulates the **general-purpose AI model**, one that "displays significant generality" and is "capable of competently performing a wide range of distinct tasks", including models trained on large data "using self-supervision at scale" [4], and presumes "high impact capabilities" when training compute exceeds 10^{25} floating-point operations [16]. The Commission's GPAI guidelines add an indicative criterion for general-purpose status itself: training compute above 10^{23} FLOP and the ability to generate language, text-to-image or text-to-video [17]. For the registry, capability therefore becomes two measurable fields, `model_generality` and `training_compute_flop`, both usually taken from the provider's documentation rather than measured in-house.

The functionality taxonomy (reactive machines, limited memory, theory of mind, self-awareness) comes from a 2016 popular article [18]. Only the first two describe systems that exist, and neither maps to a control; recognise it, but do not make it a registry field.

By learning paradigm

The learning paradigm tells you where the behaviour came from, and so where its evidence must come from.

Paradigm	How it learns	Governance hazard it adds	Control that answers it
Supervised	From labelled examples	Labels encode past human decisions, their errors and their bias; proxies for protected traits	Label provenance on the data card; subgroup evals in the eval gate
Unsupervised	Finds structure without labels (clusters, anomalies)	No ground truth to test against; segments can track protected traits	Stability tests; human review of segment definitions before use
Semi-supervised	Propagates a few labels across unlabelled data	Label errors spread silently	Audit a sample of propagated labels
Self-supervised	Predicts parts of its own input (the next token) over large corpora	Corpus provenance, rights and memorisation are hard to trace	AIBOM with dataset provenance; the GPAI training-content summary (see chapter 08)
Reinforcement, incl. from human feedback	Maximises a reward signal	Reward hacking : the system finds an unintended way to score [19]	Record the reward as the <code>objective</code> ; evals that look for unintended strategies
In-context (zero- and few-shot)	Follows instructions and examples in the prompt at inference time	Behaviour changes with a prompt edit, no retraining involved	Prompts versioned as governed artefacts; eval gate on prompt change

By technology family

Family	Example	What changes for governance
Classical machine learning	Gradient-boosted credit score on tabular data	Calibration and subgroup error dominate the eval suite
Deep learning	Image classifier	Opacity; adversarial inputs; heavier compute and evidence cost
Natural language processing	Complaint triage; LLM assistants	Text carries personal data and, for LLMs, instructions an attacker can plant
Computer vision	Document or face recognition	Biometric data raises special-category and prohibited-practice questions (see chapter 08)
Speech	Call transcription; voice synthesis	Voice is personal data; synthetic audio must be marked (Art. 50) [9]
Robotics and cyber-physical	Warehouse robot	Physical effect: the stop must bring the system to a safe state (Art. 14(4)(e)) [20]

Family	Example	What changes for governance
Logic- and knowledge-based	Expert system for diagnosis support	Inside the AI Act definition when it infers from encoded knowledge [1]; "it is only rules" is not an exemption

Predictive versus generative

A **predictive** (or discriminative) system outputs an estimate about something that exists: a score, a class, a forecast. Its harms are allocation harms (a wrong or biased estimate puts a person in the wrong queue), and its evidence is accuracy, calibration and error rates by subgroup.

A **generative** system outputs something new: text, image, audio, video, code. Its harms are different in kind. NIST's generative AI profile lists twelve risks that generative AI creates or worsens, among them **confabulation** ("the production of confidently stated but erroneous or false content"), information integrity, intellectual property, data privacy, harmful bias and homogenisation, and obscene or abusive content including synthetic child sexual abuse material [21]. The evidence changes accordingly: groundedness and refusal evals, red-teaming, output guardrails and, under the AI Act, machine-readable marking of synthetic output [9]. One control set does not fit both: a calibration threshold means nothing for generated text, and a groundedness eval nothing for a credit score.

Foundation models and GPAI

A **foundation model** is one "trained on broad data at scale" and "adaptable to a wide range of downstream tasks" [22]. The governance fact about foundation models is inheritance: in the original paper's words, "the defects of the foundation model are inherited by all the adapted models downstream" [22]. Most organisations call one through an API or adapt an open-weight one, so evidence moves from produced to collected: the provider's model card and evaluations become inputs to your registry entry, and the version you pin becomes a change you manage (see [Third-party and procured AI](#) and the [Vendor / Model Due-Diligence Gate](#)). GPAI is the AI Act's nearest legal category, with its own duties on the model provider (see [GPAI Code of Practice](#)).

LLMs and SLMs

A **large language model (LLM)** is a foundation model for language, usually served from a data centre. A **small language model (SLM)** trades breadth for size so that it can run close to the user; one 2024 technical report describes a 3.8-billion-parameter model "small enough to be deployed on a phone" [23]. The governance difference is where the controls live. An LLM behind an API sits behind a gateway you control, where every call can be traced, filtered and stopped. An SLM on a device runs where your telemetry may not reach: its guardrails ship with it, its inventory is a fleet of devices and its kill switch is a remote flag or an app update, with the lag that implies.

Multimodal models

A **multimodal** model takes or produces more than one modality (text, image, audio, video). Images and audio can carry personal data the text pipeline never saw and instructions the text filters never scanned, and synthetic images, audio and video raise the marking duties of Article 50 [9]. So guardrails exist per modality, and the eval suite includes cross-modal cases.

RAG systems

Retrieval-augmented generation (RAG) combines a model's learned ("parametric") memory with a retrievable ("non-parametric") store of documents, originally a dense vector index [24]. Its authors already named provenance as an open problem [24]. For governance, the corpus becomes behaviour: change the documents and the answers change with no model change. So the corpus is governed like a model, versioned and carded, its snapshot tied to the eval that tested it (see [data governance across the stack](#)). Retrieval also needs an entitlement check: a RAG system that retrieves a document the user may not see has leaked it, however polite the answer.

Agentic systems

An **agentic system** plans and acts: it calls tools, browses, executes code and moves data under delegated authority, often over many steps. It changes the governance problem most, because its output is an effect in a system of record, not a recommendation a person reads. The threats are catalogued in the OWASP Top 10 for Agentic Applications [25], and the controls are the layer 04 set: identity, scope, tool mediation, human gates and a tested stop ([Agent Identity & Scoped Credentials](#), [Kill Switch / Circuit Breaker](#), [Human-in-the-loop Gate](#)). The full treatment is in [Governing agents](#).

Why the type matters: the control set by kind

Kind	Distinctive harm	Control that changes	Layer · pattern
Predictive or scoring	Wrong or biased allocation	Calibration and subgroup evals; a threshold policy with an owner	03 · Eval Gate in CI ; 01 · Policy Card
Generative	Confabulation, IP, information integrity, abusive content	Groundedness and red-team evals; output guardrails; content marking	03 · Adversarial Red-Team Suite ; 04 · Runtime Guardrail
Foundation or GPAI model, procured	Inherited defects; evidence you cannot produce	Due diligence; version pinning; base model in the AIBOM	02 · AIBOM ; Vendor / Model Due-Diligence Gate

Kind	Distinctive harm	Control that changes	Layer · pattern
SLM on device	No central telemetry; update lag	Guardrails shipped with the model; device-level version inventory	02 · Agent Registry ; 04 · Kill Switch
Multimodal	New injection and personal-data channels	Guardrails per modality; cross-modal evals; marking	04 · Runtime Guardrail; 03 · Red-Team Suite
RAG	Corpus changes behaviour; retrieval leaks	Corpus as governed data; entitlement check at retrieval; groundedness evals	02 · data card; 04 · Runtime Guardrail
Agentic	Actions under delegated authority	Identity, scope, human gates, tested stop	04 · Agent Identity & Scoped Credentials; Kill Switch; Human-in-the-loop Gate

Kinds combine. `csa-01` is generative, retrieval-augmented and agentic at once, so it carries all three rows' controls; the registry's `kind` field is a list, not a single value.

Eight characteristics that break classic IT governance

Classic IT governance (change management, SDLC gates, access control, the security management system, periodic audit) assumes that behaviour is specified, a change is a code diff, a test passes or fails against a spec, a person stands behind each consequential action and the system does today what it did yesterday. AI breaks each assumption somewhere. NIST's Appendix B lists the ways AI risk differs from traditional software risk, from data that may not represent the context of use, through scale and complexity with "billions or even trillions of decision points", to "increased opacity", drift that demands more frequent maintenance and the "inability to predict or detect the side effects of AI-based systems beyond statistical measures" [8]. The table turns that list into the eight characteristics an engineer has to design for.

Characteristic	Why classic IT governance fails	What answers it (layer · pattern)	Evidence it emits
Complexity	The CMDB records the application; the model, datasets, prompts, retrieval corpus and tool graph inside it are invisible	02 · AIBOM, Agent Registry	An AIBOM per build; registry links from system to model to data
Opacity	Code review assumes the logic is readable; model internals are not	03 · behavioural evals; 02 · Model Card as Control Evidence	Eval results against named failure modes; logged explanations
Autonomy	Access control and segregation of duties assume a person behind each session	04 · Agent Identity & Scoped Credentials; Human-in-the-loop Gate; Kill Switch	Identity events; gate decisions with approver; kill-switch drill records
Speed and scale	Periodic, sample-based review meets after one error has repeated a million times	04 · Runtime Guardrail, Kill Switch / Circuit Breaker; 05 · Continuous Assurance Telemetry	Guardrail decisions; breaker trips; rollback records
Probabilistic outputs	Tests are pass/fail against a spec; a single wrong answer is a bug	03 · Eval Gate in CI with thresholds; 01 · Policy Card per risk tier	Calibration and threshold results per version
Data dependency	Data governance protects data as records, not as the source of behaviour	02 · data card and lineage; 03 · data-quality and subgroup tests	Data card; lineage record; test results filed against the dataset version
Dual use and misuse	Threat models centre on unauthorised access, not authorised use for a harmful end	03 · Adversarial Red-Team Suite; 04 · Runtime Guardrail; 01 · acceptable use as code	Red-team findings; misuse detections; policy verdicts
Adaptivity and drift	Change management triggers on code deploys; behaviour changes without one	05 · Continuous Assurance Telemetry; 03 · re-run the gate on model, data or prompt change	Drift alerts against the eval baseline; re-evaluation results

A few rows need more than a cell.

Opacity has three sources, and each has a different fix. Burrell distinguishes opacity as intentional corporate or state secrecy, opacity as technical illiteracy, and opacity "that arises from the characteristics of machine learning algorithms and the scale required to apply them usefully" [26]. Secrecy is answered by contract and disclosure (supplier documentation, audit rights); illiteracy by literacy and by explanations written for their reader; only the third needs technical explanation methods and, above all, behavioural evidence. When you cannot read the mechanism, you test the behaviour, and the eval result becomes the evidence that stands in for inspection. Explanation techniques themselves are covered in [Fairness and explainability](#).

Dual use is a property of capability, not intent. Researchers who inverted the objective of a drug-discovery toxicity model, rewarding toxicity instead of penalising it, report that it generated about 40,000 candidate toxic molecules in under six hours, including known nerve agents [27]. Nothing was breached; an authorised user changed an objective. That is why misuse needs its own threat model, red-team cases for harmful uses of legitimate capability, and runtime detection, not only perimeter security.

Speed and scale turn a small error rate into mass harm. A 1% error rate is a rounding error in a quarterly review and ten thousand wrong decisions a day in a system that makes a million. So the answers sit at runtime: a guardrail per call, a breaker that trips on a rate, a rollback tested before it is needed.

Adaptivity is broader than self-learning. For systems that keep learning in use, the AI Act asks for designs that reduce the risk of biased outputs feeding back into future inputs ("feedback loops") [12]. But most behaviour change arrives without self-learning: a vendor updates the model behind an API, the inputs drift, a prompt is edited, a corpus is refreshed. Retraining can also break what worked: neural networks are prone to **catastrophic forgetting**, losing earlier competence when trained on new tasks [28]. Each is a change event, and the eval gate runs on each.

Contrast pairs

Four pairs are confused often enough in reviews to be worth fixing in the team's vocabulary.

Pair	The difference	Why it matters for controls
Complexity and opacity	How many parts interact, against whether a person can follow the reasoning; one small neural network is simple and opaque	Complexity needs an inventory; opacity needs evals
Transparency, explainability, interpretability	In NIST's framing they answer "what happened", "how" a decision was made and "why", with its meaning to the user [8]	Three artefacts: records of what ran, an explanation method, a message the user can act on
Data drift and concept drift	The inputs change, against the relationship between inputs and the right answer changing	The first shows in the inputs; the second only in outcomes
Privacy and security	Whether processing personal data is appropriate, against whether the system resists attack	A secure system can still process data it has no right to

Governing probabilistic outputs

Conventional software returns an answer. Most AI returns an estimate or a sample, and someone has to decide what to do with it. That decision is most often left to a data scientist's default, and it is where engineering adds the most.

A score is not a decision

A predictive model emits a score. A decision is a score, plus a threshold, plus an action taken when the score crosses it. The threshold is where risk appetite becomes behaviour, so it is a policy decision with an owner, a version and an effective date, not a hyperparameter left at 0.5. Write it as a **Policy Card** rule, test it in the eval gate and log it with every decision it produces. When an auditor asks why an applicant was declined, "the score was 0.41 and the threshold, owned by credit risk and effective since 1 October, was 0.45" is an answer; "the model said no" is not.

Calibration before thresholds

A threshold only means something if the score does. A **calibrated** model's 0.9 is right about nine times in ten. A widely cited study found that modern neural networks, unlike those of a decade earlier, are poorly calibrated, and that a simple post-hoc fix (temperature scaling) is surprisingly effective [29]. So calibration belongs in the eval suite as a measured property with its own threshold (an expected calibration error bound, per version and per subgroup), re-checked when the model or the population changes. The AI Act already points this way for high-risk systems: the accuracy levels and "the relevant accuracy metrics" have to be declared in the instructions for use [12]. Declared metrics become the baseline that runtime telemetry is compared against.

Where a single score is not enough, **conformal prediction** offers a disciplined alternative: it turns any trained model's output into a set of candidate answers "guaranteed to contain the ground truth with a user-specified probability", without assumptions about the data distribution [30]. A large set is the model saying it is unsure, which is exactly the signal a governance rule can route on.

Certainty required by risk tier

The certainty a decision needs depends on what being wrong costs, so the runtime rule is set by risk tier. Three moves recur. An **abstention band** routes scores that are neither clearly positive nor clearly negative to a person through a **Human-in-the-loop Gate**. An **adverse-outcome rule** sends every decision that harms the subject to review, however confident the model. An **out-of-distribution rule** refuses or escalates inputs unlike anything the system was tested on, because a confident score on an unfamiliar input is the least trustworthy output a model produces.

Risk tier (illustrative)	Runtime rule	Evidence required per version	Human role
Low (internal search ranking)	Act on the top output	Aggregate accuracy on a golden set	Periodic review
Moderate (customer-facing assistant)	Act; abstain and hand over when groundedness or confidence falls below a floor	Groundedness, refusal and hand-over evals	On the loop: monitor and stop

Risk tier (illustrative)	Runtime rule	Evidence required per version	Human role
High (decisions about people's access to jobs, credit or services)	Recommend only above a calibrated threshold; abstention band and every adverse outcome to a reviewer	Calibration and subgroup error rates; declared accuracy metrics	In the loop for the band and adverse outcomes; explanation on request
Not to be automated	No automatic action; output advisory at most, or the use is blocked	A policy verdict	In command

The human role is itself a control that can degrade. Oversight under load turns into a rubber stamp, and the AI Act asks that the people overseeing high-risk systems stay aware of "automation bias", the tendency to over-rely on the output [20]. So the gate logs the approver, the time to decide and the override rate, and a falling override rate is investigated, not celebrated (see [Designing human oversight](#)).

Example (illustrative) A threshold policy for a loan-triage model, written as a Policy Card rule. The numbers are illustrative; the point is that each one has an owner and an effective date and is tested in the gate.

```
{ "policy_id": "decision-threshold.loan-triage.v3", "subject": "loan-triage-02",
  "risk_tier": "high", "owner": "credit-risk-product", "effective": "2026-10-01",
  "auto_approve_if": "calibrated_score >= 0.92",
  "review_band": [0.55, 0.92], "review_route": "hitl-gate.credit-review",
  "adverse_outcome": "always-human-review",
  "out_of_distribution": "escalate",
  "release_requires": ["calibration.ece <= 0.03", "subgroup.fnr_gap <= 0.02"] }
```

Generative outputs and non-determinism

Generative systems have no single score to threshold. The controls move to properties of the output: grounded in its sources, cited, refused when it should be, consistent across samples. Consistency cannot be assumed. One lab reports that sending the same prompt 1,000 times to a large model at temperature zero produced 80 distinct completions, and traces the variation to the serving stack's batching rather than to sampling [14]. So evidence records the model version, sampling parameters and, where the stack allows, the seed; and an eval that matters runs on several samples and reports a rate, not a single pass.

Responsible-AI principle sets, engineered

In this book, **principle** has a house meaning: one of the six rules of method in [chapter 03](#), phrased as something we do. The published responsible-AI texts use the word for a normative target, a property the AI should have. This section keeps the two apart. It calls the published ones **principle sets**, treats them as other people's frameworks (in chapter 01's [disambiguation](#), ethics sets the target; engineering hits it and proves it) and asks one question of each: which artefact evidences it, from which layer, under which house value and principle. The sets as frameworks are treated in full in [Principles and standards](#).

Four principle sets in brief

OECD AI Principles. Adopted on 22 May 2019, with the definition revised on 8 Nov 2023 and the principles on 3 May 2024, the Recommendation sets five values-based principles: inclusive growth, sustainable development and well-being; human rights and democratic values, including fairness and privacy; transparency and explainability; robustness, security and safety; and accountability [2]. The 2024 revision added points an engineer can act on directly: mechanisms so that AI systems that "risk causing undue harm or exhibit undesired behaviour" can be "overridden, repaired, and/or decommissioned safely"; attention to misuse and uses outside the intended purpose; information integrity; and an explicit reference to environmental sustainability [2].

UNESCO Recommendation on the Ethics of AI. Adopted by UNESCO's 193 member states in November 2021, it sets four core values (human rights and dignity; peaceful, just and interconnected societies; diversity and inclusiveness; environment and ecosystem flourishing) and ten principles, from proportionality and do no harm through fairness and non-discrimination [31]. Its Ethical Impact Assessment tool, aimed first at procurers of AI systems, assesses a specific system before and after deployment [32].

EU High-Level Expert Group (HLEG). The Ethics Guidelines for Trustworthy AI (8 Apr 2019) rest on four ethical principles (respect for human autonomy, prevention of harm, fairness, explicability) and set seven requirements: human agency and oversight; technical robustness and safety; privacy and data governance; transparency; diversity, non-discrimination and fairness; societal and environmental well-being; and accountability [13]. The Assessment List for Trustworthy AI (ALTAI, 17 Jul 2020) turns the seven into a self-assessment checklist [33], and AI Act Recital 27 points back to the same seven as non-binding principles that complement the Act [34].

G7 Hiroshima Process. The International Guiding Principles for Organizations Developing Advanced AI Systems (30 Oct 2023), with a companion Code of Conduct, build on the OECD principles for advanced and foundation models [35]. Its eleven principles are operational rather than ethical: lifecycle risk measures including red-teaming, post-deployment monitoring, public reporting of capabilities and limitations, incident information sharing, governance policies, security controls, content provenance, research, global challenges, standards, and data-input and IP protections [36]. Since February 2025 the OECD has run a voluntary reporting framework against the Code of Conduct [37].

Where the sets agree

The four sets disagree on emphasis and agree on substance. The table crosses the seven principles they share with where each set states them.

Shared principle	OECD (2024)	UNESCO (2021)	EU HLEG (2019)	G7 Hiroshima (2023)
Fairness and non-discrimination	1.2 (fairness, non-discrimination)	Fairness and non-discrimination	Req. 5 diversity, non-discrimination and fairness	Preamble; 11 (data quality against harmful bias)
Safety and reliability	1.4 (robust, safe; override, repair, decommission)	Proportionality and do no harm; safety and security	Req. 2 technical robustness and safety	1 (lifecycle risk measures); 2 (post-deployment monitoring)
Privacy and security	1.2 (privacy, data protection); 1.4 (security)	Right to privacy and data protection; safety and security	Req. 3 privacy and data governance	6 (security controls); 11 (personal data, IP)
Transparency and explainability	1.3 (incl. information to challenge an output)	Transparency and explainability	Req. 4 transparency	3 (public reporting); 7 (content provenance)
Accountability	1.5 (traceability; systematic risk management)	Responsibility and accountability	Req. 7 accountability	4 (incident sharing); 5 (governance policies)
Human-centricity, incl. accessibility and inclusion	1.1 (inclusive growth); 1.2 (human agency and oversight)	Human oversight and determination; awareness and literacy; diversity and inclusiveness	Req. 1 human agency and oversight; Req. 5 (accessibility and universal design)	Preamble (human-centricity)
Sustainability	1.1 (environmental sustainability)	Sustainability; environment and ecosystem flourishing	Req. 6 societal and environmental well-being	9 (climate crisis and other global challenges)

Sources: [2][31][13][36].

From principle to artefact

A principle is applied when it has been traced to a named harm, a control that bites, a metric that moves and an evidence record someone can query. That is chapter 03's "[start from a named failure mode or a named harm](#)" applied to other people's targets. The table gives, for each shared principle, the house values ([chapter 03](#)) and house principles that engineer it and the artefact that evidences it. It is a starting map, not a claim that any artefact satisfies a principle.

Shared principle	House values	House principles	Artefact that evidences it	Layer · pattern
Fairness	2 evals fail builds; 7 realised risk reduction	Start from a named harm; give every control teeth	Subgroup eval results against a declared threshold; data card with representativeness notes; FRIA	03 · Eval Gate in CI; 01 · FRIA-as-Code
Safety and reliability	2; 3 evidence from runtime	Build at the earliest point; give every control teeth	Eval-gate and red-team results per version; guardrail decisions; kill-switch drill records	03 · Adversarial Red-Team Suite; 04 · Runtime Guardrail, Kill Switch
Privacy and security	1 governance is code; 4 identity and scope	Register and bound every actor; build at the earliest point	Policy verdicts on data class and residency; scoped credentials; DPIA; PII-leakage evals	01 · Policy Card; 04 · Agent Identity & Scoped Credentials
Transparency and explainability	5 machine-readable evidence; 6 inspectable tooling	Instrument the build	Model card, data card and AIBOM; disclosure and marking records; reason codes logged per decision	02 · Model Card as Control Evidence; AIBOM
Accountability	4; 8 owned with engineering	Register and bound every actor; instrument the build	Registry owner per entry; decision records; signed logs; incident records; OSCAL assessment results	02 · Agent Registry; 05 · Incident Pipeline, Machine-Readable Evidence (OSCAL)
Human-centricity	8; 3	Start from a named harm; make the governed path the easiest	Gate logs (approver, time to decide, override rate); accessibility test results for notices and explanations; appeal records	04 · Human-in-the-loop Gate
Sustainability	7	Instrument the build	Energy or compute per eval run and per 1,000 inferences in the evidence store; a model-size decision record	05 · Continuous Assurance Telemetry

Three rows carry legal or numeric weight. **Human-centricity** includes accessibility, and for high-risk systems it is a duty: providers must meet the accessibility requirements of the EU web accessibility and European Accessibility Act directives (Art. 16(l)) [38], so

every notice and explanation the system shows a person gets an accessibility test in the pipeline. **Transparency** reaches the affected person: the OECD text asks for information that lets those adversely affected "to challenge its output" [2], and the AI Act gives people affected by certain high-risk decisions a right to "clear and meaningful explanations of the role of the AI system" [10]; the artefact is a logged reason code and an appeal route with recorded outcomes. **Sustainability** has a number: the IEA estimates data centres used about 415 TWh in 2024, around 1.5% of global electricity, and projects around 945 TWh by 2030 [39]. Not all of that is AI, but it makes the choice between an SLM and an LLM for the same task a governance decision with a record.

Example (illustrative) One principle traced end to end. OECD 1.3 asks that people adversely affected by a system can challenge its output. Named harm: an applicant declined by `loan-triage-02` cannot find out why or contest it. Control: every adverse decision carries logged reason codes and an appeal route to a reviewer who can reverse it. Metric: appeal volume, reversal rate and time to resolution, per month. Evidence: the appeal log, filed against the registry entry and the model version. Obligation it supports: AI Act Art. 86 where it applies, GDPR Art. 22 safeguards where the decision is solely automated.

Trade-offs are decisions, and decisions are records

Principles collide. NIST names the usual collisions: interpretability against privacy, predictive accuracy against interpretability, and privacy-enhancing techniques that cost accuracy and with it fairness where data is sparse; it adds that these trade-offs "should be resolved in a manner that is both transparent and appropriately justifiable" [8]. The engineering reading is that every resolved trade-off is a decision record with an owner, the options considered, the metric each would have moved and the date it will be revisited.

Tension	Typical case	Where the decision lives
Accuracy against interpretability	A gradient-boosted model beats a scorecard by a few points	Model-selection record on the model card, with both eval results
Fairness testing against privacy	Subgroup evals need the special-category data privacy law restricts	Data card noting the lawful basis (see Art. 4a in chapter 08), pseudonymisation and deletion
Efficiency against human-centricity	A review step adds latency to every decision	Gate placement record: which actions are gated and why
Transparency against security	Publishing detection rules helps attackers evade them	Disclosure decision: what is published, what is held for auditors

A trade-off no one wrote down was still made; it was made by default, by whoever touched the code last.

In practice (illustrative) A governance team inherited a published "responsible AI charter" of six principles and no evidence behind any of them. Rather than rewrite the charter, it added one column to the registry per principle and asked, for each high-risk system, which artefact evidenced it. Four of six columns were empty for most systems on day one. The empty cells became the backlog, and the charter became auditable for the first time: a principle with no artefact was reported as a gap, not as a value.

What you can do this week

1. Add the eight scoping fields from this chapter (`substrate` , `objective` , `intended_purpose` , `inference_technique` , `output_types` , `effect_surface` , `autonomy_level` , `adapts_in_use`) and a `definition_decision` with its reason to your registry schema, and backfill your ten highest-exposure systems.
2. Write down the out-of-scope decisions you have already made implicitly (rules engines, dashboards, baseline forecasters), each with the excluded family and the reason, so a later change shows up as a diff.
3. For one predictive system in production, find the decision threshold, its owner and its last calibration check. If any of the three is missing, add a calibration eval to its gate and put the threshold in a policy file with an owner.
4. For one generative system, run its most important eval five times on the current model version and record the pass rate with the sampling settings. If the rate is below the floor you thought you had, you have found your first real gate.
5. Take one principle your organisation has published and trace it to an artefact for one system, using the table above. If there is no artefact, record the gap in the risk register.

Maps to: EU AI Act Art. 3(1), 3(63), 3(66) (definitions), Art. 14 (human oversight), Art. 15 (accuracy metrics, feedback loops), Art. 16(I) (accessibility), Art. 50 (transparency), Art. 51 (GPAI systemic risk), Art. 86 (explanation) · GDPR Art. 22 · ISO/IEC 22989 · ISO/IEC 42001 · NIST AI RMF (Map, Measure) and NIST AI 600-1 · OECD AI Principles · OWASP Agentic ASI02/ASI03 · Layers 01–05. Mappings are illustrative, not a claim of conformity.

Sources

[1] Commission Guidelines on the definition of an artificial intelligence system established by Regulation (EU) 2024/1689 (C(2025) 5053 final; first published 6 Feb 2025; not binding; seven elements of Art. 3(1); exclusions at paras 40–51; definition applicable since 2 Feb 2025). European Commission. 2025-07-29. <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-guidelines-ai-system-definition-facilitate-first-ai-acts-rules-application> (verified: primary) [2] Recommendation of the Council on Artificial Intelligence, OECD/LEGAL/0449 (adopted 22 May 2019; definition revised 8 Nov 2023; principles revised 3 May 2024; principles 1.1–1.5, incl. 1.3(iv) challenge an output and 1.4(b) override, repair, decommission). OECD. 2024-05-03. <https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449> (verified: primary) [3] Explanatory memorandum on the updated OECD definition of an AI system (2019 and 2023 texts compared; autonomy and adaptiveness explained; not part of the Recommendation). OECD Artificial Intelligence Papers. 2024-03. https://www.oecd.org/en/publications/explanatory-memorandum-on-the-updated-oecd-definition-of-an-ai-system_623da898-en.html (verified: primary) [4] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 3 (definitions: (1) AI system, (3) provider, (4) deployer, (63) general-purpose AI model, (66) general-purpose AI system). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_3 (verified: primary) [5] Regulation (EU) 2024/1689 (AI Act), Recital 12 (AI distinguished from simpler traditional software and from rules defined solely by natural persons; inference; machine learning and logic- and knowledge-based approaches; autonomy and adaptiveness; recitals are not reproduced in the consolidated text). Publications Office of the EU (EUR-Lex). 2024-07-12. https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng#rct_12 (verified: primary) [6] ISO/IEC 22989:2022, Artificial intelligence concepts and terminology (AI system, term 3.1.4; autonomy and heteronomy, terms 3.1.5 and 3.1.16; clause 5.13 autonomy, heteronomy and automation; clause 5.19 AI stakeholder roles); referenced by identifier only. ISO/IEC. 2022-07. <https://www.iso.org/standard/74296.html> (verified: secondary) [7] ISO/IEC 22989:2022/FDAmD 1, Generative AI (stage 50.00, FDIS registered for formal approval on 2026-09-18; not published as of 2026-09-24). ISO/IEC JTC 1/SC 42. 2026-09-18. <https://www.iso.org/standard/88145.html> (verified: primary) [8] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (AI system definition; trustworthy characteristics; s. 3.5 transparency, explainability, interpretability; trade-offs; Appendix B, how AI risks differ from traditional software risks). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [9] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 50 (disclosure of interaction with an AI system; machine-readable marking of synthetic audio, image, video and text). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_50 (verified: primary) [10] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 86 (right to clear and meaningful explanations of the role of a high-risk AI system in a decision). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_86 (verified: primary) [11] Regulation (EU) 2016/679 (GDPR), Art. 22(1) (right not to be subject to a decision based solely on automated processing, including profiling, with legal or similarly significant effects). Publications Office of the EU (EUR-Lex). 2016-04-27. https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng#art_22 (verified: primary) [12] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 15 (15(3) accuracy levels and metrics declared in the instructions for use; 15(4) feedback loops in systems that continue to learn). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_15 (verified: primary) [13] Ethics Guidelines for Trustworthy AI (four ethical principles; seven requirements; HITL, HOTL and HIC oversight; requirement 5 includes accessibility and universal design). High-Level Expert Group on AI / European Commission. 2019-04-08. <https://digital-strategy.ec.europa.eu/en/library/ethics-guidelines-trustworthy-ai> (verified: primary) [14] "Defeating Nondeterminism in LLM Inference" (1,000 temperature-zero completions of one prompt gave 80 unique outputs; cause traced to lack of batch invariance). Thinking Machines Lab (Horace He et al.). 2025-09-10. <https://thinkingmachines.ai/blog/defeating-nondeterminism-in-llm-inference/> (verified: primary) [15] Levels of AGI for Operationalizing Progress on the Path to AGI (levels of performance, generality and autonomy) (arXiv 2311.02462). Morris et al.. 2023-11-04. <https://arxiv.org/abs/2311.02462> (verified: primary) [16] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 51 (classification of GPAI models with systemic risk; 51(2) presumption of high-impact capabilities above 10^{25} FLOP of training compute). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_51 (verified: primary) [17] Commission Guidelines on the scope of the obligations for providers of general-purpose AI models (C(2025) 7719 final; first published 18 Jul 2025; para. 17 indicative criterion: training compute above 10^{23} FLOP and able to generate language, text-to-image or text-to-video). European Commission. 2025-11-19. <https://digital-strategy.ec.europa.eu/en/library/guidelines-scope-obligations-providers-general-purpose-ai-models-under-ai-act> (verified: primary) [18] "Understanding the four types of AI, from reactive robots to self-aware beings" (reactive machines, limited memory, theory of mind, self-awareness). The Conversation (Arend Hintze). 2016-11-14. <https://theconversation.com/understanding-the-four-types-of-ai-from-reactive-robots-to-self-aware-beings-67616> (verified: primary) [19] Concrete Problems in AI Safety (reward hacking among five practical problems) (arXiv 1606.06565). Amodei et al.. 2016-06-21. <https://arxiv.org/abs/1606.06565> (verified: primary) [20] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 14 (14(4)(b) automation bias; 14(4)(e) interrupting the system so it comes to a halt in a safe state). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_14 (verified: primary) [21] Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1 (twelve risks unique to or exacerbated by generative AI; confabulation defined). NIST. 2024-07. <https://doi.org/10.6028/NIST.AI.600-1> (verified: primary) [22] On the Opportunities and Risks of Foundation Models ("trained on broad data at scale"; defects inherited downstream) (arXiv 2108.07258). Bommasani et al. (Stanford CRFM). 2021-08-16. <https://arxiv.org/abs/2108.07258> (verified: primary) [23] Phi-3 Technical Report: A Highly Capable Language Model Locally on Your Phone (3.8-billion-parameter model deployable on a phone) (arXiv 2404.14219). Abdin et al. (Microsoft). 2024-04-22. <https://arxiv.org/abs/2404.14219> (verified: primary) [24] Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks (parametric and non-parametric memory; provenance as an open problem) (arXiv 2005.11401). Lewis et al.. 2020-05-22. <https://arxiv.org/abs/2005.11401> (verified: primary) [25] Top 10 for Agentic Applications 2026 (ASI01–ASI10 threat catalogue for agentic systems). OWASP GenAI Security Project. 2025-12-09.

<https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [26] "How the machine thinks: Understanding opacity in machine learning algorithms" (three forms of opacity), *Big Data & Society* 3(1). SAGE (Jenna Burrell). 2016-01-06. <https://doi.org/10.1177/2053951715622512> (verified: primary) [27] "Dual use of artificial-intelligence-powered drug discovery" (inverted toxicity model generated about 40,000 candidate toxic molecules in under six hours), *Nature Machine Intelligence*. Urbina, Lentzos, Invernizzi and Ekins (full text on PubMed Central). 2022-03-07. <https://pmc.ncbi.nlm.nih.gov/articles/PMC9544280/> (verified: primary) [28] Overcoming catastrophic forgetting in neural networks (neural networks lose earlier competence when trained on new tasks; elastic weight consolidation) (arXiv 1612.00796). Kirkpatrick et al.. 2016-12-02. <https://arxiv.org/abs/1612.00796> (verified: primary) [29] On Calibration of Modern Neural Networks (modern networks poorly calibrated; temperature scaling), *ICML 2017* (arXiv 1706.04599). Guo, Pleiss, Sun and Weinberger. 2017-06-14. <https://arxiv.org/abs/1706.04599> (verified: primary) [30] A Gentle Introduction to Conformal Prediction and Distribution-Free Uncertainty Quantification (prediction sets with user-specified coverage) (arXiv 2107.07511). Angelopoulos and Bates. 2021-07-15. <https://arxiv.org/abs/2107.07511> (verified: primary) [31] Recommendation on the Ethics of Artificial Intelligence (adopted by 193 member states, November 2021; four core values; ten principles). UNESCO. 2021-11. <https://www.unesco.org/en/artificial-intelligence/recommendation-ethics> (verified: primary) [32] Ethical Impact Assessment: a tool of the Recommendation on the Ethics of AI (ex-ante and ex-post assessment of a system; aimed at procurers of AI systems). UNESCO. 2023-08-28. <https://www.unesco.org/en/articles/ethical-impact-assessment-tool-recommendation-ethics-artificial-intelligence> (verified: primary) [33] Assessment List for Trustworthy Artificial Intelligence (ALTAI) for self-assessment (final list presented 17 Jul 2020). High-Level Expert Group on AI / European Commission. 2020-07-17. <https://digital-strategy.ec.europa.eu/en/library/assessment-list-trustworthy-artificial-intelligence-altai-self-assessment> (verified: primary) [34] Regulation (EU) 2024/1689 (AI Act), Recital 27 (the seven HLEG principles as non-binding ethical principles complementing the Act). Publications Office of the EU (EUR-Lex). 2024-07-12. https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng#rct_27 (verified: primary) [35] Hiroshima Process International Guiding Principles for Organizations Developing Advanced AI Systems (welcomed by G7 leaders with a companion Code of Conduct; builds on the OECD AI Principles). European Commission. 2023-10-30. <https://digital-strategy.ec.europa.eu/en/library/hiroshima-process-international-guiding-principles-advanced-ai-system> (verified: primary) [36] Hiroshima Process International Guiding Principles, full text of the eleven principles (preamble on human rights, fairness and human-centricity; principle 11 elaboration on data quality against harmful bias). G7 Information Centre (University of Toronto). 2023-10-30. <https://g7.utoronto.ca/summit/2023hiroshima/231030-ai-principles.html> (verified: secondary) [37] Hiroshima AI Process (HAIP) Reporting Framework (voluntary reporting against the Code of Conduct; launched February 2025). OECD.AI. 2025-02. <https://oecd.ai/en/hiroshima> (verified: primary) [38] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 16 (provider obligations; 16(l) accessibility requirements under Directives (EU) 2016/2102 and (EU) 2019/882). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_16 (verified: primary) [39] Energy and AI (data centres about 415 TWh in 2024, around 1.5% of global electricity; projected around 945 TWh by 2030). International Energy Agency. 2025. <https://www.iea.org/reports/energy-and-ai> (verified: primary)

12. Running the AI governance program

An AI governance program is the organisation governed as a system: people hold the duties, a committee decides what gates cannot, policies compile into gates, and the evidence reaches the board.

The organisation as an object of governance

Chapter 01 names five objects of governance: models, systems, agents, data and the organisation. The first four get most of this book's machinery. The fifth decides whether that machinery is built, funded, obeyed or bypassed. "A control with no owner is not a control" is a claim about the organisation, and this chapter writes it out: who holds which duty, where decisions are taken, how policies become gates, how people are trained and heard, and how leadership learns whether any of it works.

One rule runs through the chapter: **the committee decides; the gates enforce**. People take the decisions that need judgement (is this use case worth its risk, is this residual risk acceptable, is this exception justified). Code enforces them on every change and leaves the evidence. A program that inverts this, with meetings enforcing and code advising, is the "risk review board" anti-pattern of chapter 04: recommendation without consequence.

The law already expects the organisational layer to be designed. The EU AI Act requires a high-risk provider's quality management system to include "an accountability framework setting out the responsibilities of the management and other staff" (Art. 17(1) (m)) [1]. ISO/IEC 42001 asks for defined roles, responsibilities and authorities (clause 5.3; Annex A.3.2) [2], and the NIST AI RMF for documented roles and lines of communication for AI risk (GOVERN 2.1) [3]. None says how to make that framework true on a Tuesday. That is the engineering job.

This chapter is not a GRC programme manual and not legal advice. It is the operating model that gives the five layers of [the stack](#) their owners. The risk loop is chapter 13 ([Where risk management sits](#)); the controls at each build and run stage are chapters 14 and 15 ([Governing AI development](#), [Governing deployment and use](#)).

The stakeholder map

Each stakeholder holds a duty, a decision right (or explicitly none) and an artefact that evidences the duty. If you cannot name the artefact, the duty is not yet real.

Stakeholder	Duty in the program	Decides	Artefact it owns or signs
Board (governing body)	Sets AI risk appetite; oversees the program	Appetite; the AI policy	Appetite statement; board minutes
Executive leadership	Owns AI risk decisions for the business; funds the program	Acceptance of the highest residual risks	Signed risk acceptances; budget
CAIO / CDAO	Runs AI strategy and the use-case portfolio; chairs the committee	Portfolio priorities	Portfolio; use-case inventory
AI governance committee	Decides what gates cannot: residual risk, exceptions, value trade-offs	Exceptions; triggered go/no-go	Decision records; exception register
Legal	Reads obligations; confirms a control meets them	Interpretation	Obligation register; contract clauses
Privacy / DPO	Data protection by design; DPIA; data-subject rights	DPIA advice and sign-off	DPIA; records of processing
CISO / security	AI threat model; security controls; incident response	Security exceptions	Threat models; red-team results
Risk (second line)	AI risk taxonomy inside ERM; challenge; KRIs	Rating method	Risk register; KRI thresholds
Internal audit (third line)	Independent assurance over the program	Audit opinion	Audit reports; tested samples
Product owner	Accountable for one system's use case, value and risk	Scope; launch request	Justification memo; registry owner field
Engineering (ML, data, platform)	Builds and runs the system inside the gates	Technical design	Code; eval results; AIBOM
AI governance engineer	Builds the gates, the registry and the evidence path	Gate design	Policy code; evidence store
Procurement	AI intake for purchases; vendor tiering	Vendor approval, with risk	Vendor file; contract
HR	Workforce literacy; AI in employment decisions; worker information	People processes	Training records; worker notices

Stakeholder	Duty in the program	Decides	Artefact it owns or signs
Operators and end users	Use systems as instructed; exercise oversight; report concerns	Override in the moment	Override and escalation logs
Affected people and representatives	Give feedback; contest decisions	None formally; a voice	Feedback and contest records
Vendors	Supply evidence; notify changes and incidents	Their own system	Model cards; AIBOM; incident notices

Four rows need more than a cell.

The board. In the Institute of Internal Auditors' Three Lines Model, the governing body is accountable for oversight, management carries the first- and second-line roles, and internal audit gives independent assurance [4]. For AI, the board approves appetite and policy and receives evidence; it does not review use cases. NIST states the executive duty plainly: executive leadership "takes responsibility for decisions about risks associated with AI system development and deployment" (GOVERN 2.3) [3]. A board never asked to accept an AI risk has not delegated the decision; it has never seen it.

The CAIO. The Chief AI Officer (or Chief Data and AI Officer) owns the portfolio: which use cases the organisation pursues, and why. The clearest public template is the US federal one: OMB Memorandum M-25-21 of 3 April 2025 required each agency to designate a CAIO within 60 days, maintaining the AI use-case inventory and establishing "a process for an independent review of high-impact use cases before risk acceptance" [5]. The lesson transfers: the CAIO owns the inventory and the acceptance process, and does not review their own use cases.

Operators. A deployer of a high-risk system must "assign human oversight to natural persons who have the necessary competence, training and authority, as well as the necessary support" (Art. 26(2)) [6]. Competence and authority are organisational facts: a training record and a documented right to stop the system (see [Designing human oversight](#)).

Affected people. The people a system decides about rarely sit in the program, so it has to reach them. Employers deploying a high-risk system at the workplace must inform workers' representatives and affected workers first (Art. 26(7)) [6]. NIST asks for practices that integrate feedback from people outside the team that built or deployed the system (GOVERN 5.1) and for decisions informed by a diverse team (GOVERN 3.1) [3]. An ethics board or external panel earns its place only if its advice is recorded against a decision and answered.

A lifecycle RACI

The RACI says who does what at each lifecycle stage. **R** does the work, **A** answers for it (one per row), **C** is consulted before, **I** is informed after.

Stage	Product owner	Engineering	AI gov. engineer	Legal & privacy	Security	Risk	Committee	Internal audit
Intake	A	C	R	C	C	C	I (C if triggered)	I
Design	A	R	C	C	C	I	I	I
Data	A	R	C	R	I	I	I	I
Build	A	R	C	I	C	I	I	I
Test	A	R	R	I	R	C	I	I
Release	A (committee if triggered)	R	R	C	C	C	C	I
Operate	A	R	R	I	R	C	I	I
Change	A	R	R	C	C	I	I	I
Retire	A	R	R	C	C	I	I	I

Three rules keep the table honest. The product owner is accountable at every stage, because accountability that moves between functions as a system matures is the gap incidents fall through. Internal audit is informed everywhere and responsible nowhere; once it runs a first- or second-line task it can no longer audit that task independently [4]. The committee holds the A only for triggered use cases, so it does not become a bottleneck for ordinary ones.

A RACI in a slide is a claim. Compile it instead: one `raci.yaml` maps stages to roles, each registry entry names the people holding those roles for that system, and the pipeline reads both. A release with no named product owner fails admission; a pull request touching a policy needs its owner's review (a code-owners rule generated from the same file). The accountability framework of Art. 17(1)(m) becomes a file you can diff [1].

The committee decides, the gates enforce

Committees have a bad reputation in this book, and chapter 04 earns it: a board that rates findings monthly with no power to stop a launch is theatre. But some decisions cannot be automated, and pretending otherwise hides them in pipeline configuration

nobody reviews. The committee is legitimate where it takes those decisions, and only there.

What the committee is for

Four kinds of decision. **Risk acceptance:** whether a residual risk above the product owner's authority is acceptable, for how long and under which compensating controls. **Exceptions:** whether a system may proceed while failing a named rule. **Value trade-offs:** whether a benefit justifies a risk no threshold can price (a rights-affecting decision, a vulnerable population). **Policy:** approving the policy set and its material changes. It does not review every release, write controls or run evals; gates and teams do.

Charter and membership

A one- or two-page charter sets purpose, decision rights, quorum, membership, cadence, escalation, how decisions are recorded and how the charter changes. A workable core is the CAIO or a delegate (chair), legal, privacy, security, risk, a senior engineering lead and one or two product leaders, with HR and procurement for their cases and internal audit as a non-voting observer. For breadth, M-25-21 asked the AI governance boards of the largest (CFO Act) agencies to include IT, cybersecurity, data, budget, legal, privacy, civil rights and civil liberties, and to consult external experts as needed [5].

Advisory or binding

An advisory committee recommends and a named executive decides; a binding committee decides within its charter. Either works if the charter says which, per decision type. What fails is ambiguity: a committee that believes it approved a launch and a product owner who believes it merely commented. A common split is binding on exceptions and triggered use cases, advisory on strategy.

Risk acceptance and exceptions

Residual risk is accepted by someone with the authority to own it, for a bounded time. An acceptance matrix makes that explicit, using the ratings from chapter 13 (thresholds illustrative):

Residual risk	Who may accept	Maximum validity	Required evidence
Low	Product owner	12 months	Registry entry; passed gates
Medium	Product owner + risk function	6 months	Compensating controls named
High	AI governance committee	3 months	Decision record; monitoring plan
Above appetite	Executive leadership, reported to the board	3 months	Board notification
Prohibited use	No one	Not applicable	Blocked at intake

An exception is a risk acceptance for one rule on one system. It belongs in the policy repository as data, not in minutes. A record (illustrative):

```
exception:
  id: EXC-2026-014
  rule_id: eval.injection-floor.v4
  system: csa-01
  requested_by: team-support-platform
  justification: "Vendor model update lowered injection resistance; fix scheduled"
  compensating_controls:
    - guardrail.input.injection.v3 in block mode
    - human approval for refunds above the tier-2 limit
  residual_risk: high
  decision_record: DEC-2026-051
  approved_by: ai-governance-committee
  expires: 2026-10-31T23:59:59Z
```

The gate reads the register. While the exception is live, the rule returns `allow` with the exception id in its verdict, so the evidence shows the release passed *under an exception*. When it expires, the same rule fails the build again without anyone having to remember. Open exceptions by age become a board indicator.

Escalation, triggers and cadence

Most use cases never reach the committee; they pass [intake](#), [get a tier](#) and go through the gates. Review triggers route the rest:

- a decision with legal or similarly significant effect on a person (credit, employment, insurance, housing, education, public services);
- biometric identification or categorisation, emotion recognition, or special-category data;
- children or other vulnerable people as users or subjects;
- an agent with write access to money, customer records or production infrastructure;
- outputs that cannot be explained well enough for the people who must act on them;
- any exception request rated high or above.

Exceptions and triggered cases need a service level (for example, a decision within ten working days) and an asynchronous path; a monthly meeting would make governance the slowest step in delivery. Policy approvals can be monthly and the board report quarterly. Escalation runs product owner, committee, executive, board, with the trigger for each hop written in the charter.

In practice (illustrative) In a large telco, the committee's first meetings debated individual releases. Moving exceptions into a register the gates read changed its job. Engineers filed requests as pull requests; the committee decided within the service level; the gate enforced the expiry. Meetings shrank to triggered use cases and the trend in open exceptions, and an auditor could list every release that shipped under an exception with one query.

Enterprise risk, the three lines and internal audit

AI risk in the enterprise risk register

AI risk belongs in the enterprise risk register under the same appetite, rating scale and reporting line as every other risk, with AI categories underneath (harm to people, legal exposure, security, reliability, third parties). ISO/IEC 23894 adapts the ISO 31000 risk process to AI and is the natural bridge [7]. Generate the enterprise view from the system view: each registry entry carries its ratings and linked controls, and the register rolls them up by category and business unit. The link runs both ways, so a change in appetite changes tier rules and gate thresholds.

The three lines, applied to AI

Line	Who	AI duties	Evidence it produces
First	Product owners, engineering, operators	Build and run systems inside the gates; own their risks	Registry entries; eval results; runtime logs
Second	Risk, compliance, privacy, security, AI governance	Set method and policy; build the paved path; challenge first-line ratings	Policies as code; KRI thresholds; review records
Third	Internal audit	Independent assurance on the design and operation of controls	Audit reports; tested samples

The AI governance engineer usually sits in the second line, building tools the first line runs. The model describes roles, not boxes on an org chart; what matters is that the third line stays independent of what it assures [4].

What internal audit tests

ISO/IEC 42001 asks for internal audits of the management system (clause 9.2) [2]. They should test the gates, not the documents about them. **Re-performance**: re-run the policy decision for a random sample of releases from the stored inputs; the verdict should match the evidence store. **Bypass hunting**: compare what discovery finds running with the registry, and deployments with gate verdicts; a deploy without a verdict is a finding. **Exception hygiene**: sample exceptions for a named approver, an expiry and compensating controls that actually ran. Tabletop exercises (a simulated serious incident, a vendor model withdrawn overnight) test the decision paths no pipeline exercises.

Maps to: EU AI Act Art. 17(1)(m) (accountability framework), Art. 26(2) and Art. 26(7) (oversight competence; informing workers) · ISO/IEC 42001 clauses 5.1–5.3, 9.2; Annex A.2, A.3 · NIST AI RMF GOVERN 2, 3, 5 · layers 1 Govern-as-Code and 5 Assurance & Continuous Compliance. Mappings are illustrative, not a claim of conformity.

AI literacy as code

What Article 4 asks after the Omnibus

Article 4 of the EU AI Act has applied since 2 February 2025. As amended by Regulation (EU) 2026/1744, in force since 27 July 2026, it requires providers and deployers to "take measures to support the development of AI literacy" of their staff and others operating AI systems on their behalf, and adds that this "does not require providers or deployers to guarantee any specific level of AI literacy of any individual" [8][9]. The Commission's Q&A (updated 27 July 2026) says the obligation remains with no "sufficient" level mandated; no certificate is needed and an internal record of trainings will do; "other persons" include contractors, service providers and clients; the instructions for use alone are not enough; and national market-surveillance authorities supervise the rule from 2 August 2026 [10]. That is the position as of 2026-09-24.

The softer wording is no reason to do less. For high-risk deployers the harder duty sits in Art. 26(2) : oversight goes to people with the competence, training and authority to exercise it [6]. NIST expects AI risk training suited to each person's duties (GOVERN 2.2) [3], and ISO/IEC 42001 addresses competence and awareness in clauses 7.2 and 7.3 [2]. The engineering answer to all three is literacy as a role-based system with records, not an annual slide deck.

Role-based curricula

Persona	Must be able to	Curriculum blocks	Refresh trigger
Board and executives	Set appetite; read the KPI/KRI pack; accept or refuse risk	Terminology; strategy and appetite; provider or deployer role	New law; major incident
Product owners	Write a justification memo; tier a use case; own residual risk	Intake and triggers; risk method; policies by stage	Policy change
Engineers and data scientists	Build inside the gates; read an eval result; file an exception	Paved path; evals; data acquisition; incident duties	New gate or tool
Legal, privacy, compliance	Translate an obligation into a rule and back	The stack; evidence formats; system behaviour	New obligation
Operators with oversight duties	Read outputs; override, stop, escalate	The specific system; automation bias; override drill on the real interface	New model version
All staff using AI tools	Use approved tools on permitted data; report concerns	Acceptable use; data classes; the concern channel	Annual; new tool
Procurement and HR	Spot AI in a purchase; handle AI in people decisions	Intake flag; vendor tiering; employment rules	Template change

Formats follow the persona: scenario briefings for the board, labs for engineers, simulations for operators, microlearning with attestation for everyone else.

Training records and attestation as an access condition

A training record is evidence when it is structured, tied to a system and able to expire (illustrative):

```
{ "person": "u-48213", "role": "operator.credit-review",
  "module": "oversight.credit-scorer.v3", "completed": "2026-09-12",
  "assessment": "pass", "systems": ["credit-scorer-02"],
  "expires": "2027-09-12T00:00:00Z", "attested": true }
```

It becomes a control when access depends on it. The identity provider or AI gateway asks the policy engine before granting access (illustrative `OPA/Rego`):

```
package access.ai_tools

import rego.v1

default allow := false

allow if {
  some r in data.training_records[input.user]
  r.module == data.required_module[input.tool]
  r.attested
  time.parse_rfc3339_ns(r.expires) > time.now_ns()
}
```

An operator whose module has expired loses the override console, not only a line in a report; a new model version bumps the required module, so operators retrain before touching it. The record is `Art. 4` evidence, the access decision is `Art. 26(2)` evidence, and both land in the evidence store without a collection sprint.

Measuring and refreshing literacy

Completion rates measure attendance. Better indicators are coverage by persona, time from joining (or from a new model version) to a current record, and outcome signals: operators' override rates and time-to-decide (chapter 04's oversight metrics), the share of exception requests that arrive well formed, concerns raised per team. Refresh on events (a new law, capability, incident or tool) as well as on the calendar.

Governance culture

Controls fail quietly when people route around them; culture is whether they do. Three levers are within a governance function's reach.

Champions. A named champion in each product team, trained in more depth, answers first questions and first-reviews intakes. Champions scale the second line without adding to its headcount and carry the paved path into teams that would otherwise meet governance only as a blocked build ([make the governed path the easiest path](#)).

Incentives. Measure teams on releases through the paved path, exceptions closed before expiry and concerns raised and resolved, never on zero incidents, which rewards silence. NIST asks for a critical-thinking, safety-first mindset and for practices that enable testing, incident identification and information sharing (GOVERN 4.1, 4.3) [3]; incentives are how that mindset survives a deadline.

Blameless review. After an AI incident or near miss, review the system, not the person. Google's SRE practice defines a blameless postmortem as one that focuses "on identifying the contributing causes of the incident without indicting any individual or team for bad or inappropriate behavior" [11]. Its engineering output is a changed gate, eval or policy, filed as a pull request citing the review. A rising count of reported near misses is usually good news: the alternative is fewer reports, not fewer failures.

A channel for raising concerns

Pipelines catch what they were built to see. A data scientist who suspects a benchmark was gamed, an operator who sees a pattern of harmful outputs, an engineer asked to disable a guardrail before a demo: these reach the program only if people can raise them safely, outside the chain of command that created the problem. The law now expects such channels (as of 2026-09-24):

Regime	Who must act	What it requires
EU AI Act Art. 87 with Directive (EU) 2019/1937 [12][13]	Private legal entities with 50 or more workers, through national transposing law	Internal channels and follow-up (Art. 8); acknowledgment within seven days and feedback within three months (Art. 9(1)(b), (f)); no retaliation (Art. 19)
California SB 53, Labor Code §1107.1 [14][15]	Frontier developers; the internal-process duty binds large frontier developers	No rule preventing covered employees from disclosing to the Attorney General or other authorities; no retaliation; notice of rights; an anonymous internal process with monthly updates to the reporter, shared with officers and directors at least quarterly
ISO/IEC 42001 Annex A.3.3 [2]	Organisations implementing the standard (voluntary)	A process for reporting concerns about AI systems

Article 87 applies the Whistleblower Directive to reports of AI Act infringements from 2 August 2026 [12]. SB 53, in force since 1 January 2026, protects "covered employees" (those responsible for assessing, managing or addressing the risk of critical safety incidents) who disclose that a frontier developer's activities pose "a specific and substantial danger to the public health or safety resulting from a catastrophic risk" or violate the Act [14][15].

Build the channel like any governed system. Intake accepts anonymous and named reports by more than one route. Each report becomes a case record with the statutory clocks encoded as timers, not reminders. Triage routes a possible incident to the [Incident Pipeline](#), a possible infringement to legal, a policy gap to the committee. The reporter's identity is sealed from the people named, and HR watches for retaliation signals (sudden performance actions, access changes) around protected reporters. Volumes, clock compliance and outcomes go upward without identities. This sketches the engineering; it is not advice on any national transposing law.

KPIs and KRIs for leadership and the board

Leadership needs a few indicators it can trust, computed from live systems rather than self-reported. A **KPI** says whether the program is doing its job; a **KRI** says whether risk is moving towards the edge of appetite.

Indicator	Type	Definition	Produced by
Registry coverage	KPI	Share of discovered AI systems and agents with a registry entry and an owner	Layer 02; Shadow-AI Discovery
Unregistered AI found	KRI	Count of running AI with no entry, by tier	Layer 02 discovery
Gate coverage	KPI	Share of production releases that passed through an eval gate	Layer 03
Open exceptions by age	KRI	Live exceptions, oldest first; expired ones flagged	Exception register (layer 01)
Time to decision	KPI	Median days from intake to go/no-go, by tier	Intake workflow
Assessments current	KPI	High-risk systems with a current FRIA or DPIA	Layer 02
Incidents and time to contain	KRI	AI incidents by severity; median time to detect and to contain	Layers 04 and 05
Oversight quality	KRI	Override rate and time-to-decide at human checkpoints	Layer 04
Literacy coverage	KPI	Share of each persona with a current training record	Training records
Concern clocks met	KPI	Reports acknowledged within seven days and answered within three months	Concern channel
Vendor reassessments overdue	KRI	Tier-1 vendors past their reassessment date	Procurement file
Realised risk reduction	KPI	Change in the rate of named failure modes in production	Layer 05

The last row matters most and is hardest to fill, which is why it belongs in the board pack from the start (value 7). Coverage indicators are inputs; chapter 07 (metrics per level) shows the engineering metrics beneath them. The board pack is one page: trends for six to eight indicators, anything outside threshold, decisions the board must take, exceptions above appetite. A query generates it; a hand-assembled pack drifts from the systems it describes.

Management review and continual improvement

A management system improves only if someone looks at the evidence on a schedule and changes something. ISO/IEC 42001 asks for monitoring and measurement, internal audit and management review (clauses 9.1 to 9.3) and for continual improvement with corrective action (clauses 10.1 and 10.2); read the standard for the required inputs and outputs [2]. One review can serve several management systems (integrating ISO/IEC 42001 with 27001, 27701 and 9001, chapter 22). NIST asks for planned periodic review of the risk process, with roles and frequency defined (GOVERN 1.5) [3].

Engineer the review to produce changes, not minutes. Inputs: the KPI/KRI pack, audit findings, incidents and near misses, concerns, changes in law and standards, open corrective actions. Outputs, recorded as data: a policy diff with an effective date, a threshold change, a resourcing decision, a corrective action with owner and due date. Track corrective actions the way OSCAL tracks a plan of action and milestones (chapter 04), so each review opens with what was promised and what was done. A review that changes nothing for two cycles means the evidence is not reaching it, or is not believed.

Maps to: EU AI Act Art. 4 (AI literacy), Art. 26(2) (oversight competence), Art. 87 (reporting of infringements) · Directive (EU) 2019/1937 · California SB 53 (Labor Code §1107.1) · ISO/IEC 42001 clauses 7.2–7.3, 9.1–9.3, 10.1–10.2; Annex A.3.3 · NIST AI RMF GOVERN 1.5, 2.2, 4 · layers 1 Govern-as-Code and 5 Assurance & Continuous Compliance.

Strategy, value and whether to use AI at all

Governance usually starts after someone has decided to build. It should start a step earlier. The NIST AI RMF expects the goals for AI and the business value of each use to be documented (MAP 1.3, 1.4), benefits and costs to be examined, including the non-monetary costs of errors (MAP 3.1, 3.2), and, after mapping, an "initial go/no-go decision about whether to design, develop, or deploy an AI system"; later it asks again whether development or deployment should proceed (MANAGE 1.1) [3].

Make the question a required field. A justification memo at intake (illustrative):

```
use_case: refund-triage-assistant
owner: team-support-platform
problem: "Refund requests wait days for a first answer"
non_ai_alternative: "Rules engine plus extra staff at peak"
why_ai: "Free-text requests; the rules engine misroutes a large share"
benefit_metric: "Median time to first answer"
who_bears_errors: "Customers wrongly refused a refund"
contest_route: "Human review on request, within two working days"
reversible: true
kill_criteria: "Wrong-refusal rate above the tier threshold for two weeks"
```

Five questions decide most cases. Is there a non-AI alternative at acceptable cost? Can the benefit be measured, and by whom? Who bears the errors, and can they contest them? Is the decision reversible? What would make us stop? A use case that cannot answer the last question is not ready for a gate, because there is no threshold to enforce.

Rolled up, the memos are the AI portfolio: where the organisation spends, which risks it carries, which benefits it has measured. They also answer the charge that governance only slows things down. "Time to decision" is a program KPI, and a paved path that takes a low-risk use case from intake to production in days is how governance enables delivery rather than taxing it.

Standing up a program without engineering capacity

Many organisations that need a program build no AI at all; they buy it. The engineering-first route of chapter 04 (the minimum viable stack for a team of one) assumes a pipeline to put gates in. A buyer still has pipelines: procurement, identity and expenses. Build on those.

Pillar	Minimum artefact	Enforced through
Charter and scope	Program charter; committee charter	Executive sponsor's approval
Inventory	Registry with owner, vendor, data classes and tier	Procurement intake; single sign-on app catalogue; expense review
Policy set	Acceptable use; AI intake; third-party AI	Purchase approval; gateway or browser controls
Roles	Named owner per system; committee membership	Required registry field
Literacy	Role-based modules; training records	Tool access conditional on attestation
Metrics	Five indicators from the table above	Monthly query over registry and procurement data

Pillar	Minimum artefact	Enforced through
Review cadence	Quarterly management review	Decisions recorded as data

A first 90 days: charter, committee, acceptable-use policy and an inventory seeded from procurement and the sign-on catalogue (days 1 to 30); the AI flag in purchase requests, tiering of what is already bought, modules for operators of the riskiest systems (days 31 to 60); the first KPI pack, the first management review and a decision on which control to automate first (days 61 to 90). The Commission's Q&A notes that Article 4 mandates no specific governance structure [10]; size the program to what the organisation runs and grow the code with the portfolio. Chapter 13 sets how much of the risk loop each kind of organisation runs ([proportionate governance](#)), and the templates page has starter [committee](#), [RACI](#) and [AI policy sections](#).

Policies across the lifecycle

Policy, standard, procedure, code

Policy documents fail by being too vague to enforce or too detailed to keep current. A four-level hierarchy gives each level one job.

Level	Answers	Approved by	Changes	Example
Policy	Why and what: principles, appetite, scope	Board or committee	Rarely	"No AI system reaches production without an owner and a passed eval gate."
Standard	Measurable requirements per tier	Committee or delegate	Quarterly	"Tier 2 and 3 systems score at least 0.95 on the injection suite."
Procedure	How, step by step	Function owner	As needed	"Run the gate locally; attach the result to the registry entry."
Policy as code	The enforced rule	Code review with the policy owner	Every change is a pull request	<code>eval.injection-floor.v4</code>

ISO/IEC 42001 asks for an AI policy (clause 5.2) and has controls on policies related to AI (Annex A.2) [2]; NIST asks that AI risk policies and procedures be in place, transparent and implemented effectively (GOVERN 1) [3]. The hierarchy adds one engineering rule: every rule in code carries the ids of the standard and policy it implements, so a reader can walk from a failed build to the sentence the board approved.

What policy requires at each stage

Each stage has a minimum requirement, a gate that enforces it and the evidence it leaves. Chapters 14 and 15 treat the build and run stages in depth.

Stage	Policy requires	Gate that enforces it	Evidence	Layer
Intake	Justification memo; risk tier; prohibited-use screen; review triggers	Intake writes a registry stub; no stub, no deploy	Registry entry; tier record	1 · 2
Design	Threat model ; oversight design; impact assessment when triggered	Design review as a required check	Threat model; FRIA/DPIA reference	1 · 3
Data	Acquisition record; lawful basis; licence; quality and bias checks	Pipeline refuses a dataset without a valid data card	Data card; lineage	2 · 3
Build	Approved models and platforms; versioned prompts, retrieval and tools; AIBOM	CI policy checks; model allowlist	AIBOM; policy verdicts	1 · 2
Test	Required eval categories and thresholds by tier; red teaming for higher tiers	Eval gate	Eval results	3
Release	Complete deployment package; approvals; transparency notices	Admission control reads the registry	Release record; model card	1 · 2 · 5
Operate	Monitoring; oversight; incident definition and severity scale; logging	Guardrails; alerts; incident pipeline	Traces; guardrail events; incident records	4 · 5
Change	Material-change triggers for model, prompt, data and tool scope	Gates re-run on change; registry version bump	Diff; new eval results	1 · 3
Retire	Revoke identities, archive evidence, delete or retain data	Registry status <code>retired</code> ; identity revoked	Decommission record	2 · 4 · 5

Three stages are often missing from policy sets. **Operate** needs an incident definition wider than the law's. The AI Act's "serious incident" covers death or serious harm to health, serious and irreversible disruption of critical infrastructure, infringement of fundamental-rights obligations and serious harm to property or the environment [16]; most incidents a program must learn from sit below that line (a biased batch, a leaked prompt, a tool call outside scope). Route every severity through one pipeline and let

only the top class start a statutory clock (chapter 17, [Incidents, issues and root causes](#)). High-risk deployers must also inform the provider and suspend use when they have reason to consider the system presents a risk ([Art. 26\(5\)](#)) [6]. **Change** needs triggers, because a prompt edit or a new retrieval source can change behaviour as much as a new model. **Retire** needs a [runbook](#): NIST asks for safe decommissioning "in a manner that does not increase risks" (GOVERN 1.7) [3], which means revoking every identity and credential, marking the registry entry retired, archiving the evidence for its retention period and applying retention rules to training and derived data.

Policy as code: one source, two outputs

The drift between a policy PDF and the check that enforces it is where auditors find their findings. Write each rule once, as data, and compile it twice: into the prose people read and the check the pipeline runs. The source (illustrative):

```
id: AIP-07
title: Evaluation before release
owner: ai-governance-committee
effective: 2026-10-01
maps_to: ["EU AI Act Art. 15", "ISO/IEC 42001 A.6", "NIST AI RMF MEASURE"]
rules:
- rule_id: eval.injection-floor.v4
  applies_to_tiers: [2, 3]
  suite: injection-resistance.v4
  threshold: 0.95
  exceptions: register
```

The prose compiler renders: "AIP-07.1. A tier 2 or tier 3 AI system is released only if its latest [injection-resistance.v4](#) run scores at least 0.95. Exceptions follow the exception register. Owner: AI governance committee. Effective 1 Oct 2026." The code compiler renders the check (illustrative [OPA/Rego](#)):

```
package aip07

import rego.v1

deny contains msg if {
  input.system.tier in {2, 3}
  r := input.eval["injection-resistance.v4"]
  r.score < 0.95
  not exception_active(input.system.id, "eval.injection-floor.v4")
  msg := sprintf("AIP-07 eval.injection-floor.v4: %s scored %v, below 0.95", [input.system.id, r.score])
}

exception_active(sys, rule) if {
  some e in data.exceptions
  e.system == sys
  e.rule_id == rule
  time.parse_rfc3339_ns(e.expires) > time.now_ns()
}
```

Both outputs come from one commit, so the published policy and the enforced rule cannot disagree. The same source feeds the [Framework Crosswalk](#) and, for agents, a [Policy Card](#). Tests prove the rule fires on a violating input and passes a clean one, as layer 01 requires.

Updating the policies you already have

Most organisations do not need a new policy for every AI concern. They need their privacy, security, data governance and intellectual-property policies to see AI. A gap assessment finds where they do not.

1. **Inventory** every policy that touches AI systems or their data, including procurement, HR, records and acceptable use.
2. **Test each against the five objects** (model, system, agent, data, organisation) and the lifecycle stages: does it name the object, contain a rule that applies to it, and say what evidence shows the rule is followed?
3. **Decide: extend or create.** Extend when the existing owner and control fit (a retention rule that only needs model artefacts added). Create when a new object needs a new owner (agent identity has no home in a classic access-control policy).
4. **File each gap as data** (policy, clause, gap, decision, owner, due date, evidence), so the gap register is a query and its closure a KPI.

Policy	Typical AI gaps	Typical additions	Evidence
Privacy	Lawful basis for training versus inference; purpose limitation on reuse; what models memorise; notices; rights over models and outputs; retention of training and derived data	Dataset purpose tags; DPIA triggers for AI; procedure for rights requests against models	DPIA; data card; rights-request log
Security	Prompt injection, poisoning, model extraction and supply-chain threats missing from the risk assessment and playbooks; no trusted model sources	AI threats in the ISMS risk assessment; AI incident playbooks; model and dataset allowlist	Threat model; red-team results; allowlist
Data governance	Lineage without provenance; scraped, brokered and synthetic data unlabelled; no retention by layer	Acquisition policy (below); provenance fields; retention for raw data, features, labels and weights	Data card; lineage graph
Intellectual property	Training rights and text-and-data-mining opt-outs; use of outputs; trade secrets in prompts; open-weight licences; vendor indemnities	Rights review per dataset; output-use rules; prompt rules by data class; model licence review	Rights ledger ; licence records

Three notes. For **security**, the agentic threat catalogue (goal hijack, tool misuse, identity and privilege abuse, rogue agents) is the checklist to add to the existing threat model [17]. For **data governance**, keep a contrast pair straight: *lineage* is the path data took through your pipelines; *provenance* is where it came from and on what terms. Perfect lineage over unknown provenance is still ungoverned. For **intellectual property**, EU law lets rightholders reserve works from text and data mining "in an appropriate manner, such as machine-readable means in the case of content made publicly available online" (Directive (EU) 2019/790, Art. 4(3)) [18], and general-purpose model providers must have a policy to identify and comply with those reservations (Art. 53(1)(c)) [19]. Chapters 19 and 20 ([Privacy and data protection law applied to AI](#), [Other law that already applies to AI](#)) cover the law; the policy's job is to make each rule checkable.

A data acquisition policy

Most data-governance failures are decided at acquisition: a scrape nobody scoped, a broker's dataset with no provenance, labels produced under conditions nobody checked. ISO/IEC 42001 has an Annex A control on the acquisition of data (A.7.3) [2]. The policy names acceptable sources and the minimum conditions for each, and makes every condition a field in the acquisition record.

Source	Minimum conditions	Evidence field
First-party data collected for another purpose	Compatibility of purpose assessed; notice updated; DPIA if triggered	Purpose tag; lawful basis
Web scraping	Sensitive sources excluded; machine-readable reservations and exclusion files respected; opt-out list honoured; collection bounded in time	Crawler configuration hash; exclusion and opt-out list versions
Data brokers and licensed datasets	Provenance chain; lawful-basis warranties; licence covering AI training; audit right; deletion on request	Contract id; provenance statement
Labelled or annotated data	Written guidelines; pilot; agreement between annotators above a threshold; pay and conditions standard; quality assurance	Guideline version; agreement score; supplier attestation
Data shared by a partner	Agreement covering purpose, retention, onward sharing, security, deletion, breach notice and audit	Agreement id
Synthetic data	Generator and seed data recorded; labelled as synthetic; re-identification test	Generator version; test result

The scraping row follows the European Data Protection Board's Opinion 28/2024, whose mitigating measures include excluding certain sources and data categories, respecting "robots.txt or ai.txt files or any other recognised mechanism" that objects to scraping, and a controller-managed opt-out list [20]. The labelling row follows the Partnership on AI's guidance on sourcing data enrichment work, which covers provider selection, pilots, clear instructions, payment terms, communication with workers, quality assurance and offboarding [21]. Annotators' conditions are a governance matter: labels produced in a rush under unclear instructions become the noise and bias the eval suite later has to find.

Enforce at the pipeline boundary: no dataset enters a training, fine-tuning or retrieval pipeline without an acquisition record that passes schema validation, and the record flows into the data card and the **AIBOM** (see [data governance across the stack](#)).

Third-party AI policy

Most AI an organisation runs, it bought. Chapter 04 explains how the stack degrades for procured AI ([third-party and procured AI](#)), and chapter 05 gives the [Vendor / Model Due-Diligence Gate](#). ISO/IEC 42001 covers third-party and customer relationships in Annex A.10 [2]; NIST asks for policies on third-party AI risk, including infringement of third-party intellectual property, and for contingency processes for failures in high-risk third-party data or systems (GOVERN 6.1, 6.2) [3].

Procurement intake. Every purchase request carries an AI flag: does the product use AI, process our data with AI, train on our data, act on our systems, or make or support decisions about people? A yes routes it to tiering. The quieter case is AI arriving inside a product already bought: a release note adding an AI feature to an existing contract triggers the same intake.

Vendor tiering. Tier by criticality, data sensitivity, autonomy and regulatory context, and scale the assessment to the tier.

Tier	Typical profile	Assessment	Reassessment
1	Decisions about people; high-risk use; agents with write access; special-category data	Full due diligence; boundary evals; full clause set; committee approval	Annual and on triggers
2	Internal productivity on confidential data	Questionnaire with evidence; standard clause set	Every two years and on triggers
3	No confidential data; no decisions about people	Light check; covered by acceptable use	On renewal

Contract terms as controls. A clause is a control when it creates something you can monitor. The Commission's community of public buyers publishes model contractual AI clauses in a high-risk and a non-high-risk version, voluntary and deliberately silent on IP, payment and data protection; the version on its page is dated 29 September 2023 (as of 2026-09-24) [22]. They are a sound starting library for private buyers too.

Clause	Control it creates	Evidence or monitor
Disclosure of AI use and sub-processors	Inventory completeness; fourth-party map	Vendor register; supplied AIBOM
No training on customer data without opt-in	Purpose limitation	Contract flag; attestation; configuration check
Notice of material change (model, version, behaviour)	Trigger for re-evaluation	Notice starts a boundary-eval re-run
Incident notification window	Input to your own incident clock	Notice timestamp in the incident pipeline
Evidence and audit rights	Collected evidence	Model card, eval results and certificates in the evidence store
Bias testing and remediation duty	Fairness evidence for your use	Vendor test reports
Deactivation, data return and exit	A contractual kill switch	Tested exit runbook
Liability and indemnity, including IP	Risk transfer, not risk reduction	Contract register

Supply chain and open source. The foundation model under a vendor's product is a dependency you inherit; map these fourth parties. The value chain can also change your role: under [Art. 25](#), a distributor, importer, deployer or other third party that puts its name or trademark on a high-risk system, substantially modifies one, or changes a system's intended purpose so that it becomes high-risk is treated as its provider [23]. Open-weight models and open datasets go through the same intake: licence and use restrictions reviewed, provenance recorded, artefacts scanned and pinned before loading, results in the AIBOM. Reassess on events, not only on renewal: an incident, an ownership change, a new model version, public controversy or regulatory action, a change in the law.

People. AI used for recruitment and selection, promotion or termination, task allocation, or monitoring and evaluating workers is high-risk under Annex III point 4 [24], with the worker-information duty of [Art. 26\(7\)](#) for deployers [6]. Annotators, contractors and outsourced reviewers who handle your data are part of the supply chain, under the acquisition conditions above [21].

Acceptable use of AI by staff

The glossary defines shadow AI as AI running in production without registering. Staff use of unapproved tools is its everyday twin: an employee pasting a customer file into a public chatbot. An acceptable-use policy (AUP) covers approved tools, prohibited inputs by data class, the duty to review outputs, disclosure where outputs reach customers, logging, the attestation required before access and proportionate consequences.

Data class	Public AI tool	Sanctioned AI gateway	Approved internal system
Public	Allowed	Allowed	Allowed
Internal	Not allowed	Allowed, logged	Allowed
Confidential or customer data	Not allowed	Approved use cases only; logged; redacted	Allowed within scope
Special-category or regulated data	Not allowed	Only with a DPIA-backed use case	Allowed within scope
Secrets, credentials, restricted code	Not allowed	Not allowed	Per security standard

Enforce with the [gateway](#), not the handbook: approved tools behind single sign-on and a gateway that applies data-class rules and logs use; access conditional on a current AUP attestation (the literacy gate above); discovery of unapproved tools through

identity, network and expense data (the [Shadow-AI Discovery](#) pattern). When discovery finds an unapproved tool, offer a way in (register, tier, approve or replace) before a sanction. People use unapproved tools because the approved path is slower; the fix is usually a better path.

Example (illustrative) A legal team starts using a public drafting assistant for contract summaries. Discovery flags the traffic. Rather than block the domain, the program runs the tool through procurement intake, signs an enterprise agreement with no training on customer data, routes it through the gateway under the confidential-data rule, and adds a one-page module to the legal team's curriculum. Usage moves to the sanctioned route within weeks, because it is now the easiest one.

Maps to: EU AI Act Art. 25 (value chain), Art. 26 (deployer duties), Art. 53(1)(c) (GPAI copyright policy), Annex III point 4 (employment) · Directive (EU) 2019/790 Art. 4(3) · ISO/IEC 42001 clause 5.2; Annex A.2, A.7.3, A.10 · NIST AI RMF GOVERN 1, 6; MAP 1, 3; MANAGE 1.1 · layers 1 Govern-as-Code, 2 Inventory & Transparency and 5 Assurance & Continuous Compliance.

What you can do this week

1. **Write the committee charter on one page**, listing the four decision types the committee alone takes and stating that gates enforce everything else.
2. **Create the exception register** as a file in the policy repository, point one gate at it and set a maximum expiry.
3. **Gate one tool on training**: make access to your riskiest system's override console, or to your AI gateway, conditional on a current training record.
4. **Generate three board indicators from live data**: registry coverage, unregistered AI found and open exceptions by age.
5. **Run the gap assessment on two policies** (privacy and security) against the five objects, and file each gap as a row with an owner.

Sources

[1] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 17 (quality management system; Art. 17(1)(a) strategy for regulatory compliance; Art. 17(1)(m) accountability framework; Art. 17(2) proportionality, as amended by Reg. (EU) 2026/1744). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_17 (verified: primary) [2] ISO/IEC 42001:2023, AI management system (referenced by number only: clauses 5.1–5.3, 7.2–7.3, 9.1–9.3, 10.1–10.2; Annex A.2, A.3.2, A.3.3, A.7.3, A.10). ISO/IEC. 2023-12. <https://www.iso.org/standard/81230.html> (verified: secondary) [3] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (GOVERN 1, 1.5, 1.7, 2.1–2.3, 3.1, 4.1, 4.3, 5.1, 6.1–6.2; MAP 1.3–1.4, 3.1–3.2; MANAGE 1.1; initial go/no-go decision after MAP). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [4] The IIA's Three Lines Model: an update of the Three Lines of Defense (governing body; management's first- and second-line roles; internal audit as third line; third-line independence). The Institute of Internal Auditors. 2020-07. <https://www.theiia.org/en/content/position-papers/2020/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense/> (verified: primary) [5] OMB Memorandum M-25-21, Accelerating Federal Use of AI through Innovation, Governance, and Public Trust (CAIO within 60 days; AI use-case inventory; independent review of high-impact use cases before risk acceptance; CFO Act agency AI Governance Boards within 90 days, chaired at Deputy Secretary level, with IT, cybersecurity, data, budget, legal, privacy, civil rights and civil liberties representation). Office of Management and Budget, The White House. 2025-04-03. <https://www.whitehouse.gov/wp-content/uploads/2025/02/M-25-21-Accelerating-Federal-Use-of-AI-through-Innovation-Governance-and-Public-Trust.pdf> (verified: primary) [6] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 26 (deployer obligations: 26(1) use per instructions; 26(2) oversight by persons with competence, training and authority; 26(5) monitoring, informing the provider and suspension; 26(7) informing workers' representatives and affected workers). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_26 (verified: primary) [7] ISO/IEC 23894:2023, Guidance on AI risk management (adapts ISO 31000 to AI). ISO/IEC. 2023-02. <https://www.iso.org/standard/77304.html> (verified: secondary) [8] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 4 (as amended by Reg. (EU) 2026/1744: providers and deployers "take measures to support the development of AI literacy"; no guaranteed level for any individual; support from the Commission and Member States; Board recommendations; applies since 2 Feb 2025 under Art. 113(a)). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_4 (verified: primary) [9] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 et al.; OJ L, 24 July 2026; in force 27 Jul 2026. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [10] AI Literacy: Questions & Answers (obligation remains, no specific or "sufficient" level mandated; no certificate needed; internal record of trainings; "other persons" include contractors, service providers and clients; no specific governance structure mandated; instructions for use alone not sufficient; supervision by national market-surveillance authorities from 2 Aug 2026). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers> (verified: primary) [11] "Postmortem Culture: Learning from Failure" (John Lunney, Sue Lueder), in Site Reliability Engineering. Google. 2016. <https://sre.google/sre-book/postmortem-culture/> (verified: primary) [12] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 87 (Directive (EU) 2019/1937 applies to the reporting of infringements of the AI Act and the protection of reporting persons; applies from 2 Aug 2026 under Art. 113). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_87 (verified: primary) [13] Directive (EU) 2019/1937 on the protection of persons who report breaches of Union law

(Art. 8(1) and 8(3) internal channels for private entities with 50 or more workers; Art. 9(1)(b) acknowledgment within seven days; Art. 9(1)(f) feedback within three months; Art. 19 prohibition of retaliation). Publications Office of the EU (EUR-Lex). 2019-10-23. <https://eur-lex.europa.eu/eli/dir/2019/1937/oj/eng> (verified: primary) [14] SB 53, Transparency in Frontier Artificial Intelligence Act (Chapter 138, Statutes of 2025, approved and filed 29 Sep 2025, a regular-session statute and so in force from 1 Jan 2026 under Cal. Const. art. IV, §8(c)(1); Labor Code §§1107–1107.2: "covered employee", no rule preventing disclosure, no retaliation, notice of rights, anonymous internal process for large frontier developers with monthly updates and quarterly sharing with officers and directors). California Legislature. 2025-09-29. https://leginfo.ca.gov/faces/billTextClient.xhtml?bill_id=202520260SB53 (verified: primary) [15] "California's SB 53: the first frontier AI law explained" (frontier developers: trained a foundation model with more than 10^{26} operations; large frontier developers: also more than USD 500M in annual gross revenue; up to USD 1M per violation; AG enforcement). Future of Privacy Forum (Justine Gluck). 2025-10-03. <https://fpf.org/blog/californias-sb-53-the-first-frontier-ai-law-explained/> (verified: secondary) [16] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 3(49) (definition of "serious incident"). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_3 (verified: primary) [17] Top 10 for Agentic Applications 2026. OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [18] Directive (EU) 2019/790 on copyright and related rights in the Digital Single Market (Art. 4(1) text-and-data-mining exception; Art. 4(3) reservation by rightholders, by machine-readable means for content online). Publications Office of the EU (EUR-Lex). 2019-04-17. https://eur-lex.europa.eu/eli/dir/2019/790/oj/eng#art_4 (verified: primary) [19] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 53(1)(c) (GPAI providers' copyright policy, incl. identifying and complying with Art. 4(3) reservations). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_53 (verified: primary) [20] Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (paras 104–106: web-scraping mitigations incl. excluding sources and data categories, respecting robots.txt or ai.txt, opt-out lists). European Data Protection Board. 2024-12-17. https://www.edpb.europa.eu/our-work-tools/our-documents/opinion-board-art-64/opinion-282024-certain-data-protection-aspects_en (verified: primary) [21] Responsible Sourcing of Data Enrichment Services (provider selection, pilots, instructions, payment terms, communication with workers, quality assurance, offboarding). Partnership on AI. 2021-06-16. <https://partnershiponai.org/paper/responsible-sourcing-considerations/> (verified: primary) [22] EU model contractual AI clauses (MCC-AI) to pilot in procurements of AI (high-risk and non-high-risk versions; voluntary; exclude IP, payment and GDPR terms). Public Buyers Community, European Commission. 2023-09-29. <https://public-buyers-community.ec.europa.eu/communities/procurement-ai/resources/eu-model-contractual-ai-clauses-pilot-procurements-ai> (verified: primary) [23] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 25(1) (a value-chain actor becomes the provider when it puts its name or trademark on a high-risk system, makes a substantial modification, or modifies the intended purpose so that the system becomes high-risk). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_25 (verified: primary) [24] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Annex III, point 4 (employment, workers' management and access to self-employment: recruitment and selection; decisions on work relationships, task allocation, monitoring and evaluation). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#anx_III (verified: primary)

13. Where risk management sits

Risk management is the loop that tells every other control how hard to bite: identify, assess, treat and monitor, run on the five layers and seven workflows, with the risk register as evidence.

What this chapter settles

The book has leaned on risk without giving it a home. Chapter 03 says every control should [start from a named failure mode or harm](#); chapter 04 warns against a risk review board that rates findings but cannot stop a launch; chapter 08 names a "risk register as code" as the artefact behind [Art. 9](#) without defining it. None of them says where risk decisions are made, on what scale, by whom, or how a decision becomes a threshold a pipeline can enforce. This chapter does.

The claim is short. Risk management is not a sixth layer and not a committee beside the stack. It is the loop that sets the parameters of every other control: which systems get which gates, how high an eval threshold sits, when a person must approve an action, and who may sign for the risk that is left. The loop has four steps (identify, assess, treat, monitor). Each step produces an artefact on one of the five layers and is owned by one of the seven workflows of chapter 06. Its evidence record is the **risk register**, kept as versioned data rather than as a spreadsheet.

Three contrasts keep the scope honest (chapter 01 has the full cluster). **Enterprise risk management** aggregates every risk an organisation runs; AI risk management feeds it, as the NIST AI RMF asks [1]. **Model risk management** validates models in the banking tradition; in the United States its founding guidance, SR 11-7, was superseded on 17 Apr 2026 by interagency guidance that tailors the practice to each bank's model risk profile, size and complexity [2]. This discipline borrows the tailoring and adds agents, runtime control and continuous evidence. **AI safety research** asks whether a capability is dangerous in principle; this chapter decides what one deployment may do, and proves it.

Risk, defined for engineers

Two definitions anchor the chapter. The EU AI Act defines **risk** as "the combination of the probability of an occurrence of harm and the severity of that harm" [3]. The NIST AI RMF uses the same shape, "the composite measure of an event's probability of occurring and the magnitude or degree of the consequences", and allows those consequences to be positive or negative [1]. This book works on the negative side: harm to people, to their rights, to the organisation and to the systems around it. The shared vocabulary comes from the ISO risk family, whose current vocabulary standard is ISO 31073:2022; it replaced ISO Guide 73:2009, which is now withdrawn [4].

Each term below has an artefact that holds it; that is the test that a term does work.

Term	Meaning in this book	Where it lives
Risk source	Anything that can give rise to risk: a dataset, a tool grant, an adversary, a user group	Register source ; AIBOM; threat model
Inherent risk	The rating before any control is counted	Register inherent
Residual risk	The rating after the controls that have evidence of working	Register residual
Risk appetite	How much risk, and of which kinds, the organisation is prepared to take on for its objectives	Appetite data file (layer 01)
Risk tolerance	How much of a given risk the organisation will bear to reach an objective; the bound a gate enforces	Tier thresholds (layer 01)
Treatment	The option chosen (avoid, mitigate, transfer, accept) and the controls that carry it	Register treatment ; control ids
Acceptance	A named, signed and expiring decision to carry a residual risk	Acceptance record (layer 05)

AI makes each of these harder to pin down. NIST lists why: third-party components, emergent risks, no agreed metrics, ratings that shift across the lifecycle, lab results that differ from production, opacity and no human baseline [1]. So every rating is provisional, recomputed from evidence (an eval result, a telemetry signal, an incident), not re-argued in a meeting.

The loop: identify, assess, treat, monitor

ISO 31000:2018 gives the generic process: communicate and consult; set scope, context and criteria; assess (identify, analyse, evaluate); treat; monitor and review; record and report [5]. The 2018 edition is current but flagged for revision, with a successor at committee-draft stage as of 2026-09-24 [5]. ISO/IEC 23894:2023 is the AI-specific guidance for organisations that develop, produce, deploy or use AI, customisable to any organisation and context [6]. Its clauses follow the ISO 31000 structure, as NIST's crosswalk between the two shows [7].

The EU AI Act turns the same loop into law for high-risk systems. Article 9 requires a risk management system to be "established, implemented, documented and maintained", run as a continuous iterative process across the lifecycle, with four steps: identify and

analyse the known and reasonably foreseeable risks to health, safety or fundamental rights; estimate and evaluate the risks under intended use and reasonably foreseeable misuse; evaluate further risks from post-market monitoring data; and adopt targeted risk management measures [8]. The Digital Omnibus left Article 9 unamended [9]; for Annex III systems it applies from 2 Dec 2027 [10]. It binds the provider; the deployer runs its own loop through [Art. 26](#) monitoring and, where it applies, the [Art. 27](#) FRIA (chapter 08). A legal reading of Article 9, written against the 2021 proposal, is a useful guide to what each step asks [11]. No harmonised standard for AI risk management is yet cited in the Official Journal [12]; the draft that would answer Article 9, prEN 18228, is tracked in [the JTC 21 programme](#) (chapter 22).

The four steps compress ISO's activities: **identify** covers scope, context, criteria and identification; **assess** covers analysis and evaluation; **monitor** covers review, recording and reporting. Communication and consultation runs through all four, here as stakeholder mapping.

Step	ISO/IEC 23894 clause (per NIST crosswalk)	NIST AI RMF	EU AI Act Art. 9	Primary artefact
Identify	6.3 scope, context, criteria; 6.4.2 identification	MAP 1–5; GOVERN 5	9(2)(a)	Use-case risk profile; stakeholder map; register entry
Assess	6.4.3 analysis; rest of 6.4	MAP 5.1; MEASURE 1–2	9(2)(b)	Matrix rating; eval results as likelihood evidence
Treat	6.5 treatment	MANAGE 1–3	9(2)(d); 9(5)	Controls linked to the risk; acceptance record
Monitor	6.6 monitoring and review; 6.7 recording and reporting	MEASURE 3–4; MANAGE 4	9(2)(c)	Telemetry re-rating; incident links; review log

The loop on the five layers

The loop does not add a layer. It gives each existing layer a risk job, and each job leaves an evidence record that the layer above can read.

Layer	Its risk job	Risk artefact	Evidence record
01 Govern-as-Code	Holds appetite, tolerance, scales and tier rules as data; blocks what exceeds them	<code>appetite.yaml</code> ; gate policy	Policy verdict that cites the risk id and band
02 Inventory & Transparency	Gives every risk an object: registry id, owner, tier, affected stakeholders	Registry entry; use-case risk profile; AIBOM	Registry record with tier and linked risk ids
03 Evals & Red Teaming as Evidence	Measures likelihood; finds risks nobody listed	Eval suites with thresholds set by tier; red-team findings	Eval result filed against the risk and the version
04 Runtime Controls & Observability	Treats at runtime; detects a risk becoming real	Guardrails; human-in-the-loop gates; scoped identity; kill switch	Guardrail events; approval logs; traces
05 Assurance & Continuous Compliance	Records, re-rates and reports; holds acceptances	Risk register as data; acceptance records; incident links	Register history; signed acceptances; review log

Evidence flows up, as everywhere in the stack. A residual rating is a claim that a control works; it is credible only if the control's id resolves to a policy verdict, eval result or guardrail event from the current review period. A residual rating whose control has no evidence is inherent risk with a better label.

The loop in the seven workflows

Each workflow of chapter 06 owns part of the loop; the system owner stays accountable for each risk end to end.

Workflow	Risk step	What it produces
Intake and classification	Identify	Use-case risk profile; tier; first register entries; stakeholder map
Inventory and registry	Identify	Registry id, owner and tier for every risk; unregistered systems as unassessed risk
Evals and red teaming as evidence	Assess	Likelihood evidence; new risks from red-team findings
Policy-as-code and gates	Treat	Appetite compiled into gate rules; deploy denied on unaccepted residual risk
Runtime monitoring and incidents	Treat, monitor	Runtime controls; signals that re-rate risks; incident links
Assurance and audit evidence	Monitor	The register as evidence; acceptance and review records; reports
Regulatory translation	Identify, treat	Obligations as risk sources and as required treatments

NIST AI RMF and ISO/IEC 23894 on the stack

The NIST AI RMF 1.0 splits risk work into four functions, each broken into categories and subcategories. GOVERN applies across the whole process; MAP, MEASURE and MANAGE apply per system and per lifecycle stage [1]. Chapter 08 maps the functions to layers; the table below goes down to the 19 categories and the subcategories this chapter builds on (paraphrased; the ids are NIST's; the layer column is this book's illustrative reading). Chapter 22 walks [the 19 NIST AI RMF categories](#) in full.

Category	Subcategories this chapter uses	Layer	Artefact
GOVERN 1	1.3 level of risk activity set by risk tolerance; 1.5 review frequency; 1.6 inventory	1 · 2	Appetite data; tier rules; registry
GOVERN 2	2.1 roles and lines of communication; 2.3 executive leadership owns AI risk decisions	1 · 5	Acceptance-authority table; RACI
GOVERN 3	3.2 roles for human-AI configurations and oversight	1 · 4	Oversight design; approval-gate configuration
GOVERN 4	4.2 teams document risks and impacts; 4.3 testing, incident identification, information sharing	3 · 5	Register; incident pipeline
GOVERN 5	5.1 feedback from people outside the team; 5.2 adjudicated feedback into design	2	Stakeholder map; feedback channel
GOVERN 6	6.1 third-party policies; 6.2 contingency for failures in high-risk third-party systems	2 · 5	Due-diligence gate; AIBOM
MAP 1	1.1 intended purpose and context; 1.5 risk tolerances determined and documented	1 · 2	Use-case risk profile; appetite data
MAP 2	2.1 task and method; 2.2 knowledge limits and human oversight	2	Tier; model card
MAP 3	3.2 costs of errors against risk tolerance; 3.5 human oversight processes	2 · 3	Benefit and cost note; benchmark results
MAP 4	4.1 component and legal risks; 4.2 internal controls per component	2	AIBOM-linked risks
MAP 5	5.1 likelihood and magnitude of each impact; 5.2 regular engagement	2 · 3	Matrix ratings; stakeholder log
MEASURE 1	1.1 most significant risks measured first, unmeasured ones documented; 1.3 independent assessors	3	Eval plan per risk
MEASURE 2	2.6 residual negative risk within tolerance, fails safely; 2.7 security; 2.11 fairness	3	Eval results; red-team findings
MEASURE 3	3.1 existing, unanticipated and emergent risks; 3.3 user feedback and appeal	4 · 5	Telemetry re-rating; feedback channel
MEASURE 4	4.3 improvements or declines from field data	3 · 5	Suite coverage review
MANAGE 1	1.1 go or no-go; 1.2 prioritise by impact, likelihood, resources; 1.3 mitigate, transfer, avoid or accept; 1.4 residual risks documented	1 · 5	Gate decision; register treatment; acceptance record
MANAGE 2	2.1 non-AI alternatives weighed; 2.3 response to a previously unknown risk; 2.4 supersede, disengage or deactivate	4	Substitution record; kill switch
MANAGE 3	3.1 third-party risks monitored; 3.2 pre-trained models monitored	2 · 4	Vendor re-assessment; drift monitoring
MANAGE 4	4.1 post-deployment monitoring plans; 4.3 incidents communicated	4 · 5	Monitoring plan; incident pipeline

The AI RMF also offers **profiles**: a current profile of how risk is managed today, a target profile of the outcomes wanted, and the gap between them as the action plan [1]. The tailoring matrix later in this chapter makes the same move.

ISO 31000, ISO/IEC 23894 and ISO/IEC 42001

Three ISO documents, three jobs. ISO 31000 is generic guidance for any risk [5]; ISO/IEC 23894 applies it to AI [6]; ISO/IEC 42001 is the certifiable management-system standard, whose clauses on AI risk assessment (6.1.2), AI risk treatment (6.1.3) and AI system impact assessment (6.1.4), and their operation (8.2 to 8.4), require the loop to exist and run [13]. NIST's crosswalk shows that its functions and the 23894 clauses describe one process [7].

AI RMF function	ISO/IEC 23894 clauses in NIST's crosswalk	Layer
GOVERN	5.2 leadership and commitment; 5.3 integration; 5.4 design (5.4.1 to 5.4.5: context, commitment, roles, resources, communication)	1 · 2
MAP	5.4.1 context; 6.3.2 to 6.3.4 scope, context and risk criteria; 6.4.2 identification (6.4.2.3 risk sources, 6.4.2.4 events and outcomes, 6.4.2.6 consequences); 6.4.3 analysis; 5.7 improvement; 6.7	2 · 3
MEASURE	6.3.4 risk criteria; 6.4.2.5 identification of controls; 6.4.3.2 consequences; 6.4.3.3 likelihood; 6.6 monitoring and review; 6.7	3

AI RMF function	ISO/IEC 23894 clauses in NIST's crosswalk	Layer
MANAGE	5.5 implementation; 5.7 improvement; 6.5 treatment (6.5.2 options, 6.5.3 plans); 6.6; 6.7	4 · 5

NIST's crosswalk was a January 2023 draft for comment, mapped against the final draft of 23894 [7]; check the clause numbers against the published 2023 text before citing them in an audit (verify).

Note A crosswalk is an index, not a control (see the [Framework Crosswalk](#) pattern). The row that counts is the one whose artefact exists and emits evidence.

Identifying risk: sources, factors and stakeholders

Identification is where risk work fails quietly: a register written in a workshop lists what the room thought of, and the rest stays invisible until an incident names it. Engineering it means a systematic list of sources, contributing factors captured as data, stakeholders mapped rather than assumed, and an intake path no system can skip on its way to production.

Internal and external risk sources

An **internal** source sits inside the organisation's control: data, design choices, people, processes. An **external** source arises outside it: suppliers, adversaries, users, the operating context, regulators, society. The split predicts the treatment. Internal sources can often be eliminated or substituted by design; external ones mostly have to be engineered against and monitored.

Source	Internal or external	Typical risks	Identified by (artefact, layer)
Training, fine-tuning and retrieval data	Internal (external when bought)	Bias; personal-data leakage; poisoned corpus; stale knowledge	Data card, lineage (2); data tests (3)
Model choice and configuration	Internal	Capability beyond need; opacity; confabulation	Model card (2); capability evals (3)
System design: prompts, tools, autonomy	Internal	Tool misuse; excessive agency; goal hijack	Registry scope (2); threat model; red team (3)
People and process	Internal	Automation bias; unowned systems; change without review	Oversight metrics (4); registry ownership (2)
Organisational incentives	Internal	Thresholds tuned to ship; gates routed around	Gate-bypass rate (1); audit (5)
Third-party models, APIs and components	External	Silent model updates; undisclosed training data; outage	Due-diligence gate, AIBOM (2); boundary evals (3)
Adversaries	External	Prompt injection; data exfiltration; model extraction	Red-team suite (3); guardrails (4)
Users and reasonably foreseeable misuse	External	Use outside the intended purpose; over-reliance	Intended-purpose record (2); misuse evals (3)
Operating context	External	Data drift; new populations; seasonal shifts	Drift telemetry (4)
Law and regulators	External	New obligation; moved date; enforcement priority	Regulatory translation (1); crosswalk
Affected people and society	External	Rights impact; discrimination; loss of trust	FRIA or DPIA (1 · 2); stakeholder map

Two rows carry a legal note. The AI Act's **reasonably foreseeable misuse** is use outside the intended purpose that "may result from reasonably foreseeable human behaviour or interaction with other systems, including other AI systems" [3]: misuse by users and by other agents is in scope, not an excuse. And NIST warns that third-party risk comes both from the component and from how it is used, and that developer and deployer metrics may not match [1]. Chapter 14 turns foreseeable misuse into design inputs ([reasonably foreseeable misuse](#)). Catalogues find gaps; they are not a register. NIST AI 600-1 names 12 risks unique to or made worse by generative AI and suggests grouping them as technical or model, misuse by humans, and ecosystem or societal [14]. The OWASP Top 10 for Agentic Applications covers agent threats such as goal hijack, tool misuse and privilege abuse [15]. The MIT AI Risk Repository consolidates 1,725 risks from 74 frameworks and finds that human decisions cause nearly as many AI risks (38%) as AI systems themselves (42%) [16]: a register that lists only model failure modes misses a large share of what goes wrong.

Contributing factors and the use-case risk profile

A **contributing factor** does not create a risk on its own; it moves likelihood, severity or both. NIST gives higher initial priority where training data is sensitive or personal or outputs affect people directly, and counts deployer customisation as a factor [1]. Article 9 asks providers to consider people under 18 and other vulnerable groups [8]. Capture factors as registry fields at [intake](#) and let a policy compute the tier.

Factor	Moves	Profile field
Autonomy: suggests, drafts, acts after review, acts alone	Likelihood and severity	autonomy
Decision impact: none, informs, decides about a person	Severity	decision_impact
Exposure: internal users, customers, the public; daily volume	Likelihood	exposure , volume_per_day
Reversibility of the worst outcome	Severity	reversibility
Vulnerable groups affected: minors, patients, applicants	Severity	vulnerable_groups
Data sensitivity: personal, special category, confidential	Severity	data_class
Opacity and novelty of the technique	Likelihood, and confidence in the rating	explainability , novel_technique
Third-party dependency	Likelihood	supplier_ids
Deployer customisation (for providers)	Likelihood	customisation

The tier is computed, not negotiated. A system owner who disagrees with the tier changes a factor with evidence, in a reviewed pull request, and the tier follows.

Example (illustrative) HR proposes a CV-screening assistant. Its profile reads `decision_impact: decides-about-person , exposure: public-applicants , autonomy: filters , a recruiter sees only the shortlist , data_class: personal`. The tier rule places it in tier 3 before any meeting. The gate then asks for fairness and robustness evals, a DPIA link and a signed acceptance for any residual risk above Low. Whether it is also a high-risk system under the AI Act is a separate question for the Annex III route (chapter 08).

Stakeholder mapping

Different actors see different risks. A developer releasing a pre-trained model can have a different risk perspective from the deployer using it, and the people harmed are not always direct users [1]. The AI RMF builds this into GOVERN 5.1, MAP 1.2 and MEASURE 1.3, which asks that affected communities be consulted as risk tolerance requires [1]. For deployers of certain high-risk systems the FRIA makes it law: it names the categories of people likely to be affected and the specific risks of harm to them [17]. ISO calls the same step "communicate and consult" [5].

Stakeholder	How their view enters the loop	Evidence
Direct users (operators, customers)	Usability tests; in-product feedback	Feedback items linked to risk ids
Affected non-users (applicants, patients, the public)	Consultation; FRIA; complaints	FRIA record; complaint links
Downstream deployers (for providers)	Instructions for use; deployer reports	Deployer-reported issues
Upstream providers (for deployers)	Due diligence; change notices	Supplier evidence in the AIBOM
Internal functions (legal, privacy, security, risk, audit)	Review at intake; second-line challenge	Review records
Regulators and authorities	Obligations mapped; reporting paths	Crosswalk; incident pipeline
Executives and the governing body	Appetite statement; risk reports	Approved appetite; acceptances

The output is not a poster. It is a stakeholder list on the registry entry, an `affected` field on every register risk, and a log of who was consulted, when and with what result.

Assessing risk: the likelihood-by-severity matrix

A risk matrix turns two judgements into a band that triggers a response. Its value is consistency, not precision: two assessors rating one scenario should land in the same cell, and the cell should decide the same gate every time. IEC 31010:2019 catalogues other risk assessment techniques for when a matrix is not enough [18].

Defined scales

Without shared definitions, assessors can give opposite ratings to the same risk [19]. Anchor likelihood to evidence you can read (eval failure rates, telemetry, incidents) and severity to the worst credible consequence of one occurrence. The thresholds are illustrative; calibrate them to your volumes.

Level	Likelihood	Definition (per system, in production)	Evidence that sets it
L1	Rare	Not expected in the system's life	A targeted red team cannot reproduce it
L2	Unlikely	Could occur about once a year	Reproduced only by a dedicated adversarial suite
L3	Possible	Expected a few times a year	Regression or red-team failure rate below 1%

Level	Likelihood	Definition (per system, in production)	Evidence that sets it
L4	Likely	Expected monthly	Failure rate of 1% to 5%, or near misses in telemetry
L5	Almost certain	Expected weekly or more	Failure rate above 5%, or already seen in production

Level	Severity	Worst credible consequence of one occurrence
S1	Negligible	Inconvenience; fully reversible; nobody's rights affected
S2	Minor	Limited, reversible harm to a few people or a small loss; fixed within a day
S3	Moderate	Material harm to individuals (a wrongful denial, one person's data exposed); reversible with effort
S4	Major	Significant harm to many people or to fundamental rights; hard to reverse
S5	Catastrophic	Death or serious harm to health; serious and irreversible disruption of critical infrastructure; serious harm to property or the environment; widespread infringement of fundamental rights

S4 and S5 together cover the four categories of a **serious incident** under the AI Act [3], so a risk rated there is a candidate reportable incident the day it materialises. The [harms atlas](#) gives a harm taxonomy by level, with real incident records, to calibrate the severity column against.

The matrix and what each band triggers

Severity / likelihood	L1 Rare	L2 Unlikely	L3 Possible	L4 Likely	L5 Almost certain
S5 Catastrophic	Critical (override)	Critical (override)	Critical (override)	Critical (override)	Critical (override)
S4 Major	Medium	High	High	Critical	Critical
S3 Moderate	Low	Medium	High	High	Critical
S2 Minor	Low	Low	Medium	Medium	High
S1 Negligible	Low	Low	Low	Medium	Medium

A band is useful only if it changes what the pipeline does. The policy later in this chapter compiles these illustrative consequences.

Band	Minimum treatment	Gate	Who may accept the residual	Review
Low	Monitor	Registry entry and owner	System owner	Annually or on change
Medium	At least one engineered control with evidence	Eval gate on the linked risk	Product owner	Every six months
High	Engineered controls plus runtime detection; a person decides where consequences reach a person	Eval gate and runtime guardrail; deploy denied without a current acceptance	Risk committee, second line consulted	Quarterly
Critical	Eliminate or substitute; engineering alone does not ship it	Deploy denied	Governing body, or no one	Monthly while open

The catastrophic-severity override

Multiplying likelihood by severity hides the tail. A grid can give a rare catastrophe the band of a frequent nuisance, and where frequency and severity are negatively correlated (the shape of catastrophic risk) matrices can be "worse than useless" [19]. So S5 runs on its own track:

1. **The band ignores likelihood.** Any S5 scenario is Critical. Its likelihood is recorded, because it guides monitoring, but it does not lower the band.
2. **The team cannot accept it.** Treatment must eliminate the scenario or cut its severity, usually by removing a capability, an action or an exposure. Otherwise only the governing body may accept it, explicitly and for a fixed period.
3. **Present harm means stop.** Where significant negative impacts are imminent, severe harms are occurring or catastrophic risks are present, NIST says development and deployment "should cease in a safe manner until risks can be sufficiently managed" [1]. The tested kill switch is the mechanism.
4. **The frontier uses the same logic.** Under the GPAI Code of Practice, signatories define systemic risk tiers (or other acceptance criteria), apply them with safety margins and, if systemic risk is not acceptable, do not make the model available, or restrict, withdraw or recall it [20].

Most controls cut likelihood; only a design change cuts severity. The override forces that design conversation instead of letting likelihood controls talk a catastrophe down to Medium.

What a matrix cannot tell you

Cox names four limits: poor resolution, rating errors, no basis for allocating resources, and ambiguous inputs and outputs [19]. The answers are procedural:

- **Keep the numbers behind the cell** (eval failure rate, volume, worst-case estimate) so the band can be recomputed. The cell is a view of the data, not the data.
- **Never sum or average cells.** Prioritise by band, then severity, then cost of treatment; MANAGE 1.2 prioritises by impact, likelihood and available resources [1].
- **Read eval-based likelihood as a lower bound.** An eval is sampling-bound and catches regressions, not novelty ([the limits of the eval gate](#)).

For high-risk systems the law points the same way: testing runs against "prior defined metrics and probabilistic thresholds" appropriate to the intended purpose [8]. A likelihood scale written as thresholds a pipeline can check is exactly that.

Risk appetite and tolerance, compiled into gates

NIST does not prescribe a risk tolerance. It defines tolerance as the "readiness to bear the risk in order to achieve its objectives", calls it contextual and changing, tells organisations to follow sector rules or define a reasonable tolerance where none exist, and asks that tolerances be documented (MAP 1.5) and set the level of risk-management effort (GOVERN 1.3) [1]. An appetite statement that lives only in a board pack changes nothing a pipeline does. Compile it.

From statement to data

Example (illustrative) An appetite statement as a governing body might approve it: "We use AI to make staff and customers faster. We accept moderate risk in internal tools and in decision support where a person reviews each output, so that we learn quickly. We accept only low residual risk in systems that decide about a person or act on their behalf. No agent moves money above a set amount without a person's decision. We carry catastrophic risk only with the governing body's explicit acceptance, for a fixed period. No risk is accepted indefinitely."

Each sentence becomes a value in a versioned file that gates read. The file is the enforced version; the statement is its documentation.

```
# appetite.yaml (illustrative, not a claim of conformity)
version: 2026-09-24
approved_by: governing-body
tolerance:                # highest residual band carried without escalation
  tier-1-internal: medium
  tier-2-decision-support: medium
  tier-3-decision-about-a-person: low
  tier-4-agentic-or-high-stakes: low
acceptance_authority:      # who may sign each residual band
  low: system-owner
  medium: product-owner
  high: risk-committee
  critical: governing-body
max_acceptance_days: {low: 365, medium: 180, high: 90, critical: 30}
eval_floor:               # likelihood evidence required per tier
  tier-3-decision-about-a-person: {robustness: 0.95, subgroup_parity: 0.90}
  tier-4-agentic-or-high-stakes: {injection_resistance: 0.95, tool_scope_adherence: 0.99}
human_approval_above_eur: 250 # enforced at runtime by the approval gate
catastrophic_override: true # severity 5: eliminate, or governing-body acceptance
```

Statement clause	Compiled into	Layer	Evidence
"moderate risk in internal tools and in decision support"	tolerance for tiers 1 and 2: medium	01	Gate verdict
"only low residual risk in systems that decide about a person or act on their behalf"	tolerance for tiers 3 and 4: low; eval_floor	01 · 03	Gate verdict; eval result
"No agent moves money above a set amount without a person's decision"	human_approval_above_eur	04	Approval log
"catastrophic risk only with the governing body's explicit acceptance"	Override rule; critical: governing-body	01 · 05	Signed acceptance
"No risk is accepted indefinitely"	max_acceptance_days	05	Acceptance expiry

From data to a gate

The gate runs at deploy (layer 01) over the registry entry (layer 02), the system's open risks (layer 05) and its latest eval results (layer 03). Its verdict names the risk id, so the evidence says which risk stopped which release.

```

package risk.gate

import rego.v1

# Illustrative, not a claim of conformity. data.appetite is appetite.yaml;
# input holds the registry entry, the system's open risks and its eval results.

rank := {"low": 1, "medium": 2, "high": 3, "critical": 4}

tier := input.system.tier

deny contains "system has no known tier in the registry" if {
    not data.appetite.tolerance[tier]
}

# Residual above the tier's tolerance needs a current acceptance by the
# authority that the residual band requires.
deny contains msg if {
    some r in input.risks
    rank[r.residual.band] > rank[data.appetite.tolerance[tier]]
    not valid_acceptance(r, data.appetite.acceptance_authority[r.residual.band])
    msg := sprintf("%s: residual %s above %s tolerance, no valid acceptance", [r.id, r.residual.band, tier])
}

# Catastrophic-severity override: likelihood plays no part.
deny contains msg if {
    some r in input.risks
    r.residual.severity == 5
    not valid_acceptance(r, "governing-body")
    msg := sprintf("%s: severity 5 needs elimination or governing-body acceptance", [r.id])
}

# Eval floors by tier: missing evidence fails like bad evidence.
deny contains msg if {
    some metric, floor in data.appetite.eval_floor[tier]
    not input.evals[metric] >= floor
    msg := sprintf("%s: eval %s below the %s floor", [input.system.id, metric, tier])
}

valid_acceptance(r, role) if {
    r.acceptance.role == role
    time.parse_ns("2006-01-02", r.acceptance.expires) > time.now_ns()
}

```

Two details matter more than the syntax. A missing eval result fails like a low one, so "we did not measure it" is never a pass. An expired acceptance counts as none, so the calendar enforces review. Like every layer 01 policy it ships with a fixture that must be denied and one that must pass ([Layer 01](#)).

Treating risk: the mitigation hierarchy

NIST lists the response options as mitigating, transferring, avoiding or accepting [1]; the order in which you reach for them matters more. Occupational safety ranks controls by effectiveness (elimination, substitution, engineering, administrative, then protective equipment) and warns against relying on the last when better options exist [21]. The AI Act sets the same order for high-risk systems: eliminate or reduce risk through design as far as technically feasible, then mitigation and control measures, then information and, where appropriate, training for deployers [8]. NIST adds that non-AI alternatives be weighed (MANAGE 2.1) [1].

Rung	What it means for AI	Stack control	Pattern	Evidence
1 Eliminate	Do not build it; remove the capability; refuse the use	Policy deny; prohibited-use blacklist; tool never granted	Policy Card	Deny verdict; absent scope in the registry
2 Substitute	Same goal, lower risk: a non-AI method, a simpler or interpretable model, retrieval over free generation, read-only instead of write	Design record; narrower registry scope	Agent Identity & Scoped Credentials	Design decision linked to the risk id

Rung	What it means for AI	Stack control	Pattern	Evidence
3 Engineer	Controls that act without relying on anyone remembering	Eval gate; runtime guardrail; approval gate; kill switch	Eval Gate in CI, Runtime Guardrail, Human-in-the-loop Gate, Kill Switch	Eval results; guardrail events; approval logs
4 Administrative	Rules for people: instructions for use, training, procedures, warnings	Instructions for use; literacy and training records	Model Card as Control Evidence	Training attestations; versioned instructions
5 Accept and monitor	Carry what is left, knowingly, and watch it	Signed acceptance; telemetry; review date	Continuous Assurance Telemetry	Acceptance record; monitoring signal

Elimination has a legal floor: practices the AI Act prohibits are eliminated, never treated or accepted [22]. **Transfer** (insurance, contractual indemnities) sits beside the ladder, not on it: it moves the financial consequence, not the harm to the person on the other end of the decision, so it never replaces rungs one to four where people can be harmed.

Four rules turn the ladder into practice:

- **Work top down, and write down why.** The register records which higher rungs were considered and why they were infeasible; a treatment that starts at rung four without that record fails review.
- **Engineered controls count only with evidence.** A guardrail never fired in a test, or a kill switch never exercised, is rung four at best.
- **Administrative controls alone do not move a High band.** Reviewers tend to confirm confident machine output; oversight has to be designed and measured ([designing human oversight](#)).
- **Every rung leaves a residual.** The ladder ends in acceptance, never in "resolved".

In practice (illustrative) The first design of `csa-01`, the customer-service assistant of chapter 04, gave it a tool that issued refunds. Intake rated the scenario "an injected instruction makes the agent refund the wrong amount or account" at L4 and S3: High. The team walked the ladder. Eliminating refunds would remove the use case. Substituting a read-only scope, with the agent drafting a refund that a person issues, cut the path to the event. Engineered controls (an injection guardrail, an injection-resistance eval gate, the approval step) cut likelihood further. The residual came out at L2 and S3, Medium, accepted by the product owner for six months, void if the eval score fell below its floor. The read-only refund scope in the chapter 04 registry entry is that decision, as data.

Inherent risk, residual risk and who accepts it

Inherent risk is the rating before any control is counted. **Residual risk** is the "risk remaining after risk treatment", in the ISO-derived definition NIST adopts [1]. The gap between them is the value claimed for the controls; a large gap resting on one control is a single point of failure that deserves its own test.

Three texts make residual risk a first-class output. Article 9 requires that "the relevant residual risk associated with each hazard, as well as the overall residual risk" be judged acceptable [8]. MEASURE 2.6 asks that residual negative risk stay within tolerance and the system fail safely, and MANAGE 1.4 that residual risks to downstream acquirers and end users be documented [1]. So a residual rating is also a transparency artefact: it belongs in the model card's limitations and the instructions for use, not only in the register.

One rule keeps it honest: **a residual rating credits only controls whose ids resolve to evidence from the current review period.** If the eval has not run since the model changed, the residual reverts towards the inherent rating until it does.

Who may accept

Acceptance is a decision with a name on it. The Institute of Internal Auditors' Three Lines Model gives a common division of labour: the first line provides the product and manages its risk; the second line provides expertise, support, monitoring and challenge on risk; internal audit provides independent assurance; the governing body sets direction [23]. The AI RMF adds that executive leadership takes responsibility for decisions about AI risk (GOVERN 2.3) [1]. [Chapter 12](#) covers committees and decision rights; the table below is the part a gate can enforce.

Residual band	Accepts	Consulted (challenge)	Maximum period	Record
Low	System owner	None required	12 months	Register entry
Medium	Product owner	Second-line risk	Six months	Signed acceptance with a voiding condition
High	Risk committee	Second line; legal and privacy where rights are involved	Three months	Signed acceptance with rationale and conditions

Residual band	Accepts	Consulted (challenge)	Maximum period	Record
Critical or S5	Governing body, or no one	Second line; independent review	One month, renewed only with new evidence	Minute of the decision linked to the risk id

An acceptance record carries the person and role, the rationale, the conditions that void it (a monitoring signal and its threshold), the date and the expiry. Every residual is accepted by the authority its band names; the gate blocks only when the band is above the tier's tolerance and no valid acceptance exists. Above Medium, the acceptor should sit at least one level above the team whose delivery date depends on the answer.

Anti-pattern "Accepted" as a status with no name, no date and no expiry. The register fills with risks nobody chose to carry, and the first incident reveals that the acceptance was a spreadsheet default.

The risk register as an evidence record

Chapter 08 names a "risk register as code" as the artefact behind [Art. 9](#) and ISO/IEC 23894; this section defines it. The register is the layer 05 evidence record of the whole loop: one versioned file per risk, keyed to a registry id, every control reference resolving to an artefact that emits evidence, every change reviewed like code. It answers Article 9's "documented" and is where an auditor starts. Its closest standard shape is the plan of action and milestones ([POA&M](#)) in OSCAL's assessment layer [24], into which a register can export its open treatments. A JSON Schema for [a risk register entry](#), with a filled example, is on the templates page.

Register schema

```
# risk-register/csa-01/R-017.yaml (illustrative, not a claim of conformity)
id: R-017
system: csa-01 # registry id (layer 02)
title: Injected instruction leads to a wrong refund
scenario:
  cause: instruction hidden in a customer message reaches the refund workflow
  event: a refund is proposed and issued for the wrong amount or account
  consequence: financial loss; customer harm; possible fraud report
source: {origin: external, category: adversary}
affected: [customers, finance-operations]
factors: {autonomy: drafts, exposure: public, reversibility: partial}
inherent: {likelihood: 4, severity: 3, band: high}
treatment:
  option: mitigate
  rung: substitute+engineer
  higher_rungs_considered: "eliminate rejected (refunds are the use case); substitute adopted (read-only scope)"
  controls:
    - scope.refunds.read-only # registry scope (layer 02)
    - guardrail.input.injection.v3 # runtime guardrail (layer 04)
    - eval.injection-resistance.v4 # eval gate (layer 03)
    - approval.refund-issue # human decision (layer 04)
residual: {likelihood: 2, severity: 3, band: medium}
owner: team-support-platform
acceptance:
  by: head-of-support-products
  role: product-owner
  date: 2026-09-18
  expires: 2027-03-17
  voided_if: "injection-resistance below 0.95, or approval override rate above 2%"
review: {cadence: semiannual, last: 2026-09-18, next: 2027-03-17}
rerate_on: [model-version-change, new-tool-grant, linked-incident, eval-regression]
links:
  evals: [injection-resistance.v4@csa-01@2026-09-18]
  incidents: []
  obligations: ["ISO/IEC 42001 6.1.3", "NIST AI RMF MANAGE 1.3"]
status: open
```

Three fields do what a spreadsheet cannot. `treatment.controls` resolves to artefacts that emit evidence, `treatment.higher_rungs_considered` proves the hierarchy was applied, and `acceptance.voided_if` lets telemetry end an acceptance without waiting for a meeting.

Operating the register

- **Cadence by band, triggers by event.** The band table sets the calendar; `rerate_on` overrides it, forcing a re-rating before the next release.
- **Changes arrive as pull requests,** with the evidence in the diff, a second-line reviewer for High and above, and an append-only history.
- **The gate reads it,** so an unaccepted residual above tolerance blocks the release with the risk id in the verdict.
- **Links run both ways.** An eval failure opens or re-rates a risk; an incident links to its risk, and the risk lists its evals and incidents.
- **Measure the register, not its size:** open High and Critical residuals, expired acceptances, time from identifying a risk to a control in a gate, and the share of residual ratings backed by fresh evidence ([metrics per level](#)).

In practice (illustrative) A governance function moved its register from a spreadsheet into the repository that holds its policies, one file per risk keyed to registry ids, and pointed the deploy gate at it. The first run blocked two releases for the same reason: accepted risks with no named acceptor and no expiry. Nobody had decided to carry them; the spreadsheet had. Within a quarter every open High risk had either a signed, expiring acceptance or a control whose evidence the gate could read.

Proportionate governance: tailoring the loop

The loop is the same everywhere; its intensity is not. The AI RMF sets the level of risk activity by risk tolerance (GOVERN 1.3) [1]. The EU AI Act has required since 2024 that a high-risk provider's quality management system be proportionate to the size of its organisation, while providers "respect the degree of rigour and the level of protection required" [27]. The Digital Omnibus adds "in particular, if the provider is an SME, including a start-up, or an SMC", and opens the simplified technical-documentation form, until then limited to SMEs and start-ups, to small mid-cap enterprises [9]. US banking supervisors now tailor model risk management to profile, size and complexity [2]. Proportionality lowers the cost of the loop, never the protection owed to the people on the other end.

The tailoring matrix

Six factors set the intensity. For each, the matrix gives minimum controls, gates and review intensity. Read each row as a floor; where two rows apply, the stricter wins.

Factor	Profile	Minimum controls	Gates	Review intensity
Size	Team of one, start-up or SME	Register in the repo; appetite as one data file; published scales	Deny unregistered systems and open Criticals	On change; appetite yearly
	Mid-size, several product teams	Register keyed to the registry; acceptance authorities; stakeholder maps from tier 3	Band against tier tolerance; eval gate from tier 2	Quarterly; second-line challenge for High
	Federated enterprise	Central appetite, local tolerances; register rolled up into enterprise risk	Local gates inherit a shared policy library	Monthly committee for High and Critical; audit sampling
Sector	General commercial	The rows below, nothing extra	As tiered	As tiered
	Regulated (finance, health, critical infrastructure, public sector)	Sector overlay fields (below); independent validation for tiers 3 and 4	Sector evidence before deploy	As the regime expects, never less than tiered
Maturity (chapter 07)	Level 1 to 2	Register exists and is keyed to registry ids	Deny unregistered systems	Calendar reviews
	Level 3	Eval results populate likelihood	Risk report in CI, non-blocking	Review at each release
	Level 4 to 5	Bands compiled into gates; telemetry re-rates	Deny on unaccepted residual; acceptances void themselves	Event-driven plus calendar
Products and services	Tier 1: internal tool	Registry entry, owner, acceptable-use rules	Registry gate	Yearly
	Tier 2: decision support, a person reviews each output	Plus capability and misuse evals; oversight metrics	Eval gate	Every six months
	Tier 3: automated decision about a person	Plus fairness and robustness evals; FRIA or DPIA where required; a contest channel	Eval gate; no deploy without acceptance at High	Quarterly

Factor	Profile	Minimum controls	Gates	Review intensity
	Tier 4: agentic with write access, or real-time high stakes	Plus approval gates; scoped identity; tested kill switch; runtime guardrails	Plus runtime enforcement	Monthly and event-driven
Objectives	Innovation-led	Sandboxed tiers 1 and 2 with wider tolerance; floor unchanged	Sandbox gates apart from production	Frequent, light
	Risk-averse	Lower tolerances; acceptance one level higher	Higher eval floors	Heavier, less frequent
	Mission-driven (public service, health)	Affected-group consultation from tier 3	Impact-assessment gate	Includes affected-group input
Risk tolerance	Low	Tolerance low from tier 2; higher eval floors	Deny more, accept higher up	Shorter acceptance periods
	Higher	Tolerance medium for tiers 1 and 2	As tiered	As tiered; the S5 override unchanged

A team of one should not try to run all of this: start from the thin vertical slice of chapter 04 ([the minimum viable stack](#)) plus the register and one gate, and add rows as the organisation and its exposure grow.

Sector overlays

NIST tells organisations to follow the risk criteria, tolerances and responses their sector already sets [1]. An overlay adds register fields and gates, not a second register.

Sector	Existing regime to integrate with	What it adds to the loop
Banking and finance	Model risk management guidance; in the US, SR 26-2 (17 Apr 2026), which superseded SR 11-7 and is most relevant to banking organisations above USD 30 billion in total assets [2]	Independent validation before use and a model inventory with risk ratings, as in the model-risk tradition; intensity tailored to size and complexity
Medical devices and health	ISO 14971:2019, risk management for medical devices [25]; the AI Act's Annex I route, with high-risk duties for embedded systems from 2 Aug 2028 [10]	Hazard-based register; benefit-risk evaluation; post-market surveillance feeding re-rating
Industrial and safety-critical	Functional-safety practice; ISO/IEC TR 5469:2024 on AI inside safety-related functions and non-AI functions that keep AI-controlled equipment safe [26]	Safety requirements per function; non-AI safety functions as rung-three controls
Public sector	FRIA duty when bodies governed by public law, or private entities providing public services, deploy high-risk systems [17]	Mandatory affected-group mapping; complaint mechanisms and internal governance arrangements as treatments

The floor that does not tailor away

Some controls are the same at every size, in every sector and at every maturity level:

- Every AI system in production has a registry entry, an owner and a tier.
- Prohibited practices are eliminated, never treated or accepted [22].
- Every S5 scenario runs the catastrophic-severity override.
- Every accepted risk has a named acceptor, a voiding condition and an expiry.
- Every incident links to a risk, existing or new.
- Every agent that acts has its own identity and a tested kill switch.

Risk, maturity and incidents

Risk practice by maturity level

Risk practice is not a sixth row in the maturity model; it is a lens on all five layers, and the weakest-layer rule of chapter 07 applies to it too ([the five levels](#)).

Level	Risk practice you can show	Evidence
1 Documented	A register maintained by hand; an appetite statement; defined scales	The register file; approved scales
2 Inventoried	Every risk keyed to a registry id; unregistered systems flagged as unassessed risk	The join between register and registry; discovery report
3 Tested	Likelihood ratings cite eval results; red-team findings open new risks	Eval ids in register links

Level	Risk practice you can show	Evidence
4 Enforced	Tolerances compiled into gates; an expired acceptance blocks deploy	Gate verdicts that cite risk ids
5 Continuous	Telemetry re-rates risks; acceptances void themselves when their condition fails	Rating history driven by runtime signals

Incidents are realised risks

An incident is a risk that materialised, or one nobody identified. If it matches a register entry, it is likelihood evidence: the rating is recomputed and, if the voiding condition fired, the acceptance lapses. If it matches nothing, it opens a new entry, the AI RMF's response to a previously unknown risk (MANAGE 2.3) [1], and asks identification why intake missed it.

The severity scale connects the two. Because S4 and S5 cover the AI Act's serious-incident categories [3], an entry rated there already names the reporting path, and the [Incident Pipeline](#) can start the [Art. 73](#) clock from the risk id (deadlines in [chapter 08](#)). Article 9 closes the loop from the other side: risks emerging from post-market monitoring data are evaluated in the risk management system [8]. MANAGE 4.3 adds that incidents are communicated to relevant AI actors, including affected communities [1]. [Chapter 17](#) covers the incident lifecycle; this chapter owns the link.

Two measures show whether the link works. The **identification hit rate** is the share of incidents that matched a pre-existing risk; a low rate means intake misses sources. The **re-rating lag** is the time from an incident to the recomputed rating; a long lag means the register records the past.

Maps to: EU AI Act Art. 9 (risk management system), Art. 17(2) (proportionality), Art. 26, Art. 27 (FRIA), Art. 72, Art. 73 · ISO 31000 · ISO/IEC 23894 · ISO/IEC 42001 (6.1.2, 6.1.3, 8.2, 8.3) · NIST AI RMF (Govern, Map, Measure, Manage) · OWASP Agentic ASI01–ASI10 · all five layers of the stack. Mappings are illustrative, not a claim of conformity.

What you can do this week

- Publish the scales.** Write five-level likelihood and severity definitions for your context, with S5 aligned to the serious-incident categories and the catastrophic-severity override stated. One page, versioned beside your policies.
- Compile one line of appetite.** Put tolerance by tier into a data file and make one deploy gate read it: deny when a system carries an open Critical or an unaccepted residual above its tier.
- Key the register to the registry.** For your three highest-tier systems, move their top risks into files keyed to registry ids, each with inherent and residual ratings, controls that resolve to evidence, an owner and an expiry.
- Find the orphans.** List every accepted risk with no named acceptor or no expiry, and every incident of the last quarter with no linked risk. Both lists are next month's backlog.
- Map one system's stakeholders.** For the system with the widest exposure, name the affected non-users and write down how their view reaches the register.

Sources

[1] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (§1.1 risk; §1.2.2 risk tolerance; §1.2.3 prioritisation, "cease in a safe manner", residual risk; Core tables 1 to 4; §6 profiles). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [2] SR 26-2, Revised Guidance on Model Risk Management (Federal Reserve, OCC, FDIC; supersedes SR 11-7 and SR 21-8; tailored to risk profile, size and complexity; most relevant above USD 30 billion in assets). Board of Governors of the Federal Reserve System. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> (verified: primary) [3] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 3 (points 2 "risk", 13 "reasonably foreseeable misuse", 49 "serious incident"). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_3 (verified: primary) [4] ISO 31073:2022, Risk management: Vocabulary (replaced ISO Guide 73:2009, withdrawn). ISO/TC 262. 2022-02. <https://www.iso.org/standard/79637.html> (verified: primary) [5] ISO 31000:2018, Risk management: Guidelines (stage 90.92, to be revised; ISO/CD 31000 under development as of 2026-09-24). ISO/TC 262. 2018-02. <https://www.iso.org/standard/65694.html> (verified: primary) [6] ISO/IEC 23894:2023, Artificial intelligence: Guidance on risk management. ISO/IEC JTC 1/SC 42. 2023-02. <https://www.iso.org/standard/77304.html> (verified: primary) [7] Crosswalk: AI RMF (1.0) and ISO/IEC FDIS 23894 (draft for comment; function to clause mapping). NIST. 2023-01-26. https://www.nist.gov/system/files/documents/2023/01/26/crosswalk_AI_RMF_1_0_ISO_IEC_23894.pdf (verified: primary) [8] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 9 (risk management system; 9(2) steps; 9(5) residual risk and order of measures; 9(8) "prior defined metrics and probabilistic thresholds"; 9(9) minors and vulnerable groups). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_9 (verified: primary) [9] Regulation (EU) 2026/1744, Digital Omnibus on AI (Art. 9 not amended; Art. 1 point (10): Art. 11(1) simplified technical-documentation form extended to SMCs; Art. 1 point (11): Art. 17(2) replaced to name SMEs, start-ups and SMCs). Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [10] "AI Omnibus enters into force" (Annex III high-risk → 2 Dec 2027; Annex I → 2 Aug 2028). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force> (verified: primary) [11] Risk management in the Artificial Intelligence Act (J. Schuett; Art. 9 of the 2021 proposal; Eur. J. Risk Regul. 15 (2024) 367-385). arXiv 2212.03109. 2024.

<https://arxiv.org/abs/2212.03109> (verified: primary) [12] CEN-CENELEC JTC 21 standards tracker (no harmonised standard cited in the OJ). CEN-CENELEC JTC 21 (via kla.digital). 2026. <https://kla.digital/blog/jtc-21-standards-tracker> (verified: secondary) [13] ISO/IEC 42001:2023, Artificial intelligence: Management system (6.1.2 AI risk assessment, 6.1.3 AI risk treatment, 6.1.4 AI system impact assessment; 8.2 to 8.4). ISO/IEC JTC 1/SC 42. 2023-12. <https://www.iso.org/standard/81230.html> (verified: secondary) [14] Generative Artificial Intelligence Profile, NIST AI 600-1 (12 GAI risks; grouping in footnote 5). NIST. 2024-07. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf> (verified: primary) [15] Top 10 for Agentic Applications 2026 (ASI01 to ASI10). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [16] The AI Risk Repository (v3; 74 frameworks, 1,725 risks; human decisions 38%, AI systems 42%) (arXiv 2408.12622). P. Slattery et al., MIT. 2026-05-05. <https://arxiv.org/abs/2408.12622> (verified: primary) [17] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 27 (FRIA: who performs it; elements (a) to (f)). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_27 (verified: primary) [18] IEC 31010:2019, Risk management: Risk assessment techniques. IEC / ISO/TC 262. 2019-06. <https://www.iso.org/standard/72140.html> (verified: primary) [19] What's Wrong with Risk Matrices? (L. A. Cox Jr.; Risk Analysis 28(2) 497-512). Wiley. 2008-04. <https://doi.org/10.1111/j.1539-6924.2008.01030.x> (verified: primary) [20] GPAI Code of Practice, Safety and Security chapter, Commitment 4 (systemic risk acceptance determination; Measure 4.2). code-of-practice.ai. 2025-07-10. <https://code-of-practice.ai/?section=safety-security> (verified: secondary) [21] Hierarchy of Controls. CDC / NIOSH. 2024-04-10. <https://www.cdc.gov/niosh/hierarchy-of-controls/about/index.html> (verified: primary) [22] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 5 (prohibited AI practices, as amended by the Digital Omnibus, Reg. (EU) 2026/1744). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_5 (verified: primary) [23] The IIA's Three Lines Model: an update of the Three Lines of Defense. The Institute of Internal Auditors. 2020-09-08. <https://www.theiia.org/en/content/position-papers/2020/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense/> (verified: primary) [24] OSCAL native model (assessment layer incl. POA&M). NIST. 2026. <https://pages.nist.gov/OSCAL/learn/concepts/layer/> (verified: primary) [25] ISO 14971:2019, Medical devices: Application of risk management to medical devices. ISO/TC 210. 2019-12. <https://www.iso.org/standard/72704.html> (verified: primary) [26] ISO/IEC TR 5469:2024, Artificial intelligence: Functional safety and AI systems. ISO/IEC JTC 1/SC 42. 2024-01. <https://www.iso.org/standard/81283.html> (verified: primary) [27] Regulation (EU) 2024/1689 (AI Act), text as published in the Official Journal (OJ L, 12.7.2024), Art. 17(2) (quality management system proportionate to the size of the provider's organisation; providers "shall, in any event, respect the degree of rigour and the level of protection required"). Publications Office of the EU (EUR-Lex). 2024-06-13. https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng#art_17 (verified: primary)

14. Governing AI development

AI development is governed when every decision in the build, from the use case to the release, leaves a record that a gate reads, so the pipeline compiles the technical file instead of a team writing it afterwards.

The build as a chain of gates

Most governance failures in an AI system are decided before it serves its first request. The use case was never written down, so nobody can say what the system is for. The training set was scraped under terms nobody checked. The test set leaked into training. The release went out because the date was fixed. Each of these is a development decision, and each leaves behind either a record or a gap.

This chapter covers the provider side of the lifecycle: the organisation that designs, trains, tests and releases an AI system or model. [Chapter 15](#) covers deployment and use. The split follows the EU AI Act's duty holders (see the [regulatory map](#)): most of what follows binds the provider, and a deployer that builds on a procured model inherits a thinner version of it through the **Vendor / Model Due-Diligence Gate**.

The reference texts agree on the stages and say little about the mechanism. ISO/IEC 5338:2023 defines AI system life cycle processes [1]; ISO/IEC 42001 groups the controls under Annex A.6 (life cycle) and A.7 (data) [2]; the NIST AI RMF puts context in Map and testing in Measure [3]; the EU AI Act's quality management system asks for design control, design verification and "examination, test and validation procedures to be carried out before, during and after the development" [4]. The engineering reading: every stage ends in a gate, every gate reads a structured record, and every record lands in the evidence store keyed to the registry id, the data path of [one system through the five layers](#).

Layer numbers in the tables of this chapter follow chapter 04: **1 Govern-as-Code · 2 Inventory & Transparency · 3 Evals & Red Teaming as Evidence · 4 Runtime Controls & Observability · 5 Assurance & Continuous Compliance**.

Stage	Governance question	Record	Gate	Layer
Use case	Is this the right problem, and is AI the right tool?	Use-case record	Intake approval	1 · 2
Design review	Do the requirements, architecture and misuse analysis hold up?	Design record and decision log	Design review sign-off	1 · 2
Data	May we use this data, and is it fit for the purpose?	Dataset admission record, datasheet, lineage	Dataset admission gate	1 · 2 · 3
Testing	Does the system meet thresholds fixed before the tests ran?	Test plan, eval results, test report	Eval gate	3
Release	Is it ready, and is the conformity route complete?	Go/no-go record, declaration, registration	Release gate	1 · 5
Technical file	Can an authority reconstruct all of the above?	Annex IV file, cards, AIBOM	Documentation build	2 · 5

This is not MLOps, which moves the model through the same stages, and it is not model validation in the banking sense, which challenges the model at points in time (the [disambiguation cluster](#) draws both lines). It is the governance record those two activities produce, made machine-readable and given the power to block. The organisation-level rules each gate enforces are set out in chapter 12 ([what policy requires at each stage](#)), and the templates page has schemas and filled examples for the [use-case record](#), [design review](#), [dataset admission](#), [test plan and report](#), and [release gate](#).

The use-case record

The use-case record is the first artefact and the one most often missing. It is written at [intake](#), stored as fields on the registry entry, and read by every later gate. The EU AI Act anchors it: the **intended purpose** is "the use for which an AI system is intended by the provider, including the specific context and conditions of use" [5], and most high-risk duties are measured against it. The NIST AI RMF asks for the same thing in engineering terms: intended purposes, prospective settings and the types of users are "understood and documented" (MAP 1.1), and organisational risk tolerances are "determined and documented" (MAP 1.5) [3].

Field	What it records	Read later by
Business context	The objective, the sponsor, the decision the system informs	Design review, go/no-go
Intended purpose	Task, context and conditions of use	Classification, tests, instructions for use
Out-of-scope uses	Uses the provider rules out, stated explicitly	Misuse analysis, instructions for use, runtime policy
Users and affected persons	Who operates it; who is subject to its outputs, including vulnerable groups	Impact assessments, bias tests

Field	What it records	Read later by
Decision authority	Advisory, human-approved or autonomous; who can overrule it	Oversight design, human-in-the-loop gate
Operating environment	Where it runs, input sources, languages, jurisdictions	Representativeness checks, test plan
Success metrics	The business metric, the model metric and the link between them	Test plan, monitoring
Error appetite	The cost of a false positive against a false negative; tolerated rates	Thresholds
Expected lifetime	Review date and retirement criteria	Maintenance, retention
Data availability	Whether lawful, sufficient data exists	Feasibility, dataset admission

Is AI the right tool?

The first gate question is whether to build at all. Google's engineering guidance opens with the rule "Don't be afraid to launch a product without machine learning" [6], and the governance version is sharper: if a rule, a lookup or a human workflow meets the success metric, a model adds risk without adding value. Record the non-ML baseline in the use-case record and require the design review to beat it by a stated margin. The baseline also gives testing its first comparison: a model that does not outperform the rule it replaces has not earned a place in production.

Error appetite: false positives versus false negatives

Every classifier trades one error for another, and the trade is a business and rights decision, not a modelling one. A fraud model that flags too much freezes legitimate customers; one that flags too little lets fraud through. Write the appetite down before training, in the currency of harm: what a missed case costs, what a false alarm costs, and which error, for which group, is capped regardless of cost. Threshold selection then becomes arithmetic against stated costs, and moving the threshold becomes a change to the record with an approver, not a tuning decision inside a notebook. Per-group error rates and the fairness trade-offs they force are treated in [chapter 16](#).

Function creep

A model built for one purpose drifts into others because its scores are available and cheap. The US banking agencies' revised model-risk guidance puts it plainly: "Using a model beyond its intended purpose introduces additional uncertainty and risk" [7]. Under the EU AI Act the drift has legal consequences. A value-chain actor that modifies the intended purpose of a system so that it becomes high-risk is treated as its provider (Art. 25(1)(c)) [8], and a change not foreseen in the initial conformity assessment that affects compliance is a **substantial modification** (Art. 3(23)) [5]. The engineering control is to make the intended purpose and the out-of-scope list fields that a policy reads. A new consumer of the model's API declares its use at registration; a declared use outside the record fails admission and reopens classification and the impact assessments.

Example (illustrative) A use-case record stored on the registry entry of a credit-limit model. Every later gate reads these fields rather than a slide.

```
{
  "id": "uc-credit-limit-07",
  "registry_id": "clm-07",
  "intended_purpose": "Recommend a credit-limit band for existing retail customers; a credit officer approves.",
  "out_of_scope": ["new-customer onboarding", "collections prioritisation", "employment decisions"],
  "affected_persons": ["retail customers", "guarantors"],
  "decision_authority": "advisory; officer approval required above band 3",
  "success_metric": { "business": "bad-debt rate", "model": "AUC >= 0.78 on frozen holdout" },
  "error_appetite": { "false_negative": "loss amount", "false_positive": "declined uplift",
    "max_fnr_gap_between_groups": 0.03 },
  "non_ml_baseline": "scorecard-v5",
  "classification": { "eu_ai_act": "high-risk, Annex III 5(b)", "gdpr_dpia": true, "fria": true },
  "owner": "team-credit-decisioning",
  "review_by": "2027-03-31"
}
```

In practice (illustrative) A retention team in a large telco asked for a churn model and got, at intake, a one-page use-case record to fill instead of a notebook. Writing the out-of-scope list surfaced that sales wanted the same scores to set individual discount levels: a second purpose with its own fairness exposure. The record split the request into two use cases, each with its own classification and error appetite, and the discount case went back for an impact assessment before any training ran.

Design review

The design review is the gate between an approved use case and spending compute. It reads the use-case record and produces a **design record**: requirements, architecture and model choice with their rationale, the misuse analysis, the oversight design and the controls built in. Annex IV point 2(b) will ask a high-risk provider for the key design choices, their rationale and assumptions, and the trade-offs made [9]; written at the time, that costs minutes, and reconstructed a year later, it costs a project.

Requirements with traceability

Requirements come in three families. **Functional** requirements say what the system does. **Non-functional** requirements set floors for accuracy, latency, fairness, explainability, privacy, robustness and cost. **Regulatory** requirements are the obligations the classification triggers, such as event logging or designed-in oversight for a high-risk system. The NIST AI RMF asks that system requirements are "elicited from and understood by relevant AI actors" (MAP 1.6) [3].

Traceability is the engineering part. Each requirement gets an id, each id maps to at least one test, and each test emits an evidence record naming the requirement. The trace then becomes a join, not a spreadsheet: **REQ-FAIR-02** (false-negative-rate gap between age bands at most 0.03) resolves to the suite **fmr-gap-by-age.v2**, to its last result, and to the release that shipped on it. A requirement with no test is a wish; a test with no requirement is noise in the gate.

Architecture and model-selection trade-offs

Model choice is a governance decision because it fixes what can later be tested, explained and evidenced. Record each choice as a short decision record (context, options, decision, consequences, date, approver) in the same repository as the code.

Choice	Options	Governance consequence
Interpretable or complex	Scorecard, sparse or additive model, small tree; or gradient boosting, deep network, LLM	An interpretable model is its own explanation; a complex one needs post-hoc explanation that can diverge from the model. Rudin argues that high-stakes decisions should use interpretable models instead of explaining black boxes after the fact [10]
Open-weight or proprietary	Self-hosted weights; or a vendor API	Weights can be tested, pinned and hosted in region; an API can change behind you, and its evidence is collected, not produced (procured AI)
Train, fine-tune or prompt	Own model; fine-tuned foundation model; prompting and retrieval	Each step up adds training-data duties; a large enough modification of a general-purpose model can make you its provider [11]
Retrieval or fine-tuning for knowledge	RAG corpus; knowledge in weights	A corpus can be versioned, filtered and deleted from; knowledge in weights cannot be removed without retraining
Hosting	Managed service; own infrastructure	Data residency, log ownership and retention control
Cost and sustainability	Model size, training runs, inference volume	Annex IV asks for the computational resources used to develop, train, test and validate [9]; Annex XI asks GPAI providers for known or estimated energy consumption [12]

Reasonably foreseeable misuse

Reasonably foreseeable misuse is "the use of an AI system in a way that is not in accordance with its intended purpose, but which may result from reasonably foreseeable human behaviour or interaction with other systems" [5]. It is not the same thing as an attack. An attacker is modelled by the red team in **layer 03**; foreseeable misuse is what ordinary users and adjacent systems will do with the output anyway: a triage score read as a diagnosis, a CV ranking used to reject without review, a summariser pointed at a language it was never tested on.

The EU AI Act makes the analysis a design input twice. The risk management system must estimate and evaluate the risks that emerge under conditions of reasonably foreseeable misuse (Art. 9(2)(b)) [13], and the instructions for use must disclose known or foreseeable circumstances, including such misuse, that may lead to risks to health, safety or fundamental rights (Art. 13(3)(b)(iii)) [14]. Keep a **misuse register** in the design record: scenario, who would do it, likelihood, harm, and the response. Each entry must land in at least one of three places: a test in the eval suite, a runtime policy that blocks or flags it, or a warning in the instructions for use. An entry that lands nowhere is an accepted risk and needs a named acceptor (**chapter 13** covers who may accept).

Oversight and controls designed in

The decision-authority field of the use-case record sets the oversight model. The EU's High-Level Expert Group names three approaches: human-in-the-loop, human-on-the-loop and human-in-command [15]. The design review picks one per class of decision and designs it against automation bias and oversight that degrades under load, as set out in **designing human oversight** and the **Human-in-the-loop Gate** pattern. The same review fixes the controls that are cheap now and expensive to retrofit: event logging, a rollback path, a shadow mode, and a **Kill Switch / Circuit Breaker** for anything that acts.

The review is a gate with named reviewers: an engineering lead, the AI governance engineer, security, privacy, a domain expert and, where the affected persons are outside the organisation, someone who can speak for them. Its output is a signed design record with open conditions, not minutes.

Data for training and testing

[Data governance across the stack](#) sets the rule that every dataset carries a lawful basis, a provenance, a retention limit and a set of rights. This section is the development-time procedure that enforces it: a **dataset admission gate**. A training job may read only datasets whose admission record is complete and signed by the data owner, and the check is policy-as-code in the pipeline, not a reminder in a wiki.

The right to use the data

Admission starts with rights, because a quality problem can be fixed and a rights problem often cannot. Per dataset, the record answers five questions.

- **Lawful basis and purpose.** For personal data, which GDPR basis applies to training, and whether training is compatible with the purpose of the original collection. Purpose limitation (Art. 5(1)(b)) and the compatibility factors of Art. 6(4) decide whether data collected to serve customers may train a model about them [16]. Consent to a service is not consent to train.
- **Special categories.** After the Digital Omnibus, the narrow basis to process special-category data for bias detection sits in a new Art. 4a rather than the old Art. 10(5), conditioned on safeguards and deletion [17] (see the [regulatory map](#)).
- **Models as personal data.** The EDPB's Opinion 28/2024 (December 2024) holds that a model trained on personal data is anonymous only if it is very unlikely both to identify the people whose data trained it and to let anyone extract that data through queries; it sets a three-step test for legitimate interest and warns that unlawful processing in development can affect the lawfulness of deployment [18]. [Chapter 19](#) takes this further.
- **Scraped and third-party content.** The EU's commercial text-and-data-mining exception applies only where rightholders have not reserved their rights "in an appropriate manner, such as machine-readable means" for content made publicly available online (DSM Directive Art. 4(3)) [19], and a GPAI provider must keep a copyright policy that identifies and complies with such reservations (AI Act Art. 53(1)(c)) [20]. Record the crawl date, the reservation check and its result per source.
- **Licences and warranties.** Whether the dataset licence permits training, commercial use and distribution of derived models, and what the supplier warrants about lawful collection. The licence goes into the **AIBOM** so a licence change surfaces in the next build.

Quality, quantity, representativeness and fitness for purpose

For high-risk systems, Art. 10 turns data quality into law. Training, validation and testing sets need governance practices covering, among others, collection and origin, preparation, the assumptions about what the data measures, availability and suitability, bias examination and mitigation, and data gaps (Art. 10(2)); they must be "relevant, sufficiently representative, and to the best extent possible, free of errors and complete" (Art. 10(3)) and reflect the setting of use (Art. 10(4)) [21]. The ISO/IEC 5259 series supplies the vocabulary, the measures and the process and governance frameworks [22].

Dimension	Question	Test that evidences it
Label accuracy	Are the labels right?	Audit of a labelled sample; inter-annotator agreement
Completeness	Are fields, segments or periods missing?	Null rates per field and per segment
Consistency	Is the same fact recorded the same way?	Schema and constraint checks
Timeliness	Is the data current for the operating environment?	Date range against the use-case record
Quantity	Are there enough examples per class and per group?	Cell counts against the minimum in the test plan
Representativeness	Does the population match the deployment population?	Distribution comparison against a reference
Fitness for purpose	Does the data measure what the use case needs, or a proxy?	Proxy analysis; assumption register (Art. 10(2)(d))
Integrity	Has it changed since admission?	Content hashes; signed snapshots

Quantity is not representativeness. A large dataset drawn from the wrong population is precisely wrong, and more of it does not cure the bias; it only narrows the confidence interval around the wrong answer. The tools catalogue lists [data-validation tools](#) as illustrative examples, not endorsements.

Owners, stewards and the admission gate

The **data owner** is accountable for a dataset: its permitted uses, its risk acceptance and the signature on its admission record. The **data steward** operates it: quality checks, metadata, access and deletion. Separating the two keeps the person who wants the data used from being the only person who decides it may be. Where many teams share data, a small data review board settles contested admissions and sets the minimum admission checklist; the checklist itself lives as code so that a missing field fails the pipeline.

Provenance versus lineage

The two words are used interchangeably and should not be. **Provenance** is where a dataset came from and on what terms. W3C PROV defines it as "information about entities, activities, and people involved in producing a piece of data or thing, which can be used to form assessments about its quality, reliability or trustworthiness", and its data model (PROV-DM, a W3C Recommendation

since 30 Apr 2013) expresses it as entities, activities and agents [23]. **Lineage** is how the data moved and changed through pipelines. OpenLineage provides an open standard for emitting lineage events about datasets, jobs and runs, with extensible facets [24]. Lineage runs both ways: backward lineage answers "what fed this model?", forward lineage answers "which models used this dataset?", and the second question is the one an erasure request or a licence withdrawal asks.

Choose granularity by where rights attach. Dataset-level provenance is the default. Record-level provenance is needed where rights attach to records (personal data, per-source licences, opt-outs). Feature-level lineage is needed for sensitive derived features that can act as proxies. The human-readable companion is a datasheet: Gebru and colleagues proposed that every dataset carry one covering its motivation, composition, collection, preprocessing, uses, distribution and maintenance [25]. The tools catalogue lists [versioning and lineage tools](#) as illustrative examples, not endorsements.

Synthetic data, augmentation and privacy-enhancing technologies

Synthetic data inherits the properties of its generator: its biases, its gaps and, where the generator memorised, its source records. Treat a synthetic set as a dataset with its own admission record naming the generator, the seed data and the privacy method. Differential privacy is the privacy-enhancing technology with a measurable guarantee, and NIST SP 800-226 (March 2025) explains how to evaluate a differential-privacy claim and the "privacy hazards" that arise when the mathematics meets an implementation [26]. Augmentation and resampling change class balance and, applied before the train and test split, leak information into the test set and inflate scores.

Synthetic data is also a disclosure item. California's AB 2013, operative since 1 Jan 2026, requires developers of generative AI systems made available to Californians to post training-data documentation that states, among other items, whether synthetic data generation was used [27]; the EU template for the GPAI training-content summary lists synthetic data among the data sources to describe [28].

Example (illustrative) A dataset admission record. The training job checks `admitted` and `permitted_uses` against the use-case id before it reads a byte.

```
{
  "dataset_id": "ds-claims-2019-2025@v4",
  "owner": "head-of-claims-data",
  "steward": "data-platform-claims",
  "sources": [{ "name": "claims-core", "period": "2019-01/2025-12",
    "basis": "GDPR Art. 6(1)(f); compatibility assessment CA-2026-014", "licence": "internal" }],
  "tdm_reservation_check": "not applicable (internal data)",
  "special_category": { "present": false },
  "provenance": "prov:wasDerivedFrom claims-core@2026-01-15",
  "lineage_run": "openlineage:claims-features/run-8812",
  "quality": { "null_rate_max": 0.02, "label_agreement": 0.91, "min_n_per_group": 400 },
  "permitted_uses": ["uc-fraud-triage-03"],
  "retention_until": "2032-12-31",
  "admitted": true,
  "admitted_by": "head-of-claims-data",
  "timestamp": "2026-09-20T10:12:00Z"
}
```

Testing and validation

A test plan before the first run

The EU AI Act requires high-risk systems to be tested "throughout the development process, and, in any event, prior to their being placed on the market", against "prior defined metrics and probabilistic thresholds that are appropriate to the intended purpose" (Art. 9(8)) [13]. The NIST AI RMF asks that test sets, metrics and tools are documented (MEASURE 2.1) and that the system is shown to be valid and reliable, with the limits of generalisation documented (MEASURE 2.5) [3]. The operative words are *prior defined*. Freeze the test plan in the repository before evaluation starts: metrics, thresholds with their link to the error appetite, datasets, subgroups, sample sizes and the number of repeated runs. A change to the plan after results are known is a diff with an approver. That single rule prevents metric shopping, the habit of choosing the metric that passes after seeing all of them.

The test-type matrix

ISO/IEC TR 29119-11 gives guidelines for testing AI-based systems [29], and the ISO/IEC 24029 series covers the assessment of neural-network robustness [30]. The matrix below is the working version: one row per test type, one column per system family, and the evidence each run leaves. Tail latency (the 95th or 99th percentile) belongs in it because a mean hides the slow requests that users and timeouts actually meet.

Test type	Classic ML	LLM or agent system	Evidence record
Unit	Feature transforms, data validators, model-wrapper input and output contracts	Prompt templates, tool schemas, output parsers	CI test run
Integration	Pipeline end to end on a fixture dataset	Orchestration, retrieval and tool calls against sandboxes	Integration report
Validation	Holdout, k-fold cross-validation, external validation on another site or period	Held-out task suites, golden sets, human-rated samples	Eval result with interval
Performance	Throughput, p95 and p99 latency, memory	Time to first token, p99 latency, tokens and cost per task	Load-test report
Robustness and out-of-distribution	Noise, perturbation, covariate shift, out-of-distribution sets	Paraphrase, typos, language and format shift, long context	Robustness eval
Stress and edge cases	Extreme values, rare classes, missing inputs	Oversized inputs, tool failures, timeouts, loops	Stress report
Security and adversarial	Evasion, poisoning, model extraction, membership inference	Prompt injection, jailbreak, tool misuse, data exfiltration	Red-team findings
Bias and fairness	Error and selection rates by group	Quality and refusal rates by group, language and dialect	Subgroup eval
Interpretability	Global feature importance, local explanations, reason-code stability	Citation faithfulness, rationale consistency	Explanation eval
Scenario	End-to-end cases from the use-case record and misuse register	Multi-step tasks and agent trajectories	Scenario report
Human-in-the-loop	Reviewer accuracy with and without the model; override rate	Approval quality under load; automation-bias probes	Oversight test
Regression	Score deltas against the last release	Score deltas against the last model or prompt version	Eval gate verdict

Each row is a suite behind the **Eval Gate in CI**; the security row is the **Adversarial Red-Team Suite**. Fairness metrics are defined in [chapter 16](#), which also covers [bias and interpretability testing](#) of the explanations themselves.

Statistical validity of evals

An eval gate is only as good as the statistics under its threshold, and most gates have none ([the limits of the eval gate](#) set out the other limits). Miller's treatment of language-model evaluations frames eval questions as a sample from an unseen super-population and gives the formulas for standard errors, for comparing two models and for planning sample sizes [31]. Four consequences for the gate follow.

- **Report an interval, not a point.** A pass rate of 0.96 on 200 cases has a standard error of $\sqrt{(0.96 \times 0.04 / 200)} \approx 0.014$, so its 95% interval is about 0.933 to 0.987 (± 1.96 standard errors). A 0.95 threshold sits inside it, and the gate cannot tell a pass from a fail. On 2,000 cases the interval narrows to about 0.951 to 0.969. Size the suite from the threshold, not from the time available.
- **Zero failures is not zero risk.** If none of n independent cases fails, the failure rate that would produce that result 5% of the time satisfies $(1 - p)^n = 0.05$, so $p \approx -\ln(0.05)/n \approx 3/n$. Three hundred clean cases bound the failure rate at about 1% with 95% confidence.
- **Repeat non-deterministic runs.** Sampling temperature, batching and tool latency make one run a sample of one. Run each suite several times, report the mean and the spread, pin seeds and versions where the stack allows, and compare models on the same questions (a paired design) to cut noise [31].
- **Distrust the judge and the benchmark.** LLM judges show position, verbosity and self-enhancement biases, even where strong judges reach over 80% agreement with human preferences [32]. Calibrate a judge against a human-labelled sample, randomise answer order, prefer a judge from a different model family than the one under test, and version the judge prompt with the suite. Test items seen in training inflate scores; contamination can be demonstrated even for black-box models [33]. Keep private held-out sets, rotate items and record when each item was written against the model's data cut-off.

Independent validation and model risk management

Banking has run independent model validation for years, and AI governance engineering borrows its best idea: **effective challenge**. In the US, SR 11-7 (2011) was replaced on 17 Apr 2026 by SR 26-2, joint guidance from the Federal Reserve, the OCC and the FDIC. It keeps effective challenge as critical analysis by objective experts with the expertise, "sufficient independence to maintain objectivity", and the standing to effect change, and it keeps the three components of validation: conceptual soundness, ongoing monitoring and outcomes analysis [7]. It also draws a line the engineer must notice: generative and agentic AI models "are not within the scope of this guidance", while its principles apply to traditional models and "non-generative, non-agentic AI models" [7]. In the UK, the PRA's SS1/23 applies to banks, building societies and PRA-designated investment firms with internal-

model approval, makes independent model validation one of its five principles and addresses AI and machine-learning techniques [34].

AI governance engineering takes from this tradition the validator's independence, the documented challenge and tiering by materiality. It adds validation as a re-runnable suite with evidence records rather than a PDF, and coverage for the generative and agentic systems SR 26-2 leaves out. The validator works from a separate repository with read access to model and data, files findings as issues with owners and deadlines, and signs the release gate for the high tiers.

Reproducibility and linked versioning

A result nobody can reproduce is not evidence. The **training record** captures the code commit, the hashes of the admitted data snapshots, the configuration and hyperparameters, the seeds, the environment (container digest, library versions, hardware), the compute used, labelling quality (inter-annotator agreement) and the owner. The record links in both directions: model version to training record to eval results to release tag to the risk approvals that let it ship.

The **model artefact itself needs integrity**. Sign it: the OpenSSF model-signing tooling signs a statement listing each model file and its digest, through Sigstore or conventional keys, and verification recomputes the hashes [35]. Refuse to load serialised formats that execute code from untrusted sources; the Python documentation is blunt that "The pickle module is not secure" [36]. Both checks belong in the build next to the **AIBOM**. The tools catalogue lists **signing and artefact-scanning tools** as illustrative examples, not endorsements.

What goes wrong in training and testing

Problem	How it shows	How to detect it	Gate response
Data leakage	Test score too good; collapses in production	Split by entity and time; audit features for post-outcome fields	Block; re-split and retrain
Overfitting	Training score far above validation	Learning curves; cross-validation variance	Block; regularise or add data
Underfitting	Both scores low, near the baseline	Comparison with the non-ML baseline	Block; revisit the design
Label noise	Accuracy ceiling; inconsistent labels	Inter-annotator agreement; relabelled sample	Reopen dataset admission
Class imbalance	High accuracy, poor minority recall	Per-class metrics, not accuracy alone	Resample or reweight; re-test
Poor calibration	Scores do not match observed rates	Reliability diagram; calibration error	Recalibrate before thresholds are set
Subgroup coverage gap	Wide intervals or no data for a group	Cell counts against the test plan	Block for high-risk; collect data
Environment mismatch	Passes offline, fails online	Shadow run on live inputs	Hold at shadow
Test contamination	Public-benchmark score above private-set score	Private and public gap; contamination tests	Drop contaminated items
Irreproducible result	A rerun disagrees	Fixed-seed reruns	Block until reproducible
Use beyond consent scope	Dataset used outside its permitted uses	Lineage joined to admission records	Block; legal review

Every finding becomes an issue with an owner, a severity and a deadline. A finding that ships unfixed is an accepted risk with a named acceptor, recorded in the risk register that [chapter 13](#) describes, and becomes a regression test so it cannot return silently.

In practice (illustrative) An LLM summariser passed its release gate at 0.96 against a 0.95 floor, on 150 hand-picked cases. A reviewer asked for the interval: at that sample size it ran from about 0.93 to 0.99, so the gate could not tell a pass from a fail. The team moved to a frozen plan of 1,500 cases stratified by document type and language, three repeated runs to capture sampling variance, and a judge from a different model family calibrated against 200 human ratings. The gate became slower, and its verdicts started to mean something.

Release readiness and conformity

The go/no-go gate

Release is a governance milestone, not an engineering handover. The release gate reads the records the earlier gates produced and refuses to open while any is missing or stale: a current use-case record; a signed design record; admitted datasets; a test report against the frozen plan; open issues below the agreed severity or accepted by a named acceptor; completed impact assessments; regenerated cards and instructions for use; monitoring configured (see [chapter 15](#)); a tested rollback; trained operators. The reviewers are named in advance: product owner, engineering, the AI governance engineer, security, privacy and, for the high tiers, legal and the independent validator. The output is a signed go/no-go record with its conditions, filed against the

registry entry. The deployer runs its own [go-live review](#) on top of it (chapter 15). [Release in stages](#), each with exit criteria from the test plan: **shadow** (the system runs on live inputs and its outputs are logged, not used), **canary** (a small share of traffic), a **limited pilot**, then general availability. In the EU, research, testing and development before placing on the market sit outside the AI Act, except testing in real-world conditions [37]; that testing is governed by Art. 60, which after the Omnibus covers Annex III systems and Annex I Section A products, with a new Art. 60a letting member states permit it for Section B products [17].

EU AI Act conformity, in order

For high-risk systems the release gate carries a legal sequence. After the Digital Omnibus, the high-risk duties apply to Annex III systems from 2 Dec 2027 and to Annex I products from 2 Aug 2028 [38].

Step	Article	Artefact	Produced by
1. Quality management system in place	Art. 17	QMS procedures, versioned	Provider
2. Technical documentation drawn up	Art. 11 , Annex IV	The technical file	Pipeline and named authors
3. Conformity assessment	Art. 43 , Annex VI or VII	Internal-control record, or notified-body certificate	Provider, or notified body
4. EU declaration of conformity	Art. 47 , Annex V	Signed declaration	Provider
5. CE marking	Art. 48	Physical or digital CE marking, with the notified-body number where one was involved	Provider
6. Registration	Art. 49 , Art. 71	EU database entry	Provider
7. Placing on the market and monitoring	Art. 72	Post-market monitoring plan in operation	Provider

Annex VI or Annex VII. Annex III points 2 to 8 follow internal control under Annex VI, with no notified body [39]. Under Annex VI the provider verifies that its quality management system complies with Art. 17, examines the technical documentation against the requirements, and verifies that the design and development process and the post-market monitoring are consistent with that documentation [39]. Annex III point 1 (biometrics) may use Annex VI or Annex VII only where the provider has applied harmonised standards or common specifications; otherwise it must follow Annex VII, in which a notified body assesses the quality management system and the technical documentation, with full access to the training, validation and testing datasets, issues a certificate and must be told of changes [39]. No harmonised standard had been cited in the Official Journal at the last check this book records (2026-09-19; see [what is not harmonised yet](#)) [40]; while that holds, a biometric provider planning today should plan for a notified body. Annex I products go through their sectoral conformity procedure, and the Omnibus lets bodies notified under that legislation assess the AI requirements if they apply for designation by 28 Jan 2028 [17].

Declaration, marking and registration. The EU declaration of conformity follows Annex V and is kept for 10 years; the CE marking is affixed visibly, legibly and indelibly, or digitally for systems provided digitally [41]. Before placing on the market, the provider registers Annex III systems in the EU database, except point 2 (critical infrastructure), which is registered at national level; systems the provider has judged not high-risk under Art. 6(3) are also registered; and law enforcement, migration, asylum and border systems go into a non-public section [42]. After the Omnibus, the Art. 6(3) registration asks for less data, and SMEs and small mid-caps may provide the technical documentation in a simplified form the Commission establishes [17]. The engineering move is to generate the database payload from the registry entry, so that the registration and the **Agent Registry** cannot drift apart.

Substantial modification

A **substantial modification** is a change after placing on the market "which is not foreseen or planned in the initial conformity assessment carried out by the provider and as a result of which the compliance of the AI system with the requirements set out in Chapter III, Section 2 is affected or results in a modification to the intended purpose for which the AI system has been assessed" [5]. It triggers a new conformity assessment (Art. 43(4)); for systems that keep learning after release, changes the provider pre-determined at the initial assessment and described in the technical documentation are not substantial modifications [39], which is why Annex IV point 2(f) asks for those pre-determined changes and the technical solutions that keep the system compliant as it changes [9].

Write the pre-determined envelope as code: permitted data sources, retraining cadence, metric floors and threshold ranges. Then classify every change to model, data, prompts, tools or thresholds on merge: inside the envelope (re-run the gates), outside it but compliance unaffected (re-run the gates and record the reasoning), or a potential substantial modification (stop, legal review, reassessment). A retrained model is a new release. It passes the same gates, gets a new version in the registry and regenerates its cards; it does not inherit its predecessor's verdicts. For agents, chapter 23 puts [prompt and system-prompt changes under change control](#).

The technical file

Annex IV, element by element

Art. 11 requires the technical documentation of a high-risk system to be drawn up before it is placed on the market and kept up to date, with at least the contents of Annex IV [9]. Most of Annex IV is already produced by a governed pipeline; the rest is judgement that only a person can supply. The table splits it.

Annex IV item	What it asks for	Pipeline source	What a person must still write
1(a)	Intended purpose, provider, version	Use-case record; registry entry	The intended-purpose statement itself
1(b)	Interaction with other hardware, software and AI systems	AIBOM; architecture diagram	Integration assumptions
1(c)	Software and firmware versions; update requirements	AIBOM; lockfiles	None beyond review
1(d)	Forms in which it is placed on the market	Release manifest	Distribution description
1(e)	Hardware it runs on	Deployment manifests	None beyond review
1(f)	Photographs, where it is a product component	Not applicable to most software	Product documentation
1(g)	The user interface given to the deployer	UI captures from integration tests	Description of use
1(h)	Instructions for use	Generated from the use-case record, model card and misuse register	Limitations and oversight guidance, in plain language
2(a)	Development methods, pre-trained systems, third-party tools	Training record; AIBOM	Why these were chosen
2(b)	Design specifications, key choices, rationale, trade-offs	Design record; decision log	The rationale and assumptions
2(c)	Architecture and computational resources	Training record (compute); architecture diagram	None beyond review
2(d)	Datasheets: training data, provenance, selection, labelling, cleaning	Admission records; datasheets; lineage	The assumptions about what the data measures
2(e)	Assessment of the human-oversight measures	Oversight design; human-in-the-loop test results	The assessment
2(f)	Pre-determined changes and how compliance is kept	Envelope-as-code	The justification of the envelope
2(g)	Validation and testing: data, metrics, discriminatory impacts, dated and signed test reports	Test plan; eval results; test reports	Signatures of the responsible persons
2(h)	Cybersecurity measures	Security test results; threat model ; signing records	Residual security risk
3	Capabilities, limitations, accuracy for specific groups, foreseeable unintended outcomes	Model card; subgroup evals; misuse register	Interpretation of the limits
4	Why the performance metrics are appropriate	Test plan	The argument
5	The risk management system	Risk register	Residual-risk judgement
6	Relevant changes over the lifecycle	Version control; registry history	None beyond review
7	Harmonised standards applied, or the other solutions used	Crosswalk file	The solutions description (no OJ-cited standard at the last check)
8	A copy of the EU declaration of conformity	Generated from the evidence	Signature
9	The post-market monitoring system, with its plan	Monitoring configuration	The plan's triggers and responses

The post-market monitoring plan is part of this file, not a separate document (Art. 72(3)) [43]. Build the file the way code is built: a documentation job assembles it on every release candidate, fails when a generated row is stale or a written row is older than the model version it describes, and emits the result as **Machine-Readable Evidence (OSCAL)** alongside a human-readable rendering.

Model cards, system cards and datasheets

The documents overlap and answer different questions for different readers.

Document	Describes	Main reader	Filled from
Model card	One trained model: intended use, evaluation across groups and conditions, limitations [44]	Integrators, deployers, auditors	Eval results; AIBOM
System card	The deployed system: models, prompts, retrieval, tools, guardrails and oversight	Deployers, authorities, the public	Registry; guardrail configuration; red-team results
Datasheet (data card)	One dataset: motivation, composition, collection, preprocessing, uses, distribution, maintenance [25]	Data owners, model builders, auditors	Admission record; lineage
Instructions for use	What a deployer needs to use a high-risk system correctly (Art. 13) [14]	Deployers	Use-case record; model card; misuse register
Technical file	All of the above plus risk management, standards, declaration and monitoring plan [9]	Authorities; notified bodies	Everything above

Most risk sits in the system, not the raw model ([chapter 01](#)), so a model card alone under-describes anything with tools or retrieval. Generate every card from the same records, as in the **Model Card as Control Evidence** pattern, so the card an auditor reads is the card production produced.

The GPAI provider side

A provider of a general-purpose AI model has its own documentation set under Art. 53: technical documentation per Annex XI for the AI Office and national authorities, information per Annex XII for downstream providers, a copyright policy, and a public summary of training content on the AI Office template [20]. Annex XI covers architecture and parameter count, training methodology, the training data (type, provenance, curation, methods to detect unsuitable sources and biases), the compute and the known or estimated energy consumption; for models with systemic risk it adds evaluation strategies, adversarial testing and system architecture [12].

Who is a GPAI provider is partly a compute question. The Commission's indicative criterion is training compute above 10^{23} FLOP with the ability to generate language, text-to-image or text-to-video; a downstream modifier is indicatively the provider of the modified model when its modification compute exceeds a third of the original's; and the systemic-risk presumption starts at 10^{25} FLOP, with notification to the Commission within two weeks [11]. Put these thresholds in the design review's model-selection record, because a fine-tuning plan can change the organisation's legal role.

Three Commission instruments turn the duties into artefacts. The GPAI Code of Practice (10 Jul 2025, voluntary) includes, in its Transparency chapter, a Model Documentation Form [45] that gathers the Annex XI and XII information in one place and marks each item for downstream providers, the AI Office or national authorities; the Code asks that each version's documentation be kept for 10 years [46]. The training-content summary uses a template that is mandatory under Art. 53(1)(d): it covers general information, data sources (including public, private, scraped, user and synthetic data) and data processing, lists the top 10% of scraped domains (5% or 1,000, whichever is lower, for SMEs), is refreshed every six months or sooner after a material update, and must exist by 2 Aug 2027 for models placed on the market before 2 Aug 2025 [28]. For systemic-risk models, the Code's Safety and Security chapter adds a Safety and Security Model Report, created before the model is placed on the market and kept up to date (Commitment 7) [46]. Engineering implication: the Model Documentation Form is generated from the training record and the AIBOM, and the training-content summary, including its domain list, is a query over the admission records and the crawl logs, not a drafting exercise.

Open-weight release decisions

Release is a gradient, not a switch. Solaiman describes six levels of access: fully closed, gradual or staged access, hosted access, cloud or API access, downloadable access, and fully open [47]. Staged release, as practised for GPT-2 in 2019, leaves time between releases for risk and benefit analysis as capability grows [48]. For open weights the decision is irreversible in a way nothing else in this chapter is: a released model cannot be recalled, patched or placed behind a kill switch. The release record should therefore carry the capability and dual-use evals, the misuse register, the answer to "what would we do if this is misused, given that we cannot withdraw it?", and the licence choice. The Open Source Initiative's definition requires the freedoms to use, study, modify and share, and treats data information, code and parameters as the preferred form for modification [49]; a licence that restricts fields of use therefore does not meet it.

The legal exemptions for open source are narrower than they sound.

- The AI Act does not apply to AI systems released under free and open-source licences, unless they are placed on the market or put into service as high-risk systems, as prohibited practices or as Art. 50 systems (Art. 2(12)) [37].
- A GPAI model under a free and open-source licence with public parameters is exempt only from the Annex XI and Annex XII documentation duties; the copyright policy and the training-content summary still apply, and no exemption applies to models with systemic risk (Art. 53(2)) [20][11].
- The Commission's guidelines treat monetisation as disqualifying: dual licensing (free for academic use, paid for commercial use), paid support that is required to use the model, and processing user data for commercial gain are given as examples [50].

Record keeping

For high-risk systems, the provider keeps the technical documentation, the quality management system documentation, changes approved by notified bodies, their decisions and the EU declaration of conformity at the disposal of national authorities for 10 years after placing on the market (Art. 18), and keeps the logs the system generates automatically, where they are under its control, for a period appropriate to the intended purpose of at least six months, unless other law provides otherwise; financial institutions keep them within their financial-services documentation (Art. 19) [51]. Deployers carry a parallel log duty, covered in [chapter 15](#).

Treat retention as code: each evidence class carries a retention rule keyed to its obligation, signed records go to write-once storage, a legal hold overrides deletion, and the six-month log floor is a floor, not a default, reconciled with the GDPR's storage limitation for personal data in the logs. A 10-year horizon outlives most tools, which argues for open formats (JSON, [OSCAL](#)).

Public disclosures

Different audiences are owed different disclosures, and each has something that must not be published.

Audience	What they get	Channel	What to withhold
Authority or notified body	The full technical file, test logs, access to datasets under Annex VII	On request; conformity assessment	Nothing the law requires; mark trade secrets as confidential
Deployer	Instructions for use (Art. 13); model and system cards; Annex XII information for GPAI	Contract; documentation portal	Exploitable security detail; weights
Affected persons	That AI is used, and how to contest or seek explanation (see chapter 15)	Product interface; notices	Nothing about their own case that a right entitles them to
The public	EU database entry; GPAI training-content summary; AB 2013 documentation; bias-audit summaries; published impact assessments	Website; public registers	Red-team exploit detail; personal data; security configuration

Two non-EU disclosures show the pattern. New York City's Local Law 144 requires employers using an automated employment decision tool to hold a bias audit by an independent auditor from within the past year, to publish a summary of its results, including the source of the data used, and to notify candidates 10 business days before use [52]. Canada's Directive on Automated Decision-Making requires federal institutions to publish the final results of their algorithmic impact assessment on the Open Government Portal before the system goes into production [53].

In practice (illustrative) A provider preparing an Annex III system for the 2 Dec 2027 date listed the 23 items of Annex IV in a file, one row each, with the pipeline source and a named author. Most rows turned out to be assembled from records the pipeline already emitted; the rest were rationale, residual-risk judgements and signatures. The documentation job ran on every release candidate and failed twice in its first month: once on a model card older than the model, once on a test report nobody had signed. Both failures would have surfaced a year later, in front of a notified body.

Impact assessments compared

A single system can trigger several impact assessments at once. They overlap on facts (who is affected, what could go wrong, what controls exist) and differ on law, trigger, reviewer and audience. The engineering answer is one shared fact base with several views, not five documents that drift apart.

Assessment	Performed by	Trigger	When	Reviewed or signed by	Published	Re-assessed when
AI system impact assessment (ISO/IEC 42005)	The organisation developing or providing the system	Organisational policy; ISO/IEC 42001 A.5	Throughout the lifecycle, from design [54]	Per the organisation's AI management system	Voluntary	Updated as needed over the lifecycle [54]
DPIA (GDPR Art. 35)	The controller	Processing likely to result in high risk; mandatory cases in Art. 35(3)	Before the processing [16]	Controller, with the DPO's advice; the supervisory authority if high risk remains (Art. 36)	Not required	When the risk of the processing changes (Art. 35(11)) [16]
FRIA (AI Act Art. 27)	Deployers that are public bodies or provide public services, and deployers of Annex III 5(b) and (c) systems	Deploying an Annex III high-risk system (not point 2)	Before first use [55]	Results notified to the market surveillance authority	Not required publicly	When any assessed element changes [55]

Assessment	Performed by	Trigger	When	Reviewed or signed by	Published	Re-assessed when
Algorithmic impact assessment (Canada)	Federal institution	Automated decision system under the Directive	Before production [53]	Approved internally; expert review per impact level	Yes, Open Government Portal	On a schedule, and when functionality or scope changes [53]
Bias audit (NYC Local Law 144)	Independent auditor, for the employer or agency	Using an automated employment decision tool in NYC	Within one year before use [52]	Independent auditor	Yes, summary of results	Every year [52]
Independent model validation (SR 26-2, SS1/23)	Validation function independent of development	Model use in a supervised bank	Generally before first use [7]	Validators with standing to effect change	No	Periodically, and on material change [7]

Dimensions that make impacts comparable

Score each impact on the same axes whichever assessment it feeds: **severity** (how bad for the person affected), **scale** (how many people), **reversibility** (whether the harm can be undone, and how fast), **duration** and **likelihood**. The dimensions are not invented here. Canada's Directive defines its impact levels by them, from level I, where impacts are likely to be "little to no, easily reversible, and brief", to level IV, where they are likely to be "very high, irreversible and perpetual" [53]. The FRIA asks for the affected categories, the specific risks of harm, the oversight measures and the mitigation and complaint arrangements (Art. 27(1)) [55]; the DPIA asks for the processing, its necessity and proportionality, the risks and the measures (Art. 35(7)) [16]. One record with these fields answers both, and Art. 27(4) lets a FRIA build on a DPIA that covers the same ground [55].

Performing versus reviewing

The performer owns the facts; the reviewer challenges them. A reviewer who did not write the assessment checks six things: the scope matches the current use-case record; the affected groups include people who never use the system; every risk rating cites evidence (an eval id, a test report, a data profile), not an opinion; every mitigation links to a control that runs; residual risk is accepted by someone with the authority to accept it; and the re-assessment triggers are written as conditions a pipeline can evaluate. An assessment that fails any of the six goes back, however well written it is.

Re-assessment triggers

Encode the triggers so that the registry, not a calendar reminder, reopens the assessment: a new or widened intended purpose; retraining on a new data source; a new affected population, language or jurisdiction; a threshold change; an incident or near miss ([chapter 17](#)); a monitoring signal outside its band; new law or guidance; and a scheduled review date. The **FRIA-as-Code** pattern already does this for the FRIA and its DPIA cross-reference; the same structure generalises, as Impact-Assessment-as-Code, to every assessment in the table.

In practice (illustrative) The credit-limit model from the use-case example sat under four assessments at once: a DPIA (the bank as controller), a FRIA (the bank as deployer of an Annex III 5(b) system), an impact assessment run by the model team along ISO/IEC 42005 lines, and independent validation. The team kept one fact base (affected groups, harms scored on the five dimensions, controls with their eval ids) and rendered four views from it. When retraining added a new data source, the lineage change tripped the trigger for all four in the same pipeline run, and the reviewers saw a diff instead of four new documents.

Maps to: EU AI Act Art. 3(12), 3(13) and 3(23), Art. 9, 10, 11 and Annex IV, Art. 13, 17, 18, 19, 25, 27, 43 and Annexes VI and VII, Art. 47 to 49, Art. 53 and Annexes XI and XII, Art. 72 · GDPR Art. 35 · ISO/IEC 42001 (A.5, A.6, A.7), ISO/IEC 42005, ISO/IEC 5338, ISO/IEC 5259 · NIST AI RMF (Map, Measure) · Layer 01 Govern-as-Code to Layer 05 Assurance & Continuous Compliance. Mappings are illustrative, not a claim of conformity.

What you can do this week

1. Write the use-case record for the highest-risk system you have in development, including its out-of-scope uses and its false-positive against false-negative appetite, and store it on the registry entry.
2. Freeze the test plan for its next release in the repository: metrics, thresholds, subgroups, repeated runs, and the sample size each threshold needs to be distinguishable from a fail.
3. Pick one training dataset and fill its admission record (basis or licence, reservation check, provenance, owner, steward), then make the training job refuse datasets without one.
4. Map your current documentation to the Annex IV table above and mark each row generated, written or missing.

5. List every impact assessment the system triggers and move their shared facts into one record, with the re-assessment triggers written as conditions.

Sources

[1] ISO/IEC 5338:2023, AI system life cycle processes. ISO/IEC. 2023. <https://www.iso.org/standard/81118.html> (verified: primary) [2] ISO/IEC 42001:2023, AI management system (Annex A.5 impact assessment, A.6 AI system life cycle, A.7 data for AI systems). ISO/IEC. 2023. <https://www.iso.org/standard/81230.html> (verified: secondary) [3] AI Risk Management Framework 1.0 (NIST AI 100-1; MAP 1.1 intended purposes and context documented, MAP 1.5 risk tolerances, MAP 1.6 system requirements, MEASURE 2.1 test sets and metrics documented, MEASURE 2.5 validity and reliability). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [4] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 17 (quality management system: design control and design verification; examination, test and validation procedures before, during and after development; data management). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_17 (verified: primary) [5] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 3 (definitions: (12) intended purpose, (13) reasonably foreseeable misuse, (23) substantial modification). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_3 (verified: primary) [6] Rules of Machine Learning: Best Practices for ML Engineering (Rule #1: "Don't be afraid to launch a product without machine learning"). Google for Developers. n.d. (accessed 2026-09-24). <https://developers.google.com/machine-learning/guides/rules-of-ml> (verified: primary) [7] SR 26-2, Revised Guidance on Model Risk Management (Federal Reserve, OCC and FDIC; supersedes SR 11-7 of 2011-04-04 and SR 21-8; generative and agentic AI models out of scope; effective challenge; conceptual soundness, ongoing monitoring, outcomes analysis; model use beyond intended purpose). Board of Governors of the Federal Reserve System. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> (verified: primary) [8] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 25 (responsibilities along the AI value chain; 25(1)(c) a third party that modifies the intended purpose of a system so that it becomes high-risk is considered its provider). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_25 (verified: primary) [9] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 11 and Annex IV (technical documentation: 1(a) to (h) general description incl. instructions for use; 2(a) to (h) development process, design choices and trade-offs, compute, datasheets and provenance, oversight, pre-determined changes, validation and testing with dated and signed reports, cybersecurity; 3 to 9 capabilities and limitations, metrics, risk management, changes, standards, declaration, post-market monitoring). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#anx_IV (verified: primary) [10] Stop explaining black box machine learning models for high stakes decisions and use interpretable models instead (Cynthia Rudin). Nature Machine Intelligence. 2019. <https://www.nature.com/articles/s42256-019-0048-x> (verified: primary) [11] General-Purpose AI Models in the AI Act: Questions & Answers (indicative GPAI criterion: training compute above 10^{23} FLOP and generation of language, text-to-image or text-to-video; a downstream modifier is indicatively the provider when modification compute exceeds a third of the original's; 10^{25} FLOP systemic-risk threshold; notification within two weeks; Art. 53(2) open-source conditions). European Commission. 2026. <https://digital-strategy.ec.europa.eu/en/faqs/general-purpose-ai-models-ai-act-questions-answers> (verified: primary) [12] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Annexes XI and XII (GPAI technical documentation: architecture and parameters, training methodology, training data provenance and curation, compute, known or estimated energy consumption; Section 2 for systemic-risk models: evaluation strategies, adversarial testing, system architecture; Annex XII information for downstream providers). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#anx_XI (verified: primary) [13] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 9 (risk management system; 9(2)(b) risks under reasonably foreseeable misuse; 9(8) testing against prior defined metrics and probabilistic thresholds, before placing on the market). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_9 (verified: primary) [14] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 13 (transparency and instructions for use; 13(3)(b)(iii) known or foreseeable circumstances, incl. reasonably foreseeable misuse, that may lead to risks). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_13 (verified: primary) [15] Ethics Guidelines for Trustworthy AI (High-Level Expert Group on AI; oversight through human-in-the-loop, human-on-the-loop and human-in-command approaches). European Commission. 2019-04-08. <https://digital-strategy.ec.europa.eu/en/library/ethics-guidelines-trustworthy-ai> (verified: primary) [16] Regulation (EU) 2016/679 (GDPR): Art. 5(1)(b) purpose limitation; Art. 6(4) compatibility of further processing; Art. 35 data protection impact assessment (35(2) DPO advice, 35(3) mandatory cases, 35(7) contents, 35(11) review when the risk changes); Art. 36 prior consultation. Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [17] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, as amended by Regulation (EU) 2026/1744 (Art. 4a replaces the deleted Art. 10(5) for special-category data in bias detection; simplified technical documentation for SMEs and small mid-caps under Art. 11(1); Annex VIII Section B points 7 and 9 deleted for Art. 6(3) registrations; Art. 43(3) sectoral notified bodies to apply for designation by 28 Jan 2028; Art. 60 scope (Annex III and Annex I Section A) and new Art. 60a (Annex I Section B)). Publications Office of the EU (EUR-Lex). 2026-07-27. <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng> (verified: primary) [18] Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (anonymity of models; legitimate interest; consequences of unlawful processing in development). European Data Protection Board. 2024-12. https://www.edpb.europa.eu/documents/opinion-of-the-board-art-64/opinion-282024-on-certain-data-protection-aspects-related-to_en (verified: primary) [19] Directive (EU) 2019/790 on copyright in the Digital Single Market, Art. 4 (text and data mining exception; 4(3) reservation of rights by machine-readable means for content made publicly

available online). Publications Office of the EU (EUR-Lex). 2019-05-17. <https://eur-lex.europa.eu/eli/dir/2019/790/oj/eng> (verified: primary) [20] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 53 (GPAI provider obligations: (a) Annex XI documentation, (b) Annex XII information for downstream providers, (c) copyright policy incl. reservations of rights, (d) public summary of training content on the AI Office template; 53(2) open-source exemption from (a) and (b), not for systemic-risk models). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_53 (verified: primary) [21] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 10 (data and data governance: 10(2) practices, 10(3) relevant, sufficiently representative, free of errors and complete, 10(4) specific setting of use). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_10 (verified: primary) [22] ISO/IEC 5259 series, Data quality for analytics and machine learning (ML): Part 1 overview, terminology and examples (2024); Part 2 data quality measures (2024); Part 3 data quality management requirements and guidelines (2024); Part 4 data quality process framework (2024); Part 5 data quality governance framework (2025). ISO/IEC. 2024–2025. <https://www.iso.org/standard/81088.html> (verified: primary) [23] PROV Overview (PROV-DM and PROV-O W3C Recommendations of 30 April 2013; provenance as information about entities, activities and people involved in producing data). W3C. 2013-04-30. <https://www.w3.org/TR/prov-overview/> (verified: primary) [24] OpenLineage: an open platform for collection and analysis of data lineage (standard API for lineage events over datasets, jobs and runs, with facets). OpenLineage project (The Linux Foundation). 2026. <https://openlineage.io/> (verified: primary) [25] Datasheets for Datasets (Gebru et al.; arXiv 1803.09010). arXiv. 2018-03-23. <https://arxiv.org/abs/1803.09010> (verified: primary) [26] NIST SP 800-226, Guidelines for Evaluating Differential Privacy Guarantees (differential privacy pyramid; privacy hazards). NIST. 2025-03. <https://csrc.nist.gov/pubs/sp/800/226/final> (verified: primary) [27] AB 2013, Generative artificial intelligence: training data transparency (chaptered 2024-09-28; operative 2026-01-01; developers post training-data documentation incl. sources, personal information, copyright status and use of synthetic data). California Legislature. 2024-09-28. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202320240AB2013 (verified: primary) [28] Template for general-purpose AI model providers to summarise their training content (template mandatory under Art. 53(1)(d); applicable from 2 Aug 2025, legacy models by 2 Aug 2027; sources incl. scraped, user and synthetic data; top 10% of scraped domains, for SMEs 5% or 1,000; six-monthly update). European Commission. 2025-07-24. <https://digital-strategy.ec.europa.eu/en/faqs/template-general-purpose-ai-model-providers-summarise-their-training-content> (verified: primary) [29] ISO/IEC TR 29119-11:2020, Software testing, Part 11: Guidelines on the testing of AI-based systems. ISO/IEC. 2020. <https://www.iso.org/standard/79016.html> (verified: primary) [30] ISO/IEC TR 24029-1:2021 and ISO/IEC 24029-2:2023, Robustness of neural networks (Part 1 overview; Part 2 methodology for the use of formal methods). ISO/IEC. 2021–2023. <https://www.iso.org/standard/79804.html> (verified: primary) [31] Adding Error Bars to Evals: A Statistical Approach to Language Model Evaluations (Evan Miller; arXiv 2411.00640). arXiv. 2024-11-01. <https://arxiv.org/abs/2411.00640> (verified: primary) [32] Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena (Zheng et al.; position, verbosity and self-enhancement biases; over 80% agreement with human preferences; arXiv 2306.05685). arXiv. 2023-06-09. <https://arxiv.org/abs/2306.05685> (verified: primary) [33] Proving Test Set Contamination in Black Box Language Models (Oren et al.; arXiv 2310.17623). arXiv. 2023-10-26. <https://arxiv.org/abs/2310.17623> (verified: primary) [34] SS1/23, Model risk management principles for banks (five principles incl. independent model validation; UK-incorporated banks, building societies and PRA-designated investment firms with internal-model approval; addresses AI and machine-learning techniques; first published 17 May 2023, in effect from 17 May 2024; current version published and effective 23 Apr 2026 after low-impact amendments). Bank of England, Prudential Regulation Authority. 2026-04-23. <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> (verified: primary) [35] model-transparency: supply chain security for ML (OpenSSF-linked model signing; signs an in-toto statement of file paths and digests through Sigstore or conventional keys; verification recomputes the hashes). Sigstore (GitHub). 2026. <https://github.com/sigstore/model-transparency> (verified: primary) [36] pickle: Python object serialization ("The pickle module is not secure. Only unpickle data you trust."). Python Software Foundation. 2026. <https://docs.python.org/3/library/pickle.html> (verified: primary) [37] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 2 (2)(8) research, testing and development before placing on the market excluded, except testing in real-world conditions; 2(12) systems under free and open-source licences excluded unless high-risk, Art. 5 or Art. 50). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_2 (verified: primary) [38] "AI Omnibus enters into force" (Reg. (EU) 2026/1744, in force 2026-07-27; Annex III high-risk from 2 Dec 2027; Annex I from 2 Aug 2028). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force> (verified: primary) [39] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 43 and Annexes VI and VII (internal control for Annex III points 2 to 8; Annex VI or VII for point 1 where harmonised standards or common specifications are applied, Annex VII otherwise; Annex I products under sectoral procedures; 43(4) new assessment on substantial modification, pre-determined changes excepted; Annex VII notified-body access to training, validation and testing data and control of changes). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_43 (verified: primary) [40] CEN-CENELEC JTC 21 standards tracker (no AI Act harmonised standard cited in the Official Journal, so no Art. 40 presumption of conformity; tracker updated 29 Jun 2026; the book's regulatory map rechecked on 2026-09-19). CEN-CENELEC JTC 21 (via kla.digital). 2026-06-29. <https://kla.digital/blog/jtc-21-standards-tracker> (verified: secondary) [41] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Arts. 47 and 48 (EU declaration of conformity per Annex V, kept for 10 years; CE marking affixed visibly, legibly and indelibly, digital marking for digitally provided systems, notified-body number where applicable). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_47 (verified: primary) [42] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 49 (registration in the EU database before placing on the market; Annex III point 2 at national level; Art. 6(3) systems; public-authority deployers; non-public section for law enforcement, migration, asylum and border control). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_49 (verified: primary) [43] Regulation (EU) 2024/1689 (AI Act), consolidated

text of 2026-07-27, Art. 72 (post-market monitoring system; 72(3) the monitoring plan is part of the Annex IV technical documentation; as amended by Reg. (EU) 2026/1744, Commission guidance including a template by 2 Sep 2027). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_72 (verified: primary)

[44] Model Cards for Model Reporting (Mitchell et al.; arXiv 1810.03993). arXiv. 2018-10-05. <https://arxiv.org/abs/1810.03993> (verified: primary)

[45] The General-Purpose AI Code of Practice (published 10 Jul 2025; voluntary; Transparency chapter with a Model Documentation Form; Safety and Security chapter for systemic-risk models). European Commission. 2025-07-10. <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai> (verified: primary)

[46] EU AI Act: General-Purpose AI Code of Practice, final version (unofficial reader: Model Documentation Form marks items for downstream providers, AI Office or national authorities; documentation kept 10 years per version; Safety and Security chapter Commitment 7, a Safety and Security Model Report before placing a model on the market). code-of-practice.ai (Alexander Zacherl). 2025. <https://code-of-practice.ai/> (verified: secondary)

[47] The Gradient of Generative AI Release: Methods and Considerations (Irene Solaiman; six levels of access from fully closed to fully open; arXiv 2302.04844). arXiv. 2023-02-05. <https://arxiv.org/abs/2302.04844> (verified: primary)

[48] Release Strategies and the Social Impacts of Language Models (Solaiman et al.; GPT-2 staged release; arXiv 1908.09203). arXiv. 2019-08-24. <https://arxiv.org/abs/1908.09203> (verified: primary)

[49] The Open Source AI Definition 1.0 (freedoms to use, study, modify and share; preferred form for modification covers data information, code and parameters). Open Source Initiative. 2024-10. <https://opensource.org/ai/open-source-ai-definition> (verified: primary)

[50] Commission Guidelines on the scope of the obligations for providers of general-purpose AI models established by Regulation (EU) 2024/1689 (C(2025) 7719 final; section 4.2.2, paras 82 to 84: monetisation defeats the open-source exceptions, e.g. dual licensing free for academic and paid for commercial use, paid support or services required to access or use the model, and processing of personal data other than strictly for model security). European Commission. 2025-11-19. <https://digital-strategy.ec.europa.eu/en/library/guidelines-scope-obligations-providers-general-purpose-ai-models-under-ai-act> (verified: primary)

[51] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Arts. 18 and 19 (provider keeps technical documentation, QMS documentation, notified-body decisions and the EU declaration for 10 years; automatically generated logs kept at least six months unless other law provides otherwise; financial institutions keep logs within financial-services documentation). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_18 (verified: primary)

[52] Automated Employment Decision Tools: Frequently Asked Questions (Local Law 144 of 2021; bias audit by an independent auditor within the past year; selection or scoring rates and impact ratios across sex, race/ethnicity and intersectional categories; public summary incl. data source; notice 10 business days before use). NYC Department of Consumer and Worker Protection. 2023. <https://www.nyc.gov/assets/dca/downloads/pdf/about/DCWP-AEDT-FAQ.pdf> (verified: primary)

[53] Directive on Automated Decision-Making (6.1 algorithmic impact assessment completed, approved and published on the Open Government Portal before production, updated on a schedule and when functionality or scope changes; 6.3.7 expert review; Appendix B impact levels defined by reversibility and duration). Treasury Board of Canada Secretariat. 2025-06-24. <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32592> (verified: primary)

[54] ISO/IEC 42005:2025, AI system impact assessment (guidance for assessing impacts on individuals, groups and society throughout the life cycle, updated as needed; complements ISO/IEC 42001 and ISO/IEC 23894). ISO/IEC. 2025-05. <https://www.iso.org/standard/44545.html> (verified: primary)

[55] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 27 (FRIA by deployers that are bodies governed by public law or private entities providing public services, and deployers of Annex III points 5(b) and (c), except point 2 systems; elements (a) to (f); results notified to the market surveillance authority; 27(4) relationship with the DPIA). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_27 (verified: primary)

15. Governing deployment and use

Governing the run: how a deployer decides to use an AI system, chooses it, contracts for it, takes it live, operates it and retires it, with every step leaving evidence that a control fired.

Most organisations deploy far more AI than they build. A provider's design duties are largely discharged when the system is placed on the market; a deployer's duties begin when the system is put to use, and they run for as long as it runs: use it as instructed, staff its oversight, monitor it, suspend it when it presents a risk, keep its logs and tell people it is there [1]. Chapter 18 lists the [Article 26 deployer duties](#) one by one, and chapter 17 covers the incident side of them ([deployer duties: inform the provider, suspend use](#)). This chapter follows one system from the decision to use it to the day it is switched off. At each step it names the decision, the artefact that records it, the stack layer that produces the evidence and the record that lands in the assurance store.

Two terms carry the chapter. A **deployer** is anyone using an AI system under its authority, except in a personal, non-professional activity; a **provider** develops a system or model, or has it developed, and places it on the market or puts it into service under its own name or trademark [2]. The labels describe tasks, not kinds of organisation: a bank that fine-tunes a vendor model and ships the result under its own brand can hold both roles for the same system (see [When a deployer becomes a provider](#)). Chapter 14 covers the build side; this chapter covers the run. Article references are to the EU AI Act as amended by the Digital Omnibus, as of 2026-09-24, whose high-risk rules apply to Annex III systems from 2 December 2027 [3]; they are illustrative mappings, not a claim of conformity.

Governing deployment is not release engineering. MLOps asks whether a new version can be rolled out and rolled back. AI governance engineering asks who decided the system may serve, on what evidence, which signal rolls it back without a meeting, and what record proves each of those happened.

The deployment lifecycle at a glance

Stage	The decision	Artefact	Layer	Evidence record
Decide	Should AI do this, and exactly what?	Deployment Decision Record	1 · 2	Signed record linked to the registry entry
Choose	Which model, hosted where, adapted how?	Model selection record	3 · 2	Task-eval results per candidate
Contract	On what terms?	Contract and licence review	1 · 5	Clause checklist; AIBOM licence fields
Go live	Approve, approve with conditions, or reject?	Go-live decision with dissent	1 · 5	Decision record; conditions as policy
Roll out	How much exposure, and what rolls it back?	Rollout plan with rollback criteria	4	Stage-gate results; rollback events
Operate	Is it still fit, fair and worth it?	Monitoring plan ; maintenance calendar	4 · 5	Drift, fairness, cost and energy telemetry
Assure	Do the controls still work?	Audit, red-team and threat-model programme	3 · 5	Findings tracked to closure
Communicate	Who must hear what, and when?	Communications plan and templates	5	Notices sent, with timestamps
Retire	Degrade, localise or switch off?	Deactivation and retirement runbook	4 · 2	Decision record; final evidence snapshot

The deployment decision

Start from the use case, not the model

The decision to deploy is a product decision with a governance record. Before any model is compared, write down the business objective and how you will know it was met, the people the system will act on, the decision it informs or makes, and whether AI is the right tool at all: a rules engine, a better form or a search index is sometimes the honest answer.

Then name the **negative space**: what the system is explicitly not for. Negative space is what later makes function creep detectable, because a use that was never approved has somewhere to be recorded as out of scope. The provider's **intended purpose** (the use it designed and documented the system for, including the context and conditions of use [2]) is the outer boundary; your negative space sits inside it.

Classify the use at intake, the workflow described in [chapter 06](#): risk tier, regulatory exposure, data sensitivity and autonomy. The classification decides which of the controls in this chapter apply. An Annex III use triggers the deployer duties of Article 26 [1] and, for public bodies, private entities providing public services, and credit-scoring and life- and health-insurance pricing uses, the

Article 27 fundamental-rights impact assessment (FRIA) before first use [4]. A chatbot or a generator of synthetic content triggers the Article 50 transparency duties, which apply from 2 August 2026 [5]; a generative system already on the market before that date has until 2 December 2026 to meet the Article 50(2) marking duty (Article 111(4)) [8]. The prohibited practices of Article 5 bind deployers as well as providers, including the ban on systems that exploit vulnerabilities due to age, disability or a specific social or economic situation [6].

Set performance and explainability requirements first

Requirements written after a vendor demonstration are fitted to the demonstration. Set them before you look at candidates:

- **Metrics that match the harm.** For a triage classifier, false negatives on urgent cases; for a generative assistant, groundedness and the refusal of out-of-scope requests. An average accuracy figure is rarely the metric that matches a harm.
- **Per-group floors.** A threshold per population the system acts on, so a good average cannot hide a group the system fails.
- **Go/no-go thresholds** that the go-live review will apply, each traced to the failure mode it stands for, which is the discipline set out in [the limits of the eval gate](#).
- **The explanation the use needs.** A reason code for an adverse decision, a cited source for a generated answer, or an interpretable model where the decision must be contestable. When a decision based on the output of most Annex III systems has legal or similarly significant effects on a person, that person has a right to a clear and meaningful explanation from the deployer of the system's role in the decision [7]. Designing for that answer is cheaper than retrofitting it; [chapter 16](#) covers the methods.

Check the data and the people

Data. Does the input data exist at the coverage and quality the use needs, with a supply that will last, and a lawful basis for this purpose? Where the deployer controls the input data of a high-risk system, it must ensure the data is relevant and sufficiently representative for the intended purpose [1].

People. Oversight must be assigned to people with the necessary competence, training and authority, and the support to use it [1]. Article 4, reworded by the Omnibus, asks providers and deployers to support the AI literacy of their staff [8]. Before a high-risk system is used at work, an employer-deployer must inform workers' representatives and the affected workers [1]. Readiness also means the authority to pause: an operator who sees the system misbehave must be allowed to stop it without first asking permission.

The Deployment Decision Record

Pull these answers into one artefact, the **Deployment Decision Record (DDR)**, committed next to the system's code and referenced from its registry entry (layer 02). Its floors become the thresholds of the eval gate (layer 03); its negative space becomes the scope the runtime watches (layer 04). The templates page has a JSON Schema for [the deployment decision and the retirement workbook](#). An illustrative excerpt:

```
{ "ddr_id": "ddr-csa-01-v1", "system": "csa-01",
  "objective": "resolve tier-1 refund queries without an agent",
  "not_for": ["credit decisions", "complaints about staff"],
  "risk_tier": "limited", "obligations": ["EU AI Act Art. 50", "GDPR Art. 35"],
  "floors": { "groundedness": 0.95, "out_of_scope_refusal": 0.98 },
  "retire_if": ["deflection below business case for two quarters"],
  "owner": "team-support-platform", "decision": "proceed-to-selection" }
```

In practice (illustrative) For `csa-01`, the customer-service assistant in a large telco, the DDR's negative space listed "complaints about staff". Months later a team proposed routing internal HR queries to the same assistant. The intake form checked the proposal against the record, flagged it as a new use, and sent it back through classification instead of a quiet configuration change. The record did not stop the idea; it made the change of purpose visible and owned.

Choosing the model

Evaluate on your task, your data and your users

A public benchmark answers "how good is this model at that benchmark?". The deployer's question is "how good is it at our task, for our users, under our constraints?". Build a **selection eval**: a set of representative cases drawn from traffic you may lawfully use, labelled with the answer you want, stratified by the groups and edge cases the DDR names, and scored on the metrics that match the harm. Make it large enough to show the per-group difference you care about. Run every candidate through the same harness with the same prompts, retrieval and guardrails, and keep the results: the selection eval becomes the first version of the regression suite behind the [eval gate](#).

What public benchmarks and leaderboards cannot tell you

- **Contamination.** Test items leak into training data. When researchers wrote a fresh set of grade-school maths problems matched to a popular benchmark, several model families lost up to 8% in accuracy, a sign of overfitting to the public set [9].

- **Selective disclosure.** A ranking reflects what providers choose to submit. An analysis of a widely used arena-style leaderboard found that a few providers tested many private variants before release and could retract scores if they chose [10].
- **Goodhart.** Once a benchmark matters commercially, models are tuned to it. The pressure that makes an eval gate Goodhartable applies with more force to a public number you do not control.

Use benchmarks to build a shortlist, never to make the decision.

Count the whole cost, including energy

The cost of a model is the licence or API fee plus inference compute, integration, evaluation and monitoring, the running cost of the governance stack around it (see [the cost of the stack](#)) and the cost of leaving. Energy and carbon belong on the same ledger, and the model choice is where most of them are decided. One study measured multi-purpose generative architectures as orders of magnitude more expensive per inference than task-specific systems on the same tasks, even controlling for model size [11]. The measurement boundary matters: one provider put the median text prompt of its assistant at 0.24 Wh, counting idle capacity and data-centre overhead as well as the accelerators [12]; a figure that leaves those out is not comparable. At the level of the whole sector, the IEA projects data-centre electricity use to more than double to around 945 TWh by 2030 [13]. The AI Act asks GPAI providers to document the known or estimated energy consumption of their models [14]; nothing in it measures your inference footprint, so the deployer has to.

Record the choice

The **model selection record** lists the candidates, their selection-eval results, the cost and energy estimates, the reasons for the choice, the conditions that would reopen it (a price change, a new vendor version, a floor breached in production) and the exit plan. It is filed against the registry entry, so "why this model?" is answered by a query a year later, when the people who chose have moved on.

Model types and deployment options

The model type changes the failure modes. The hosting option changes who can see and stop what. The adaptation technique changes what you must re-test and, sometimes, your legal role. The tables below describe each option, and the matrix at the end names the control each combination adds. Treat all of it as illustrative, not a claim of conformity: the controls a real deployment needs follow from its risk tier, its obligations and its failure modes.

Model type changes the control set

Model type	Dominant failure modes	Controls it adds (layer)
Classic predictive (classifier, scorer, forecaster)	Miscalibration; error gaps between groups; input and label drift; feedback loops where the score shapes the next training data.	L3: Per-group performance floors and a calibration eval on your own labelled data; L4: Drift monitor on inputs and outcomes (PSI, KS); L2: Model card that states the population the model was validated on
Generative (text, code, media)	Ungrounded or fabricated output; harmful or infringing content; prompt injection; leakage of personal or confidential data.	L3: Groundedness and red-team evals on your own prompts; L4: Input and output guardrails; disclosure and labelling of synthetic content (Art. 50); L2: Prompts and system prompts versioned as configuration in the registry entry
Proprietary (API or licensed weights)	Silent version change; lock-in; opaque training data; terms or prices that change under you.	L1: Contract terms (no training on inputs, residency) enforced as policy; L2: Vendor model version pinned in the registry entry; L3: Boundary evals re-run on every vendor version change
Open-weight	Licence or acceptable-use breach; tampered or malicious weight files; unpatched vulnerabilities that are now yours to patch.	L1: Licence and acceptable-use check as a policy gate; L2: AIBOM entry with source, licence and file hash; L3: Full eval and red-team suite of your own; L4: Your own guardrails: no vendor safety layer sits in front
Small (task-sized, edge-capable)	Capability ceiling; weaker refusal training; brittle outside its task.	L3: Task-specific eval that proves fitness for this task, not in general; L4: Route out-of-scope requests to a fallback or a human
Large (general-purpose, frontier)	Broad capability surface; wide jailbreak surface; cost overruns; over-reliance by users.	L1: Scope the use case in policy: what the system may not be asked to do; L3: Broader red team across the capabilities you do not need; L4: Rate limits and spend caps per identity
Language-only	Text harms; injection through documents and web content the model reads.	L3: Text red team including indirect injection; L4: Text guardrails on input and output
Multimodal (image, audio, video)	Synthetic media and impersonation; instructions hidden in images or audio; biometric and surveillance uses.	L1: Prohibited-practice checks (Art. 5) and a biometric-use policy; L3: Cross-modal red team; L4: Machine-readable marking of generated media (Art. 50)

The largest split is classic against generative. Classic models fail quietly, through calibration, drift and group error gaps; generative models fail loudly, through content. Proprietary against open-weight is mostly a question of who produces the evidence: with an API you collect it from the vendor (model card, AIBOM if offered, change notices), with open weights you produce almost all of it yourself (hashes, scans, evals, red-team results, runtime logs; see [third-party and procured AI](#)).

Where it runs

Where it runs	Dominant failure modes	Controls it adds (layer)
Cloud (managed service or API)	Data leaves your boundary; provider outage; inference routed to the wrong region.	L1: Residency and data-class policy as code; L4: Egress and region enforcement on the inference path; L5: Provider attestations and sub-processor list collected and dated
On-premise (your data centre or private cloud)	You own patching, capacity and physical security; updates lag.	L4: Network segmentation and access control on the weights; L2: AIBOM with file hashes for every deployed artefact; L5: Your own tamper-evident logs
Edge (device, vehicle, branch)	Tampering; extraction of weights; stale versions in the field; no central log.	L2: Signed model artefacts and a registry of field versions; L4: Secure boot, device attestation, remote rollback and remote disable; L5: Sampled telemetry that reaches the evidence store
Hybrid (split by data class or load)	Policy gaps at the boundary; sensitive data routed to the wrong tier; inconsistent versions.	L1: Routing policy by data class, evaluated on every request; L2: One registry entry spanning every tier and its versions

How it is adapted

Adaptation	Dominant failure modes	Controls it adds (layer)	Role effect
As is (prompting only)	Model not fitted to your task or population; the vendor changes it underneath you.	L3: Validation against your own thresholds before go-live; L4: Compensating guardrails for the gaps the validation found; L2: System prompt versioned with the registry entry	Deployer, unless you rebrand it or change its intended purpose (Art. 25(1)(a), (c)).
Fine-tune	Safety training eroded; tuning data memorised; new biases.	L3: Treat the result as a new system: full eval and red team again; L2: Data card for the tuning set; AIBOM links base model and tuned weights; L1: Compute log checked against the GPAI modification criterion	Can be a substantial modification of a high-risk system (Art. 25(1)(b)) or make you the provider of a modified GPAI model.
Retrieval-augmented generation (RAG)	Retrieval poisoning; stale or unlicensed corpus; answers that leak documents across users.	L4: Corpus access control that mirrors the source system's permissions; L3: Groundedness eval against a corpus snapshot; L2: Corpus provenance and licence recorded in the AIBOM	Usually leaves the role unchanged.
Distillation, quantisation, LoRA adapters	Silent quality or safety regression; shifted error rates between groups; adapter sprawl.	L3: Re-run the eval gate and red team on the compressed artefact; L2: Register every adapter and quantised build as its own version	Distilling or adapting a GPAI model is a modification: check it against the compute criterion (verify).
Agentic wrapper (tools, actions)	Tool misuse; goal hijack; privilege abuse; actions that cascade.	L4: Agent identity, scoped credentials, tool mediation and a tested kill switch; L2: Agent registry entry with owner, scope and expiry; L4: Human-in-the-loop gate on high-consequence actions	Changes the risk more than the role: autonomy is the risk multiplier.

The model-type by deployment-option matrix

Read each cell as the one control the combination adds on top of its row and its column.

Model type	Cloud	On-premise	Edge	Fine-tune	RAG	Agentic wrapper
Classic predictive	Residency check on features; input drift monitor	Own the retraining pipeline and its approval	Signed model; field-version telemetry; remote rollback	Retrain is a release: re-run per-group floors	Not typical; govern feature-store lineage instead	Score triggers an action: human gate on adverse outcomes
Generative, language	No-training and retention terms; output guardrail	Own guardrails, patching and energy metering	Small model; offline guardrails; signed updates	Full red team; safety-erosion eval	Groundedness eval; corpus permissions; poisoning checks	Agent identity, tool mediation, kill switch
Generative, multimodal	Provenance marks on output; biometric-use block	Own content signing; media retention rules	Camera and microphone notices; on-device minimisation	Likeness and consent checks on tuning media	Cross-modal injection tests on retrieved media	Screen and voice actions behind a human gate
Proprietary (API)	Pin the version; boundary evals on every change	Vendor appliance: attest version and update path	Vendor SDK: licence limits; offline revocation	Vendor tuning service: data terms; your own re-eval	Your corpus, their model: retention and no-training terms	Grant scoped tools; the vendor agent gets its own identity

Model type	Cloud	On-premise	Edge	Fine-tune	RAG	Agentic wrapper
Open-weight	Licence gate; hash-verified weights on rented compute	You own patching: AIBOM, file scans, red team	Weights are extractable: licence terms and threat model	Compute log against the GPAI one-third criterion	Every layer of evidence is yours to produce	Own guardrails end to end; no vendor safety layer

Build, buy or adapt

Three routes, three evidence burdens

Route	What you control	Evidence you produce	Evidence you collect	Typical role
Buy (SaaS, API)	Integration, prompts, identities, the traffic you send	Boundary evals; runtime logs of your traffic	Model card, instructions for use, certifications, change notices	Deployer
Adapt (fine-tune, RAG, agentic wrapper)	The adaptation and everything around it	Evals of the adapted system; tuning data card; compute log	Base model documentation and licence	Deployer; provider if an Art. 25 trigger or the GPAI criterion applies
Build (own model)	Everything	Everything	Licences for third-party data and components	Provider and deployer

The less of the model you own, the more of your control budget moves from testing it to bounding it and evidencing the supplier; the more you own, the more of the evidence is yours to produce.

When a deployer becomes a provider

Article 25(1) makes a distributor, importer, deployer or other third party the provider of a high-risk AI system, with the provider's obligations, when it puts its name or trademark on a high-risk system already on the market; makes a substantial modification to a high-risk system so that it remains high-risk; or changes the intended purpose of a system, including a general-purpose one, so that it becomes high-risk [15]. A **substantial modification** is a change not foreseen in the provider's initial conformity assessment that affects compliance with the high-risk requirements or changes the intended purpose [2]. The initial provider then stops being the provider of that system but must cooperate; the Omnibus extended that duty to cover technical documentation, known limitations and failure modes, and targeted technical access for testing and validation [8].

General-purpose models have their own test. The Commission's guidelines on GPAI obligations (content approved on 18 July 2025, adopted as C(2025) 7719 final on 19 November 2025) [16] treat an actor that modifies or fine-tunes a GPAI model as the provider of the modified model only in exceptional cases, with an indicative criterion: the modification uses more than one third of the original model's training compute. The documentation, copyright-policy and training-summary obligations then cover the modification, not the whole model [17]; where the original model has systemic risk, the guidelines presume the modified model has it too, with the full systemic-risk duties [16]. The criterion is indicative, and how it applies to distillation or repeated adapter training is a question to put to counsel (verify). The engineering consequence is plain either way: log the compute of every fine-tune as an artefact, because the question will be asked.

Trigger	How it happens in practice	Detection	Artefact
Name or trademark (Art. 25(1)(a))	White-labelling a vendor's high-risk system	Brand check in the release checklist	Role decision in the registry entry
Substantial modification (Art. 25(1)(b))	Retraining, new data sources, thresholds moved beyond the provider's pre-determined changes	Change classification in CI against the pre-determined changes in the instructions for use [18]	Change record
Changed intended purpose (Art. 25(1)(c))	A general assistant put to work on hiring or credit	Intake; the downstream use register	Re-classification; amended DDR
GPAI modification	Fine-tuning a GPAI model with more than a third of its original training compute	Compute log	Compute estimate filed with the AIBOM

Open-weight licences

Open weights are not one licence, and "open weight" is not "open source". Each family asks something different of a deployer:

Family	Examples	What it asks of you	Watch for
Permissive	Apache 2.0, MIT, BSD	Keep notices and the licence text; Apache 2.0 adds an express patent grant.	The model licence may be permissive while its training data or a dataset licence is not.

Family	Examples	What it asks of you	Watch for
Copyleft	GPL family	Distributing a derivative requires releasing it under the same licence.	Applies to code in the serving stack as much as to the model; distribution is the trigger.
Network copyleft	AGPL 3.0	Users interacting over a network with a modified version must be offered its source.	Serving a modified component behind an API can trigger the source offer.
Responsible-AI licence (use-restricted)	OpenRAIL family	Open access with listed prohibited uses that must be passed on to every downstream user and derivative.	Use restrictions travel with the model: your terms of use must carry them.
Custom community licence	Vendor "community" licences for open-weight models	Acceptable-use policy incorporated by reference; attribution or naming duties; scale thresholds above which a separate licence is needed.	Thresholds and policies differ per model version; naming rules can apply to derivatives you publish.
Non-commercial or research-only	CC BY-NC family; research licences	No commercial use.	A research-only dataset or model inside a commercial product is a breach, whoever added it.

Three examples show the range. Apache 2.0 adds an express patent grant to its permissions [19]. The AGPL requires that users interacting with a modified version over a network be offered its source [20], which reaches serving stacks. OpenRAIL-style licences grant open access but attach use restrictions that must pass to every derivative and redistribution [21]. Custom community licences go further: the Llama 3.1 licence incorporates an acceptable-use policy, requires "Built with Llama" attribution, asks that derived models distributed to others carry "Llama" at the start of their name, and requires licensees whose products had more than 700 million monthly active users on the release date to request a separate licence [22]. The controls follow: a licence check as a policy gate (layer 01), licence, acceptable-use version and file hash in the **AIBOM** (layer 02), hash verification of every weight file before load, and a [scan of serialised model files](#) before they reach a runtime. The full clause and licence checklist is on the [contracts page](#).

Owning the model: the upside and the burden

Building or heavily adapting your own model buys control: over versions and retirement dates, over customisation, over where data lives, and over the evidence itself, since you can red-team weights you hold. It also buys the provider's burden if you place the system on the market, and three operational risks that API customers mostly rent away. **Weight security**: the weights are an asset to protect, from theft of the files and from extraction through the inference API, which NIST's taxonomy of adversarial attacks and MITRE ATLAS both catalogue [23][24]; rate limits, query-pattern monitoring and least-privilege access to weight storage are the controls. **Maintenance**: patching, re-validation and base-model upgrades become your calendar. **Key-person risk**: a model only two people can retrain is a continuity risk with names attached.

Liability, insurance and risk transfer

The new Product Liability Directive brings software, including AI systems, within the definition of a product; Member States must transpose it by 9 December 2026, and it applies to products placed on the market after that date [25]. For builders that place systems on the market, defect liability becomes a design input; for deployers, the contract decides what recourse they have against the supplier. A market for AI-specific insurance exists, including cover for losses from model errors offered to AI vendors and to the organisations that deploy their systems [26]. Check existing cyber, technology errors-and-omissions and liability policies for AI exclusions with your broker before assuming cover. Where an insurer asks for evidence of controls, the underwriting questionnaire becomes one more consumer of the assurance store. And risk transferred is not risk reduced: the residual risk left after caps, exclusions and deductibles belongs in the risk register (see [chapter 13](#)).

Vendor contracts and licence terms

When you deploy a system you did not build, the contract is a control surface, and the place where the organisation's [third-party AI policy](#) (chapter 12) becomes enforceable. It decides whether you may test the system, whether you hear when it changes, where your data goes and how you leave. The AI Act requires a written agreement between the provider of a high-risk system and third parties that supply its components, tools and services, specifying the information, capabilities, technical access and assistance the provider needs [15]. For buyers, the EU model contractual clauses for AI procurement (MCC-AI), updated on 5 March 2025 in a high-risk and a light version with a commentary, give a reference text drafted for public organisations; it is the latest version as of 2026-09-24 [27]. ISO/IEC 42001 Annex A.10 and the NIST AI RMF (GOVERN 6, MANAGE 3) name the third-party controls the clauses support [28][29][30].

The clauses that matter most for governance, with the red flag to look for and the evidence to keep (the fallback position for each is on the [contracts page](#)):

Clause	Red flag	Evidence to keep
Use of your data for training	Training use is on by default, allowed for "service improvement", or controlled by a setting the supplier can change.	The clause, the account or API setting captured at go-live, and a periodic re-check of that setting.
Rights in inputs and outputs	The supplier takes a licence to your inputs beyond providing the service, or reserves rights in outputs.	The clause, referenced from the registry entry of each system that uses the supplier.
Retention and deletion	Retention "as long as necessary" with no number, or abuse-monitoring retention you cannot shorten or see.	Retention terms per data type; deletion confirmations; your own log-retention schedule that meets Art. 26(6).
Sub-processors and upstream model providers	A sub-processor list that is not published, or changes with no notice and no right to object.	Dated snapshots of the sub-processor list; objection decisions.
Data residency and transfers	A region commitment for storage only, while inference or support may run anywhere.	Residency policy verdicts from the inference path; the transfer assessment.
Documentation and instructions for use	Documentation "available on request" or limited to marketing material.	Versioned copies attached to the registry entry.
Audit and evaluation access	Audit only by reading the supplier's own summary; testing, benchmarking or security research prohibited.	Reports received; your boundary eval results; the agreed test windows.
Change notice, version pinning and deprecation	Models may be "updated or improved at any time"; deprecation notice shorter than your re-validation cycle.	Change notices filed against the registry entry; re-validation results per version.
Incident and vulnerability notification	Notice "without undue delay" with no hours, or limited to personal-data breaches.	The SLA; notices received and their timestamps; your incident records that cite them.
Availability, latency and rate limits	Service credits as the only remedy for an outage that halts a critical process.	SLA reports; your own availability monitoring; continuity tests.
IP indemnity	Indemnity excluded when you modify prompts, use filters differently or combine outputs.	Proof that you met the indemnity conditions (filters on, documented use), kept as logs.
Performance warranties and output disclaimers	Blanket disclaimers of accuracy with no documented performance at all.	The documented performance, compared with your own evals.
Liability caps and exclusions	A cap set at a few months of fees, with data, IP and regulatory losses all excluded.	The cap and carve-outs, recorded as residual risk in the risk register.
Supplier acceptable-use policy	A policy incorporated by reference that the supplier can change unilaterally.	The policy version checked at go-live, mapped to your own prohibited-use list.
Role allocation and regulatory cooperation	Silence on AI Act roles, or a clause that shifts provider duties to you without the access to meet them.	The role decision recorded in the registry entry, with the clause that supports it.
Security controls and certifications	Certifications that exclude the AI service from their scope.	Certificates with their scope statements; red-team summaries.
Termination assistance, portability and exit	No transition period; fine-tuned weights or adapters belong to the supplier; export only in proprietary formats.	An exit plan and the record of an exit drill.
Insurance	No insurance clause, or cover that excludes AI-related claims.	Certificates of insurance, dated and filed with the contract.

Two rules turn the table into governance. First, a clause that matters at runtime must become a check: the no-training setting read back from the account, the residency commitment enforced on the inference path, the version pin held in the registry. A clause nothing checks is a hope. Second, the review is one step of the [Vendor / Model Due-Diligence Gate](#), so it re-opens on renewal and on every material change notice. The dataset behind this table, with the risk each clause addresses, a fallback position and the instruments it maps to, is an engineering checklist, not legal advice.

Example (illustrative) A supplier's terms allowed 60 days' notice before retiring a model version. The deployer's re-validation cycle (selection eval, red team, canary) took about 90 days. The gap was recorded as a risk, negotiated to a 120-day deprecation window at renewal, and in the meantime covered by keeping a second candidate model warm in the eval harness.

The go-live review

What the review reads

The go-live review reads an evidence pack, not a slide deck: the DDR; the model selection record; eval gate results against the floors; the red-team summary; the impact assessments (a FRIA where Article 27 applies, a DPIA where data protection law requires one, both maintained as in the [FRIA-as-Code](#) pattern); the contract review; the monitoring plan with named owners; the rollout plan with its rollback criteria; the communications plan; and the deactivation runbook. When the evidence is the provider's own (its instructions for use, which must state the system's capabilities, limitations, oversight measures and maintenance needs [18]), the review runs in **review mode**: it assesses the supplier's assessment and records, explicitly, what the deployer could not verify. On the provider side, the same evidence came out of [release readiness and conformity](#) (chapter 14).

Three outcomes

Outcome	Meaning	What is recorded	What the pipeline does
Approve	The evidence meets the floors	Decision, approver, residual risk and who accepted it	The rollout plan starts at its first stage
Approve with conditions	Proceed only while named conditions hold	Each condition with an owner, a deadline and the check that verifies it	Conditions become policy: a flag caps exposure, and the approval carries an expiry
Reject	The evidence does not support deployment	The reasons and what would change the answer	The deploy is blocked; the registry status reads <code>rejected</code>

An approval with conditions is where governance most often turns into theatre, because conditions are easy to grant and easy to forget. Make them code: each condition is a check with a deadline, and if the check has not passed by then the approval lapses and the feature flag closes. Residual risk is accepted by an authority that matches the risk tier, never by the team that wants to ship.

Recorded dissent

Any member of the review can record dissent. The dissent is attached to the decision record, named, and reviewed at the first monitoring review after go-live. It costs nothing when the dissenter is wrong, and when they are right it answers the first question every incident review asks: did anyone see this coming?

In practice (illustrative) The go-live review for `csa-01` approved it with two conditions: a groundedness floor on the refunds topic, re-measured after four weeks of live traffic, and a Spanish-language red team before the assistant served Spanish speakers. Both became flags. The security lead recorded dissent on the tool scope for order lookups. The four-week check passed; the red team did not, so Spanish stayed behind its flag until a fix shipped, and the dissent was closed with a narrowed scope.

Progressive delivery as a control

Progressive delivery limits exposure while evidence accumulates. Each stage is a gate with a criterion set in advance; the stages are borrowed from site reliability engineering, where canarying is defined as a partial, time-limited deployment of a change and its evaluation [31].

Stage	What it is	What it proves	Rollback criterion (set before the stage starts)	Evidence
Shadow	The new system sees live inputs; its outputs are not used	Behaviour on real traffic without exposure	Disagreement with the incumbent or with human decisions above a threshold	Paired outputs; disagreement log
Pilot	A small, informed group of users	Usability; oversight works; the workforce is ready	Override rate or complaint rate above a threshold	Pilot report; feedback log
Canary	A small share of production traffic, compared with a control group [31]	No regression at scale	Any floor breached against the control	Per-metric canary analysis
Blue-green	Two production environments; traffic switches between them [32]	A tested, instant path back	Any severity-1 event	Switch events
Feature flags	Runtime toggles per cohort, region or function, including operational kill switches [33]	Exposure is controllable without a deploy	Set per flag	Flag change log
Version pinning	The registry pins model, prompt, corpus and guardrail versions	What ran is known	An unpinned change is detected	Registry diff

Rollback criteria must be **pre-registered**: written into the [rollout plan](#) before the stage starts, and evaluated by the pipeline, not by a meeting. A criterion invented after the metric moved is a negotiation, not a control. The same applies to changes you did not

make: a new vendor model version is a release, and it goes through shadow and canary on your side against the pinned version before it takes traffic. The tools catalogue lists [progressive-delivery tools](#) as illustrative examples, not endorsements.

Operating the system

Policies at go-live

The system goes live with the policies that make its use governable. An **acceptable-use policy** for staff and customers, drawn from the negative space. **Role-based training**: what the system is for, the limitations its instructions for use declare [18], when to override it and how to report a problem, with completion as a condition of access. **Interface aids** that support judgement rather than replace it: sources shown, confidence where it is meaningful, and a visible way to reach a person. These are the practical form of the Article 26 duties to use the system as instructed and to give oversight to competent people with authority [1], and of the responsible-use controls in ISO/IEC 42001 Annex A.9 [28]. Oversight itself is designed as in [designing human oversight](#).

Inference-time data governance

Live inputs are data processing, and a deployed system creates new data with every request: prompts, retrieved passages, outputs, logs and feedback. Govern them as you govern training data (see [data governance across the stack](#)):

- **Minimise** what reaches the model, with PII filtering and data-loss prevention in the input [guardrail](#).
- **Set retention per data type** as code, reconciling the log-retention floor below with the storage-limitation ceiling of data protection law.
- **Re-check the lawful basis** when the purpose changes; a new use of old logs is a new processing purpose.
- **Map transfers** when inference, storage or support run in another jurisdiction; chapter 19 treats [remote inference as a transfer](#).
- **Plan for data-subject requests** that reach prompts, logs, retrieval corpora and fine-tuned weights. Deleting a record from a corpus is a delete; removing its influence from tuned weights may mean retraining, so decide before you tune on personal data. Deployers of high-risk systems use the provider's information to carry out their DPIA [1]; [chapter 19](#) covers the privacy side in depth.

Maintenance calendar and retraining governance

The provider's instructions for use state the system's expected lifetime and the maintenance it needs, including how often [18]. The deployer's calendar starts there and adds its own:

Cadence	Activity	Artefact	Layer
Continuous	Drift, fairness, quality, cost and energy signals against thresholds	Monitoring telemetry	4 · 5
Weekly	Triage issues and near misses; review override and complaint trends	Issue log	5
Monthly	Vendor change notices, sub-processor changes, SLA reports	Third-party review record	2 · 5
Quarterly	Threshold review; red team on current versions; card and registry refresh	Updated cards; red-team results	2 · 3
Yearly (or per risk tier)	Impact re-assessment; benefit review; licence and dependency refresh; deactivation drill	Re-assessment; drill record	1 · 2 · 4
On an event	New population, jurisdiction, autonomy level or vendor version; an incident	Re-assessment trigger record	1 · 2

Retraining governance rests on one rule: a retrain, a fine-tune, a prompt change, a corpus refresh and a vendor model update are all releases. Each goes through the eval gate and the progressive delivery stages, and each bumps the version in the registry. A threshold change is a change to a control, so it is a reviewed diff with an approver, not an edit on a dashboard. Retraining is triggered by a drift or floor breach, by the calendar, or by a change in the world the DDR describes. The tools catalogue lists [monitoring tools](#) as illustrative examples, not endorsements.

Drift: what moves and how to see it

Concept drift is an unforeseeable change in the distribution of the data a model sees over time, and the research on it divides the work into detection, understanding and adaptation [34]. In production it helps to name what moved:

Drift	What changes	Example (illustrative)	How to detect it
Data (covariate)	The input distribution	A new product line changes the questions customers ask	Population Stability Index or a Kolmogorov-Smirnov test on features or embeddings against a reference window
Label (prior)	The base rate of the outcome	Fraud rate rises in a season	Predicted against observed positive rate
Concept	The relationship between input and outcome	Same symptoms, new treatment guidance	Performance on fresh labels; change-point detection on the error rate
Pipeline	An upstream feature, schema or retrieval step	A schema change empties a field	Data contracts; null-rate and freshness monitors

Drift	What changes	Example (illustrative)	How to detect it
Vendor model	The model behind the API	The provider ships a new version	Version-pin check; canary against the pinned baseline
Usage	Who uses the system, and for what	Staff start using the assistant for HR questions	Topic classification of traffic against the negative space

Labels often arrive late, or never. For classic models, pair input-drift statistics with a delayed performance check when labels land; for generative systems, sample outputs for groundedness scoring and human review. Every [drift signal](#) needs a threshold, an owner and a defined consequence: an issue, a retrain, a degraded mode or an incident.

Fairness and quality in production

A system that passed its [fairness evals](#) at go-live can drift into unfairness without any code change. Monitor error rates per group against the per-group floors in the DDR, complaint and appeal rates by group, and, for generative systems, groundedness and refusal rates by topic and language. Where law requires a periodic bias audit (New York City's Local Law 144, for example, requires a bias audit within one year before an automated employment decision tool is used, and a public summary of its results [35]), the production telemetry is what makes the audit cheap. [Chapter 16](#) covers the metrics; the point here is that they run continuously and feed the same threshold, issue and incident path as every other signal.

Who owns the signal

Signal	Watches (responsible)	Decides (accountable)	Consulted	Informed	Escalates to
Performance and drift	ML platform on-call	System owner	AI governance engineer	Risk	Go-live panel if a floor is breached
Fairness	AI governance engineer	System owner	Legal; representatives of affected groups	DPO	Risk committee
Security and abuse	Security operations	Security lead	AI governance engineer	System owner	Incident pipeline
Compliance obligations	AI governance engineer	Compliance lead	Legal	Regulator liaison	Incident pipeline; communications owner
Cost, energy and benefit	FinOps	Business owner	Sustainability lead	Finance	Benefit review

The rule is the one from [chapter 06](#): you own a signal when you can be paged for it. A critical system needs coverage for every hour it runs, and a signal with no owner is a signal nobody acts on.

Monitoring third parties while you run

A procured system keeps changing after the contract is signed. File every change and deprecation notice against the registry entry, read the SLA reports, snapshot the sub-processor list, and re-open the due-diligence gate on renewal. Keep an alternative model warm in the eval harness so a forced migration starts from evidence, not from a standing start. The NIST AI RMF asks for exactly this: third-party risks and benefits monitored regularly, and pre-trained models monitored as part of the system's own maintenance [30]. The [operate step of the due-diligence gate](#) turns this into a runbook.

When the provider fails: continuity

Plan for the supplier failing in each of the ways it can: an outage, a rate limit at peak, a quality drop, a withdrawn model, a forced deprecation, or a commercial or legal exit. The fallbacks are a manual process that staff have practised, an alternative model behind the same interface, cached or templated answers, and the degraded modes described below. Recovery needs its own evidence: back up the corpus snapshot and the embeddings, or know that you can rebuild the index; keep the prompts and guardrail configurations under version control; and test the switch. The NIST AI RMF asks for contingency processes for failures in third-party AI systems deemed high-risk [29].

Some sectors make this a legal duty. Financial entities under DORA, in application since 17 January 2025 [36], must keep a register of information on all contractual arrangements for ICT services from third-party providers, and must have exit strategies for ICT services that support critical or important functions [37]. An AI model reached as a service is likely to count as an ICT service for this purpose (verify for your case). Entities in scope of NIS2 must take measures for business continuity, including backup management and disaster recovery, and for supply-chain security [38]; whether you are in scope depends on your sector and size (verify).

Benefit realisation

Track the objective in the DDR against what the system delivers, including its inference and operating cost. Under-delivery is a governance signal, not only a business one: a system that costs more to run and govern than it returns is a candidate for re-

scoping or retirement, and the benefit review is where that is decided on evidence. A register of live systems with no measured benefit is an inventory of unpriced risk.

Energy footprint reporting

Measure energy per request and in total, with the boundary stated: accelerators, host systems, idle capacity and data-centre overhead [12]. On your own hardware, meter it; on a provider's, ask for it in the contract and record what you received. Convert to carbon with the grid intensity of the region that serves the traffic, report it next to cost in the benefit review, and let it inform the next model choice: when a smaller model passes the selection eval, the energy difference is a reason to prefer it [11].

Records retention

Record	Kept by	Minimum	Source
Logs automatically generated by a high-risk system, to the extent under the deployer's control	Deployer	At least six months, unless other law says otherwise	Art. 26(6) [1]
The same logs, under the provider's control	Provider	At least six months	Art. 19(1) [39]
Technical and quality-management documentation, declaration of conformity	Provider	10 years after placing on the market	Art. 18(1) [40]
DDR, go-live decision, conditions and dissent	Deployer	The life of the system plus the limitation period counsel sets	Practice
Operator logs under China's voluntary TC260 framework 3.0	Operator	At least six months, with audit	\$5.3 [41]

Retention is a control, so it is code: a schedule per record type, tamper-evident storage for logs, a legal hold that overrides deletion, and archive formats someone can still read in 10 years. The six-month floor for logs is a minimum; data protection law sets a ceiling for the personal data inside them, and the two are reconciled per data type, not by keeping everything.

Periodic assurance

An audit programme, not an audit

A single audit is a snapshot. An audit programme has a charter, a risk-based cadence tied to the risk tier, and independence proportionate to the stakes: second-line review, internal audit, or an external assessor (see [how this relates to certification](#)). Good programmes re-perform rather than read: the auditor re-runs a fairness check or replays a sample of logs instead of accepting the report that says it was done. Every finding gets an owner, a date and a closure test, and the open findings are a live query, not a spreadsheet.

Red teaming on a schedule

Schedule red teaming by risk tier, and aim it at the deployed configuration (prompts, tools, retrieval corpus, guardrails), not only at the model. For a procured system, test at the boundary within the windows the contract allows. The [Adversarial Red-Team Suite](#) pattern turns each finding into a regression test, so the next scheduled run proves the fix held.

Threat modelling the deployed system

Decompose the data flows (user, application, retrieval, model, tools, downstream consumers), then enumerate threats per element with a classic category checklist such as STRIDE, extended with the AI-specific attacks that NIST's adversarial machine learning taxonomy [23], MITRE ATLAS [24] and the OWASP Top 10 for Agentic Applications [42] catalogue. The output that matters is the mapping from threat to mitigation to the test that proves the mitigation works:

Threat	Where it enters	Mitigation	The test that proves it
Indirect prompt injection	Retrieved documents, tool outputs	Input guardrail; narrow tool scope	Red-team cases with planted instructions
Retrieval poisoning	Corpus ingestion	Source allow-list; provenance in the AIBOM	Canary documents that must never be retrieved
Model extraction	Inference API	Rate limits; query-pattern detection	Extraction probe against the limits
Membership inference, inversion	A model tuned on personal data	Minimise personal data in tuning; output filtering	Privacy attack suite on the tuned model
Tampered weights	Supply chain	Hash and signature verification	The pipeline fails on a hash mismatch
Tool misuse	Agent actions	Scoped credentials; human gate on high-consequence actions	Scope and kill-switch tests

The site's [threat bridge](#) lines up these threats with the patterns that control them.

Secondary use and downstream harm

Systems are used for more than they were approved for. The AI Act names the concept: **reasonably foreseeable misuse** is use not in accordance with the intended purpose, but which may result from reasonably foreseeable human behaviour or interaction with other systems [2]. Around it sit **function creep** (the gradual extension of a system to purposes no one approved), **dual use** (the same capability serving a harmful purpose), **downstream harm** (outputs feeding other systems that act on them), **feedback loops** (outputs shaping the data the next version learns from, as when a risk score decides who is inspected and so decides which cases get labelled) and **synthetic recycling** (generated outputs reused as training data).

Forecast them before go-live with three cheap techniques. A **premortem**: assume it is a year later and the system caused harm, then write down how. **Abuse cases**: misuse stories written next to the user stories, by people paid to think like the abuser.

Stakeholder impact mapping: every group the outputs reach, including those who never touch the interface.

Then give the answers a home, which this chapter calls a **downstream use register**: intended and prohibited uses written as a **Policy Card**; every consumer of the outputs (systems, teams, partners) recorded against the registry entry; provenance and caveats stamped on outputs so a consumer knows what it is using; and a re-test whenever outputs are used in a new context. At runtime, off-purpose use is a signal like any other: classify traffic against the negative space and alert on what falls outside it. Consumer-facing deployments add one more question, whether children or other vulnerable people will use the system, with age assurance and the Article 5 prohibition on exploiting vulnerabilities as the controls to consider [6].

External communications

Every deployed system needs a plan for talking to people outside the organisation, written before it is needed. The plan names one owner and a single voice, an approval workflow, and a single source of truth: a transparency page and a plain-language system card **generated from the registry**, so what you say publicly cannot drift from what is running. Templates are versioned like code. The NIST AI RMF asks that incidents and errors be communicated to relevant AI actors, including affected communities [30].

Audience	Proactive	Reactive trigger	Clock	Template
Market-surveillance authority	Registration where required (public-authority deployers) [1]	Reason to consider the system presents a risk: inform the provider or distributor and the authority, and suspend use [1]	Without undue delay	Pre-filled risk notice
Provider, then authority	None	A serious incident: inform the provider first, then the importer or distributor and the authorities [1]	Immediately; the provider's own reporting clocks follow (see chapter 08)	Serious-incident notice
Data protection authority	DPIA where required	A personal data breach	Within 72 hours where feasible [43]	Breach notification
Users and affected people	AI disclosure [5]; notice to people subject to Annex III decisions [1]; explanation on request [7]	A breach likely to cause high risk to them [44]; a material change; a correction	Without undue delay	Notices; correction notice
Workers and their representatives	Information before use at work [1]	A change of scope	Before use	Briefing pack
Business customers and partners	Change log; model card and AIBOM updates	An incident affecting them; a deprecation	As the contract sets	Customer notice
Media and public	Transparency page; system card	An incident with public impact	Holding statement first, facts as confirmed	Holding statement; Q&A

A **holding statement** is prepared in skeleton before any incident: what happened, stated only as far as it is known; what has been done to contain it; what affected people should do; and when the next update will come. It never speculates about cause. The incident side of communication is developed in [chapter 17](#). At retirement, the same plan sends the sunset notices. And measure the plan: whether notices reached the people they were for, and what the complaint volume did afterwards.

Deactivation, degradation, localisation and retirement

A deactivation policy someone can execute

A **deactivation policy** names its triggers, its decision authority, the record each decision leaves, how evidence is preserved and the criteria for a safe restart. Triggers come in two kinds. Threshold triggers: a floor breached and not recovered within a set window, a fairness gap above its limit, an incident severity. Legal triggers: the deployer's own duty to suspend use when it has reason to consider the system presents a risk [1]; a provider's corrective action to withdraw, disable or recall a non-conforming system [45]; action by an authority on an AI system presenting a risk to health, safety or fundamental rights [46]; and a practice newly

prohibited. The NIST AI RMF asks for mechanisms, with assigned responsibilities, to supersede, disengage or deactivate systems whose performance or outcomes are inconsistent with intended use [30].

Evidence preservation comes first: freeze the logs, apply a legal hold, snapshot the versions. Then stop. Deactivation applies to every kind of system, not only agents: a classifier embedded in a vendor product needs a switch too, whether a feature flag or a fallback path. For agents, the [Kill Switch / Circuit Breaker](#) pattern applies, and [chapter 23](#) develops it.

Graduated degradation

Switching off is the last resort, not the only one. Build the intermediate modes in advance as operational toggles [33], and test them:

Mode	What changes	Use it when
Advice-only	Output goes to a person; the system never acts or decides alone	Doubt about accuracy or fairness; the action is what carries risk
Raised thresholds	The system abstains below a higher confidence and routes to a person	Drift detected; labels pending
Grounded-only	Answers only with a retrieved source; otherwise it refuses	Hallucination rate rising
Scoped off	Disabled for one group, language, region or function	Harm concentrated in one segment
Back to pilot	Exposure returns to the pilot cohort	Broad regression with an unknown cause
Off	The fallback process takes over	Legal trigger; severe harm

Localisation by jurisdiction

Launch only where compliance has been shown, and keep the jurisdiction as a policy input rather than a deployment accident: per-jurisdiction rule sets as code, regional instances where residency requires them, and feature flags by region so one market can be switched off without touching the others. Obligations overlap in places (the AI Act's six-month log floor and the six-month operator log retention in China's voluntary TC260 framework [1][41]) and diverge in many others; see [chapter 21](#) and the [regulatory map](#).

Retirement and decommissioning

Design retirement in from the start: the DDR already names the conditions under which the system is retired. Triggers include a benefit shortfall, a vendor deprecation, a replacement and a legal event. The NIST AI RMF warns that irregular or indiscriminate termination can itself increase risk [29], so retirement is a runbook, not a deletion:

1. **Dependency analysis.** Who consumes the outputs? The [downstream use register](#) answers it.
2. **Fallback and transition.** Users move to the replacement or the manual process, with training.
3. **Sunset notices.** Customers, partners and affected people hear before the date, not after.
4. **Final evidence snapshot.** Cards, evals, decisions and logs are archived per the retention schedule.
5. **Archive or dispose.** Weights, corpora and logs are kept or destroyed as licence, lawful basis and retention decide.
6. **Revoke identities and credentials.** Every non-human identity the system held is revoked.
7. **Retire, do not delete, the registry entry.** Its status reads `retired`, with the date and the decision record.
8. **Confirm it is gone.** [Shadow-AI Discovery](#) checks that no copy still runs.

One system from decision to retirement

`csa-01`, the assistant that [chapter 04](#) follows through the five layers, also runs through this chapter. The artefacts it leaves, all illustrative:

Stage	Artefact	Layer
Decide	<code>ddr-csa-01-v1</code> , with its negative space and floors	1 · 2
Choose	Selection eval across three candidates; energy estimate per 1,000 requests	3
Contract	Clause review; no-training setting read back weekly	1 · 5
Go live	Approved with two conditions and one dissent	1 · 5
Roll out	Shadow, then canary with pre-registered rollback on groundedness	4
Operate	Usage-drift alert on HR topics; vendor version change passed canary	4 · 5
Assure	Quarterly red team; findings closed as regression tests	3 · 5
Retire	Retirement conditions in the DDR; runbook drilled once a year	2 · 4

Maps to: EU AI Act Art. 4, 5, 13, 25, 26, 27, 50, 86 · GDPR Art. 33, 34, 35 · ISO/IEC 42001 Annex A.6.2.5, A.6.2.6, A.9, A.10 · NIST AI RMF (GOVERN 1.7, GOVERN 6, MANAGE 2.4, MANAGE 3, MANAGE 4) · DORA Art. 28 · NIS2 Art. 21 · all five layers. Mappings are illustrative, not a claim of conformity.

What you can do this week

1. **Write the DDR for your riskiest live system**, retroactively if you must, including its negative space and retirement conditions, and link it from the registry entry.
2. **Check five clauses in your largest AI contract**: use of your data for training, change and deprecation notice, incident notice, audit and evaluation access, and exit. File each gap as a risk.
3. **Pre-register the rollback criteria** for your next model, prompt or vendor-version change, and wire one of them as an automatic canary check.
4. **Compare log retention** on every high-risk or likely high-risk system against the six-month floor and your data-protection ceiling.
5. **Build one degraded mode** (advice-only or grounded-only) behind a flag, and test that it works.

Sources

[1] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 26 (deployer obligations: 26(1) use per the instructions; 26(2) oversight by competent persons with authority; 26(4) relevant and representative input data; 26(5) monitor, suspend and inform, serious incidents to the provider first; 26(6) logs kept at least six months; 26(7) inform workers; 26(8) public-authority registration; 26(9) DPIA; 26(11) inform affected persons). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_26 (verified: primary) [2] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 3 definitions: (3) provider, (4) deployer, (12) intended purpose, (13) reasonably foreseeable misuse, (23) substantial modification. Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_3 (verified: primary) [3] "AI Omnibus enters into force" (Reg. (EU) 2026/1744, in force 2026-07-27; Annex III high-risk rules from 2 Dec 2027; Annex I from 2 Aug 2028). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force> (verified: primary) [4] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 27(1) (FRIA before first use by public bodies, private entities providing public services and deployers of Annex III points 5(b) and (c)). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_27 (verified: primary) [5] "Safer and more transparent AI" (Art. 50 transparency obligations apply from 2 Aug 2026). European Commission. 2026-08-02. https://commission.europa.eu/news-and-media/news/safer-and-more-transparent-ai-2026-08-02_en (verified: primary) [6] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 5(1)(b) (prohibition on exploiting vulnerabilities due to age, disability or a specific social or economic situation; applies to placing on the market, putting into service and use). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_5 (verified: primary) [7] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 86(1) (right to a clear and meaningful explanation from the deployer of the role of an Annex III system in a decision, except point 2 systems). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_86 (verified: primary) [8] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, as amended by Regulation (EU) 2026/1744 (Art. 4 replaced: providers and deployers support AI literacy; Art. 25(2) cooperation extended to technical documentation, known limitations and failure modes and targeted technical access; Art. 25(4) revised; Art. 26 unchanged; Art. 111(4) transitional period for Art. 50(2) marking to 2 Dec 2026 for generative systems placed on the market before 2 Aug 2026). Publications Office of the EU (EUR-Lex). 2026-07-27. <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng> (verified: primary) [9] "A Careful Examination of Large Language Model Performance on Grade School Arithmetic" (GSM1k; accuracy drops of up to 8% against GSM8k; systematic overfitting in several model families) (arXiv 2405.00332). Zhang et al. 2024-05-01. <https://arxiv.org/abs/2405.00332> (verified: primary) [10] "The Leaderboard Illusion" (undisclosed private testing of multiple variants and score retraction on Chatbot Arena) (arXiv 2504.20879). Singh et al. 2025-04-29. <https://arxiv.org/abs/2504.20879> (verified: primary) [11] "Power Hungry Processing: Watts Driving the Cost of AI Deployment?" (multi-purpose generative architectures orders of magnitude more expensive per inference than task-specific systems, controlling for parameters) (arXiv 2311.16863; FAccT '24). Luccioni, Jernite, Strubell. 2023-11-28. <https://arxiv.org/abs/2311.16863> (verified: primary) [12] "Measuring the environmental impact of delivering AI at Google Scale" (median Gemini Apps text prompt 0.24 Wh; boundary includes host energy, idle capacity and data-centre overhead) (arXiv 2508.15734). Elsworth et al., Google. 2025-08-21. <https://arxiv.org/abs/2508.15734> (verified: primary) [13] Energy and AI, executive summary (data-centre electricity 415 TWh in 2024, around 945 TWh by 2030). International Energy Agency. 2025-04. <https://www.iea.org/reports/energy-and-ai/executive-summary> (verified: primary) [14] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Annex XI, Section 1, point 2(e) (GPAI technical documentation: known or estimated energy consumption of the model). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#ann_xi (verified: primary) [15] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 25 (value chain: 25(1)(a) name or trademark, (b) substantial modification, (c) changed intended purpose; 25(2) cooperation of the initial provider; 25(4) written agreement with third-party suppliers). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_25 (verified: primary) [16] Commission Guidelines on the scope of the obligations for providers of general-purpose AI models established by Regulation (EU) 2024/1689

(C(2025) 7719 final; content approved 18 Jul 2025; paras. 67 to 68: a modified systemic-risk model is presumed to have systemic risk). European Commission. 2025-11-19. <https://digital-strategy.ec.europa.eu/en/library/guidelines-scope-obligations-providers-general-purpose-ai-models-under-ai-act> (verified: primary) [17] Guidelines on obligations for general-purpose AI providers, FAQ (modifiers become providers only when the modification uses more than one third of the original model's training compute; obligations limited to documenting the modification). European Commission. 2025. <https://digital-strategy.ec.europa.eu/en/faqs/guidelines-obligations-general-purpose-ai-providers> (verified: primary) [18] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 13(3) (instructions for use: capabilities and limitations of performance; pre-determined changes; human oversight measures; expected lifetime and maintenance measures, including their frequency; log collection). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_13 (verified: primary) [19] Apache License, Version 2.0 (section 3, grant of patent licence). Apache Software Foundation. 2004-01. <https://www.apache.org/licenses/LICENSE-2.0> (verified: primary) [20] GNU Affero General Public License v3 (section 13, remote network interaction). Free Software Foundation. 2007-11-19. <https://www.gnu.org/licenses/agpl-3.0.html> (verified: primary) [21] "OpenRAIL: Towards open and responsible AI licensing frameworks" (use-based restrictions that must be adopted by redistributions and derivatives). Hugging Face. 2022-08-31. https://huggingface.co/blog/open_rail (verified: primary) [22] Llama 3.1 Community License Agreement (Acceptable Use Policy incorporated by reference; "Built with Llama" attribution; "Llama" at the start of distributed derived model names; separate licence above 700 million monthly active users on the release date). Meta. 2024-07-23. https://github.com/meta-llama/llama-models/blob/main/models/llama3_1/LICENSE (verified: primary) [23] NIST AI 100-2 E2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations. NIST. 2025-03. <https://csrc.nist.gov/pubs/ai/100/2/e2025/final> (verified: primary) [24] MITRE ATLAS: adversarial tactics and techniques knowledge base for AI systems. MITRE. 2026. <https://atlas.mitre.org/> (verified: primary) [25] Directive (EU) 2024/2853 on liability for defective products (software within the definition of product; transposition by 9 Dec 2026; applies to products placed on the market or put into service after that date). Publications Office of the EU (EUR-Lex). 2024-10-23. <https://eur-lex.europa.eu/eli/dir/2024/2853/oj/eng> (verified: primary) [26] aiSure AI insurance (cover for losses from AI model errors, for AI vendors and corporate adopters). Munich Re. 2026. <https://www.munichre.com/en/solutions/for-industry-clients/insure-ai.html> (verified: primary) [27] Updated EU AI model contractual clauses (MCC-AI high-risk and light versions, with commentary; update of the 2023 clauses). Community of Practice on Public Procurement of AI, Public Buyers Community (European Commission). 2025-03-05. <https://public-buyers-community.ec.europa.eu/communities/procurement-ai/resources/updated-eu-ai-model-contractual-clauses> (verified: primary) [28] ISO/IEC 42001:2023, Annex A control titles (A.6.2.5 AI system deployment; A.6.2.6 operation and monitoring; A.9 use of AI systems; A.10 third-party and customer relationships), referenced by identifier only. ISO/IEC (titles checked via a secondary listing). 2023. <https://www.iso.org/standard/42001> (verified: secondary) [29] NIST AI RMF Playbook, GOVERN (1.7 decommissioning and phasing out safely; 6.1 third-party risk policies; 6.2 contingency for failures in high-risk third-party systems). NIST. 2023. <https://airc.nist.gov/airmf-resources/playbook/govern/> (verified: primary) [30] NIST AI RMF Playbook, MANAGE (2.4 supersede, disengage or deactivate; 3.1 third-party risks monitored; 3.2 pre-trained models monitored; 4.1 post-deployment monitoring plans; 4.3 incidents communicated, including to affected communities). NIST. 2023. <https://airc.nist.gov/airmf-resources/playbook/manage/> (verified: primary) [31] The Site Reliability Workbook, ch. 16 "Canarying Releases" ("a partial and time-limited deployment of a change in a service and its evaluation"). Google (O'Reilly). 2018. <https://sre.google/workbook/canarying-releases/> (verified: primary) [32] "BlueGreenDeployment" (two identical production environments; switch back on failure). Martin Fowler. 2010-03-01. <https://martinfowler.com/bliki/BlueGreenDeployment.html> (verified: primary) [33] "Feature Toggles (aka Feature Flags)" (release, experiment, ops and permissioning toggles; ops kill switches for graceful degradation). Pete Hodgson, martinfowler.com. 2017-10-09. <https://martinfowler.com/articles/feature-toggles.html> (verified: primary) [34] "Learning under Concept Drift: A Review" (IEEE TKDE 31(12); detection, understanding and adaptation) (arXiv 2004.05785). Lu et al. 2018. <https://arxiv.org/abs/2004.05785> (verified: primary) [35] Automated Employment Decision Tools (NYC Local Law 144 of 2021: bias audit within one year before use, public summary, candidate notices; enforced from 5 Jul 2023). NYC Department of Consumer and Worker Protection. 2023. <https://www.nyc.gov/site/dca/about/automated-employment-decision-tools.page> (verified: primary) [36] Digital Operational Resilience Act (DORA): in application since 17 Jan 2025; register of information; ICT third-party risk. EIOPA. 2025. https://www.eiopa.europa.eu/digital-operational-resilience-act-dora_en (verified: primary) [37] Regulation (EU) 2022/2554 (DORA), Art. 28(3) register of information on ICT third-party arrangements and Art. 28(8) exit strategies for ICT services supporting critical or important functions. Publications Office of the EU (EUR-Lex). 2022-12-14. https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng#art_28 (verified: primary) [38] Directive (EU) 2022/2555 (NIS2), Art. 21(2)(c) business continuity, backup management, disaster recovery and crisis management, and (d) supply-chain security. Publications Office of the EU (EUR-Lex). 2022-12-14. https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng#art_21 (verified: primary) [39] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 19(1) (providers keep automatically generated logs for at least six months). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_19 (verified: primary) [40] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 18(1) (providers keep documentation for 10 years after placing on the market or putting into service). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_18 (verified: primary) [41] AI Safety Governance Framework 3.0, §5.3 operators' guidelines (logs kept for at least six months and audited; voluntary). TC260 / CAC. 2026-09-14. <https://www.cac.gov.cn/rootimages/uploadimg/1791137114683961/1791137114683961.pdf> (verified: primary) [42] Top 10 for Agentic Applications 2026 (ASI01 to ASI10). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [43] Regulation (EU) 2016/679 (GDPR), Art. 33 (notification of a personal data breach to the supervisory authority without undue delay and, where feasible, within 72 hours). Publications Office of the EU (EUR-Lex). 2016-04-27. https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng#art_33 (verified: primary) [44] Regulation (EU) 2016/679 (GDPR), Art. 34(1) (communication of a breach likely to result in a high risk to the data subject without undue delay).

Publications Office of the EU (EUR-Lex). 2016-04-27. https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng#art_34 (verified: primary)

[45] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 20(1) (providers take corrective action: bring into conformity, withdraw, disable or recall; inform distributors and deployers). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_20 (verified: primary)

[46] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 79 (procedure for AI systems presenting a risk to health, safety or fundamental rights). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_79 (verified: primary)

16. Fairness and explainability for practitioners

Fairness and explainability become controls only when they are measured, gated and filed as evidence; this chapter maps each technique to its stack layer and its legal hook.

How to read this chapter

Fairness and explainability are the two principles every responsible-AI framework names and the two that most often stay on the poster. NIST's AI Risk Management Framework lists "Fair – with Harmful Bias Managed" and "Explainable and Interpretable" among the characteristics of trustworthy AI, and gives each a measurement subcategory: [MEASURE 2.11](#) (fairness and bias are evaluated and the results documented) and [MEASURE 2.9](#) (the model is explained, validated and documented, and its output interpreted in context) [1]. The engineering question is what those two sentences turn into on a Tuesday: which metric, computed on which slice, against which threshold, failing which build; which explanation, produced by which method, tested how, delivered to whom, and kept as which record.

The chapter keeps the house line from chapter 01. Responsible AI and AI ethics set the target; AI governance engineering builds the control that hits it and the evidence that proves it (see [the disambiguation cluster](#)). Nothing here is legal advice. The law decides which disparity is unlawful and which explanation is owed; the engineer builds the measurement and the explanation so that Legal has something true to decide on.

The two halves belong together for a practical reason. Fairness is about outcomes across people; explainability is about the reasons for one outcome. An explanation is how an individual discovers that a decision was unfair to them, and attribution methods are one way a team finds the proxy that made a model unfair. Both also trade against privacy: you cannot measure a disparity across a group you may not observe, or explain a decision without disclosing something about its data. The first half covers fairness, the second explainability, and the last section places both in the five layers of [the stack](#).

Where bias enters the lifecycle

NIST SP 1270 sorts AI bias into three categories, **systemic**, **statistical** and **human**, and states plainly that "it is not possible to achieve zero risk of bias in an AI system" [2]. The consequence for an engineer is that fairness is managed like any other residual risk: named, measured, bounded and monitored, never declared solved.

Suresh and Guttag give the lifecycle view: seven sources of downstream harm, spread from data collection to deployment [3]. Each one has a different control, so the first job is to know which one you are looking at.

Source	Where it enters	Typical failure	Control and evidence	Layer
Historical bias	The world the data describes	Past hiring decisions encode past discrimination	Label audit; decision to relabel or change the target, recorded in the data card	02 · 03
Representation bias	Sampling	A group is under-sampled, so its error rate is high and noisy	Coverage report per group against the deployment population	02 · 03
Measurement bias	Features and labels	A convenient proxy stands in for the real target	Target-validity review; proxy scan	03
Aggregation bias	Modelling	One model fitted to groups with different relationships	Per-group performance; interaction terms or separate models	03
Learning bias	Training objective	Optimising average loss trades away a minority group	Fairness-constrained training; per-group loss curves	03
Evaluation bias	Benchmarks	The test set does not look like the people served	Evaluation set drawn from the deployment population; sliced metrics	03
Deployment bias	Use in context	A score built for one purpose used for another	Intended-purpose field in the registry; misuse monitoring	02 · 04

Measurement bias deserves the most attention because it passes every accuracy test. The canonical case is a widely used commercial health-care algorithm that predicted health-care *costs* as a stand-in for health *need*. Because less money was spent on Black patients at the same level of illness, the model was accurate on its target and biased on the thing that mattered; correcting the disparity would have raised the share of Black patients flagged for extra help from 17.7% to 46.5% [4]. No fairness metric computed against the cost label would have caught it. What catches it is a review of whether the label measures the construct the decision is about, recorded before training. The [health-risk score case](#) reads it as a post-mortem, and the [recruiting-model case \(reported\)](#) does the same for historical bias in hiring data. The EU AI Act writes this view into law for high-risk systems. Article 10(2) (f) and (g) require data to be examined for biases likely to affect health and safety, harm fundamental rights or lead to prohibited discrimination, and require measures to detect, prevent and mitigate them; Article 10(3) and (4) require data that is relevant, sufficiently representative and suited to the setting of use [5]. Article 15(4) adds the feedback loop: a system that keeps learning

must be built to reduce the risk that biased outputs become future inputs [6]. Each clause is a test you can run and a record you can keep (see [Data governance across the stack](#)).

Protected characteristics, proxies and the data you need to test

Protected characteristics are defined by the legal frame, not by the engineer. US federal employment law protects race, colour, religion, sex and national origin under Title VII [7]; EU equality law defines discrimination on grounds such as racial or ethnic origin [8]; the GDPR names special categories of personal data whose processing is restricted [9]. A system deployed across jurisdictions needs the union of the lists that apply, recorded in the policy as data, not in an engineer's head.

Removing the protected attribute from the feature set, sometimes called "fairness through unawareness", does not remove the bias. Other features carry the same information: postcode stands in for ethnicity, first name for sex and origin, a career gap for sex or disability, device type for income. Two tests expose **proxies** and belong in the eval suite:

- **Predict the protected attribute.** Train a small model to predict the protected attribute from the candidate features. If it succeeds well above chance, the feature set encodes the attribute and a model trained on it can discriminate without ever seeing it.
- **Attribute and ablate.** Use feature attribution (later in this chapter) to find which features drive the disparity, then measure the disparity with each suspect feature removed or neutralised.

Both tests need the protected attribute at evaluation time, which is the privacy tension every fairness programme meets. The EU resolved it narrowly. The Digital Omnibus deleted Article 10(5) and moved the rule into a new **Article 4a**, in force since 27 July 2026 [10]. Article 4a(1) lets providers of high-risk systems exceptionally process special categories of personal data to the extent strictly necessary for bias detection and correction under Article 10(2)(f) and (g); Article 4a(2) extends the same possibility to providers and deployers of other AI systems and models and to deployers of high-risk systems, for biases likely to affect health and safety or fundamental rights or to lead to prohibited discrimination, under the same conditions, while stating that it creates no obligation to run such detection [11]. The conditions read like a control specification, which is how to build them:

Art. 4a(1) condition	Engineering control	Evidence record
(a) Other data, including synthetic or anonymised data, would not work	Necessity memo comparing the alternatives tried	Signed memo linked from the data card
(b) Re-use limits and state-of-the-art security, including pseudonymisation	Pseudonymisation at ingestion; purpose tag enforced at pipeline build	Pipeline config and policy verdict
(c) Strict, documented access for authorised persons under confidentiality	Scoped access role; access logging	Access log per query
(d) No transmission to or access by other parties	Egress policy-as-code denying export of the tagged set	Policy verdicts at every deploy
(e) Deletion once the bias is corrected or retention ends, whichever is first	Retention-as-code with a deletion job	Deletion event with dataset hash
(f) Records of processing state why the processing was strictly necessary	Record-of-processing entry generated from the memo	Record-of-processing version

The article sits on top of the GDPR, not instead of it, so the lawful basis and the DPIA still apply (see chapter 19, [Privacy and AI](#)). Where special-category data cannot be used at all, the fallbacks are voluntary self-identification with a clear purpose statement, testing on consented panels, and inferred attributes; the last carry their own error and legal risk and need the same review as any other use of the data (chapter 19 on [inferred and proxy sensitive data](#)).

Disparate treatment and disparate impact

Anti-discrimination law has two doctrines, and an AI system can breach either.

Doctrine	US frame	EU frame	What it looks like in a model	First test
Disparate treatment (direct discrimination)	Intentional or explicit use of a protected characteristic	Less favourable treatment on a protected ground in a comparable situation	The protected attribute, or a deliberate stand-in, is a feature or a rule	Feature audit; counterfactual flip test
Disparate impact (indirect discrimination)	A practice that causes a disparate impact and is not job-related and consistent with business necessity	An apparently neutral criterion that puts a group at a particular disadvantage without objective justification	Neutral features produce unequal outcomes	Selection-rate ratios; error-rate gaps

In US employment law disparate impact is statutory: a practice that causes it is unlawful unless it is job-related and consistent with business necessity, or where a less discriminatory alternative is refused [7]. The EU test for indirect discrimination has the same

shape: an apparently neutral criterion that disadvantages a group is unlawful unless objectively justified by a legitimate aim pursued by appropriate and necessary means [8]. For an engineer, "neutral criterion" means "feature", and "justified" means showing why the feature is needed and that no less discriminatory alternative performs acceptably. That comparison is an eval, and its result is evidence.

The four-fifths rule and the adverse-impact ratio

The most widely used screening number comes from the US Uniform Guidelines on Employee Selection Procedures of 1978. A selection rate for any race, sex or ethnic group that is less than four-fifths (80%) of the rate for the group with the highest rate "will generally be regarded" by federal enforcement agencies as evidence of adverse impact [12]. The ratio of the two rates is the **adverse-impact ratio (AIR)**.

The same paragraph carries the caveats that most dashboards drop. Smaller differences may still constitute adverse impact where they are significant in both statistical and practical terms, and larger differences may not where they rest on small numbers and are not statistically significant [12]. So the four-fifths rule is a trigger for investigation, not a pass mark. A gate that treats 0.81 as green and 0.79 as red, with no confidence interval and no minimum sample, is the Goodhart trap described in [the limits of the eval gate](#).

Example (illustrative) A screening model advances 120 of 400 applicants from group A (a selection rate of 30%) and 45 of 250 from group B (18%). The AIR for group B is $18 / 30 = 0.60$, well under 0.8. The eval records the rates, the counts, the ratio, a bootstrap confidence interval for the ratio and the protected attribute's source, and the gate routes the release to review rather than silently failing or passing it.

The legal weight of the rule is moving. As of 2026-09-24, US federal enforcement has turned away from disparate impact: on 9 June 2026 the Department of Justice announced an Office of Legal Counsel opinion concluding that the EEOC's disparate-impact guidelines are unconstitutional [13]. The opinion addresses the Uniform Guidelines, is presented as implementing Executive Order 14281, and follows an EEOC enforcement plan that prioritises disparate treatment; it is not a court ruling, and commentators note that private plaintiffs and many state laws still support disparate-impact claims [14]. The engineering conclusion does not change with the enforcement weather: the adverse-impact ratio remains the cheapest early signal of an unequal outcome, and several regimes still require it by name.

New York City's Local Law 144 is the clearest example. An employer may use an automated employment decision tool only if it has had a bias audit by an independent auditor within the past year; the audit must calculate selection or scoring rates and impact ratios across sex categories, race/ethnicity categories and **intersectional** categories; a summary of results must be published; and categories under 2% of the audit data may be excluded [15]. The law requires no specific action on the results [15], which is exactly why the engineering function should attach an internal threshold and an owner: a published impact ratio with neither is transparency without a control.

Two further legal points constrain the fix, not only the finding. Title VII forbids adjusting scores or using different cut-off scores by race, colour, religion, sex or national origin in employment tests [7], so a post-processing fix that sets group-specific thresholds can itself be unlawful in that setting. And any mitigation that uses the protected attribute at decision time risks becoming direct discrimination under EU law. Mitigation choices go to Legal with the eval evidence attached (see [mitigation](#) below). The wider US and EU picture is in chapter 20, [Existing law and AI](#).

Group fairness metrics

A **group fairness metric** compares a statistic of the model's behaviour across groups. The five that matter most, in the vocabulary of the research that defined them, are below. $\hat{Y}$ is the decision or prediction, Y the true outcome and A the group.

Metric	Holds when	Equalises	Fits when	Watch out for
Demographic parity (statistical parity)	$P(\hat{Y}=1 \text{ given } A=a)$ is equal across groups	Selection rates	The opportunity should be shared regardless of measured outcome; the AIR is its ratio form	Ignores different base rates; can be met by selecting unqualified members of a group [16]
Equal opportunity	True-positive rates are equal	Benefit to the qualified	Missing a qualified person is the main harm (hiring, admissions, access to care) [17]	Leaves false positives unconstrained
Equalised odds	True-positive and false-positive rates are both equal	Both error types	Both errors are costly [17]	Harder to satisfy; may cost accuracy for all groups
Predictive parity	Precision ($P(Y=1 \text{ given } \hat{Y}=1)$) is equal	Meaning of a positive decision	A positive decision triggers action whose value depends on being right (fraud referral) [18]	Incompatible with equal error rates when base rates differ
Calibration within groups	Among people scored s , a fraction s are positive, in every group	Meaning of a score	Scores are consumed as probabilities (credit pricing, clinical risk) [19]	A calibrated score can still produce very different error rates

Two practical rules follow. Report differences *and* ratios, because a small absolute gap at a low base rate can be a large ratio and the reverse [20]. And report the metric with its denominator: a rate on 30 people is an anecdote, and the eval should say so. The tools catalogue lists [fairness toolkits](#) as illustrative examples, not endorsements.

Individual and counterfactual fairness

Group metrics can be satisfied while individuals are treated arbitrarily inside each group. Two individual-level notions address that. **Individual fairness** requires that similar individuals be treated similarly, given a task-specific measure of similarity; the hard part, which its authors name, is agreeing that measure [16]. **Counterfactual fairness** requires that a decision be the same in the actual world and in a counterfactual world where the individual belonged to a different group, which needs an explicit causal model of how the attribute influences the other features [21].

Neither is usually computed exactly in production, but both have a cheap and useful approximation: the **counterfactual flip test**. Change only the protected attribute, or its textual markers (a name, a pronoun, a dialect), hold everything else fixed, and measure how often the decision or the generated text changes. For LLM-based systems this is the most practical fairness eval available, because group labels for outputs rarely exist while paired prompts are easy to generate.

The impossibility results

Two papers from 2016 and 2017 turned "which fairness metric?" from a technical question into a value choice. Kleinberg, Mullainathan and Raghavan formalised three conditions (calibration within groups and balance of scores for the positive and for the negative class) and proved that, except in highly constrained special cases, no method can satisfy all three at once [19]. Chouldechova showed that when the prevalence of the outcome differs across groups, an instrument cannot satisfy predictive parity and equal error rates simultaneously, and that disparate impact can arise when error-rate balance fails [18]. The special cases are perfect prediction and equal base rates, and real deployments rarely have either.

Example (illustrative) Two groups of 1,000 people. Group A has a base rate of 30% (300 positives), group B a base rate of 10% (100 positives). A classifier with the same true-positive rate (0.8) and false-positive rate (0.1) in both groups satisfies equalised odds. In group A it produces 240 true positives and 70 false positives (0.1×700), a precision of $240 / 310 = 0.77$. In group B it produces 80 true positives and 90 false positives (0.1×900), a precision of $80 / 170 = 0.47$. Equal error rates, unequal meaning of a positive decision: predictive parity fails, and no threshold choice fixes both while the base rates differ.

The engineering consequence is procedural. Because the metrics conflict, the choice between them is a governance decision with an owner, taken *before* the results are seen and recorded as policy. A team that picks the metric after looking at which one its model passes is metric shopping, and the record should make that impossible: the chosen metric, the reason, the threshold and the approver live in a versioned [Policy Card](#) that the eval reads.

Intersectional and subgroup testing

Aggregate group metrics hide the people at the intersections. The Gender Shades audit of three commercial gender classifiers found error rates of up to 34.7% for darker-skinned women against a maximum of 0.8% for lighter-skinned men [22]; a report by gender alone, or by skin type alone, averages the worst-served group into a larger one. Kearns and colleagues named the general failure **fairness gerrymandering**: a classifier can look fair on every predefined group and still badly violate the constraint on structured subgroups defined over the protected attributes [23]. Model cards were proposed in part to report evaluation across demographic and intersectional groups [24], and New York City's bias audits now require intersectional categories [15].

Intersectional testing runs into small numbers fast, so the eval needs rules for them:

- **A minimum cell size** in the policy; below it the eval reports "insufficient data", lists the cell and never counts it as a pass.
- **Confidence intervals** on every rate and ratio, with the gate on the interval, not the point.
- **A stated multiple-comparison correction**, because with dozens of cells some fail by chance.
- **A search for the worst slice**, for example a shallow tree fitted to the error indicator, to find subgroups nobody listed; the worst-group metric is reported beside the average.

Choosing a fairness metric by use case

The metric follows the harm, and the harm follows the use case. Fairlearn's user guide separates **allocation harms** (a system extends or withholds opportunities, resources or information) from **quality-of-service harms** (a system works less well for some people even when nothing is withheld) and **stereotyping harms** [20]. Add the cost of each error type and the legal frame, and the choice narrows. The cost of each error type is the use-case record's [error appetite](#) (chapter 14).

Use case	Harm type	Costliest error	Primary metric	Secondary checks	Legal frame
CV screening, promotion	Allocation	Rejecting a qualified candidate	Selection-rate AIR; equal opportunity	Intersectional AIR; proxy scan	Title VII, Uniform Guidelines, NYC LL144; AI Act Annex III point 4

Use case	Harm type	Costliest error	Primary metric	Secondary checks	Legal frame
Credit approval and pricing	Allocation	Both: wrongful denial and unaffordable credit	Calibration within groups; approval-rate AIR	Error-rate gaps; reason-code consistency	ECOA and Regulation B, FCRA; AI Act Annex III point 5(b)
Benefits eligibility and recovery	Allocation (punitive when reclaiming)	Wrongly cutting or reclaiming a benefit	False-positive-rate parity	Predictive parity; appeal outcomes by group	Equality law; GDPR Art. 22; AI Act Annex III point 5(a)
Clinical triage	Allocation (need-based)	Missing a person in need	Equal opportunity; calibration	Label-validity review (cost versus need)	Medical-device and equality law
Speech, vision, document search	Quality of service	Failing for a group of users	Worst-group error rate	Intersectional error	Accessibility and equality law
Generative assistant	Quality of service; stereotyping	Degraded or demeaning output for a group	Counterfactual flip rate; per-group quality floor	Stereotype probes; refusal-rate gaps	Equality and consumer law

The Annex III points are the AI Act's high-risk use cases for employment (point 4), public assistance benefits (point 5(a)) and creditworthiness and credit scoring (point 5(b)), which expressly excludes systems used to detect financial fraud [25]. The table is a starting point, not a rule. What makes the choice defensible is that it is written down with its reasons before the eval runs, reviewed by someone who represents the affected people (the [FRIA-as-Code](#) pattern is where that review lives), and revisited when the use case changes.

Mitigation before, during and after training

Once a disparity is found and judged unacceptable, the fixes fall into three families by where they act. Open toolkits implement many of them; AI Fairness 360 includes dataset and model metrics and mitigation algorithms [26], Fairlearn provides assessment and mitigation with an explicit sociotechnical framing [27], and Aequitas focuses on auditing across subgroups [28]. They are named as examples of a category, not endorsements.

Stage	Techniques (examples)	What changes	Evidence to keep	Caution
Pre-processing	Collect better data; reweight or resample under-represented groups; relabel after a label audit; transform features to remove proxy information	The training data	Data card diff; before/after coverage report	Often the most durable fix; reweighting can overfit small groups
In-processing	Fairness-constrained optimisation; regularisers on group gaps; adversarial debiasing	The learning objective	Training config; per-group loss curves; the constraint and its bound	Needs the attribute at training time (see Art. 4a)
Post-processing	Group-specific thresholds [17]; reject-option review near the boundary	The decision rule	Threshold table; decision-rule version	Group-specific cut-offs may be unlawful in US employment tests [7] and risk direct discrimination in the EU

Three rules apply to every mitigation. Re-run the whole suite, including accuracy per group, because a fix can "equalise" by making everyone worse off. Record the mitigation as a change with an owner and a reason, so the model card explains the behaviour. And prefer the earliest fix that works: better data beats a clever constraint, and a constraint beats a threshold patch.

Monitoring fairness in production

A fairness eval proves the model was acceptable on the evaluation data at build time. Production brings new people, shifted populations and delayed labels. Monitoring fills the gap with signals that do not need ground truth immediately:

- **Selection or approval rates by group** and their AIR, on a rolling window, compared against the eval baseline. These need no outcome label.
- **Calibration and error rates by group** once outcomes arrive, with the label delay stated.
- **Human-oversight signals by group**: override rates, time-to-decide and reversal rates at the [Human-in-the-loop Gate](#). A reviewer who overrides one group more often is a fairness signal about the model or about the reviewer.
- **Complaints, appeals and explanation requests by group**, including their outcomes. The [contest channel](#) is a sensor.
- **Feedback-loop checks** for systems whose outputs shape future training data, which Article 15(4) requires high-risk systems that keep learning to address [6].

The group attribute is usually absent at runtime. The options are a consented sample or panel on which the attribute is known, periodic audits under the Article 4a conditions (deployers of high-risk systems fall under Article 4a(2) [11]), or monitoring only the

outcome-free rates with the attribute joined in a secured environment. Whichever is chosen, the **monitor** is a layer 04 signal streamed into layer 05 through **Continuous Assurance Telemetry**, and a breach opens a ticket with an owner, not a chart nobody reads. A disparity that caused harm is an incident and follows chapter 17, **Incidents**.

Transparency, interpretability and explainability

The three words are used interchangeably and should not be. NIST's framework draws the line in one sentence each: transparency answers "what happened" in the system, explainability answers "how" a decision was made, and interpretability answers "why" it was made and what it means to the user in context [1]. Chapter 11 names the three sources of opacity among **the traits of AI that break classic IT governance**.

Term	Question it answers	Typical artefact	Primary audience	Layer
Transparency	What is this system, what data and model does it use, what can it do and not do?	Model card, data card, AIBOM, instructions for use, AI-use notice	Deployers, auditors, the public	02
Explainability	How did the system arrive at this output?	Per-decision explanation record; attribution; reason codes	Operators, affected people, reviewers	03 - 04
Interpretability	Why does this output mean what it means, here?	A model whose structure a person can read; interpretation guidance	Model owners, validators, domain experts	03

NIST IR 8312 adds four principles a system that must be explainable should meet: it delivers **explanation** (evidence or reasons for outputs), the explanation is **meaningful** to its intended consumer, it has **explanation accuracy** (it correctly reflects how the output was produced), and the system respects **knowledge limits** (it operates only where it was designed to and with sufficient confidence) [29]. The third principle is the one most often broken, and the one this chapter returns to under testing.

Interpretable by design or explained after the fact

There are two routes to an explanation. An **inherently interpretable** model is one whose structure is the explanation: a sparse linear or logistic model, a points-based scorecard, a generalised additive model, a shallow decision tree or a short rule list. A **post-hoc** explanation is produced by a second method that approximates the behaviour of a model that is not itself readable.

Rudin's argument is that for high-stakes decisions this choice is not neutral: explaining a black box rather than using an interpretable model "is likely to perpetuate bad practices", because a post-hoc explanation is a model of the model, and can be wrong about it [30]. The practical form of that argument is a design rule. Train an interpretable baseline first. If the complex model does not beat it by a margin that matters for the decision, ship the interpretable one; if it does, record the margin, the reason the gain justifies the explanation risk, and the post-hoc method that will be used, in the design decision log (chapter 14, **Governing development**).

When an interpretable model is required

No statute in this chapter says "use a scorecard". Several say things that are hard to meet any other way. An interpretable model is the default when most of the following hold:

- **The decision has legal or similarly significant effects on a person** (credit, employment, benefits, insurance, education), so reasons are owed by law.
- **The reasons must be the factors actually used.** Regulation B requires adverse-action reasons to relate to the factors actually considered or scored [57]; a post-hoc approximation can drift.
- **The data is tabular with meaningful features**, where interpretable models are often competitive.
- **Validators or regulators must reproduce the logic**, as in model risk management.
- **The person must be able to act on the explanation**, which needs stable, understandable factors.

Where these hold and a complex model is still chosen, the gate should demand the stronger evidence: explanation-accuracy tests, reason-code stability tests and a signed justification.

Explanation techniques

Explanations vary along two axes: **scope** (a *global* explanation describes the model's overall behaviour; a *local* one explains a single output) and **access** (a *model-agnostic* method needs only inputs and outputs; a *model-specific* one uses the model's internals). The tools catalogue lists **explainability libraries** as illustrative examples, not endorsements.

	Global	Local
Model-agnostic	Global surrogate models; permutation feature importance; partial dependence	LIME; KernelSHAP; counterfactual explanations; nearest-example explanations
Model-specific	Coefficients of an interpretable model; tree structure; probing of internal representations	TreeSHAP; integrated gradients and other gradient attributions; attention or circuit analysis (research)

Feature attribution: SHAP, LIME and integrated gradients

Feature attribution assigns each input feature a share of responsibility for one output. **SHAP** (SHapley Additive exPlanations) assigns each feature an importance value for a particular prediction, grounded in Shapley values from game theory, and unifies several earlier methods as additive feature-attribution measures [32]. **LIME** explains an individual prediction by fitting a simple, interpretable model to the black box's behaviour on perturbed samples around that input [33]. **Integrated gradients** attributes a deep network's prediction by accumulating gradients along a path from a baseline input to the actual one, and is designed to satisfy two axioms, sensitivity and implementation invariance, that many attribution methods fail [34].

Each has failure modes the eval suite should test rather than assume away:

- **Correlated features.** Credit is split between correlated features according to the method's assumptions, so two proxies for the same thing can each look minor.
- **Baselines.** SHAP and integrated gradients explain relative to a reference; change it and the explanation changes, so the reference is part of the artefact.
- **Off-manifold perturbations.** Slack and colleagues built a scaffolded classifier whose predictions stay biased while LIME and SHAP explanations look innocuous [35]. Explanations can be gamed.
- **Methods that ignore the model.** Some saliency methods produce explanations independent of both the model and the data, so visual plausibility is no evidence of accuracy [36].

Surrogate models

A **global surrogate** is an interpretable model (a tree, a rule list) trained to mimic the complex model's predictions. It is useful for review and documentation, and only as good as its **fidelity**: the share of inputs on which it agrees with the model it describes. A surrogate reported without its fidelity on the deployment population is a diagram, not evidence.

Counterfactual explanations

A **counterfactual explanation** states the smallest change to the input that would have changed the outcome, for example (illustrative) "had your declared monthly income been 400 higher, the application would have been approved". Wachter, Mittelstadt and Russell argued that such explanations can help a data subject understand, contest and act on a decision without opening the black box [37]. They are the natural fit for **recourse**, and they map closely onto what the Court of Justice has since asked of controllers (see the legal hooks below).

Counterfactuals need engineering constraints to be honest and useful. Restrict changes to features the person can actually change (never age, origin or disability); respect causal dependencies between features; prefer plausible, sparse changes; and check that the counterfactual is stable, so two near-identical applicants are not told opposite things. A counterfactual that recommends changing a protected characteristic is a fairness finding, not an explanation.

Example-based explanations

Example-based explanations show prototypes, the nearest training examples or the examples that most influenced a prediction. They are intuitive for images and documents and for expert reviewers. They also disclose training data: showing a similar past case can reveal another person's personal data, so the method needs the same privacy review as any data release.

Explanations for LLMs and RAG systems

Large language models add two complications. First, the model's own account of its reasoning is not an explanation in the NIST sense of explanation accuracy. Chain-of-thought text can systematically misrepresent the true reason for a prediction: when models were nudged by features they never mentioned, they produced plausible rationalisations, with accuracy dropping by as much as 36% on the affected tasks [38]. A generated rationale is an output to be evaluated, not a window into the model.

Second, **mechanistic interpretability**, the research programme that tries to reverse-engineer the computations inside a network, has made visible progress but, by its own researchers' account, still faces open conceptual and practical problems before many of its benefits can be realised [39]. As of 2026-09-24, treat it as a research input to red-teaming and safety cases, not as a source of per-decision explanations an organisation can hand to an affected person or an auditor.

For retrieval-augmented generation the practical explanation is the **citation**: which retrieved passages support which sentences. Citations are only as good as their support. An audit of four generative search engines found that on average 51.5% of generated sentences were fully supported by their citations and 74.5% of citations supported their sentence [40]. So a RAG explanation artefact needs its own evals: citation precision (does each cited passage support its claim?), citation recall (is each claim cited?), and groundedness, all run in layer 03, plus a trace in layer 04 that stores the corpus snapshot and passage identifiers behind each answer so the citation can be re-checked later.

The legal hooks for explanations

Explanation duties come from several regimes that differ in who owes what, to whom and when. The table routes the work; the subsections add what matters for the build. Chapters 18 to 20 ([The EU AI Act](#), [Privacy and AI](#), [Existing law and AI](#)) give the full legal picture.

Instrument	Who owes it	Trigger	What must be given	Artefact
ECOA and Regulation B, 12 CFR 1002.9	Creditor	Adverse action on a credit application or account	Statement of specific principal reasons [31]	Reason-code service; notice template; decision log
FCRA, 15 U.S.C. 1681m and 1681g(f)	User of a consumer report	Adverse action based on the report	Notice, credit score used and up to four key factors [41]	Score and key-factor record
GDPR Arts. 13(2) (f), 14(2)(g), 15(1) (h)	Controller	Automated decision-making under Art. 22(1) and (4)	Meaningful information about the logic involved, the significance and envisaged consequences [9]	System-level notice; per-request explanation
GDPR Art. 22(3)	Controller	Solely automated decision with legal or similarly significant effect, on contract or consent	Human intervention, the chance to express a view and to contest [9]	Contest channel; review log
UK GDPR Arts. 22A–22D	Controller	Significant decision based solely on automated processing	Information, representations, human intervention, contest [42]	Same, UK variant
AI Act Art. 13	Provider (to deployers)	High-risk system	Instructions for use enabling deployers to interpret output [43]	Instructions for use; explanation-method card
AI Act Art. 86	Deployer	Decision based on an Annex III system (except point 2) with legal or similarly significant adverse effect	Clear and meaningful explanation of the AI system's role and the main elements of the decision [44]	Explanation request workflow; explanation record

Credit: adverse-action notices and reason codes

US credit law is the oldest explanation regime and the most concrete. Regulation B requires the reasons for adverse action to be specific and to indicate the principal reasons; saying only that the applicant missed internal standards or a qualifying score is insufficient [31]. The official commentary adds the engineering detail: more than four reasons is not likely to be helpful; reasons must relate to and accurately describe the factors actually considered or scored; no principal reason may be left out; and no single selection method is required, with two reference methods that compare the applicant's score on each factor against average scores [57]. When the action rests on a consumer report, the FCRA adds the credit score used and up to four key factors [41].

The CFPB's two circulars applying these duties to complex algorithms and to sample reason forms were withdrawn on 12 May 2025 [45]; as of 2026-09-24 the regulation and its commentary still carry the duty. So a **reason-code** service maps each principal factor the model actually used to a stable, human-readable reason, versioned with the model, and a test shows that the reasons given for a sample of denials match the factors that drove them. If the model is too complex for that test to pass, the model is the problem, not the notice.

Data protection: GDPR and the UK regime

The GDPR's articles do not use the words "right to explanation"; Recital 71 mentions obtaining "an explanation of the decision reached", and Articles 13 to 15 require meaningful information about the logic involved where Article 22 automated decision-making takes place [9]. The Court of Justice has made that concrete. In *SCHUFA* (C-634/21, 7 December 2023) it held that generating a credit score can itself be an Article 22(1) decision where a third party draws strongly on it [46], so the scoring provider, not only the lender, can owe the safeguards. In *Dun & Bradstreet Austria* (C-203/22, 27 February 2025) it held that the controller must explain the procedure and principles actually applied, that a complex mathematical formula does not meet the duty, and that trade secrets go to the authority or court for a case-by-case balance rather than justifying refusal [47]. The Court added that, for profiling, the national court could find it sufficiently transparent and intelligible to tell the data subject how far a variation in the personal data taken into account would have led to a different result (para. 62) [47][48]: a counterfactual explanation in legal language.

In the UK, the Data (Use and Access) Act 2025 replaced Article 22 with Articles 22A to 22D, which treat a decision as solely automated where there is no meaningful human involvement and require safeguards to inform the data subject, take representations, provide human intervention and allow contest [42]. The ICO's co-badged guidance with The Alan Turing Institute on explaining AI decisions is under review as a result as of 2026-09-24; its six explanation types (rationale, responsibility, data, fairness, safety and performance, impact) remain a useful checklist [49]. In the EU, the Commission's wider digital omnibus proposed rewriting Article 22; a first Council compromise dropped that change, and as of 2026-09-24 the GDPR amendments are not adopted [50] (verify before relying on the current text).

The EU AI Act: Articles 13 and 86

The AI Act adds one duty upstream and one downstream. Article 13 requires high-risk systems to be transparent enough for deployers to interpret the output and use it appropriately, with instructions for use that are "relevant, accessible and comprehensible to deployers" and that cover the system's technical capabilities to provide information relevant to explain its output, its performance for the persons or groups on which it is intended to be used, and the technical measures that help

deployers interpret outputs [43]. The provider's artefact is an explanation-method card shipped with the instructions: method, baseline, known limits, fidelity and group-level performance.

Article 86 gives a person subject to a deployer's decision based on an Annex III high-risk system (except critical infrastructure, point 2), with legal or similarly significant adverse effects on their health, safety or fundamental rights, the right to "clear and meaningful explanations of the role of the AI system in the decision-making procedure and the main elements of the decision taken" [44]. It applies only where Union law does not already provide the right [44], so GDPR Articles 15(1)(h) and 22 come first where they bite. Deployers must also tell people they are subject to the system [51]. The Omnibus moved the main Annex III obligations to 2 December 2027 [10]; whether the practical start of Article 86 tracks that date should be confirmed with counsel (verify). The build need not wait: one explanation record, described below, serves Article 86, Article 15(1)(h) and an adverse-action notice.

Testing explanation quality

An explanation is an output, so it gets evals like any other output. Doshi-Velez and Kim's taxonomy gives three levels of evidence, in rising cost: **functionally grounded** tests with no humans (proxy metrics), **human-grounded** tests with lay people on simplified tasks, and **application-grounded** tests with the real users on the real task [52]. A practical suite mixes all three.

Test	What it checks	Level	Example gate condition (illustrative)
Fidelity	The explanation reflects the model (NIST explanation accuracy [29]): deleting the top-attributed features changes the output more than deleting random ones	Functional	Deletion-curve area beats random by a set margin on the validation set
Stability	Near-identical inputs get near-identical explanations and reason codes	Functional	Top-k reason overlap above a threshold under small perturbations
Sanity	The explanation changes when the model is randomised [36]	Functional	Explanation similarity after weight randomisation below a threshold
Manipulation resistance	Off-manifold probing cannot hide a known bias [35]	Functional	Planted-bias test model is detected by the explanation method
Reason-code consistency	Reason codes match the factors that actually drove the decision [57]	Functional	100% of sampled denials have reasons drawn from scored factors
Counterfactual validity	The suggested change flips the decision and uses only mutable features	Functional	All sampled counterfactuals valid and actionable
Comprehension	The intended audience can state the main reason and what they could change	Human-grounded	A majority of a test panel answers both questions correctly
Decision support	Reviewers with explanations decide better, not only faster, and are not led into automation bias	Application-grounded	Override accuracy with explanations at least equal to without

The last two rows are the ones teams skip and the ones the law cares about: an explanation must be **meaningful** to the person who receives it [29]. Test the notice with people like its recipients, including people with low literacy in its language and people who use assistive technology, and keep the protocol and results as evidence. For reviewers, pair this with [Designing human oversight](#): an explanation that makes reviewers agree faster with a wrong model is a control failure.

Accessible explanations

An explanation that the recipient cannot perceive or understand fails the "meaningful" test whatever its fidelity. The AI Act asks for instructions for use that are "relevant, accessible and comprehensible to deployers" [43] and requires providers of high-risk systems to meet the EU accessibility requirements of Directives (EU) 2016/2102 and 2019/882 [53]. WCAG 2.2 gives the testable criteria for the digital channel [54]. In practice:

- **Text first.** Every attribution chart (a SHAP waterfall, a saliency map) has a text equivalent that states the main factors in words (WCAG success criterion 1.1.1, non-text content).
- **Never colour alone.** Positive and negative contributions are marked by sign and label, not only red and green (1.4.1, use of colour).
- **Plain language.** Reason codes are written for the recipient, not the data scientist; aim for a lower-secondary reading level where the audience is the public (3.1.5, reading level, a level AAA criterion used here as a target).
- **Layered detail.** A one-sentence reason, then the main factors, then how to contest, then the technical annex for those who ask.
- **More than one channel.** The same explanation is available on paper, by phone or in person for people who do not use the digital channel.

Explanation artefacts as evidence records

An explanation delivered and not kept cannot be audited, reproduced or defended. The unit of evidence is the **explanation record**: one structured object per explained decision, written at decision time by the runtime (layer 04), keyed to the same registry id as every other artefact, and retained by the obligation it serves.

Example (illustrative) An explanation record for a declined device-financing application:

```
json { "decision_id": "dfc-2026-09-18-004211", "subject": "credit-dfc@2026-09-01", "outcome": "decline", "method": "treeshap", "method_version": "0.46", "baseline": "bg-sample.v12", "fidelity_check": "pass", "reason_codes": ["R07 debt-to-income", "R12 recent missed payments"], "counterfactual": { "feature": "monthly_debt", "change": "-180", "result": "approve" }, "template": "adverse-action.en.v5", "audience": "applicant", "delivered": "2026-09-18T10:02:13Z", "channel": "email+letter", "contest_url_ref": "appeal-flow.v3" }
```

The record makes three things true. The explanation is reproducible, because the model version, the method, its version and the baseline are pinned. It is checkable, because the reason codes can be re-derived and compared. And it is reusable, because the same record answers a Regulation B notice, an Article 15(1)(h) access request, an Article 86 request and an internal appeal. Explanation records stream into layer 05 with the rest of the evidence, where an auditor can ask "show me every decline in August whose reason codes differ from a fresh recomputation" and get a query, not a project.

Fairness and explainability in the stack

Both disciplines produce evidence at every layer. The table is the checklist; each row names the artefact, not the aspiration.

Layer	Fairness artefact	Explainability artefact	Pattern
01 Govern-as-Code	Fairness policy as data: protected attributes by jurisdiction, chosen metric and reason, thresholds, minimum cell size, approver	Explanation policy: required explanation types per use case, interpretable-by-default rule, reason-code limits	Policy Card
02 Inventory & Transparency	Data card with coverage per group and the Art. 4a basis; model card with disaggregated and intersectional metrics	Instructions for use and explanation-method card (method, baseline, fidelity, limits); AI-use notice	Model Card as Control Evidence
03 Evals & Red Teaming as Evidence	Fairness eval suite : group metrics with intervals, intersectional slices, proxy scan, counterfactual flip test	Explanation eval suite: fidelity, stability, sanity, reason-code consistency, comprehension test	Eval Gate in CI
04 Runtime Controls & Observability	Rolling selection rates and AIR by group; override and appeal rates by group	Explanation record per decision; contest channel; RAG citation trace	Human-in-the-loop Gate
05 Assurance & Continuous Compliance	Fairness results and audit summaries as machine-readable evidence; LL144-style published summary	Explanation-request log with response times; periodic re-derivation checks	Machine-Readable Evidence (OSCAL)

Layer 03 is where both become controls, which is why the definition of done in [Layer 03](#) applies unchanged: the suites are versioned with the model, run in CI, emit structured results filed against the registry entry, and fail the build when they fail. For procured models the same logic holds at the boundary: you can still compute group metrics on a vendor system's outputs and test the explanations it returns, and the [Vendor / Model Due-Diligence Gate](#) is where you ask for the provider's own disaggregated results and explanation-method documentation (see [Third-party and procured AI](#)).

The standards shelf for this work is short. NIST SP 1270 frames bias [2], NIST IR 8312 frames explanation [29], and ISO/IEC TR 24027:2021 covers bias in AI systems and AI-aided decision making [55]; it is referenced here by number only. ISO/IEC TS 6254:2025 (published September 2025) is the SC 42 document on objectives and approaches for explainability and interpretability of machine-learning models and AI systems [56]; it too is referenced here by number only. None of these is a harmonised standard, and none confers a presumption of conformity with the AI Act (see [the regulatory map](#)).

Gate conditions

A gate condition is a sentence the pipeline can evaluate. Illustrative conditions, each tied to a policy value rather than a round number chosen for comfort:

- For every group and intersectional cell above the minimum size, the lower confidence bound of the AIR is at or above the policy floor and the gap in the chosen error metric is within its bound, or a signed justification is attached to the release.
- Cells below the minimum size are listed as "insufficient data"; none is reported as a pass.
- The proxy scan is below the policy limit, or every flagged feature has a recorded justification.
- The explanation method passes fidelity, stability and sanity checks; sampled reason codes come only from scored factors; sampled counterfactuals are valid and use only mutable features.
- The model card, explanation-method card and instructions for use were regenerated for this version.

An eval-gate result carries the metric, its interval and the policy it was judged against (illustrative):

```
{ "suite_id": "fairness.credit-dfc.v3", "model_version": "credit-dfc@2026-09-01",  
  "metric": "approval_air", "group": "age_65_plus", "value": 0.86,  
  "ci95": [0.81, 0.91], "floor": 0.80, "min_cell": 200, "n": 1840,  
  "policy": "fairness-policy.credit.v2", "result": "pass" }
```

In practice (illustrative) A telco that sells handsets on instalment plans runs a credit check at the point of sale, so every decline is a credit decision that owes the applicant its reasons. The first version used a gradient-boosted model and generated reason codes from SHAP values at request time. A reason-code consistency test found that for a slice of declines the top SHAP feature was an engineered interaction no notice could describe. The team trained a monotone scorecard as a baseline, found it within a small margin of the complex model on approval accuracy, and shipped the scorecard. The fairness eval then gated each release on the approval-rate AIR by age band with intervals, and every decline wrote an explanation record. The audit question "why was this customer declined, and was anyone like them treated differently?" became two queries.

Maps to: EU AI Act Art. 4a (special-category data for bias detection), Art. 10(2)(f)–(g), 10(3)–(4) (data and bias), Art. 13 (transparency to deployers), Art. 15(4) (feedback loops), Art. 26(11) (informing affected persons), Art. 86 (right to explanation) · GDPR Arts. 13–15, 22 · UK GDPR Arts. 22A–22D · ECOA / Regulation B, FCRA · US Uniform Guidelines (29 CFR 1607.4(D)) · NYC Local Law 144 · NIST AI RMF (Measure 2.9, 2.11) · NIST SP 1270 · NIST IR 8312 · ISO/IEC TR 24027 · Layers 01–05. Mappings are illustrative, not a claim of conformity.

What you can do this week

1. **Pick one decision system about people and write its fairness policy as data:** the protected attributes that apply, the metric you chose and why, the threshold, the minimum cell size and the approver. Commit it before you look at the next eval run.
2. **Run a proxy scan** on that system's features: train a model to predict the protected attribute from them and record the result in the data card, with the Art. 4a basis if you used special-category data.
3. **Add one intersectional fairness eval to CI** with confidence intervals and an "insufficient data" outcome, wired to the [Eval Gate in CI](#) so that it can fail the build.
4. **Emit an explanation record for every adverse decision** the system makes, with the model version, method, baseline and reason codes pinned, and test 10 of them for reason-code consistency.
5. **Put one notice in front of five people** like the ones who receive it and ask them to state the main reason and what they could change. Keep the answers as evidence and fix what they got wrong.

Sources

[1] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (transparency answers "what happened", explainability "how", interpretability "why"; MEASURE 2.9 and 2.11). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [2] NIST SP 1270, Towards a Standard for Identifying and Managing Bias in Artificial Intelligence (three categories: systemic, statistical and human; "not possible to achieve zero risk of bias"). NIST. 2022-03-15. <https://doi.org/10.6028/NIST.SP.1270> (verified: primary) [3] "A Framework for Understanding Sources of Harm throughout the Machine Learning Life Cycle" (H. Suresh, J. Gutttag; seven sources: historical, representation, measurement, aggregation, learning, evaluation, deployment; EAAMO 2021). arXiv 1901.10002. 2019-01-28. <https://arxiv.org/abs/1901.10002> (verified: primary) [4] "Dissecting racial bias in an algorithm used to manage the health of populations" (Z. Obermeyer, B. Powers, C. Vogeli, S. Mullainathan; Science 366(6464):447–453; cost as a proxy for need; 17.7% to 46.5%). Science (PubMed 31649194). 2019-10-25. <https://doi.org/10.1126/science.aax2342> (verified: primary) [5] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 10 (data and data governance; 10(2)(f)–(g) examination for and mitigation of biases; 10(3)–(4) relevance, representativeness and setting; former 10(5) deleted and moved to Art. 4a by the Omnibus). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_10 (verified: primary) [6] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 15(4) (systems that continue to learn must reduce the risk of biased outputs influencing input for future operations, "feedback loops"). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_15 (verified: primary) [7] 42 U.S.C. § 2000e-2(k) and (l) (burden of proof in disparate-impact cases: job related and consistent with business necessity; less discriminatory alternative; (l) no adjusted scores or different cut-off scores by race, colour, religion, sex or national origin). US Government Publishing Office, GovInfo (United States Code, 2024 edition). 2024. <https://www.govinfo.gov/content/pkg/USCODE-2024-title42/html/USCODE-2024-title42-chap21-subchapVI-sec2000e-2.htm> (verified: primary) [8] Council Directive 2000/43/EC (Racial Equality Directive), Art. 2(2)(a)–(b) (direct and indirect discrimination). EUR-Lex. 2000-06-29. <https://eur-lex.europa.eu/eli/dir/2000/43/oj/eng> (verified: primary) [9] Regulation (EU) 2016/679 (GDPR), Arts. 9, 13(2)(f), 14(2)(g), 15(1)(h), 22 and Recital 71 ("an explanation of the decision reached"). EUR-Lex. 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [10] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689; OJ L, 24 July 2026; in force 27 Jul 2026; Annex III high-risk obligations moved to 2 Dec 2027. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/2026-07-24/eng>

lex.europa.eu/eli/reg/2026/1744/oj/eng (verified: primary) [11] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 4a (processing of special categories of personal data for bias detection and correction: conditions (a)-(f) in para. 1; para. 2 for other AI systems and models and for deployers of high-risk systems; no obligation created; inserted by Reg. (EU) 2026/1744, in force 27 Jul 2026). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_4a (verified: primary) [12] 29 CFR 1607.4(D), Uniform Guidelines on Employee Selection Procedures (1978): adverse impact and the "four-fifths rule", with the statistical and practical significance and small-numbers caveats. eCFR (text as of 2026-09-01). 2026-09-01. <https://www.ecfr.gov/current/title-29/subtitle-B/chapter-XIV/part-1607/section-1607.4> (verified: primary) [13] "Justice Department Concludes EEOC Disparate-Impact Guidelines Violate the Constitution" (Office of Legal Counsel opinion). US Department of Justice. 2026-06-09. <https://www.justice.gov/opa/pr/justice-department-concludes-eeoc-disparate-impact-guidelines-violate-constitution> (verified: primary) [14] "DOJ Opinion Finds EEOC Disparate Impact Liability Guidelines Unconstitutional" (opinion addresses 29 CFR part 1607 and 1608; "helps to implement" Executive Order 14281; EEOC enforcement plan of 4 Jun 2026 prioritises disparate treatment; private and state-law disparate-impact claims remain). Ogletree Deakins. 2026-06-29. <https://ogletree.com/insights-resources/blog-posts/doj-opinion-finds-eeoc-disparate-impact-liability-guidelines-unconstitutional/> (verified: secondary) [15] Automated Employment Decision Tools: Frequently Asked Questions (Local Law 144 of 2021: independent bias audit within the past year; selection or scoring rates and impact ratios across sex, race/ethnicity and intersectional categories; published summary; no specific action required; categories under 2% may be excluded). NYC Department of Consumer and Worker Protection. 2023-06-29. <https://www.nyc.gov/assets/dca/downloads/pdf/about/DCWP-AEDT-FAQ.pdf> (verified: primary) [16] "Fairness Through Awareness" (C. Dwork, M. Hardt, T. Pitassi, O. Reingold, R. Zemel; individual fairness; limits of statistical parity). arXiv 1104.3913. 2011-04-20. <https://arxiv.org/abs/1104.3913> (verified: primary) [17] "Equality of Opportunity in Supervised Learning" (M. Hardt, E. Price, N. Srebro; equalised odds, equal opportunity and post-processing adjustment). arXiv 1610.02413. 2016-10-07. <https://arxiv.org/abs/1610.02413> (verified: primary) [18] "Fair prediction with disparate impact: A study of bias in recidivism prediction instruments" (A. Chouldechova; criteria cannot all hold when prevalence differs across groups). arXiv 1703.00056. 2017-02-28. <https://arxiv.org/abs/1703.00056> (verified: primary) [19] "Inherent Trade-Offs in the Fair Determination of Risk Scores" (J. Kleinberg, S. Mullainathan, M. Raghavan; three fairness conditions cannot hold together except in highly constrained special cases). arXiv 1609.05807. 2016-09-19. <https://arxiv.org/abs/1609.05807> (verified: primary) [20] Fairlearn user guide, "Fairness in machine learning" (allocation, quality-of-service and stereotyping harms; disparity metrics as ratios or differences). Fairlearn project. 2026. https://fairlearn.org/main/user_guide/fairness_in_machine_learning.html (verified: primary) [21] "Counterfactual Fairness" (M. Kusner, J. Loftus, C. Russell, R. Silva). arXiv 1703.06856. 2017-03-20. <https://arxiv.org/abs/1703.06856> (verified: primary) [22] "Gender Shades: Intersectional Accuracy Disparities in Commercial Gender Classification" (J. Buolamwini, T. Gebru; error rates up to 34.7% for darker-skinned females; maximum 0.8% for lighter-skinned males). Proceedings of Machine Learning Research 81:77-91. 2018. <https://proceedings.mlr.press/v81/buolamwini18a.html> (verified: primary) [23] "Preventing Fairness Gerrymandering: Auditing and Learning for Subgroup Fairness" (M. Kearns, S. Neel, A. Roth, Z. S. Wu). arXiv 1711.05144. 2017-11-14. <https://arxiv.org/abs/1711.05144> (verified: primary) [24] "Model Cards for Model Reporting" (M. Mitchell et al.; evaluation across demographic and intersectional groups; FAT* 2019). arXiv 1810.03993. 2018-10-05. <https://arxiv.org/abs/1810.03993> (verified: primary) [25] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Annex III (high-risk use cases: point 2 critical infrastructure; point 4 employment; point 5(a) public assistance benefits; point 5(b) creditworthiness and credit scoring, excluding financial-fraud detection). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#annx_III (verified: primary) [26] "AI Fairness 360: An Extensible Toolkit for Detecting, Understanding, and Mitigating Unwanted Algorithmic Bias" (R. Bellamy et al.). arXiv 1810.01943. 2018-10-03. <https://arxiv.org/abs/1810.01943> (verified: primary) [27] "Fairlearn: Assessing and Improving Fairness of AI Systems" (H. Weerts et al.; fairness as a sociotechnical challenge). arXiv 2303.16626. 2023-03-29. <https://arxiv.org/abs/2303.16626> (verified: primary) [28] "Aequitas: A Bias and Fairness Audit Toolkit" (P. Saleiro et al.). arXiv 1811.05577. 2018-11-14. <https://arxiv.org/abs/1811.05577> (verified: primary) [29] NIST IR 8312, Four Principles of Explainable Artificial Intelligence (explanation, meaningful, explanation accuracy, knowledge limits). NIST. 2021-09-29. <https://doi.org/10.6028/NIST.IR.8312> (verified: primary) [30] "Stop Explaining Black Box Machine Learning Models for High Stakes Decisions and Use Interpretable Models Instead" (C. Rudin; Nature Machine Intelligence 1:206-215, May 2019). arXiv 1811.10154. 2018-11-26. <https://arxiv.org/abs/1811.10154> (verified: primary) [31] 12 CFR 1002.9 (Regulation B, notifications; 1002.9(b)(2) specific principal reasons; the official commentary is [57]). eCFR (text as of 2026-09-01). 2026-09-01. <https://www.ecfr.gov/current/title-12/chapter-X/part-1002/section-1002.9> (verified: primary) [32] "A Unified Approach to Interpreting Model Predictions" (S. Lundberg, S.-I. Lee; SHAP). arXiv 1705.07874. 2017-05-22. <https://arxiv.org/abs/1705.07874> (verified: primary) [33] "'Why Should I Trust You?': Explaining the Predictions of Any Classifier" (M. T. Ribeiro, S. Singh, C. Guestrin; LIME). arXiv 1602.04938. 2016-02-16. <https://arxiv.org/abs/1602.04938> (verified: primary) [34] "Axiomatic Attribution for Deep Networks" (M. Sundararajan, A. Taly, Q. Yan; integrated gradients; sensitivity and implementation invariance). arXiv 1703.01365. 2017-03-04. <https://arxiv.org/abs/1703.01365> (verified: primary) [35] "Fooling LIME and SHAP: Adversarial Attacks on Post hoc Explanation Methods" (D. Slack, S. Hilgard, E. Jia, S. Singh, H. Lakkaraju). arXiv 1911.02508. 2019-11-06. <https://arxiv.org/abs/1911.02508> (verified: primary) [36] "Sanity Checks for Saliency Maps" (J. Adebayo et al.; some saliency methods are independent of model and data). arXiv 1810.03292. 2018-10-08. <https://arxiv.org/abs/1810.03292> (verified: primary) [37] "Counterfactual Explanations without Opening the Black Box: Automated Decisions and the GDPR" (S. Wachter, B. Mittelstadt, C. Russell; Harvard Journal of Law & Technology, 2018). arXiv 1711.00399. 2017-11-01. <https://arxiv.org/abs/1711.00399> (verified: primary) [38] "Language Models Don't Always Say What They Think: Unfaithful Explanations in Chain-of-Thought Prompting" (M. Turpin, J. Michael, E. Perez, S. R. Bowman; accuracy drops of up to 36% on 13 BIG-Bench Hard tasks). arXiv 2305.04388. 2023-05-07. <https://arxiv.org/abs/2305.04388> (verified: primary) [39] "Open Problems in Mechanistic Interpretability" (L. Sharkey et al.). arXiv 2501.16496. 2025-01-27. <https://arxiv.org/abs/2501.16496> (verified: primary) [40] "Evaluating Verifiability in Generative Search Engines" (N. F. Liu, T. Zhang, P. Liang; 51.5% of generated sentences fully supported by citations; 74.5% of citations support their

sentence). arXiv 2304.09848. 2023-04-19. <https://arxiv.org/abs/2304.09848> (verified: primary) [41] 15 U.S.C. § 1681m(a) and § 1681g(f)(1) (duties of users taking adverse action on the basis of a consumer report; credit score, range and key factors, not more than four). US Government Publishing Office, GovInfo (United States Code, 2024 edition). 2024. <https://www.govinfo.gov/content/pkg/USCODE-2024-title15/html/USCODE-2024-title15-chap41-subchapIII.htm> (verified: primary) [42] Data (Use and Access) Act 2025, s. 80 (replaces UK GDPR Art. 22 with Arts. 22A–22D; Art. 22A no meaningful human involvement; Art. 22C safeguards: information, representations, human intervention, contest; in force 5 Feb 2026). legislation.gov.uk. 2025. <https://www.legislation.gov.uk/ukpga/2025/18/section/80> (verified: primary) [43] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 13 (transparency and provision of information to deployers; 13(2) "relevant, accessible and comprehensible to deployers"; 13(3)(b)(iv), (v), (vii); 13(3)(d)). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_13 (verified: primary) [44] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 86 (right to explanation of individual decision-making; Annex III except point 2; subsidiary to other Union law under 86(3)). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_86 (verified: primary) [45] Withdrawn guidance (Circular 2022-03 on adverse-action notices for credit decisions based on complex algorithms and Circular 2023-03 on adverse-action reasons and sample forms, both withdrawn 12 May 2025). Consumer Financial Protection Bureau. 2025-05-12. <https://www.consumerfinance.gov/compliance/guidance/withdrawn-guidance/> (verified: primary) [46] "CJEU's first ruling on Article 22 GDPR: 'credit scoring' is an automated decision" (C-634/21 SCHUFA, 7 Dec 2023; a probability value is an Art. 22(1) decision where a third party draws strongly on it). Cloisters. 2023-12-14. <https://www.cloisters.com/latest/cjeus-first-ruling-on-article-22-gdpr-credit-scoring-is-an-automated-decision> (verified: secondary) [47] CJEU, 27 February 2025, CK v Magistrat der Stadt Wien and Dun & Bradstreet Austria GmbH, C-203/22 (paras. 58 to 62 and 74 to 76; Art. 15(1)(h): explain "the procedure and principles actually applied"; a complex mathematical formula is not a sufficiently concise and intelligible explanation; for profiling, the effect of a variation in the personal data on the result can suffice (para. 62); trade secrets balanced case by case by the authority or court). Court of Justice of the EU (EUR-Lex). 2025-02-27. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:62022CJ0203> (verified: primary) [48] "ECJ Ruling on Automated Decision-Making and Data Subject Access" (commentary on C-203/22: an explanation of how variations in the data might change the outcome). Clyde & Co. 2025-03. <https://clydeco.com/en/insights/2025/03/ecj-ruling-on-automated-decision-making-and-data-s> (verified: secondary) [49] Explaining decisions made with AI (co-badged ICO and The Alan Turing Institute guidance; six explanation types; under review after the Data (Use and Access) Act). Information Commissioner's Office. consulted 2026-09-24. <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/explaining-decisions-made-with-artificial-intelligence/> (verified: primary) [50] "The Digital Omnibus: a step back from the brink, but the risks remain" (first Council compromise drops the proposed rewrite of GDPR Art. 22; GDPR amendments still in negotiation). European Digital Rights (EDRi). 2026-03-17. <https://edri.org/our-work/the-digital-omnibus-a-step-back-from-the-brink-but-the-risks-remain/> (verified: secondary) [51] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 26(11) (deployers of Annex III high-risk systems that make or assist decisions about natural persons must inform them). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_26 (verified: primary) [52] "Towards A Rigorous Science of Interpretable Machine Learning" (F. Doshi-Velez, B. Kim; application-grounded, human-grounded and functionally-grounded evaluation). arXiv 1702.08608. 2017-02-28. <https://arxiv.org/abs/1702.08608> (verified: primary) [53] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 16(l) (providers of high-risk systems ensure accessibility requirements under Directives (EU) 2016/2102 and (EU) 2019/882). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_16 (verified: primary) [54] Web Content Accessibility Guidelines (WCAG) 2.2 (W3C Recommendation; SC 1.1.1, 1.4.1, 3.1.5). W3C. 2024-12-12. <https://www.w3.org/TR/WCAG22/> (verified: primary) [55] ISO/IEC TR 24027:2021, Bias in AI systems and AI aided decision making (referenced by identifier and title only). ISO/IEC JTC 1/SC 42. 2021. <https://www.iso.org/standard/77607.html> (verified: secondary) [56] ISO/IEC TS 6254:2025, Information technology, Artificial intelligence: Objectives and approaches for explainability and interpretability of machine learning (ML) models and artificial intelligence (AI) systems (published, edition 1; referenced by identifier and title only). ISO/IEC JTC 1/SC 42. 2025-09. <https://www.iso.org/standard/82148.html> (verified: primary) [57] 12 CFR Part 1002, Supplement I, Official Interpretations, comments 9(b)(2)-1 to -5 (more than four reasons not likely helpful; reasons must relate to and accurately describe the factors actually considered or scored; no principal reason left out; no single reason-selection method required, two reference methods against average scores). eCFR (text as of 2026-09-01). 2026-09-01. <https://www.ecfr.gov/current/title-12/chapter-X/part-1002/appendix-Supplement%20I%20to%20Part%201002> (verified: primary)

17. Incidents, issues and root causes

AI incident management turns a runtime signal into an event that is classified, contained, reported on every clock that applies and explained, with its cause fed back into the controls.

This chapter extends two things the book already has. The **Incident Pipeline** pattern (chapter 05) wires detection to a report with the statutory timer running; the Article 73 clock table in the [regulatory map](#) (chapter 08) says how long that timer is. Neither says what counts as an incident below the serious threshold, how to rank severity, who pulls which lever, how to find the cause, or what to do when one event starts four clocks at once.

One contrast first. **Security incident response**, the sibling discipline's home ground, handles compromise: an attacker, a vulnerability, a breach. AI incident management inherits its lifecycle and many of its tools, but the harm set is wider (discrimination, unsafe advice, rights infringements, misinformation acted upon) and the failure is often behaviour rather than compromise: a model that drifts, an agent that uses a permitted tool in a harmful way. Nothing was breached, and people were still hurt. The deliverable is a governed event with an evidence trail, not only a restored service.

Incident, hazard, issue and serious incident

Four words decide whether a clock starts, so define them before anything else.

The OECD's definitions are the most widely shared starting point. An **AI incident** is an event, circumstance or series of events where the development, use or malfunction of one or more AI systems directly or indirectly leads to harm: injury or harm to the health of people, disruption of critical infrastructure, violations of human rights or of legal obligations protecting fundamental, labour and intellectual property rights, or harm to property, communities or the environment. An **AI hazard** is the same kind of event where the AI system *could plausibly lead* to such an incident [1]. The OECD paper also defines graded terms (serious AI incident, AI disaster, serious AI hazard), and its common reporting framework uses that ladder as the values of its severity field [1] [2].

The EU AI Act defines only the top of the ladder. A **serious incident** under [Art. 3\(49\)](#) is an incident or malfunctioning of an AI system that directly or indirectly leads to one of four outcomes: (a) the death of a person or serious harm to a person's health; (b) a serious and irreversible disruption of the management or operation of critical infrastructure; (c) the infringement of obligations under Union law intended to protect fundamental rights; or (d) serious harm to property or the environment [3]. A separate defined term, **widespread infringement** ([Art. 3\(61\)](#)), covers acts contrary to Union law that harm the collective interests of individuals across several Member States; it shortens the reporting deadline, as the clocks section shows [3].

Two more terms are house definitions, and the book uses them consistently:

- An **issue** is a defect, deviation or control weakness that has not produced an event: an eval that regressed below its threshold in staging, a drift alert, a model card that no longer matches the deployed version, a guardrail whose false-positive rate has doubled. An issue is tracked to closure with an owner and a due date. In ISO/IEC 42001 terms most issues are nonconformities handled under clause 10.2 [4].
- A **near miss** is a hazard that a control (or luck) interrupted: the guardrail blocked the exfiltration attempt, the human reviewer caught the invented dosage. No harm occurred, but the path to harm was real. The GPAI Code of Practice asks providers to report "individual or aggregate data on near misses" connected to a serious incident, which tells you near misses are evidence, not noise [5].

Term	Harm realised?	Starts a legal clock?	Where it lives	Example
Issue	No event	No	Issue log (backlog with owner, due date)	Injection eval drops from 0.98 to 0.93 in staging
Near miss / AI hazard	No, but plausible	No, but may be data inside a GPAI report	Incident record, severity SEV-4	Guardrail blocks an agent's attempt to send order data to an external URL
AI incident	Yes	Only if a regime's trigger is met	Incident record, SEV-3 or above	Assistant quotes a wrong refund policy to 40 customers
Serious incident (Art. 3(49))	Yes, at one of four legal thresholds	Yes, for high-risk providers and GPAI systemic-risk providers	Incident record, SEV-1 or SEV-2, with clocks	Credit model's drift produces discriminatory refusals

The distinction that matters most in practice is between *severity* and *reportability*. Severity is a judgement about harm on your internal scale. Reportability is a separate test, run once per regime, against that regime's trigger. A moderate incident can still be notifiable (a small personal data breach under GDPR); a severe one can fall outside every regime's scope (a non-high-risk system with no personal data involved). Keep the two decisions in separate fields, made by named people, with timestamps.

In practice (illustrative) In a large telco, the first useful change to the incident process was not a new tool but a new field. Tickets had one "priority" value that engineering set for urgency and legal read as reportability, and the two readings disagreed silently. Splitting it into `severity` (set by the on-call engineer from a harm table) and one `reportable_<regime>` flag per applicable regime (set by the privacy and legal owners, each with a timestamp and a rationale) made every decision reviewable afterwards. The first review found tickets from the prior quarter that should have been assessed for GDPR notification and never were.

A severity scale mapped to the clocks

A severity scale is a policy, so write it as one. The scale below has four incident levels and one level for issues. It is illustrative; what matters is that each level names a harm test, maps to the legal classes it can trigger and carries a default response.

Level	Harm test	AI Act class it can trigger	OECD severity value [2]	Default response
SEV-1 Critical	Death; serious harm to health; serious and irreversible disruption of critical infrastructure; widespread infringement	Art. 73(4) death: 10 days; Art. 73(3) : 2 days	Serious incident; disaster	Incident commander within 15 minutes; contain first; legal and DPO on the bridge
SEV-2 Major	Infringement of fundamental-rights obligations; serious harm to property or environment; high-risk personal data breach; serious cybersecurity breach of a model	Art. 73(2) : 15 days	Serious incident	Same working day; reportability assessed per regime within hours
SEV-3 Moderate	Realised harm that is limited, recoverable and below the serious thresholds	None on its own; check GDPR, NIS2, DORA	Incident	Contain same day; after-action review within five working days
SEV-4 Near miss	No harm; a plausible path to harm was interrupted	None; near-miss patterns feed GPAI reports [5]	Hazard; serious hazard	Weekly review; regression eval added
Issue	Defect or control weakness with no event	None	Not an event	Issue log with owner and due date

Three rules make the scale work under pressure.

1. **Classify up, downgrade with evidence.** At triage you rarely know the full harm. Classify against the most severe plausible reading and record why; downgrade when evidence narrows it. The AI Act supports this reading: the outer deadlines run from awareness, and the "reasonable likelihood" of a causal link is enough to call for the report [3].
2. **Severity follows harm, not cause.** A trivial bug that caused a death is SEV-1; a sophisticated attack that a guardrail stopped is SEV-4. Technical interest is not a severity input.
3. **The scale is code.** The harm tests and the regime triggers are evaluated by a rule engine when an incident opens, so the first classification and the clocks it starts are reproducible, versioned and auditable. A human can override; the override is logged with a reason.

Example (illustrative) A severity rule written as a [Policy Card](#) fires when an incident record has `harm.type` of `fundamental_rights` and `system.ai_act_class` of `high_risk`: it sets `severity: SEV-2`, opens an `ai_act_art73` clock with a 15-day ceiling from the `aware_at` timestamp, and pages the system owner and legal. The verdict itself is stored as evidence, so a later reviewer can see which rule version classified the event.

Two caveats on the mapping. The AI Act classes apply only to high-risk systems (for [Art. 73](#)) and to GPAI models with systemic risk (for [Art. 55](#)), and the GPAI classes differ slightly: the Code of Practice adds a five-day class for serious cybersecurity breaches, including exfiltration of model weights [5]. And the OECD values are a vocabulary for reporting, not a legal threshold.

The response lifecycle

NIST's incident-response guidance changed shape in April 2025. SP 800-61 Revision 3 superseded the 2012 revision and its circular lifecycle (preparation; detection and analysis; containment, eradication and recovery; post-incident activity) with a model built on the six CSF 2.0 functions, arguing that incidents are now frequent and long, and that lessons should be shared as soon as they are identified [6]. The phases below keep the familiar verbs, because on-call engineers think in them, and map each to the CSF function NIST now uses.

Phase	AI-specific actions	Evidence record it leaves	Layer	CSF 2.0 function [6]
Detect	Guardrail events, production eval regressions, drift alerts, user complaints, deployer or provider notices, incident-database scans	Signal event with source, timestamp and registry id	04 · 05	Detect
Triage	Severity from the harm table; reportability per regime; owner and incident commander named; <code>aware_at</code> fixed	Incident record opened; clocks started	05	Detect · Respond
Contain	Kill switch or circuit breaker; scope revocation; fallback to a human path; rollback to the last good model or prompt version; deployer suspension	Containment action with actor, time and scope	04	Respond
Eradicate	Fix the cause: patch the guardrail, remove poisoned data, revoke credentials, retrain; only after evidence is preserved	Change record linked to the incident	01 · 03	Respond
Recover	Re-run the eval gate; staged reintroduction; heightened monitoring window	Eval-gate result; monitoring window closed	03 · 04	Recover
After-action review	Blameless review; root cause; CAPA; risk register and eval updates	Review record; CAPA items; updated risk entries	05	Identify (Improvement)

Detection needs more channels than the runtime signals from [layer 04](#). The GPAI Code of Practice expects providers to review police and media reports, social media, research papers and incident databases, and to facilitate reporting by downstream modifiers, downstream providers and users by telling them of direct reporting channels, to the provider or to the AI Office, where these are available [5]. A deployer that only watches its own dashboards will learn about some incidents from a journalist. Staff are a channel too: [a channel for raising concerns](#) (chapter 12) routes their reports into the same pipeline, and for a high-risk provider the post-market monitoring plan is a standing source ([post-market monitoring and serious incidents under the AI Act](#), chapter 18).

Containment is where the runtime patterns earn their keep. A [kill switch](#) that revokes one agent's scope without breaking the fleet, a [runtime guardrail](#) tightened by a config push, and a registry that knows the live and the last good version turn "contain" from a meeting into a command. The NIST AI RMF names the capability: mechanisms and assigned responsibilities to "supersede, disengage, or deactivate" AI systems whose performance or outcomes are inconsistent with intended use [7].

Freeze before you fix

The instinct after containment is to fix the thing. For a high-risk system the AI Act says wait: after reporting a serious incident, the provider investigates, including a risk assessment and corrective action, but must not perform any investigation that alters the system in a way that may affect the later evaluation of the incident's causes before informing the competent authorities [3]. Engineering reads that as a preservation step between contain and eradicate:

- **Snapshot the system as it was.** Model version and hash, system prompt, policy and guardrail versions, tool scopes, retrieval index snapshot, configuration and feature flags, all keyed to the registry id and the incident id.
- **Seal the traces.** The [Art. 12](#) logs and the runtime traces for the incident window, exported to tamper-evident storage. Deployers must keep a high-risk system's automatically generated logs, where under their control, for at least six months unless other law says otherwise [3]; an open incident is a reason to hold them longer.
- **Record who touched what.** Every containment and diagnostic action is logged with its actor, so the evaluation of causes can separate the incident from the response.
- **Fix on a branch, not in place.** Eradication runs as a change to a new version; the incident version stays reproducible.

Retention outlives the incident. The Code of Practice commits GPAI signatories to keep incident documentation for at least five years from the documentation or the incident, whichever is later [5]. The frozen evidence also feeds the [defence file](#) that product liability law now lets a court order disclosed (chapter 20).

Playbooks, RACI and drills

A playbook is the response to one failure mode, written before it happens. Keep it short enough to read during the incident and specific enough to act on without interpretation.

```
# playbook: indirect-prompt-injection (illustrative)
trigger: guardrail rule output.exfil.* fires, or a tool call to an unregistered domain
first_15_minutes:
  - page: on-call engineer, AI governance engineer
  - contain: revoke agent tool scope "http:egress" via kill switch; keep read scopes
  - preserve: snapshot registry entry, prompt, retrieval index; seal traces for the window
decision_rights:
  kill_switch: on-call engineer (no approval needed)
  customer_notice: DPO
  regulator_filing: legal, on DPO or system-owner recommendation
```

```
evidence_checklist: [trace_ids, guardrail_events, affected_records, scope_revocation_event]
regimes_to_assess: [gdpr_art33, gdpr_art34, nis2_art23, ai_act_art73]
```

The decision-rights block matters most. Whoever is on call must be able to pull the kill switch without asking, because containment that waits for a committee is not containment. Filing with a regulator is the opposite: it needs named owners with the authority to sign. A RACI makes both explicit (R responsible, A accountable, C consulted, I informed):

Activity	On-call engineer	AI governance engineer	System owner	Security IR lead	DPO	Legal	Provider liaison
Detect and open the record	R	C	I	C	I	I	I
Set severity	R	A	C	C	C	I	I
Pull the kill switch or suspend use	R	I	A	C	I	I	I
Preserve evidence	R	A	I	C	I	C	I
Decide reportability per regime	I	C	C	C	R (GDPR)	A	C
File the regulatory report	I	C	C	C (NIS2, DORA)	R (GDPR)	A	I
Inform the provider (deployer duty)	I	C	A	I	I	C	R
Root-cause analysis	C	R	A	C	C	I	C
Approve CAPA and close	I	R	A	C	C	C	I

Adapt the columns to your organisation; do not drop the rows. Each row is an artefact someone must produce, and an empty cell at 2 a.m. is a gap an auditor will find later.

Drills are the control; the playbook is the claim. The book treats an untested kill switch as a claim, not a control, and the same test applies to the playbook. Run tabletop exercises on a schedule, score them and keep the result as evidence:

- **Scenarios.** Rotate through the failure modes below: an indirect prompt injection that exfiltrates data; drift that produces discriminatory outcomes; a vendor that silently changes the model behind an API; an agent loop that burns budget and calls tools thousands of times; confident, wrong advice acted on by a user.
- **Measures.** Time to classify, time to contain, time to a draft report for each clock, and whether each clock would have been met. Track mean time to detect (MTTD), to contain (MTTC) and to recover (MTTR) across real incidents and drills separately.
- **Evidence.** The drill produces the same records a real incident would (record, clocks, draft reports, containment events), tagged as a drill. An auditor asking "can you report on time?" gets a query over drill results, not a promise.

In practice (illustrative) A quarterly tabletop in a large telco replayed an injection scenario against a customer-service agent. The first run took 50 minutes to revoke the agent's egress scope, because the only person who knew the revocation command was on leave. The fix was a one-line runbook entry and a second named holder; the next run took four minutes. The drill record, with both timings, went into the assurance store as evidence for the containment control.

AI-specific failure modes

Most AI incidents are system incidents, not model incidents: the model behaved as models do, and the system around it (retrieval, tools, prompts, oversight) turned that behaviour into harm. The table names the failure modes that recur, the signal that usually detects them and the first containment move.

Failure mode	What it looks like in production	Typical detection signal	First containment
Brittleness	Small, benign input changes produce large output changes; out-of-distribution inputs break behaviour	Spike in low-confidence or inconsistent outputs; complaints clustered on a new input type	Route the affected input class to a fallback or a human
Lack of robustness	Adversarial or noisy inputs degrade accuracy or safety	Red-team finding reproduced in production; guardrail hit-rate change	Tighten input filters; rate-limit the pattern
Poor or unrepresentative data	Error rates differ by subgroup; retrieval returns stale or wrong documents	Subgroup metrics in monitoring; grounding failures	Suspend the affected decision class; pin the last good corpus

Failure mode	What it looks like in production	Typical detection signal	First containment
Drift	The input distribution (data drift) or the input-outcome relationship (concept drift) moves after deployment	Distribution tests against the eval baseline; outcome metrics	Raise the human-review share; roll back or retrain
Prompt injection	Instructions hidden in user input or in retrieved content redirect the system; OWASP lists it first (LLM01:2025), direct and indirect [8]	Guardrail events; tool calls outside the task; unusual egress	Revoke the tool scope the injection used; quarantine the source document
Tool misuse	An agent uses a permitted tool in an unintended or harmful way (ASI02) [9]	Tool-call volume or parameter anomalies against the registry scope	Kill switch on the agent; narrow the scope
Hallucination with harm	Invented facts, citations, policies or dosages that a person acts on	Complaints; downstream corrections; groundedness checks	Disable the answer class; require grounding or a citation
Cascading failures	One agent's error propagates through others (ASI08) [9]	Correlated failures across agents sharing a tool or memory	Break the chain at the shared component
Rogue behaviour	An agent acts outside its declared scope or persists after it should stop (ASI10) [9]	Identity events outside scope; activity after expiry	Revoke identity; verify the revocation took effect

Two practical points follow. First, a failure mode is a *hypothesis* at triage and a *finding* only after root-cause analysis; do not let the first label stick. Second, every row maps to a test that could have caught it earlier (an adversarial case, a subgroup eval, a drift threshold), which is why the after-action review ends in the eval suite, not in a slide. For agents, chapter 23 extends the table into [the agent incident taxonomy](#).

Root-cause analysis

Root-cause analysis (RCA) answers "why did this happen, and why did our controls not stop it?" The second half is the part AI governance engineering adds: an incident is also evidence that a control failed, was missing, or was never designed.

Who takes part

Run the review as a small **incident review board** with a standing core and invited specialists:

- a facilitator who is not in the reporting line of anyone involved;
- the system owner, who is accountable for the CAPA;
- the ML or data engineer who knows the model and its data;
- the AI governance engineer, who owns the mapping from cause to control and to obligation;
- security, when an adversary or a vulnerability is plausible;
- the DPO and legal, when personal data or rights are involved;
- someone who represents the people affected (customer operations, a domain expert, a clinician), so harm is described from the receiving end.

The board meets for every SEV-1 and SEV-2 incident and samples SEV-3 incidents and near misses. It decides four things and records each as a decision: the confirmed causes, the CAPA items and owners, the changes to the risk register, and closure.

Techniques

Five whys. Ask why the harm happened, then why that happened, until you reach a cause you can change. It is fast, but it follows one chain, while AI failures usually have several contributing causes (a data gap *and* a missing eval *and* an oversight step that rubber-stamped). It also tends to stop at "human error", which is where analysis should start.

Fault tree analysis. Start from the top event (the harm) and decompose it through AND and OR gates into the conditions that had to hold for it to occur; IEC 61025 standardises the method [10]. It suits governed AI systems well, because controls are layered: a harmful output reached a customer only if the model produced it AND the output guardrail missed it AND no human review applied. The tree shows which layers failed together, and which single fix would have broken the chain.

Blameless post-mortem. The review looks for contributing causes "without indicting any individual or team", on the premise that people acted reasonably on what they knew and that you can fix systems and processes but not people [11]. Set the triggers for a mandatory post-mortem in advance (every SEV-1 and SEV-2, every regulatory filing, every kill-switch pull) so that writing one is routine, not an accusation [11].

A cause taxonomy that points at controls

A cause taxonomy is useful only if each class names the control that should have caught it. Code every confirmed cause against one or more of these classes:

Cause class	What it means	Control that should have caught it	Layer	Pattern
Data	Poor-quality, unrepresentative, stale or poisoned training or retrieval data	Data card, lineage, data-quality and bias tests	02 · 03	Eval Gate in CI
Model limits	Brittleness, lack of robustness, hallucination, capability limits	Capability and robustness evals; red team	03	Adversarial Red-Team Suite
Drift	Data or concept drift after deployment	Monitoring against the eval baseline; retraining triggers	04 · 05	Continuous Assurance Telemetry
Testing gap	Too little or unrepresentative testing; a suite tuned to its own threshold	Eval-suite coverage review; adversarial case maintenance	03	Eval Gate in CI
Design or specification	Misaligned objective, wrong proxy metric, flawed prompt or workflow design	Design review; policy as code on intended use	01	Policy Card
Integration and tooling	Excessive tool scope, missing mediation, shared credentials	Scoped identity; tool-call mediation	04	Agent Identity & Scoped Credentials
Adversarial	Prompt injection, jailbreak, supply-chain compromise	Red team; input and output guardrails; AIBOM	03 · 04	Runtime Guardrail
Oversight failure	Automation bias; a reviewer without context, time or authority; no checkpoint	Designed oversight with measured override rates	04	Human-in-the-loop Gate
Change management	Unreviewed model, prompt or config change; silent vendor update	Registry versioning; change gate; vendor notice terms	01 · 02	Vendor / Model Due-Diligence Gate
Use outside intended purpose	Deployment beyond the use the system was assessed for	Intake and classification ; instructions for use	01 · 02	Agent Registry
Organisational	No owner, unclear decision rights, alert fatigue, untrained staff	Operating model, RACI, drills	05	Incident Pipeline

The taxonomy is not only a learning device; regulators ask for it. The Commission's reporting template for GPAI serious incidents has a root-cause field that asks for the model outputs that led to the incident and the factors behind them, including the inputs used and any failures or circumventions of systemic-risk mitigations [12]. NIS2's final report asks for "the type of threat or root cause" likely to have triggered a significant incident [13]. DORA goes further: recurring incidents that are individually below the major threshold count as one major incident when they occur at least twice within six months with the same apparent root cause and together meet the criteria [14]. Inconsistent cause coding therefore does more than spoil your statistics: under DORA it can hide a reportable incident. The OECD reporting framework keeps its own cause-adjacent fields (whether the incident is linked to the training data, to the AI model, or to the interaction of several AI systems) that the same coding can fill [2].

Example (illustrative) A fault tree for "discriminatory refusals reached applicants" has three AND-ed branches: the model's error rate rose for one age band (cause class: drift); the monitoring compared only aggregate accuracy, not subgroup accuracy (testing gap); and reviewers approved 99% of model recommendations in under ten seconds (oversight failure). Fixing any one branch would have broken the chain. The board assigns three CAPA items, one per branch, and records all three cause codes on the incident.

CAPA: from incident to risk register and eval suite

CAPA (corrective and preventive action) is the output of the review. The corrective action fixes this instance: patch, retrain, roll back, re-scope. The preventive action stops the class of failure recurring anywhere in the fleet: a new eval case for every similar system, a policy change, a registry field made mandatory. ISO/IEC 42001 places this in clause 10.2 [4]; the NIST AI RMF asks that incidents and errors be communicated to relevant AI actors, including affected communities, and that tracking and response processes be documented [7]. For high-risk providers the AI Act adds hard edges: a provider with reason to consider a system non-conforming must immediately bring it into conformity, withdraw, disable or recall it, and inform distributors and deployers; where it presents a risk, the provider investigates the causes with the reporting deployer and informs the market-surveillance authority [3].

Every closed incident should leave five artefacts behind:

1. **A regression eval.** The incident becomes a test case that fails on the incident version and passes on the fix, wired into the [eval gate](#) so the failure cannot ship again unnoticed.
2. **A risk register change.** Either a new risk or a re-scored existing one, with the incident id attached. The link runs both ways: the incident record lists the risks it realised, and the risk entry lists the incidents that realised it. The risk method itself is chapter 13, [risk management](#).
3. **A control change** where the fault tree found one: a tightened guardrail, a narrower scope, a new oversight checkpoint.
4. **A playbook update**, if the response itself was slow or unclear.

5. **An evidence record** that the CAPA was verified: the new eval passes in CI, and the runtime metric has stayed at baseline for a defined window.

Two cross-checks keep the link to the risk register honest. A risk scored "low likelihood" that already has two incidents attached is mis-scored. An incident that matches no risk in the register is itself a finding: risk identification missed it, and that goes on the CAPA list too.

```
{
  "capa_id": "CAPA-2026-041",
  "incident_id": "INC-2026-0918-01",
  "type": "preventive",
  "cause_codes": ["adversarial", "integration_and_tooling"],
  "action": "Add indirect-injection cases from quarantined documents to injection-resistance.v5",
  "owner": "team-support-platform",
  "due": "2026-10-02",
  "risk_ids": ["RISK-017"],
  "verification": { "eval_suite": "injection-resistance.v5", "result": "pending" }
}
```

Measure the loop, not the paperwork: recurrence rate by cause class, CAPA items closed and verified on time, the share of incidents that produced a regression eval, and MTTD and MTTC trends. Those are realised-risk-reduction numbers; a count of post-mortems written is not.

Deployer duties: inform the provider, suspend use

Most organisations meet AI incidents as **deployers** of a system someone else built. For high-risk systems, [Art. 26\(5\)](#) sets three duties [3]:

- **Monitor** the system's operation on the basis of the instructions for use and, where relevant, inform the provider for its post-market monitoring.
- **Inform and suspend.** Where the deployer has reason to consider that using the system as instructed may present a risk within the meaning of [Art. 79\(1\)](#), it informs the provider or distributor and the market-surveillance authority without undue delay, and suspends use.
- **Report serious incidents up the chain.** Where the deployer identifies a serious incident, it immediately informs first the provider, then the importer or distributor and the market-surveillance authority. If it cannot reach the provider, [Art. 73](#) applies to the deployer mutatis mutandis: the deployer inherits the reporting clock.

Two carve-outs apply: the duty does not cover sensitive operational data of law-enforcement deployers, and for financial institutions the monitoring duty is deemed fulfilled by complying with their internal-governance rules under financial-services law [3]. These duties apply with the rest of the high-risk regime, from 2 Dec 2027 for Annex III systems after the Digital Omnibus (see [chapter 08](#)).

Each duty needs an engineered artefact, and none of them exists by default:

Duty	Artefact	Where it lives
Monitor per the instructions for use	Monitoring hooks for the metrics the provider's instructions name; thresholds as code	Layer 04
Inform the provider	Provider incident contact and channel in the registry entry; contractual notification terms tested in drills	Layer 02
Suspend use	A tested suspension path for a procured system: feature flag, traffic switch to a human or legacy path	Layer 04
Serious incident: provider first	The deployer's incident record exports the provider-facing report; timestamps of each notification	Layer 05
Provider unreachable	Fallback clock: the same Art. 73 timers start on the deployer's own record	Layer 05
Evidence for the provider's investigation	Deployer-held logs retained at least six months, longer while an incident is open [3]	Layers 04 - 05

Suspension is a kill switch for a system you do not own. You cannot revoke a vendor's weights, but you can stop sending it traffic; test that you can, and how long it takes, before you need it. The [Incident Pipeline](#) builds the deployer side. The [Vendor / Model Due-Diligence Gate](#) is where the two-way notification terms belong: the provider tells you about incidents and corrective actions that affect your deployment, and you have a named channel to tell the provider. The same logic runs further up the chain for GPAI: the Code of Practice asks model providers to tell downstream providers, modifiers and users how to report serious incidents, directly or to the AI Office [5]. Deployment governance as a whole is chapter 15, [governing deployment](#), whose [external communications plan](#) carries the [notices](#) to users, affected people and authorities.

The overlapping clocks

One event can start several clocks. An indirect prompt injection that leaks customer data from a high-risk system run by a bank can, at once, be a serious incident under the AI Act, a personal data breach under GDPR and a major ICT-related incident under DORA; at a non-financial essential entity the same leak could be a significant incident under NIS2. Each regime has its own trigger, recipient, deadline and content. The table puts them side by side, as of 2026-09-24.

Regime	Who reports	Trigger	First report	Follow-up and final	To whom
EU AI Act Art. 73 [3]	Provider of a high-risk system; the deployer if the provider cannot be reached	Serious incident (Art. 3(49))	Immediately on a causal link or its reasonable likelihood; no later than 2 days (widespread infringement or critical infrastructure), 10 days (death) or 15 days (other) from awareness; an incomplete initial report is allowed	Investigation, risk assessment and corrective action; no altering the system before informing authorities	Market-surveillance authority where it occurred; the AI Office for systems under its competence [15]
EU AI Act Art. 26(5) [3]	Deployer of a high-risk system	Serious incident; or reason to consider the system presents a risk	Serious incident: immediately, provider first; risk: without undue delay, plus suspension	Cooperation with the provider's investigation	Provider, then importer or distributor, and the market-surveillance authority
EU AI Act Art. 55(1)(c) with Code of Practice Commitment 9 [5][16]	Provider of a GPAI model with systemic risk	Serious incident involving the model	Without undue delay; under the Code: 2 days (critical infrastructure), 5 days (serious cybersecurity breach), 10 days (death), 15 days (health, rights, property, environment)	Intermediate report at least every four weeks while unresolved; final report within 60 days of resolution	AI Office and, as applicable, national authorities
GDPR Art. 33 [17]	Controller (the processor notifies the controller without undue delay)	Personal data breach, unless unlikely to result in a risk	Without undue delay and, where feasible, within 72 hours of awareness; reasons required if later	Information may be provided in phases; every breach documented	Supervisory authority
GDPR Art. 34 [17]	Controller	Breach likely to result in a high risk	Without undue delay	None set	Affected data subjects
NIS2 Art. 23 [13]	Essential and important entities	Significant incident	Early warning within 24 hours; incident notification within 72 hours	Intermediate report on request; final report within one month of the notification	CSIRT or competent authority
DORA Art. 19 with RTS 2025/301 [18] [19]	Financial entities	Major ICT-related incident	Within 4 hours of classification as major, and no later than 24 hours from awareness; if classified as major only after those 24 hours, within 4 hours of that classification	Intermediate within 72 hours of the initial notification; final within one month of the latest intermediate report	Financial competent authority
Cyber Resilience Act Art. 14 [20]	Manufacturers of products with digital elements	Actively exploited vulnerability; severe incident affecting product security	Early warning within 24 hours; notification within 72 hours	Final report 14 days after a fix is available (vulnerability) or one month after notification (incident)	Coordinating CSIRT and ENISA, via the single reporting platform
California SB 53 [21]	Frontier developers (all, not only large frontier developers)	Critical safety incident	Within 15 days of discovery; within 24 hours if there is an imminent risk of death or serious physical injury	None set here	Office of Emergency Services; for imminent risk, an appropriate authority

Regime	Who reports	Trigger	First report	Follow-up and final	To whom
New York RAISE Act [22][23]	Frontier developers (models trained above 10 ²⁶ operations; all, not only large frontier developers)	Critical safety incident	Within 72 hours of a determination or of learning facts that support a reasonable belief; within 24 hours if there is an imminent risk of death or serious physical injury; effective 1 Jan 2027	None set here	Oversight office within the Department of Financial Services; for imminent risk, a law enforcement or public safety agency with jurisdiction
OECD common reporting framework [2]	Voluntary	AI incident or hazard	No clock	29 criteria across eight dimensions	Not a filing duty; a shared schema

Reading the table

The triggers are not the same event. GDPR, NIS2, the CRA and Art. 73 count from *awareness*. DORA's four-hour clock counts from *classification* as major, with an outer limit of 24 hours from awareness; a classification made after those 24 hours starts its own four-hour clock (Art. 5(2) of RTS 2025/301) [19]. Art. 73 also asks for the report *immediately* once a causal link, or its reasonable likelihood, is established, with the day counts as outer limits [3]. RAISE counts from a *determination* or a *reasonable belief* [23]. An incident record therefore needs a timestamp per trigger, not one "opened at": first signal, awareness decision, classification per regime, causal link established, and each submission.

Some regimes defer to others. NIS2 steps aside where a sector-specific Union act imposes at least equivalent incident notification, which is how DORA displaces NIS2 reporting for financial entities [13]. The AI Act narrows itself in a similar way: for Annex III systems whose providers are already under equivalent Union reporting obligations, and for AI in medical devices, Art. 73 reporting is limited to fundamental-rights infringements (Art. 3(49)(c)) [3]. According to a law-firm summary of the Commission's draft guidance, the draft applies this to sectors such as NIS2 critical infrastructure [24]. Which regimes count as "equivalent" for a given system is a legal call; record it per system in the registry, not per incident under pressure.

Dates are moving. Four points to re-check before relying on the table, all as of 2026-09-24:

- The high-risk regime applies to Annex III systems from 2 Dec 2027 and to Annex I systems from 2 Aug 2028, after the Digital Omnibus postponed Chapter III, Sections 1 to 3 (Art. 113(c)) [34]. Art. 73 sits in Chapter IX and was not itself postponed, but it reaches a system only once Art. 6 classifies it as high-risk, so in practice it follows the same dates (verify with counsel); the GPAI duties in Art. 55 already apply (see chapter 08).
- The Omnibus left the Art. 73 deadlines unchanged but added Art. 75(1a): providers of high-risk systems under the AI Office's exclusive competence (broadly, systems built on the provider's own GPAI model and systems in very large online platforms or search engines) report serious incidents to the AI Office [15][25].
- The Commission published draft Art. 73 guidance and a reporting template on 26 Sep 2025, aligned with the OECD's incidents monitor and common reporting framework [26]. Whether the final guidance has since been adopted is not confirmed here (verify).
- A separate Digital Omnibus proposal (COM(2025) 837) would change GDPR breach notification and add a single entry point for incident reports. It is tabled, not adopted: as of the Parliament's 1 Aug 2026 update, amendments were under discussion and the Council's mandate had stalled [27]. Commentators report a longer GDPR deadline limited to high-risk breaches (verify). The 72-hour rule stands; chapter 19 covers [AI-specific privacy breaches and the 72-hour clock](#).
- Outside the EU the clocks differ again: chapter 21 lays out the [incident clocks across regimes](#).

One record, many reports

The engineering answer to overlapping clocks is not a better calendar. It is one incident record that holds the facts once, and a generator per regime that renders the report that regime wants, each with its own timer. The clocks live in the record, and the pipeline alerts on the nearest deadline:

```
{
  "incident_id": "INC-2026-0918-01",
  "clocks": [
    { "regime": "gdpr_art33", "trigger": "aware", "trigger_at": "2026-09-18T15:02:00Z",
      "due_at": "2026-09-21T15:02:00Z", "status": "submitted",
      "submitted_at": "2026-09-20T10:40:00Z" },
    { "regime": "nis2_art23", "trigger": "aware", "trigger_at": "2026-09-18T15:02:00Z",
      "status": "not_applicable",
      "rationale": "not significant under Art. 23(3); signed off by security IR lead" },
    { "regime": "ai_act_art73", "status": "not_applicable",
      "rationale": "csa-01 is not a high-risk system (registry class: limited risk)" }
  ]
}
```

A "not applicable" decision is evidence too. Write it down with its rationale and its owner; the question an authority asks a year later is usually "why did you not report?", and the answer should be a record, not a memory.

In practice (illustrative) Replaying a realistic scenario on `csa-01`, the customer-service assistant from [chapter 04](#): an order note carrying hidden instructions made the assistant include another customer's delivery address in a reply. The guardrail logged but did not block the output. Triage set SEV-2 (personal data disclosed to a third party) and ran the regimes. GDPR Art. 33 : notifiable, 72-hour clock from the DPO's awareness decision. GDPR Art. 34 : not high risk for the one affected customer on the facts, decision recorded. NIS2: telecoms providers are in scope as digital infrastructure [13], but a single-record disclosure was not significant, determination recorded. AI Act Art. 73 : not a high-risk system, so no clock; the incident still went to the model provider through its downstream reporting channel. The GDPR notification left in 44 hours, generated from the same record the root-cause review later used.

The incident record

Design the record once, around what the most demanding recipients ask for, and every other report becomes a projection of it. The templates page has the [incident record fields](#) as a JSON Schema with a filled example. Two public schemas set the bar. The Commission's template for GPAI serious incidents asks for ten items: start and end dates, the resulting harm and the victims or affected group, the chain of events, the model involved, the evidence available, the provider's response, its recommendation to the authorities, a root-cause analysis, patterns from post-market monitoring including near misses, and submitter information [12]. The OECD common reporting framework defines 29 criteria in eight dimensions (metadata, harm details, people and planet, economic context, data and input, AI model, task and output, other information) [2].

Field group	Record fields	Commission GPAI template [12]	OECD reporting framework [2]	Filled from
Identity	<code>incident_id</code> , title, description, systems and versions, registry ids, organisations that developed and deployed	Model involved; submitter	Title; description; name and version; organisations; submitter	Registry (layer 02)
Time	<code>first_signal_at</code> , <code>aware_at</code> , <code>started_at</code> , <code>ended_at</code> , per-regime trigger and submission times	Start and end dates	Date of first known occurrence	Traces; pipeline
Harm	Severity, harm type, quantification, affected groups, countries, rights impact	Resulting harm and victims	Severity; harm type; quantification; affected stakeholders; human-rights impacts; countries	Triage; DPO; legal
Context	Industry, business function, critical-infrastructure link, breadth of deployment, task, autonomy level	Chain of events	Industry; business function; critical infrastructure; breadth of deployment; task; autonomy level	Registry; intake record
Cause	Failure-mode hypothesis, confirmed cause codes, link to training data, model or multi-system interaction, misuse	Root-cause analysis; post-market patterns and near misses	Training-data link; model link; multi-system interaction; unintended or wrongful use	Review board
Evidence	Trace ids, snapshots, guardrail events, supporting material	Evidence available	Supporting materials; steps to reproduce	Layers 04 - 05
Response	Containment actions, corrective actions, CAPA ids, recommendation to authorities	Response; recommendation	Actions taken	Incident commander; CAPA
Clocks	One entry per regime: applicability, rationale, owner, due, submitted	Not in template	Not in framework	Pipeline
Links	Risk ids, eval ids added, playbook used	Not in template	Not in framework	Risk register; eval suite

Store the record as structured data in the assurance store, and emit its control-relevant parts as machine-readable evidence: CAPA items map naturally to an [OSCAL](#) plan of action and milestones ([POA&M](#)), the native model's place for open findings and their remediation [28]. That is the [Machine-Readable Evidence](#) pattern applied to incidents, and it lets an auditor query "all SEV-2 incidents in Q3 with open CAPA" instead of asking for a spreadsheet.

Learning from public incident databases

Your own incident history is small and biased toward what you already detect. Public repositories widen it, as long as you know what they are. This site keeps two curated starting points: the [incident cases written as post-mortems](#) and the [harms atlas](#), which maps harms by level to the control that catches each.

- **AI Incident Database (AIID).** Run by the Responsible AI Collaborative, it indexes harms and near harms from deployed AI, in the manner of aviation and computer-security incident databases. It classifies incidents with several taxonomies (the CSET AI Harm Taxonomy, a Goals, Methods and Failures taxonomy, and the MIT AI Risk Repository's) and offers full database snapshots for download [29].
- **OECD AI Incidents and Hazards Monitor (AIM).** An automated monitor of AI incidents and hazards reported in the news media, which keeps incidents and hazards apart as the OECD definitions do [30].
- **AIAAIC Repository.** An independent register of incidents and controversies involving AI, algorithms and automation, across sectors from facial recognition to automated hiring [31].
- **MIT AI Risk Repository.** Not an incident database but a structured catalogue of AI risks with causal and domain taxonomies, useful for checking that your cause taxonomy and risk register have no blind spots [32].

Use them in four ways. **Seed the risk register:** pull the incidents recorded for deployments like yours and check that each has a matching risk. **Write the eval before the incident:** turn a public incident into a test case against your system, feeding the [red-team suite](#) alongside the MITRE ATLAS technique catalogue [33]. **Calibrate the severity scale:** check that real incidents land where your harm tests say they should. **Feed GPAL monitoring:** the Code of Practice lists incident databases among the sources providers should review [5].

Know the limits. Media-sourced collections over-represent the newsworthy, the consumer-facing and the English-speaking; one event can appear several times; and none of them gives base rates. Use them to find failure modes you had not imagined, not to estimate how often yours will occur. The reading list keeps the current links under [incident and risk repositories](#).

What you can do this week

1. **Write the severity scale as policy.** Five levels, a harm test per level, the regime triggers per level; run your last three incidents through it and fix the rules until the results match what you would decide by hand.
2. **Add the timestamps.** Give every incident ticket `aware_at`, a per-regime applicability flag with owner and rationale, and a due time per clock. Backfill the open incidents.
3. **Run one tabletop.** Indirect prompt injection against your most connected assistant: pull the kill switch, preserve the evidence, draft the GDPR notification. Record the times.
4. **Test the suspension path for one procured system.** Confirm the provider's incident contact is in the registry entry and that you can stop traffic to the system, and measure how long it takes.
5. **Code three past events.** Assign cause classes from the taxonomy to your last three incidents or near misses, and add one regression eval for each.

Maps to: EU AI Act Art. 3(49), 20, 26(5)–(6), 55(1)(c), 72, 73, 75(1a) · GPAL Code of Practice, Safety and Security Commitment 9 · GDPR Arts. 33–34 · NIS2 Art. 23 · DORA Art. 19 · Cyber Resilience Act Art. 14 · ISO/IEC 42001 (clause 10.2, Annex A.8) · NIST AI RMF (Manage 2.4, 4.1, 4.3) · NIST SP 800-61r3 · OWASP LLM01:2025, Agentic ASI02/ASI08/ASI10 · Layer 04 Runtime Controls & Observability · Layer 05 Assurance & Continuous Compliance. Mappings are illustrative, not a claim of conformity.

Sources

[1] "Name it to tame it: defining AI incidents and hazards" (Luis Aranda and Karine Perset; summary of the OECD paper "Defining AI incidents and related terms", OECD Artificial Intelligence Papers, doi 10.1787/d1a8d965-en; AI incident and AI hazard definitions; graded terms serious AI incident, AI disaster, serious AI hazard). OECD.AI. 2024-05-17. <https://oecd.ai/en/wonk/defining-ai-incidents-and-hazards> (verified: primary) [2] Towards a common reporting framework for AI incidents (OECD Artificial Intelligence Papers No. 34; 29 criteria in eight dimensions; severity values hazard, serious hazard, incident, serious incident, disaster). OECD. 2025-02. https://www.oecd.org/content/dam/oecd/en/publications/reports/2025/02/towards-a-common-reporting-framework-for-ai-incidents_8c488fdb/f326d4ac-en.pdf (verified: primary) [3] Regulation (EU) 2024/1689 (AI Act) of 13 June 2024: Art. 3(49) serious incident; Art. 3(61) widespread infringement; Art. 20 corrective actions and duty of information; Art. 26(5)–(6) deployer monitoring, suspension, serious-incident information and log retention; Art. 73 reporting of serious incidents (2, 10 and 15 days; incomplete initial report; no altering the system before informing authorities; limits in Art. 73(9)–(10)). Publications Office of the EU (EUR-Lex). 2024-06-13. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [4] ISO/IEC 42001:2023, AI management systems (clause 10.2 nonconformity and corrective action; Annex A.8 information for interested parties). ISO/IEC. 2023. <https://www.iso.org/standard/81230.html> (verified: secondary) [5] General-Purpose AI Code of Practice, Safety and Security chapter, Commitment 9 serious incident reporting (Measure 9.1 identification sources and informing third parties of direct reporting channels, if available; 9.2 information incl. near misses; 9.3 timelines of 2, 5, 10 and 15 days, intermediate reports at least every four weeks, final report within 60 days of resolution; 9.4 retention of at least five years). European Commission. 2025-07-10. <https://ec.europa.eu/newsroom/dae/redirection/document/118119> (verified: primary) [6] NIST SP 800-61r3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile (supersedes SP 800-61r2; previous life-cycle phases mapped to CSF 2.0 functions). NIST. 2025-04. <https://csrc.nist.gov/pubs/sp/800/61/r3/final> (verified: primary) [7] AI Risk Management Framework 1.0, NIST AI 100-1 (MANAGE 2.4 supersede, disengage or deactivate; MANAGE 4.1 post-deployment monitoring incl. incident response; MANAGE 4.3 incidents and errors communicated, processes followed and documented). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [8] LLM01:2025 Prompt

Injection (direct and indirect prompt injection). OWASP GenAI Security Project. 2025. <https://genai.owasp.org/llmrisk/llm01-prompt-injection/> (verified: primary) [9] Top 10 for Agentic Applications 2026 (ASI02 Tool Misuse; ASI08 Cascading Failures; ASI10 Rogue Agents). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [10] IEC 61025:2006, Fault tree analysis (FTA), edition 2.0 (IEC TC 56 Dependability). IEC. 2006-12-13. <https://webstore.iec.ch/en/publication/4311> (verified: primary) [11] "Postmortem Culture: Learning from Failure" (Site Reliability Engineering, ch. 15; blameless postmortems; postmortem triggers set in advance). Google. 2016. <https://sre.google/sre-book/postmortem-culture/> (verified: primary) [12] "AI Act: Commission publishes a reporting template for serious incidents involving general-purpose AI models with systemic risk" (template under Art. 55(1)(c) and Commitment 9; ten fields from start and end dates to root-cause analysis, near-miss patterns and submitter). European Commission. 2025-11-04. <https://digital-strategy.ec.europa.eu/en/library/ai-act-commission-publishes-reporting-template-serious-incidents-involving-general-purpose-ai> (verified: primary) [13] Directive (EU) 2022/2555 (NIS2) of 14 December 2022: Art. 4 sector-specific Union acts; Art. 23 reporting obligations (significant incident; early warning within 24 hours; notification within 72 hours; final report within one month incl. type of threat or root cause); Annex I digital infrastructure incl. providers of public electronic communications networks and services. Publications Office of the EU (EUR-Lex). 2022-12-14. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj/eng> (verified: primary) [14] Commission Delegated Regulation (EU) 2024/1772, RTS on the classification of ICT-related incidents under DORA (Art. 8: major incidents; recurring incidents with the same apparent root cause, occurring at least twice within six months, count as one major incident). Publications Office of the EU (EUR-Lex). 2024-03-13. https://eur-lex.europa.eu/eli/reg_del/2024/1772/oj/eng (verified: primary) [15] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 75 (Art. 75(1a), inserted by Reg. (EU) 2026/1744: serious incidents of high-risk systems under the AI Office's competence reported to the AI Office, Art. 73(2) to (9) applying mutatis mutandis; Art. 73 deadlines unchanged). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_75 (verified: primary) [16] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 55 (GPAI models with systemic risk; Art. 55(1)(c) keep track of, document and report serious incidents to the AI Office without undue delay). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_55 (verified: primary) [17] Regulation (EU) 2016/679 (GDPR) of 27 April 2016: Art. 33 notification of a personal data breach to the supervisory authority (72 hours where feasible; processor to controller; phased information; documentation) and Art. 34 communication to the data subject (high risk). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [18] Regulation (EU) 2022/2554 (DORA) of 14 December 2022: Art. 3(8) ICT-related incident; Art. 19 reporting of major ICT-related incidents. Publications Office of the EU (EUR-Lex). 2022-12-14. <https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng> (verified: primary) [19] Commission Delegated Regulation (EU) 2025/301, RTS on the content and time limits for major ICT-related incident reports under DORA (Art. 5(1): initial notification within 4 hours of classification and no later than 24 hours from awareness; Art. 5(2): within 4 hours of a classification made after those 24 hours; intermediate within 72 hours; final within one month); report templates in Commission Implementing Regulation (EU) 2025/302. Publications Office of the EU (EUR-Lex). 2024-10-23. https://eur-lex.europa.eu/eli/reg_del/2025/301/oj/eng (verified: primary) [20] Regulation (EU) 2024/2847 (Cyber Resilience Act) of 23 October 2024: Art. 14 reporting obligations of manufacturers (24-hour early warning; 72-hour notification; final report 14 days after a fix or one month after notification; CSIRT and ENISA via the single reporting platform); Art. 71(2) Art. 14 applies from 11 Sep 2026. Publications Office of the EU (EUR-Lex). 2024-10-23. <https://eur-lex.europa.eu/eli/reg/2024/2847/oj/eng> (verified: primary) [21] SB 53, Transparency in Frontier Artificial Intelligence Act (Chapter 138, Statutes of 2025; approved 29 Sep 2025; Bus. & Prof. Code 22757.13(c): critical safety incidents reported by any frontier developer, not only a large frontier developer, to the Office of Emergency Services within 15 days, or within 24 hours to an appropriate authority on imminent risk of death or serious physical injury). California Legislative Information. 2025-09-29. https://leginfo.ca.gov/faces/billTextClient.xhtml?bill_id=202520260SB53 (verified: primary) [22] NY State Senate Bill 2025-S6953B (RAISE Act; signed 19 Dec 2025 as Chapter 699; 72-hour safety incident disclosure). New York State Senate. 2025-12-19. <https://www.nysenate.gov/legislation/bills/2025/S6953/amendment/B> (verified: primary) [23] "New York Finalizes RAISE Act for Frontier AI Models; Law Takes Effect January 1, 2027" (chapter amendment; all frontier developers, not only large frontier developers, report a critical safety incident within 72 hours of a determination or reasonable belief to the DFS office; 24 hours to law enforcement or public safety agencies on imminent risk). Wiley. 2026-04-03. <https://www.wiley.law/alert-New-York-Finalizes-RAISE-Act-for-Frontier-AI-Models-Law-Takes-Effect-January-1-2027> (verified: secondary) [24] "European Commission Publishes Draft Guidance on Reporting Serious AI Incidents" (indirect causation; simplified Art. 73 reporting where equivalent sector obligations apply, limited to fundamental-rights infringements). Latham & Watkins. 2025-10-28. <https://www.lw.com/en/insights/european-commission-publishes-draft-guidance-reporting-serious-ai-incidents> (verified: secondary) [25] "EU AI Act Update: Digital Omnibus Finalizes 8 Compliance Changes" (AI Office exclusive competence over AI systems built on the same provider's GPAI model and over systems in very large online platforms and search engines; serious-incident reports from those providers go to the AI Office). Orrick. 2026-07-29. <https://www.orrick.com/en/Insights/2026/07/EU-AI-Act-Update-Digital-Omnibus-Finalizes-8-Compliance-Changes> (verified: secondary) [26] "AI Act: Commission issues draft guidance and reporting template on serious AI incidents, and seeks stakeholders' feedback" (published 26 Sep 2025; feedback until 7 Nov 2025; alignment with the OECD AI Incidents Monitor and Common Reporting Framework). European Commission. 2025-09-26. <https://digital-strategy.ec.europa.eu/en/consultations/ai-act-commission-issues-draft-guidance-and-reporting-template-serious-ai-incidents-and-seeks> (verified: primary) [27] Legislative Train Schedule: The Digital Omnibus Regulation Proposal (COM(2025) 837; status tabled; single reporting point for cybersecurity and data incidents; co-rapporteurs' draft report 22 Jun 2026; Council mandate vote cancelled 26 Jun 2026; page updated 1 Aug 2026). European Parliament. 2026-08-01. <https://www.europarl.europa.eu/legislative-train/theme-a-new-plan-for-europe-s-sustainable-prosperity-and-competitiveness/file-digital-package> (verified: primary) [28] OSCAL native model (control layer: catalog, profile; implementation: component-definition, system-security-plan; assessment: assessment-plan, assessment-results, POA&M). NIST. 2026.

<https://pages.nist.gov/OSCAL/learn/concepts/layer/> (verified: primary) [29] AI Incident Database (harms and near harms from deployed AI; CSET, GMF and MIT taxonomies; database snapshots). Responsible AI Collaborative. 2026. <https://incidentdatabase.ai/> (verified: primary) [30] OECD.AI Incidents and Hazards Monitor (AIM; automated monitor of news media; incidents and hazards distinguished). OECD. 2026. <https://oecd.ai/en/incidents> (verified: primary) [31] AIAAIC Repository (independent register of AI, algorithmic and automation incidents and controversies). AIAAIC. 2026. <https://www.aiaaic.org/aiaaic-repository> (verified: primary) [32] MIT AI Risk Repository (living database of AI risks; causal and domain taxonomies). MIT FutureTech. 2026. <https://airisk.mit.edu/> (verified: primary) [33] MITRE ATLAS: adversarial tactics and techniques knowledge base for AI systems (incl. agents). MITRE. 2026. <https://atlas.mitre.org/> (verified: primary) [34] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 113 (Art. 113(c) as amended by Reg. (EU) 2026/1744: Chapter III, Sections 1 to 3, apply from 2 Dec 2027 for Annex III systems and from 2 Aug 2028 for Annex I systems; Chapter IX, Art. 73 included, is not listed among the postponed provisions). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_113 (verified: primary)

18. The EU AI Act in one pass

The EU AI Act, as amended by the Digital Omnibus, read end to end: what it covers, how it ranks risk, who carries which duty, and the date each duty starts to apply.

How to read this chapter

This chapter teaches the Act; [chapter 08](#) indexes it. Read this one for the logic of the law and chapter 08 for the full obligation rows. Every duty below names the artefact that evidences it and the stack layer that produces it.

The text is read against Regulation (EU) 2024/1689 [1] as amended by Regulation (EU) 2026/1744, the Digital Omnibus on AI [2], and every date is stamped as of 2026-09-24. It is an engineer's reading, not legal advice. The engineer builds the control and the evidence; counsel confirms that the obligation was read correctly (see [regulatory translation](#)). Mappings are illustrative, not a claim of conformity.

The stack layers named throughout are chapter 04's five: **1 Govern-as-Code · 2 Inventory & Transparency · 3 Evals & Red Teaming as Evidence · 4 Runtime Controls & Observability · 5 Assurance & Continuous Compliance.**

The Act and the Omnibus

The AI Act is a product-safety regulation with fundamental-rights goals. It is directly applicable in every Member State, it entered into force on 1 Aug 2024, and its duties switch on in stages [1][2]. Four ideas carry the whole text:

1. **A definition gate.** Is the thing an AI system, a general-purpose AI (GPAI) model, or neither?
2. **A risk ladder.** Which rung does the system's intended purpose put it on?
3. **A set of operator roles.** Which hat does your organisation wear for this system?
4. **A timeline.** From which date does each duty bite?

The **Digital Omnibus on AI** is Regulation (EU) 2026/1744 of 8 July 2026. It was published in the Official Journal on 24 July 2026 and entered into force on the third day after publication, 27 July 2026 [2]. It did not rewrite the Act. It moved the high-risk dates, added two prohibitions and made targeted changes that matter to an engineer (its GDPR counterpart is a separate proposal, covered in [the GDPR side of the Digital Omnibus](#), chapter 19):

Change	Where	What it means for the engineer
High-risk duties deferred	Art. 113(c)	Annex III from 2027-12-02; Annex I from 2028-08-02
Two new prohibitions	Art. 5(1)(ba), (bb)	Intimate imagery without consent and child sexual abuse material, from 2026-12-02
AI literacy reworded	Art. 4	"Take measures to support" literacy; no guaranteed level
Bias-detection data basis	Art. 4a (Art. 10(5) deleted)	Special-category data for bias correction, with strict safeguards
"Safety component" narrowed	Art. 3(14), 6(1a) to 6(1c)	Fewer embedded systems classed high-risk
SME and small mid-cap (SMC) relief	Arts. 11, 17, 63, 99(6a)	Simplified documentation and QMS; lower-of fines
Value-chain cooperation	Art. 25(2), 25(4), 99(4) (da)	Initial providers must hand over documentation and access; the duty is fined
FRIA may reuse the DPIA	Art. 27(4), 27(5)	One assessment record, cross-referenced
AI Office supervises some systems	Arts. 75(1), 75a to 75d	A second supervisor with direct powers
Cyber Resilience Act presumption	Art. 42(3)	CRA conformity counts for Art. 15 cybersecurity
Notified bodies	Arts. 28 to 30, Annex XIV	Single application; a designation code that names agentic AI (AIH 0401)

All of the above is in the amending text [2]. Article numbers in the rest of the chapter are the post-Omnibus ones.

Scope and reach

Who is in scope

Article 2(1) reaches providers placing AI systems or GPAI models on the EU market, wherever they are established; deployers in the Union; providers and deployers in third countries whose system's output is used in the Union; importers and distributors; product

manufacturers placing AI with their product under their own name; authorised representatives of non-EU providers; and affected persons in the Union [1].

The reach is extraterritorial twice over: by placement and by output [1]. The engineering consequence is a registry field. "Where is it hosted?" is not the scope question; "where is its output used?" is. An agent registry that records only the hosting region cannot answer it.

What counts as an AI system

Article 3(1) defines an **AI system** as "a machine-based system that is designed to operate with varying levels of autonomy and that may exhibit adaptiveness after deployment, and that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments" [1]. The Commission's guidelines read the sentence as seven elements (machine-based; autonomy; possible adaptiveness; objectives; inference; outputs; influence on environments) and note that not every element has to be present in both the building and the use phase [3].

The decisive element is inference. The guidelines exclude systems based on rules defined solely by natural persons, and they name four families that compute but may still fall outside the definition: systems for improving mathematical optimisation, basic data processing, systems based on classical heuristics, and simple prediction systems [3]. The guidelines are not binding [3].

For the engineer, scope is a recorded decision, not an assumption. Each registry entry carries `ai_system: true | false` and, when false, the element that fails and the reasoning. A "not an AI system" call with no reasoning attached is the first thing an authority will ask about. A **GPAI model** is a separate object with its own definition ([Art. 3\(63\)](#)), covered below; a model is not an AI system on its own and needs further components, such as a user interface, to become one (recital 97) [1]. What "AI" means technically, beyond the legal test, is the subject of [chapter 11](#).

What the Act excludes

Exclusion	Article	What to watch
Military, defence or national security	Art. 2(3)	The exclusion covers systems used <i>exclusively</i> for those purposes; a dual-use system is in scope for its other uses
Third-country public authorities and international organisations in law-enforcement or judicial cooperation	Art. 2(4)	Only with adequate safeguards for fundamental rights
Scientific research and development as the sole purpose	Art. 2(6)	The system or model must be specifically developed and put into service for that purpose alone
Research, testing and development before placing on the market	Art. 2(8)	Testing in real-world conditions is not covered by the exclusion
Purely personal, non-professional use	Art. 2(10)	Removes deployer obligations for natural persons only
Free and open-source AI systems	Art. 2(12)	Not if placed on the market as high-risk, or caught by Art. 5 or Art. 50
Products under Annex I, Section B (sectoral regimes)	Art. 2(2)	Post-Omnibus, only Art. 6(1) , Art. 60a and Arts. 102 to 112 apply

The first six rows are in the original text [1]; the Section B row is as amended [2]. Union data protection law applies alongside the Act in every case ([Art. 2\(7\)](#)).

The risk ladder

The Act sorts AI systems by intended purpose onto four rungs, and puts GPAI models on a separate track. One system can sit on two rungs at once: an Annex III chatbot carries both the high-risk duties and the [Art. 50](#) disclosure duty.

Rung	Test	Consequence	Articles	Applies from
Prohibited	The practice is listed in Art. 5	May not be placed on the market, put into service or used	Art. 5	2025-02-02; new points 2026-12-02
High-risk	Annex I safety component needing third-party assessment, or an Annex III use not filtered out by Art. 6(3)	Requirements of Arts. 8 to 15 , provider and deployer duties, conformity assessment	Arts. 6 to 49	2027-12-02 (Annex III); 2028-08-02 (Annex I)
Transparency	Interacts with people, generates synthetic content, recognises emotions, categorises biometrically, or produces deep fakes	Disclose, mark, label	Art. 50	2026-08-02
Minimal	Everything else	No specific duties beyond Art. 4 ; voluntary codes	Arts. 4 , 95	2025-02-02 (Art. 4 reworded 2026-07-27)

Rung	Test	Consequence	Articles	Applies from
GPAL track	Model generality; systemic risk by capability, compute or designation	Model-level duties	Arts. 51 to 56	2025-08-02; Commission enforcement 2026-08-02

Dates are those of [Art. 113](#) as amended [1][2].

Prohibited practices (Article 5)

Article 5 is a list of banned uses, not a risk assessment. If a practice is on the list, no mitigation makes it lawful. The list now has ten points [1][2]:

Point	Prohibited practice (paraphrased)	Narrow carve-out	Applies from
(a)	Subliminal, manipulative or deceptive techniques that materially distort behaviour, causing or likely to cause significant harm	None	2025-02-02
(b)	Exploiting vulnerabilities of age, disability or social or economic situation, to the same effect	None	2025-02-02
(c)	Social scoring leading to unjustified or out-of-context detrimental treatment	None	2025-02-02
(d)	Predicting crime risk based solely on profiling or personality traits	Support to a human assessment based on objective, verifiable facts	2025-02-02
(e)	Untargeted scraping of facial images to build recognition databases	None	2025-02-02
(f)	Inferring emotions at work or in education	Medical or safety reasons	2025-02-02
(g)	Biometric categorisation to infer sensitive traits such as race, beliefs or sexual orientation	Lawfully acquired datasets; law-enforcement categorisation	2025-02-02
(h)	Real-time remote biometric identification in public spaces for law enforcement	Three objectives, with prior authorisation (Art. 5(2) to 5(7))	2025-02-02
(ba)	Generating or manipulating realistic intimate imagery of an identifiable person without explicit consent	Conditions in Art. 5(1a) , 5(1b)	2026-12-02
(bb)	Generating or manipulating child sexual abuse material (Directive 2011/93/EU)	"Without right" defence; Art. 5(1a)	2026-12-02

The two Omnibus points carry an engineering test. Placing such a generator on the market is prohibited only where that output is its intended purpose, or where the output is "a reasonably foreseeable and reproducible outcome" and the system lacks "reasonable and adequate technical safety measures" to prevent it and correct observed misuse; use is prohibited only where the deployer uses it for that purpose [2]. The evidence that the safeguard holds is therefore part of the legal test. The Commission's guidelines on the original prohibitions are non-binding [4]. The scraping ban in point (e) has a data protection precedent in [the Clearview AI case](#).

For most organisations [Art. 5](#) is two controls: a denylist of prohibited purposes evaluated at intake ([Policy Card](#)), and for generative systems an output [Runtime Guardrail](#) tested by an [Adversarial Red-Team Suite](#). Both leave records a regulator can read. Breaches sit in the highest fine tier (see "Penalties").

In practice (illustrative) A team shipping an image-editing feature treated 2 Dec 2026 as a release gate, not a legal memo. It added an adversarial suite of intimate-imagery and minor-safety prompts to the eval gate, set a zero-tolerance threshold, and wired the output classifier's block decisions into the evidence store under the obligation id `EU-AIA-5-1-ba`. The first run failed on edits that increased exposure in existing photos. The fix shipped before the date, and the passing run, not a policy statement, became the evidence that the safeguard was "reasonable and adequate".

High-risk through products (Annex I)

A system is high-risk under [Art. 6\(1\)](#) when both conditions hold: it is a safety component of a product, or is itself a product, covered by the Union harmonisation legislation in Annex I; and that product must undergo a third-party conformity assessment under that legislation [1]. Section A of Annex I covers products such as toys, lifts, radio equipment, medical devices and in vitro diagnostics; Section B covers sectoral regimes such as civil aviation and vehicles [1].

The Omnibus narrowed the route [2]. A **safety component** must now have the intended purpose of preventing or mitigating risks to health and safety, or be one whose failure endangers them ([Art. 3\(14\)](#)). AI used solely for user assistance, performance

optimisation, efficiency, automation, convenience or quality control is not a safety component unless its failure would endanger health and safety (Art. 6(1a) , 6(1b)). A third-party assessment required only for non-safety reasons, such as radio spectrum, does not count (Art. 6(1c)). Machinery moved to Section B, and delegated acts due by 2 Aug 2027 may limit duties where Section A law already gives equivalent protection (Art. 2(13)). The Annex I route applies from 2 Aug 2028 [2].

High-risk through use (Annex III)

Under Art. 6(2) , Annex III lists eight areas. A system whose intended purpose falls in one of them is high-risk unless the Art. 6(3) filter takes it out [1]:

Area	What is listed (one line)
1. Biometrics	Remote biometric identification (not one-to-one verification), biometric categorisation by sensitive attributes, emotion recognition
2. Critical infrastructure	Safety components in critical digital infrastructure, road traffic, and the supply of water, gas, heating or electricity
3. Education and vocational training	Admission, evaluating learning outcomes, assessing the level of education, detecting prohibited behaviour in tests
4. Employment and workers' management	Recruitment and selection, decisions on terms, promotion or termination, task allocation, monitoring and evaluating performance
5. Essential private and public services	Eligibility for public benefits, creditworthiness and credit scoring (not fraud detection), life and health insurance pricing, emergency call triage and dispatch
6. Law enforcement	Victim risk, polygraphs, evidence reliability, offending risk not based solely on profiling, profiling in investigations
7. Migration, asylum and border control	Polygraphs, risk assessment of persons, examining applications, detecting or identifying persons (not travel-document checks)
8. Administration of justice and democratic processes	Assisting judicial authorities with facts and law (and ADR), influencing elections or voting behaviour

The Commission can add use cases to Annex III by delegated act (Art. 7) [1], so the intake classifier's Annex III table is data with a version, not a hard-coded list. What point 5 guards against is visible in [the Dutch childcare-benefits case](#).

The Annex III filter and the profiling override

Under Art. 6(3) , an Annex III system is not high-risk where it does not pose a significant risk of harm to health, safety or fundamental rights, including by not materially influencing the outcome of decision-making. The filter applies when at least one of four conditions holds [1]:

1. the system performs a narrow procedural task;
2. it improves the result of a previously completed human activity;
3. it detects decision-making patterns or deviations without replacing or influencing the completed human assessment without proper human review;
4. it performs a preparatory task to an assessment relevant to an Annex III use case.

One override beats all four: an Annex III system that **profiles natural persons is always high-risk** [1]. A provider relying on the filter must document its assessment before placing the system on the market, register it (Art. 6(4) , Art. 49(2)), and hand the documentation to authorities on request [1]. The Omnibus trimmed that registration record, deleting the summary of grounds and the list of Member States from Annex VIII, Section B [2].

The Commission's classification guidelines, with practical examples, were due by 2 Feb 2026 under Art. 6(5) . A draft was published on 19 May 2026, with a targeted consultation open until 23 July 2026; as of 2026-09-24 the Commission's page still presents them as a draft [5][6]. Until they are final, the engineer's defence is a good record, not a good argument.

Example (illustrative) A classification decision record, filed in the registry and re-evaluated whenever the intended purpose changes:

```
json { "system": "cv-screen-02", "annex_iii_point": "4(a)", "art_6_3_condition": "preparatory_task", "profiling": true, "result": "high-risk", "reason": "profiling override, Art. 6(3) third subparagraph", "reviewed_by": "ai-governance", "date": "2026-09-24" }
```

The explicit `profiling` flag is the point: the filter was claimed, and the override defeated it.

This record is the output of the [intake and classification](#) workflow and lives in Layer 2 (Inventory & Transparency); the rule that computes it lives in Layer 1.

Transparency cases (Article 50)

Article 50 is often called the "limited risk" rung. It applies to any AI system that fits one of its cases, whatever else the system is [1]:

Case	Duty holder	Duty	Artefact	Layer
50(1) : interacts directly with people	Provider	People must know it is AI, unless obvious	Interface disclosure; a test that it renders	4 · 3
50(2) : generates synthetic audio, image, video or text	Provider	Machine-readable, detectable marking	Watermark or provenance metadata; marking test in CI	4 · 3
50(3) : emotion recognition or biometric categorisation	Deployer	Inform the people exposed	Notice at the point of exposure	2
50(4) : deep fakes	Deployer	Disclose the manipulation (lighter for evident art or satire)	Content label; publishing check	4
50(4) : AI text informing the public	Deployer	Disclose, unless human editorial responsibility	Editorial-control record or label	2 · 4

The information must reach people at the latest at first interaction or exposure (Art. 50(5)) [1]. The article has applied since 2 Aug 2026; generative systems already on the market before that date have until 2 Dec 2026 to mark outputs (Art. 111(4)) [2]. The final Code of Practice on Transparency of AI-generated Content (10 June 2026) has a provider section on marking and a deployer section on labelling, and the Commission and the AI Board confirmed it as an adequate voluntary tool; the Commission published its guidelines on the Art. 50 transparency obligations on 20 July 2026, after a draft of 8 May 2026 [9][14]. Law outside the Act also reaches synthetic media: see [deepfakes and synthetic media](#) in chapter 20.

Minimal risk

Everything else is minimal risk. The Act asks nothing specific of it beyond AI literacy (Art. 4) and invites voluntary codes of conduct (Art. 95) [1]. "Minimal" is a legal category, not a risk verdict: data protection, consumer, product-liability and anti-discrimination law still apply (see [existing law](#) and [privacy and AI](#)), and your own [risk management](#) may rate a minimal-risk system as high for your organisation.

General-purpose AI models

Model, system and the indicative criterion

A **GPAI model** is an AI model that "displays significant generality and is capable of competently performing a wide range of distinct tasks" and can be integrated into a variety of downstream systems, excluding models used for research, development or prototyping before they are placed on the market (Art. 3(63)) [1]. A **GPAI system** is an AI system based on such a model (Art. 3(66)) [1]. The Commission's guidelines give an indicative criterion: training compute above 10^{23} FLOP and the ability to generate language (text or audio), text-to-image or text-to-video [7].

Duties of every GPAI provider

Duty	Article	Artefact	Layer
Technical documentation (Annex XI) for the AI Office and national authorities, on request	Art. 53(1) (a)	Model documentation with training, testing and evaluation results	2
Information for downstream providers (Annex XII)	Art. 53(1) (b)	Model card; capability and limitation notes; integration guide	2
Copyright policy, including honouring text-and-data-mining opt-outs	Art. 53(1) (c)	Source-filtering rules as code; opt-out honour log	1 · 2
Public summary of training content on the AI Office template	Art. 53(1) (d)	Summary generated from dataset provenance records	2
Authorised representative in the Union for non-EU providers	Art. 54	Written mandate; documentation kept for 10 years	5

The duties and their details are in the Act [1]; the chapter 08 rows for Art. 53 and Art. 55 carry the dates and the authority. The copyright law behind the Art. 53(1)(c) policy is in chapter 20 ([copyright policy and TDM opt-outs](#)).

Systemic risk: threshold, notification, designation

A GPAI model has **systemic risk** if it has high-impact capabilities, or if the Commission designates it on the Annex XIII criteria (Art. 51(1)) [1]. High-impact capabilities are presumed above 10^{25} FLOP of cumulative training compute, a threshold the Commission can amend (Art. 51(2) , 51(3)) [1]. The provider must notify the Commission within two weeks of meeting the threshold or knowing it will, and may argue that the model exceptionally presents no systemic risk (Art. 52) [1].

The engineering artefact is a **compute ledger**: cumulative training FLOP per model lineage, with the estimation method, and an alert when *planned* compute will cross the threshold, because the two-week clock can start before training ends.

Duties for models with systemic risk

On top of Arts. 53 and 54, the provider must evaluate the model with state-of-the-art protocols including adversarial testing; assess and mitigate systemic risks at Union level; track, document and report serious incidents to the AI Office without undue delay; and ensure adequate cybersecurity for the model and its physical infrastructure (Art. 55(1)) [1]. The artefacts are the **eval gate** and red-team suite, a systemic-risk register, the **incident pipeline** on the Commission's reporting template (see chapter 08) and weight-security controls.

Open-source carve-outs and their limits

A model released under a free and open-source licence, with its weights, architecture and usage information public, is exempt from Art. 53(1)(a) and (b) and from the authorised-representative duty (Arts. 53(2), 54(6)) [1]. The exemption never covers a systemic-risk model, and the copyright policy and training summary still apply [1]. Monetisation defeats it: the guidelines treat dual licensing, paid support without which the model cannot be used, and exclusive paid hosting as monetisation [7]. The Omnibus keeps GPAI models inside the Art. 25(4) written-agreement duty even when released openly [2].

When a fine-tuner becomes a GPAI provider

A modifier becomes the provider of a new GPAI model only if the change is significant for generality, capabilities or systemic risk. The guidelines' indicative criterion is modification compute above one third of the original training compute (or, if unknown, a third of 10^{25} FLOP for a systemic-risk original and of 10^{23} FLOP otherwise), and the modifier's Art. 53(1) duties are then limited to the modification and its data; Art. 54 applies, and where the original is a systemic-risk model the modified model is presumed to have systemic risk, so the modifier notifies the Commission (Art. 52) and meets the Art. 55 duties [7]. Keep this test apart from Art. 25: fine-tuning a *model* changes GPAI-provider status; changing a *system's* intended purpose into Annex III changes high-risk provider status. Two tests, two objects, two registry fields.

The Code of Practice and enforcement

The General-Purpose AI Code of Practice was published on 10 July 2025. Its Transparency and Copyright chapters apply to all GPAI providers, its Safety and Security chapter only to systemic-risk models, and the Commission and the AI Board confirmed it as an adequate voluntary tool [8]. Providers may rely on it until a harmonised standard exists; non-signatories must show adequate alternative means (Arts. 53(4), 55(2)) [1]. GPAI obligations have applied since 2 Aug 2025, Commission fines under Art. 101 since 2 Aug 2026, and models placed on the market before 2 Aug 2025 must comply by 2 Aug 2027 (Art. 111(3)) [1][7].

High-risk requirements (Articles 8 to 15)

Article 8 requires a high-risk system to meet Section 2 of Chapter III, taking into account its intended purpose and the state of the art [1]. The requirements are design duties on the provider. In one table, with the artefact that evidences each:

Article	Requirement in one line	Artefact	Layer
Art. 9	A risk management system run as a continuous, iterative process over the lifecycle, including testing and reasonably foreseeable misuse	Risk register as code, linked to eval results and the FRIA	1 · 3
Art. 10	Training, validation and testing data that are relevant, sufficiently representative and, as far as possible, free of errors and complete; bias examined and mitigated	Data cards, lineage, bias and quality tests in CI	2 · 3
Art. 11	Technical documentation (Annex IV) before placing on the market, kept up to date; a simplified form for SMEs and SMCs	AIBOM; generated technical documentation; model card	2
Art. 12	Automatic recording of events over the system's lifetime, for traceability	Structured, tamper-evident event logs and traces	4
Art. 13	Instructions for use for deployers, including declared accuracy, limitations and oversight measures	Instructions for use as code; model card	2
Art. 14	Human oversight: people can understand, monitor, stay aware of automation bias, interpret, override and stop the system	Human-in-the-loop checkpoints; override path; kill switch	4
Art. 15	Accuracy, robustness and cybersecurity across the lifecycle, including defences against poisoning, adversarial examples and confidentiality attacks	Eval gate; red-team suite; security controls	3 · 4

The requirements are in the Act [1]; the SME and SMC form in Art. 11(1) is an Omnibus addition [2]. Chapter 14 builds the **technical file** from pipeline records. Art. 14(5) adds two-person verification before acting on a remote biometric identification, with exceptions in law enforcement, migration, border control and asylum [1]; see **designing human oversight** and the **Human-in-the-loop Gate**. A high-risk system within the Cyber Resilience Act that fulfils the conditions of its Article 12(1) is deemed to meet the Art. 15 cybersecurity requirement (Art. 42(3)) [2], so one security evidence pack can serve both regimes.

Provider duties beyond the requirements

Article 16 and the quality management system (Article 17)

Article 16 is the umbrella for the provider's duties: the requirements, name on the system, QMS, documentation, logs, conformity assessment, declaration, CE marking, registration, corrective action, cooperation and accessibility [1]. Chapter 08 breaks it out article by article.

The QMS must be documented as written policies, procedures and instructions covering at least 13 aspects, from a compliance strategy with change management, design control, testing and data management to the Art. 9 risk system, post-market monitoring, incident reporting, record-keeping and an accountability framework (Art. 17(1)) [1]. It is proportionate to the provider's size, which the Omnibus now spells out for SMEs and SMCs without lowering the required rigour, and SMEs without partner or linked enterprises may meet certain elements in a simplified way (Arts. 17(2), 63) [2]. Read as an engineer, the QMS is the pipeline plus its records: versioned policies, change control and the gates that run on every release. The Article 17 standard is published but not cited in the Official Journal, and ISO/IEC 42001 is not the Article 17 QMS (see chapter 08, and chapter 22 on harmonised standards and the presumption of conformity).

Conformity assessment, declaration, marking and registration

Annex III points 2 to 8 use internal control (Annex VI) with no notified body; biometrics (point 1) may use internal control only where harmonised standards or common specifications were applied in full, and otherwise need a notified body (Annex VII) (Art. 43(1), 43(2)) [1]. Annex I, Section A products follow the sectoral procedure, which now expressly includes the Section 2 requirements and a QMS assessment; their notified bodies must apply for designation under the Act by 28 Jan 2028 (Art. 43(3)) [2]. A substantial modification triggers a new assessment (Art. 43(4)) [1].

The provider then draws up the EU declaration of conformity (Art. 47), affixes the CE marking (Art. 48) and registers the system in the EU database (Arts. 49, 71) [1]. Documentation is kept for 10 years (Art. 18) and logs for at least six months (Art. 19) [1]. Each is an output of the pipeline: the declaration is generated from the evidence that the gates passed, and the registration record is pushed from the registry.

Post-market monitoring and serious incidents (Articles 72 and 73)

The provider runs a post-market monitoring system that actively collects and analyses performance data, including from deployers, to evaluate continuous compliance (Art. 72(1), 72(2)) [1]. Its plan is part of the Annex IV documentation, and the Omnibus replaced the overdue implementing act with Commission guidance and a template due by 2 Sep 2027 (Art. 72(3)) [2]. Continuous Assurance Telemetry is the monitoring system; the plan is its versioned configuration.

Serious incidents are reported to the market surveillance authority immediately after a causal link, or its reasonable likelihood, is established, and in any event on the Art. 73 clocks, each counted from when the provider (or deployer) becomes aware of the incident: 15 days in general, two days for a widespread infringement or a serious and irreversible disruption of the management or operation of critical infrastructure (Art. 3(49)(b)), and 10 days after a death [1]. Chapter 08 holds the reporting-clock table; chapter 17 treats incidents end to end. Providers of high-risk systems under the AI Office's direct competence report to the AI Office instead (Art. 75(1a)) [2].

Who you are in the value chain

The EU operator roles

The Act binds operators (Art. 3(8)): providers, product manufacturers, deployers, authorised representatives, importers and distributors [1]. The GPAI chapter adds the GPAI provider and the downstream provider. The table puts each role in the engineer's terms: what it produces and what it must collect from someone else.

Role	Who it is (own words)	Core duties	Evidence it produces	Evidence it collects
Provider (Art. 3(3))	Develops an AI system or GPAI model, or has one developed, and places it on the market or into service under its own name	Arts. 8 to 17, 43 to 49, 72, 73; 50(1), 50(2)	Technical documentation, QMS records, eval results, declaration	Upstream model information; Art. 25(4) agreements
Deployer (Art. 3(4))	Uses an AI system under its authority, other than for personal, non-professional use	Arts. 26, 27, 50(3), 50(4), 86	Use logs, oversight roster, FRIA, notices	Instructions for use, declaration, registration id
Importer (Art. 3(6))	EU-based; places on the market a system bearing a non-EU provider's name	Art. 23: verify the provider's assessment, documents and marking; keep copies 10 years	Import verification record	Certificate, declaration, instructions

Role	Who it is (own words)	Core duties	Evidence it produces	Evidence it collects
Distributor (Art. 3(7))	Makes a system available without being its provider or importer	Art. 24 : verify marking and documents; hold back non-conforming systems	Distribution check record	The same set
Authorised representative (Art. 3(5))	EU-based, with a written mandate from a non-EU provider	Arts. 22 , 54 : verify, keep documents 10 years, cooperate, end the mandate on breach	Mandate; document copies	Everything from the provider
Product manufacturer (Art. 25(3))	Places a high-risk safety component with its Annex I, Section A product under its own name	Provider duties (Art. 16)	As a provider	Supplier documentation
GPAI provider (Art. 53)	The provider of a GPAI model	Arts. 53 to 55	Model documentation, training summary, copyright policy	Data provenance and licences
Downstream provider (Art. 3(68))	Integrates an AI model, its own or a third party's, into an AI system	Provider duties for the system	System documentation	Annex XII information

The duties are in Arts. 16 to 27 and 53 to 55 [1]. The **affected person** is in scope (Art. 2(1)(g)) as a holder of protections, not duties [1].

Article 25: when someone else becomes the provider

A distributor, importer, deployer or other third party becomes the provider of a high-risk system, with all of the Art. 16 duties, in three cases (Art. 25(1)) [1]:

1. it puts its name or trademark on a high-risk system already on the market, subject to contracts allocating the obligations otherwise;
2. it makes a substantial modification to a high-risk system that stays high-risk;
3. it changes the intended purpose of a system that was not high-risk, including a general-purpose AI system, so that it becomes high-risk.

A **substantial modification** is an unplanned change after placing on the market that affects compliance or changes the assessed intended purpose (Art. 3(23)) [1]. When a trigger fires, the initial provider stops being the provider of that system but must cooperate with the new one; the Omnibus now spells out that this means documentation sufficient to assess compliance, known limitations and failure modes, and targeted technical access for testing, unless the initial provider had clearly excluded any change into a high-risk system (Art. 25(2)) [2]. High-risk providers and their suppliers of systems, models, tools and components must fix the information and access needed in a written agreement (Art. 25(4)), and breaches of both paragraphs are now fined in the middle tier (Art. 99(4)(da)) [2].

In the pipeline the three triggers are detectable events: a white-label or brand change, a retrain that touches conformity, and a configuration change that moves `intended_purpose` into an Annex III value. Each should fire a role re-assessment and a [Vendor / Model Due-Diligence Gate](#) ticket (see [third-party and procured AI](#)).

Example (illustrative) An HR team configures a general-purpose chat assistant, which it deploys under a vendor licence, to rank job applicants. The configuration moves the intended purpose into Annex III, point 4(a), so under Art. 25(1)(c) the organisation becomes the provider of a high-risk system: Arts. 8 to 17, conformity assessment and registration are now its duties. Whether it starts with anything depends on the contract. If the vendor did not exclude high-risk use, Art. 25(2) obliges it to hand over documentation, known limitations and test access. If it did exclude it, the organisation builds the evidence alone. The exclusion clause in the vendor terms sets the size of the evidence budget.

Roles name tasks, not organisations

A role attaches to an activity on a specific system, not to a company. A bank is the provider of the credit model it built, the deployer of that model in its branches ("putting into service" includes own use, Art. 3(11) [1]) and the deployer of a vendor's chatbot. So the registry records roles per system, as a list: ["provider", "deployer"] for an in-house system, ["deployer"] for a procured one.

The same roles across regimes

The words differ across laws; the tasks rarely do. The mapping column is this chapter's reading, not a legal equivalence.

Regime	Role	What it covers (own words)	Nearest EU role (our mapping)
EU AI Act [1]	Provider; deployer; importer; distributor; authorised representative; product manufacturer	As in the table above	Reference point
Colorado SB 26-189 [10]	Developer	Builds decision-making technology used in consequential decisions; documents it for deployers	Provider
Colorado SB 26-189 [10]	Deployer	Uses it in consequential decisions; gives consumer notice; keeps records at least three years	Deployer
Texas HB 149 (TRAIGA) [11]	Developer	Develops an AI system offered or provided in Texas	Provider
Texas HB 149 (TRAIGA) [11]	Deployer	Deploys an AI system for use in Texas	Deployer
Korea AI Basic Act [12]	AI development business operator	Develops and provides AI	Provider
Korea AI Basic Act [12]	AI utilisation business operator	Offers products or services built on AI from a development operator	Downstream provider or deployer
Korea AI Basic Act [12]	User; affected person	Receives the service; has life, safety or rights significantly affected	Protected, not a duty holder
ISO/IEC 22989 [13]	AI provider, producer, customer, partner, subject; relevant authorities (verify)	Vocabulary roles, not legal duties	Useful in contracts

Colorado's law was signed on 14 May 2026 and its duties apply from 1 Jan 2027 [10]. The Korean Act (version in force since 21 July 2026) reaches acts abroad that affect the Korean market or users and requires a domestic representative for foreign operators above decree thresholds (Arts. 4 , 36) [12]. The ISO/IEC 22989 list and its clause (5.19) are marked for verification [13]. See [chapter 08](#) and [AI laws worldwide](#) for these regimes in context.

Deployer duties (Article 26)

Article 26 is the deployer's list for high-risk systems. Broken into sub-duties, each has an artefact [1]:

Sub-duty	Para.	Artefact	Layer
Use it according to the instructions for use	26(1)	Deployment config pinned to the instructions; policy check at deploy	1 · 2
Assign competent, trained, empowered overseers	26(2)	Oversight roster linked to training records; human-in-the-loop gate	4 · 5
Keep input data relevant and representative, where you control it	26(4)	Input-data checks; deployment data card	2 · 3
Monitor; inform the provider; suspend on risk; report serious incidents	26(5)	Monitoring hooks; suspension switch; incident pipeline	4 · 5
Keep logs at least six months	26(6)	Log-retention policy as code	4
Inform workers and their representatives before workplace use	26(7)	Notice and consultation record	2
Public bodies: register the use; never use unregistered systems	26(8)	Registry synced with the EU database id	2
Feed the provider's Art. 13 information into the DPIA	26(9)	DPIA cross-referencing the instructions	1 · 2
Post-remote biometric identification: authorisation, logging, reports	26(10)	Authorisation record; per-use log	5
Tell people subject to Annex III decisions	26(11)	Decision notice at the point of decision	2 · 4
Cooperate with authorities	26(12)	Evidence export on request	5

Financial institutions meet the monitoring and log duties through their financial-services governance rules [1]. The deployer's view of procured systems is developed in [governing deployment](#).

In practice (illustrative) In a large telco, the deployer duties stopped being a questionnaire once each became a registry field with an owner. `oversight_roster` pointed at named people whose literacy training was current; `log_retention_days` was checked against the six-month floor by a policy test; `worker_notice_ref` linked to the consultation record before a workplace tool could be switched on. The audit question "show me your Article 26 controls for this system" became one registry query per system.

Fundamental rights impact assessment (Article 27)

Who. Before deploying an Annex III system (except point 2, critical infrastructure), a FRIA is required from deployers that are bodies governed by public law or private entities providing public services, and from deployers of credit scoring (point 5(b)) and life and health insurance pricing (point 5(c)) [1].

When. Before first use; the deployer may rely on earlier FRIAs or on the provider's impact assessment in similar cases, and must update it when an element changes (Art. 27(2)) [1].

What. The deployer's processes that use the system; the period and frequency of use; the categories of people affected; the specific risks of harm to them, using the provider's Art. 13 information; the human oversight measures; and the measures if risks materialise, including internal governance and complaint mechanisms (Art. 27(1)(a) to (f)) [1].

Then. The deployer notifies the market surveillance authority of the results on the AI Office template (Art. 27(3)) [1]. After the Omnibus, it may cross-reference or include the relevant DPIA sections, and the template must allow for that (Art. 27(4) , 27(5)) [2]. The duty applies from 2 Dec 2027 with the Annex III regime [2]. Build it as **FRIA-as-Code**: a versioned record generated from the registry, the instructions for use and the DPIA, so an update is a diff, not a rewrite.

Explanation and notice to affected people

The right to explanation (Art. 86). A person subject to a deployer's decision based on the output of an Annex III high-risk system (except point 2), which produces legal effects or similarly significant effects that the person considers adverse to their health, safety or fundamental rights, may obtain "clear and meaningful explanations of the role of the AI system in the decision-making procedure and the main elements of the decision taken" [1]. The right yields to exceptions in Union or national law and applies only where Union law does not already provide it [1], which is why it has to be read with GDPR rights on automated decisions (see [privacy and AI](#)).

The artefact is an **explanation record** per decision: system and model version, the inputs or reason codes behind the output, whether the output was determinative or advisory, and the human who decided; methods are in [fairness and explainability](#), with what the [right to explanation \(Art. 86\)](#) asks of the content. On timing, Art. 86 sits in Chapter IX, which applies from 2 Aug 2026, but it has work to do only once Annex III systems are regulated from 2 Dec 2027. That is this chapter's reading; confirm it with counsel (verify).

The other notices. Workers before workplace use (Art. 26(7)); people subject to Annex III decisions (Art. 26(11)); people exposed to emotion recognition or biometric categorisation (Art. 50(3)); and anyone facing a deep fake (Art. 50(4)) [1]. Any person may complain to a market surveillance authority (Art. 85), and whistleblowers reporting breaches of the Act are protected under Directive (EU) 2019/1937 (Art. 87) [1].

AI literacy and bias-detection data

AI literacy (Art. 4). Since 27 July 2026, providers and deployers must "take measures to support the development of AI literacy" of their staff and others operating or using AI systems on their behalf, considering their knowledge, the context of use and the people affected, without having to guarantee any specific level [2]. It binds every provider and deployer on every rung. The artefact is a role-based literacy programme whose completion records are keyed to registry roles, so no one is rostered as an Art. 26(2) overseer without a current record.

Bias-detection data (Art. 4a). Providers of high-risk systems may exceptionally process special categories of personal data where strictly necessary for bias detection and correction, if other data (including synthetic or anonymised data) would not work, the data are pseudonymised, secured, access-controlled and never passed on, they are deleted once the bias is corrected, and the records of processing say why [2]. Art. 4a(2) extends the basis to other AI systems and models and to deployers of high-risk systems, without creating a duty [2]. The artefact is a controlled enclave with access logs and automatic deletion (see [data governance across the stack](#)).

Sandboxes and real-world testing

Sandboxes (Arts. 57 to 59). Each Member State must have at least one national AI regulatory sandbox operational by 2 Aug 2027, a date the Omnibus moved from 2 Aug 2026 [1][2]. The AI Office may run a Union-level sandbox for the systems under its direct competence, with priority for SMEs and SMCs, and a sandbox plan may include real-world testing [2]. Art. 59 sets the conditions for further processing of personal data in a sandbox for public-interest systems [1].

Real-world testing (Arts. 60 , 60a , 61). Providers may test Annex III systems, and after the Omnibus Annex I, Section A systems, in real-world conditions outside a sandbox [2]. The conditions include a plan approved by the market surveillance authority, registration with a Union-wide identification number, a maximum of six months extendable by six, informed consent that is dated and documented, effective oversight, outputs that can be reversed, and Art. 73 reporting of serious incidents [1]. Member States may allow testing of Annex I, Section B products under national frameworks (Art. 60a) [2]. A real-world test is a production system with extra evidence: a plan as code, consent records, a reversal path and incident hooks.

Governance and enforcement

Who supervises what

Body	Level	Role	Basis
AI Office	Union	Commission function; supervises GPAI models, codes and templates and, after the Omnibus, some AI systems	Arts. 3(47) , 64 , 75 , 88 to 94
European AI Board	Union	One representative per Member State; EDPS observer; AI Office without a vote	Arts. 65 , 66
Advisory forum and scientific panel	Union	Stakeholder expertise; independent experts who can raise qualified alerts on GPAI systemic risk	Arts. 67 , 68 , 90
National competent authorities	National	At least one notifying authority and one market surveillance authority, with a single point of contact	Art. 70
Market surveillance authorities	National	Enforce AI-system rules with Regulation (EU) 2019/1020 powers and source-code access on reasoned request	Art. 74
Notified bodies	Designated	Third-party conformity assessment, scoped by Annex XIV codes	Arts. 28 to 39
Fundamental-rights bodies	National	Obtain documentation through the market surveillance authority	Art. 77

Market surveillance follows the sector [1]: product authorities for Annex I, Section A systems (Art. 74(3)), financial supervisors for regulated financial institutions (Art. 74(6)), and data protection or other designated authorities for biometrics in law enforcement, border management and justice and for Annex III points 6 to 8 (Art. 74(8)). The Annex XIV codes and the Art. 77 rules are Omnibus text [2].

The AI Office's direct powers (Articles 75 and 75a to 75d)

The Omnibus made the AI Office exclusively competent for two groups of AI systems [2]: systems built on a GPAI model by the same provider or undertaking (except Annex I products, Annex III point 2, justice systems under point 8, and law-enforcement, border and financial systems under Art. 74(6)), and systems that are or sit inside designated very large online platforms or search engines. The competence covers providers, and deployers only within the same undertaking [2].

Articles 75a to 75d give the AI Office investigations, information requests, inspections, orders to give access and explanations and to retain data (Art. 75a); binding commitments (Art. 75b); non-compliance decisions with Art. 99 fines and periodic penalty payments of up to 5% of average daily income or worldwide annual turnover per day (Art. 75c); and rights of defence and publication of decisions (Art. 75d) [2]. They sit in Chapter IX, which applies from 2 Aug 2026 [1][2]. If you build systems on your own GPAI model, your evidence store must answer Brussels as fast as a national authority.

Penalties

Breach	Ceiling	Basis
Prohibited practices (Art. 5)	EUR 35 million or 7% of worldwide annual turnover, whichever is higher	Art. 99(3)
Operator obligations: providers (Art. 16), authorised representatives (22), importers (23), distributors (24), deployers (26), notified bodies, transparency (50); after the Omnibus also Art. 25(2) , 25(4)	EUR 15 million or 3%, whichever is higher	Art. 99(4)
Incorrect, incomplete or misleading information to notified bodies or national authorities	EUR 7.5 million or 1%, whichever is higher	Art. 99(5)
SMEs and start-ups; after the Omnibus, SMCs for the two lower tiers	The lower of the amount and the percentage	Art. 99(6) , 99(6a)
GPAI providers, for intentional or negligent breaches	3% or EUR 15 million, whichever is higher, by Commission decision	Art. 101
Systems under the AI Office's direct competence	Art. 99 levels, plus periodic penalty payments	Art. 75c

The tiers are in [Arts. 99](#) and [101](#) [1], with the Omnibus additions in [Arts. 75c](#), [99\(4\)\(da\)](#) and [99\(6a\)](#) [2]. Member States decide whether and how public bodies are fined ([Art. 99\(8\)](#)) [1]. Two of the factors authorities weigh are the degree of responsibility "taking into account the technical and organisational measures implemented" and whether the operator notified the infringement itself ([Art. 99\(7\)\(g\)](#) , [\(h\)](#)) [1]. Your evidence is also your mitigation argument.

The post-Omnibus timeline

Date	What applies	Basis
2024-08-01	The Act enters into force	Art. 113 [1][2]
2025-02-02	Chapters I and II: definitions, AI literacy and the original prohibitions	Art. 113(a) [1]
2025-08-02	Notified-body rules, GPAI obligations, governance, penalties (except Art. 101) and confidentiality; national contact points published	Art. 113(b) , Art. 70(2) [1]
2026-07-27	Omnibus in force: reworded Art. 4 , new Art. 4a , amendments to other acts (Arts. 102 to 110)	Omnibus Art. 4 ; Art. 113(d) [2]
2026-08-02	General application: Art. 50 transparency, Commission fines on GPAI providers, Chapter VI measures including real-world testing, and the enforcement chapter including Arts. 75a to 75d	Art. 113 [1][2]
2026-12-02	New prohibitions Art. 5(1)(ba) and (bb) ; Art. 50(2) marking for generative systems placed before 2026-08-02	Art. 113(a) , Art. 111(4) [2]
2027-08-02	GPAI models placed before 2025-08-02 must comply; national sandboxes operational; delegated acts limiting duties for Annex I, Section A products due	Arts. 111(3) , 57(1) , 2(13) [1][2]
2027-09-02	Commission guidance and template for the post-market monitoring plan due	Art. 72(3) [2]
2027-12-02	High-risk, Annex III: classification, requirements, provider and deployer duties, FRIA	Art. 113(c)(i) [2]
2028-01-28	Annex I, Section A notified bodies apply for designation under the Act	Art. 43(3) [2]
2028-08-02	High-risk, Annex I (Art. 6(1))	Art. 113(c)(ii) [2]
2030-08-02	Legacy high-risk systems intended for use by public authorities must comply	Art. 111(2) [2]
2030-12-31	Components of Annex X large-scale IT systems placed before 2027-08-02 must comply	Art. 111(1) [1]

Other high-risk systems already on the market before the Chapter III date fall under the Act only if their design changes significantly after that date ([Art. 111\(2\)](#) as amended) [2]. "Significant change in design" is therefore an event the pipeline should log, with the reasoning, every time a legacy system is modified.

What you can do this week

- Add three fields to every registry entry:** [eu_roles](#) (a list, per system), [risk_rung](#) with the article that put it there, and [output_used_in_eu](#) . Run [Shadow-AI Discovery](#) to find the systems that have no entry.
- Write the classification decision record** for every Annex III candidate, with the [Art. 6\(3\)](#) condition relied on and the profiling flag stated explicitly, and store it next to the system. The [AI Act triage](#) drafts one against the [schema](#).
- Gate the 2 Dec 2026 prohibitions.** Put [Art. 5\(1\)\(ba\)](#) and [\(bb\)](#) in the intake denylist and add an adversarial suite for any image, video or voice generator to the eval gate before that date.
- Read your vendor terms for [Art. 25](#) .** Find the clause that excludes high-risk use and the written agreement under [Art. 25\(4\)](#) ; open a due-diligence ticket wherever a high-risk component has neither.
- Test the [Art. 50](#) surfaces that are already live.** Check that every chat interface discloses AI use and every generator marks its output, and file the passing check as evidence.

Maps to: EU AI Act [Arts. 2](#) , [3](#) , [4](#) , [4a](#) , [5](#) , [6](#) , [8](#) to [27](#) , [43](#) to [50](#) , [51](#) to [57](#) , [60](#) to [61](#) , [72](#) to [75d](#) , [86](#) , [99](#) , [101](#) , [111](#) , [113](#) (as amended by Regulation (EU) 2026/1744) · GPAI Code of Practice · Code of Practice on Transparency of AI-generated Content · Colorado SB 26-189 · Texas HB 149 · Korea AI Basic Act · ISO/IEC 22989 · all five stack layers. Mappings are illustrative, not a claim of conformity.

Sources

[1] Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act), of 13 June 2024; OJ L, 2024/1689, 12.7.2024 (original text: Arts. 2, 3, 5 to 27, 43, 49 to 61, 64 to 75, 85 to 87, 99, 101, 111, 113; Annexes I, III, VIII). Publications Office of the EU (EUR-Lex). 2024-07-12. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> (verified: primary) [2] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Regulations (EU) 2024/1689, 2018/1139 and 2023/1230; OJ L, 2026/1744, 24.7.2026; in force on the third day after publication (amended Arts. 2, 3(14), 4, 4a, 5, 6, 10, 11, 17, 25, 27, 42, 43, 50, 56, 57, 60, 60a, 63, 72, 75, 75a to 75d, 77, 99, 111, 113; Annexes I, VIII, XIV). Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [3] Commission Guidelines on the definition of an artificial intelligence system established by Regulation (EU) 2024/1689 (seven elements; four out-of-scope families; non-binding; formal text C(2025) 5053 final). European Commission. 2025-02-06. <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-guidelines-ai-system-definition-facilitate-first-ai-acts-rules-application> (verified: primary) [4] Commission Guidelines on prohibited artificial intelligence practices, as defined by the AI Act (non-binding; authoritative interpretation reserved to the CJEU). European Commission. 2025-02-04. <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-guidelines-prohibited-artificial-intelligence-ai-practices-defined-ai-act> (verified: primary) [5] Draft Commission guidelines on the classification of high-risk AI systems (Art. 6; Annex I and Annex III sections; practical examples; draft for targeted consultation). European Commission. 2026-05-19. <https://digital-strategy.ec.europa.eu/en/library/draft-commission-guidelines-classification-high-risk-ai-systems> (verified: primary) [6] Guidelines for providers and deployers of AI high-risk systems (policy page: classification guidelines still in draft, consultation open until 23 July 2026; application dates 2 Dec 2027 and 2 Aug 2028). European Commission. 2026. <https://digital-strategy.ec.europa.eu/en/policies/guidelines-ai-high-risk-systems> (verified: primary) [7] Commission Guidelines on the scope of the obligations for providers of general-purpose AI models established by Regulation (EU) 2024/1689 (content approved 18 July 2025 by C(2025) 5045 final; formal text C(2025) 7719 final of 19 Nov 2025; paras. 65 to 68 on modifiers; 10²³ FLOP indicative criterion; one-third modification criterion; monetisation; notification within two weeks; fines from 2 Aug 2026). European Commission. 2025-11-19. <https://digital-strategy.ec.europa.eu/en/library/guidelines-scope-obligations-providers-general-purpose-ai-models-under-ai-act> (verified: primary) [8] The General-Purpose AI Code of Practice (published 10 July 2025; Transparency, Copyright, and Safety and Security chapters; confirmed as an adequate voluntary tool). European Commission. 2025-07-10. <https://digital-strategy.ec.europa.eu/en/policies/contents-code-gpai> (verified: primary) [9] Code of Practice on Transparency of AI-generated Content (final version 10 June 2026; provider marking and detection, deployer labelling; confirmed as an adequate voluntary tool; Art. 50 guidelines: draft 8 May 2026, final 20 July 2026). European Commission. 2026-06-10. <https://digital-strategy.ec.europa.eu/en/policies/code-practice-ai-generated-content> (verified: primary) [10] SB26-189 Automated Decision-Making Technology (signed 14 May 2026; developer and deployer duties; covered technology from 1 Jan 2027; deployer records kept at least three years). Colorado General Assembly. 2026-05-14. <https://leg.colorado.gov/bills/sb26-189> (verified: primary) [11] Texas Responsible Artificial Intelligence Governance Act (HB 149), enrolled text (Sec. 552.001 definitions of developer and deployer). Texas Legislature (89R). 2025. <https://capitol.texas.gov/tlodocs/89R/billtext/pdf/HB00149F.pdf> (verified: primary) [12] Framework Act on the Development of Artificial Intelligence and the Establishment of a Foundation for Trust (인공지능 발전과 신뢰 기반 조성 등에 관한 기본법), Act No. 21311 as amended 20 Jan 2026, version in force 21 Jul 2026 (Art. 2(7) to (9) roles; Art. 4 reach; Arts. 31 to 36 duties and domestic representative). Korea Ministry of Government Legislation (law.go.kr). 2026-07-21. <https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=282791> (verified: primary) [13] ISO/IEC 22989:2022, Artificial intelligence concepts and terminology (edition 1; AI stakeholder roles). ISO/IEC JTC 1/SC 42. 2022-07. <https://www.iso.org/standard/74296.html> (verified: primary) [14] Guidelines on transparency obligations for providers and deployers of AI systems (Art. 50; final text after the draft of 8 May 2026; obligations apply from 2 Aug 2026). European Commission. 2026-07-20. <https://digital-strategy.ec.europa.eu/en/library/guidelines-transparency-obligations-providers-and-deployers-ai-systems> (verified: primary)

19. Privacy and data protection law applied to AI

Data protection law already binds every AI system that touches personal data; this chapter turns its duties for training, inference, rights and breaches into artefacts, stack layers and evidence.

Privacy law was the first AI law. The GDPR has applied since 25 May 2018 to any processing of personal data, and a model trained on, retrieving from or deciding about people processes personal data at several points of its life [1]. The AI Act adds duties on top without displacing data protection, and says so in its own text [2]. The privacy duties usually arrive first, carry fines of up to EUR 20 million or 4% of worldwide annual turnover for breaches of the core principles [1], and reach systems the AI Act never classifies as high-risk.

The GDPR is the spine here, with short contrasts to UK GDPR, the US state laws, Brazil's LGPD and China's PIPL. Every duty resolves to an **artefact**, a **stack layer** (chapter 04) and an **evidence record** a query can return. One line of disambiguation: the data protection officer and privacy counsel decide whether a lawful basis holds; the AI governance engineer builds the record that shows the decision, the control that enforces it and the signal that says when it stopped holding. This is engineering translation, not legal advice.

How to read this chapter

An AI system processes personal data at more moments than its owners usually list, and each moment is a separate processing operation with its own purpose, basis, retention and rights exposure. The table uses the running example from chapter 04, **csa-01**, a customer-service assistant in a large telco, fine-tuned on past support transcripts, retrieving from account notes and calling a third-party model.

Processing moment	Personal data (csa-01)	What the law asks first	Evidence record
Collection for training	Historic transcripts	Purpose compatibility; basis; notice	Basis registry entry
Training and fine-tuning	Filtered transcripts	Minimisation; special-category screening	Data card; filter log
Retrieval (RAG) indexing	Account notes	Access control; retention; rights reach	Index manifest
Inference	Live prompts and outputs	Transparency; transfers; ADM limits	Trace with policy verdicts
Logging and monitoring	Prompts, outputs, traces	Storage limitation; security	Retention verdicts
Evaluation	Golden and red-team sets	Minimisation; synthetic where possible	Eval-set card

Data cards live in layer 02 (**Inventory & Transparency**); purpose, retention and residency rules in layer 01; privacy tests in layer 03; redaction, filters and routing in layer 04; and the records a regulator asks for in layer 05. Two neighbouring chapters carry the organisational side: chapter 12 on **updating the policies you already have**, and chapter 14 on **the right to use the data** at the **dataset admission gate**.

Principles applied to AI

Article 5 GDPR sets the principles (lawfulness, fairness and transparency; purpose limitation; data minimisation; accuracy; storage limitation; integrity and confidentiality) and makes the controller able to demonstrate compliance, the accountability duty [1]. For AI the principles do not change; where they bite does.

Lawful basis for training versus inference

Article 6 offers six lawful bases and none ranks above another; the controller picks the one that fits each processing activity [3]. The trap is to pick one basis for "the model". Training on transcripts, indexing account notes and answering a live customer are different activities, and each needs its own basis. **The Garante's ChatGPT order** shows what an unrecorded basis costs.

Stage	Bases that usually fit	Why the choice is hard
Training a model on scraped or third-party data	Legitimate interests (Art. 6(1)(f))	No relationship with the people; indirect notice; objection must work
Fine-tuning on customer data you hold	Legitimate interests; sometimes consent	New purpose; compatibility test; expectations
Retrieval over customer records	Contract (Art. 6(1)(b)) for that customer	The index must not answer one customer with another's data
Inference serving the customer	Contract; legitimate interests	Necessity is narrow
Log monitoring and abuse review	Legitimate interests; legal obligation	Retention drifts; human review widens access

The artefact is a **basis registry**: each dataset and stage carries its basis, purpose and a pointer to the assessment behind it, attached to the system's registry entry. A training job reads it and refuses to run on a dataset whose basis does not cover training.

Example (illustrative) A basis registry entry read by the `csa-01` training pipeline before a run:

```
json { "dataset": "support-transcripts-2025q4", "system": "csa-01", "stage": "fine-tuning", "basis": "Art. 6(1)(f)",  
"lia_ref": "lia-csa-01-v3", "purpose": "support-answer-quality", "special_category_scan": "pass", "retention":  
"P18M", "objection_opt_out": true }
```

Legitimate interests and the three-step test

Legitimate interests is the basis AI developers are most likely to rely on [4]. The EDPB set out how authorities test it in Opinion 28/2024 of 17 Dec 2024 [3]. The interest must be lawful, precisely articulated, and real and present. The processing must be necessary, with no less intrusive way to reach the same end, judged with minimisation in mind. And the interest must not be overridden by the people's rights, where reasonable expectations weigh heavily: whether the data was public, the relationship with the controller, the source and its privacy settings, whether people know their data is online [3].

When the balance tips, mitigations beyond what the GDPR already requires can restore it. The EDPB's examples include masking names and emails with fake values, a delay between collecting a dataset and training on it, an unconditional opt-out before processing, erasure beyond the Article 17 grounds, a channel to report regurgitation, excluding intrusive sources and honouring `robots.txt` or `ai.txt` when scraping, and output filters at deployment [3]. The CNIL adds a discretionary prior right to object and transparency about extraction risk [4].

Each mitigation is a control, so the **legitimate-interest assessment (LIA)** is a versioned artefact that points each mitigation at the control implementing it (the opt-out endpoint, the filter rule id, the scraping allow-list). Switch a mitigation off and the LIA goes stale; the registry should say so.

The limits of consent

Consent must be specific, informed and freely given; the controller must prove it; and people may withdraw it at any time, as easily as they gave it, with effect for the future [1]. Withdrawal after training does not remove a person's influence from computed weights, so a consent-based training set commits the controller to a removal path it can actually run (see "Suppression, retraining and unlearning" below). Consent to a service is also not consent to train a model on the service's data. The artefact is a **consent-purpose log** joining each consent to the datasets and model versions that inherited it; without that join a withdrawal cannot be traced to the runs it affects. China's PIPL adds a separate consent for sensitive personal information [5].

Transparency to the people in the data

Articles 13 and 14 require notice, and Article 14 covers data not collected from the person, the normal case for scraped or licensed training data [1]. Where Article 22 decisions are involved, notice and access must include meaningful information about the logic involved and the envisaged consequences [1]. A notice written for the original service rarely describes training, and a notice that described last year's model is wrong after a retrain on new sources. Generate the notice from the same registry entry as the model card, so it changes when the sources do; the EDPB names model cards among the ways to close the information gap [3].

Purpose limitation and function creep

Data may not be further processed in a way incompatible with its original purpose; Article 6(4) sets the test: the link between purposes, the context, the nature of the data, the consequences and the safeguards, such as encryption or pseudonymisation [1]. AI makes every stored record look like training data, and the failures are **function creep**: support transcripts reused to profile customers for sales, security footage reused for attendance, fraud features reused for credit limits.

The control is a purpose tag that travels with the data and a layer 01 rule that compares the purpose on the dataset's card with the purpose declared by the consuming system, denying the run when they differ and no compatibility assessment is recorded. A denied join is proof the purpose limit bit.

In practice (illustrative) An analytics team asked to fine-tune a churn model on the transcripts collected for `csa-01`. The purpose check denied the job: the card said `support-answer-quality`, the requester said `retention-marketing`, and no compatibility assessment existed. The request became an Article 6(4) assessment that allowed only aggregated topic counts, and the denied run and the assessment were both filed against the dataset's registry entry.

Maps to: GDPR Arts. 5–7, 13, 14 · EU AI Act Art. 10, Art. 13 · ISO/IEC 42001 · ISO/IEC 27701 · NIST AI RMF (Map) · layers 01 and 02. Mappings are illustrative, not a claim of conformity.

Minimisation, privacy by design and PETs

Data must be adequate, relevant and limited to what the purpose needs, and Article 25 requires this by design (measures such as pseudonymisation built in) and by default (only the data each purpose needs is processed and made accessible) [1]. Machine learning pulls the other way, so minimisation is argued feature by feature, not asserted once:

- **Feature-level justification.** Each input feature carries a reason and a measured contribution in the data card; one with neither is removed, and special-category fields need a documented condition.
- **Filtering before training.** PII and special-category scans run on each snapshot and the filter log is kept with it; the EDPB lists source selection, preparation and filtering among the areas an authority examines [3].
- **Minimal retrieval and logs.** RAG indexes hold only the fields answers need; log retention follows the obligation, not the storage default. The tension with the AI Act's logging duties (see [chapter 08](#)) is resolved by logging what the duty needs, pseudonymised where it allows.
- **Synthetic or masked eval sets** wherever a test does not depend on real identities.

Anonymisation versus pseudonymisation

The distinction decides whether the GDPR applies. **Pseudonymised** data cannot be attributed to a person without additional information kept separately [1]; data that can be re-attributed with that information is still about an identifiable person [1], and the EDPB's 2025 guidelines treat pseudonymisation as a safeguard to apply well [6]. **Anonymous** data falls outside the GDPR, but Recital 26 judges identifiability against all means reasonably likely to be used, by the controller or another person, given cost, time and technology [1].

In *EDPS v SRB* (C-413/23 P, 4 Sep 2025) the Court of Justice held that pseudonymised data is not personal data in all cases and for every person, since pseudonymisation may stop a recipient identifying anyone; but the controller's own duties, such as informing people, are judged from the controller's point of view at collection [7]. In an AI supply chain, a vendor receiving well-pseudonymised records without the key may be outside the GDPR for them; the sender is not.

Anonymisation claims decay. One study estimated that 99.98% of Americans would be correctly re-identified in any dataset using 15 demographic attributes [8]. Keep a **re-identification assessment** with each "anonymous" dataset: technique, attacker model, residual risk and date.

Privacy-enhancing technologies and their honest limits

Privacy-enhancing technologies (PETs) reduce what an attacker, vendor or insider can learn. None makes a system compliant, and each has a known failure mode.

PET	What it does	What it does not do	Evidence record
Differential privacy	Bounds how much one record can change a result or model	Cover data outside the budget; survive a badly set or reset budget	Privacy budget per release, with accounting method
Federated learning	Trains where the data lives [9]	Hide data in shared gradients, which can leak examples [10]	Aggregation and DP settings
Synthetic data	Replaces real records for tests or sharing	Guarantee privacy: it either fails to stop inference attacks or loses utility [11]	Generator card; attack results
Pseudonymisation and masking	Removes direct identifiers	Make data anonymous; stop quasi-identifier linkage	Key custody record; masking rules
Trusted execution (enclaves)	Protects data in use from the host	Remove trust in the hardware vendor; fix memorisation	Attestation report per workload
Output filtering and redaction	Blocks personal data at runtime	Remove data from the model; catch every paraphrase	Guardrail decisions with rule ids

NIST SP 800-226 is the reference for evaluating differential-privacy claims and names the "privacy hazards" that appear in implementation [12]. A PET claim is an eval like any other: a threshold, a named attack, a failed build when the threshold is missed.

In practice (illustrative) A team swapped real records in `csa-01`'s regression suite for synthetic ones and assumed the problem was solved. A membership-inference test added to the eval gate flagged rare records reproduced almost verbatim. The generator was retrained with a privacy budget, the test stayed as a permanent gate, and the synthetic set's card now carries the attack result as its evidence of fitness.

Maps to: GDPR Art. 5(1)(c) , Art. 25 , Art. 32 · EU AI Act Art. 10 , Art. 4a · ISO/IEC 27701 · NIST AI RMF (Measure) · [Data governance across the stack](#) · layers 01, 03 and 04. Mappings are illustrative, not a claim of conformity.

Controller duties across the AI supply chain

Controller, processor or joint controller

A **controller** decides purposes and means; a **processor** acts on its behalf; parties deciding together are **joint controllers** and must allocate responsibilities [1]. The AI Act's provider and deployer do not map onto these one to one: a deployer is usually a controller, and a model provider may be your processor for inference and a controller for its own training.

Actor	Typical GDPR role	What decides it
Model developer training on data it collected	Controller for training	It chose sources and purpose
API vendor serving your inference	Processor	It acts only on documented instructions [1]
The same vendor training on your prompts	Controller for that use	A processor that determines purposes is a controller for that processing [1]
Your organisation deploying the assistant	Controller	It decides why customers' data is processed
Partners co-training on pooled data	Joint controllers	They decide purposes and means together

Keep a **role record** per system and stage with the registry entry: a controller runs the DPIA and answers requests; a processor assists and notifies breaches to the controller without undue delay [1].

AI vendor DPAs and no-training clauses

Article 28 requires a contract under which the processor acts only on documented instructions, including on transfers [1]. For AI vendors the [Vendor / Model Due-Diligence Gate](#) should check clauses a generic agreement misses:

- **No training on customer data** (prompts, outputs, files, embeddings, feedback), any opt-in explicit.
- **Retention of prompts and outputs**, including abuse-monitoring retention and staff review.
- **Processing location** per endpoint and feature, including support access.
- **Sub-processors**, with notice and objection when a model host changes.
- **Deletion and return** at contract end, certified.
- **Breach notice** on a clock that leaves room for the controller's own 72 hours.
- **Change notification** when the model, its data policy or its region changes.
- **Evidence**: model card, security attestations and any AIBOM, delivered as stored documents.

The gate's record (checklist answers, contract reference, date) sits on the vendor's registry entry and is re-run on every notified change.

The DPIA for AI systems

A **DPIA** is required before processing likely to result in a high risk, particularly with new technologies, and always for the three Article 35(3) cases: systematic evaluation with significant automated decisions, large-scale special-category processing, and large-scale monitoring of public spaces [1]. The Article 29 Working Party's guidelines, endorsed by the EDPB, give nine criteria and say processing meeting two of them will usually need a DPIA [13]. AI systems meet several at once:

Criterion [13]	Typical AI case
Evaluation or scoring	Risk scores, propensity models, candidate ranking
Automated decisions with legal or similar effect	Credit, hiring, insurance, eligibility
Systematic monitoring	Workplace, video or agent-activity analytics
Sensitive or highly personal data	Health, biometrics, inferred traits
Large scale; matching or combining datasets	Web-scale corpora; merged training sets
Vulnerable data subjects	Employees, children, patients
Innovative technology	Generative models, agents, emotion analysis
Preventing the exercise of a right or use of a service	Automated eligibility gates

An AI DPIA needs fields a generic template lacks: each processing moment with its basis, training sources and filtering, memorisation risk with the eval results that measure it, the ADM analysis, the vendor and transfer map, the oversight design, and the rights path for data inside the model. Article 35(7) sets the minimum content, and where residual risk stays high the controller consults the authority first, which has up to eight weeks to respond [1]. The EDPB expects to see DPIAs and also decisions that one was not needed [3], so "no DPIA" is an artefact too. Deployers of high-risk systems use the provider's Article 13 information for their DPIA [14], and the Article 27 FRIA complements a DPIA rather than repeating it [15]; the [FRIA-as-Code](#) pattern writes the shared fields once. The templates page has an [AI DPIA addendum](#) in its impact-assessment schema.

Records of processing

Article 30 requires a record of processing activities (ROPA): purposes, categories of data and people, recipients, transfers, retention, security [1]. One AI system usually means one entry per processing moment, and the entries go stale with every pipeline change, so generate them from the registry, the data cards and the basis registry. The AI Act's new Article 4a relies on this record: when special-category data is processed for bias detection, the ROPA must say why it was strictly necessary and why other data would not do [2].

Transfers, remote inference and TIAs

Chapter V GDPR requires a ground for every transfer to a third country: adequacy, appropriate safeguards such as standard contractual clauses, or a narrow derogation [1]. The EDPB's three cumulative criteria define a transfer (an exporter subject to the GDPR makes personal data available to an importer in a third country), and its guidelines treat remote access from a third country as a transfer [16]. For AI that covers a prompt with personal data sent to an endpoint outside the EEA, vendor telemetry carrying prompts, a failover to another region, and a foreign support team that can read logs.

Where the ground is contractual, the exporter runs a **transfer impact assessment** on whether the importer's law lets it honour the clauses, adding supplementary measures as the EDPB recommends [17] under the 2021 standard contractual clauses [18]. For the United States, the Data Privacy Framework adequacy decision of 10 Jul 2023 covers certified organisations [19], and the General Court dismissed an action to annul it on 3 Sep 2025 [20]. Record that the vendor entity is certified for the data in question.

The control extends chapter 04's residency rule ([layer 01](#)): route inference for each data class only to endpoints whose ground is recorded, deny otherwise, and emit the verdict. The evidence is the verdict stream plus a transfer register (endpoint, region, importer, ground, TIA reference, review date).

In practice (illustrative) When `csa-01`'s vendor announced a model served from a US region, the change notice triggered the due-diligence gate. It checked the vendor's Data Privacy Framework certification, stored the check in the transfer register, and the residency policy then allowed the new endpoint for pseudonymised support prompts only. Account notes stayed on the EU endpoint, and the policy verdicts in the traces proved which data went where.

Maps to: GDPR Arts. 26, 28, 30, 35, 36, 44 – 46 · EU AI Act Art. 4a, Art. 26(9), Art. 27(4) · ISO/IEC 42001 Annex A.10 · ISO/IEC 27701 · NIST AI RMF (Govern, Map) · layers 01, 02 and 05. Mappings are illustrative, not a claim of conformity.

Automated decision-making

GDPR Article 22 after SCHUFA

Article 22 gives people the right not to be subject to a decision based solely on automated processing, including profiling, with legal or similarly significant effects. Such decisions are allowed only when necessary for a contract, authorised by law, or based on explicit consent, and then with at least the right to human intervention, to express a view and to contest [1]. Chapter 16 turns [automated decision-making under GDPR Art. 22](#) into explanation and contest records.

Two judgments set the engineering task. In SCHUFA (C-634/21, 7 Dec 2023) the Court of Justice held that a credit score is itself an automated decision when lenders give it a determining role [21] (the credit-law side is in chapter 20, [credit and lending](#)). A model that "only recommends" is inside Article 22 when humans downstream follow it as a rule, and the party producing the score is itself deciding. In Dun & Bradstreet Austria (C-203/22, 27 Feb 2025) the Court held that meaningful information about the logic means describing the procedure and principles actually applied, so the person understands which data were used and how; that saying how far a change in the data would have changed the result can be appropriate; that handing over an algorithm is not an explanation; and that claimed trade secrets go to the authority or court to balance [22].

The artefacts follow: a **decision record** per decision (model version, inputs, outcome, reason codes, counterfactual); a **notice** that a solely automated decision was taken and how to contest it; a **contest path** to a reviewer with authority and information to change the outcome, with a record of what they did; and a monitor of the oversight itself, because a reviewer who confirms almost every output in seconds is not meaningful involvement (the [Human-in-the-loop Gate](#) pattern).

Example (illustrative) A decision record for `credit-check-04`, a telco's handset-financing check, filed at runtime:

```
json { "decision_id": "cc4-2026-09-18-0192", "system": "credit-check-04@3.2", "solely_automated": true, "basis": "GDPR Art. 22(2)(a)", "outcome": "declined", "reason_codes": ["R07 payment arrears", "R12 short credit history"], "counterfactual": "approval likely after six months without arrears", "notice_sent": "2026-09-18T10:02:11Z", "contest_channel": "human-review-queue" }
```

The regimes side by side

Regime	Trigger	Core duty or right	Artefact	Layer
GDPR Art. 22, Art. 15(1)(h)	Solely automated decision, legal or similar effect	Narrow permission; intervention, view, contest; information on the logic [1][22]	Decision record; notice; contest path	4 · 5
UK GDPR Arts. 22A–22D	Significant decision without meaningful human involvement	Allowed with safeguards; tighter for special-category data [23]	The same, plus why involvement is meaningful	4 · 5
CCPA ADMT regulations	ADMT for a significant decision	Pre-use notice; opt-out or human appeal; access; from 1 Jan 2027 [24]	Notice; opt-out and appeal workflow; risk assessment	2 · 4 · 5

Regime	Trigger	Core duty or right	Artefact	Layer
US state laws (Virginia, Colorado, Minnesota)	Profiling for decisions with legal or similar effects	Opt-out [25][26]; in Minnesota, question the result, learn the reason, re-evaluation on corrected data [27]	Opt-out flag honoured at inference; review workflow	1 · 4
LGPD Art. 20	Decision solely by automated processing affecting interests	Review; information on criteria, respecting trade secrets [28]	Review workflow; criteria statement	4 · 5
PIPL Art. 24	Automated decision with significant impact	Transparency, fairness; explanation; refusal of solely automated decisions [5]	Explanation service; manual route	4
EU AI Act Art. 86 , Art. 26(11)	Deployer decision on an Annex III high-risk output	Explanation of the system's role and main elements; informing people [29][14]	Explanation keyed to the decision record	4 · 5

Article 86 applies only where Union law does not already give the right [29], so the GDPR route usually does the work (chapter 18 reads [AI Act Article 86](#) and [Article 4a](#) in context). It sits outside the Annex III requirements the Omnibus deferred to 2 Dec 2027 [2], and whether it bites earlier is not settled as of 2026-09-24 (verify). The Digital Omnibus proposal would recast Article 22 as a permission list in which contractual necessity holds even if a human could decide [30]; it is not law (see below).

Maps to: GDPR Art. 13(2)(f) , Art. 15(1)(h) , Art. 22 · UK GDPR Arts. 22A-22D · CCPA ADMT regulations · LGPD Art. 20 · PIPL Art. 24 · EU AI Act Art. 14 , Art. 26(11) , Art. 86 · NIST AI RMF (Manage) · layers 04 and 05. Mappings are illustrative, not a claim of conformity.

Data subject rights against trained models

Where a request has to reach

Rights of access, rectification, erasure and objection [1] do not stop at the database. The deadline is one month, extendable by two for complex requests [31], so the path is designed before the first request. A controller that cannot identify a person in a training set may say so, and the person may supply information that makes identification possible [31].

Where the data sits	Feasible response to erasure or objection	Evidence
Source systems and raw corpus	Normal request tooling	Ticket closure
Training and fine-tuning snapshots	Remove; flag models trained on the snapshot	Snapshot diff
RAG index and caches	Delete or re-index chunks; immediate	Index manifest
Prompt and output logs	Delete or pseudonymise by subject key	Retention verdict
Eval sets	Replace with synthetic records	Eval-set card
Model weights (if not anonymous)	Suppress outputs now; retrain or unlearn on a schedule	Filter rule; retrain plan

Suppression, retraining and unlearning

For data inside the weights there is a ladder, from fast and partial to slow and complete:

1. **Output suppression.** A filter around the model stops it producing the person's data. The CNIL accepts filters where retraining is disproportionate, if shown effective and robust, and prefers general rules to a list of names (itself a list of people who objected) [31]. The data stays in the model; test the filter like any control.
2. **Retraining without the data.** Where the training data is still held, retraining answers the request, and periodic retraining batches many [31]. Complete for the new version, costly for large models.
3. **Machine unlearning.** Exact approaches such as SISA shard training so only the affected shard is retrained [32]; approximate ones adjust weights and are hard to verify. Treat any unlearning claim as a test to pass (membership inference or extraction on the removed records).

Record the choice and its reason per request: the regulator will ask why suppression and not retraining, and when the next retrain closes the gap.

Recording how a request was honoured

The evidence is a **fulfilment record** written by the workflow: every location, the action in each, the model versions affected and when the gap closes.

Example (illustrative) An erasure request against csa-01 , closed within the deadline:

```
json { "request_id": "dsr-2026-0412", "right": "erasure", "subject_key": "hash:7c1e...", "locations": { "crm":
"deleted", "rag_index": "deleted", "fine_tune_set": "deleted", "logs": "deleted", "weights": "output-
suppression:rule-dsr-0412" }, "retrain_scheduled": "csa-01@2026-10-15", "closed": "2026-09-30", "within_deadline":
true }
```

Maps to: GDPR Art. 12(3) , Arts. 15–17 , Art. 21 · ISO/IEC 27701 · NIST AI RMF (Manage) · layers 04 and 05. Mappings are illustrative, not a claim of conformity.

Does a model contain personal data?

The EDPB anonymity test

If a model is personal data, rights, transfer and breach rules reach the weights. Authorities differ. The Hamburg authority's 2024 discussion paper argued that storing a large language model is not processing, that rights attach to the system's inputs and outputs, and that unlawful training does not taint later use [33]. The EDPB was stricter: models trained on personal data cannot in all cases be considered anonymous, and a model is anonymous only if both the likelihood of extracting training subjects' data directly and the likelihood of obtaining it through queries are insignificant, given all means reasonably likely to be used [3]. The CNIL has since published guidance on documenting whether a model falls under the GDPR and recommends robust filters around models that may have memorised data [34].

For the engineer the opinion is a test plan. Authorities will examine source selection, preparation and minimisation, training choices (regularisation, differential privacy), output measures, audits, and structured testing against attribute and membership inference, exfiltration, regurgitation, model inversion and reconstruction attacks; they expect documentation including DPIAs (or the decision not to run one), the threat model, per-source measures with source URLs, and evidence of resistance to re-identification [3]. That is an **anonymity evidence pack**, and most of it is layer 03 output: an attack suite runs as an eval gate on each model version, and its result is the claim.

Example (illustrative) One line of an anonymity evidence pack, filed against a model version:

```
json { "suite_id": "privacy.membership-inference.v2", "model_version": "csa-01@2026-09-18", "attack_auc": 0.52,
"threshold": 0.55, "canary_extraction": "0/500", "result": "pass" }
```

Passing known attacks evidences resistance to those attacks only, as the EDPB notes [3]; the pack is re-run when the model, its data or the state of the art changes.

When the model was trained unlawfully

The opinion sets three scenarios [3]. If personal data stays in the model and **the same controller** deploys it, the effect of the unlawful development is assessed case by case. If **another controller** deploys it, that deployer should have assessed that the model was not developed unlawfully, looking at the source of the data and any infringement found by an authority or court, scaled to its own risk. If the model was **anonymised** before deployment and deployment processes no personal data, the GDPR does not apply to that operation; new personal data processed in deployment is assessed on its own.

The second scenario reaches most organisations, because most deploy models they did not train. In the [Vendor / Model Due-Diligence Gate](#) it becomes stored answers: the provider's training-data summary, its stated basis, any public enforcement finding, its anonymity claim and evidence, and the date checked.

Maps to: GDPR Art. 4(1) , Art. 5(2) , Art. 24 , Art. 25 · EU AI Act Art. 53 · NIST AI RMF (Measure) · [Adversarial Red-Team Suite](#) · layers 02, 03 and 05. Mappings are illustrative, not a claim of conformity.

Special categories, inferred data and biometrics

Article 9(1) GDPR prohibits processing data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs or trade union membership, and processing genetic data, biometric data for unique identification, health data and data on sex life or sexual orientation, unless an Article 9(2) condition applies, such as explicit consent [1]. The AI Act's new Article 4a lets providers of high-risk systems process such data where strictly necessary for bias detection and correction, only if other data (including synthetic or anonymised data) would not do, with pseudonymisation, access controls, no onward transmission and deletion once the bias is corrected (chapter 16 on [special-category data for bias detection \(Art. 4a\)](#)); deployers and providers of other systems may do so exceptionally, and no duty to run bias work is created [2]. The old Article 10(5) basis was deleted [35].

Inferred and proxy sensitive data

AI creates sensitive data without collecting it: health inferred from purchases, religion from meal choices, orientation from social graphs, or a postcode standing in for ethnicity. The ICO's AI guidance treats inferences and special-category data as a lawfulness question [36]. Washington's My Health My Data Act counts as consumer health data information derived or extrapolated from non-health data, including by algorithms or machine learning [37]. California requires a risk assessment before automated inference of health, economic situation or behaviour in certain contexts [24].

Two controls make this checkable. A **proxy test** in layer 03 measures how well each feature and the output predict a protected attribute on a labelled set, failing the build above a threshold. An **inference policy** in layer 01 lists attributes a system may not infer, enforced by an output classifier in layer 04. Both leave records that the sensitive inference was looked for.

Biometrics

Biometric data results from technical processing of physical, physiological or behavioural traits that allows or confirms unique identification, such as facial images or fingerprints [1]. Keep three uses apart: **identification** (one to many), **verification** (one to one) and **categorisation** (assigning a group from traits).

Instrument	Rule on biometrics	Artefact
GDPR Art. 9	Biometric data for unique identification is a special category [1]	Article 9(2) condition record; DPIA
EU AI Act Art. 5(1)(e) – (h)	Bans untargeted facial scraping, emotion inference at work and school (medical and safety uses excepted), categorisation inferring sensitive traits, and real-time remote identification for law enforcement save narrow exceptions [38]	Prohibited-use policy as code; intake screen
EU AI Act Annex III point 1	Remote identification (not verification), sensitive categorisation and emotion recognition are high-risk where lawful [39]	High-risk classification record
Omnibus proposal Art. 9(2)(1)	Would allow verification under the person's sole control [30]	None yet
Illinois BIPA	Retention schedule, informed written consent, no profiting; private action with USD 1,000 per negligent and USD 5,000 per intentional or reckless violation [40]	Consent capture; retention as code; destruction log
PIPL Arts. 28–29	Biometrics are sensitive: specific purpose, necessity, separate consent [5]	Separate-consent record; PIPIA

BIPA is enforced through private class actions, and a 2024 amendment is reported to limit repeated scans of the same person to one recovery (verify) [40]. A leaked password can be reset; a leaked face cannot, so biometric templates get the strictest retention and access rules, and their deletion log is evidence worth keeping.

Consumer-health and neural data

Washington's My Health My Data Act, in force for most entities since 31 Mar 2024, requires consent to collect, separate consent to share and a signed authorisation to sell, enforced through the state consumer-protection act [37]. **Neural data** (information generated by measuring nervous-system activity) is sensitive personal information under the CCPA by SB 1223, approved 28 Sep 2024 [41], and sensitive data under the Colorado Privacy Act by HB24-1058, in force since 7 Aug 2024 [42]. An AI system reading wearables or brain-computer interfaces must flag these data classes at intake, because they switch on consent and assessment duties that ordinary telemetry does not.

Maps to: GDPR Art. 4(14) , Art. 9 , Art. 35(3)(b) · EU AI Act Art. 4a , Art. 5(1)(e) – (h) , Annex III point 1 · BIPA · Washington MHMDA · CCPA · PIPL Arts. 28–29 · NIST AI RMF (Map, Measure) · layers 01, 03 and 04. Mappings are illustrative, not a claim of conformity.

AI-specific privacy breaches

A **personal data breach** is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data [1]. The controller notifies the authority without undue delay and, where feasible, within 72 hours of becoming aware, unless the breach is unlikely to result in a risk; informs the people affected when the risk is high; and documents every breach [1]. AI adds ways to disclose data that do not look like a stolen database.

Breach type	Mechanism	Detection	Artefact
Regurgitation and extraction	The model reproduces memorised training text, including names, phone numbers and emails [43]	Output PII hits; canaries; user reports	Output guardrail log; extraction eval
Membership inference	An attacker learns whether a record was in the training set [44]	Found by testing, rarely at runtime	Membership-inference eval
Model inversion	Features of training subjects reconstructed from outputs and confidence scores [45]	High-volume probing patterns	Rate limits; red-team result
Prompt-injection exfiltration	Instructions hidden in retrieved content make the assistant leak data it can read [46][47]	Blocked outbound links; tool-call anomalies	Guardrail decisions; tool-call traces
Over-broad retrieval	A RAG index returns another customer's records	Cross-tenant retrieval alerts	Index access tests; retrieval traces
Log exposure	Prompts with personal data readable in observability tools	Access reviews; DLP on log stores	Retention verdicts; access logs

Whether a given event is notifiable is the privacy team's judgement on the facts, with the EDPB's worked examples as a guide [48]. The engineering job is to produce the facts within the clock: the trace of what left, the registry entry saying whose data the system holds, the eval history saying whether the weakness was known. For agents that read mail, browse and call tools, the AEPD's

guidance on agentic AI of 18 Feb 2026 sets out the added threats and the measures controllers can take [49]. One incident can start several clocks: the GDPR's 72 hours runs beside the AI Act's Article 73 deadlines (chapter 08) and any sector regime; chapter 17 sets [GDPR breach notification next to the AI Act clocks](#). Give the [Incident Pipeline](#) a personal-data-breach branch with its own timer from the awareness timestamp, and keep the Omnibus proposal's 96 hours and high-risk threshold as a parameter, not today's rule [30].

Maps to: GDPR Art. 4(12) , Arts. 32–34 · EU AI Act Art. 15 , Art. 73 · OWASP LLM02:2025 · OWASP Agentic ASI01 [50] · NIST AI RMF (Manage) · layers 03, 04 and 05. Mappings are illustrative, not a claim of conformity.

The GDPR side of the Digital Omnibus

Only one of the two Omnibus texts is law: the **Digital Omnibus on AI**, Regulation (EU) 2026/1744, in force since 27 Jul 2026, which created Article 4a [2]. The **Digital Omnibus** proposal of 19 Nov 2025, COM(2025) 837, would amend the GDPR and neighbouring rules [30]. As of 2026-09-24 it remains a proposal: the Parliament's ITRE and LIBE committees had a draft report from 22 Jun 2026 and more than 1,750 amendments, the Council's planned mandate vote of 26 Jun 2026 was cancelled, and by August 2026 trilogues had not begun [51]. Commentary on Council working texts reported that a June compromise replaced the proposed Article 88c with a recital and reworked the personal-data definition through a new pseudonymisation provision [52].

Proposed GDPR change [30]	Current law	Build now
Art. 4(1) : not personal data for an entity that cannot identify the person by means reasonably likely to be used	Recital 26; the SRB judgment [7]	Key custody records
Art. 9(2)(k) , 9(5) : residual special-category data in AI development and operation; avoid, remove, or shield from outputs	No AI-specific condition	Special-category scans; output filters
Art. 88c : legitimate interests for AI, with minimisation, protection of residual data, enhanced transparency and an unconditional right to object	Article 6(1)(f) and the three-step test [3]	LIA with an opt-out endpoint
Art. 22 : permission list; contractual necessity even if a human could decide	Current Article 22 [1]	Decision records; contest paths
Art. 33 : high-risk breaches only, 96 hours, single entry point	72 hours, any risk	A parameterised breach timer
Art. 35 : EU-wide DPIA lists, template and methodology	National lists	A DPIA mappable to a common schema

The reading is short: do not build to a proposal. Build the controls both versions want, and make the parameters that may move (breach clock, notification threshold, DPIA triggers) configuration, not code.

Beyond the EU: UK, US, Brazil and China

United Kingdom

The Data (Use and Access) Act 2025, section 80, replaced UK GDPR Article 22 with Articles 22A to 22D: a significant decision with no meaningful human involvement is allowed with safeguards (information, representations, human intervention, contest); special-category data is limited to explicit consent, or contract or legal authorisation with the substantial-public-interest condition; and the new recognised-legitimate-interests basis cannot support such a decision [23]. The rules took effect on 5 Feb 2026 [23]. The ICO consulted on draft ADM guidance from 31 Mar to 29 May 2026 [53], and marks its AI guidance as under review because of the Act [36]. Chapter 08 places the UK in the [regulatory map](#).

United States

There is no federal comprehensive privacy law. California's regulations on ADMT, risk assessments and cybersecurity audits took effect on 1 Jan 2026 [24]. Chapter 21 walks one hiring tool through [Colorado SB 26-189 and the CPPA ADMT rules](#) side by side. ADMT means technology that uses computation to replace or substantially replace human decision-making; a significant decision concerns lending, housing, education, employment or healthcare. Risk assessments are due before, among others, using ADMT for significant decisions, certain automated inferences, and training ADMT or facial-recognition technology; for processing that predates the rules they are due by 31 Dec 2027, with submissions to the agency by 1 Apr 2028 [24]. Virginia's law shows the shape of the others in the table: opt-outs of targeted advertising, sale and significant profiling, and assessments the Attorney General can demand [25][54]. The number of states with such laws keeps growing (verify the current count).

Law	Profiling or ADMT right	Assessment duty	Sensitive-data note
California CCPA and ADMT regulations	Pre-use notice; opt-out or appeal; access [24]	Risk assessments, submitted to the agency [24]	Neural data is sensitive [41]
Virginia CDPA	Opt-out of profiling [25]	Assessments, available to the Attorney General [54]	Sensitive data triggers an assessment [54]

Law	Profiling or ADMT right	Assessment duty	Sensitive-data note
Colorado Privacy Act (2023-07-01)	Opt-out incl. profiling [26]	Assessments for heightened risk [26]	Neural and biological data are sensitive [42]
Minnesota CDPA (2025-07-31)	Question, reason, review, re-evaluation [27]	Not mapped in this edition	Not mapped in this edition

The practical unit is the right, not the state: one opt-out signal honoured at inference, one reason-and-review workflow, one assessment template with fields for each state's triggers.

Brazil and China

Brazil's **LGPD** includes legitimate interests among its legal bases, sets stricter conditions for sensitive data, treats anonymised data as outside the law unless the anonymisation can be reversed with reasonable efforts, gives a right to request review of solely automated decisions with information on the criteria (subject to trade secrets), and lets the authority require an impact report [28].

China's **PIPL** lists its legal bases in Article 13 with no general legitimate-interests basis, so training on personal information usually rests on consent or another listed ground. Automated decisions must be transparent and fair, with a right to an explanation and to refuse solely automated decisions of significant impact; sensitive information, including biometrics, needs necessity and separate consent; cross-border provision needs a CAC security assessment, certification or the standard contract; and an impact assessment is required in advance for sensitive data, automated decisions, entrusted processing and cross-border provision, kept for at least three years [5]. Chapter 08 maps China's AI-specific rules ([China](#)).

Obligation to artefact map

Layers: **1 Govern-as-Code · 2 Inventory & Transparency · 3 Evals & Red Teaming as Evidence · 4 Runtime Controls & Observability · 5 Assurance & Continuous Compliance.**

Obligation	Artefact	Layer	Duty holder	Evidence record
GDPR Art. 5(1)(b) , 6(4) purpose limitation	Purpose tags; purpose-match policy	1 · 2	Controller	Verdict per run
GDPR Art. 6 lawful basis	Basis registry; versioned LIA	2	Controller	Registry entry with LIA ref
GDPR Art. 7 consent	Consent-purpose log	2 · 5	Controller	Withdrawals traced to runs
GDPR Arts. 13–14 transparency	Notice generated from the registry	2	Controller	Notice version per model version
GDPR Art. 5(1)(c) , Art. 25	Feature justification; PII filters; retention as code	1 · 3	Controller	Filter logs; retention verdicts
GDPR Art. 28 processors	AI vendor clause checklist	2 · 5	Controller	Gate record per change
GDPR Art. 30 ROPA	Records generated per processing moment	2 · 5	Controller; processor	Generated record
GDPR Arts. 35–36 DPIA	AI DPIA template; "no DPIA" decision	1 · 2	Controller	Versioned DPIA
GDPR Arts. 44–46 transfers	Transfer register; routing policy; TIA	1 · 4 · 5	Controller; processor	Routing verdicts
GDPR Art. 22 , 15(1)(h) ADM	Decision record; notice; contest path	4 · 5	Controller; score producer	Decision and review records
GDPR Arts. 15–17 , 21 rights	Request workflow across all locations	4 · 5	Controller	Fulfilment record
GDPR Art. 5(2) model anonymity	Anonymity evidence pack; privacy attack evals	3 · 5	Controller (developer)	Eval result per version
GDPR Art. 9 sensitive and inferred data	Proxy test; inference policy; condition record	1 · 3 · 4	Controller	Proxy eval; classifier decisions
GDPR Arts. 33–34 breaches	Breach branch of the incident pipeline	4 · 5	Controller; processor	Awareness timestamp; notice
EU AI Act Art. 4a	Pseudonymised bias set; deletion job; ROPA reason	1 · 2	Provider; deployer (exceptionally)	Deletion log; ROPA entry
EU AI Act Art. 26(9) , 27(4)	FRIA-as-Code sharing DPIA fields	2	Deployer	Linked assessments
EU AI Act Art. 86	Explanation keyed to the decision record	4 · 5	Deployer	Explanation per request

Obligation	Artefact	Layer	Duty holder	Evidence record
UK GDPR Arts. 22A–22D	Safeguard workflow; involvement rationale	4 · 5	Controller	Review records
CCPA ADMT regulations	Pre-use notice; opt-out or appeal; risk assessment	2 · 4 · 5	Business	Notice; opt-outs; assessment
US state profiling opt-outs	Opt-out flag at inference; assessment template	1 · 4 · 5	Controller	Opt-out verdicts
BIPA; MHMDA; neural-data laws	Consent capture; retention schedule; intake flags	1 · 2	Business	Consent and destruction logs
LGPD Art. 20; PIPL Arts. 24, 55–56	Review and explanation workflows; PIPIA	4 · 5	Controller; processor	Review records; PIPIA

In practice (illustrative) A privacy engineering lead in a large telco rebuilt the csa-01 DPIA so most of it was generated: processing moments from the registry, bases from the basis registry, the transfer map from the routing policy, memorisation risk from the latest privacy eval, the rights path from the request workflow. The DPO still wrote and signed the risk judgement. When the vendor changed region, three fields changed and the DPIA showed a diff instead of going stale in a shared drive.

Maps to: GDPR Arts. 5–7, 9, 13–17, 21, 22, 25, 26, 28, 30, 32–36, 44–46 · UK GDPR Arts. 22A–22D · CCPA and its ADMT regulations · Virginia, Colorado and Minnesota privacy acts · BIPA · Washington MHMDA · LGPD · PIPL · EU AI Act Arts. 4a, 5, 26, 27, 86 · ISO/IEC 42001 · ISO/IEC 27701 · NIST AI RMF (Govern, Map, Measure, Manage) · all five layers. Mappings are illustrative, not a claim of conformity.

What you can do this week

1. **List the processing moments** of your highest-risk AI system and write the lawful basis and retention next to each. Every blank cell is a finding.
2. **Add one privacy eval to the gate:** a PII-leakage or membership-inference test with a threshold that fails the build. Its result is page one of an anonymity evidence pack.
3. **Run a mock erasure request** through corpus, snapshots, RAG index, logs and weights, write the fulfilment record, and time it against the one-month deadline.
4. **Send your AI vendors the clause checklist** (no training, prompt retention, region, sub-processors, change notice) and store the answers on their registry entries.
5. **Trace one inference call** to the country that serves it and check the transfer register names a ground. If it does not, the residency policy has its first rule.

Sources

[1] Regulation (EU) 2016/679 (General Data Protection Regulation; Arts. 4(1), 4(4), 4(5), 4(12), 4(14), 5, 6, 6(4), 7, 9, 12(3), 13–17, 21, 22, 25, 26, 28, 30, 33–36, 44–46, 83(5), 99; Recital 26). Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [2] Regulation (EU) 2026/1744 (Digital Omnibus on AI), of 8 July 2026, amending Reg. (EU) 2024/1689 (new Art. 4a on special-category data for bias detection and correction, incl. the records-of-processing reason; amended Art. 2(7) keeping the GDPR unaffected; Annex III high-risk requirements from 2 Dec 2027); OJ L, 24 July 2026; in force 27 Jul 2026. Publications Office of the EU (EUR-Lex). 2026-07-24. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng> (verified: primary) [3] Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models (no hierarchy of legal bases; three-step legitimate-interest test; mitigating measures, paras 99–107; anonymity test at para 43, elements and documentation for the evidence at paras 49–58; three scenarios on unlawful development). European Data Protection Board. 2024-12-17. https://www.edpb.europa.eu/system/files/2024-12/edpb_opinion_202428_ai-models_en.pdf (verified: primary) [4] "Relying on the legal basis of legitimate interests to develop an AI system" (AI how-to sheet; legitimate interest as the most likely basis; balancing test; discretionary prior right to object; transparency on regurgitation risk). CNIL. 2025-06 (page dated 2026-01-05). <https://www.cnil.fr/en/relying-legal-basis-legitimate-interests-develop-ai-system> (verified: primary) [5] Personal Information Protection Law of the People's Republic of China (Arts. 13 legal bases, 24 automated decision-making, 28–29 sensitive personal information and separate consent, 38 cross-border provision, 55–56 impact assessment kept three years), official English translation. National People's Congress. 2021-08-20. http://en.npc.gov.cn.cdurl.cn/2021-12/29/c_694559.htm (verified: primary) [6] Guidelines 01/2025 on pseudonymisation (version for public consultation, 17 Jan to 14 Mar 2025). European Data Protection Board. 2025-01. https://www.edpb.europa.eu/our-work-tools/documents/public-consultations/2025/guidelines-012025-pseudonymisation_en (verified: primary) [7] Press release No 107/25: judgment in Case C-413/23 P, EDPS v SRB (pseudonymised data not personal data in all cases and for every person; identifiability for the controller's information duty assessed at collection, from the controller's point of view). Court of Justice of the

EU. 2025-09-04. <https://curia.europa.eu/site/upload/docs/application/pdf/2025-09/cp250107en.pdf> (verified: primary) [8] Rocher, Hendrickx and de Montjoye, "Estimating the success of re-identifications in incomplete datasets using generative models" (99.98% of Americans correctly re-identified with 15 demographic attributes). *Nature Communications* 10, 3069. 2019-07-23. <https://doi.org/10.1038/s41467-019-10933-3> (verified: primary) [9] McMahan et al., "Communication-Efficient Learning of Deep Networks from Decentralized Data" (federated learning; arXiv 1602.05629). arXiv. 2016-02-17. <https://arxiv.org/abs/1602.05629> (verified: primary) [10] Zhu, Liu and Han, "Deep Leakage from Gradients" (private training data recovered from shared gradients; arXiv 1906.08935). arXiv. 2019-06-21. <https://arxiv.org/abs/1906.08935> (verified: primary) [11] Stadler, Oprisanu and Troncoso, "Synthetic Data – Anonymisation Groundhog Day" (synthetic data either does not prevent inference attacks or does not retain utility; arXiv 2011.07018). arXiv. 2020-11-13. <https://arxiv.org/abs/2011.07018> (verified: primary) [12] NIST SP 800-226, Guidelines for Evaluating Differential Privacy Guarantees (differential privacy pyramid; privacy hazards). NIST. 2025-03. <https://csrc.nist.gov/pubs/sp/800/226/final> (verified: primary) [13] Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing is "likely to result in a high risk" (WP248 rev.01; nine criteria; two criteria usually require a DPIA), endorsed by the EDPB. Article 29 Working Party. 2017-10-04. <https://ec.europa.eu/newsroom/article29/items/611236> (verified: primary) [14] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 26(9) and (11) (deployers use Art. 13 information for their GDPR DPIA; informing people subject to Annex III high-risk decisions). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_26 (verified: primary) [15] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 27 (FRIA for deployers of Annex III high-risk; Art. 27(4) cross-reference to a GDPR Art. 35 DPIA). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_27 (verified: primary) [16] Guidelines 05/2021 on the interplay between the application of Article 3 and the provisions on international transfers as per Chapter V of the GDPR, version 2.0 (three cumulative criteria for a transfer; remote access from a third country, Example 11). European Data Protection Board. 2023-02-14. https://www.edpb.europa.eu/system/files/documents/2023-02/edpb_guidelines_05-2021_interplay_between_the_application_of_art3-chapter_v_of_the_gdpr_v2_en_0.pdf (verified: primary) [17] Recommendations 01/2020 on measures that supplement transfer tools to ensure compliance with the EU level of protection of personal data, version 2.0. European Data Protection Board. 2021-06-18. https://www.edpb.europa.eu/our-work-tools/our-documents/recommendations/recommendations-012020-measures-supplement-transfer_en (verified: primary) [18] Standard contractual clauses for international transfers (published 4 June 2021). European Commission. 2021-06-04. https://commission.europa.eu/publications/standard-contractual-clauses-international-transfers_en (verified: primary) [19] EU-US data transfers: adequacy decision for the EU-US Data Privacy Framework (adopted 10 July 2023). European Commission. 2023-07-10. https://commission.europa.eu/law/law-topic/data-protection/international-dimension-data-protection/eu-us-data-transfers_en (verified: primary) [20] Press release No 106/25: judgment in Case T-553/23, *Latombe v Commission* (action for annulment of the EU-US Data Privacy Framework adequacy decision dismissed). General Court of the EU. 2025-09-03. <https://curia.europa.eu/site/upload/docs/application/pdf/2025-09/cp250106en.pdf> (verified: primary) [21] Press release No 186/23: judgment in Case C-634/21, *SCHUFA Holding (Scoring)* (a credit score is an automated individual decision where lenders give it a determining role). Court of Justice of the EU. 2023-12-07. <https://curia.europa.eu/jcms/upload/docs/application/pdf/2023-12/cp230186en.pdf> (verified: primary) [22] Press release No 22/25: judgment in Case C-203/22, *Dun & Bradstreet Austria* (explanation of the procedure and principles actually applied; effect of a variation in the data; an algorithm alone is not an explanation; trade secrets balanced by the authority or court). Court of Justice of the EU. 2025-02-27. <https://curia.europa.eu/site/upload/docs/application/pdf/2025-02/cp250022en.pdf> (verified: primary) [23] Data (Use and Access) Act 2025, s. 80 (replaces UK GDPR Art. 22 with Arts. 22A–22D: meaningful human involvement, restrictions for special-category data and for Art. 6(1)(ea), safeguards; in force 5 Feb 2026). *legislation.gov.uk*. 2025. <https://www.legislation.gov.uk/ukpga/2025/18/section/80> (verified: primary) [24] California Privacy Protection Agency, CCPA regulations on automated decisionmaking technology, risk assessments and cybersecurity audits (approved by OAL 22 Sep 2025; effective 1 Jan 2026; ADMT definition § 7001(e); significant decision § 7001(ddd); risk-assessment triggers § 7150; deadlines §§ 7155(b), 7157(a); ADMT compliance § 7200(b); opt-out and appeal § 7221). California Privacy Protection Agency. 2025-09-22. https://cppa.ca.gov/regulations/ccpa_updates.html (verified: primary) [25] Code of Virginia § 59.1-577, Personal data rights; consumers (opt out of targeted advertising, sale, or profiling in furtherance of decisions that produce legal or similarly significant effects). Virginia General Assembly. 2023. <https://law.lis.virginia.gov/vacode/title59.1/chapter53/section59.1-577/> (verified: primary) [26] SB21-190, Protect Personal Data Privacy (Colorado Privacy Act; opt-outs incl. profiling; data protection assessments; universal opt-out mechanism; effective 1 July 2023). Colorado General Assembly. 2021-07-07. <https://leg.colorado.gov/bills/sb21-190> (verified: primary) [27] Minnesota Statutes § 325M.14, Consumer personal data rights, subd. 1(g) (question the result of profiling, be informed of the reason, review the data, correct and have the decision re-evaluated; effective 31 July 2025). Office of the Revisor of Statutes, Minnesota. 2025. <https://www.revisor.mn.gov/statutes/cite/325M.14> (verified: primary) [28] Lei Geral de Proteção de Dados Pessoais, Lei n. 13.709/2018, compiled text (Art. 7 legal bases incl. legitimate interests; Art. 11 sensitive data; Art. 12 anonymised data; Art. 20 review of automated decisions; Art. 38 impact report). Presidência da República (Brazil). 2018-08-14. https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709compilado.htm (verified: primary) [29] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 86 (right to explanation of individual decision-making; deployer decisions based on Annex III high-risk outputs, except point 2; applies only where Union law does not otherwise provide the right). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_86 (verified: primary) [30] Proposal for a Regulation amending Regulations (EU) 2016/679, 2018/1724, 2018/1725, 2023/2854 and Directives 2002/58/EC, (EU) 2022/2555 and (EU) 2022/2557 as regards the simplification of the digital legislative framework (Digital Omnibus), COM(2025) 837 final, Council doc. 15698/25 (GDPR Arts. 4(1), 5(1)(b), 9(2)(k)–(l) and 9(5), 12(5), 13(4), 22, 33, 35, new 88c). European Commission / Council of the EU. 2025-11-19. <https://data.consilium.europa.eu/doc/document/ST-15698-2025->

INIT/en/pdf (verified: primary) [31] "Ensuring and facilitating the exercise of data subjects' rights" (AI how-to sheet; identification in training sets; retraining; output filters based on general rules; one month plus two). CNIL. 2026-01-05. <https://www.cnil.fr/en/respect-and-facilitate-exercise-data-subjects-rights> (verified: primary) [32] Bourtole et al., "Machine Unlearning" (SISA training; arXiv 1912.03817). arXiv. 2019-12-09. <https://arxiv.org/abs/1912.03817> (verified: primary) [33] Discussion Paper: Large Language Models and Personal Data (three theses: storing an LLM is not processing; rights attach to system inputs and outputs; unlawful training does not affect later use). Hamburg Commissioner for Data Protection and Freedom of Information. 2024-07-15. https://datenschutz-hamburg.de/fileadmin/user_upload/HmbBfDI/Datenschutz/Informationen/240715_Discussion_Paper_Hamburg_DPA_KI_Models.pdf (verified: primary) [34] "AI: the CNIL finalises its recommendations on the development of artificial intelligence systems and announces its upcoming work" (guidance on GDPR applicability to AI models; annotation; secure development). CNIL. 2025-07-22. <https://www.cnil.fr/en/ai-cnil-finalises-its-recommendations-development-artificial-intelligence-systems> (verified: primary) [35] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Arts. 4a and 10 (as amended by Reg. (EU) 2026/1744: Art. 10(5) deleted; Art. 4a inserted). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_4a (verified: primary) [36] Guidance on AI and data protection (lawfulness incl. inferences and special category data; notice that it is under review because of the Data (Use and Access) Act; last updated 15 Mar 2023). Information Commissioner's Office. 2023-03-15. <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/guidance-on-ai-and-data-protection/> (verified: primary) [37] Chapter 19.373 RCW, Washington My Health My Data Act (consumer health data incl. data derived or extrapolated from non-health information by algorithms or machine learning; consent, separate sharing consent, signed authorisation for sale; enforcement under chapter 19.86 RCW; 31 Mar 2024, small businesses 30 Jun 2024). Washington State Legislature. 2023. <https://app.leg.wa.gov/RCW/default.aspx?cite=19.373&full=true> (verified: primary) [38] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 5(1)(e)–(h) (untargeted facial scraping; emotion inference at work and school; biometric categorisation of sensitive traits; real-time remote biometric identification for law enforcement). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_5 (verified: primary) [39] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Annex III, point 1 (biometrics: remote biometric identification excluding verification; sensitive-attribute categorisation; emotion recognition). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#annx_III (verified: primary) [40] "Biometric Information Privacy Act" (740 ILCS 14, 2008; informed written consent, retention schedule, no profiting; USD 1,000 / 5,000 statutory damages; 2024 amendment, SB 2979, on per-person recovery). Wikipedia. 2026. https://en.wikipedia.org/wiki/Biometric_Information_Privacy_Act (verified: secondary) [41] SB 1223, Consumer privacy: sensitive personal information: neural data (neural data defined and added to sensitive personal information under the CCPA; approved by the Governor 28 Sep 2024; Chapter 887, Statutes of 2024). California Legislature. 2024-09-28. https://leginfo.ca.gov/faces/billNavClient.xhtml?bill_id=202320240SB1223 (verified: primary) [42] HB24-1058, Protect Privacy of Biological Data (biological and neural data as sensitive data under the Colorado Privacy Act; signed 17 Apr 2024; effective 7 Aug 2024). Colorado General Assembly. 2024-04-17. <https://leg.colorado.gov/bills/hb24-1058> (verified: primary) [43] Carlini et al., "Extracting Training Data from Large Language Models" (hundreds of verbatim training sequences extracted from GPT-2, incl. names, phone numbers and email addresses; arXiv 2012.07805). arXiv. 2020-12-14. <https://arxiv.org/abs/2012.07805> (verified: primary) [44] Shokri et al., "Membership Inference Attacks against Machine Learning Models" (arXiv 1610.05820). arXiv. 2016-10-18. <https://arxiv.org/abs/1610.05820> (verified: primary) [45] Fredrikson, Jha and Ristenpart, "Model Inversion Attacks that Exploit Confidence Information and Basic Countermeasures" (CCS 2015). ACM. 2015-10-12. <https://doi.org/10.1145/2810103.2813677> (verified: primary) [46] Greshake et al., "Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection" (data theft via injected prompts in retrieved content; arXiv 2302.12173). arXiv. 2023-02-23. <https://arxiv.org/abs/2302.12173> (verified: primary) [47] LLM02:2025 Sensitive Information Disclosure (OWASP Top 10 for LLM Applications, 2025 edition). OWASP GenAI Security Project. 2025. <https://genai.owasp.org/llm022025-sensitive-information-disclosure/> (verified: primary) [48] Guidelines 9/2022 on personal data breach notification under GDPR, version 2.0. European Data Protection Board. 2023-03-28. https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-92022-personal-data-breach-notification-under_en (verified: primary) [49] "La Agencia publica unas orientaciones sobre Inteligencia Artificial agéntica desde la perspectiva de protección de datos" (press release; guidance on agentic AI and data protection). Agencia Española de Protección de Datos. 2026-02-18. <https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/la-agencia-publica-unas-orientaciones-sobre-inteligencia> (verified: primary) [50] Top 10 for Agentic Applications 2026 (ASI01 Agent Goal Hijack). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [51] "The Digital Omnibus Regulation Proposal", Legislative Train Schedule (status: tabled; ITRE and LIBE joint; draft report 22 June 2026; 1,750+ amendments; Council mandate vote of 26 June cancelled; no trilogues; last update 1 Aug 2026). European Parliament. 2026-08-01. <https://www.europarl.europa.eu/legislative-train/theme-a-new-plan-for-europe-s-sustainable-prosperity-and-competitiveness/file-digital-package> (verified: primary) [52] "Digital Omnibus (GDPR) Negotiations at the Council – September 2026 Update" (June compromise replaced the AI provision, Art. 88c, with a recital; personal-data definition reworked via a new pseudonymisation article). Privacy Next. 2026-09-01. <https://www.privacynext.eu/resources/digital-omnibus-gdpr-negotiations-at-the-council-september-2026-update/> (verified: reported) [53] ICO consultation on the draft guidance about automated decision-making, including profiling (published 31 Mar 2026; closed 29 May 2026; follows the Data (Use and Access) Act 2025). Information Commissioner's Office. 2026-03-31. <https://ico.org.uk/about-the-ico/ico-and-stakeholder-consultations/2026/03/ico-consultation-on-the-draft-guidance-about-automated-decision-making-including-profiling/> (verified: primary) [54] Code of Virginia § 59.1-580, Data protection assessments (targeted advertising, sale, risky profiling, sensitive data; available to the Attorney General on civil

investigative demand). Virginia General Assembly. 2023. <https://law.lis.virginia.gov/vacode/title59.1/chapter53/section59.1-580/> (verified: primary)

20. Other law that already applies to AI

Copyright, anti-discrimination, consumer-protection and product-liability law already bind AI systems; this chapter maps each duty to its evidence artefact and stack layer.

The AI Act is the newest layer of law over AI systems, not the only one. Four older bodies of law reached AI first and are enforced against it today: intellectual property, non-discrimination, consumer protection and product liability. A US regulator put the premise in one line when it launched a sweep against deceptive AI claims: "there is no AI exemption from the laws on the books" [1]. None of these laws was written for models, but each asks a question an AI system must answer with evidence: did we have the right to use this input, does the system disadvantage a protected group, is what we say about it true, and was it defective when it left our control.

For each body of law the chapter gives the doctrine in plain terms, a dated EU / US / UK comparison, and the artefact, stack layer (chapter 04) and pattern (chapter 05) that evidence compliance. It closes with deepfakes and one hiring model run through five bodies of law at once.

It is not legal advice. **AI compliance and legal** functions interpret these obligations; the engineer turns the interpretation into a control and a record, and depends on counsel to confirm the reading (see [the disambiguation cluster](#) and [regulatory translation](#)). Data-protection law has its own chapter (19), the AI Act has chapter 18, and AI-specific statutes around the world are in chapter 21, with the [sector rules that already reach AI](#). Every status in this chapter is stamped as of 2026-09-24; court cases and transposition deadlines move, so re-check before you rely on a row.

How to read this chapter

Each body of law asks one question of an AI system. The table names the artefact that answers it and its layer in [the stack](#): **1 Govern-as-Code · 2 Inventory & Transparency · 3 Evals & Red Teaming as Evidence · 4 Runtime Controls & Observability · 5 Assurance & Continuous Compliance.**

Body of law	The question it asks of an AI system	Primary evidence artefact	Layer
Intellectual property	Did we have the right to use each input, and does any output copy protected expression?	Training-data rights ledger ; memorisation eval; output-filter log	2 · 3 · 4
Non-discrimination	Does the system put a protected group at a disadvantage it cannot justify?	Per-group impact eval; search log for less discriminatory alternatives; reason-code fidelity test	3 · 5
Consumer protection	Is what we claim about the system, or do through its interface, misleading or unfair?	Claims register linked to eval runs; interface and disclosure review record	1 · 3 · 5
Product liability	Was the system defective when it left our control, and did we warn about its limits?	FMEA; AIBOM with hashes; eval history; change log; instructions for use	2 · 3 · 5
Synthetic media	Is generated media marked, disclosed and removable on request?	Provenance marking at generation; takedown pipeline with a clock	4 · 5

Three cautions run through the chapter.

- **Jurisdiction decides the answer.** The same training run can be lawful in one country and infringing in another, so the artefacts record *where* data was copied, a model trained and a system placed on the market.
- **The evidence you keep is evidence you can be ordered to produce.** Under the EU's new product liability regime a court can order a defendant to disclose relevant evidence, and failure to do so triggers a presumption that the product was defective [2]. A defence file that is incomplete or inaccurate works against you. Keep it complete, versioned and honest.
- **Mappings are illustrative, not a claim of conformity.** An artefact supports and evidences an obligation; whether the obligation is met is a legal judgement.

Intellectual property

Intellectual property touches an AI system at four points: the works copied to train it, its outputs, the confidential information it is fed, and the inventions it helps make. At each point the engineer records what happened, where, and under which right.

Copyright and training data

Copying a work into a training corpus is, on its face, a reproduction. The legal question is whether an exception (the EU, UK and Japanese route) or a defence (the US route) covers it.

European Union. The Digital Single Market (DSM) Directive creates two text-and-data-mining (TDM) exceptions. Article 3 lets research organisations and cultural heritage institutions mine works for scientific research. Article 4 is the general exception: anyone may copy lawfully accessible works for TDM and keep the copies as long as needed, unless the rightholder has expressly reserved that use "in an appropriate manner, such as machine-readable means in the case of content made publicly available

online" [3]. The AI Act turns that opt-out into a provider duty: Article 53(1)(c) requires every general-purpose AI (GPAI) model provider to put in place a copyright policy that identifies and complies with Article 4(3) reservations, and Article 53(1)(d) requires a public summary of the training content on the AI Office template [4]. The Commission published that template on 24 Jul 2025 [5]. The open-source exemption in Article 53(2) lifts only the documentation duties in points (a) and (b), so open-weight models still owe the copyright policy and the summary [4]. The GPAI Code of Practice turns the policy into five measures: a written policy, lawful access (no paywall circumvention, no persistently infringing sites), crawlers that follow `robots.txt`, safeguards against infringing outputs, and a complaints contact [6].

The courts are filling in the detail. In *Kneschke v LAION* the Hanseatic Higher Regional Court held on 10 Dec 2025 that building the LAION-5B dataset fell within the German TDM exceptions, and that a reservation written in natural language in website terms was not machine-readable; it allowed a further appeal to the Federal Court of Justice [7]. In *GEMA v OpenAI* the Munich Regional Court held on 11 Nov 2025 that song lyrics memorised in a model's parameters are reproductions, that the TDM exception covers preparatory copies but not the long-term incorporation of works into the model, and that outputs reproducing the lyrics were the provider's responsibility [8]; check whether an appeal is pending before relying on it (verify). The Court of Justice heard its first generative-AI copyright case, *Like Company v Google* (C-250/25), on 10 Mar 2026, on whether training is a reproduction, whether Article 4 covers it and whether chatbot answers reproducing press content are a communication to the public. An Advocate General opinion was scheduled for 3 Sep 2026; the judgment is pending as of 2026-09-24 [9] (verify the opinion).

United States. There is no TDM exception. Training is judged under fair use, which weighs four factors: the purpose and character of the use (including whether it is transformative), the nature of the work, the amount used, and the effect on the market for the work [10]. The cases so far turn on their facts; they are tabled below.

United Kingdom. The UK's TDM exception covers copies made for computational analysis "for the sole purpose of research for a non-commercial purpose" [11]. The government's statutory report of 18 Mar 2026 did not take forward the opt-out exception it had consulted on; it proposes to gather further evidence and to develop input transparency through best practice rather than statute [12] [13]. In *Getty Images v Stability AI* the High Court's November 2025 judgment dismissed the secondary-infringement claim over a model trained abroad, on the basis that the model weights were not an "infringing copy"; permission to appeal on that point was granted, and the appeal is pending [14].

Japan. Article 30-4 of the Copyright Act permits exploitation of a work where the purpose is not to enjoy its expression, such as AI training, unless it would "unreasonably prejudice the interests of the copyright owner". The Japan Copyright Office's non-binding *General Understanding* (May 2024) puts training that aims to output the training works' expression (deliberate overfitting, imitative fine-tuning, retrieval-augmented generation that outputs the source) outside Article 30-4, and copying a database sold for analysis while circumventing measures such as `robots.txt` within the proviso [15].

Question (as of 2026-09-24)	EU	United States	United Kingdom	Japan
Is commercial training on lawfully accessed works permitted without a licence?	Yes, under DSM Art. 4, unless reserved [3]	Only if fair use, decided case by case [10]	No general exception; s. 29A is non-commercial research only [11]	Yes, for non-enjoyment purposes, subject to the proviso [15]
How does a rightholder opt out?	Express reservation, machine-readable for online content [3]	No statutory opt-out	Not applicable; opt-out exception not adopted [12]	No opt-out; technical measures matter to the proviso [15]
Provider duty to publish training information?	Yes for GPAI providers: Art. 53(1)(d) summary [4]	No federal duty	No statutory duty [13]	No

US training cases, dated

Each ruling turned on its own record; none is a rule for every model.

Case	Court	What was decided	Status (as of 2026-09-24)
<i>Thomson Reuters v. ROSS Intelligence</i>	D. Del.; 3d Cir. No. 25-2153	Copying headnotes to build a competing, non-generative legal search tool was not fair use (11 Feb 2025) [16]	Interlocutory appeal argued 11 Jun 2026; decision pending [17]
<i>Bartz v. Anthropic</i>	N.D. Cal.	Training on lawfully acquired books was fair use; keeping a central library of pirated copies was not (23 Jun 2025) [18]	Class settlement of USD 1.5 billion finally approved 20 Jul 2026; release limited to past conduct, output claims preserved [18] [19]
<i>Kadrey v. Meta</i>	N.D. Cal.	Partial summary judgment for Meta on fair use for training, on the record the plaintiffs built (25 Jun 2025) [20]	Ruling confined to those plaintiffs and that record [20]
<i>New York Times v. Microsoft and OpenAI</i>	S.D.N.Y.	Claims over training on and reproducing news articles	Pending at summary judgment; the US Department of Justice filed in support of the defendants in Sep 2026 [21]
<i>Andersen v. Stability AI</i>	N.D. Cal.	Visual artists' claims over image-model training and distribution	Pending; jury trial reset to 20 Sep 2027 [22]

Case	Court	What was decided	Status (as of 2026-09-24)
<i>Disney Enterprises v. Midjourney</i>	C.D. Cal.	Studios' claims over training and character outputs (filed 11 Jun 2025)	Pending [23]

Three engineering lessons follow from these cases and the EU ones.

- **How you acquired the data matters.** *Bartz* separated lawful purchase-and-scan from pirated downloads [18], so the rights ledger records the acquisition channel, not only the licence.
- **Memorisation is the output-side exposure.** *GEMA* turned on lyrics the model could reproduce [8]; a memorisation eval finds that exposure before a claimant does.
- **Opt-outs are read by machines at crawl time.** *LAION* and the Code both rest on machine-readable signals [7] [6]; the crawler's policy is code and its decisions are logs.

Outputs: memorisation and ownership

Infringing outputs. Language models can return rare training sequences verbatim on targeted queries, and larger models are more exposed [24]. The controls sit in two layers: an eval that probes for regurgitation before release (layer 03) and an output filter that blocks near-verbatim reproduction of protected corpora or licensed code in production (layer 04), the safeguards the Code of Practice asks for [6].

Who owns an output. In the United States copyright requires a human author. The D.C. Circuit held so on 18 Mar 2025 in *Thaler v. Perlmutter* [25], and the Supreme Court declined to review the case on 2 Mar 2026 [26]. The US Copyright Office's copyrightability report (29 Jan 2025) treats prompts alone as insufficient for authorship, while human expressive contributions, selection and arrangement, and modification of AI output can be protected; its March 2023 registration guidance requires applicants to disclose AI-generated material [27]. Its report on training (Part 3) is still a pre-publication version [27]. The UK is the outlier: for a computer-generated work the author is "the person by whom the arrangements necessary for the creation of the work are undertaken" [11].

For the engineer, ownership is a provenance problem: protecting an asset a model helped make needs a record of the human contribution (prompts, selection, edits, who and when), which also supports the disclosure a registration asks for.

Database rights and trade secrets

Database right. The EU gives the maker of a database a sui generis right against extraction or re-utilisation of all or a substantial part of its contents, where the maker invested substantially in obtaining, verifying or presenting them [28]. Scraping a database for training is extraction; DSM Article 4 covers it on the same conditions as copyright, including the reservation [3].

Trade secrets and leakage through prompts. A trade secret is protected only while its holder takes "reasonable steps" (EU) or "reasonable measures" (US) to keep it secret [29] [30]. Two AI paths put that condition at risk: staff pasting code, prices or customer data into a third-party model whose terms allow retention or training, and fine-tuning on confidential material that extraction attacks can later recover [24]. A record showing no control at all is a poor start in either case. The artefacts are ordinary and cheap: a data-loss-prevention rule in front of every external model endpoint (layer 04, [Runtime Guardrail](#)); a vendor record of retention and no-training terms, checked at the [Vendor / Model Due-Diligence Gate](#); and a data-classification tag on every fine-tuning set, so a secret never enters a training pipeline without a decision on record.

Patents and AI inventorship

The DABUS applications, in which an AI system was named as sole inventor, failed everywhere they were tested. The US Federal Circuit held on 5 Aug 2022 that an inventor must be a natural person [31]; the UK Supreme Court reached the same result on 20 Dec 2023 [32]; and the EPO's Legal Board of Appeal held on 21 Dec 2021 that "a machine is not an inventor" under the EPC [33]. For AI-assisted inventions, the USPTO rescinded its February 2024 guidance on 28 Nov 2025 and replaced it: AI is treated like any other tool, and the ordinary conception test applies to the humans involved [34].

The artefact is an invention record that captures human conception (who framed the problem and recognised the solution) alongside the AI tools and inputs used.

Model licences and vendor indemnities

Open weights are not the same as open source. Many open-weight models ship under licences with use restrictions. The Llama 3.1 licence, for example, incorporates an acceptable use policy and requires a separate licence from Meta for licensees whose products exceeded 700 million monthly active users on the release date [35]. The Open Source Initiative's definition, by contrast, requires the preferred form for modification: data information, code and parameters [36]. The AI Act's open-source relief is narrower still and never covers the copyright duties [4].

The control is a licence field on every model and dataset in the [AIBOM](#), plus a policy that blocks a deployment whose use case breaches the licence's use policy or commercial threshold (layer 01). A licence read once at procurement and never again is not a control.

Indemnities are conditional, and the conditions are runtime controls. Microsoft's Copilot Copyright Commitment (7 Sep 2023), for example, is conditioned on the customer using the built-in guardrails and content filters and not attempting to generate infringing material [37]. Switching the filters off to cut false positives may switch off the indemnity. Record scope and conditions at

the due-diligence gate, and keep configuration snapshots and filter logs that show the conditions held when an output was produced.

Artefacts that evidence IP compliance

Artefact	What it records	Layer	Pattern
Training-data rights ledger	Per dataset: source, acquisition channel, licence, TDM reservation check (result, method, date), place of copying	2	Training-Data Rights Ledger; AIBOM
Crawler policy-as-code	Honouring <code>robots.txt</code> and other machine-readable reservations; no paywall circumvention; blocklist of infringing sites	1	Policy Card
Memorisation and regurgitation eval	Extraction probes and verbatim-overlap thresholds per model version	3	Eval Gate in CI
Output filter log	Blocked near-verbatim outputs; licence matches on generated code	4	Runtime Guardrail
Copyright policy and training summary	Versioned Art. 53(1)(c) policy and Art. 53(1)(d) summary for GPAI providers	5	Machine-Readable Evidence (OSCAL)
Licence and indemnity register	Model and dataset licences, use policies, indemnity scope and conditions	2 · 5	Vendor / Model Due-Diligence Gate
Prompt DLP rule	Secrets and source code blocked or redacted before external calls	4	Runtime Guardrail

In practice (illustrative) A retrieval assistant for a publisher's sales team was built on a corpus assembled by three different teams. The rights ledger was added after the fact: one row per source, with its acquisition channel and licence. Two sources had no licence on record and one had been scraped from a site whose `robots.txt` disallowed the crawler's user agent. The corpus build now fails when a source lacks a ledger row, the crawler's allow/deny decisions are logged per URL, and the two unlicensed sources were removed and the index rebuilt, with the rebuild recorded against the same registry id.

Non-discrimination

Anti-discrimination law does not ask whether a model is fair in the abstract. It asks whether a decision in a regulated domain treated a protected group worse, and whether the practice that caused it can be justified. The engineering work is to measure the effect in the law's terms and keep the justification with the measurement.

Disparate treatment, disparate impact and proxies

Two theories. *Disparate treatment* is treating someone differently because of a protected trait. *Disparate impact* is a neutral practice that falls harder on a protected group. Under Title VII, a claimant proves impact by showing that a particular practice causes it; the employer must then show the practice is "job related for the position in question and consistent with business necessity"; and the claimant can still win by showing an alternative employment practice with less impact that the employer refuses to adopt [38]. EU law draws the same line between direct and indirect discrimination: an apparently neutral criterion that puts a group "at a particular disadvantage" is unlawful "unless that provision, criterion or practice is objectively justified by a legitimate aim and the means of achieving that aim are appropriate and necessary" [39] [40].

Enforcement posture is not the statute. In the United States, Executive Order 14281 of 23 Apr 2025 directs federal agencies to deprioritise enforcement of statutes and regulations to the extent they include disparate-impact liability [41], and HUD has proposed removing its Fair Housing Act disparate-impact regulations, with a supplemental proposal whose comment period runs to 9 Oct 2026 [42]. For credit the move goes beyond posture: the CFPB amended Regulation B, with effect from 21 Jul 2026, to state that ECOA does not authorize disparate-impact liability (the "effects test"), leaving the adverse-action rules in 12 CFR 1002.9 unchanged [83]. Title VII's disparate-impact text is unchanged [38], private suits continue (see *Mobley* below) and EU and state law are unaffected, so the impact test stays for employment, under state law and in the EU; in US credit it no longer rests on Regulation B [83].

Proxies. Removing the protected attribute does not remove the effect: postcode, name, school or career gaps can carry the same information. Blindness also makes testing harder, because you cannot measure a disparity across groups you have not recorded; to test, you must process the attribute. After the Digital Omnibus, the AI Act's new Article 4a gives providers of high-risk systems a basis to process special-category data for bias detection, with pseudonymisation and deletion once the bias is corrected [43]. Chapter 16 covers the metrics themselves; this section covers what the law will read them against.

Employment

United States. Title VII applies to AI screening as to any other selection procedure [38], and vendors are not safely outside federal age-discrimination law: in *Mobley v. Workday* the court conditionally certified a nationwide age-discrimination collective against the vendor of an applicant-screening system on 16 May 2025 [44]. New York City's Local Law 144 is the most concrete AI-specific rule: an employer may not use an automated employment decision tool unless it has had a bias audit within the past year, the audit summary is published, and candidates are notified 10 business days before use; enforcement began on 5 Jul 2023 [45]. The

audit, by an independent third party, reports selection rates and impact ratios by sex, by race and ethnicity and by their intersection [46]. Illinois amended its Human Rights Act to reach discriminatory employer use of AI, reported as effective from 1 Jan 2026 (verify).

European Union. The Race Equality and Employment Framework directives prohibit direct and indirect discrimination in access to employment, working conditions and dismissal [39] [40]. The AI Act lists recruitment, selection, promotion, termination, task allocation and performance monitoring as high-risk (Annex III, point 4) [47], with the high-risk duties for Annex III systems deferred by the Omnibus to 2 Dec 2027 [48]. The Platform Work Directive (EU) 2024/2831, to be transposed by 2 Dec 2026, goes further for digital labour platforms: no automated processing of a worker's emotional state or private conversations, and no inferring of protected characteristics (Art. 7); written information on automated systems and their main parameters (Art. 9); an impact evaluation, including on equal treatment, at least every two years, and a human decision for any account suspension or termination (Art. 10); and a right to an explanation and review, with rectification within two weeks (Art. 11) [49].

Credit and lending

United States. When a creditor takes adverse action, Regulation B requires a statement of the specific reasons, or a notice of the right to receive them [50]. The CFPB's Circular 2022-03 said in 2022 that creditors using complex algorithms, including AI or machine learning, must still provide the specific principal reasons [51]; the CFPB withdrew the circular on 12 May 2025 [84], but the Regulation B duty is unchanged [50][83]. Where the decision rests on a consumer report, the FCRA adds its own adverse-action duties [52]. The engineering consequence is precise: the reasons in the notice must be the reasons the model used, so a reason code produced by an attribution method is tested for fidelity against each model version (chapter 16 on [adverse-action notices](#)).

European Union. The second Consumer Credit Directive (EU) 2023/2225 requires a creditworthiness assessment on relevant, accurate information, without special-category data or social networks as a source (Art. 18(3)). Where the assessment is automated, the consumer can obtain human intervention: an explanation of the assessment and its logic, a chance to state their view, and a review (Art. 18(8)). Member States had to adopt the rules by 20 Nov 2025 and apply them from 20 Nov 2026 [53] (verify national transposition and any change to the application date). Creditworthiness scoring is also high-risk under the AI Act (Annex III, point 5(b)), with fraud detection excluded [47]; the data-protection rules on automated decisions are in chapter 19.

Housing, insurance and public services

Housing. The Fair Housing Act reaches ad-delivery algorithms: in a 2022 settlement with the US Department of Justice, Meta agreed to drop its "Special Ad Audience" tool and build a system to reduce variance in housing-ad delivery across groups [54]. In the EU, the Race Equality Directive covers access to goods and services available to the public, including housing [39].

Insurance. Colorado's SB21-169 (signed 6 Jul 2021) bars insurers from unfairly discriminating through external consumer data, algorithms and predictive models, and requires a risk-management framework, assessment and monitoring, and attestation by a chief risk officer, under rules the commissioner adopts line of insurance by line [55] (verify the lines covered and effective dates of the implementing rules as of 2026-09-24). The NAIC's model bulletin of 4 Dec 2023 expects insurers to maintain a written programme for the responsible use of AI systems, including oversight of third-party AI systems and data [56]. In the EU, the Court of Justice held in *Test-Achats* that the derogation allowing sex-based differences in insurance premiums was invalid with effect from 21 Dec 2012 [57], and the AI Act lists risk assessment and pricing in life and health insurance as high-risk (Annex III, point 5(c)) [47].

Public services. Eligibility decisions for public assistance are high-risk under the AI Act (Annex III, point 5(a)) [47]. In the UK *Bridges* case the Court of Appeal found that the police force had "never sought to satisfy themselves, either directly or by way of independent verification, that the software program in this case does not have an unacceptable bias on grounds of race or sex", a breach of the public sector equality duty [58]. The missing artefact was a bias test the deployer owned.

Fairness measures the law recognises

The law picks no single fairness metric, but several of its tests are quantitative. Each maps to an eval and a record.

Legal test	What it asks	Eval (layer 03)	Evidence record (layer 05)
Four-fifths rule (US selection procedures)	A selection rate below 80% of the highest group's is generally evidence of adverse impact; smaller gaps can still count [59]	Adverse-impact ratio per group, with sample sizes and a significance test	Signed eval result per model version, in the model card
Title VII disparate impact	Impact caused by a practice; business necessity; less discriminatory alternative [38]	Impact metrics; job-relatedness validation; search across candidate models	Log of alternatives considered and why each was rejected
NYC Local Law 144	Impact ratios by sex, race and ethnicity, and intersectional categories, by an independent auditor [46]	The same calculation on historical or test data	Published audit summary with its date; candidate notice record
EU indirect discrimination	Particular disadvantage; objective justification; appropriate and necessary means [39]	Group-disparity metrics plus a necessity analysis	Justification section in the FRIA or DPIA
Adverse action (ECOA, FCRA)	Specific principal reasons for the decision [50] [52]	Reason-code fidelity test against the model	Reason-code eval result and the notice template version

Legal test	What it asks	Eval (layer 03)	Evidence record (layer 05)
CCD2 Art. 18(8)	Explanation, human intervention and review [53]	Explanation artefact per model version	Review log with outcome and reviewer

The four-fifths rule is a rule of thumb for enforcement agencies, not a safe harbour [59]. Treat an impact ratio above 0.8 as a pass of one check, not as proof of lawfulness. Chapter 16 computes and reports it with counts and intervals ([disparate impact and the four-fifths rule](#)).

In practice (illustrative) A recruitment team deployed a vendor ranking model in New York and two EU countries. The vendor's bias audit was a year old and computed on another customer's data. The team re-ran the impact ratios on its own applicant flow monthly, as a pipeline eval with a 0.8 floor that paged the owner. In month three one intersectional category fell to 0.71; the cause was a new "years of continuous experience" feature that penalised career gaps. The feature was removed, the search log recorded the alternatives tested, and a refreshed audit summary was published before the next round.

Consumer protection

Consumer-protection law reaches AI through three doors, with no AI-specific statute: what you claim about the system, how its interface treats people, and what it does with their data. What a chatbot tells a customer binds the business that deployed it: [Moffatt v. Air Canada](#) is the case written up as a post-mortem.

Unfair and deceptive practices in the United States

Section 5 of the FTC Act prohibits unfair or deceptive acts or practices. A practice is unfair only if it causes or is likely to cause "substantial injury to consumers which is not reasonably avoidable by consumers themselves and not outweighed by countervailing benefits" [60]. Deception, in the FTC's 1983 policy statement, is a representation, omission or practice that is likely to mislead a consumer acting reasonably and is material [61]. An AI performance claim with no evidence behind it is deceptive in exactly this sense [62].

- **Unsubstantiated performance claims.** Workado claimed its AI-content detector was 98% accurate; testing put accuracy on general-purpose content at 53%, because the model was trained on academic text. The order requires competent and reliable evidence for such claims [62]. The September 2024 sweep, Operation AI Comply, targeted a "robot lawyer" service among others [1].
- **Deploying without reasonable safeguards.** Rite Aid is banned for five years from using facial recognition for security or surveillance, after the FTC alleged it deployed the technology without reasonable procedures to prevent harm to consumers [63].
- **Algorithmic disgorgement.** When a company trains on data it obtained unlawfully, the remedy can reach the model. The Everalbum order defines "Affected Work Product" as "any models or algorithms developed in whole or in part using" the biometric data, and requires its deletion within 90 days with a sworn statement [64].
- **AI washing.** In March 2024 the SEC settled with two investment advisers over false claims about their use of AI, for USD 400,000 in combined penalties [65].
- **Fake reviews and bots.** The FTC's rule on consumer reviews (16 CFR Part 465) bans fake reviews, including AI-generated reviews attributed to people who do not exist, with civil penalties [66]. California makes it unlawful to use a bot to mislead a person about its artificial identity in order to sell something or influence a vote, unless the bot is disclosed clearly and conspicuously [67].

Enforcement priorities change with administrations; the statute and the orders above do not. A claim needs evidence when it is made, and a model trained on tainted data can be ordered destroyed.

The EU: UCPD, DSA and the AI Act

The Unfair Commercial Practices Directive prohibits practices that are contrary to professional diligence and materially distort, or are likely to distort, the average consumer's economic behaviour, judged from a vulnerable group's perspective where it is targeted [68]. Since the 2019 amendments, its blacklist includes stating that reviews come from real users without reasonable steps to check, and submitting or commissioning false reviews [69]. The Digital Services Act adds platform-specific rules: online platforms may not design interfaces that deceive or manipulate users or impair their free and informed decisions (Art. 25); platforms must explain the main parameters of their recommender systems (Art. 27); and very large platforms' risk mitigation includes prominent marking of generated or manipulated media that appreciably resembles real persons or events (Art. 35(1)(k)) [70]. The AI Act prohibits AI systems that use manipulative or deceptive techniques, or exploit vulnerabilities, to distort behaviour in ways that cause significant harm (Art. 5(1)(a)–(b)) [71], and requires that people be told when they are interacting with an AI system unless it is obvious (Art. 50(1)) [72].

The United Kingdom: DMCC Act

Under the Digital Markets, Competition and Consumers Act 2024, the general prohibition of unfair commercial practices has applied since 6 Apr 2025 (s. 225), and the practices always deemed unfair include fake consumer reviews and reviews that conceal

an incentive (Sch. 20, para. 13) [73].

Practice (as of 2026-09-24)	United States	European Union	United Kingdom	Evidence artefact	Layer
Unsubstantiated accuracy or fairness claim	FTC Act s. 5; Workado order [62]	UCPD general clause [68]	DMCC s. 225 [73]	Claims register linked to eval runs	3 · 5
AI-generated fake reviews	16 CFR Part 465 [66]	UCPD Annex I, 23b–23c [69]	DMCC Sch. 20, para. 13 [73]	Policy blocking review generation; provenance log	1 · 4
Undisclosed bot	Cal. BPC s. 17941 [67]	AI Act Art. 50(1) [72]	No bot-specific rule; s. 225 may apply [73]	Disclosure control and a test that it renders	4
Manipulative interface or output	FTC Act s. 5 unfairness [60]	DSA Art. 25 [70]; AI Act Art. 5(1)(a)–(b) [71]	s. 225 [73]	Interface review; red-team eval for manipulation	3 · 5
Model built on unlawfully obtained data	Deletion of "Affected Work Product" [64]	Data-protection remedies (chapter 19)	Data-protection remedies (chapter 19)	Lineage from dataset to every model trained on it	2

Claims substantiation and algorithmic disgorgement

A claims register. Every public statement about accuracy, fairness, autonomy or "AI-powered" capability is a row: the claim, where it appears, the eval run that supports it, the data it was measured on, and the date. Workado failed on the last two columns: the measurement did not match the population the claim described [62]. A model release reruns the eval and re-validates every claim that cites it; a stale or failing claim is pulled from the copy. This is proposed here as a new pattern, the **Claims Substantiation Gate**: an [eval gate](#) pointed at marketing copy.

Deletion-ready lineage. An order to delete "models or algorithms developed in whole or in part using" some data [64] can only be complied with, and proven, if you know which models touched the data. That is an [AIBOM](#) with dataset lineage down to the version, plus the [training-data rights ledger](#). Without it, the only safe response to a disgorgement order is to delete everything.

Product liability

Product liability asks whether a product was defective and whether the defect caused the harm. For AI the new questions are whether software is a product, who controls it after it ships, and what a defect is in something that learns and updates.

The EU Product Liability Directive

The revised Product Liability Directive, (EU) 2024/2853, was adopted on 23 Oct 2024 and published on 18 Nov 2024. Member States must transpose it by 9 Dec 2026, and it applies to products placed on the market or put into service after that date [2]. Its main moves for AI:

- **Software is a product** (Art. 4(1)); the recitals name AI among the reasons for the revision, and free and open-source software supplied outside a commercial activity is excluded (Art. 2(2)) [2].
- **Defect is judged with learning and updates in view.** The factors include "the effect on the product of any ability to continue to learn or acquire new features after it is placed on the market", relevant safety requirements including cybersecurity, and the moment the product left the manufacturer's control (Art. 7(2)) [2]. Control continues while the manufacturer can supply software updates (Art. 4(5)) [2].
- **Updates reopen the file.** The defence that a defect arose after placing on the market does not apply where, within the manufacturer's control, the defect is due to software or its updates, a missing safety update, or a substantial modification (Art. 11(2)) [2]. Whoever substantially modifies a product outside the manufacturer's control becomes its manufacturer (Art. 8(2)) [2].
- **Disclosure and presumptions.** A court can order the defendant to disclose relevant evidence, with protection for trade secrets (Art. 9). Defect is presumed if the defendant fails to disclose, if the product breaches mandatory safety requirements, or if damage came from an obvious malfunction; and a court must presume defect or causation where the claimant faces excessive difficulty, notably from technical or scientific complexity, and shows that either is likely (Art. 10) [2].
- **Damage and time.** Compensable damage covers death, personal injury including medically recognised psychological harm, property damage and the destruction or corruption of data not used for professional purposes (Art. 6). Claims expire 10 years after placing on the market, restarting from a substantial modification, or 25 years for latent personal injury (Art. 17) [2].

The parallel AI Liability Directive proposal, which would have eased fault-based claims, was withdrawn: announced in the Commission's 2025 work programme, published in the Official Journal on 6 Oct 2025 [74]. Fault-based AI claims stay with national tort law.

United States tort theories

US product liability recognises three kinds of defect: manufacturing defects in some units, design defects inherent in the design, and marketing defects, which cover improper instructions and failures to warn of latent dangers; courts test design defects by consumer expectations, by weighing risk against utility, or both [75]. Whether software, and a chatbot in particular, is a "product" is contested and decided case by case. In *Garcia v. Character Technologies*, a wrongful-death suit over a companion-chatbot app pleaded as product liability, the court granted in part and denied in part the motions to dismiss on 21 May 2025, and the case was

resolved and dismissed without prejudice on 7 Jan 2026 [76]; check reports that product-liability theories survived against the order itself (verify).

The UK product liability review

The Law Commission is reviewing the Consumer Protection Act 1987 regime, expressly including digital products and AI; terms of reference were published on 8 Dec 2025 and a consultation is planned for the second half of 2026 [77].

Defect types mapped to AI failure modes

Each legal category maps onto engineering failure modes and an artefact that shows whether they happened.

Defect type	What it means for an AI system	Evidence that answers it	Layer
Manufacturing	The deployed system departs from its own design: wrong model version, corrupted weights, misconfigured guardrail, broken data pipeline	AlBOM with hashes; signed deployment record; configuration drift alerts	2 · 4 · 5
Design	The design itself is unsafe for a foreseeable use, and a safer alternative was reasonably available: untested operating conditions, no guardrail, no human oversight where needed	FMEA; eval coverage matrix; red-team results; design review with alternatives considered	1 · 3
Warning (marketing)	Known limits and out-of-scope uses were not disclosed	Model card; instructions for use; in-product notices, all versioned	2 · 5
Update (EU Art. 11(2))	An update introduced the defect, or a safety update that was needed was not shipped	Change log; regression evals per release; patch decision records	3 · 4 · 5

Duty to warn after updates

A model update is a new release. Under the EU regime the manufacturer answers for defects that updates cause, or that a missing safety update leaves in place, while the system is within its control [2]; US failure-to-warn theories reach the same point [75]. So warnings travel with versions: the model card and instructions for use regenerate on every release, release notes list known limitations and changed behaviour, and field monitoring feeds the Incident Pipeline, so a new hazard produces a decision (patch, warn, withdraw) with an owner and a date (chapter 17).

The defence file

A defence file per product release holds:

- a **failure mode and effects analysis** in the form the IEC 60812 standard describes, with AI failure modes (distribution shift, prompt injection, hallucinated facts, unsafe tool use) as rows [78];
- the **AlBOM** for the release, with model, dataset and dependency hashes;
- the **eval history**: every gate result for this and prior versions, including failures and the fixes that followed;
- **signed runtime logs** for the decisions in question, retained for the claim period;
- the **warnings as shipped**: model card, instructions for use and in-product notices at that version.

The file cuts both ways: a claimant can obtain disclosure, and a gap can itself raise a presumption of defect [2]. Keep it complete and retrievable for at least the 10-year expiry period [2]; as machine-readable evidence, disclosure becomes a query rather than a project.

Deepfakes and synthetic media

Synthetic media sits across consumer protection, privacy and criminal law. Three regimes set the floor.

- **European Union.** Providers of generative systems must mark outputs in a machine-readable, detectable way (AI Act Art. 50(2)), and deployers must disclose deepfakes, with lighter rules for evidently artistic, satirical or fictional work (Art. 50(4)) [72]. Article 50 has applied since 2 Aug 2026 [79], with a marking grace period until 2 Dec 2026 for generative systems placed on the market before 2 Aug 2026 (Art. 111(4)) [43]. The Digital Omnibus also added a prohibition aimed at AI generation of non-consensual intimate imagery and child sexual abuse material, applying from 2 Dec 2026 [43]. Very large platforms must mark generated or manipulated media prominently as part of their DSA risk mitigation [70].
- **United States.** The TAKE IT DOWN Act (Public Law 119-12, 19 May 2025) makes it a federal crime to knowingly publish non-consensual intimate images, including "digital forgeries", and requires covered platforms to run a notice-and-removal process (within one year of enactment) that removes reported content within 48 hours, enforced by the FTC [80]. State deepfake and likeness laws vary (verify the states relevant to each deployment).
- **United Kingdom.** Sharing an intimate photograph or film that "shows, or appears to show" another person without consent has been an offence since 31 Jan 2024 [81], and the Data (Use and Access) Act 2025 added an offence of creating a purported intimate image of an adult [82].

The artefacts are provenance marking at the point of generation (for example content credentials or watermarks, layer 04), a detection eval for the marking's survival through common transformations (layer 03), and a takedown path with a 48-hour clock, an owner and a log (layer 05, built on the Incident Pipeline).

One hiring model through five bodies of law

A single system usually answers to several of these bodies of law at once, so its artefacts should share one registry id.

Example (illustrative) An employer in New York and the EU deploys a vendor's model that ranks applicants for interviews. One registry entry answers five legal questions.

Body of law	The question for this system	Artefact, keyed to the registry id	Layer
AI Act (chapter 18)	Annex III point 4 high-risk: are the deployer duties met, and has the provider supplied its evidence? [47]	Registry entry with role (deployer); provider's documentation collected at the due-diligence gate; human oversight design	2 · 5
Data protection (chapter 19)	Is the processing lawful and are automated decisions safeguarded?	DPIA; candidate notice; review path	1 · 5
Non-discrimination	Is there adverse impact, is the practice justified, and were alternatives searched? [38] [45] [39]	Monthly impact-ratio eval; published audit summary; search log	3 · 5
Consumer protection	Is the vendor's "bias-free" claim, repeated in our candidate materials, substantiated? [62]	Claims register row citing our own eval run, not the vendor's brochure	3 · 5
Product liability	Is the directive the route for a rejected candidate?	Usually not: its damage heads (injury, property, data) do not include discrimination [2], so the exposure runs through equality law and contract	5

The last row is the useful surprise: for a hiring model the law that bites is equality and data protection, not product liability; for a medical triage assistant the balance reverses. Writing this table per system, before building controls, decides where the evidence budget goes.

What you can do this week

- Add four fields to every dataset's data card:** source, acquisition channel, licence, and the result and date of the TDM reservation check. Fail the pipeline when any is empty.
- Search your public copy** (website, sales decks, model cards) for numeric or absolute claims such as "99% accurate", "unbiased" or "fully autonomous". Link each to an eval run id, or remove it.
- Compute adverse-impact ratios per group** for every selection, eligibility or pricing model you run, with sample sizes, and store them in the model card for the current version.
- Put a data-loss-prevention rule in front of every external model endpoint** for secrets and source code, and record which vendors have no-training and retention terms.
- Open a defence file for your next AI release:** AIBOM with hashes, eval history, an FMEA, the instructions for use and the release notes, with a retention period of at least 10 years.

Maps to: EU AI Act Art. 4a, 5, 50, 53(1)(c)–(d), Annex III points 4–5 · DSM Directive Arts. 3–4 · PLD (EU) 2024/2853 · Platform Work Directive (EU) 2024/2831 · CCD2 Art. 18 · UCPD · DSA Arts. 25, 27, 35 · FTC Act s. 5 · Title VII s. 703(k) · 29 CFR 1607.4(D) · Regulation B · NYC LL144 · TAKE IT DOWN Act · DMCC Act 2024 · all five stack layers (chapter 04). Mappings are illustrative, not a claim of conformity.

Sources

[1] "FTC Announces Crackdown on Deceptive AI Claims and Schemes" (Operation AI Comply; "there is no AI exemption from the laws on the books"; DoNotPay "robot lawyer" proposed order). Federal Trade Commission. 2024-09-25. <https://www.ftc.gov/news-events/news/press-releases/2024/09/ftc-announces-crackdown-deceptive-ai-claims-schemes> (verified: primary) [2] Directive (EU) 2024/2853 on liability for defective products (Art. 2 scope and FOSS exclusion; Art. 4 software as a product and manufacturer's control; Art. 6 damage; Art. 7 defectiveness incl. ability to continue to learn; Art. 8(2) substantial modification; Art. 9 disclosure; Art. 10 presumptions; Art. 11(2) updates; Art. 17 expiry; Art. 22 transposition by 9 Dec 2026; OJ L 18 Nov 2024). Official Journal of the EU. 2024-10-23. <https://eur-lex.europa.eu/eli/dir/2024/2853/oj> (verified: primary) [3] Directive (EU) 2019/790 on copyright and related rights in the Digital Single Market, Arts. 3 and 4 (TDM for scientific research; general TDM exception subject to a reservation "in an appropriate manner, such as machine-readable means"). Official Journal of the EU. 2019-04-17. <https://eur-lex.europa.eu/eli/dir/2019/790/oj> (verified: primary) [4] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 53 (GPAI providers: 53(1)(c) copyright policy honouring Art. 4(3) DSM reservations; 53(1)(d) public summary of training content; 53(2) open-source relief limited to points (a) and (b), not for systemic-risk models). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_53 (verified: primary) [5] "Commission presents template for General-Purpose AI model providers to summarise the data used to train their model" (template for the Art. 53(1)(d) public summary). European Commission. 2025-07-24. <https://digital-strategy.ec.europa.eu/en/news/commission-presents-template-general-purpose-ai-model-providers-summarise-data-used-train-their> (verified: primary) [6] GPAI Code of Practice, Copyright chapter (Measures 1.1 to 1.5: copyright policy; lawful access without circumventing effective technological measures and excluding

persistently infringing sites; robots.txt compliance; safeguards against infringing outputs; point of contact and complaints). Code of Practice text as published 10 Jul 2025. 2025-07-10. <https://code-of-practice.ai/?section=copyright> (verified: secondary) [7] "Machine-readable opt-outs and AI training: Hamburg Court clarifies copyright exceptions" (Kneschke v. LAION, OLG Hamburg 5 U 104/24, 10 Dec 2025; natural-language reservations in terms of use insufficient; further appeal to the BGH allowed). Norton Rose Fulbright, Inside Tech Law. 2025-12. <https://www.insidetechlaw.com/blog/2025/12/machine-readable-opt-outs-and-ai-training-hamburg-court-clarifies-copyright-exceptions> (verified: secondary) [8] "German court rules in favour of music rights management organisation against OpenAI" (GEMA v. OpenAI, Munich Regional Court I, 11 Nov 2025; memorisation in model parameters as reproduction; TDM exception limited to preparatory copies; decision open to appeal). European Commission, European IP Helpdesk. 2025-11-14. https://intellectual-property-helpdesk.ec.europa.eu/news-events/news/german-court-rules-favour-music-rights-management-organisation-against-openai-nyt-vs-openai-dispute-2025-11-14_en (verified: secondary) [9] "CJEU Grand Chamber rules on music sampling and pastiche; first CJEU hearing on generative AI and copyright: Like Company v Google" (C-250/25; hearing 10 Mar 2026; questions on reproduction in training, DSM Art. 4 and chatbot outputs; Advocate General opinion scheduled for 3 Sep 2026). European Commission, European IP Helpdesk. 2026-04-24. https://intellectual-property-helpdesk.ec.europa.eu/news-events/news/cjeu-grand-chamber-rules-music-sampling-and-pastiche-first-cjeu-hearing-generative-ai-and-copyright-2026-04-24_en (verified: secondary) [10] 17 U.S.C. § 107, Limitations on exclusive rights: fair use (the four factors). US Government Publishing Office, GovInfo (United States Code, 2024 edition). 2024. <https://www.govinfo.gov/content/pkg/USCODE-2024-title17/html/USCODE-2024-title17-chap1-sec107.htm> (verified: primary) [11] Copyright, Designs and Patents Act 1988, s. 29A (copies for text and data analysis for non-commercial research) and s. 9(3) (author of a computer-generated work). legislation.gov.uk. current. <https://www.legislation.gov.uk/ukpga/1988/48/section/29A> (verified: primary) [12] Report and Impact Assessment on Copyright and Artificial Intelligence (published under ss. 135 and 136 of the Data (Use and Access) Act 2025). UK Government, GOV.UK. 2026-03-18. <https://www.gov.uk/government/publications/report-and-impact-assessment-on-copyright-and-artificial-intelligence> (verified: primary) [13] "Copyright and artificial intelligence: analysing the UK government's March 2026 reports" (opt-out TDM exception previously favoured not taken forward; further evidence to be gathered; input transparency through best practice rather than statute). VWW. 2026-03. <https://www.vww.co.uk/insights/articles/copyright-and-artificial-intelligence-analysing-the-uk-governments-march-2026-reports> (verified: secondary) [14] "High Court grants permission to appeal in Getty Images v Stability AI" (secondary infringement and the meaning of "infringing copy" for an AI model; Stability refused permission on the trade mark findings). Wiggin LLP. 2026-01. <https://www.wiggin.co.uk/insight/high-court-grants-permission-to-appeal-in-getty-images-v-stability-ai/> (verified: secondary) [15] "General Understanding on AI and Copyright in Japan": Overview (Art. 30-4 non-enjoyment purpose and its proviso; fine-tuning and RAG that output training expression fall outside Art. 30-4; database works and robots.txt; not legally binding). Japan Copyright Office, Agency for Cultural Affairs. 2024-05. https://www.bunka.go.jp/english/policy/copyright/pdf/94055801_01.pdf (verified: primary) [16] Thomson Reuters Enterprise Centre GmbH v. ROSS Intelligence Inc., No. 1:20-cv-00613 (D. Del.), Memorandum Opinion (Bibas, J.). CourtListener (court docket). 2025-02-11. <https://www.courtlistener.com/docket/17131648/thomson-reuters-enterprise-centre-gmbh-v-ross-intelligence-inc/> (verified: primary) [17] "Third Circuit Hears Oral Argument in Ross v. Reuters AI Training Copyright Case" (No. 25-2153; argued 11 Jun 2026; first federal appeal on fair use in AI training). Baker Botts. 2026-07. <https://www.bakerbotts.com/thought-leadership/publications/2026/july/third-circuit-hears-oral-argument> (verified: secondary) [18] Bartz v. Anthropic PBC, No. 4:24-cv-05417 (N.D. Cal.): Order on Fair Use (Alsup, J., 23 Jun 2025, ECF 231) and Order Granting Final Approval of Class Action Settlement (Martínez-Olguín, J., 20 Jul 2026, ECF 680). CourtListener (court docket). 2026-07-20. <https://www.courtlistener.com/docket/69058235/bartz-v-anthropic-pbc/> (verified: primary) [19] "Court Grants Final Approval of \$1.5 Billion Anthropic Copyright Settlement" (release limited to past acquisition and copying through 25 Aug 2025; output claims preserved). The Authors Guild. 2026-07. <https://authorsguild.org/news/court-grants-final-approval-anthropic-copyright-settlement/> (verified: secondary) [20] Kadrey v. Meta Platforms, Inc., No. 3:23-cv-03417 (N.D. Cal.), Order denying the plaintiffs' motion and granting Meta's cross-motion for partial summary judgment (Chhabria, J., ECF 598). CourtListener (court docket). 2025-06-25. <https://www.courtlistener.com/docket/67569326/kadrey-v-meta-platforms-inc/> (verified: primary) [21] "DOJ urges judge to rule for OpenAI, Microsoft in N.Y. Times lawsuit" (summary-judgment stage; first US government position on AI-training copyright litigation). The Washington Post. 2026-09-02. <https://www.washingtonpost.com/technology/2026/09/02/doj-urges-judge-rule-openai-microsoft-ny-times-lawsuit/> (verified: secondary) [22] Andersen v. Stability AI Ltd., No. 3:23-cv-00201 (N.D. Cal.), Order regarding case schedule (Orrick, J., ECF 597; jury trial reset to 20 Sep 2027). CourtListener (court docket). 2026-06-15. <https://www.courtlistener.com/docket/66732129/andersen-v-stability-ai-ltd/> (verified: primary) [23] Disney Enterprises Inc. v. Midjourney Inc., No. 2:25-cv-05275 (C.D. Cal.), complaint (ECF 1). CourtListener (court docket). 2025-06-11. <https://www.courtlistener.com/docket/70513159/disney-enterprises-inc-v-midjourney-inc/> (verified: primary) [24] Extracting Training Data from Large Language Models (Carlini et al.; verbatim training sequences recovered from GPT-2; larger models more vulnerable; arXiv 2012.07805). arXiv. 2020-12-14. <https://arxiv.org/abs/2012.07805> (verified: primary) [25] Thaler v. Perlmutter, No. 23-5233 (human authorship required for copyright registration). US Court of Appeals for the D.C. Circuit. 2025-03-18. <https://media.cadc.uscourts.gov/opinions/docs/2025/03/23-5233.pdf> (verified: primary) [26] "Supreme Court Denies Cert in AI Authorship Case" (Thaler v. Perlmutter; certiorari denied 2 Mar 2026). Mayer Brown. 2026-03. <https://www.mayerbrown.com/en/insights/publications/2026/03/supreme-court-denies-review-in-ai-authorship-case> (verified: secondary) [27] Copyright and Artificial Intelligence (Part 2, Copyrightability, 29 Jan 2025; Part 3, Generative AI Training, pre-publication version 9 May 2025; registration guidance for works containing AI-generated material, 16 Mar 2023). U.S. Copyright Office. 2025. <https://copyright.gov/ai/> (verified: primary) [28] Directive 96/9/EC on the legal protection of databases, Art. 7 (sui generis right against extraction and re-utilisation of a substantial part). Official Journal of the EU. 1996-03-11. <https://eur-lex.europa.eu/eli/dir/1996/9/oj> (verified: primary) [29] Directive (EU) 2016/943 on the protection of undisclosed know-how and business information (trade secrets), Art. 2(1) ("reasonable steps under the circumstances" to keep information secret). Official

Journal of the EU. 2016-06-08. <https://eur-lex.europa.eu/eli/dir/2016/943/oj> (verified: primary) [30] 18 U.S.C. § 1839(3) (trade secret: the owner "has taken reasonable measures to keep such information secret"). US Government Publishing Office, GovInfo (United States Code, 2024 edition). 2024. <https://www.govinfo.gov/content/pkg/USCODE-2024-title18/html/USCODE-2024-title18-part1-chap90-sec1839.htm> (verified: primary) [31] Thaler v. Vidal, No. 2021-2347 (inventors under the Patent Act must be natural persons). US Court of Appeals for the Federal Circuit. 2022-08-05. https://cafc.uscourts.gov/opinions-orders/21-2347.OPINION.8-5-2022_1988142.pdf (verified: primary) [32] Thaler v Comptroller-General of Patents, Designs and Trade Marks [2023] UKSC 49 (DABUS cannot be an inventor under the Patents Act 1977). UK Supreme Court. 2023-12-20. <https://www.supremecourt.uk/cases/uksc-2021-0201> (verified: primary) [33] J 8/20 (DABUS; "A machine is not an inventor within the meaning of the EPC"). EPO Legal Board of Appeal. 2021-12-21. <https://www.epo.org/en/boards-of-appeal/decisions/j200008eu1> (verified: primary) [34] Revised Inventorship Guidance for AI-Assisted Inventions, 90 FR 54636 (rescinds the 13 Feb 2024 guidance; AI as a tool; ordinary conception standard). USPTO, Federal Register. 2025-11-28. <https://www.federalregister.gov/documents/2025/11/28/2025-21457/revised-inventorship-guidance-for-ai-assisted-inventions> (verified: primary) [35] Llama 3.1 Community License Agreement (Acceptable Use Policy incorporated; separate licence required above 700 million monthly active users on the release date). Meta. 2024-07-23. https://github.com/meta-llama/llama-models/blob/main/models/llama3_1/LICENSE (verified: primary) [36] The Open Source AI Definition 1.0 (use, study, modify, share; preferred form for modification: data information, code and parameters). Open Source Initiative. 2024-10. <https://opensource.org/ai/open-source-ai-definition> (verified: primary) [37] "Microsoft announces new Copilot Copyright Commitment for customers" (defence and payment of adverse judgments; conditional on using built-in guardrails and content filters and not attempting to generate infringing material). Microsoft On the Issues. 2023-09-07. <https://blogs.microsoft.com/on-the-issues/2023/09/07/copilot-copyright-commitment-ai-legal-concerns/> (verified: primary) [38] 42 U.S.C. § 2000e-2(k) (Title VII s. 703(k): burden of proof in disparate-impact cases; business necessity; alternative employment practice). US Government Publishing Office, GovInfo (United States Code, 2024 edition). 2024. <https://www.govinfo.gov/content/pkg/USCODE-2024-title42/html/USCODE-2024-title42-chap21-subchapVI-sec2000e-2.htm> (verified: primary) [39] Council Directive 2000/43/EC implementing the principle of equal treatment irrespective of racial or ethnic origin, Art. 2(2)(b) (indirect discrimination; objective justification) and Art. 3(1)(h) (goods and services, including housing). Official Journal of the EU. 2000-06-29. <https://eur-lex.europa.eu/eli/dir/2000/43/oj> (verified: primary) [40] Council Directive 2000/78/EC establishing a general framework for equal treatment in employment and occupation. Official Journal of the EU. 2000-11-27. <https://eur-lex.europa.eu/eli/dir/2000/78/oj> (verified: primary) [41] Executive Order 14281, Restoring Equality of Opportunity and Meritocracy (s. 4: agencies to deprioritise enforcement of disparate-impact liability; FR Doc. 2025-07378). The White House, via GovInfo (Federal Register). 2025-04-23. <https://www.govinfo.gov/content/pkg/FR-2025-04-28/html/2025-07378.htm> (verified: primary) [42] HUD's Implementation of the Fair Housing Act's Disparate Impact Standard: proposed rule (FR Doc. 2026-00590, 14 Jan 2026) and supplemental proposed rule (FR Doc. 2026-16228; comments due 9 Oct 2026). US Department of Housing and Urban Development, Federal Register. 2026-08-10. <https://www.federalregister.gov/documents/2026/08/10/2026-16228/huds-implementation-of-the-fair-housing-acts-disparate-impact-standard-amendments-to-huds-title-vi> (verified: primary) [43] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, as amended by Regulation (EU) 2026/1744 (Art. 4a special-category data for bias detection in high-risk systems; Art. 5(1)(ba) and (bb) prohibitions on NCII and CSAM generation, applying from 2 Dec 2026 under Art. 113(a); Art. 111(4): Art. 50(2) marking deadline of 2 Dec 2026 for generative systems placed on the market before 2 Aug 2026). Publications Office of the EU (EUR-Lex). 2026-07-27. <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng> (verified: primary) [44] Mobley v. Workday, Inc., No. 3:23-cv-00770 (N.D. Cal.), Order granting preliminary collective certification (Lin, J., ECF 128). CourtListener (court docket). 2025-05-16. <https://www.courtlistener.com/docket/66831340/mobley-v-workday-inc/> (verified: primary) [45] Automated Employment Decision Tools (Local Law 144 of 2021 and 6 RCNY 5-300: bias audit within one year before use, published summary, notice 10 business days before use; enforced from 5 Jul 2023). NYC Department of Consumer and Worker Protection. 2023. <https://www.nyc.gov/site/dca/about/automated-employment-decision-tools.page> (verified: primary) [46] Automated Employment Decision Tools: Frequently Asked Questions (bias audit by an independent third party; selection rates and impact ratios by sex, race/ethnicity and intersectional categories). NYC Department of Consumer and Worker Protection. 2023. <https://www.nyc.gov/assets/dca/downloads/pdf/about/DCWP-AEDT-FAQ.pdf> (verified: primary) [47] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Annex III, points 4 and 5 (employment, workers management; public assistance eligibility; creditworthiness, fraud detection excepted; risk assessment and pricing in life and health insurance). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#anx_III (verified: primary) [48] "AI Omnibus enters into force" (Reg. (EU) 2026/1744, in force 27 Jul 2026; Annex III high-risk obligations from 2 Dec 2027). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force> (verified: primary) [49] Directive (EU) 2024/2831 on improving working conditions in platform work, Arts. 7 (limits on processing), 9 (transparency), 10 (human oversight), 11 (human review) and 29 (transposition by 2 Dec 2026). Official Journal of the EU. 2024-10-23. <https://eur-lex.europa.eu/eli/dir/2024/2831/oj> (verified: primary) [50] 12 CFR § 1002.9 (Regulation B notifications: statement of specific reasons for adverse action). eCFR (text as of 2026-09-01). 2026-09-01. <https://www.ecfr.gov/current/title-12/chapter-X/part-1002/section-1002.9> (verified: primary) [51] Circular 2022-03: Adverse action notification requirements in connection with credit decisions based on complex algorithms (withdrawn by the CFPB on 2025-05-12, 90 FR 20084, FR Doc. 2025-08286, item 14; the circular's page carries no withdrawal banner as of 2026-09-24). Consumer Financial Protection Bureau. 2022-05-26. <https://www.consumerfinance.gov/compliance/circulars/circular-2022-03-adverse-action-notification-requirements-in-connection-with-credit-decisions-based-on-complex-algorithms/> (verified: primary) [52] 15 U.S.C. § 1681m(a) (FCRA duties of users taking adverse action on the basis of consumer reports). US Government Publishing Office, GovInfo (United States Code, 2024 edition). 2024. <https://www.govinfo.gov/content/pkg/USCODE-2024-title15/html/USCODE-2024-title15-chap41-subchapIII-sec1681m.htm> (verified: primary) [53] Directive (EU) 2023/2225 on credit agreements for consumers, Art. 18 (creditworthiness assessment; 18(3)

no special-category data, social networks not an external source; 18(8) human intervention and explanation) and Art. 48 (adopt by 20 Nov 2025, apply from 20 Nov 2026). Official Journal of the EU. 2023-10-18. <https://eur-lex.europa.eu/eli/dir/2023/2225/oj> (verified: primary) [54] "Justice Department Secures Groundbreaking Settlement Agreement with Meta Platforms, Formerly Known as Facebook, to Resolve Allegations of Discriminatory Advertising" (Fair Housing Act; Special Ad Audience discontinued; Variance Reduction System for housing ads). US Department of Justice. 2022-06-21. <https://www.justice.gov/opa/pr/justice-department-secures-groundbreaking-settlement-agreement-meta-platforms-formerly-known> (verified: primary) [55] SB21-169, Restrict Insurers' Use of External Consumer Data (signed 6 Jul 2021; risk-management framework, assessment and monitoring, chief risk officer attestation; rules by insurance practice). Colorado General Assembly. 2021-07-06. <https://leg.colorado.gov/bills/sb21-169> (verified: primary) [56] NAIC Model Bulletin: Use of Artificial Intelligence Systems by Insurers (written AIS Program; third-party AI systems and data; adopted 4 Dec 2023). National Association of Insurance Commissioners. 2023-12-04. https://content.naic.org/sites/default/files/inline-files/2023-12-4%20Model%20Bulletin_Adopted_0.pdf (verified: primary) [57] Case C-236/09, Association Belge des Consommateurs Test-Achats (Art. 5(2) of Directive 2004/113/EC invalid with effect from 21 Dec 2012). Court of Justice of the EU. 2011-03-01. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:62009CJ0236> (verified: primary) [58] R (Bridges) v Chief Constable of South Wales Police [2020] EWCA Civ 1058 (public sector equality duty; no verification that facial recognition software lacked unacceptable race or sex bias). Court of Appeal (Civil Division), Courts and Tribunals Judiciary. 2020-08-11. <https://www.judiciary.uk/wp-content/uploads/2020/08/R-Bridges-v-CC-South-Wales-ors-Judgment.pdf> (verified: primary) [59] 29 CFR § 1607.4(D), Uniform Guidelines on Employee Selection Procedures (adverse impact and the "four-fifths rule"). eCFR (text as of 2026-09-01). 2026-09-01. <https://www.ecfr.gov/current/title-29/subtitle-B/chapter-XIV/part-1607/section-1607.4> (verified: primary) [60] 15 U.S.C. § 45(n) (FTC Act s. 5: standard for unfairness). US Government Publishing Office, GovInfo (United States Code, 2024 edition). 2024. <https://www.govinfo.gov/content/pkg/USCODE-2024-title15/html/USCODE-2024-title15-chap2-subchapl-sec45.htm> (verified: primary) [61] FTC Policy Statement on Deception (representation, omission or practice likely to mislead a consumer acting reasonably; materiality). Federal Trade Commission. 1983-10-14. <https://www.ftc.gov/legal-library/browse/ftc-policy-statement-deception> (verified: primary) [62] "FTC Order Requires Workado to Back Up Artificial Intelligence Detection Claims" (claimed 98% accuracy; 53% on general-purpose content; competent and reliable evidence required). Federal Trade Commission. 2025-04-28. <https://www.ftc.gov/news-events/news/press-releases/2025/04/ftc-order-requires-workado-back-artificial-intelligence-detection-claims> (verified: primary) [63] FTC v. Rite Aid Corporation, No. 2:23-cv-5023 (E.D. Pa.) (five-year ban on facial recognition for security or surveillance; stipulated order approved 8 Mar 2024). Federal Trade Commission, case page. 2024-03-08. <https://www.ftc.gov/legal-library/browse/cases-proceedings/2023190-rite-aid-corporation-ftc-v> (verified: primary) [64] In the Matter of Everalbum, Inc., Decision and Order ("Affected Work Product": models or algorithms developed using users' biometric information, to be deleted within 90 days with a sworn statement). Federal Trade Commission. 2021-05-07. https://www.ftc.gov/system/files/documents/cases/1923172_-_everalbum_decision_final.pdf (verified: primary) [65] "SEC Charges Two Investment Advisers with Making False and Misleading Statements About Their Use of Artificial Intelligence" (Delphia and Global Predictions; USD 400,000 combined penalties). US Securities and Exchange Commission. 2024-03-18. <https://www.sec.gov/newsroom/press-releases/2024-36> (verified: primary) [66] "Federal Trade Commission Announces Final Rule Banning Fake Reviews and Testimonials" (16 CFR Part 465; covers AI-generated fake reviews; civil penalties for knowing violations). Federal Trade Commission. 2024-08-14. <https://www.ftc.gov/news-events/news/press-releases/2024/08/federal-trade-commission-announces-final-rule-banning-fake-reviews-testimonials> (verified: primary) [67] California Business and Professions Code ss. 17940 to 17943 (bot disclosure: unlawful to use a bot to mislead about its artificial identity to incentivise a sale or influence a vote, unless clearly and conspicuously disclosed; in force 1 Jul 2019). California Legislative Information. 2019. https://leginfo.ca.gov/faces/codes_displayText.xhtml?lawCode=BPC&division=7.&title=&part=3.&chapter=6.&article= (verified: primary) [68] Directive 2005/29/EC (Unfair Commercial Practices Directive), Art. 5 (general prohibition; professional diligence; average and vulnerable consumer). Official Journal of the EU. 2005-05-11. <https://eur-lex.europa.eu/eli/dir/2005/29/oj> (verified: primary) [69] Directive (EU) 2019/2161 (better enforcement and modernisation of EU consumer protection rules), adding UCPD Annex I points 23b and 23c (consumer reviews). Official Journal of the EU. 2019-11-27. <https://eur-lex.europa.eu/eli/dir/2019/2161/oj> (verified: primary) [70] Regulation (EU) 2022/2065 (Digital Services Act), Arts. 25 (online interface design and organisation), 27 (recommender system transparency) and 35(1)(k) (prominent marking of generated or manipulated media). Official Journal of the EU. 2022-10-19. <https://eur-lex.europa.eu/eli/reg/2022/2065/oj> (verified: primary) [71] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 5(1)(a) and (b) (manipulative or deceptive techniques; exploitation of vulnerabilities). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_5 (verified: primary) [72] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Art. 50 (disclosure of AI interaction; machine-readable marking of synthetic content; deployer disclosure of deep fakes). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_50 (verified: primary) [73] Digital Markets, Competition and Consumers Act 2024, s. 225 (unfair commercial practices prohibited; in force 6 Apr 2025) and Sch. 20, para. 13 (fake and concealed-incentive consumer reviews). legislation.gov.uk. 2024. <https://www.legislation.gov.uk/ukpga/2024/13/section/225> (verified: primary) [74] AI Liability Directive, Legislative Train Schedule (withdrawal announced in the Commission 2025 work programme; withdrawal published OJ C/2025/5423, 6 Oct 2025). European Parliament. 2026-08. <https://www.europarl.europa.eu/legislative-train/theme-a-europe-fit-for-the-digital-age/file-ai-liability-directive> (verified: secondary) [75] "Products liability" (design, manufacturing and marketing defects, including failure to warn; consumer-expectation and risk-utility tests). Legal Information Institute, Wex. current. https://www.law.cornell.edu/wex/products_liability (verified: secondary) [76] Garcia v. Character Technologies, Inc., No. 6:24-cv-01903 (M.D. Fla.): order granting in part and denying in part motions to dismiss (ECF 115, 21 May 2025); notice of resolution and order dismissing without prejudice (ECF 242 and 244, 7 Jan 2026). CourtListener (court docket). 2026-01-07. <https://www.courtlistener.com/docket/69300919/garcia-v-character-technologies-inc/> (verified: primary) [77] Product liability

(review of the regime, including digital products and AI; terms of reference 8 Dec 2025; consultation planned for the second half of 2026). Law Commission of England and Wales. 2025-12. <https://lawcom.gov.uk/project/product-liability/> (verified: primary) [78] IEC 60812:2018, Failure modes and effects analysis (FMEA and FMECA), edition 3.0. International Electrotechnical Commission. 2018-08-10. <https://webstore.iec.ch/en/publication/26359> (verified: primary) [79] "Safer and more transparent AI" (Art. 50 transparency live 2 Aug 2026). European Commission. 2026-08-02. https://commission.europa.eu/news-and-media/news/safer-and-more-transparent-ai-2026-08-02_en (verified: primary) [80] TAKE IT DOWN Act, Public Law 119-12 (S. 146) (knowing publication of intimate images incl. digital forgeries; notice-and-removal process within one year of enactment; removal within 48 hours; FTC enforcement). US Government Publishing Office, GovInfo. 2025-05-19. <https://www.govinfo.gov/content/pkg/PLAW-119publ12/html/PLAW-119publ12.htm> (verified: primary) [81] Sexual Offences Act 2003, s. 66B (sharing or threatening to share a photograph or film which "shows, or appears to show" another person in an intimate state; in force 31 Jan 2024). legislation.gov.uk. 2024-01-31. <https://www.legislation.gov.uk/ukpga/2003/42/section/66B> (verified: primary) [82] Data (Use and Access) Act 2025, s. 138 (inserts Sexual Offences Act 2003 s. 66E, creating a purported intimate image of an adult). legislation.gov.uk. 2025. <https://www.legislation.gov.uk/ukpga/2025/18/section/138> (verified: primary) [83] Equal Credit Opportunity Act (Regulation B): final rule (ECOA does not authorize disparate-impact liability, the effects test; amends 12 CFR 1002.4, 1002.6, 1002.8 and 1002.15 and Supplement I, not 1002.9; 91 FR 21620, FR Doc. 2026-07804; effective 2026-07-21). Consumer Financial Protection Bureau, Federal Register. 2026-04-22. <https://www.federalregister.gov/documents/2026/04/22/2026-07804/equal-credit-opportunity-act-regulation-b> (verified: primary) [84] Withdrawn guidance (Circular 2022-03 on adverse-action notices for credit decisions based on complex algorithms, 87 FR 35864, withdrawn on 12 May 2025 by the notice at 90 FR 20084). Consumer Financial Protection Bureau. 2025-05-12. <https://www.consumerfinance.gov/compliance/guidance/withdrawn-guidance/> (verified: primary)

21. AI-specific laws around the world

Outside the EU, AI-specific law ranges from Korea's horizontal Basic Act to US state statutes, public-sector directives and voluntary frameworks; this chapter dates each regime and names the artefact that evidences each duty.

How to read this chapter

This chapter is a field guide to the AI-specific rules that sit beside the EU AI Act. It is written for the engineer who has to make one set of controls answer several regimes at once, not for the lawyer who has to opine on any one of them. Chapter 18 treats the [EU AI Act](#) in depth; chapter 19 covers privacy and data protection, including [the regimes beyond the EU](#); chapter 20 covers the [other law that already applies to AI](#); chapter 22 covers [principles, soft law and standards](#), including the international treaties. Chapter 08 remains the [reverse index](#) that turns each obligation into an artefact and a layer.

Every entry below follows the same template: **status**, **dates**, **scope**, **key duties**, **enforcement** and the **artefacts that evidence compliance**. Every status is stamped **as of 2026-09-24**. Where a rule was still moving on that date, or a fact could not be confirmed against a primary source, the copy says so and carries a [\(verify\)](#) tag. Translations of Korean, Japanese, Chinese, Italian, Spanish and Portuguese terms are ours unless a source gives an official one.

The status vocabulary has four values, the same four the site's jurisdiction dataset uses:

- **Binding, horizontal.** A statute in force that applies across sectors (Korea, Italy, Japan's promotion act).
- **Binding, targeted.** Binding rules limited to a use, a sector, a class of developer or the public sector (the US states, the US federal agencies, China's departmental rules, Canada's directive).
- **Voluntary.** Frameworks, guidance and principles with no penalty attached (Singapore, the United Kingdom's AI-specific approach, India, Australia).
- **Bill.** Not law yet (Brazil, Spain's national AI bill).

The engineering reading is the one chapter 06 calls [regulatory translation](#): most of these regimes ask for the same small set of artefacts (an inventory, a classification decision, a notice, a label, a risk assessment, an incident report, a record kept for a fixed period). What differs is the trigger, the wording of the notice, the clock on the report, the recipient and the enforcer. Build the control once in the stack and parameterise it per jurisdiction; the [Framework Crosswalk](#) pattern is the place where those parameters live. None of this is legal advice, and the mappings are illustrative, not a claim of conformity.

The landscape at a glance

Jurisdiction	Main instrument	Status (as of 2026-09-24)	Kind	Who enforces
South Korea	AI Basic Act and Enforcement Decree	In force since 2026-01-22; fines subject to a guidance period of at least one year [1][2][3]	Binding, horizontal	Ministry of Science and ICT (MSIT)
United States (federal)	EO 14179, EO 14365, OMB M-25-21, M-25-22 and M-26-04	In force for federal agencies; no federal statute for private actors [5][6][8][10]	Binding, targeted	OMB and agencies; DOJ task force against state laws
United States (states)	Colorado SB 26-189, Texas HB 149, California SB 53, SB 942, AB 2013, SB 243 and CPPA rules, New York RAISE and GBL Art. 47, Utah, Illinois, NYC LL 144	Mixed: several in force, Colorado from 2027-01-01, RAISE from 2027-01-01 [15][18][19][26]	Binding, targeted	State attorneys general and agencies
Japan	AI Promotion Act (Act No. 53 of 2025)	Fully in force since 2025-09-01 [31][32]	Binding, horizontal (promotional; no penalties)	Cabinet AI Strategy Headquarters
China	CAC departmental rules, most recently the anthropomorphic interaction measures	In force; newest from 2026-07-15 [35]	Binding, targeted	Cyberspace Administration of China (CAC)
Brazil	PL 2338/2023	Bill: passed the Senate 2024-12-10; awaiting report in the Chamber [36][37]	Bill	Not yet designated in law
Canada	Directive on Automated Decision-Making	In force for federal institutions; AIDA lapsed [38][39]	Binding, targeted	Treasury Board of Canada Secretariat

Jurisdiction	Main instrument	Status (as of 2026-09-24)	Kind	Who enforces
India	India AI Governance Guidelines	Published 2025-11-05; no AI act [40]	Voluntary	MeitY (guidance only)
United Kingdom	Principles applied by existing regulators; ATRS; AI Cyber Security Code of Practice	Non-statutory for AI as such [41][43][44]	Voluntary	Existing sector regulators (for example the ICO, FCA and MHRA)
Italy	Law 132/2025	In force since 2025-10-10 [46]	Binding, horizontal	AgID and ACN, plus financial supervisors
Spain	Bill for the good use and governance of AI; AESIA; sandbox	Bill not adopted; sandbox and guides live [47][48][49]	Bill	AESIA and sector authorities (as proposed)
Singapore	Model AI Governance Frameworks (incl. agentic), AI Verify	Voluntary [50][51][53]	Voluntary	IMDA (guidance)
Australia	National AI Plan; Guidance for AI Adoption	Existing law applies; no AI act [54]	Voluntary	Existing regulators; AI Safety Institute advises

The same regimes are drawn as [a tile map by jurisdiction](#).

South Korea: the AI Basic Act

South Korea has a horizontal AI statute in force that carries operator duties and fines. Its formal name is the Basic Act on the Development of Artificial Intelligence and the Establishment of a Foundation for Trust (인공지능 발전과 신뢰 기반 조성 등에 관한 기본법), Act No. 20676 [1]. Most of the Act is industrial policy (a national AI strategy committee, training data, AI clusters, industry support); the duties that matter to the engineer sit in Chapter 4, Articles 31 to 36, and in the enforcement provisions of Articles 40 and 43 [1].

Status and dates

The Act was promulgated on 21 Jan 2025 and entered into force on 22 Jan 2026; the part of the high-impact definition that covers digital medical devices started on 24 Jan 2026 [1]. An amending Act, No. 21311 of 20 Jan 2026, revised Article 2 and other provisions before entry into force. A second group of its changes took effect on 21 Jul 2026: a second sentence in Article 35(1) requires the impact assessment to reflect the characteristics of AI-vulnerable groups, and Article 16(3) and (4) tell public bodies to consider designated AI products first when they buy, and exempt the officials who buy or use them from liability to their body for any resulting loss, save intent or gross negligence [1]. The Enforcement Decree, Presidential Decree No. 36053, was promulgated on 21 Jan 2026 and took effect on 22 Jan 2026 [2]. MSIT, the competent ministry, announced a guidance period of at least one year during which fact-finding investigations and administrative fines are suspended except in very exceptional cases, such as loss of life or human-rights violations [3]. The grace period is on the fines, not on the duties: the obligations have applied since 22 Jan 2026. A decree amendment in force from 21 Jul 2026, Presidential Decree No. 36506, defined the AI-vulnerable groups (among them people with disabilities, people aged 65 or over, people eligible for job-seeker benefits and women with career breaks), set up the ministry's confirmation of AI products for public procurement, and amended Decree Article 28(1) so that the impact assessment's identification of affected people reflects those groups [2][4]. The other operator duties described below are unchanged.

Scope and duty holders

The Act reaches conduct abroad that affects the Korean market or Korean users (Article 4(1)), and excludes AI developed and used solely for defence or national security, as specified by decree (Article 4(2); Decree Article 2) [1][2]. The duty holder is the **AI business operator**, which the Act splits into two roles: the operator that develops and provides AI, and the operator that uses AI provided by another to offer its own product or service (Article 2(7)) [1]. The split is close to the EU's provider and deployer, but not identical: both roles carry the transparency and high-impact duties, and the decree lets a using operator rely on the developer's risk-management, explanation and user-protection measures unless it materially changes the system's purpose or use (Decree Article 27(3)) [2].

High-impact AI and how it is confirmed

High-impact AI is an AI system that may significantly affect, or pose a risk to, human life, physical safety or fundamental rights, and that is used in one of the areas the Act lists (Article 2(4)) [1]:

- energy supply; the production of drinking water; the provision of health care; the development and use of medical devices and digital medical devices; the safe management of nuclear materials and facilities;
- the analysis and use of biometric information for criminal investigation or arrest;
- judgements or evaluations that significantly affect individual rights and obligations, **such as hiring and loan screening**;
- the main operation of transport means, facilities and systems;

- decisions by state bodies, local governments and public institutions that affect citizens, such as eligibility checks and the collection of charges for public services;
- student evaluation in early childhood, primary and secondary education;
- any further area designated by presidential decree.

The operator must review in advance whether its system is high-impact, and may ask MSIT to confirm (Article 33(1)) [1]. The decree turns the request into a file: an overview of the product or service, an overview of the training data, material showing how the system is used and what it produces, and any other supporting document. MSIT weighs the area, the impact, severity and frequency of the risk, the operator's own prior review and, where consulted, an expert committee, and replies within 30 days, extendable once by 30 days. An operator that disagrees can ask for re-confirmation within 10 days, and MSIT must answer within a further 30 days after consulting the expert committee (Decree Article 25) [2].

For the engineer this is an intake artefact: a **classification decision record** per system, holding the Article 2(4) area, the risk rationale, the training-data overview and, when requested, MSIT's reply. It is the same record chapter 06 builds at [intake and classification](#), with one more field.

Transparency: prior notice and labelling

Article 31 carries three duties [1]:

1. **Prior notice.** An operator that provides a product or service using high-impact or generative AI must tell users in advance that it runs on that AI.
2. **Output labelling.** An operator that provides generative AI, or a product or service using it, must indicate that outputs were generated by generative AI.
3. **Realistic synthetic content.** Where a system produces sound, images or video that are hard to distinguish from reality, the operator must notify or label them so users can clearly recognise them as AI-generated; for artistic or creative works, the notice may be given in a way that does not hinder exhibition or enjoyment.

The decree sets the mechanics (Decree Article 23) [2]. Prior notice can sit in the product itself, in the contract, manual or terms of use, on the user's screen or device, or be posted at the place of supply. Labels can be human-perceivable or machine-readable; where they are machine-readable only, the operator must also tell the user at least once, by text or voice, that the output was generated by generative AI. Notices and labels for realistic synthetic content must be easy to perceive and must take account of the main users' age and physical or social conditions. Three exemptions apply: where AI use is obvious from the product name, screen or output; where the system is used only for the operator's internal business; and cases MSIT designates by public notice.

Duties for high-impact AI

An operator that provides high-impact AI must implement six measures (Article 34(1)) [1]: a risk management plan; an explanation plan covering, within technical feasibility, the final result, the main criteria used to reach it and an overview of the training data; a user-protection plan; human management and supervision; documents showing the measures taken; and any further measure the national AI committee resolves. The decree adds three operational rules (Decree Article 27) [2]:

- the operator posts the main content of the risk management, explanation and user-protection plans, and the name and contact details of the person who oversees the system, at its offices or on its website, with trade secrets excepted;
- the operator keeps the documentary evidence of the measures for **five years**, electronically or otherwise;
- a using operator may ask the developing operator for the information it needs, and the developer must endeavour to cooperate; measures taken under other laws count where the decree's annex says so.

Impact assessment is a best-effort duty: operators "shall endeavour" to assess the effect on fundamental rights before providing high-impact AI, and public bodies must give priority to products that were assessed (Article 35) [1]. The decree fixes the content: the individuals and groups likely to be affected, reflecting the characteristics of AI-vulnerable groups (Act Articles 3(5) and 35(1), in force from 21 Jul 2026); the fundamental rights at stake; the social and economic effects; the patterns of use; the quantitative or qualitative indicators and method used; the prevention, mitigation and recovery measures; and an improvement plan where needed. The operator may run the assessment itself or through a third party (Decree Article 28) [2].

Safety duties for high-compute systems

Article 32 applies to systems whose cumulative training compute exceeds a threshold set by decree [1]. The decree requires all three of: cumulative training compute of at least **10²⁶ floating-point operations**; construction and operation with the most advanced AI technology of the day; and a risk profile that may broadly and seriously affect life, safety and fundamental rights (Decree Article 24) [2]. Operators of such systems must identify, assess and mitigate risks across the lifecycle, build a risk-management system that monitors and responds to AI safety incidents, and submit the results to MSIT [1]. The compute figure is the same 10²⁶ that the US frontier laws use (see [frontier-developer laws](#) in chapter 08), but the conjunctive test makes the Korean class narrower on paper.

Domestic representative

An operator with no address or business establishment in Korea must designate a **domestic representative** in writing and report it to MSIT if it meets any decree threshold (Article 36; Decree Article 29) [1][2]: prior-year total revenue of KRW 1 trillion or more; prior-year revenue from AI services of KRW 10 billion or more; an average of 1 million or more daily users in Korea over the three

months before the end of the prior year; or a past fine for ignoring a corrective order. The representative submits the Article 32 safety results, files high-impact confirmation requests and supports the Article 34 measures, including checking that the documents are current and accurate; its breaches are attributed to the operator [1].

Enforcement and the grace period

MSIT may demand documents and investigate, including on-site, when it finds or is told of a suspected breach of the labelling, safety or high-impact duties, and may order the breach stopped or corrected (Article 40) [1]. Administrative fines of up to **KRW 30 million** apply to three failures only: not giving the Article 31(1) prior notice, not designating a domestic representative, and not obeying a stop or corrective order (Article 43) [1]. A labelling failure is therefore not fined directly; it becomes finable when the operator ignores the corrective order that follows. During the guidance period described above, fact-finding and fines are held back except in exceptional cases [3].

Duty (article)	Who is bound	Engineering artefact that evidences it	Layer
High-impact self-review and optional confirmation (Art. 33; Decree Art. 25)	All AI business operators	Classification decision record per system: Art. 2(4) area, risk rationale, training-data overview, MSIT reply	1 · 2
Prior notice (Art. 31(1); Decree Art. 23(1))	Operators of products using high-impact or generative AI	Notice component in UI, terms and contracts; notice inventory per user surface	2 · 4
Output labels and realistic-content notice (Art. 31(2)–(3); Decree Art. 23(2)–(3))	Operators of generative AI	Provenance pipeline: visible label or machine-readable mark, plus at least one text or voice notice	3 · 4
Safety duties above 10 ²⁶ FLOP (Art. 32; Decree Art. 24)	Operators of qualifying systems	Lifecycle risk register; safety-incident monitoring; results report to MSIT	3 · 4 · 5
High-impact measures (Art. 34; Decree Art. 27)	Operators of high-impact AI	Risk management, explanation and user-protection plans; named human overseer; published summary; five-year evidence store	1 · 2 · 4 · 5
Impact assessment, best effort (Art. 35; Decree Art. 28)	Operators of high-impact AI	Fundamental-rights impact assessment carrying the seven decree elements	1 · 5
Domestic representative (Art. 36; Decree Art. 29)	Foreign operators above a threshold	Designation filed with MSIT; evidence-access runbook for the representative	5

In practice (illustrative) A foreign provider of a hiring-assessment API crossed the 1-million-daily-user threshold through Korean customers of its customers. The governance team did three things. It added a `jurisdiction.kr` block to each system's registry entry holding the Article 2(4) area ("hiring"), the self-review verdict and a link to the decree-shaped impact assessment. It extended the evidence store's retention policy to five years for every artefact tagged `kr-art34`. And it gave the domestic representative read access to a filtered evidence view, so the representative could answer MSIT from current documents instead of emailing the product team. Nothing new was built in the model; the work was in the registry, the retention policy and the access path.

United States: the federal layer

The United States has no federal AI statute that binds private actors. The federal layer is a set of executive orders and Office of Management and Budget (OMB) memoranda that bind federal agencies, and, through procurement, the vendors that sell to them. Since December 2025 it has also included a deliberate push against state AI laws.

Executive orders

- **EO 14179** (23 Jan 2025), *Removing Barriers to American Leadership in Artificial Intelligence*, ordered a review of every action taken under the revoked EO 14110, so that those inconsistent with the new policy could be suspended, revised or rescinded, and ordered an AI action plan within 180 days [5].
- **EO 14319** (23 Jul 2025), *Preventing Woke AI in the Federal Government*, set two "Unbiased AI Principles" (truth-seeking and ideological neutrality) for large language models the government buys [8].
- **EO 14365** (11 Dec 2025), *Ensuring a National Policy Framework for Artificial Intelligence*, targets state AI laws; it is treated in its own subsection below [10].

OMB memoranda for federal agencies

M-25-21 (3 Apr 2025), *Accelerating Federal Use of AI through Innovation, Governance, and Public Trust*, rescinded and replaced M-24-10 [6]. It defines **high-impact AI** as AI whose output serves as a principal basis for decisions or actions with a legal, material, binding or significant effect on civil rights, civil liberties or privacy, on access to education, housing, insurance, credit, employment and other programmes, on access to critical government services, or on human health and safety, among others [6]. Some use-case categories are presumed high-impact; an agency official who concludes otherwise must document the decision to the Chief AI Officer. Agencies had 365 days from issuance to document the minimum practices for high-impact AI: pre-deployment testing;

an AI impact assessment; ongoing monitoring for performance and adverse impacts; adequate training of operators; human oversight, intervention and accountability, with a fail-safe where practicable; consistent remedies or appeals for affected individuals; and consultation of end users and the public [6]. **M-25-22**, issued the same day, covers acquisition [7].

M-26-04 (11 Dec 2025) implements EO 14319 [8]. Agencies had until 11 Mar 2026 to update their procurement policies, and every solicitation for a large language model must request, as a minimum, the vendor's acceptable use policy; model, system or data cards; end-user resources; and a mechanism for end-user feedback on outputs that breach the principles [8]. The requirements also reach models embedded in other software the agency buys [8].

America's AI Action Plan

The plan, published in July 2025, has three pillars: accelerate innovation, build American AI infrastructure, and lead in international AI diplomacy and security [9]. Two of its actions matter here. It asks agencies with discretionary AI funding to consider a state's AI regulatory climate when making funding decisions, and the Federal Communications Commission to evaluate whether state AI rules interfere with its mandate; and it directs NIST to revise the AI Risk Management Framework to remove references to misinformation, diversity, equity and inclusion, and climate change [9].

The federal push against state AI laws

EO 14365 sets the machinery [10]. The Attorney General was to establish an **AI Litigation Task Force** within 30 days to challenge state AI laws that conflict with federal policy; the Secretary of Commerce was to publish, within 90 days, an evaluation of "onerous" state AI laws, including those that require models to alter truthful outputs; states with such laws become ineligible for some broadband (BEAD) funds and may see other discretionary grants conditioned; the FCC is to consider a federal reporting and disclosure standard that would preempt conflicting state rules; the Federal Trade Commission (FTC) is to issue a policy statement on how its deception authority applies to state laws that require altered outputs; and the President's advisers are to prepare legislation for a uniform federal framework. The order's legislative recommendation must not propose preempting state laws on child safety, on AI compute and data-centre infrastructure other than permitting, or on state procurement and use of AI [10].

What happened next, as of 2026-09-24:

- The Attorney General announced the task force on 9 Jan 2026, as reported by practitioners [12].
- The White House published non-binding legislative recommendations on 20 Mar 2026, asking Congress to preempt state AI laws that impose undue burdens while not preempting generally applicable state laws that protect children, prevent fraud and protect consumers [11].
- The FTC sought comment on 1 Jul 2026 on a proposed policy statement: that deliberately distorting an AI system's outputs for undisclosed ideological purposes may be deceptive under Section 5 of the FTC Act. The statement discusses Colorado's AI Act and suggests it may be impliedly preempted where it coerces changes to outputs; comments closed on 31 Jul 2026 [13].
- In the House, a bipartisan discussion draft released in June 2026 would allow federal preemption of state AI regulation for three years; it was a draft for stakeholder feedback, not a filed bill [14]. Whether it has since been introduced should be checked (verify).
- The Commerce evaluation was due within 90 days of the order [10]; whether it has been published, and which laws it names, should be checked (verify).
- In the courts, xAI sued on 9 Apr 2026 to block Colorado's original AI Act, SB 24-205, and the US Department of Justice intervened with a companion complaint on 24 Apr 2026, arguing that the Act violates the Equal Protection Clause [16][17]. On 27 Apr 2026 a federal magistrate judge entered a stipulated order under which the Colorado Attorney General would not enforce SB 24-205 until 14 days after a ruling on xAI's motion for a preliminary injunction; SB 26-189 then replaced the Act [16].

For the engineer the practical rule is simple: a state duty binds until it is repealed, replaced or enjoined. Keep each state's controls as a separate, versioned policy module keyed to the jurisdiction, so that a court order or a repeal is a configuration change and not a rebuild.

Federal instrument	Applies to	What it asks for	Artefact the agency or vendor keeps	Layer
OMB M-25-21 [6]	Federal agencies (Intelligence Community elements encouraged, not required)	High-impact determination; seven minimum practices; Chief AI Officer; use-case inventory	Use-case inventory entry; pre-deployment test report; AI impact assessment; monitoring plan; appeal path	2 · 3 · 4 · 5
OMB M-26-04 [8]	Agencies buying large language models, and their vendors	Unbiased AI Principles as contract terms; minimum transparency package	Acceptable use policy; model, system or data cards; end-user resources; feedback channel	2 · 5
EO 14365 and the FTC proposal [10] [13]	States; developers subject to state laws	No duty yet on private actors; litigation and preemption risk	Jurisdiction-keyed policy modules; record of which output controls each state law requires	1

United States: state laws that bind private organisations

Chapter 08 maps the two frontier laws, Texas and Colorado at the level of the [US federal and state laws](#) table. This section adds the laws that reach ordinary developers and deployers, and gives each one its scope, dates, duties and enforcement.

Law	Status (as of 2026-09-24)	Scope	Key duties	Enforcement	Evidence artefact	Layer
Colorado SB 26-189 (Automated Decision-Making Technology)	Signed 2026-05-14; effective 2027-01-01; repeals and re-enacts SB 24-205 [15][16]	Developers and deployers of ADMT in consequential decisions (employment, housing, lending, insurance, benefits)	Developer documentation to deployers (intended uses, training-data categories, known limits, instructions) and notice of material updates; deployer notice of ADMT use; plain-language explanation within 30 days of an adverse outcome; consumer correction, human review and reconsideration; records kept three years or more	Attorney General under the Consumer Protection Act; 60-day cure notice before 2030; no new private right of action [15]	ADMT inventory; developer documentation pack; notice and adverse-outcome explanation templates; human-review queue; three-year record store	2 · 4 · 5
Texas TRAIGA (HB 149)	In force 2026-01-01 [18]	Persons doing business in Texas; developers, deployers, government	Intent-based prohibitions (behaviour manipulation, government social scoring, unlawful discrimination, certain sexual content); disclosure by government agencies and in health care services; 36-month sandbox; local AI rules preempted	Attorney General only; no private right of action; 60-day cure; USD 10,000–12,000 per curable, 80,000–200,000 per incurable violation, 2,000–40,000 per day continuing [18]	Prohibited-use policy-as-code; disclosure controls; a model card that answers the Attorney General's eight investigative questions	1 · 2 · 4
California SB 53 (Transparency in Frontier AI Act)	Chaptered 2025-09-29; in force 2026-01-01 [19][20]	Frontier developers (models trained above 10 ²⁶ operations); large frontier developers (revenue above USD 500M)	Published frontier AI framework; transparency report before deploying a new or substantially modified frontier model; critical safety incidents reported within 15 days, 24 hours if death or serious injury is imminent; whistleblower channel	Attorney General; civil penalty up to USD 1M per violation [19]	Published framework; pre-deployment transparency report; incident pipeline with the two clocks; anonymous reporting channel	3 · 4 · 5
California AI Transparency Act (SB 942 as amended by AB 853)	Operative 2026-08-02; platform duties 2027-01-01; capture devices 2028-01-01 [21]	Covered providers of public generative AI systems; large online platforms; hosting platforms; capture-device makers	Free detection tool; optional visible (manifest) disclosure; embedded (latent) disclosure in image, video and audio; platforms detect and surface provenance and must not strip it	Civil penalty of USD 5,000 per violation, each day a separate violation, in actions by the Attorney General, a city attorney or a county counsel (Bus. & Prof. Code s. 22757.4) [21]	Provenance pipeline writing latent metadata; public detection endpoint; platform-side provenance display	3 · 4
California AB 2013 (training-data transparency)	Documentation due on or before 2026-01-01 and on each new release or substantial modification [22]	Developers of generative AI systems released since 2022-01-01 for use in California	Public summary of training datasets: sources, purpose, size, data types, IP status, licensing, personal information, cleaning, collection period, first use, synthetic data	Exemptions: security and integrity, aircraft operation, federal national-security uses [22]	Data card per dataset, published at release; training-data rights ledger	2
California CCPA regulations (ADMT, risk assessments, cybersecurity audits)	Approved 2025-09-23; effective 2026-01-01; ADMT duties from 2027-01-01; risk-assessment attestations due 2028-04-01 [23]	Businesses subject to the CCPA using ADMT for significant decisions	ADMT duties for significant decisions (detail in chapter 19); risk assessments; cybersecurity audits	California Privacy Protection Agency [23]	ADMT register; pre-use notice; opt-out routing; risk-assessment record	2 · 4 · 5

Law	Status (as of 2026-09-24)	Scope	Key duties	Enforcement	Evidence artefact	Layer
California SB 243 (companion chatbots)	Chaptered 2025-10-13; annual reports from 2027-07-01 [24]	Operators of companion chatbots	Disclose AI where a reasonable person could be misled; for known minors, disclose AI and remind at least every three hours, and prevent sexually explicit content; suicide and self-harm protocol with crisis referral	Private right of action: at least USD 1,000 per violation [24]	Companion-mode policy; reminder timer; crisis-referral classifier and log; annual report	1 · 4 · 5
New York RAISE Act	Signed 2025-12-19; effective 2027-01-01 after the 2026 chapter amendment [25] [26]	Frontier developers (models trained above 10^{26} operations) for incident reports; large frontier developers (revenue above USD 500M) for the published protocol, after the chapter amendment [26]	Published safety protocol; safety incidents disclosed within 72 hours; DFS oversight office	Attorney General [25]	Published protocol; 72-hour incident pipeline	4 · 5
New York GBL Article 47 (AI companion models)	In force [27] (verify commencement date)	Operators of AI companions	Protocol to detect suicidal ideation and self-harm and refer to crisis services; notice that the user is not talking to a human at the start and at least every three hours	Attorney General; civil penalties up to USD 15,000 per day [27]	Crisis-referral classifier and log; notice timer	4 · 5
Utah AI Policy Act (SB 149 as amended by SB 226 and SB 332)	Amendments effective 2025-05-07; Act repeals on 2027-07-01 [28]	Suppliers using generative AI in consumer transactions; regulated occupations	Disclose AI when a person clearly asks; prominent disclosure in "high-risk" interactions (sensitive data or personalised advice) by regulated professionals, verbally at the start or in writing before; safe harbour for clear disclosure at the outset	Division of Consumer Protection [28]	Disclosure component with interaction-risk flag; conversation log showing the disclosure	4
Illinois HB 3773 (Human Rights Act amendment)	Effective 2026-01-01; implementing rules in draft, as reported [29]	Employers using AI in recruitment, hiring, promotion, discipline and other terms of employment	No use of AI with a discriminatory effect on protected classes; no ZIP codes as a proxy; notice to employees and applicants	Illinois Department of Human Rights and the Human Rights Act's remedies [29]	AI-in-HR inventory; adverse-impact eval per protected class; notice record	2 · 3 · 4
NYC Local Law 144 (automated employment decision tools)	Enforced since 2023-07-05 [30]	Employers and employment agencies using AEDTs for New York City roles	Bias audit within one year before use; public summary of results; notices to candidates and employees	Department of Consumer and Worker Protection; complaints channel [30]	Independent bias-audit report; published summary; notice record	3 · 5

Consequential decisions: one hiring tool, four regimes

Colorado, the California ADMT rules, Illinois and New York City all reach automated hiring, but each asks for a different artefact: Colorado an explanation within 30 days of an adverse outcome and a human-review path [15]; California, from 2027, the CPPA's ADMT duties [23]; Illinois a notice and an absence of discriminatory effect [29]; New York City an independent bias audit, published, less than a year old [30]. Korea lists hiring as a high-impact area too [1]. A single eval suite that measures selection rates per protected class, run in CI and on production samples, produces the evidence every one of them needs; the notices and review paths differ only in wording and timing.

Example (illustrative) A vendor's CV-ranking model is deployed by employers in Denver, Chicago, New York City and Seoul. The [Eval Gate in CI](#) runs an adverse-impact suite on every release and blocks one that moves any group's selection-rate ratio below the configured floor. The same results feed the NYC bias-audit auditor's data request, the Illinois discriminatory-effect file and the Korean impact assessment's "indicators and method" section. The registry entry carries four notice templates and one human-review queue; the [adverse-outcome explanation](#) is generated from the model's top reason codes and logged with the decision, so Colorado's 30-day clock is met by the same pipeline that answers a US credit adverse-action notice.

Provenance, training data and frontier developers

California splits content transparency across two statutes: AB 2013 makes developers publish a summary of their training data [22], and the AI Transparency Act makes large providers embed provenance in the media their systems produce and give the public a way to check it [21]. Both are evidence problems before they are legal ones: a data card per dataset and a provenance pipeline that writes metadata at generation time are the artefacts, and both belong in layers 2 and 3 of the [stack](#). For frontier developers, SB 53 and RAISE converge on a published safety framework and a short incident clock [19][25]; chapter 08 carries the [frontier-developer rows](#).

Chatbots and companions

Utah, California and New York regulate the conversational interface itself, not the model behind it [24][27][28]. Utah asks for disclosure on a clear request and prominent disclosure in regulated, high-risk interactions [28]; California and New York add periodic reminders and a crisis-referral protocol for companion products, with California's reminders tied to known minors [24][27]. China's anthropomorphic interaction measures, below, cover the same ground with a two-hour reminder [35]. These are [Runtime Guardrail](#) problems: a session timer, a classifier that detects self-harm signals and routes to a referral, and a log that proves both fired.

Japan: the AI Promotion Act

Japan's Act on the Promotion of Research, Development and Utilisation of AI-Related Technologies (人工知能関連技術の研究開発及び活用の推進に関する法律), Act No. 53 of 2025, was promulgated on 4 Jun 2025 and fully in force from 1 Sep 2025, when the provisions setting up the AI Strategy Headquarters took effect [31][32]. It is a framework and promotion law with no penalties [31]. Its duty on business is one sentence: operators that use AI-related technology in their business must endeavour to use it actively and must **cooperate** with the measures of national and local government (Article 7) [31]. The state issues guidelines consistent with international norms to ensure appropriate research, development and use (Article 13), and collects information on, and analyses, cases where improper purposes or inappropriate methods infringed people's rights, then gives guidance, advice and information to operators (Article 16) [31].

The instruments that give the Act content are soft. The AI Strategy Headquarters adopted guidelines on ensuring the appropriateness of AI research, development and use on 19 Dec 2025 [34]. The Cabinet adopted the first AI Basic Plan on 23 Dec 2025 and a revised plan on 14 Jul 2026 [33]. The engineering reading: no filing and no fine, but a government that investigates rights-infringing cases and names operators in guidance. An operator that keeps an incident record and a model card current can answer an Article 16 inquiry without a scramble.

China: what chapter 08 does not already cover

Chapter 08 maps China's [binding and voluntary tiers](#), from the algorithmic-recommendation provisions to the TC260 framework 3.0. One rule it does not map is the **Interim Measures for the Administration of Anthropomorphic Interaction Services** (人工智能拟人化互动服务管理暂行办法), issued by the CAC with four other bodies and in force from 15 Jul 2026 [35]. They apply to AI services offered to the public in China that simulate human personality, thinking and communication style to provide **sustained emotional interaction**, such as companionship or emotional support; customer service, question answering, work assistants, education and research tools without sustained emotional interaction are out of scope (Article 2) [35]. The duties:

- no virtual family members or virtual intimate partners for minors; guardian consent for users under 14; a minors' mode with reality reminders and time limits; reasonable steps to identify minors (Article 14) [35];
- labelling of AI-generated content under the national labelling rules and a clear signal that the user is interacting with AI; a pop-up reminder when over-reliance or addiction appears; a reminder after every **two hours** of continuous use (Article 18) [35];
- an easy exit: when the user asks to leave, the service must stop and must not keep the user engaged (Article 19) [35];
- a **security assessment**, reported to the provincial cyberspace office, when the service launches or adds such features, when new technology changes it significantly, when it reaches 1 million registered or 100,000 monthly active users, or when national security or public-interest risks arise (Article 22) [35];
- algorithm filing under the recommendation provisions, with annual checks by the CAC (Article 26) [35].

The artefacts are the same ones the US companion laws call for, plus a threshold monitor on user counts that triggers the assessment, and the filing record that chapter 08 already maps.

Brazil: PL 2338/2023 (bill)

Brazil's AI bill, PL 2338/2023, was introduced in the Senate on 3 May 2023, approved by the Senate plenary on 10 Dec 2024 and sent to the Chamber of Deputies, which received it on 17 Mar 2025 [36][37]. The Chamber created a special committee on 4 Apr 2025 because the bill was referred to more than four standing committees; as of the last procedural entry, on 2 Sep 2026, the bill was under a priority regime and awaiting the rapporteur's report, with a growing number of related bills attached [37]. It is a bill, not a law. The Senate text, whose stated object is the development, promotion and ethical and responsible use of AI centred on the human person [37], follows a risk-based model with a list of high-risk uses and prohibited uses (verify the current text before relying on any article). The engineering advice for a bill is the same everywhere: map it in the crosswalk as `status: bill`, attach no controls to it yet, and watch the committee.

Canada: after AIDA, the Directive on Automated Decision-Making

The Artificial Intelligence and Data Act (AIDA), part of Bill C-27, died on the Order Paper when the first session of the 44th Parliament ended on 6 Jan 2025 [38]. Canada therefore has no federal AI statute for the private sector. What binds is the Treasury Board **Directive on Automated Decision-Making**, which applies to federal institutions' automated decision systems [39]. It took effect on 1 Apr 2019; the current version (modified 24 Jun 2025) gave systems in place before that date until 24 Jun 2026 to meet the new requirements, and the directive is reviewed every two years [39]. Its core:

- an **Algorithmic Impact Assessment** (AIA) completed and published on the Open Government Portal before production, and updated when functionality or scope changes;
- requirements scaled by the AIA's **impact level** (I to IV), set out in Appendix C;
- notice before decisions through every service channel, in plain language, and a meaningful explanation after decisions;
- quality assurance, including peer review by qualified experts with the review or a summary published before production, and a Gender-based Analysis Plus;
- recourse options to challenge the decision, and published reporting on effectiveness and fairness [39].

The AIA is the most mature public example of an impact assessment that is also a published, versioned artefact; it is a direct model for [FRIA-as-Code](#).

India: governance guidelines, no AI act

India has no AI-specific statute. MeitY published the **India AI Governance Guidelines** on 5 Nov 2025, under the IndiaAI Mission [40]. They comprise seven guiding principles ("sutras"), recommendations across six pillars, an action plan on short, medium and long-term timelines, and practical guidance for industry, developers and regulators [40]. The Secretary of MeitY described the policy as using existing legislation wherever possible [40]. Obligations therefore come from existing law, notably information-technology and data-protection law, which chapter 19 covers; any AI-specific amendment to the IT Rules, for example on labelling synthetic content, should be checked for its current status before it is mapped (verify).

United Kingdom: principles, regulators and public-sector records

The UK has no horizontal AI statute. Its approach, confirmed in the government's February 2024 response to the AI regulation white paper, is five cross-sector principles (safety, security and robustness; appropriate transparency and explainability; fairness; accountability and governance; contestability and redress) applied by existing regulators within their remits [41]. Whether a frontier-AI bill has been introduced since should be checked before relying on this paragraph (verify). The rest of the UK picture is concrete:

- the **AI Security Institute** (renamed from the AI Safety Institute in February 2025) evaluates frontier models [42];
- the **Algorithmic Transparency Recording Standard** (ATRS) is mandatory for all government departments and for arm's-length bodies that deliver public or frontline services or interact directly with the public; records are published in a central repository [43];
- the **AI Cyber Security Code of Practice** (31 Jan 2025) sets baseline security principles for AI systems, with an implementation guide [44] (chapter 08 separately maps the ETSI baseline for securing AI, EN 304 223);
- for significant, solely automated decisions, the Data (Use and Access) Act 2025 replaced UK GDPR Article 22 with Articles 22A to 22D, in force since 5 Feb 2026 (see [chapter 08](#)) [45].

An ATRS record is an inventory entry written for the public. A registry that already holds purpose, owner, data, human oversight and risk fields can generate most of it.

Italy: Law 132/2025

Italy has a national AI law of general scope that sits beside the EU AI Act. Law No. 132 of 23 Sep 2025, *Provisions and delegations to the Government on artificial intelligence*, was published in the Gazzetta Ufficiale on 25 Sep 2025 and entered into force on 10 Oct 2025 [46]. It must be read and applied consistently with the EU AI Act (Article 1(2)) [46]. The provisions an engineer will meet:

- **Minors.** Access to AI technologies by children under 14, and the related processing of personal data, requires the consent of the holder of parental responsibility (Article 4(4)) [46].

- **Work.** The employer must inform workers when AI is used, in the cases and manner of the existing transparency rules for automated systems (Article 11(2)) [46].
- **Professions.** In the intellectual professions AI may be used only for instrumental and support activities, and the professional must tell the client which AI systems are used (Article 13) [46].
- **Authorities.** AgID (the digital agency) handles innovation and the notification and monitoring of conformity-assessment bodies; ACN (the cybersecurity agency) supervises AI systems, including inspections and sanctions; the Bank of Italy, CONSOB and IVASS remain market-surveillance authorities for their sectors (Article 20) [46].
- **Criminal law.** A new offence of unlawful dissemination of AI-generated or altered images, video or voices that cause unjust harm, punishable by one to five years' imprisonment (Article 26, inserting Article 612-quater into the Criminal Code) [46].

The law also delegates further rule-making to the Government; the consolidated text on Normattiva showed a last update of 26 Jun 2026 [46].

Spain: AESIA, the sandbox and a bill

Spain has an operational AI supervisor, a live sandbox and a national AI bill that is not law.

- **The bill.** The Council of Ministers approved, at first reading on 11 Mar 2025, the draft bill for the good use and governance of AI (Anteproyecto de Ley para el buen uso y la gobernanza de la Inteligencia Artificial), with urgent processing; it had to return to the Council of Ministers as a bill and then go to the Cortes Generales [47]. As proposed, it sets the sanctions regime for the EU AI Act within the Act's ranges, treats a failure to label deepfakes as a serious infringement, adds a power to withdraw a system provisionally from the Spanish market after a serious incident, and allocates supervision: the data-protection agency for prohibited biometric and border-management systems and for high-risk migration and asylum systems of the State security forces, the judiciary's council for justice, the central electoral board for democratic processes, the Bank of Spain, the insurance directorate and CNMV for their sectors, and AESIA for the rest [47]. It had not been adopted as of 2026-09-24; check its parliamentary stage before citing it (verify).
- **The sandbox.** Royal Decree 817/2023 set up a controlled testing environment for compliance with the (then proposed) AI Act [48]; the first call sought up to 12 high-risk systems for a one-year test [47].
- **The guides.** AESIA publishes 16 guides produced in the sandbox pilot: two introductory guides, 13 technical guides (conformity assessment, quality management, risk management, human oversight, data governance, transparency, accuracy, robustness, cybersecurity, logging, post-market monitoring, incident management, technical documentation) and a checklist manual. They are non-binding and predate the AI Omnibus, Regulation (EU) 2026/1744, in force since 27 Jul 2026 [68]. As of 2026-09-24 AESIA's page still says they will be updated once the Omnibus is approved, so check each guide against the amended Act [49].

The guides are the most practical public template set for the EU high-risk requirements; chapter 18 maps the articles they implement.

Singapore: model frameworks and AI Verify

Singapore regulates AI through voluntary frameworks and a testing toolkit, maintained by IMDA and the AI Verify Foundation.

- The **Model AI Governance Framework for Generative AI** (May 2024) sets governance dimensions including testing, transparency, incident reporting, security and content provenance [52].
- The **Model AI Governance Framework for Agentic AI** was launched at Davos on 22 Jan 2026 [50]; the current version 1.5 was published on 20 May 2026 and updated on 5 Jun 2026 [51]. It has four dimensions: assess and bound the risks upfront (suitable use cases; limits and permissions by design); make humans meaningfully accountable (allocation of responsibility; meaningful oversight); implement technical controls and processes (in design, before deployment, and continuously in deployment); and enable end-user responsibility [51].
- **AI Verify** is a testing framework that assesses an AI system against 11 internationally recognised governance principles, with a generative-AI extension and technical testing tools [53].

The agentic framework's first two dimensions are what this book calls the [Agent Registry](#) and [Agent Identity & Scoped Credentials](#); its third is the [Eval Gate in CI](#) plus runtime monitoring. Chapter 23 on [governing agents](#) goes further.

Australia: existing law and voluntary guidance

Australia has no AI act. The government's **National AI Plan**, published in December 2025, states that Australia has strong existing, largely technology-neutral legal frameworks that can apply to AI, and that the government will monitor and respond as challenges arise [54]. It establishes an **AI Safety Institute** to monitor, test and share information on emerging capabilities and risks and to advise existing regulators, and builds adoption tools on the six essential practices of the **Guidance for AI Adoption** [54]. For the engineer, obligations come from privacy, consumer, discrimination and sector law; the six practices are a reasonable checklist for a governance programme, not a compliance duty.

Comparing the regimes

The comparison below uses the questions a governance function asks of any AI-specific law. It covers regimes whose text this edition verified; the EU AI Act is the reference point and lives in chapter 18, which also maps [the same roles across regimes](#) that the Roles column compresses. One international treaty sits beside these regimes: the [Council of Europe Framework Convention](#) is treated in chapter 22, with its ratification status.

Regime	Classification trigger	Core duties	Notice and human oversight	Frontier or general-purpose models	Enforcement	Roles
Korea AI Basic Act [1][2]	Listed high-impact areas plus significant risk; generative AI	Risk management, explanation, user protection, documents kept five years; impact assessment (best effort)	Prior notice; output labels; named human overseer	Safety duties above 10 ²⁶ FLOP and state of the art	MSIT; fines up to KRW 30M for three failures; grace period	Developing and using operators; domestic representative
Colorado SB 26-189 [15]	ADMT in consequential decisions	Developer documentation; records three years	Notice; explanation within 30 days; human review and reconsideration	None	Attorney General; cure period; no private action	Developer and deployer
Texas TRAIGA [18]	Prohibited intents; government and health-care use	Avoid prohibited uses; answer investigative demands	Disclosure by government and in health care	None	Attorney General; tiered civil penalties; cure period	Developer, deployer, government
California SB 53 and SB 942 [19] [21]	Compute and revenue (frontier); user base (provenance)	Frontier framework; transparency report; provenance and detection	Latent and manifest disclosures	Frontier developers above 10 ²⁶ operations	Attorney General; up to USD 1M per violation (SB 53)	Frontier developer; covered provider; platform
China, anthropomorphic measures [35]	Sustained emotional interaction services	Security assessment; algorithm filing; minors' mode	AI signal; two-hour reminder; easy exit	None specific	CAC and provincial offices	Service provider; app stores
Japan AI Promotion Act [31]	None (all AI-related technology)	Cooperation with government measures	None in the Act	None	No penalties; guidance after investigation	Research institutions; using operators
Italy Law 132/2025 [46]	Sector provisions on top of the EU AI Act	Worker information; professional disclosure; parental consent under 14	Information to workers and clients	Through the EU AI Act	AgID and ACN; criminal offence for harmful deepfakes	Employer; professional; provider

Sector rules that already reach AI

AI-specific law is only half the picture. Sector regimes written before, or beside, the AI laws already bind many AI systems, usually because the AI sits inside a product, a financial model, an ICT system or a platform they regulate. Chapter 20 covers general law (intellectual property, non-discrimination, consumer protection, product liability); the table below is the sector layer.

Regime	AI trigger	Duty	Engineering artefact	Layer
DORA, Reg. (EU) 2022/2554 (applies from 2025-01-17) [55]	A financial entity's ICT systems or ICT third-party services include AI	ICT risk management, including ICT third-party risk, and reporting of major ICT-related incidents	AI systems in the ICT asset inventory; AI vendors in the third-party register; incident pipeline using the DORA classification	2 · 4 · 5
NIS2, Dir. (EU) 2022/2555 (transposition due 2024-10-17) [56]	An essential or important entity's network and information systems include AI	Cybersecurity risk management; early warning within 24 hours, notification within 72 hours, final report within one month	AI assets in the security scope; incident pipeline with the NIS2 clock	4 · 5
Cyber Resilience Act, Reg. (EU) 2024/2847 (reporting from 2026-09-11; main duties from 2027-12-11) [57][58]	A product with digital elements that includes AI components	Security by design and vulnerability handling; report actively exploited vulnerabilities and severe incidents: 24 hours, 72 hours, final report	SBOM and AIBOM; vulnerability-handling process; reporting runbook for the single reporting platform	2 · 4 · 5

Regime	AI trigger	Duty	Engineering artefact	Layer
Data Act, Reg. (EU) 2023/2854 (applies from 2025-09-12) [59]	Connected products and related services whose data trains or feeds AI; AI delivered as a data-processing service	Data access and sharing for users; switching between data-processing services	Data-access interface and sharing log in the data card; exit and switching plan for the AI platform	2 · 5
EU MDR and IVDR, with MDCG 2025-6 on their interplay with the AI Act (June 2025) [60]	Medical-device software that uses AI	Device conformity assessment; where the AI is also high-risk under the AI Act, both regimes apply and the MDCG FAQ explains how they fit together	Technical documentation built once to serve both regimes; clinical or performance evaluation; post-market surveillance plan	3 · 5
FDA draft guidance on AI-enabled device software functions (January 2025; still draft on the FDA page) [61]	AI-enabled device software in a US marketing submission	Recommended documentation across the total product lifecycle to support the safety and effectiveness review	Model description; data management and validation report; labelling; post-market performance monitoring	3 · 5
US model risk management: SR 26-2 (2026-04-17), superseding SR 11-7 [62]	Models, including AI and ML, used by banking organisations; most relevant above USD 30B in assets	Risk-based model risk management tailored to the model risk profile	Model inventory entry; validation report; eval results as validation evidence; performance monitoring	2 · 3 · 5
PRA SS1/23 (effective 2024-05-17; revised version effective 2026-04-23) [63]	Models used by UK banks, building societies and PRA-designated investment firms with internal-model approval for regulatory capital	Five principles for a strategic approach to model risk, starting with model identification and model risk classification	Model inventory with tiering; validation record; model-risk mitigants log	2 · 3 · 5
ECOA and Regulation B; FCRA adverse-action notices [64]	A credit decision made or supported by a complex algorithm	Specific principal reasons for adverse action under 12 CFR 1002.9; the CFPB's Circular 2022-03 saying complexity is no excuse was withdrawn on 12 May 2025, and the Regulation B duty stands [71]. FCRA notices apply where a consumer report is used (verify scope per product)	Reason-code generator logged with each decision; notice template; eval that reasons are faithful to the model	3 · 4 · 5
Platform Work Directive, Dir. (EU) 2024/2831 (transposition by 2 Dec 2026, Art. 29(1)) [65][70]	Digital labour platforms using automated monitoring or decision-making	Transparency of automated systems; monitoring by qualified staff; a right to contest automated decisions	Algorithmic-management register; worker-facing information; human-review queue with decision log; DPIA	2 · 4 · 5
Minors and online safety: DSA Art. 28 guidelines (2025-07-14); UK Online Safety Act children's duties; companion-chatbot laws [66][67][24][27][35]	Services likely to be used by children, including AI chat and companions	Proportionate protection measures; children's risk assessment; reminders and crisis referral	Age-assurance signal; minors' mode configuration; children's risk assessment; reminder and referral logs	1 · 4 · 5

Two of these rows changed recently enough to trip a team that last looked in 2025. The US banking agencies replaced SR 11-7, the reference text of "model risk management" for fifteen years, with SR 26-2 on 17 Apr 2026 [62]; references to "SR 11-7" in model-governance policies should now point to the revised guidance. And the Cyber Resilience Act's reporting duties started on 11 Sep 2026 [57].

Incident clocks across regimes

One AI incident can start several clocks at once. The [Incident Pipeline](#) pattern should hold each clock as data, keyed to the regime and the trigger, so that one triage decision fans out to every report that is due. Chapter 17 treats [incident response](#) in full.

Regime	Trigger	Clock	Recipient
NIS2 [56]	Significant incident	24 h early warning; 72 h notification; final report within one month	CSIRT or competent authority
Cyber Resilience Act [58]	Actively exploited vulnerability or severe incident	24 h early warning; 72 h notification; final report 14 days after a fix (vulnerabilities) or one month (incidents)	Single reporting platform

Regime	Trigger	Clock	Recipient
DORA [55]	Major ICT-related incident	Initial notification within 4 h of classifying the incident as major and no later than 24 h from awareness; intermediate report within 72 h of the initial notification; final report within one month of the latest intermediate report (Delegated Regulation (EU) 2025/301, Art. 5) [69]	Competent financial authority
California SB 53 [19]	Critical safety incident	15 days; 24 h if death or serious injury is imminent	Office of Emergency Services; appropriate authority for the 24-hour case
New York RAISE [25] [26]	Critical safety incident	72 h; 24 h if death or serious physical injury is imminent	Oversight office within the Department of Financial Services; law enforcement or public safety agency for the 24-hour case
Korea AI Basic Act [1]	Safety duties for high-compute systems	No fixed clock; results of the safety measures submitted to MSIT	MSIT
EU AI Act Art. 73	Serious incident (high-risk)	See the clock table in chapter 08	Market-surveillance authority

In practice (illustrative) A payments company ran a fraud-scoring model inside a platform that was an ICT service under DORA, an important entity under NIS2 and, through its point-of-sale devices, a CRA product. When a prompt-injection path in its support agent exposed card data, the incident pipeline opened one ticket and three regulator-facing reports from the same timeline, each with its own clock and template. What made it work was not the model: it was a registry that already tagged the agent with all three regimes, and an evidence store that let each report cite the same signed logs.

What you can do this week

1. **Add a jurisdiction block to every registry entry.** List where each system is offered, and for each place record the status value (binding-horizontal, binding-targeted, voluntary, bill), the classification verdict and the notice template in force. Start with Korea's high-impact test and Colorado's consequential-decision test; they cover most hiring and lending systems.
2. **Check the Korean domestic-representative thresholds.** Pull last year's revenue from AI services and the three-month daily-user average for Korea; if either crosses the decree line, designate a representative and give it a read-only evidence view before the guidance period ends.
3. **Turn incident clocks into data.** Put NIS2, CRA, DORA, SB 53, RAISE and AI Act Article 73 clocks in one table keyed by trigger, and make the incident pipeline read it. Test it with a tabletop incident that hits two regimes.
4. **Replace "SR 11-7" in your model-governance policy.** Point it at SR 26-2 and re-tier your model inventory against the revised, risk-based guidance.
5. **Make the model card answer the Texas questions.** Purpose, training-data types, input and output categories, performance metrics, known limits and post-deployment monitoring: the eight items the Texas Attorney General may demand are a good minimum for any model card.

Maps to: Korea AI Basic Act Arts. 2, 4, 31–36, 40, 43 and Enforcement Decree Arts. 23–29 · OMB M-25-21 §4 and M-26-04 · EO 14365 · Colorado SB 26-189 · Texas HB 149 · California SB 53, SB 942 and AB 853, AB 1013, SB 243 and the CPPA ADMT regulations · New York RAISE and GBL Art. 47 · Utah AI Policy Act · Illinois HB 3773 · NYC Local Law 144 · Japan Act No. 53 of 2025 · CAC anthropomorphic interaction measures · Canada Directive on Automated Decision-Making · Italy Law 132/2025 · Singapore Model AI Governance Frameworks and AI Verify · DORA · NIS2 · Cyber Resilience Act · Data Act · MDR and IVDR · SR 26-2 · PRA SS1/23 · Regulation B · Platform Work Directive · DSA Art. 28 · all five stack layers ([Govern-as-Code](#) to [Assurance & Continuous Compliance](#)). Mappings are illustrative, not a claim of conformity.

Sources

[1] Basic Act on the Development of Artificial Intelligence and the Establishment of a Foundation for Trust (인공지능 발전과 신뢰 기반 조성 등에 관한 기본법; Act No. 20676, promulgated 2025-01-21, in force 2026-01-22; as amended by Act No. 21311 of 2026-01-20, in force 2026-01-22 and, for Arts. 3(5), 16(3)–(5), 17-2, 18, 22-3 and the second sentence of 35(1), 2026-07-21; Arts. 2(4) high-impact areas, 2(7) operators, 4 scope, 31 transparency, 32 safety, 33 confirmation, 34 high-impact duties, 35 impact assessment, 36 domestic representative, 40 fact-finding, 43 fines up to KRW 30M; version in force 2026-07-21). Korean Law Information Center (MOLEG). 2026-07-21. <https://www.law.go.kr/LSW/IsInfoP.do?IsiSeq=282791&efYd=20260721> (verified: primary) [2] Enforcement Decree of the AI Basic Act (Presidential Decree No. 36053, promulgated 2026-01-21, in force 2026-01-22; as amended by Presidential Decree No. 36506 of 2026-07-20, in force 2026-07-21, and No. 36580, in force 2026-08-20; Art. 1-2 AI-vulnerable groups, Art. 15(4) confirmation of AI products for public procurement, Art. 23 notice and labelling methods, Art. 24 10[^]26 FLOP and two further criteria, Art. 25 confirmation procedure and 30-day reply, Art. 27 publication and five-year retention,

Art. 28 impact-assessment content, Art. 29 domestic-representative thresholds; version in force 2026-08-20). Korean Law Information Center (MOLEG). 2026-08-18. <https://www.law.go.kr/LSW/lsInfoP.do?lsiSeq=288781&efYd=20260820> (verified: primary) [3] "AI Basic Act Update: Enforcement and Key Implications" (MSIT guidance period of at least one year for fact-finding and fines; exceptions for loss of life or human-rights violations; AI Basic Act help desk). Shin & Kim. 2026-02-11. <https://www.shinkim.com/eng/media/newsletter/3117> (verified: secondary) [4] "AI기본법 시행령 7월 시행, 공공조달 AI 확인 제도 핵심 정리" (decree amendment in force 2026-07-21: public-procurement AI confirmation system, liability exemption for adopting officials, AI-vulnerable groups widened to job seekers and women with career breaks, support measures). Korea Data Economy News (한국데이터경제신문). 2026-07-20. <https://www.dataeconomy.co.kr/news/articleView.html?idxno=41346> (verified: secondary) [5] Executive Order 14179, Removing Barriers to American Leadership in Artificial Intelligence (signed 2025-01-23; review of actions taken under the revoked EO 14110; AI action plan within 180 days). Federal Register, Vol. 90, No. 20 (via GovInfo). 2025-01-31. <https://www.govinfo.gov/content/pkg/FR-2025-01-31/html/2025-02172.htm> (verified: primary) [6] OMB Memorandum M-25-21, Accelerating Federal Use of AI through Innovation, Governance, and Public Trust (rescinds M-24-10; high-impact AI definition; minimum practices §4(b); 365 days to document). Office of Management and Budget. 2025-04-03. <https://www.whitehouse.gov/wp-content/uploads/2025/02/M-25-21-Accelerating-Federal-Use-of-AI-through-Innovation-Governance-and-Public-Trust.pdf> (verified: primary) [7] "White House Releases New Policies on Federal Agency AI Use and Procurement" (M-25-21 and M-25-22, Driving Efficient Acquisition of Artificial Intelligence in Government). The White House. 2025-04-07. <https://www.whitehouse.gov/releases/2025/04/white-house-releases-new-policies-on-federal-agency-ai-use-and-procurement/> (verified: primary) [8] OMB Memorandum M-26-04, Increasing Public Trust in Artificial Intelligence Through Unbiased AI Principles (implements EO 14319 of 2025-07-23; policies updated by 2026-03-11; minimum LLM transparency: acceptable use policy, model/system/data cards, end-user resources, feedback mechanism). Office of Management and Budget. 2025-12-11. <https://www.whitehouse.gov/wp-content/uploads/2025/12/M-26-04-Increasing-Public-Trust-in-Artificial-Intelligence-Through-Unbiased-AI-Principles-1.pdf> (verified: primary) [9] Winning the Race: America's AI Action Plan (three pillars; funding and state AI regulatory climate; FCC evaluation; NIST AI RMF revision). The White House. 2025-07. <https://www.whitehouse.gov/wp-content/uploads/2025/07/Americas-AI-Action-Plan.pdf> (verified: primary) [10] Executive Order 14365, Ensuring a National Policy Framework for Artificial Intelligence (signed 2025-12-11; §3 AI Litigation Task Force in 30 days; §4 Commerce evaluation in 90 days; §5 BEAD and grant conditions; §6 FCC; §7 FTC policy statement; §8 legislative recommendation and carve-outs). Federal Register, Vol. 90, No. 239 (via GovInfo). 2025-12-16. <https://www.govinfo.gov/content/pkg/FR-2025-12-16/html/2025-23092.htm> (verified: primary) [11] National Policy Framework for Artificial Intelligence: Legislative Recommendations (non-binding; preempt unduly burdensome state AI laws; keep generally applicable child-protection, anti-fraud and consumer laws). The White House. 2026-03-20. <https://www.whitehouse.gov/wp-content/uploads/2026/03/03.20.26-National-Policy-Framework-for-Artificial-Intelligence-Legislative-Recommendations.pdf> (verified: primary) [12] "Navigating the Emerging Federal-State AI Showdown: DOJ Establishes AI Litigation Task Force" (task force announced by the Attorney General on 2026-01-09). BakerHostetler. 2026-01-20. <https://www.bakerlaw.com/insights/navigating-the-emerging-federal-state-ai-showdown-doj-establishes-ai-litigation-task-force/> (verified: secondary) [13] "FTC Seeks Public Comment on Policy Statement Addressing AI Accuracy" (proposed Section 5 policy statement; Colorado AI Act discussed as possibly impliedly preempted; comments to 2026-07-31). Federal Trade Commission. 2026-07-01. <https://www.ftc.gov/news-events/news/press-releases/2026/07/ftc-seeks-public-comment-policy-statement-addressing-ai-accuracy> (verified: primary) [14] "Lawmakers propose AI framework that would preempt state laws for 3 years" (Obernolte and Trahan discussion draft, Great American Artificial Intelligence Act of 2026). Nextgov/FCW. 2026-06-04. <https://www.nextgov.com/artificial-intelligence/2026/06/lawmakers-propose-ai-framework-would-preempt-state-laws-3-years/413975/> (verified: secondary) [15] SB26-189, Automated Decision-Making Technology (repeals and re-enacts SB 24-205; signed 2026-05-14; effective 2027-01-01; developer documentation, deployer notice, 30-day explanation, human review, three-year records; Attorney General enforcement with 60-day cure). Colorado General Assembly. 2026-05-14. <https://leg.colorado.gov/bills/sb26-189> (verified: primary) [16] "Colorado AI law in flux: comprehensive replacement bill signed after federal court blocks predecessor's enforcement" (SB 24-205 delayed to 2026-06-30, then replaced by SB 26-189; xAI suit filed 2026-04-09; DOJ companion complaint 2026-04-24; stipulated order of 2026-04-27 pausing enforcement). McDermott Will & Emery. 2026-05-27. <https://www.mcdermottlaw.com/insights/colorado-ai-law-in-flux-comprehensive-replacement-bill-signed-after-federal-court-blocks-predecessors-enforcement/> (verified: secondary) [17] "DOJ Intervenes in Lawsuit Challenging Colorado's 'Algorithmic Discrimination' Law" (developer suit filed 2026-04-09 in the District of Colorado; DOJ complaint on Equal Protection grounds). Barnes & Thornburg. 2026-05-01. <https://btlaw.com/en/insights/alerts/2026/doj-intervenes-in-lawsuit-challenging-colorados-algorithmic-discrimination-law> (verified: secondary) [18] Texas Responsible Artificial Intelligence Governance Act (HB 149, enrolled; effective 2026-01-01; §552.051 disclosure, §§552.052–552.057 prohibitions, §552.101 no private right of action, §552.103 civil investigative demand items, §552.104 60-day cure, §552.105 penalties, 36-month sandbox). Texas Legislature (89R). 2025. <https://capitol.texas.gov/tlodocs/89R/billtext/pdf/HB00149F.pdf> (verified: primary) [19] SB-53, Artificial intelligence models: large developers (Transparency in Frontier Artificial Intelligence Act; chaptered 2025-09-29, Chapter 138; 10²⁶ operations; USD 500M revenue; frontier AI framework; transparency report; incident reports to OES in 15 days or 24 hours; up to USD 1M per violation; a regular-session statute, in force from 1 Jan 2026 under Cal. Const. art. IV, §8(c)(1)). California Legislative Information. 2025-09-29. https://leginfo.legislature.ca.gov/faces/billNavClient.xhtml?bill_id=202520260SB53 (verified: primary) [20] "California's SB 53: the first frontier AI law explained" (frontier developers: trained a foundation model with more than 10²⁶ operations; large frontier developers: also more than USD 500M in annual gross revenue; transparency reports by all frontier developers). Future of Privacy Forum. 2025-10-03. <https://fpf.org/blog/californias-sb-53-the-first-frontier-ai-law-explained/> (verified: secondary) [21] AB-853, California AI Transparency Act (amends SB 942; chaptered 2025-10-13, Chapter 674; operative 2026-08-02; platform duties 2027-01-01; capture devices 2028-01-01; s. 22757.4 civil penalty USD 5,000 per violation, each day a discrete violation). California Legislative Information. 2025-10-13. https://leginfo.legislature.ca.gov/faces/billNavClient.xhtml?bill_id=202520260AB853 (verified: primary)

primary) [22] AB-2013, Generative artificial intelligence: training data transparency (chaptered 2024-09-28, Chapter 817; documentation on or before 2026-01-01 for systems released since 2022-01-01; exemptions). California Legislative Information. 2024-09-28. https://leginfo.legislature.ca.gov/faces/billNavClient.xhtml?bill_id=202320240AB2013 (verified: primary) [23] "California Finalizes Regulations to Strengthen Consumers' Privacy" (ADMT, risk-assessment and cybersecurity-audit regulations approved 2025-09-23; effective 2026-01-01; ADMT from 2027-01-01; attestations from 2028-04-01). California Privacy Protection Agency. 2025-09-23. <https://cppa.ca.gov/announcements/2025/20250923.html> (verified: primary) [24] SB-243, Companion chatbots (chaptered 2025-10-13, Chapter 677; AI disclosure; three-hour reminders for known minors; self-harm protocol; reports from 2027-07-01; private right of action, at least USD 1,000 per violation). California Legislative Information. 2025-10-13. https://leginfo.legislature.ca.gov/faces/billNavClient.xhtml?bill_id=202520260SB243 (verified: primary) [25] NY State Senate Bill 2025-S6953B (RAISE Act as signed 2025-12-19: frontier models above 10^{26} operations costing over USD 100M; safety protocols; 72-hour incident disclosure; thresholds and the reporting recipient superseded by the chapter amendment signed 2026-03-27, which uses 10^{26} operations, USD 500M revenue for large frontier developers and a DFS office, see [26]). New York State Senate. 2025-12-19. <https://www.nysenate.gov/legislation/bills/2025/S6953/amendment/B> (verified: primary) [26] "New York Finalizes RAISE Act for Frontier AI Models; Law Takes Effect January 1, 2027" (chapter amendment S8828 signed 2026-03-27; SB 53's thresholds: frontier model above 10^{26} operations, large frontier developer above USD 500M annual revenue; all frontier developers report critical safety incidents within 72 hours to a new DFS office, or within 24 hours to law enforcement or public safety agencies on imminent risk). Wiley. 2026-04-03. <https://www.wiley.law/alert-New-York-Finalizes-RAISE-Act-for-Frontier-AI-Models-Law-Takes-Effect-January-1-2027> (verified: secondary) [27] New York General Business Law Article 47, Artificial Intelligence Companion Models (§1701 self-harm protocol; §1702 notice at start and every three hours; §1703 Attorney General, up to USD 15,000 per day). New York State Senate. 2026. <https://www.nysenate.gov/legislation/laws/GBS/A47> (verified: primary) [28] S.B. 226, Artificial Intelligence Consumer Protection Amendments, enrolled copy (disclosure on clear request; high-risk AI interaction; regulated occupations; safe harbour; effective 2025-05-07; AI Policy Act repeal date 2027-07-01). Utah State Legislature. 2025. <https://le.utah.gov/Session/2025/bills/enrolled/SB0226.pdf> (verified: primary) [29] "Illinois Adopts New AI-in-Employment Regulations: What Employers Need to Know for 2026" (HB 3773 effective 2026-01-01; notice duty; IDHR draft rules; Human Rights Act remedies). Hinshaw & Culbertson. 2026. <https://www.hinshawlaw.com/en/insights/blogs/employment-law-observer/illinois-adopts-new-ai-in-employment-regulations-what-employers-need-to-know-for-2026> (verified: secondary) [30] Automated Employment Decision Tools (Local Law 144 of 2021; bias audit within one year; public summary; notices; enforcement from 2023-07-05). NYC Department of Consumer and Worker Protection. 2023. <https://www.nyc.gov/site/dca/about/automated-employment-decision-tools.page> (verified: primary) [31] Act on the Promotion of Research, Development and Utilisation of AI-Related Technologies (人工知能関連技術の研究開発及び活用の推進に関する法律; Act No. 53 of 2025, promulgated 2025-06-04; Arts. 7, 13, 16, 18; no penalties). e-Gov Law Search (Digital Agency). 2025-06-04. <https://laws.e-gov.go.jp/law/507AC0000000053> (verified: primary) [32] AI Act page (promulgated and partly in force 2025-06-04; fully in force 2025-09-01). Cabinet Office of Japan. 2025. https://www8.cao.go.jp/cstp/ai/ai_act/ai_act.html (verified: primary) [33] AI Basic Plan (Cabinet decisions of 2025-12-23 and 2026-07-14). Cabinet Office of Japan. 2026-07-14. https://www8.cao.go.jp/cstp/ai/ai_plan/ai_plan.html (verified: primary) [34] Guidelines on ensuring the appropriateness of research, development and use of AI-related technologies (AI Strategy Headquarters decision of 2025-12-19). Cabinet Office of Japan. 2025-12-19. https://www8.cao.go.jp/cstp/ai/ai_guideline/ai_guideline.html (verified: primary) [35] Interim Measures for the Administration of Anthropomorphic Interaction Services (人工智能拟人化互动服务管理暂行办法; CAC, NDRC, MIIT, MPS and SAMR; Art. 2 scope; Art. 14 minors; Art. 18 labelling and two-hour reminder; Art. 19 exit; Art. 22 security assessment incl. 1M registered or 100k monthly active users; Art. 26 filing; in force 2026-07-15). Cyberspace Administration of China. 2026-04-10. https://www.cac.gov.cn/2026-04/10/c_1777558395078289.htm (verified: primary) [36] PL 2338/2023, Marco Legal da Inteligência Artificial (introduced 2023-05-03; approved by the Senate plenary 2024-12-10; sent to the Chamber of Deputies). Federal Senate of Brazil. 2025-03-17. <https://www25.senado.leg.br/web/atividade/materias/-/materia/157233> (verified: primary) [37] PL 2338/2023 in the Chamber of Deputies (received 2025-03-17; special committee created 2025-04-04; priority regime; awaiting report as of the 2026-09-02 entry). Câmara dos Deputados. 2026-09-02. <https://www.camara.leg.br/proposicoesWeb/fichadetramitacao?idProposicao=2487262> (verified: primary) [38] C-27 (44-1), Digital Charter Implementation Act, 2022 (enacting the Artificial Intelligence and Data Act; session ended 2025-01-06). LEGISinfo, Parliament of Canada. 2025. <https://www.parl.ca/legisinfo/en/bill/44-1/c-27> (verified: primary) [39] Directive on Automated Decision-Making (effective 2019-04-01; modified 2025-06-24; existing systems to comply by 2026-06-24; AIA, Appendix C impact levels, notice, explanation, peer review, GBA Plus, recourse, reporting). Treasury Board of Canada Secretariat. 2025-06-24. <https://www.tbs-sct.canada.ca/pol/doc-eng.aspx?id=32592> (verified: primary) [40] "MeitY Unveils India AI Governance Guidelines under IndiaAI Mission" (seven sutras, six pillars, action plan; existing legislation wherever possible). Press Information Bureau, Government of India. 2025-11-05. <https://www.pib.gov.in/PressReleasePage.aspx?PRID=2186639> (verified: primary) [41] A pro-innovation approach to AI regulation: government response (CP 1019; five cross-sector principles applied by existing regulators). Department for Science, Innovation and Technology. 2024-02-06. <https://www.gov.uk/government/consultations/ai-regulation-a-pro-innovation-approach-policy-proposals/outcome/a-pro-innovation-approach-to-ai-regulation-government-response> (verified: primary) [42] "AI Security Institute" (written statement announcing the rename of the AI Safety Institute). UK Parliament. 2025-02-24. <https://questions-statements.parliament.uk/written-statements/detail/2025-02-24/hlws454> (verified: primary) [43] Algorithmic Transparency Recording Standard Hub (mandatory for government departments and for arm's-length bodies delivering public or frontline services). Government Digital Service. 2025-05-08. <https://www.gov.uk/government/collections/algorithmic-transparency-recording-standard-hub> (verified: primary) [44] AI Cyber Security Code of Practice (code and implementation guide). Department for Science, Innovation and Technology. 2025-01-31. <https://www.gov.uk/government/publications/ai-cyber-security-code-of-practice> (verified: primary) [45] Data (Use and Access) Act 2025, s. 80 (replaces UK GDPR Art. 22 with Arts. 22A–22D; in force 2026-

02-05). <https://www.legislation.gov.uk/ukpga/2025/18/section/80> (verified: primary) [46] Legge 23 settembre 2025, n. 132, Disposizioni e deleghe al Governo in materia di intelligenza artificiale (GU Serie Generale n. 223 of 2025-09-25; in force 2025-10-10; Arts. 1(2), 4(4), 11(2), 13, 20, 26; consolidated text last updated 2026-06-26). Gazzetta Ufficiale / Normattiva. 2025-09-25. <https://www.gazzettaufficiale.it/eli/id/2025/09/25/25G00143/sg> (verified: primary) [47] Referencia del Consejo de Ministros, 11 March 2025 (Anteproyecto de Ley para el buen uso y la gobernanza de la Inteligencia Artificial, first reading, urgent processing; sanctions, deepfake labelling, provisional withdrawal, authorities; sandbox call for up to 12 systems). La Moncloa. 2025-03-11. <https://www.lamoncloa.gob.es/consejodeminstros/referencias/paginas/2025/20250311-referencia-rueda-de-prensa-ministros.aspx> (verified: primary) [48] Real Decreto 817/2023, de 8 de noviembre, entorno controlado de pruebas (AI regulatory sandbox). Boletín Oficial del Estado. 2023-11-09. <https://www.boe.es/eli/es/rd/2023/11/08/817> (verified: primary) [49] Guías (16 guides from the Spanish AI regulatory sandbox pilot; non-binding; the page still says they will be updated once the digital Omnibus is approved, as of 2026-09-24). AESIA. 2026. <https://aesia.digital.gob.es/es/guias> (verified: primary) [50] "Singapore Launches New Model AI Governance Framework for Agentic AI" (launched at Davos). IMDA. 2026-01-22. <https://www.imda.gov.sg/resources/press-releases-factsheets-and-speeches/press-releases/2026/new-model-ai-governance-framework-for-agentic-ai> (verified: primary) [51] Model AI Governance Framework for Agentic AI, version 1.5 (published 2026-05-20, updated 2026-06-05; four dimensions). IMDA. 2026-06-05. <https://www.imda.gov.sg/-/media/imda/files/about/emerging-tech-and-research/artificial-intelligence/mgf-for-agentic-ai.pdf> (verified: primary) [52] Model AI Governance Framework for Generative AI (voluntary). IMDA / AI Verify Foundation. 2024-05. <https://aiverifyfoundation.sg/wp-content/uploads/2024/05/Model-AI-Governance-Framework-for-Generative-AI-May-2024-1-1.pdf> (verified: primary) [53] AI Verify Testing Framework (11 internationally recognised AI governance principles; generative-AI update). AI Verify Foundation. 2026. <https://aiverifyfoundation.sg/what-is-ai-verify/> (verified: primary) [54] National AI Plan, "Keep Australians safe" (existing technology-neutral frameworks; AI Safety Institute; six essential practices of the Guidance for AI Adoption; published December 2025; opened via the Internet Archive). Department of Industry, Science and Resources. 2025-12. <https://www.industry.gov.au/publications/national-ai-plan/keep-australians-safe> (verified: primary) [55] Digital Operational Resilience Act (DORA) (entered into force 2023-01-16; applies from 2025-01-17; ICT and ICT third-party risk; reporting of major ICT-related incidents). European Securities and Markets Authority. 2025. <https://www.esma.europa.eu/esmas-activities/digital-finance-and-innovation/digital-operational-resilience-act-dora> (verified: primary) [56] NIS2 Directive: questions and answers (transposition by 2024-10-17; early warning 24 hours, notification 72 hours, final report within one month). European Commission. 2024. <https://digital-strategy.ec.europa.eu/en/faqs/directive-measures-high-common-level-cybersecurity-across-union-nis2-directive-faqs> (verified: primary) [57] Cyber Resilience Act (in force 2024-12-10; reporting obligations from 2026-09-11; main obligations from 2027-12-11; guidance of 2026-07-27). European Commission. 2026. <https://digital-strategy.ec.europa.eu/en/policies/cyber-resilience-act> (verified: primary) [58] Cyber Resilience Act: reporting obligations (24-hour early warning, 72-hour notification, final report 14 days after a corrective measure or one month for severe incidents; single reporting platform). European Commission. 2026. <https://digital-strategy.ec.europa.eu/en/policies/cra-reporting> (verified: primary) [59] Data Act (in force 2024-01-11; applies from 2025-09-12; access to data from connected products; switching between cloud providers). European Commission. 2025. <https://digital-strategy.ec.europa.eu/en/policies/data-act> (verified: primary) [60] MDCG 2025-6, FAQ on interplay between the MDR and IVDR and the Artificial Intelligence Act (how the device regulations and the AI Act apply together; listed on the Commission's MDCG guidance page). Medical Device Coordination Group (European Commission). 2025-06. https://health.ec.europa.eu/document/download/b78a17d7-e3cd-4943-851d-e02a2f22bbb4_en?filename=mdcg_2025-6_en.pdf (verified: primary) [61] Artificial Intelligence-Enabled Device Software Functions: Lifecycle Management and Marketing Submission Recommendations (draft guidance; docket FDA-2024-D-4488). US Food and Drug Administration. 2025-01-07. <https://www.fda.gov/regulatory-information/search-fda-guidance-documents/artificial-intelligence-enabled-device-software-functions-lifecycle-management-and-marketing> (verified: primary) [62] SR 26-2, Revised Guidance on Model Risk Management (Federal Reserve, OCC and FDIC; supersedes SR 11-7 of 2011-04-04 and SR 21-8; most relevant above USD 30B in total assets). Board of Governors of the Federal Reserve System. 2026-04-17. <https://www.federalreserve.gov/supervisionreg/srletters/SR2602.htm> (verified: primary) [63] SS1/23, Model risk management principles for banks (published 2023-05-17; effective 2024-05-17; revised version effective 2026-04-23; scope: banks, building societies and PRA-designated investment firms with internal-model approval; five principles). Prudential Regulation Authority (Bank of England). 2026-04. <https://www.bankofengland.co.uk/prudential-regulation/publication/2023/may/model-risk-management-principles-for-banks-ss> (verified: primary) [64] Consumer Financial Protection Circular 2022-03, Adverse action notification requirements in connection with credit decisions based on complex algorithms (ECOA and Regulation B; withdrawn by the CFPB on 2025-05-12, 90 FR 20084, FR Doc. 2025-08286, item 14, although the page shows no withdrawal banner as of 2026-09-24). Consumer Financial Protection Bureau. 2022-05-26. <https://www.consumerfinance.gov/compliance/circulars/circular-2022-03-adverse-action-notification-requirements-in-connection-with-credit-decisions-based-on-complex-algorithms/> (verified: primary) [65] "Platform workers: Council adopts new rules to improve their working conditions" (algorithmic management transparency; monitoring by qualified staff; right to contest; two years to transpose). Council of the European Union. 2024-10-14. <https://www.consilium.europa.eu/en/press/press-releases/2024/10/14/platform-workers-council-adopts-new-rules-to-improve-their-working-conditions/> (verified: primary) [66] "Commission publishes guidelines on the protection of minors" (DSA Art. 28 guidelines). European Commission. 2025-07-14. <https://digital-strategy.ec.europa.eu/en/library/commission-publishes-guidelines-protection-minors> (verified: primary) [67] Online Safety Act: explainer (children's risk assessments due 2025-07-24; child-safety regime in effect from summer 2025). Department for Science, Innovation and Technology. 2025-04-24. <https://www.gov.uk/government/publications/online-safety-act-explainer/online-safety-act-explainer> (verified: primary) [68] "AI Omnibus enters into force" (Reg. (EU) 2026/1744, in force 27 Jul 2026; Annex III high-risk obligations from 2 Dec 2027). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force> (verified: primary) [69]

Commission Delegated Regulation (EU) 2025/301, RTS on the content and time limits for major ICT-related incident reports under DORA (Art. 5: initial notification within 4 hours of classification and 24 hours of awareness; intermediate within 72 hours; final within one month). Publications Office of the EU (EUR-Lex). 2024-10-23. https://eur-lex.europa.eu/eli/reg_del/2025/301/oj/eng (verified: primary) [70] Directive (EU) 2024/2831 on improving working conditions in platform work (Art. 29(1): transposition by 2 Dec 2026). Official Journal of the EU. 2024-10-23. <https://eur-lex.europa.eu/eli/dir/2024/2831/oj/eng> (verified: primary) [71] Withdrawn guidance (Circular 2022-03 on adverse-action notices for credit decisions based on complex algorithms, 87 FR 35864, withdrawn on 12 May 2025 by the notice at 90 FR 20084). Consumer Financial Protection Bureau. 2025-05-12. <https://www.consumerfinance.gov/compliance/guidance/withdrawn-guidance/> (verified: primary)

22. Principles, soft law and standards

Principles say what good looks like and standards say how to show it; this chapter maps each instrument to the stack layer and the evidence record that answer it.

How to read this chapter

Most of what shapes AI governance is not law. It is a lattice of principle sets, a treaty, voluntary frameworks and technical standards, each written by a different body for a different audience. The engineer's job is not to recite them. It is to know, for each one, what it asks for, how much force it carries, and which artefact in the stack would evidence that the ask is met. A principle only counts once it is a control; a standard only helps once its clauses are wired to a gate, a registry field or an evidence record.

In rough order of force: binding law (the AI Act, in [chapter 08](#) and [chapter 18](#)); a binding treaty, the Council of Europe Framework Convention, which binds the Parties that ratify it and leaves each to choose how to reach private actors [1]; **harmonised standards**, European standards written on a Commission request that give a presumption of conformity once their reference is published in the Official Journal [2]; international standards and frameworks (ISO/IEC, NIST, IEEE), voluntary and sometimes certifiable; and principles and soft law (OECD, UNESCO, G7, the EU High-Level Expert Group), which set the target and the shared vocabulary.

Two cautions run through the chapter. Standards support, they do not confer: no certificate and no coverage figure makes a system compliant, and the test from [chapter 01](#) still applies. And this chapter explains the instruments while [chapter 08](#) stays the obligations index; where an instrument already has rows there, this chapter links to them. Principle sets are the home ground of Responsible AI and AI ethics ([chapter 01](#)): they set the values. The tables of artefacts and layers below are the engineering contribution, not a claim about what the principles' authors intended.

The instruments at a glance

Instrument	Issuer	Force	What it changes in the stack	Main layers
OECD AI Principles (2019, rev. 2024)	OECD	Political commitment by 47 adherents	Shared definition, lifecycle and classification fields for the registry	1 · 2
UNESCO Recommendation (2021)	UNESCO	Non-binding, adopted by 193 Member States	Ethical impact assessment as a registry-linked record	2
Framework Convention (CETS No. 225)	Council of Europe	Binding on Parties once in force; not in force as of 2026-09-24	Risk and impact management, testing on change, contestability records	1 · 2 · 3 · 5
Hiroshima Code of Conduct (2023)	G7	Voluntary; OECD reporting framework	Public capability reporting, incident sharing, provenance	2 · 4 · 5
Ethics Guidelines and ALTAI (2019, 2020)	EU AI HLEG	Non-binding; recalled in AI Act recital 27	Seven requirements as a checklist to convert into controls	1 · 2
NIST AI RMF 1.0 and profiles	NIST	Voluntary	Function, category and subcategory ids as control metadata	1–5
ISO/IEC 22989, 42001 and family	ISO/IEC JTC 1/SC 42	Voluntary; 42001 certifiable	Management-system evidence; vocabulary; lifecycle processes	1 · 2 · 5
JTC 21 harmonised standards	CEN-CENELEC	Presumption of conformity once OJ-cited; none cited as far as we can find	Provider risk file, logging schema, QMS evidence	1–5
IEEE 7000 series	IEEE	Voluntary	Ethics-by-design and bias processes in the SDLC	1 · 2 · 3

Sources for each row are in the section that treats it. The adherent and Member State counts come from [3] and [4]; the Convention's status from [5].

A short lineage of AI soft law

The instruments cite each other, and the order matters because definitions travel downstream. The EU High-Level Expert Group published its Ethics Guidelines on 8 April 2019 [6]. The OECD Council adopted its Recommendation on AI on 22 May 2019, and G20 leaders welcomed G20 AI Principles drawn from it at Osaka in June 2019 [7]. UNESCO's Member States adopted the Recommendation on the Ethics of AI in November 2021 [4]. The OECD published its Framework for the Classification of AI Systems on 22 February 2022 [8], and NIST's AI RMF 1.0 followed on 26 January 2023, adapting the OECD lifecycle and dimensions in its own Figure 2 [9]. G7 leaders agreed the Hiroshima Guiding Principles and Code of Conduct on 30 October 2023 [10]. The OECD revised its AI-system definition on 8 November 2023 and the whole Recommendation on 3 May 2024 [7]. The Council of Europe

adopted its Framework Convention on 17 May 2024 and opened it for signature on 5 September 2024 [11]. The OECD launched the Hiroshima reporting framework on 7 February 2025 [12], and the European Union ratified the Convention on 15 May 2026 [13]. The practical consequence is convergence on one definition. The OECD definition of an AI system, the Convention's Article 2 and the AI Act's Article 3(1) use near-identical wording, and the AI Act's recital 12 says the notion should be closely aligned with the work of international organisations [7][1][14]. A registry that classifies systems against that wording once can answer all three instruments; [chapter 11](#) treats the definition itself, and tabulates [where the principle sets agree](#).

OECD AI Principles

The OECD Recommendation on AI (legal instrument [OECD/LEGAL/0449](#)) was the first intergovernmental standard on AI. It contains five values-based principles for AI actors, five recommendations to governments, and definitions of AI system, AI system lifecycle and AI actors [7]. The 2024 revision added explicit attention to misinformation and information integrity, to uses outside the intended purpose, to safe override and decommissioning, and to environmental sustainability, and moved traceability and risk management under the accountability principle [7]. As of 2026-09-24, OECD.AI lists 47 adherents, including the 38 OECD members, the European Union and eight non-members [3].

The five principles and five recommendations

The principles address AI actors; the recommendations address governments. Only the first five become engineering work directly. The table reads each principle as a question the stack must answer.

Principle	What it asks of AI actors (paraphrased)	Engineering artefact	Layer
1.1 Inclusive growth, sustainable development and well-being	Pursue beneficial outcomes for people and planet	Intended-use and benefit statement in the intake record; named harms per system	2
1.2 Rule of law, human rights and democratic values, incl. fairness and privacy	Respect rights across the lifecycle; human agency and oversight; guard against misuse	Impact assessment linked to the registry; fairness and privacy evals; oversight checkpoint	2 · 3 · 4
1.3 Transparency and explainability	Meaningful, context-appropriate information about the system and its outputs	Model card and data card; interaction disclosure; explanation artefacts	2
1.4 Robustness, security and safety	Function under normal use, foreseeable misuse and adverse conditions; override, repair or decommission safely	Adversarial and robustness evals; kill switch; content provenance	3 · 4
1.5 Accountability	Traceability of datasets, processes and decisions; systematic risk management per lifecycle phase	Evidence store keyed to registry ids; risk register as code; supplier records	1 · 5

The five recommendations (research and development; an inclusive AI-enabling ecosystem; an interoperable governance and policy environment; human capacity and labour-market transformation; international co-operation) address Adherents, not system owners. Recommendation 2.5's call for "multi-stakeholder, consensus-driven global technical standards" is the policy root of the standards work later in this chapter [7].

Principle 1.4(b) is the most directly operational sentence in the instrument: mechanisms should let AI systems that risk undue harm be "overridden, repaired, and/or decommissioned safely" [7]. In stack terms that is the **Kill Switch / Circuit Breaker** pattern with a tested revocation path, and a decommissioning record in the registry. Principle 1.5(b)'s traceability "in relation to datasets, processes and decisions" is what **Continuous Assurance Telemetry** produces when every evidence record carries the registry id of the system it describes.

The OECD AI system definition and lifecycle

The 2023 definition reads: a machine-based system that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations or decisions that can influence physical or virtual environments; systems vary in autonomy and in adaptiveness after deployment [7]. OECD.AI notes that the European Union, the Council of Europe, the United States and the United Nations use this definition and lifecycle in their own frameworks [3].

The lifecycle has seven phases: plan and design; collect and process data; build or adapt models; test, evaluate, verify and validate; make available for use or deploy; operate and monitor; retire or decommission. The phases are iterative and not necessarily sequential, and retirement can happen at any point during operation [7]. That last clause is easy to miss and useful to encode: the registry needs a `retired` state reachable from `operating` , with its own evidence (who retired it, why, what data was deleted), not only a path from `built` to `deployed` .

OECD lifecycle phase	Where it lives in the pipeline	Evidence it should leave
Plan and design	Intake and classification	Intake record; risk tier; intended purpose
Collect and process data	Data pipeline	Data card; lineage; lawful-basis note
Build or adapt models	Training and fine-tuning jobs	AIBOM; training-run metadata

OECD lifecycle phase	Where it lives in the pipeline	Evidence it should leave
Test, evaluate, verify, validate	CI eval gate	Eval result against threshold
Make available or deploy	Admission and release	Policy verdict; registry entry
Operate and monitor	Runtime	Guardrail decisions; traces; drift alerts
Retire or decommission	Registry state change	Retirement record; revoked credentials

The Framework for the Classification of AI Systems

The OECD classification framework evaluates an AI system from a policy perspective along five dimensions: **People & Planet**, **Economic Context**, **Data & Input**, **AI Model** and **Task & Output**, each with its own properties and attributes [8]. NIST's AI RMF reproduces a modified version of the same picture, with Application Context in place of Economic Context and test, evaluation, verification and validation (TEVV) drawn across the lifecycle [9].

For an engineer the framework is a schema, not a paper. Each dimension becomes a group of registry fields that makes a system comparable with others and tells the rest of the stack what to test.

Example (illustrative) A registry entry extended with the five dimensions. The fields are the team's own choice; the grouping is the OECD's.

```
yaml id: credit-limit-assist oecd_classification: people_and_planet: { affected: [applicants], rights_impact: high,
opt_out: false } economic_context: { sector: consumer-credit, criticality: high, deployment: customer-facing }
data_and_input: { provenance: [bureau-feed, application-form], personal_data: true } ai_model: { type: gradient-
boosted-trees, adaptive_after_deployment: false } task_and_output: { task: recommendation, autonomy: human-reviewed,
output: limit-band }
```

A policy in layer 01 reads `rights_impact: high` and requires a fairness eval gate; the eval gate in layer 03 reads `personal_data: true` and adds a leakage suite. The classification stops being a description and starts routing controls.

The OECD.AI observatory

Three OECD.AI resources are worth wiring in. The **Catalogue of Tools & Metrics for Trustworthy AI** is a place to find eval methods and metrics, not an endorsement list [15]. The **AI Incidents and Hazards Monitor** [3] is an input to layer 03: a reported failure in a comparable system is a candidate eval case (see [chapter 17](#)). The **Hiroshima AI Reporting Framework** is where developers of advanced AI systems file risk-management reports [3] (see the G7 section).

In practice (illustrative) A governance team in a large insurer added the five OECD dimensions to its registry schema as required fields. The first reconciliation found several systems whose `task_and_output.autonomy` said "human-reviewed" while runtime traces showed no reviewer action on most decisions. The field did not create the gap; it made the gap queryable. The fix was an oversight checkpoint with logged approvals, and the registry field became a claim the traces could falsify.

UNESCO Recommendation on the Ethics of AI

UNESCO's 193 Member States adopted the Recommendation on the Ethics of Artificial Intelligence in November 2021, the first global standard on AI ethics [4]. It rests on four core values (human rights and dignity; just, peaceful and interconnected societies; diversity and inclusiveness; the flourishing of environment and ecosystems) and ten core principles: proportionality and do no harm; safety and security; privacy and data protection; multi-stakeholder and adaptive governance; responsibility and accountability; transparency and explainability; human oversight and determination; sustainability; awareness and literacy; fairness and non-discrimination [4]. Policy action areas then turn the values into government programmes.

The Recommendation addresses states, so its operational weight for an organisation comes through two tools. The **Readiness Assessment Methodology** (RAM) assesses how prepared a country is to govern AI responsibly [16]; it is useful context when deploying into a jurisdiction that has run one. The **Ethical Impact Assessment** (EIA) is system-level: it helps assess the ethical implications of an individual AI system before and during use, and is designed for governments procuring or deploying AI, companies developing it and researchers assessing it [17].

In the stack an EIA is one more impact assessment: attached to the registry entry, versioned and re-run on change, following **FRIA-as-Code**. A public buyer that requires one from suppliers makes it a procurement artefact for the **Vendor / Model Due-Diligence Gate**. "Proportionality and do no harm" restates the house principle [start from a named failure mode or a named harm](#) [4].

Council of Europe Framework Convention (CETS No. 225)

The Framework Convention on Artificial Intelligence and Human Rights, Democracy and the Rule of Law is the first international legally binding treaty on AI. It was adopted in Strasbourg on 17 May 2024 and opened for signature in Vilnius on 5 September 2024 [11]. It is technology-neutral and binds Parties, not companies [5][1].

Scope and status

Article 3 sets the scope. Parties must apply the Convention to lifecycle activities of AI systems undertaken by public authorities or private actors acting on their behalf. For other private actors, each Party must address risks and impacts in a manner consistent with the Convention's object and purpose, and must declare how it will do so. National security, national defence and research not yet made available for use are carved out, with conditions [1].

The Convention enters into force on the first day of the month following three months after five signatories, including at least three Council of Europe member states, have ratified it (Article 30(3)) [1]. **Status as of 2026-09-24:** the Council of Europe's own page lists the European Union as the only Party and 20 further signatories, among them the United Kingdom, Norway, Switzerland, Ukraine, Canada, Israel, Japan, the United States and Uruguay [5]. The Convention is therefore not yet in force. The European Parliament consented to the EU's conclusion on 11 March 2026 [18], and the EU ratified on 15 May 2026 at the Committee of Ministers' 135th Session in Chişinău [13]. The Council Decision concluding the Convention for the Union, Decision (EU) 2026/1080 of 21 April 2026 (OJ L, 13.5.2026), states that the Convention is implemented in the Union exclusively through the AI Act and other relevant Union acquis, and carries the EU's Article 3(1)(b) declaration that it will apply Chapters II to VI of the Convention to private actors through the AI Act [19].

Inside the EU, then, the treaty is implemented through the AI Act rather than through a separate set of private-sector duties. Outside it, once the Convention is in force, each Party's implementing measures are what bind; track them per jurisdiction in [chapter 21](#).

What the Convention asks for, and what it changes in the stack

Chapter III sets principles that Parties implement: human dignity and individual autonomy; transparency and oversight; accountability and responsibility; equality and non-discrimination; privacy and personal data protection; reliability; safe innovation, including controlled testing environments (Articles 7–13) [1]. Chapters IV and V are where the engineering lives.

Article	Duty on Parties (paraphrased)	Engineering artefact	Layer
Art. 14(2) (a)–(b)	Document relevant information about systems that can significantly affect human rights, sufficient for affected people to contest decisions	Decision record per consequential output; contest path with the record attached	2 · 5
Art. 14(2) (c)	An effective possibility to complain to competent authorities	Complaint intake linked to the registry id	5
Art. 15(2)	Notify people that they are interacting with an AI system, as appropriate	Interaction disclosure enforced at runtime	4
Art. 16(1)–(2) (a)–(f)	Iterative, graduated risk and impact management: context, severity and probability, stakeholder views, monitoring, documentation	Risk register as code; impact assessment linked to registry; monitoring against baseline	1 · 2 · 4
Art. 16(2) (g)	Test systems before first use and when significantly modified, where appropriate	Eval gate on release and on material change	3
Art. 16(4)	Assess the need for a moratorium, ban or other measures for incompatible uses	Policy-as-code blocklist of prohibited uses	1

Article 16(2)(g) deserves the emphasis. "When they are significantly modified" is a trigger, not a date, and a trigger is something a pipeline can evaluate: a registry diff that changes the model, the training data or the intended purpose re-runs the gate. That is the **Eval Gate in CI** pattern with the material-change rule written down, and it answers the same question the AI Act asks about substantial modification (see [chapter 18](#)).

The Council of Europe also published **HUDERIA**, a non-binding methodology for risk and impact assessment of AI systems from the point of view of human rights, democracy and the rule of law. It has two parts: the HUDERIA Methodology, approved by the Committee of Ministers on 26 February 2025, and the HUDERIA Model: Context-Based Risk Analysis (COBRA), approved on 25 February 2026, which structures the collection of information about a system's context, design and deployment [20]. Parties may use or adapt either. For a team that already runs FRIA-as-Code, COBRA's context questions are a field list to reconcile with the registry, not a second process.

Maps to: CETS No. 225 Arts. 14–16 · EU AI Act Art. 9, 27, 50 (via the EU's implementing choice) · layers 1–5. Mappings are illustrative, not a claim of conformity.

G7 Hiroshima Process

G7 leaders agreed two texts on 30 October 2023: the International Guiding Principles for Organizations Developing Advanced AI Systems and the International Code of Conduct built on them. The Code is voluntary, addressed to organisations developing the most advanced AI systems (including foundation models and generative AI), described as a non-exhaustive living document that builds on the OECD AI Principles, and to be followed in line with a risk-based approach [10]. Its 11 actions map onto the stack with little translation:

Action	Ask (paraphrased)	Engineering artefact	Layer
1	Identify, evaluate and mitigate risks across the lifecycle, including testing before deployment	Adversarial red-team suite; eval gate	3
2	Identify and mitigate vulnerabilities, incidents and misuse after deployment	Runtime monitoring; incident pipeline	4 · 5
3	Publicly report capabilities, limitations and appropriate and inappropriate uses	Model card published from the registry	2
4	Share information and report incidents responsibly with industry, governments, civil society, academia	Incident pipeline with an external-sharing branch	5
5	Develop, implement and disclose AI governance and risk-management policies	Policy-as-code library with a published summary	1
6	Invest in security controls, including physical, cyber and insider-threat safeguards	Security controls on weights and pipelines	4
7	Deploy content authentication and provenance mechanisms where feasible	Provenance marking at output; verification test	4
8	Prioritise research on societal, safety and security risks	(Programme-level; no direct artefact)	–
9	Prioritise systems that address global challenges	(Programme-level; no direct artefact)	–
10	Advance and adopt international technical standards	Standards watch; crosswalk maintenance	1
11	Implement data input measures and protect personal data and intellectual property	Data card; licence and provenance in the AIBOM	2

On 7 February 2025 the OECD launched a framework for companies to report comparably on how they apply the Code (risk assessment, incident reporting, information sharing). First reports were due by 15 April 2025, with rolling submissions and annual updates afterwards [12]. A report is a disclosure, not an audit; generated from the registry and the evidence store it stays true, written by hand it drifts. For developers of general-purpose AI models placed on the EU market, the binding counterpart is the AI Act's GPAI regime and its voluntary Code of Practice, indexed in [chapter 08](#).

EU HLEG guidelines and ALTAI

The Commission's independent High-Level Expert Group on AI presented its Ethics Guidelines for Trustworthy AI on 8 April 2019. Trustworthy AI, in the Guidelines, is lawful, ethical and robust, and seven key requirements make it concrete: human agency and oversight; technical robustness and safety; privacy and data governance; transparency; diversity, non-discrimination and fairness; societal and environmental well-being; accountability [6]. The Guidelines name three oversight approaches (human-in-the-loop, human-on-the-loop and human-in-command), which is still the most compact vocabulary for oversight design [6]; the **Human-in-the-loop Gate** pattern chooses among them by consequence.

The **Assessment List for Trustworthy AI** (ALTAI) followed on 17 July 2020, revised after a pilot with over 350 stakeholders and published both as a document and as a web-based self-assessment tool [21]. The AI Act's recital 27 recalls the seven principles as non-binding guidance that contributes to trustworthy, human-centric AI, without prejudice to the Act's binding requirements [14].

ALTAI's lasting lesson is a warning. A self-assessment questionnaire answered once is an attestation, and the book's third value says evidence comes from runtime, not from a point-in-time attestation ([value 3](#)). The useful move is to treat each question as a candidate control. The Guidelines ask for "safeguards that enable a fallback plan in case of problems" [6]; as a control that becomes "is there a tested kill switch, and when did the last test pass?". A question that cannot become a check with an evidence record goes to the review board, and the list is still worth keeping for that.

NIST AI RMF 1.0 in depth

The NIST AI Risk Management Framework 1.0 (NIST AI 100-1, 26 January 2023) describes itself as voluntary, rights-preserving, non-sector-specific and use-case agnostic [9]. Chapter 08 maps its four functions to artefacts ([chapter 08](#), [NIST AI RMF](#)); this section goes one level down, to what an engineer needs to use its identifiers as control metadata.

Harm, risk and tolerance

Part 1 frames risk as a function of the magnitude of harm and its likelihood, and groups potential harms into harm to people, harm to an organisation and harm to an ecosystem [9]. Two framing choices matter for engineering. The RMF can help prioritise risk but "does not prescribe risk tolerance": the threshold is the organisation's to set, influenced by law, policy and norms [9]. And it treats measurement as hard: risks that will not or cannot be measured must still be documented (MEASURE 1.1). Both push the same way as the house principle [give every control teeth](#): a threshold must be chosen, written down with its rationale and enforced, because the framework will not choose it for you.

The seven trustworthy characteristics

The RMF names seven characteristics of trustworthy AI and describes valid and reliable as the base for the others, with accountable and transparent spanning them all [9].

Characteristic	Evidence that it holds	Layer
Valid and reliable	Capability and regression evals against a golden set; drift monitoring	3 · 4
Safe	Safety-threshold evals; tested kill switch; override path	3 · 4
Secure and resilient	Adversarial red-team suite; threat model ; runtime detection	3 · 4
Accountable and transparent	Registry ownership; model card; evidence keyed to registry ids	2 · 5
Explainable and interpretable	Explanation artefacts and reason codes, tested for fidelity (chapter 16)	2 · 3
Privacy-enhanced	Leakage and memorisation evals; DPIA linked to registry (chapter 19)	2 · 3
Fair with harmful bias managed	Fairness evals with thresholds traced to named harms	3

The Core: 19 categories

The Core has four functions, 19 categories and, by our count of the published tables, 72 subcategories [9]. GOVERN is cross-cutting; MAP, MEASURE and MANAGE run per system. The table paraphrases each category in one line and names the artefact that evidences it.

Category	In one line (paraphrased)	Artefact	Layer
GOVERN 1	Policies and processes for AI risk exist, are transparent and work; includes inventory (1.6) and decommissioning (1.7)	Policy-as-code library; registry fed by deploys	1 · 2
GOVERN 2	Accountability structures: people empowered, responsible and trained	Owner field per registry entry; RACI	1 · 2
GOVERN 3	Diverse teams and defined human-AI roles inform risk work	Reviewer roster; oversight role definitions	1
GOVERN 4	A culture that considers and communicates risk; testing, incident identification and sharing (4.3)	Incident pipeline; eval ownership	3 · 5
GOVERN 5	Engagement with relevant AI actors, including feedback from outside the team	Feedback and contest channel tied to the registry	4 · 5
GOVERN 6	Third-party software, data and supply-chain risks addressed	Vendor due-diligence gate; AIBOM	1 · 2
MAP 1	Context established: purposes, users, laws, norms, settings	Intake record	2
MAP 2	The system is categorised: tasks, methods, knowledge limits	Classification fields (the OECD dimensions fit here)	2
MAP 3	Capabilities, usage, benefits and costs understood; oversight processes defined (3.5)	Intended-use statement; oversight design	2 · 4
MAP 4	Risks and benefits mapped for every component, including third-party	Component risk map from the AIBOM	2
MAP 5	Impacts on individuals, groups, communities, organisations and society characterised	Impact assessment (FRIA, ISO/IEC 42005)	1 · 2
MEASURE 1	Methods and metrics chosen, starting with the most significant risks	Eval plan with thresholds and rationale	3
MEASURE 2	Systems evaluated against the trustworthy characteristics	Eval suites; red-team results	3
MEASURE 3	Risks tracked over time, including emergent ones in deployment	Runtime metrics compared with eval baseline	4
MEASURE 4	Feedback on whether measurement works is gathered and assessed	Eval coverage review; missed-incident analysis	3 · 5
MANAGE 1	Risks prioritised and treated; a go or no-go decision on deployment	Risk register decisions; release gate	1 · 5
MANAGE 2	Benefit-maximising and harm-minimising strategies; supersede, disengage or deactivate (2.4)	Runtime guardrail; kill switch	4
MANAGE 3	Third-party risks and benefits managed; pre-trained models monitored	Supplier monitoring; model provenance checks	2 · 4
MANAGE 4	Treatments, response, recovery and communication documented and monitored; incidents communicated (4.3)	Incident pipeline; post-deployment monitoring plan	4 · 5

The identifiers are the useful part. A control that carries `nist_ai_rmf: [MEASURE 2.7, MANAGE 2.4]` in its metadata can be counted, crosswalked and queried; a control described in prose cannot. The **Framework Crosswalk** pattern generates the RMF view from that metadata instead of maintaining it beside the code.

How a Playbook entry is structured

The AI RMF Playbook is the companion that turns each subcategory into suggested practice. Every entry has the same five parts: **About** (what the subcategory means), **Suggested Actions, Transparency and Documentation** (framed as "Organizations can document the following", a list of questions), **AI Transparency Resources** and **References** [22]. NIST describes the Playbook as voluntary material that users tailor, not a checklist to complete [9].

Read as an engineer, the "Transparency and Documentation" questions are acceptance criteria. Each question either names an artefact the stack already emits (then link it) or exposes a gap (then build it or record why not).

Example (illustrative) One subcategory, turned into a gate and an evidence record.

```
yaml control: kill-switch-tested nist_ai_rmf: [MANAGE 2.4] # supersede, disengage or deactivate playbook_question:
"Who can deactivate the system, and how is that tested?" check: last_kill_switch_test.passed == true and age_days <=
30 enforce: deploy-admission # block release if stale evidence: kill-switch-test-result # filed against the registry
id
```

The Playbook supplied the question; the pipeline supplies the answer on every release.

Profiles and the Generative AI Profile

A profile applies the Core to a context. The RMF describes three kinds: **use-case profiles** for a particular setting, **temporal profiles** (a Current Profile of how AI is managed today and a Target Profile of where the organisation wants to be, whose comparison reveals the gaps) and **cross-sectoral profiles** for risks common across uses, such as the use of large language models, cloud-based services or acquisition [9]. Generated from control metadata, the Current Profile is the live coverage of each subcategory by a running control, and the Target Profile is a reviewed diff.

NIST AI 600-1, the Generative AI Profile (26 July 2024), is the main cross-sectoral profile. It defines 12 risks unique to or exacerbated by generative AI: CBRN information or capabilities; confabulation; dangerous, violent or hateful content; data privacy; environmental impacts; harmful bias and homogenization; human-AI configuration; information integrity; information security; intellectual property; obscene, degrading and/or abusive content; value chain and component integration [23]. It then lists suggested actions keyed to the RMF subcategories with identifiers such as `GV-1.1-001`; we count 212 such identifiers in the published text [23]. Those identifiers make good test names: an eval suite for confabulation that cites the actions it implements can be traced back to the profile without a spreadsheet. On 7 April 2026 NIST also announced a concept note for an AI RMF profile on trustworthy AI in critical infrastructure [24].

Adjacent NIST work

Four further NIST publications bear directly on the stack. The newer drafts already indexed in [chapter 08](#) (the AI Agent Standards Initiative, the draft Cyber AI Profile and the draft AI 800-1) are not repeated here.

- **NIST AI 100-2 E2025** (March 2025) is a taxonomy and terminology of adversarial machine learning: ML methods, lifecycle stages of attack, attacker goals, objectives, capabilities and knowledge, and mitigations [25]. Use its terms to name the cases in the **Adversarial Red-Team Suite**, so a finding reads the same in the eval report and in the threat model.
- **NIST SP 800-218A** (July 2024) is a Secure Software Development Framework community profile for generative AI and dual-use foundation models. It adds AI-specific practices and tasks to SSDF 1.1 for producers of AI models, producers of AI systems that use them, and acquirers [26]. It is the build-pipeline half of the story: provenance of weights and data, integrity of the training environment.
- **CSF 2.0** (26 February 2024) organises cybersecurity outcomes in six Functions: Govern, Identify, Protect, Detect, Respond and Recover [27]. The AI RMF and CSF 2.0 are siblings, not substitutes: the RMF covers AI risk broadly (fairness, privacy, explainability as well as security), CSF covers cybersecurity outcomes for any system, and both put governance first. The draft Cyber AI Profile (NIST IR 8596) is the bridge, a CSF 2.0 profile for AI [28].
- **COSAIs**, the SP 800-53 Control Overlays for Securing AI Systems, will tailor SP 800-53 controls to five use cases: generative AI assistants, predictive AI, single-agent and multi-agent systems, and controls for AI developers. As of 2026-09-24 the project page shows the concept paper (14 August 2025) and an annotated outline for the predictive-AI overlay (8 January 2026), with no public draft overlay yet [29]. For organisations that already run SP 800-53, the overlays will be the most direct route from an existing control baseline to AI.

Revision status

The RMF itself foresaw a formal review with community input no later than 2028, with versions numbered 1.n for minor and 2.0 for major revisions [9]. As of 2026-09-24 NIST's framework page states that AI RMF 1.0 "is being revised as part of the White House AI Action Plan" [24]; we found no published revised version, so 1.0 remains the citable text (verify before relying on category wording). Two engineering consequences follow. Pin the version in control metadata (`nist_ai_rmf@1.0`), so a revision is a diff you review rather than a silent change of meaning. And prefer the category and subcategory identifiers over their prose, because identifiers tend to survive revisions better than wording.

NIST also hosts crosswalks from the RMF to other frameworks, including ISO/IEC 42001 and, dated 14 August 2025, a revised ISO/IEC 23894 crosswalk and a new ISO/IEC 42005 one [30]. They are a sound starting point for a crosswalk file, not a substitute

for mapping your own controls.

The ISO/IEC family

ISO/IEC JTC 1/SC 42 publishes the international AI standards. They are referenced here by number and short title only; the texts are sold by ISO and national bodies and are not reproduced. Chapter 08 already maps the ISO/IEC 42001 Annex A areas and ISO/IEC 42005, 42006 and 23894 to artefacts ([chapter 08](#), [ISO/IEC](#)).

Foundations and vocabulary

Standard	Short title	What it changes in the stack	Layer
ISO/IEC 22989:2022	AI concepts and terminology [31]	Controlled vocabulary for registry fields and policy text; stakeholder roles	1 · 2
ISO/IEC 23053:2022	Framework for AI systems using machine learning [32]	Reference decomposition of an ML system into components for the AIBOM	2
ISO/IEC 5338:2023	AI system life cycle processes, based on ISO/IEC/IEEE 15288 and 12207 [33]	Lifecycle stages the pipeline gates attach to	1 · 3
ISO/IEC TR 24028:2020	Overview of trustworthiness in AI [34]	Background taxonomy for threat and failure-mode catalogues	1

ISO/IEC 22989 establishes terminology and concepts for AI and is written to be used by other standards [31]; ISO/IEC 5338, for example, draws its AI-specific processes from 22989 and 23053 [33]. A registry whose field names follow 22989 needs less translation when an auditor works from the SC 42 family. The standard also defines stakeholder roles such as AI provider, AI producer, AI customer, AI partner and AI subject (verify the role list against the text), which are not the AI Act's provider and deployer: map them explicitly in the registry rather than assuming they coincide.

Risk, quality and data

Standard	Short title	What it changes in the stack	Layer
ISO/IEC 23894:2023	AI: guidance on risk management [35]	Organisational AI risk process; risk register as code	1 · 3
ISO/IEC TR 24027:2021	Bias in AI systems and AI aided decision making [36]	Bias sources and measures to cover in fairness evals	3
ISO/IEC 5259 series (2024–2025)	Data quality for analytics and ML: overview, process framework, governance framework and related parts [37]	Data-quality tests in CI; data card fields; data governance roles	2 · 3
ISO/IEC 25059:2023	Quality model for AI systems (SQuaRE extension) [38]	Quality characteristics to specify and measure; eval-suite coverage	3
ISO/IEC 38507:2022	Governance implications of the use of AI by organizations [39]	Board-level decision rights and oversight reporting	1 · 5

Two details matter for planning. ISO/IEC 25059 is marked "to be revised" on ISO's page as of 2026-09-24, with a replacement edition already at FDIS stage and expected within months [38], so pin the edition you map to. And ISO/IEC 38507 is written for the governing body and its advisers (executives, auditors, policymakers) [39]: it is the standard that tells a board what it owns, which is where the escalation path in layer 05 ends.

The management-system trio

ISO/IEC 42001:2023 specifies requirements for establishing, implementing, maintaining and continually improving an AI management system [40]. **ISO/IEC 42005:2025** gives guidance for AI system impact assessments on individuals, groups and society across the lifecycle [41]. **ISO/IEC 42006:2025** sets additional requirements, on top of ISO/IEC 17021-1, for bodies that audit and certify AI management systems against 42001 [42]: it is how a certificate's issuer shows the competence to issue it.

42001 follows ISO's Harmonized Structure for management-system standards, the shared layout and core text defined in Annex SL, so its clauses 4 to 10 (context, leadership, planning, support, operation, performance evaluation, improvement) line up with every other ISO management-system standard [43]. Like ISO/IEC 27001, it pairs those clauses with an annex of controls, and the organisation justifies which controls it applies in a Statement of Applicability (verify the clause wording). The engineering reading of the SoA: it is a generated file, not a document. Each Annex A control listed as applicable should point at the running control and the evidence stream that implements it; each exclusion should carry its justification and an owner.

What a 42001 certificate proves, and what it does not, is set out in [chapter 07](#) and [chapter 08](#): it evidences a management system; it confers no AI Act presumption of conformity.

Integrating with 27001, 27701 and 9001

ISO designed management-system standards to share a structure so that an organisation can run one integrated management system meeting several of them at once [43]. For AI that means ISO/IEC 42001 alongside ISO/IEC 27001:2022 for information security [44], ISO/IEC 27701 for privacy, whose 2025 edition is a standalone privacy information management system that can be used on its own or aligned with 27001 [45], and ISO 9001 for quality, whose 2026 edition replaced the 2015 edition in September 2026 [46].

Shared clause (Harmonized Structure)	One artefact serving all four	Layer
4 Context	One scope statement and interested-party register, with AI systems as registry entries	2
5 Leadership	One policy set as code, with AI, security, privacy and quality sections	1
6 Planning	One risk register with typed risks (AI, security, privacy, quality) and one treatment workflow	1
7 Support	One competence and training record; one documented-information store	5
8 Operation	Pipeline gates tagged with the standards each serves	1 · 3 · 4
9 Performance evaluation	One evidence store answering internal audit for all four	5
10 Improvement	One nonconformity and corrective-action queue fed by incidents	5

In practice (illustrative) A team that already held ISO/IEC 27001 added 42001 by extending, not duplicating. The risk register gained an ai risk type and a link to the registry id; the internal audit programme gained AI controls; the Statement of Applicability for 42001 was generated from the same control metadata as the 27001 one. The certification audit found the evidence where the 27001 auditors had always found it. The one new artefact was the impact assessment, built to 42005 and attached to each high-risk registry entry.

Harmonised standards under the AI Act

Last reviewed 2026-09-24. Stages change monthly; re-check before relying on any row.

How presumption of conformity works

Article 40 of the AI Act presumes that high-risk systems (and general-purpose AI models) conform with the corresponding requirements when they conform with harmonised standards whose references have been published in the Official Journal, to the extent the standards cover those requirements [2]. Two conditions gate the presumption: a European standard adopted on a Commission request, and its reference cited in the OJ after the Commission assesses it. Publication by CEN-CENELEC alone is not enough. Where standards do not arrive, are not accepted or insufficiently address fundamental rights, Article 41 lets the Commission adopt **common specifications** by implementing act instead [2].

The Commission first asked CEN and CENELEC for AI standards on 22 May 2023 ([C\(2023\)3215](#) , registered as request [M/593](#)) [47] [48]. After CEN-CENELEC reported significant delays, the Commission repealed and replaced that request in June 2025 with [C\(2025\)3871](#) , aligned with the final AI Act text [47]. The request covers ten topics: risk management; governance and quality of datasets; record keeping; transparency; human oversight; accuracy; robustness; cybersecurity; quality management; conformity assessment [49]. In October 2025 CEN and CENELEC adopted exceptional measures to accelerate delivery, including direct publication after a positive Enquiry vote without a separate Formal Vote, with the priority deliverables targeted for Q4 2026 [48].

The timing interacts with the Digital Omnibus, which moved the application of the Annex III high-risk obligations to 2 December 2027 and of Annex I to 2 August 2028 [50]. For most providers the standards should therefore land before the obligations apply, but not long before, which leaves little room to build to a final text.

The JTC 21 programme

The work sits in the joint technical committee CEN-CENELEC JTC 21, organised in working groups on operational aspects, engineering aspects, foundational and societal aspects, and cybersecurity [51]. Stages below come from a pan-European standards information point run with national standards bodies [52] and are cross-checked against a public tracker [53]; both are secondary, and the article mapping is as reported by those sources.

Deliverable	Subject	AI Act	Stage as of 2026-09-24 (reported)	What it changes in the stack	Layer
EN 18286:2026	Quality management system for AI Act purposes	Art. 17	Published July 2026 [54]; no OJ citation found	QMS processes run as pipeline stages; design and change control leave evidence	1 · 5
prEN 18228	AI risk management	Art. 9	Enquiry vote closed 30 Jul 2026	Provider risk file: hazard, estimate, evaluate, control, monitor; acceptability criteria as code	1 · 3 · 5
prEN 18229-1	Trustworthiness framework, Part 1: logging	Art. 12	Enquiry vote closed 20 Aug 2026	Event-log schema and retention for high-risk systems	4 · 5

Deliverable	Subject	AI Act	Stage as of 2026-09-24 (reported)	What it changes in the stack	Layer
prEN 18229-2	Part 2: transparency	Art. 13	Drafting (comment period closed Jan 2026)	Instructions-for-use and model-card fields	2
prEN 18229-3	Part 3: human oversight	Art. 14	Enquiry launched 30 Jul 2026	Oversight checkpoint design; oversight telemetry	4
prEN 18229-4 , -5	Parts 4 and 5: accuracy, robustness	Art. 15	New projects approved 24 Jun 2026	Accuracy and robustness thresholds in the eval gate	3
prEN 18282	Cybersecurity specifications for AI systems	Art. 15	Enquiry vote closed 30 Jul 2026	Threat model; adversarial suite; runtime detection	3 · 4
prEN 18283	Managing bias in AI systems	Art. 10	Approved for Enquiry 24 Sep 2026	Bias measures in fairness evals; bias-data handling	2 · 3
prEN 18284	Quality and governance of datasets	Art. 10	Drafting; no Enquiry recorded (verify)	Data cards; lineage; dataset acceptance tests	2 · 3
prEN 18285	Conformity assessment framework	Art. 43	Drafting; no Enquiry recorded (verify)	Structure of the evidence pack for assessment	5
prEN 18281 , prEN ISO/IEC 23282	Accuracy evaluation for computer vision and for NLP	Art. 15	18281: Enquiry vote closed 11 Jun 2026; 23282: Enquiry from 3 Sep 2026	Task-specific eval methods and metrics	3

Some ISO/IEC standards have also been adopted as European standards (for example [EN ISO/IEC 23894:2024](#) [52]). Adoption as an EN does not make a standard harmonised under the AI Act: only a standard delivered on the Commission's request and cited in the OJ carries the presumption. As of 2026-09-24 we found no Commission implementing decision citing any AI Act harmonised standard, consistent with the June 2026 tracker [53] and with [chapter 08](#) (verify on EUR-Lex before relying on it).

What each deliverable changes in the stack

The drafts are not public, so this is a reading of their published scopes, not of their clauses. Three shifts stand out.

Risk management moves from the organisation to the product. The published scope of prEN 18228 addresses providers of AI systems: identify hazards, estimate and evaluate risks, control them and monitor the controls, for risks to health, safety and fundamental rights, across the lifecycle. It requires providers to set objective risk-acceptability criteria but does not set the levels, and it is not intended for managing risks the organisation itself faces [52]. That is a different object from ISO/IEC 23894, which guides organisational risk management [35]. In the stack, the risk file becomes a per-system artefact keyed to the registry id, with acceptability criteria written as thresholds a gate can evaluate, and monitoring that closes the loop in layer 05.

Logging, oversight and transparency become specifiable. The prEN 18229 series splits Articles 12–15 into separate parts [52]. Once final, the logging part is a schema to validate event logs against in CI, the oversight part a design reference for the **Human-in-the-loop Gate**, and the transparency part a field list for the model card and instructions for use.

The QMS becomes auditable as a pipeline. EN 18286 supports the Article 17 quality management system [54]. A QMS whose design control, change management and post-market monitoring run as pipeline stages emits its own evidence; one that lives in procedures does not. The **Machine-Readable Evidence (OSCAL)** pattern is how that evidence reaches an assessor.

Building before the OJ citation

The gap between a draft and a cited standard is where most teams will spend 2026 and 2027. Three rules keep the work reusable:

- Build to the requirement, map to the standard.** The AI Act article is fixed; the standard's clause numbering is not. Key controls on [Art. 9](#) , [Art. 12](#) and so on, and add standard clause ids as metadata when the text is final.
- Keep a standards watch as data.** One file with each deliverable, its stage, the date you last checked and the controls that depend on it. A stage change is then a diff that names the controls to re-review, not a surprise.
- Do not claim the presumption early.** Until the OJ citation exists, conformity with a draft or a published EN is evidence on its own merits, not a presumption. Say so in the technical documentation.

In practice (illustrative) A provider of a high-risk recruitment tool built its risk file to the published scope of prEN 18228 while the draft was at Enquiry: hazards, estimates, controls and monitoring per system, with acceptability thresholds as code. When EN 18286 was published, the team compared its QMS process list with the pipeline stages it already ran and found two gaps (supplier change notification and a post-market review cadence). Both became pipeline stages with owners. The standards-watch file recorded the date of each check, which is what an assessor asked to see.

IEEE 7000 series

The IEEE 7000 series approaches ethics as systems-engineering process. None of these standards is harmonised under the AI Act, and none confers a presumption; they are useful as process references.

Standard	Subject	What it changes in the stack	Layer
IEEE 7000-2021	Model process for considering ethical values from concept exploration through development, with stakeholder value elicitation and traceability [55]	Value requirements traced to design decisions and tests	1
IEEE 7001-2021	Transparency of autonomous systems, in measurable, testable levels [56]	Transparency levels written as testable requirements	2 · 3
IEEE 7002-2022	Data privacy process for systems using personal data [57]	Privacy requirements as SDLC gates	1 · 2
IEEE 7003-2024	Algorithmic bias considerations, incl. validation-data selection and application boundaries [58]	Bias validation sets; declared application boundaries in the registry	2 · 3
IEEE 7005-2021	Transparent employer data governance [59]	Handling rules for employee data used by AI	2
IEEE 7010-2020	Recommended practice for assessing the impact of autonomous and intelligent systems on human well-being [60]	Well-being indicators in the impact assessment	2

IEEE 7003's "application boundaries for which the algorithm has been designed" is the most portable idea here: a declared boundary in the registry entry is something a runtime guardrail can enforce and an eval can test against [58].

One control, many instruments

The instruments overlap far more than their authors' different vocabularies suggest. The table shows, for seven controls the stack already builds, where each instrument asks for them. It is a starting point for a crosswalk file, not a claim that the rows are equivalent.

Control (layer)	OECD	CoE CETS 225	G7 Code	NIST AI RMF	ISO/IEC	JTC 21
Risk and impact assessment (1 · 2)	1.5(c)	Art. 16	Action 1	MAP 5, MANAGE 1	23894, 42005	prEN 18228
Testing before release and on change (3)	1.4(a)	Art. 16(2) (g)	Action 1	MEASURE 1, 2	42001 A.6	prEN 18229-4, -5
Traceability and logging (4 · 5)	1.5(b)	Art. 14(2) (a)	Action 1	MEASURE 3, MANAGE 4	42001 A.6	prEN 18229-1
Transparency and disclosure (2 · 4)	1.3	Art. 8, 15(2)	Action 3	MEASURE 2.8	42001 A.8	prEN 18229-2
Human oversight and override (4)	1.2(b), 1.4(b)	Art. 8	–	MAP 3.5, MANAGE 2.4	42001 A.9	prEN 18229-3
Incident handling and sharing (5)	–	Art. 16(3)	Actions 2, 4	GOVERN 4.3, MANAGE 4.3	42001 10.2	–
Supply chain and third parties (2)	1.5(c)	–	Action 11	GOVERN 6, MANAGE 3	42001 A.10	–

Sources: [7][1][10][9][40][52]; the ISO/IEC 42001 clause and Annex A ids follow [chapter 08](#) and the site's [crosswalk](#), whose [explorer](#) derives these pairs for any two instruments and exports them as an OSCAL mapping collection. Mappings are illustrative, not a claim of conformity.

The engineering rule is the one from the [regulatory translation](#) workflow: build each control once, tag it with every instrument it serves, and generate each instrument's view from the tags. A principle, a treaty article, a subcategory and a harmonised clause then become four queries over the same evidence, and adding a fifth instrument is a metadata change, not a new programme.

Maps to: OECD AI Principles 1.1 – 1.5 · CoE CETS No. 225 Arts. 14–16 · G7 Hiroshima Code of Conduct actions 1–7, 10, 11 · EU AI Act Art. 9–15, 17, 40, 41 · ISO/IEC 22989, 23894, 42001, 42005, 42006 · NIST AI RMF (Govern, Map, Measure, Manage) and AI 600-1 · CEN-CENELEC JTC 21 deliverables · all five layers of the stack. Mappings are illustrative, not a claim of conformity.

What you can do this week

1. **Add the five OECD classification dimensions to your registry schema** as required fields, and make one policy read one of them (for example, `rights_impact: high` requires a fairness eval).
2. **Tag your ten most important controls with NIST AI RMF subcategory ids and ISO/IEC 42001 clause ids**, pinned to the edition, and generate a Current Profile from the tags.

3. **Start a standards-watch file** listing each JTC 21 deliverable in the table above, its stage, the date you checked and the controls that depend on it; set a monthly review.
4. **Take your organisation's published AI principles and name, for each, the control and the evidence record that implement it.** A principle with no control is a gap; write it down as one.
5. **If you hold ISO/IEC 27001, map its shared clauses to the 42001 ones** and point both at one evidence store before you write any new procedure.

Sources

[1] Council of Europe Framework Convention on Artificial Intelligence and Human Rights, Democracy and the Rule of Law (CETS No. 225), text (Art. 2 definition; Art. 3 scope and private-actor declaration; Arts. 7–13 principles; Arts. 14–15 remedies and safeguards; Art. 16 risk and impact management; Art. 30 entry into force). Council of Europe. 2024-09-05. <https://rm.coe.int/1680afae3c> (verified: primary) [2] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27, Arts. 40 and 41 (Art. 40: harmonised standards, presumption of conformity once references are published in the OJ; Art. 41: common specifications by implementing act). Publications Office of the EU (EUR-Lex). 2026-07-27. https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng#art_40 (verified: primary) [3] OECD AI Principles overview (47 adherents: 38 OECD members, the EU and eight non-members; definition and lifecycle used by the EU, the Council of Europe, the US and the UN; AI Incidents and Hazards Monitor; Hiroshima AI Reporting Framework). OECD.AI. 2026-09-24. <https://oecd.ai/en/ai-principles> (verified: primary) [4] Recommendation on the Ethics of Artificial Intelligence (adopted November 2021 by 193 Member States; four core values, ten core principles, policy action areas). UNESCO. 2021-11. <https://www.unesco.org/en/artificial-intelligence/recommendation-ethics> (verified: primary) [5] The Framework Convention on Artificial Intelligence (technology-neutral; Parties: the European Union; 20 further signatories listed, read on 2026-09-24). Council of Europe. 2026-09-24. <https://www.coe.int/en/web/artificial-intelligence/the-framework-convention-on-artificial-intelligence> (verified: primary) [6] Ethics Guidelines for Trustworthy AI (lawful, ethical, robust; seven key requirements; human-in-the-loop, human-on-the-loop, human-in-command; "safeguards that enable a fallback plan in case of problems"). High-Level Expert Group on AI / European Commission. 2019-04-08. <https://digital-strategy.ec.europa.eu/en/library/ethics-guidelines-trustworthy-ai> (verified: primary) [7] Recommendation of the Council on Artificial Intelligence, OECD/LEGAL/0449 (adopted 22 May 2019; G20 AI Principles drawn from it, June 2019; AI-system definition revised 8 Nov 2023; revised 3 May 2024; five principles, five recommendations; definitions of AI system, lifecycle and AI actors). OECD. 2024-05-03. <https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449> (verified: primary) [8] OECD Framework for the Classification of AI Systems (OECD Digital Economy Papers No. 323; People & Planet, Economic Context, Data & Input, AI Model, Task & Output). OECD. 2022-02-22. <https://doi.org/10.1787/cb6d9eca-en> (verified: primary) [9] Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (Fig. 1 harms; risk tolerance not prescribed; Fig. 2 lifecycle and dimensions adapted from the OECD; seven trustworthy characteristics; Core of 4 functions and 19 categories, 72 subcategories by our count of Tables 1–4; use-case, temporal and cross-sectoral profiles; formal review no later than 2028). NIST. 2023-01-26. <https://doi.org/10.6028/NIST.AI.100-1> (verified: primary) [10] Hiroshima Process International Code of Conduct for Organizations Developing Advanced AI Systems, with the International Guiding Principles (11 actions; voluntary; living document building on the OECD AI Principles). G7 / European Commission. 2023-10-30. <https://digital-strategy.ec.europa.eu/en/library/hiroshima-process-international-code-conduct-advanced-ai-systems> (verified: primary) [11] "Council of Europe adopts first international treaty on artificial intelligence" (adopted in Strasbourg on 17 May 2024; opens for signature in Vilnius on 5 September 2024). Council of Europe. 2024-05-17. <https://www.coe.int/en/web/portal/-/council-of-europe-adopts-first-international-treaty-on-artificial-intelligence> (verified: primary) [12] "OECD launches global framework to monitor application of G7 Hiroshima AI Code of Conduct" (first reports by 15 April 2025, rolling submissions, annual updates). OECD. 2025-02-07. <https://www.oecd.org/en/about/news/press-releases/2025/02/oecd-launches-global-framework-to-monitor-application-of-g7-hiroshima-ai-code-of-conduct.html> (verified: primary) [13] "European Union ratifies the Council of Europe Framework Convention on Artificial Intelligence" (15 May 2026, 135th Session of the Committee of Ministers, Chişinău). Council of Europe. 2026-05-15. <https://www.coe.int/en/web/artificial-intelligence/-/european-union-ratifies-the-council-of-europe-framework-convention-on-artificial-intelligence> (verified: primary) [14] Regulation (EU) 2024/1689 (AI Act), Recitals 12 and 27 and Art. 3(1) (recital 27: the seven AI HLEG principles as non-binding guidance; recital 12: the AI-system notion closely aligned with the work of international organisations; Art. 3(1)). Publications Office of the EU (EUR-Lex). 2024-07-12. https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng#rct_27 (verified: primary) [15] Catalogue of Tools & Metrics for Trustworthy AI. OECD.AI. 2026. <https://oecd.ai/en/catalogue/overview> (verified: primary) [16] Readiness Assessment Methodology (RAM): country-level readiness to govern AI (RAM 2.0). UNESCO Global AI Ethics and Governance Observatory. 2026. <https://www.unesco.org/ethics-ai/en/ram> (verified: primary) [17] Ethical Impact Assessment (EIA): system-level assessment before and during use, for governments, companies and researchers. UNESCO Global AI Ethics and Governance Observatory. 2026. <https://www.unesco.org/ethics-ai/en/eia> (verified: primary) [18] "EU Parliament backs EU conclusion of the Council of Europe Framework Convention on Artificial Intelligence" (European Parliament approval on 11 March 2026). Council of Europe. 2026-03-11. <https://www.coe.int/en/web/artificial-intelligence/-/eu-parliament-backs-eu-conclusion-of-the-council-of-europe-framework-convention-on-artificial-intelligence> (verified: primary) [19] Council Decision (EU) 2026/1080 of 21 April 2026 on the conclusion, on behalf of the European Union, of the Council of Europe Framework Convention on AI (implemented in the Union exclusively through Reg. (EU) 2024/1689 and other relevant Union acquis; declaration under Art. 3(1)(b) on private actors; OJ L 13 May 2026; text read from the Publications Office Cellar, CELEX 32026D1080). Council of the EU (EUR-Lex). 2026-05-13. <https://eur-lex.europa.eu/eli/dec/2026/1080/oj/eng> (verified: primary) [20] HUDERIA: risk and impact assessment of AI systems (HUDERIA Methodology approved 26 February 2025; HUDERIA Model: COBRA approved 25 February 2026; non-binding). Council of Europe.

2026. <https://www.coe.int/en/web/artificial-intelligence/huderia-risk-and-impact-assessment-of-ai-systems> (verified: primary) [21] Assessment List for Trustworthy Artificial Intelligence (ALTAI) for self-assessment (final list 17 July 2020 after a pilot with over 350 stakeholders; document and web tool). High-Level Expert Group on AI / European Commission. 2020-07-17. <https://digital-strategy.ec.europa.eu/en/library/assessment-list-trustworthy-artificial-intelligence-altai-self-assessment> (verified: primary) [22] NIST AI RMF Playbook, GOVERN entries (per subcategory: About; Suggested Actions; Transparency and Documentation; AI Transparency Resources; References). NIST Trustworthy and Responsible AI Resource Center. 2026. <https://airc.nist.gov/airmf-resources/playbook/govern/> (verified: primary) [23] NIST AI 600-1, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (12 risks; suggested actions coded GV/MP/MS/MG, 212 identifiers by our count). NIST. 2024-07-26. <https://doi.org/10.6028/NIST.AI.600-1> (verified: primary) [24] AI Risk Management Framework ("The AI RMF 1.0 is being revised as part of the White House AI Action Plan"; concept note for a critical-infrastructure profile, 7 April 2026). NIST. 2026-09-24. <https://www.nist.gov/itl/ai-risk-management-framework> (verified: primary) [25] NIST AI 100-2 E2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations. NIST. 2025-03. <https://csrc.nist.gov/pubs/ai/100/2/e2025/final> (verified: primary) [26] NIST SP 800-218A, Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile (augments SSDF 1.1). NIST. 2024-07-26. <https://csrc.nist.gov/pubs/sp/800/218/a/final> (verified: primary) [27] The NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (Functions: Govern, Identify, Protect, Detect, Respond, Recover). NIST. 2024-02-26. <https://doi.org/10.6028/NIST.CSWP.29> (verified: primary) [28] NIST IR 8596 (initial preliminary draft): Cybersecurity Framework Profile for Artificial Intelligence (Cyber AI Profile; comments closed 30 January 2026). NIST. 2025-12-16. <https://csrc.nist.gov/pubs/ir/8596/iprd> (verified: primary) [29] SP 800-53 Control Overlays for Securing AI Systems (COSAiS) (five use cases; concept paper 14 August 2025; predictive-AI annotated outline 8 January 2026; page updated 8 January 2026). NIST CSRC. 2026-01-08. <https://csrc.nist.gov/projects/cosais> (verified: primary) [30] AI RMF crosswalk documents (AI RMF to ISO/IEC 42001; ISO/IEC 23894 revised crosswalk and ISO/IEC 42005 crosswalk dated 14 August 2025). NIST Trustworthy and Responsible AI Resource Center. 2025. <https://airc.nist.gov/airmf-resources/crosswalks/> (verified: primary) [31] ISO/IEC 22989:2022, Information technology: Artificial intelligence: AI concepts and terminology. ISO/IEC. 2022-07. <https://www.iso.org/standard/74296.html> (verified: primary) [32] ISO/IEC 23053:2022, Framework for AI systems using machine learning. ISO/IEC. 2022-06. <https://www.iso.org/standard/74438.html> (verified: primary) [33] ISO/IEC 5338:2023, AI system life cycle processes (based on ISO/IEC/IEEE 15288 and 12207, with AI-specific processes from ISO/IEC 22989 and 23053). ISO/IEC. 2023-12. <https://www.iso.org/standard/81118.html> (verified: primary) [34] ISO/IEC TR 24028:2020, Overview of trustworthiness in artificial intelligence. ISO/IEC. 2020-05. <https://www.iso.org/standard/77608.html> (verified: primary) [35] ISO/IEC 23894:2023, AI: Guidance on risk management (organisational AI risk management). ISO/IEC. 2023-02. <https://www.iso.org/standard/77304.html> (verified: primary) [36] ISO/IEC TR 24027:2021, Bias in AI systems and AI aided decision making. ISO/IEC. 2021-11. <https://www.iso.org/standard/77607.html> (verified: primary) [37] ISO/IEC 5259 series, Data quality for analytics and machine learning (Part 1:2024 overview, terminology and examples; Part 4:2024 process framework; Part 5:2025 governance framework). ISO/IEC. 2024-07. <https://www.iso.org/standard/81088.html> (verified: primary) [38] ISO/IEC 25059:2023, SQuaRE: Quality model for AI systems (stage 90.92, to be revised, as of 2026-09-24; replacement at FDIS stage, expected within the coming months). ISO/IEC. 2023-06. <https://www.iso.org/standard/80655.html> (verified: primary) [39] ISO/IEC 38507:2022, Governance implications of the use of artificial intelligence by organizations (for governing bodies, executives, auditors, policymakers). ISO/IEC. 2022-04. <https://www.iso.org/standard/56641.html> (verified: primary) [40] ISO/IEC 42001:2023, AI management systems (requirements for establishing, implementing, maintaining and continually improving an AIMS). ISO/IEC. 2023-12. <https://www.iso.org/standard/81230.html> (verified: primary) [41] ISO/IEC 42005:2025, AI system impact assessment (guidance). ISO/IEC. 2025-05. <https://www.iso.org/standard/44545.html> (verified: primary) [42] ISO/IEC 42006:2025, Requirements for AIMS audit and certification bodies (builds on ISO/IEC 17021-1). ISO/IEC. 2025-07. <https://www.iso.org/standard/44546.html> (verified: primary) [43] Management system standards (Harmonized Structure; Annex SL common text; integrated management systems). ISO. 2026. <https://www.iso.org/management-system-standards.html> (verified: primary) [44] ISO/IEC 27001:2022, Information security management systems. ISO/IEC. 2022-10. <https://www.iso.org/standard/82875.html> (verified: primary) [45] ISO/IEC 27701:2025, Privacy information management systems: Requirements and guidance (independent management system standard; aligns with ISO/IEC 27001). ISO/IEC. 2025-10. <https://www.iso.org/standard/85819.html> (verified: primary) [46] ISO 9001:2026, Quality management systems: Requirements (replaces ISO 9001:2015). ISO. 2026-09. <https://www.iso.org/standard/9001> (verified: primary) [47] Commission Implementing Decision C(2025)3871 on a standardisation request to CEN and Cenelec in support of Reg. (EU) 2024/1689, repealing Implementing Decision C(2023)3215 of 22 May 2023 (significant delays reported by CEN and Cenelec; request aligned with the final AI Act). European Commission. 2025-06-23. [https://ec.europa.eu/transparency/documents-register/detail?ref=C\(2025\)3871&lang=en](https://ec.europa.eu/transparency/documents-register/detail?ref=C(2025)3871&lang=en) (verified: primary) [48] "Update on CEN and CENELEC's decision to accelerate the development of standards for artificial intelligence" (direct publication after a positive Enquiry vote; drafting group for delayed drafts; Q4 2026 target; Standardization Request M/593 and Amendment M/613). CEN-CENELEC. 2025-10-23. <https://www.cencenelec.eu/news-events/news/2025/brief-news/2025-10-23-ai-standardization/> (verified: primary) [49] AI Act standardisation (ten requested topics; prEN 18286 first to public enquiry on 30 October 2025; page updated 3 August 2026). European Commission. 2026-08-03. <https://digital-strategy.ec.europa.eu/en/policies/ai-act-standardisation> (verified: primary) [50] "AI Omnibus enters into force" (Reg. (EU) 2026/1744; Annex III high-risk from 2 Dec 2027; Annex I from 2 Aug 2028). European Commission. 2026-07-27. <https://digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force> (verified: primary) [51] Working groups and projects of CEN-CENELEC JTC 21 (WG 2 operational aspects, WG 3 engineering aspects, WG 4 foundational and societal aspects, WG 5 cybersecurity; prEN 18229 in five parts). JTC 21 website. 2026. <https://jtc21.eu/working-groups/> (verified: secondary) [52] Project stages for JTC 21 deliverables read on 2026-09-24: EN 18286:2026 (60.60, 2026-07-22); prEN 18228 (40.60, vote closed 2026-07-30; published scope); prEN 18229-1 (40.60, 2026-08-20); prEN 18229-2 (20.60, 2026-01-06); prEN 18229-3 (40.20, 2026-07-30); prEN 18229-4 and -5 (10.99, 2026-06-24); prEN 18281 (40.60, 2026-06-11); prEN 18282 (40.60, 2026-07-30);

prEN 18283 (30.99, 2026-09-24); prEN 18284 (10.99); prEN 18285 (10.99); prEN ISO/IEC 23282 (40.20, 2026-09-03); EN ISO/IEC 23894:2024 (60.60). Genorma (pan-European standards information point with national standards bodies). 2026-09-24. <https://genorma.com/en/standards/pren-18228> (verified: secondary) [53] JTC 21 standards tracker (AI Act article per deliverable; no JTC 21 deliverable cited in the OJ as of June 2026). kla.digital. 2026-06-29. <https://kla.digital/blog/jtc-21-standards-tracker> (verified: secondary) [54] "EN 18286 in the spotlight: supporting compliance with the AI Act" (EN 18286:2026, Artificial intelligence: Quality management system for EU AI Act regulatory purposes; supports Art. 17). CEN-CENELEC. 2026-07-31. <https://www.cenelec.eu/news-events/news/2026/en-in-the-spotlight/2026-07-30-ai-quality-management/> (verified: primary) [55] IEEE 7000-2021, Standard Model Process for Addressing Ethical Concerns during System Design. IEEE SA. 2021. <https://standards.ieee.org/standard/7000-2021.html> (verified: primary) [56] IEEE 7001-2021, Standard for Transparency of Autonomous Systems. IEEE SA. 2021. <https://standards.ieee.org/standard/7001-2021.html> (verified: primary) [57] IEEE 7002-2022, Standard for Data Privacy Process. IEEE SA. 2022. <https://standards.ieee.org/standard/7002-2022.html> (verified: primary) [58] IEEE 7003-2024, Standard for Algorithmic Bias Considerations (validation-data selection; application boundaries). IEEE SA. 2024. <https://standards.ieee.org/standard/7003-2024.html> (verified: primary) [59] IEEE 7005-2021, Standard for Transparent Employer Data Governance. IEEE SA. 2021. <https://standards.ieee.org/standard/7005-2021.html> (verified: primary) [60] IEEE 7010-2020, Recommended Practice for Assessing the Impact of Autonomous and Intelligent Systems on Human Well-Being. IEEE SA. 2020. <https://standards.ieee.org/standard/7010-2020.html> (verified: primary)

23. Governing AI agents

An AI agent is governed when every action traces back to a registered identity, a scope someone approved, a checkpoint that fired where the stakes required one and a tested way to stop it.

Chapter 05 carries four agent patterns: the [Agent Registry](#), [Agent Identity & Scoped Credentials](#), the [Kill Switch / Circuit Breaker](#) and the [Human-in-the-loop Gate](#). [Layer 04 of the stack](#) says what runtime control must prove, and the [regulatory map](#) lines up the agent controls of three frameworks side by side. None says in one place what makes an agent different to govern, how the controls form one control plane, or where each control meets the law. This chapter does.

One contrast first. **AI security engineering**, the sibling discipline, asks how an attacker can make an agent cause harm, and it owns the [threat model](#). AI governance engineering asks a wider question: under whose authority did the agent act, within what bound, with what evidence, and who could have stopped it. The two share most controls. They differ on what counts as done: for security a blocked attack is done; for governance it is done when the block, the authority behind the action and the approval are on the record.

The OWASP agentic list states the first principle, **least agency**: its advice is "to avoid unnecessary autonomy", because agentic behaviour deployed where it is not needed "expands the attack surface without adding value" [1]. The cheapest agent control is the agent you did not build: a fixed workflow with one model call is easier to govern than a planner that picks its own tools. Chapter 15 treats [the agentic wrapper as a deployment option](#), with the controls it adds on top of the model it wraps.

What makes an agent a governance object

An agent is an AI system that pursues a goal by choosing and taking actions: it plans, calls tools, reads and writes memory and may hand work to other agents. Chapter 11 places it among [the kinds of AI](#) a registry must tell apart. Four properties matter for governance, and each breaks an assumption that model governance relies on.

Property	What changes	Governance question	First control
Delegated authority	The agent acts on someone's behalf, with their permissions or its own	Whose authority was used, and was it narrower than theirs?	Workload identity; delegation record
Tools	Output becomes an effect in a system of record, not text a person reads	Which actions can it take, on which resources?	Tool allow-list; scoped credentials
Memory	State persists across sessions, users and tasks	What does it remember, for how long, and who can write to it?	Memory scopes; retention; write provenance
Autonomy	Steps happen with no person between them	Where must a person decide, and can they stop it?	Checkpoints; kill switch

The evidence model changes with them. A model is evaluated on its outputs; an agent must also be evaluated on its **trajectory**, the sequence of plans, tool calls and memory operations that led to an effect. An eval that scores the final answer and ignores the path will pass an agent that reached the right result through a tool it should never have held.

Autonomy is a design decision

Autonomy is a setting the deployer chooses, not a property of the model. As Feng, McDonald and Zhang put it, "An agent's level of autonomy can be treated as a deliberate design decision, separate from its capability and operational environment" [2]. They define five levels by the role the user plays: operator, collaborator, consultant, approver and observer. [Singapore's Model AI Governance Framework for Agentic AI](#) describes four levels of human involvement, from "agent proposes, human operates" to "agent operates, human observes", and cites the same work [3]. The Cloud Security Alliance's Agent Trust Framework names four tiers, from Intern (read-only) to Principal (autonomous within bounds), and makes promotion earned: "sustained accuracy, a clean incident record, a passed security audit, and explicit governance sign-off" [4].

The EU AI Act asks for the same proportionality: oversight measures for a high-risk system must be commensurate with its risks, its level of autonomy and its context of use ([Art. 14\(3\)](#)) [5]. The table aligns the three scales and gives each level a minimum control set. The alignment and the control sets are this book's reading, not the authors'.

User's role [2]	Nearest IMDA level [3]	Nearest ATF tier [4]	What the person does	Minimum controls
Operator	Agent proposes, human operates	Intern	Takes every action	Registry entry; own identity; read-only tools; traces
Collaborator	Agent and human collaborate	Junior	Approves significant steps	The above, plus a tool allow-list and a checkpoint before every write
Consultant	Between the two	Junior to Senior	Sets goals, gives feedback	The above, plus a runtime guardrail on every tool call and execution budgets

User's role [2]	Nearest IMDA level [3]	Nearest ATF tier [4]	What the person does	Minimum controls
Approver	Agent operates, human approves	Senior	Approves critical or irreversible steps	The above, plus an approval log, a per-agent circuit breaker and a drilled kill switch
Observer	Agent operates, human observes	Principal	Audits after the fact	The above, plus trajectory anomaly detection and independent trajectory evals; reversible, bounded actions only

Record the level as a registry field (chapter 11 gives [an illustrative autonomy scale](#) for it) and treat raising it as a change that needs the same review as a new deployment. A promotion is a decision with evidence behind it, not a flag someone flipped.

The agent registry

The [Agent Registry](#) pattern makes registration a precondition of production: owner, scope and expiry, written by the pipeline. An agent's entry has to carry more. Singapore's framework asks that agent identities be "catalogued and centrally managed", issued from and tracked by a central system "to prevent agent sprawl" [3]; TC260's agentic appendix asks for a unique identity per agent and permissions set by decision mode [6].

Field	Why it is there	Evidence it enables
Identity (for example a SPIFFE ID)	Attribution	Every log line joins to one entry
Owner (team and accountable person)	Accountability	An escalation route that exists
Purpose	Scope test; legal classification	Detection of use outside purpose
Autonomy level	Proportionate controls	Promotion history
Tools and scopes	The enforced allow-list	Guardrail configuration diffs
Data classes and memory stores	Privacy and retention	DPIA and records-of-processing links
Delegation rights	Bounds between agents	Delegation policy
Versions (model, prompts, policy bundle)	Change control	Replay of the exact configuration in an incident
Checkpoints	Oversight design	Approval log
Stop handles (breaker, revocation path, last drill)	Kill switch	Drill record
Expiry	No agent outlives its review	Automatic deactivation
Regulatory role and class	Obligations	Obligation map

Example (illustrative) A registry entry for a refunds agent, written by the deploy pipeline. The versions block is what makes an incident replayable; the stop block is what makes the kill switch more than a claim.

```
# agent-registry entry (illustrative)
id: refunds-agent
identity: spiffe://corp.example/agents/refunds-agent
owner: { team: support-platform, accountable: head-of-support-operations }
purpose: Draft and execute refunds for orders under the published returns policy
autonomy_level: approver
tools:
  - { name: orders.read, scopes: [orders:read] }
  - { name: refunds.create, scopes: [refunds:write], checkpoint: "amount_eur > 200" }
delegation: { may_call: [fraud-check-agent], may_be_called_by: [support-orchestrator] }
memory: { session: true, long_term: none }
versions: { model: vendor-model@2026-08-15, system_prompt: "sha256:9f2c...e41", policy_bundle: v14 }
budgets: { tool_calls_per_task: 25, spend_eur_per_day: 5000 }
stop: { breaker: cb-refunds-01, revoke: identity, last_drill: 2026-09-10 }
ai_act: { role: deployer, class: not-high-risk }
expiry: 2026-12-17
```

A registry is only as good as what it misses. The [Shadow-AI Discovery](#) pattern reconciles it against what runs: SaaS connectors, coding agents on laptops and local MCP servers, which run with the same privileges as the client that launched them [7]. An agent found by discovery is either registered within a deadline or switched off.

In practice (illustrative) In a large telco, the first discovery sweep found more agents on developer laptops than in the production registry: coding assistants with local MCP servers holding personal access tokens, some with write access to shared repositories. The fix was not a ban. A paved path issued each developer's agent a short-lived, repository-scoped credential from the production identity system, and the sweep became a weekly reconciliation with an owner for every finding.

Identity and short-lived credentials

Channel authentication is not agent identity

Chapters 04 and 05 draw the key line. **Channel authentication** secures one hop, such as a client talking to an MCP server. **Agent workload identity** is the attributable identity the agent carries across every hop, under which its actions are logged and its access revoked. Singapore's framework lists what that identity must be: unique and "cryptographically verifiable"; "accounted for", tied to a supervising agent, a human user or an organisational department; differentiated "according to the capacity in which it acts", independently or on behalf of a named user; and catalogued centrally [3]. NIST's NCCoE asks how each agent can be "known, trusted, and properly governed" [8].

Short-lived, attested credentials

SPIFFE defines "short lived cryptographic identity documents", called SVIDs, delivered through a Workload API that also rotates them; an SVID is currently either an X.509 certificate or a JWT, and SPIRE is the reference implementation [9]. A third format, WIT-SVID, a SPIFFE profile of the IETF WIMSE Workload Identity Token, is still incubating as of 2026-09-24 [30]. The governance value is in the lifetime: a credential that expires in minutes need not be hunted down after an incident, only not reissued. A static API key in an agent's configuration is the opposite, and attackers know where to look: MITRE ATLAS catalogues "Credentials from AI Agent Configuration" (`AML.T0083`) [10]. TC260 asks that credentials be revoked at the end of the task [6]. Singapore asks that authorisations be "time- or session-bound, non-transferable", least privilege by default and never greater than what the authorising human may do [3].

Delegation without impersonation

When an agent acts for a user, two identities are in play, and the log must keep both. OAuth 2.0 Token Exchange (RFC 8693) separates **impersonation**, where the actor becomes indistinguishable from the subject, from **delegation**, where both stay identifiable. Its `act` claim "provides a means within a JWT to express that delegation has occurred and identify the acting party", and nested `act` claims record the earlier actors in the chain [11]. The rule for agents follows: exchange the user's token for a delegated one that names the agent, with a narrower scope and a short expiry; never hand the agent the user's own token.

Example (illustrative) The claims of a delegated access token. The user is the subject; the refunds agent is the current actor; the orchestrator that delegated the task to it is nested inside. The audience is one API and the scope one operation.

```
{
  "sub": "user:4711",
  "aud": "https://refunds.api.example",
  "scope": "refunds:write",
  "exp": 1790330400,
  "act": {
    "sub": "spiffe://corp.example/agents/refunds-agent",
    "act": { "sub": "spiffe://corp.example/agents/support-orchestrator" }
  }
}
```

MCP authorization as of 2026-07-28

The Model Context Protocol specification dated 2026-07-28 is the current version as of 2026-09-24. Authorisation is optional in MCP; where an HTTP transport uses it, the MCP server acts as an OAuth 2.1 resource server [12]. The requirements that matter for governance:

Requirement (spec 2026-07-28)	What it prevents	Evidence to keep
Servers MUST implement OAuth 2.0 Protected Resource Metadata (RFC 9728), and clients MUST use it to find the authorisation server [12]	Clients guessing where tokens come from	Discovery configuration in the tool manifest
Clients and authorisation servers SHOULD support Client ID Metadata Documents; Dynamic Client Registration is deprecated [12][13]	Anonymous, unmanaged client registrations	Allowed client domains as policy
Clients MUST send the <code>resource</code> parameter (RFC 8707) with the server's canonical URI [12]	Tokens that work at any server	Token requests naming the resource

Requirement (spec 2026-07-28)	What it prevents	Evidence to keep
Servers MUST validate that a token was issued for them and "MUST NOT accept or transit any other tokens" [12]	Token passthrough and the confused deputy	Audience-check failures raised as alerts
Clients MUST validate the <code>iss</code> parameter (RFC 9207) before redeeming a code, and client credentials are bound to the issuer that minted them [12][13]	Authorisation-server mix-up	The recorded issuer per flow
Servers SHOULD challenge with the scopes an operation needs, and clients step up for more [12]	Omnibus scopes granted up front	Elevation events with correlation IDs [7]

The accompanying security guidance is blunter: token passthrough "is explicitly forbidden", and the scope mistakes it lists include "Publishing all possible scopes" and "Using wildcard or omnibus scopes" [7]. The 2026-07-28 release also set a deprecation policy with a twelve-month minimum window [13], so the MCP version each server speaks is a registry field. And the Client ID Metadata Document specification is still an IETF Internet-Draft (revision 02, 6 Jul 2026) [14].

None of this identifies the agent. MCP secures the hop between one client and one server. Which agent sits behind the client, and for whom, is the workload identity's job.

Tool and MCP server permissions

The tool allow-list

A tool is a capability, and the allow-list is where capabilities are granted. OWASP's advice under [ASI02](#) is to "Define per-tool least-privilege profiles (scopes, maximum rate, and egress allowlists)" and to express them "as IAM or authorization policy stanzas attached to each tool, rather than relying on ad-hoc conventions" [1]. TC260 asks that an agent get only the minimum permissions its current task needs, and that an operation be refused by default when the approval system fails, the user does not respond or no approval rule exists [6]. An allow-list entry has more than a name:

Property	Rule	Example
Tool identity	Server, tool name and a hash of the tool definition, pinned	<code>refunds.create</code> on <code>payments-mcp</code> , definition <code>sha256:...</code>
Operation class	Read, write, delete, send, execute or pay; the class drives checkpoints	<code>refunds.create</code> is pay
Resource scope	The narrowest resource set the task needs	Orders of the customer in the current case
Rate and volume	Calls per task and per hour	25 per task
Egress	Destinations the tool may reach	Internal payments API only
Data classes	What may flow in and out	No special-category data to external tools
Checkpoint	When a person must approve	Amount above 200 EUR

No tool is harmless by name. OWASP's list describes a coding agent whose auto-approved ping tool was triggered repeatedly to exfiltrate data through DNS queries [1]; ATLAS catalogues "Exfiltration via AI Agent Tool Invocation" ([AML.T0086](#)) and "Data Destruction via AI Agent Tool Invocation" ([AML.T0101](#)) [10]. Rate and egress bounds therefore apply to every tool, including the ones nobody worries about.

Example (illustrative) The allow-list as a deny-by-default policy the tool gateway evaluates on every call, reading the registry as data. The rate check is omitted for brevity.

```
package agents.tools

default allow := false

allow if {
  entry := data.registry[input.agent_id]
  some tool in entry.tools
  tool.name == input.tool.name
  tool.definition_hash == input.tool.definition_hash
  input.tool.scope in tool.scopes
}

needs_approval if {
  input.tool.operation in {"delete", "send", "pay", "execute"}
}
```

Admitting an MCP server

An MCP server is a supplier. OWASP separates two cases: a tool whose interface is manipulated at runtime (tool poisoning, under [ASI02](#)) and a tool that is malicious or compromised at the source ([ASI04](#)) [1]. ATLAS added "AI Agent Tool Poisoning" ([AML.T0110](#)) for malicious content or behaviour introduced into a tool's model-visible definition or its implementation [10]. A tool description is an instruction the model reads, so a changed description is a changed instruction. Admit a server through a gate:

1. **Provenance.** Publisher, source repository and a signed release, recorded in the [AIBOM](#) of every agent that uses it.
2. **Definition pinning.** Hash tool names, descriptions and schemas at admission; alert on change.
3. **Authorisation conformance.** MCP version, protected-resource metadata, audience validation, no token passthrough.
4. **Sandboxing for local servers.** The MCP guidance requires that a client show the exact command, without truncation, and get explicit approval before a one-click local server install, and recommends running such servers sandboxed with minimal privileges [7].
5. **Testing.** Poisoned descriptors and injected tool outputs, before any allow-list.
6. **An owner and a review date,** like any other supplier.

The [Vendor / Model Due-Diligence Gate](#) covers the commercial side: who answers when the server misbehaves, and what notice you get before it changes.

Human checkpoints and approval design

Where to put a checkpoint

The [Human-in-the-loop Gate](#) pattern says to gate by consequence. Two sources make "consequence" concrete. The Partnership on AI grades agent risk on three factors: **stakes** (the severity of potential consequences), **reversibility** (whether a failure can be undone) and **affordances** (unconstrained tool selection and persistent memory introduce more complex failure modes than constrained designs) [15]. Singapore's framework lists four kinds of checkpoint: high-stakes actions and decisions, irreversible actions, outlier or atypical behaviour, and user-defined boundaries [3].

Checkpoint class	Trigger (examples)	Who approves	Evidence
High stakes	A final decision about a person; an edit to a sensitive record	A named role with the authority to refuse	Approval record with the context shown
Irreversible	A payment, a deletion, an external message, a publication	The action's business owner	Approval bound to the exact parameters
Outlier	Access outside the usual scope; a plan twice the usual length	The on-call owner	Anomaly event and decision
User-defined	A purchase above the user's own limit	The user	Consent record
Scope elevation	A step-up request for a new scope	The agent's owner	Elevation event

What a good approval looks like

The AI Act describes the overseer the design must serve. For a high-risk system they must be able to recognise "the possible tendency of automatically relying or over-relying on the output", to "disregard, override or reverse the output", and to "interrupt the system through a 'stop' button or a similar procedure" ([Art. 14\(4\)\(b\), \(d\), \(e\)](#)) [5]. The deployer must assign oversight to people "who have the necessary competence, training and authority, as well as the necessary support" ([Art. 26\(2\)](#)) [5]. Singapore adds two practical points: keep approval requests "contextual and digestible" while making the risk clear, and "Enforce human approval through system-level controls where possible, vs prompt-layer guardrails, which may be bypassed or 'forgotten'" [3].

The threat to design against is [ASI09](#), **human-agent trust exploitation**: people over-relying on an agent's confident rationale and "approving actions without independent validation", which an attacker steering the agent can exploit [1]. ATLAS has a technique for the persuasion itself, "LLM Trusted Output Components Manipulation" ([AML.T0067](#)) [10]. The rules that follow:

1. **The gate lives outside the model.** The tool gateway holds the call until approval arrives; the prompt does not decide whether to ask.
2. **Show the call, not the story.** The approver sees the tool, the parameters and the target as the gateway will execute them, then the agent's reason, the risk and what happens on rejection.
3. **Bind the approval.** An approval is single-use and bound to a hash of the parameters; a changed amount needs a new approval.
4. **Time out closed.** No answer means no action.
5. **Measure the oversight.** Approval rate, time to decide and override rate, as [designing human oversight](#) describes.

Anti-pattern A checkpoint that fires 200 times a day on a person with other work. It becomes a rubber stamp within a week, and the approval log then launders the decisions it was meant to examine.

In practice (illustrative) A payments team found its reviewers approving almost every agent refund request within seconds. Two changes fixed it: only irreversible, high-value refunds now reach a person, which cut the volume by an order of magnitude, and the approval screen shows the raw tool call first, with the agent's explanation below it. Overrides rose from almost none to a rate worth investigating, and two of the first exposed a prompt-injection path through customer notes.

Runtime guardrails for tool calls

A runtime guardrail for an agent sits at one point: between the decision to call a tool and the call. The CSA's Autonomous Action Runtime Management (AARM) specification defines "the capabilities an agent security system must provide to govern what an AI agent is allowed to do at runtime", starting with pre-execution interception bound to identity and policy evaluation before the action runs [16]. OWASP's Agent Control Standard is a wire specification for the same point: it lets a separate guardian agent "inspect what an AI agent is about to do and permit, deny, or modify that action before it happens, over an authenticated channel, with an audit trail" [17].

The reference guardian in the ACS repository starts with a failure posture of "proceed", overridable to deny [17]. As of 2026-09-24 the repository's README also discloses that the reference guardian does not yet implement the HMAC-SHA256 envelope signature the specification requires, so its wire is unauthenticated and anything that can reach the port can read and cause decisions [17]. The fail-open default is a governance decision disguised as a setting: when the guardian is down, fail-open lets every call through unchecked and fail-closed stops the business. Decide per operation class and record it in the agent's [Policy Card](#): fail closed for pay, delete, send and execute; fail open, with an alert, only for reads.

Check	Runs	On failure
Identity matches a live registry entry	Every call	Deny
Tool on the allow-list; definition hash matches	Every call	Deny
Parameters within policy (resource in scope, amount limits)	Every call	Deny, or route to a checkpoint
Instruction provenance: did the request originate in untrusted content?	Before write-class calls	Route to a checkpoint
Output and egress filter (secrets, personal data, destinations)	After the call, before the result returns	Redact or block
Execution budgets (steps, calls, tokens, spend, time)	Continuously	Trip the breaker
Code runs only in a sandbox	Execute-class tools	Deny (ASI05)

Execution limits

Budgets are the guardrail that catches what no rule anticipated. The 2026 OWASP LLM list names "agentic architectures and tool-use protocols (such as MCP) that amplify a single request into cascading downstream operations" as an aggravating factor and recommends "hard spending caps, agent-level circuit breakers, and continuous cost-attribution monitoring" ([LLM06:2026](#)) [18]. ATLAS added "Agentic Resource Consumption" ([AML.T0034.002](#)) for attackers who coerce an agent into expensive tool calls [10], and TC260 asks for step, frequency and duration limits [6]. Put the budgets in the registry entry, enforce them at the gateway and make exhaustion trip the breaker rather than raise a ticket. The [Runtime Guardrail](#) pattern covers the mechanics; a **guardian agent**, as chapter 04 notes, is one way to build the enforcement point and needs its own identity, scope and kill switch.

Kill switch and per-agent circuit breakers

Autonomy is granted only where it can be withdrawn. The NIST AI RMF asks for mechanisms to "supersede, disengage, or deactivate" systems whose outcomes are inconsistent with intended use (MANAGE 2.4) [19]; the AI Act asks for a stop procedure ([Art. 14\(4\)\(e\)](#)) [5]; the CSA's framework puts the goal plainly: "You can stop one agent without stopping the business" [4]. The [Kill Switch / Circuit Breaker](#) pattern gives the mechanism. In operation, a stop has levels:

Stop level	Mechanism	Blast radius	Target time (illustrative)	Evidence
Pause a task	Hold at the next checkpoint, or cancel the task	One task	Seconds	Task state change
Narrow the scope	Remove one tool or scope from the allow-list	One capability of one agent	Under a minute	Policy diff
Trip the breaker	The gateway rejects every call from the agent	One agent	Seconds	Breaker event
Revoke the identity	Stop issuing credentials; revoke refresh tokens	One agent, everywhere	Bounded by credential lifetime	Revocation record
Stop a class	Breakers on every agent sharing a model, tool or prompt version	A fleet segment	Minutes	Fleet event

Stop level	Mechanism	Blast radius	Target time (illustrative)	Evidence
Degrade	Switch to advice-only or back to pilot	Behaviour, not availability	Minutes	Mode change

The last row uses the [graduated degradation](#) modes of chapter 15: "advice-only" (the agent drafts, a person acts) keeps the service while removing the autonomy. Triggers are defined in advance: a manual pull, a budget or unauthorised-call threshold, an anomaly, an upstream notice (the model vendor reports an incident) or a legal instruction.

A stop that has not been drilled is a claim. Drill it on a schedule, measure time to stop, and check that the stop held: no tool calls after the breaker tripped, no credentials issued after revocation. Chapter 17 makes the same point for [rogue behaviour](#): revoke, then verify that the revocation took effect. [Decommissioning](#) is the planned version: TC260 lists complete shutdown, data backup and environment cleanup [6]; add deleting memory under its retention rule and removing the agent from other agents' delegation lists.

Stopping across hops

You cannot stop someone else's agent. A2A's cancel operation says so: "The server will attempt to cancel the task, but success is not guaranteed" [20]. What you control is your own boundary: stop your agents from calling the remote one, and revoke what you issued to it. Short-lived delegated tokens make that revocation bounded by their lifetime; long-lived ones make it a hope.

In practice (illustrative) A kill-switch drill on a document-processing agent measured four seconds from the pull to the breaker rejecting calls, which looked like a pass. The follow-up check found long-running tasks still writing to storage twenty minutes later, on a refresh token issued before the pull. Agent refresh tokens were removed, access tokens cut to five minutes, and the drill now asserts zero writes after the pull, not only a fast breaker.

Memory and context governance

Memory turns one bad input into a lasting one. The 2026 OWASP LLM list calls this **memory persistence**: "an injection that writes to long-term memory, a RAG corpus, a vector store, or a hosted memory service taints every subsequent session that reads from that store" [18]. OWASP's agentic list has it as [ASI06 Memory & Context Poisoning](#) [1]; ATLAS has "AI Agent Context Poisoning" ([AML.T0080](#)), with sub-techniques for memory and for the chat thread [10].

Memory	What it holds	Main risk	Control	Retention
Context window	Instructions, retrieved text, tool outputs	Injection through tool output	Provenance tags; untrusted segments marked	One request
Conversation thread	One session	Thread poisoning (AML.T0080.001)	Per-session isolation	The session
Long-term memory	Facts and preferences across sessions	Memory poisoning (AML.T0080.000); personal data kept too long	Write gate; per-user namespace; time to live; erasure path	Policy-defined, per class
Retrieval corpus	Documents	Poisoned or stale sources (AML.T0099)	Source admission; entitlement check at retrieval	Per corpus version
Shared memory	State passed between agents	Cross-agent contamination	Per-task isolation; attributed writes	The task
Agent configuration	Prompts, tool settings	Tampering (AML.T0081); stored credentials (AML.T0083)	Change control; no secrets	Versioned

Five rules make memory governable. **Writes are events** that carry their source, so a poisoned entry traces back to what produced it. **Untrusted content cannot write to long-term memory** without a gate. **Memory is isolated** per user and per task, as TC260 asks, with retention windows and no credentials in memory [6]. **Retention is code**: a memory store holding personal data is subject to the GDPR's minimisation and storage-limitation principles ([Art. 5\(1\)\(c\)](#), [\(e\)](#)) and to the right to erasure ([Art. 17](#)) [21]; see [data subject rights against trained models](#). **Memory can be rolled back** to a known-good snapshot instead of being wiped.

For high-risk systems that continue to learn after deployment, the AI Act asks that they be developed to reduce "the risk of possibly biased outputs influencing input for future operations" ([Art. 15\(4\)](#)) [5]. A memory that shapes later behaviour is such a feedback path in all but name, and reading [Art. 15\(4\)](#) as covering it is the prudent course until guidance says otherwise.

Multi-agent systems and delegation chains

The Agent2Agent protocol (A2A) is an open protocol for communication between agents, first developed by Google and donated to the Linux Foundation. Version 1.0.0 was released on 12 Mar 2026 and 1.0.1 on 28 May 2026 [20]; on 27 Aug 2026 A2A was accepted as a Growth Stage project of the Agentic AI Foundation, directed by the Linux Foundation, alongside MCP [22]. Its security model gives you building blocks. An agent publishes an **Agent Card** at [/.well-known/agent-card.json](#) describing its

identity, skills, endpoint and authentication requirements; the card may be signed with JWS over a canonical JSON form; the card declares the authentication schemes the agent accepts (API keys, HTTP authentication, OAuth 2.0, OpenID Connect or mutual TLS); and the server "MUST authenticate every incoming request" [20]. Authorisation after that is, in the specification's words, "implementation-specific" [20].

What A2A does not give you is accountability. An agent that needs more authority mid-task moves the task to `TASK_STATE_AUTH_REQUIRED`, and a client that is itself an agent can pass the request up, "forming a chain of Tasks" [20]. But the specification states that it "does not define the scope, representation, validity, or revocation semantics of the authorization decision or credential obtained" [20]. The protocol moves tasks; the rules about who may authorise what, across how many hops, are yours to write.

The threats are named: `ASI07` Insecure Inter-Agent Communication, `ASI08` Cascading Failures and `ASI10` Rogue Agents [1], and ATLAS added "Autonomous AI Agent Communication" (`AML.T0118`) at the end of August 2026 [10]. The GPAI Code of Practice lists "colluding" with other AI systems and "mis-coordination or conflict" with them among the model propensities that are sources of systemic risk [23].

Accountability across hops

Property	Rule	Evidence
Originating principal	Every task carries the person or system that started it	Root of the delegation record
Actor per hop	Each agent authenticates as itself; delegation, never impersonation	Nested act claims [11]
Scope	Narrows or stays equal at each hop; never widens	Token-exchange log
Purpose	The task's purpose travels with it and is checked at each hop	Purpose field on every call
Depth and fan-out	Maximum hops and maximum parallel sub-tasks	Breaker event on breach
Trace	One trace context from the first hop to the last	Trace ID on every span
Peers	Only registered agents with verified, signed cards	Peer allow-list
Third parties	A contract names who answers for a remote agent	Clause reference in the registry

Two standards efforts address the hard part, carrying identity and authorisation context through a call chain. The OAuth working group's Transaction Tokens draft (revision 11, 30 Jul 2026, awaiting its write-up) is designed "to maintain and propagate user identity, workload identity and authorization context throughout the Call Chain within a trusted domain" [24]; the IETF's WIMSE working group (Workload Identity in Multi System Environments) covers workload identity across systems [25]. Both are unfinished as of 2026-09-24. Until they settle, the table above is the contract, enforced at each gateway you control. For third-party agents, the clauses in [contracts and licences](#) are the other half.

Prompts as configuration under change control

An agent's behaviour is set by its model, its system prompt, its tool descriptions and its policy bundle. Change any one and the behaviour changes, with no code change at all. So treat each as configuration under change control, like infrastructure code:

- 1. **Version and own it.** Prompts live in the repository, with a named owner and two reviewers.
- 2. **Hash it everywhere.** The registry records the hash, and so does every trace: the OpenTelemetry conventions carry `gen_ai.agent.version` for exactly this [26].
- 3. **Gate it.** Every change runs the regression suite (task success, injection resistance, trajectory checks) in the [Eval Gate in CI](#); a failure blocks the change.
- 4. **Roll it out and back.** Canary the change, as in [progressive delivery](#), and keep the previous hash ready to restore.
- 5. **Ask whether the purpose changed.** A prompt that changes what the system is for can be a [substantial modification](#) and, under [Article 25](#), can make the deployer the provider.

A system prompt is configuration, not a secret and not a control. The 2026 OWASP list renamed system prompt leakage to **Hidden Context Exposure** (`LLM08:2026`) and advises that "Practitioners should design under the assumption that hidden context is discoverable": no credentials in it, and no reliance on it "as a security boundary for authorization, privilege separation, policy enforcement, or content filtering" [18]. ATLAS lists both "Extract LLM System Prompt" (`AML.T0056`) and "Modify AI Agent Configuration" (`AML.T0081`) [10]. Anything that must hold goes in the gateway.

Example (illustrative) A prompt manifest that the pipeline refuses to deploy unless the eval run it names has passed.

```
# prompt manifest (illustrative)
agent: refunds-agent
artefact: system_prompt
version: 2026-09-22.1
sha256: "9f2c...e41"
```

```
owner: support-platform
reviewers: [product-owner, ai-governance-engineer]
eval_run: evals/refunds-agent/2026-09-22-1842 # must be green
rollout: { strategy: canary, share: 5%, hold_hours: 48 }
rollback_to: 2026-09-10.3
changes_intended_purpose: false
```

Anti-pattern Editing the production system prompt in a vendor console to fix a complaint. The behaviour changes, the registry and the traces still name the old version, and the next incident replays a configuration that never ran.

Agent incidents and telemetry

An agent incident taxonomy

The Partnership on AI defines the capability agents need most: "Real-time failure detection is the use of automated monitoring systems that track agent behavior as it unfolds, flag anomalies, and either halt execution or escalate to human oversight" [15]. The taxonomy below extends the [AI-specific failure modes](#) of chapter 17 for agents; the severity scale and the reporting clocks are the ones [chapter 17 sets out](#).

Class	What it looks like	Detection signal	First containment	IDs
Goal hijack	Instructions in a document redirect the task	Tool calls unrelated to the task's purpose	Pause the task; quarantine the source	ASI01 ; AML.T0051.001
Tool misuse	A permitted tool used to harmful effect	Parameters outside the registry profile	Narrow the scope; trip the breaker	ASI02 ; AML.T0053
Privilege abuse	The agent uses authority beyond its task	Audience or scope failures	Revoke the identity	ASI03 ; AML.T0098
Supply-chain compromise	A tool definition changes after admission	Definition-hash mismatch	Remove the server from allow-lists	ASI04 ; AML.T0110
Unexpected code execution	Generated code runs outside the sandbox	Sandbox violation	Kill the process; revoke	ASI05 ; AML.T0112.000
Memory poisoning	An injected "fact" persists across sessions	Memory writes from untrusted sources	Freeze and roll back the store	ASI06 ; AML.T0080
Inter-agent spoofing	An unregistered agent answers as a peer	Unknown identity; unsigned card	Block the peer	ASI07 ; AML.T0118
Cascade	One agent's error amplifies through others	Correlated failures	Break the chain at the shared component	ASI08
Trust exploitation	A misleading summary wins an approval	Mismatch between summary and call	Show raw calls; review past approvals	ASI09 ; AML.T0067
Runaway or rogue	Activity out of scope, after expiry or past budget	Calls after expiry; spend spike	Revoke; verify the stop held	ASI10 ; AML.T0034.002
Exfiltration through a tool	Data encoded into a legitimate write	Egress to an unknown destination	Block egress; trip the breaker	ASI02 ; AML.T0086

Telemetry with the OpenTelemetry GenAI conventions

The OpenTelemetry generative-AI semantic conventions now live in their own repository and are in **Development** status, so names can still change [26]. They define operations for `create_agent`, `invoke_agent`, `invoke_workflow`, `plan`, `execute_tool` and memory operations such as `search_memory` and `update_memory`. A tool span is named `execute_tool {gen_ai.tool.name}`; `gen_ai.tool.name` is required, `gen_ai.tool.call.id` recommended, and the call's arguments and result are opt-in. Agent spans carry `gen_ai.agent.id`, `gen_ai.agent.name` and `gen_ai.agent.version`, and a separate convention covers MCP (`mcp.method.name`, `mcp.session.id`) [26].

Governance needs fields the conventions do not define yet (registry ID, workload identity, policy verdict, approval ID, delegation chain): add them in your own namespace and map them later. Turning on argument and result capture may capture personal data, so it needs its own retention and access rules. And the logs are evidence: high-risk systems must record events over their lifetime ([Art. 12](#)), and deployers must keep the logs under their control for at least six months ([Art. 26\(6\)](#)) [5]. The [incident record](#) of chapter 17 is where the trace ends up.

Threats mapped to controls

The two OWASP lists divide the ground. The 2026 LLM list, published on 3 Aug 2026, says it "owns the risk when the model is a component inside your application"; once the model "becomes an actor, with tools it can call, memory it carries between sessions, and consequences it sets in motion downstream, the risk moves to the OWASP Agentic Top 10", and Excessive Agency climbed to third ([LLM03:2026](#)) [18]. The table maps each agentic threat to related LLM entries, example ATLAS techniques from the 2026-09 data release [10], a control and the pattern that implements it.

Agentic threat [1]	Related LLM 2026 [18]	Example ATLAS techniques	Control	Pattern	Layer
ASI01 Agent Goal Hijack	LLM01 Prompt Injection	AML.T0051 LLM Prompt Injection	Instruction provenance; checkpoints before writes; trajectory evals	Runtime Guardrail	03 · 04
ASI02 Tool Misuse and Exploitation	LLM03 Excessive Agency; LLM06 Unbounded Consumption	AML.T0053 AI Agent Tool Invocation; AML.T0086	Tool allow-list; per-tool rate, egress and budgets	Runtime Guardrail	04
ASI03 Identity and Privilege Abuse	LLM03 Excessive Agency	AML.T0083 ; AML.T0098 AI Agent Tool Credential Harvesting	Workload identity; short-lived delegated tokens; audience checks	Agent Identity & Scoped Credentials	04
ASI04 Agentic Supply Chain Vulnerabilities	LLM04 Supply Chain	AML.T0110 AI Agent Tool Poisoning	Server admission; definition pinning	AIBOM	02
ASI05 Unexpected Code Execution (RCE)	LLM10 Improper Output Handling	AML.T0112.000 Local AI Agent	Sandboxed execution; deny by default	Runtime Guardrail	04
ASI06 Memory & Context Poisoning	LLM05 Data and Model Poisoning; LLM09 Vector and Embedding Weaknesses	AML.T0080 AI Agent Context Poisoning	Memory write gate; namespaces; rollback	Runtime Guardrail	03 · 04
ASI07 Insecure Inter-Agent Communication	None	AML.T0118 Autonomous AI Agent Communication	Mutual authentication; signed Agent Cards; peer allow-list	Agent Identity & Scoped Credentials	04
ASI08 Cascading Failures	LLM06 Unbounded Consumption	AML.T0034.002 Agentic Resource Consumption	Depth and fan-out limits; per-agent breakers	Kill Switch / Circuit Breaker	04
ASI09 Human-Agent Trust Exploitation	LLM07 Misinformation	AML.T0067 LLM Trusted Output Components Manipulation	Raw-call approvals; oversight metrics	Human-in-the-loop Gate	04 · 05
ASI10 Rogue Agents	LLM03 Excessive Agency	AML.T0103 Deploy AI Agent	Registry with expiry; discovery; drilled kill switch	Agent Registry; Shadow-AI Discovery	02 · 04

[LLM02:2026](#) Sensitive Information Disclosure lands in the egress filter and [LLM08:2026](#) Hidden Context Exposure in the treatment of prompts. Use the ATLAS IDs to tag test cases in the [Adversarial Red-Team Suite](#), so a finding traces from technique to control to the eval that now guards it. The site's [threat bridge](#) carries the same rows as data. Mappings are illustrative, not a claim of conformity.

Frameworks written for agents

Five bodies have published agent-specific guidance, and chapter 08 already sets three of them side by side in its [agent-control table](#). Their status as of 2026-09-24:

Framework	Status	What it adds
NIST AI Agent Standards Initiative (CAISI)	Launched 17 Feb 2026; three pillars: industry-led standards, open protocols, research on agent security and identity [27]	An RFI on AI agent security and the NCCoE concept paper on agent identity and authorisation [27][8]
CSA Agentic Trust Framework and AARM	ATF v1, published in February 2026 under CC BY 4.0 [4]; AARM from a CSA working group [16]; both named in the CSA's April 2026 agentic control plane programme [28]	Zero trust for agents with earned autonomy tiers (ATF); runtime interception requirements (AARM)
IMDA Model AI Governance Framework for Agentic AI	Launched 22 Jan 2026 [29]; version 1.5 published 20 May 2026 [3]	Four dimensions: bound risks up front, make humans accountable, technical controls, end-user responsibility
TC260 AI Safety Governance Framework 3.0, Appendix 2	Voluntary; published 14 Sep 2026 [6]	Identity by decision mode, tamper-proof approval logs, memory isolation, decommissioning

Framework	Status	What it adds
OWASP Agent Control Standard	Donated to the OWASP GenAI Security Project, announced 1 Sep 2026; repository at version 0.1.2 [17]	A wire contract between an agent host and a guardian

The regulatory map also lists a proposed AICM Agentic Control Supplement from the CSA. This chapter could not match it to a CSA primary document as of 2026-09-24, so treat it as unconfirmed (verify).

Side by side, they converge on one short list: a unique identity per agent, least privilege that expires, checkpoints on irreversible actions, interception before execution, a stop that works on one agent, isolated memory and complete logs. Singapore adds end-user responsibility, the CSA earned autonomy, TC260 decommissioning. None confers conformity; they are sources of controls and vocabulary.

EU AI Act hooks for agents

The AI Act does not define "agent". An agent is an AI system, classified by its intended purpose like any other: an agent that screens job applicants is high-risk through Annex III whatever its architecture, and a scheduling assistant is not. Chapter 18 has the [high-risk requirements](#) and the [deployer duties](#) in full. The provisions below are where agent controls produce the evidence; the obligation register gives each its own page, with its dates, evidence and crosswalk: [Art. 12](#), [Art. 14](#), [Art. 15](#), [Art. 25](#), [Art. 26](#) and [Art. 50](#).

Provision	What it asks	Agent artefact	Duty holder
Art. 12	Automatic recording of events over the lifetime, to identify risk, support post-market monitoring and monitor operation [5]	Traces with identity, tool calls, verdicts and approvals	Provider
Art. 14(3) – (4)	Oversight commensurate with the level of autonomy; awareness of automation bias; override; stop [5]	Autonomy level; checkpoints; raw-call approvals; kill switch	Provider designs; deployer operates
Art. 15(4)	Resilience; reduce feedback loops in systems that keep learning [5]	Memory write gate; memory evals; rollback	Provider
Art. 15(5)	Resilience against attempts to alter use, outputs or performance, including poisoning and adversarial inputs [5]	Guardrails; server admission; red team tagged with ATLAS IDs	Provider
Art. 25	A deployer that substantially modifies a high-risk system, or changes a system's intended purpose so that it becomes high-risk, becomes its provider [5]	Change review of prompts and tools with a purpose check	Deployer
Art. 26(1) – (2) , (5) – (6)	Use per instructions; competent overseers with authority; monitor and suspend; keep logs at least six months [5]	Approver roster; breaker; log retention	Deployer
Art. 50(1)	People are told they are interacting with an AI system unless that is obvious; applies from 2 Aug 2026 [5]	Disclosure in the messages, calls and chats an agent sends	Provider
Arts. 53, 55	Documentation for downstream providers; systemic-risk assessment for the largest models [5]	The provider's documentation as due-diligence input; agentic evals in the vendor file	GPAI provider

The GPAI Code of Practice makes the agentic link explicit for providers of models with systemic risk. Its sources of systemic risk include "capabilities to operate autonomously" and "capabilities to use tools, including 'computer use'", and among the affordances "access to tools (including other AI models/systems)" and the "level of human oversight (e.g. degree of model autonomy)"; its specified systemic risks include **loss of control**, defined as "Risks from humans losing the ability to reliably direct, modify, or shut down a model" [23]. A deployer should ask how the provider evaluated autonomy and tool use at the [due-diligence gate](#); chapter 18 covers the [GPAI duties](#). The Code is a voluntary tool. Mappings are illustrative, not a claim of conformity.

What you can do this week

- Find your agents.** Run a discovery sweep that includes coding agents and local MCP server configurations, and register what you find with an owner, an autonomy level and an expiry.
- Retire one static key.** Move one agent to a short-lived workload identity, and confirm that the MCP servers it calls reject tokens issued for another audience.
- Write one allow-list as policy.** Deny by default, with definition hashes, operation classes and a checkpoint on every pay, delete, send and execute call.
- Drill the stop.** Trip the breaker on one agent, measure the time to stop, and confirm that no call or write happened afterwards.
- Version the system prompt.** Put it in the repository behind an eval gate and record its hash in the registry and in every trace.

Maps to: EU AI Act [Art. 12](#), [14\(3\)–\(4\)](#), [15\(4\)–\(5\)](#), [25](#), [26\(1\)–\(2\)](#), [26\(5\)–\(6\)](#), [50\(1\)](#), [53](#), [55](#) · GPAI Code of Practice, Safety and Security (Appendix 1.3, 1.4) · ISO/IEC 42001 (Annex A.6, A.9) · NIST AI RMF (Manage 2.4) · NIST AI Agent Standards Initiative · OWASP Agentic ASI01–ASI10 · OWASP LLM01, LLM03, LLM06, LLM08:2026 · MITRE ATLAS · IMDA Model AI Governance Framework for Agentic AI ·

Sources

[1] OWASP Top 10 for Agentic Applications 2026 (ASI01 Agent Goal Hijack; ASI02 Tool Misuse and Exploitation, per-tool least-privilege profiles, auto-approved ping tool used for DNS exfiltration; ASI03 Identity and Privilege Abuse; ASI04 Agentic Supply Chain Vulnerabilities; ASI05 Unexpected Code Execution (RCE); ASI06 Memory & Context Poisoning; ASI07 Insecure Inter-Agent Communication; ASI08 Cascading Failures; ASI09 Human-Agent Trust Exploitation; ASI10 Rogue Agents; "Least-Agency"). OWASP GenAI Security Project. 2025-12-09. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/> (verified: primary) [2] "Levels of Autonomy for AI Agents" (K. J. Kevin Feng, David W. McDonald, Amy X. Zhang; arXiv 2506.12469; five levels by user role: operator, collaborator, consultant, approver, observer; autonomy as a design decision separate from capability). Knight First Amendment Institute at Columbia University / arXiv. 2025-06-14 (v2 2025-07-28). <https://arxiv.org/abs/2506.12469> (verified: primary) [3] Model AI Governance Framework for Agentic AI, version 1.5 (published 2026-05-20; four levels of human involvement; agent identity unique, cryptographically verifiable, accounted for, differentiated by capacity, catalogued and centrally managed; authorisations scoped, time- or session-bound, non-transferable, bounded by the authorising human; significant checkpoints for high-stakes, irreversible, outlier and user-defined actions; approvals contextual and digestible; human approval enforced through system-level controls). IMDA. 2026-05-20. <https://www.imda.gov.sg/-/media/imda/files/about/emerging-tech-and-research/artificial-intelligence/mgf-for-agentic-ai.pdf> (verified: primary) [4] Agentic Trust Framework, v1 (zero-trust governance for AI agents; five elements: identity, behaviour, data governance, segmentation, incident response; autonomy tiers Intern, Junior, Senior, Principal; promotion criteria; CC BY 4.0; released February 2026). CSAI Foundation / Cloud Security Alliance. 2026-02. <https://agentictrustframework.ai/> (verified: primary) [5] Regulation (EU) 2024/1689 (AI Act), consolidated text of 2026-07-27 as amended by Regulation (EU) 2026/1744: Art. 12 record-keeping; Art. 14(3)–(4) human oversight commensurate with risks, level of autonomy and context of use, automation bias, override, "stop" button; Art. 15(4)–(5) robustness, feedback loops, cybersecurity; Art. 25 responsibilities along the value chain; Art. 26(1)–(2), (5)–(6) deployer obligations; Art. 50(1) transparency for systems interacting with natural persons; Arts. 53 and 55 GPAI providers; Art. 113 application dates as amended (Annex III high-risk from 2 December 2027, Annex I from 2 August 2028). Publications Office of the EU (EUR-Lex). 2026-07-27. <https://eur-lex.europa.eu/eli/reg/2024/1689/2026-07-27/eng> (verified: primary) [6] AI Safety Governance Framework 3.0 (人工智能安全治理框架3.0), Appendix 2 agentic AI risk management (II.2 unique identity and minimum permissions by decision mode, credentials revoked at task end; II.3 human control checkpoints, tamper-proof approval logs, deny by default when approval fails or no rule exists; II.5 execution limits, memory retention and isolation, no credentials in memory; II.7 decommissioning). TC260 / CAC. 2026-09-14. <https://www.cac.gov.cn/rootimages/uploadimg/1791137114683961/1791137114683961.pdf> (verified: primary) [7] Model Context Protocol, Security Best Practices, version 2026-07-28 (confused deputy; token passthrough "explicitly forbidden"; SSRF; state handle hijacking; local MCP server compromise, consent and sandboxing; scope minimisation and common mistakes). Model Context Protocol. 2026-07-28. https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices (verified: primary) [8] "Accelerating the Adoption of Software and AI Agent Identity and Authorization" (concept paper; "known, trusted, and properly governed"; non-repudiation, tamper-proof logging). NIST NCCoE. 2026-02-05. <https://www.nccoe.nist.gov/news-insights/new-concept-paper-identity-and-authority-software-agents> (verified: primary) [9] SPIFFE overview (Secure Production Identity Framework for Everyone; SPIFFE ID; short-lived SVIDs as X.509 or JWT delivered and rotated through the Workload API; SPIRE reference implementation). SPIFFE project. 2026. <https://spiffe.io/docs/latest/spiffe-about/overview/> (verified: primary) [10] MITRE ATLAS data, release v2026.09 (agent techniques incl. AML.T0034.002 Agentic Resource Consumption, AML.T0051 LLM Prompt Injection, AML.T0053 AI Agent Tool Invocation, AML.T0056 Extract LLM System Prompt, AML.T0067 LLM Trusted Output Components Manipulation, AML.T0080 AI Agent Context Poisoning (.000 Memory, .001 Thread), AML.T0081 Modify AI Agent Configuration, AML.T0083 Credentials from AI Agent Configuration, AML.T0086 Exfiltration via AI Agent Tool Invocation, AML.T0098 AI Agent Tool Credential Harvesting, AML.T0099 AI Agent Tool Data Poisoning, AML.T0101 Data Destruction via AI Agent Tool Invocation, AML.T0103 Deploy AI Agent, AML.T0110 AI Agent Tool Poisoning, AML.T0112.000 Local AI Agent, AML.T0118 Autonomous AI Agent Communication). MITRE. 2026-09-15. <https://github.com/mitre-atlas/atlas-data/releases/tag/v2026.09> (verified: primary) [11] RFC 8693, OAuth 2.0 Token Exchange (M. Jones, A. Nadalin, B. Campbell, J. Bradley, C. Mortimore; impersonation versus delegation semantics; "act" actor claim and nested actors; "may_act" claim). IETF. 2020-01. <https://www.rfc-editor.org/rfc/rfc8693.html> (verified: primary) [12] Model Context Protocol specification, version 2026-07-28, Authorization (optional; OAuth 2.1 resource server; RFC 9728 Protected Resource Metadata; Client ID Metadata Documents SHOULD, Dynamic Client Registration deprecated; RFC 8707 resource parameter; audience validation; no other tokens accepted or transited; RFC 9207 issuer validation; scope challenges and step-up). Model Context Protocol. 2026-07-28. <https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization> (verified: primary) [13] "Authorization changes in the 2026-07-28 specification" (RFC 9207 issuer validation; DCR "formally deprecated in favor of CIMD"; client credentials bound to the issuer that minted them; formal deprecation policy with a twelve-month minimum window). Model Context Protocol blog. 2026-07-28. <https://blog.modelcontextprotocol.io/posts/2026-07-28/> (verified: primary) [14] draft-ietf-oauth-client-id-metadata-document-02, OAuth Client ID Metadata Document (Internet-Draft, OAuth working group; a URL used as client_id that points to the client metadata). IETF. 2026-07-06. <https://datatracker.ietf.org/doc/draft-ietf-oauth-client-id-metadata-document/> (verified: primary) [15] Prioritizing Real-Time Failure Detection in AI Agents (lead author Madhulika Srikumar; stakes, reversibility and affordances; definition of real-time failure detection). Partnership on AI. 2025-09-11. <https://partnershiponai.org/resource/prioritizing-real-time-failure-detection-in-ai-agents/> (verified: primary) [16] Autonomous Action Runtime Management (AARM) specification (system category specification for agentic runtime security; pre-execution

interception with identity binding; policy evaluation before execution; core requirements R1–R6; CSA working group). Cloud Security Alliance. 2026. <https://aarm.dev/> (verified: primary) [17] Agent Control Standard (ACS) (wire specification letting a guardian agent permit, deny or modify an agent's action before it happens, over an authenticated channel, with an audit trail; reference guardian failure posture "proceed" unless overridden; README discloses that the reference guardian lacks the required HMAC-SHA256 envelope signature, open issue #70; repository github.com/GenAI-Security-Project/agent-control-standard at version 0.1.2; donated to the OWASP GenAI Security Project, announced 1 Sep 2026). OWASP GenAI Security Project. 2026-09-01. <https://genai.owasp.org/resource/agent-control-standard-ac/> (verified: primary) [18] OWASP GenAI LLM Top 10 2026 (published 3 Aug 2026; LLM01 Prompt Injection incl. memory persistence; LLM02 Sensitive Information Disclosure; LLM03 Excessive Agency; LLM04 Supply Chain; LLM05 Data and Model Poisoning; LLM06 Unbounded Consumption; LLM07 Misinformation; LLM08 Hidden Context Exposure, formerly System Prompt Leakage; LLM09 Vector and Embedding Weaknesses; LLM10 Improper Output Handling; boundary with the Agentic Top 10 stated in the preface; final text in github.com/GenAI-Security-Project/GenAI-LLM-Top10, 2026/final). OWASP GenAI Security Project. 2026-08-03. <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (verified: primary) [19] AI Risk Management Framework 1.0, NIST AI 100-1 (MANAGE 2.4: mechanisms to supersede, disengage or deactivate AI systems inconsistent with intended use). NIST. 2023-01-26. <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> (verified: primary) [20] Agent2Agent (A2A) Protocol Specification, v1.0 (releases v1.0.0 on 2026-03-12 and v1.0.1 on 2026-05-28 in github.com/a2aproject/A2A; Agent Card at [.well-known/agent-card.json](https://github.com/a2aproject/A2A/blob/main/.well-known/agent-card.json), optional JWS signature over JCS-canonicalised JSON; security schemes; servers MUST authenticate every incoming request; authorisation implementation-specific; in-task authorisation via TASK_STATE_AUTH_REQUIRED and its unspecified scope and revocation semantics; Cancel Task not guaranteed). A2A Project (Linux Foundation). 2026-05-28. <https://a2a-protocol.org/latest/specification/> (verified: primary) [21] Regulation (EU) 2016/679 (GDPR) of 27 April 2016: Art. 5(1)(c) data minimisation and 5(1)(e) storage limitation; Art. 17 right to erasure. Publications Office of the EU (EUR-Lex). 2016-04-27. <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng> (verified: primary) [22] "A New Chapter for A2A: Joining the Agentic AI Foundation" (A2A accepted as a Growth Stage project of the Linux Foundation-directed Agentic AI Foundation, alongside MCP, goose and AGENTS.md). A2A Project. 2026-08-27. <https://a2a-protocol.org/latest/blog/2026/08/27/a-new-chapter-for-a2a-joining-the-agentic-ai-foundation/> (verified: primary) [23] General-Purpose AI Code of Practice, Safety and Security chapter, Appendix 1.3 sources of systemic risk (capabilities to operate autonomously and to use tools; propensities incl. colluding and mis-coordination with other AI systems; affordances incl. access to tools and level of human oversight) and Appendix 1.4 specified systemic risks (incl. loss of control). European Commission. 2025-07-10. <https://ec.europa.eu/newsroom/dae/redirection/document/118119> (verified: primary) [24] draft-ietf-oauth-transaction-tokens-11, Transaction Tokens (Internet-Draft, OAuth working group; WG state "Waiting for Write-Up"; propagation of user identity, workload identity and authorisation context through a call chain within a trust domain). IETF. 2026-07-30. <https://datatracker.ietf.org/doc/draft-ietf-oauth-transaction-tokens/> (verified: primary) [25] Workload Identity in Multi System Environments (WIMSE) working group, charter. IETF. 2026. <https://datatracker.ietf.org/wg/wimse/about/> (verified: primary) [26] OpenTelemetry semantic conventions for generative AI (status Development; agent spans create_agent, invoke_agent, invoke_workflow, plan; execute_tool span and gen_ai.tool.* attributes, arguments and results opt-in; memory operations; gen_ai.agent.id, .name, .version; MCP conventions mcp.method.name, mcp.session.id). OpenTelemetry. 2026. <https://github.com/open-telemetry/semantic-conventions-genai/tree/main/docs/gen-ai> (verified: primary) [27] "Announcing the AI Agent Standards Initiative for Interoperable and Secure Innovation" (CAISI with ITL; three pillars; RFI on AI agent security; AI agent identity and authorization concept paper; listening sessions). NIST. 2026-02-17. <https://www.nist.gov/news-events/news/2026/02/announcing-ai-agent-standards-initiative-interoperable-and-secure> (verified: primary) [28] "Securing the Agentic Control Plane: Key Progress at the CSAI Foundation" (Agentic Trust Framework; Autonomous Action Runtime Management framework; Catastrophic Risk Annex; STAR for AI). Cloud Security Alliance. 2026-04-29. <https://cloudsecurityalliance.org/blog/2026/04/29/securing-the-agentic-control-plane-key-progress-at-the-csai-foundation> (verified: primary) [29] "Singapore Launches New Model AI Governance Framework for Agentic AI" (launched at Davos). IMDA. 2026-01-22. <https://www.imda.gov.sg/resources/press-releases-factsheets-and-speeches/press-releases/2026/new-model-ai-governance-framework-for-agentic-ai> (verified: primary) [30] WIT-SVID (SPIFFE specification; Stability: Incubating; a sub-profile of the Workload Identity Token of the IETF WIMSE working group). SPIFFE project. 2026. <https://spiffe.io/docs/latest/spiffe-specs/wit-svid/> (verified: primary)

Contributors and signatories

Authorship

Jorge García Aibar, AI Governance & Privacy Engineer. Sole author of the Body of Knowledge, website, datasets and project materials. LinkedIn: <https://www.linkedin.com/in/jorgara>

The Thesis is the sole exception. It is co-authored by Jorge García Aibar and **Aurélié Pols**, Responsible AI (EU/Global), Privacy & Data Governance (v0.1–v0.5.0). LinkedIn: <https://www.linkedin.com/in/aureliepols>

Accepted substantive contributions are credited below but do not change the authorship of the Body of Knowledge or other project materials. Home: <https://aigovernanceengineer.com> · source repository github.com/losanchos5/aige.

How to contribute

Contributors may correct or substantially revise a chapter or pattern and are credited by name. To contribute:

1. Read `STYLEGUIDE.md`. Every chapter, 00 to 23, is drafted; contributors extend and sharpen them, add patterns as files under `bok/patterns/` (STYLEGUIDE §4), or propose new chapters from `OUTLINE.md`.
2. Write it to the template. Every factual claim needs a `[n]` citation tagged `primary`, `secondary` or `reported`, with a matching row in `sources/SOURCES.md` under that chapter's section.
3. Open a pull request. Add yourself to the **Contributors** list below in the same PR.
4. Keep the voice practitioner-direct, name categories rather than vendors, and never invent a figure. Respect the BRIEF blocklist recorded in `STYLEGUIDE.md` §7.

Substantive fixes (a corrected fact, a sharper argument, a better source) are also credited, in the **Contributors** list.

Roles and credit

Three roles touch the text. None of them changes the authorship stated above unless that is expressly agreed in writing.

- **Author.** Writes and maintains the text, decides what is published in each release and answers for every claim in it. The author role is held as stated under **Authorship**.
- **Reviewer.** Reads a chapter or a dataset for a named version before it is released, against its sources and `STYLEGUIDE.md`: every claim supported by the source it cites, each source carrying the right verification tag (`primary`, `secondary` or `reported`), every "as of" date current, every mapping labelled illustrative, not a claim of conformity. A reviewer records findings as issues or pull-request review comments; the author records how each one was resolved. A reviewer discloses any commercial interest in a vendor, product or standard the reviewed text names.
- **Contributor.** Anyone whose accepted issue or pull request changes the substance of the text: a corrected fact, a new or better source, a new pattern, obligation row, glossary term or case.

How credit is given:

1. Contributors are listed under **Contributors** below, one line each: name as they wish to appear, an optional link, and what they contributed with the version it shipped in.
2. Reviewers are listed under **Reviewers** below once a review is complete, one line each: name, role or organisation (optional), what they reviewed and for which version, the date the review closed and any interest they disclosed. The line credits the review; it does not say the reviewer endorses every claim in the text.
3. Anyone may decline credit or ask to be listed by initials. Typo and formatting fixes are welcome and stay credited in the repository history rather than in these lists.
4. Signing the Thesis (below) is an endorsement, not a review, and is listed separately.

Reviewers

None yet. This list names the people who have completed a review of a chapter or dataset for a released version, in the form:

```
- Name, role / organisation (optional), reviewed chapter NN (title) for vX.Y.Z, YYYY-MM-DD, interests: none declared
```

Contributors

None yet. This section lists people who have made substantive corrections or additions.

Signatories

Signing the Thesis means you endorse *The AI Governance Engineering Thesis*: its definition, values and principles. Signatories are practitioners and organisations who support the discipline; signing does not require writing a chapter.

To sign: open a pull request that adds a line to the list below, in the form:

- Name, role / organisation (optional), LinkedIn or GitHub link (optional)

Add yourself at the end of the list. Keep it to one line. By signing you confirm you are adding your own name and that the entry contains nothing confidential.

Signatories

- Jorge García Aibar, AI Governance & Privacy Engineer, <https://www.linkedin.com/in/jorgara>

Licence

Except where otherwise noted, this work is licensed under **CC BY 4.0**. You may share and adapt it provided you give appropriate credit, link to the licence and indicate changes. Attribute the Body of Knowledge, website, datasets and project materials to Jorge García Aibar. Attribute the Thesis to Jorge García Aibar and Aurélie Pols.

Changelog

All notable changes to *AI Governance Engineering: The Thesis & Body of Knowledge* are recorded here. Versioning is semantic in spirit: patch = fact/typo fixes, minor = new chapters or patterns, major = a completed, reviewed core (1.0).

[0.5.0] - 2026-09-25

Minor release: thirteen new chapters (11 to 23) bring the book to 24 chapters in five parts; the patterns get their own pages and grow from 17 to 33; the site gains a reference layer (obligation ids and pages, glossary term pages, the harms atlas, cases, contract clauses, templates and schemas, crosswalk v2 with a clause explorer, the threat bridge), a browser toolkit of eleven tools, citable and exportable figures and posters, a static open-data API and a read-only MCP server. It folds in the pending patch of 2026-09-20 (China, authorship, no em dashes) and the fact-check pass of 2026-09-24 and 2026-09-25. The Thesis definition, values and principles are unchanged; its CC BY attribution notice is clarified and its fifth problem attributes its evidence more precisely (see Fixes).

Content

New chapters. - Chapters 11 to 22 are written in full, replacing the stubs, in three parts: foundations (11 AI defined for governance; 12 running the AI governance program; 13 where risk management sits), the lifecycle (14 governing development; 15 governing deployment and use; 16 fairness and explainability; 17 incidents, issues and root causes) and law and standards (18 the EU AI Act in one pass; 19 privacy and data protection; 20 other law that already applies to AI, covering intellectual property, non-discrimination, consumer protection, product liability and deepfakes, with a dated case table and a defect-to-evidence table; 21 AI-specific laws around the world; 22 principles, soft law and standards). - Chapter 23, **Governing AI agents**, replaces the stub. It covers what makes an agent a governance object and autonomy as a design decision (Knight Institute, IMDA and CSA scales aligned to [Art. 14\(3\)](#)), the agent registry, workload identity and short-lived credentials (SPIFFE/SPIRE, RFC 8693 delegation, the MCP authorization specification of 2026-07-28), tool allow-lists and MCP server admission, human checkpoints, runtime guardrails for tool calls with an explicit failure posture, kill-switch stop levels, memory and context governance, A2A v1.0 delegation chains and accountability across hops, prompts as configuration under change control, an agent incident taxonomy with OpenTelemetry GenAI telemetry, a threat-to-control table (OWASP Agentic 2026, OWASP GenAI LLM Top 10 2026, MITRE ATLAS v2026.09), the frameworks written for agents and the EU AI Act hooks. Sources [\[1\]](#) to [\[29\]](#), all [primary](#), as of 2026-09-24; one item marked " (verify)". - [OUTLINE.md](#) lists the 24 chapters in five parts, with a brief for chapters 11 to 23, and describes the pattern pages.

Patterns: own pages, 17 to 33. - Each of the 17 patterns of chapter 05 moved to `bok/patterns/<slug>.md` (prose unchanged; sections one heading level up, citations renumbered per page) and renders at `/patterns/<slug>` with the chapter layout: breadcrumb, its archify diagram (moved from the chapter), glossary hover cards, its own numbered sources, a "Cite this pattern" block and a pager in catalogue order. Each page adds one line under its **Maps to** line naming the OWASP Agentic and NIST AI RMF sources and the "illustrative, not a claim of conformity" notice; the "Related patterns" names link to the pages. `/patterns` is a new index of the catalogue grouped by the five stack layers. - Chapter 05 is now the catalogue: introduction, the pattern template, the pattern map and, under each unchanged `## Pattern: <name>` heading, a short summary linking to the page, so every published `/bok/patterns#pattern-*` link still lands on its pattern. Its sources are renumbered (1-5) and a new one dates the harmonised-standards remark (none referenced in the Official Journal as of 2026-09-24). The page no longer inlines 17 diagrams. - Eight development-side patterns, catalogue order 18 to 25: **Use-Case Intake & Risk Tiering**, **AI Threat Model** (STRIDE extended with MITRE ATLAS, NIST AI 100-2 and the OWASP LLM and Agentic ids), **Training-Data Rights Ledger**, **Dataset Admission Gate**, **Fairness Eval Suite**, **Explanation Artefact**, **Model Artefact Integrity** (model signing, build provenance, serialisation scanning, verification before load) and **Claims Substantiation Gate**. Four of the artefacts reuse the published schemas (`use-case-record.v1`, `dataset-admission-record.v1`, `eval-result.v1`, `evidence-record.v1`) and validate against them; the chapter 20 table no longer marks the rights ledger as proposed. - Eight deployment and use side patterns: **Decision Notice & Contest Path** (GDPR [Art. 22](#), UK Arts. 22A-22D, AI Act [Art. 26\(11\)](#) and [Art. 86](#), Regulation B adverse action), **Rights Requests Against Models**, **Sanctioned AI Gateway**, **Staged Rollout with Rollback Criteria**, **Drift & Fairness Monitor**, **Downstream Use Register**, **Disclosure & Notification Pipeline** and **Deactivation, Localisation & Retirement Runbook**. Each follows the pattern template with a `### Forces` subsection under Problem and a **Maps to** line with AI Act articles, ISO/IEC 42001 Annex A ids, NIST AI RMF subcategories and, where relevant, OWASP ids. Three artefacts are instances of the published schemas and validate against them: an evidence record (gateway decision event), a post-market monitoring plan (the deployer's monitoring plan) and a decommissioning runbook (retirement record). - Every new pattern has its own page, archify diagram, illustrative artefact, numbered sources, a `## Pattern:` section with the usual anchor in the chapter 05 catalogue and an entry in `site/src/data/patterns.ts`. Mappings are illustrative, not a claim of conformity. - Four patterns reach the deployer and operate side (no heading, slug or anchor renamed): Incident Pipeline gains issue versus incident, a severity scale mapped to the [Art. 73](#) classes, the incident record schema, RCA and CAPA, blameless review, tabletop drills and the [Art. 26\(5\)](#) deployer duties; FRIA-as-Code is generalised as Impact-Assessment-as-Code (ISO/IEC 42005 AIIA, DPIA and FRIA as views of one fact base, with re-assessment triggers as code) at the same address; the Adversarial Red-Team Suite gains the step from threat model to test plan; the Vendor / Model Due-Diligence Gate gains an operate step (change and deprecation notices, detection of unannounced change, reassessment by trigger and tier, a tested fallback). - The pattern map and the discipline map draw the new patterns (`pattern-map.svg`, `discipline-map.svg`); `site/src/data/map.ts` gains shorts for the five longest new pattern names.

Chapter 08 and the obligation register. - The register grows from 68 to 178 rows and from 31 to 76 instruments, so every obligation the new chapters teach has an id and a page: GDPR articles, NIS2, DORA, the Cyber Resilience Act, the Product Liability Directive, the DSM Directive, the DSA, the UCPD, the Platform Work and Consumer Credit Directives, Korea's AI Basic Act article by article, US state and federal law that reaches AI (California, New York, Illinois, New York City, Utah, Colorado, Virginia, Minnesota, Washington, OMB, Regulation B, the FCRA, Title VII, the FTC Act, the TAKE IT DOWN Act), Canada, Brazil, China's PIPL and anthropomorphic-interaction measures, the Council of Europe Convention, the OECD AI Principles, the G7 Hiroshima Code, ISO/IEC 42005 and 22989, NIST AI 600-1, the JTC 21 deliverables and 26 more EU AI Act articles and paragraphs (among them [Art. 86](#) and [Art. 26\(11\)](#)). Chapter 08 carries every row in its own tables, with a new section, "Data protection and other EU law", and new subsections for US state privacy and sector law, US federal law, Korea and treaty and soft law; its new sources, numbered 63 to 116, were verified on 2026-09-24. - A **China** subsection under "Other jurisdictions": the two-tier picture (four binding CAC rules on algorithmic recommendation, deep synthesis, generative AI services and AI-content labelling, plus the mandatory standard GB 45438-2025; the voluntary GB/T 45654-2025 and the TC260 **AI Safety Governance Framework 3.0**), a seven-row obligation-to-artefact table stamped "as of 2026-09-20", and a crosswalk of the framework's **Appendix 2** (agentic AI risk management) against the OWASP Top 10 for Agentic Applications 2026 and the NIST AI Agent Standards Initiative. A new "What is NOT harmonised yet" bullet notes that the TC260 framework cross-references neither the Western instruments nor China's own binding rules. Sources [\[41\]](#) – [\[51\]](#) (ten [primary](#), one [reported](#)). - Dates: the rows carry the dates chapter 08 states in prose but no row held (Annex I embedded systems from 2028-08-02 and legacy high-risk systems intended for public authorities by 2030-08-02, [Art. 111\(2\)](#), as later milestones on the high-risk rows); the GPAI rows ([Art. 52](#) to [Art. 55](#)) gain the 2 August 2027 milestone of [Art. 111\(3\)](#) for models placed on the market before 2 August 2025, and chapter 08 states it; the [Art. 4](#) row applies since 2025-02-02 (Chapter I, [Art. 113\(a\)](#)), reworded by the Digital Omnibus on 2026-07-27, in line with chapter 12. - The Article 73 clock table counts the 15-, 2- and 10-day outer deadlines from awareness, with the immediate duty on a causal link, and names the deployer when it cannot reach the provider ([Art. 26\(5\)](#)); [Art. 75\(1a\)](#) and the scope of [Arts. 75a](#) to [75d](#) are stated precisely; Omnibus precisions for [Art. 6](#) and [Art. 25](#) are added in prose; the EU AI Act lead states the amended [Art. 113\(c\)](#) and how the map dates the high-risk duties that sit outside Chapter III; a pointer to chapter 18 opens the EU section. - Rows and pointers: the CSA row that named an "Agentic Control Supplement" now names what the CSA has published (the AICM agent controls, the Agentic Trust Framework and AARM), because the supplement could not be matched to a primary document; STAR for AI lists its three levels; the agent-control table uses OWASP's official ASI names; the Korea row cites the Act and Enforcement Decree on law.go.kr (primary, [\[34\]](#)) with the MSIT guidance period; the Colorado row describes SB 26-189; the China paragraph and the US section point to chapter 21; "What is NOT harmonised yet" gives the JTC 21 stages as of 2026-09-24; the NIST AI RMF section notes that 1.0 "is being revised". Sources [\[57\]](#) to [\[63\]](#) added. No H2 or H3 renamed.

Glossary. - The glossary grows from 63 to 322 terms, covering every term chapters 11 to 23 define plus the core vocabulary of the EU AI Act, risk, privacy, fairness, incidents and generative AI. Every entry is at most 60 words, cites its source when it comes from a law, a standard or a paper, names the terms it is most often confused with ("Contrast with") and links the exact section that develops it ("See"). Letter headings and a "Commonly confused pairs" table (ten pairs, from transparency versus explainability to provider versus deployer) are new. "Serious incident" carries the four limbs of AI Act [Art. 3\(49\)](#) and points to chapter 17; "Model risk management" records that SR 26-2 superseded SR 11-7 on 17 Apr 2026. Sources grow from 19 to 142.

Integration across the book. - Chapters 11 to 23 are woven into the rest of the book: [site/src/data/chapters.ts](#) carries a one-sentence summary and an "at a glance" block for chapter 02 and each new chapter; "Key terms in this chapter" ([keyTerms](#), five to ten glossary slugs per chapter but the glossary) renders under "At a glance" with the same hover cards as the prose, and the build fails on a slug the glossary does not define. - Chapters link to each other by section: chapters 01 to 04, 06 to 08 and 11 to 22 gain deep links to the sections that develop each topic, and every remaining chapter-to-chapter link without an anchor in chapters 04, 06 and 11 to 23 points at the section that treats the topic (whole-chapter orientation references aside), including chapter 23 to chapters 11, 15 and 21 and to the obligation pages of Arts. 12, 14, 15, 25, 26 and 50; chapters 04, 11, 14, 15, 17 and 21 to the matching sections of chapter 23; chapter 07 to the maturity self-check; chapters 14, 15 and 16 to their tool categories; chapter 22 to the crosswalk explorer. Chapters 01, 02, 03, 06 and 07 link the later chapters where they first introduce a topic now taught in depth (risk, the lifecycle, fairness, incidents, the EU AI Act, privacy, agents), one link per topic, and chapters link the harms atlas, the cases and the templates page. - Links to a pattern point at its own page ([/patterns/<slug>](#)) instead of its catalogue anchor, which still resolves; chapters 11 to 23 link the new pattern pages from the sentences that already describe the practice (for example the downstream use register and the retirement runbook in chapter 15, the contest path and the fulfilment record in chapter 19, the gateway in chapter 12), with the prose unchanged. - "What you can do this week" closes chapters 04, 06 and 07, five concrete actions each, as in the chapters from 11 on. The preface routes each audience into the book (governance leads, security, privacy, MLOps, risk leads and CISOs, executives and boards, lawyers, the public sector, small organisations) and gains a "How to use this book" section on the five parts. - Chapter 14 opens with an interactive diagram of the build as a chain of gates: intake, design review, dataset admission, eval gate and release gate, each named with the pattern the chapter ties to it, ending in the technical file the pipeline compiles.

Sources, references and wording. - SR 11-7 superseded: chapters 01 and 02 and [STYLEGUIDE.md](#) section 10 say that SR 26-2 (Federal Reserve, OCC and FDIC, 17 Apr 2026) replaced SR 11-7 and leaves generative and agentic AI models out of its scope; [STYLEGUIDE.md](#) gains a "Superseded references" rule (SR 26-2, ISO 31073:2022, ISO 9001:2026, ISO/IEC 27701:2025). - Source integrity sweep over chapters 11 to 23: the 64 entries that cited the Future of Life Institute's AI Act Explorer for EU legal text, 57 of them tagged [primary](#), cite EUR-Lex: the consolidated text of Regulation (EU) 2024/1689 of 2026-07-27 with the article or annex

anchor (`#art_<n>` , `#anx_<n>`), or the Official Journal text with the recital anchor (`#rct_<n>`) for recitals, which the consolidated text does not reproduce. Each gloss was checked against the provision as amended by the Digital Omnibus; chapter 14's Art. 72 entry gives the amended wording (Commission guidance with a template by 2 Sep 2027), and its source on monetisation and the open-source exemption cites the Commission's GPAI guidelines (C(2025) 7719 final, paras 82 to 84) instead of a third-party overview. - Unofficial reproductions no longer stand in for the official text: seven US Code and CFR entries in chapter 20 tagged `primary` on the Legal Information Institute cite GovInfo (United States Code, 2024 edition) or the eCFR; two in chapter 16 and the GDPR entries of chapters 11 and 15 (gdpr-info.eu) move from `secondary` to the official text. - `sources/SOURCES.md` gains sections for chapters 11 to 23, the pattern pages (the public AIGP Body of Knowledge v2.1 cited by competency code IV.C, paraphrased, with a note that the site is not affiliated with or endorsed by IAPP), a "Site data pages" part (harms atlas, cases, templates), rows 62-159 for chapter 10 and a short tool-catalogue section, and rows for the new sources of chapters 01, 02 and 08. - Typography: no em dashes anywhere in the published text. Every one in the Thesis (EN and ES), the chapters, this changelog, the site copy, the diagrams and the figures became a comma pair, a colon, a semicolon, a full stop or parentheses; the wording and meaning are unchanged. Anchors that changed with a heading: the five `#layer-0N-...` sections of chapter 04 (links updated) and these changelog headings. `STYLEGUIDE.md` states the rule. - Authorship and CC BY attribution are explicit by scope: Jorge García Aibar is the sole author of the Body of Knowledge, website, datasets and project materials; the Thesis remains co-authored by Jorge García Aibar and Aurélie Pols. Chapter citations, BibTeX, JSON-LD, dataset metadata, `CITATION.cff`, contribution guidance and the downloadable PDF follow that distinction. `bok/CONTRIBUTORS.md` defines the author, reviewer and contributor roles and how reviewers are credited.

Reference layer

- **Obligations** (`site/src/data/frameworks.ts` , `/obligations` , `/obligations/<id>`): every row of the regulatory map carries a stable id of the form `AIGE-OBL-<INSTRUMENT>-<CLAUSE>` (for example `AIGE-OBL-EUAIA-ART9`), assigned once and never reused; a removed row's id stays reserved. Each page shows the clause, the duty holder, the application date with its status and later dates, the artefact, the layers, the patterns, the crosswalk siblings, the cases that cite the same EU AI Act article, the chapter 08 section it comes from, its review date, its JSON and a citation block; it opens with the obligation-to-evidence chain generated from its row (clause, duty holder, date, artefact, layer and the record schema its evidence is filed as, with the crosswalk siblings and "As of" in the image) and has its own Open Graph card (`/og/obligations/<id>.png`). The sitemap dates these pages by the row's review date.
- The obligation heat matrix on `/resources/frameworks` joins each row to its instrument by `frameworkId` . A "What applies now" band on the home page shows the EU AI Act articles that already apply and the next three dates with what each switches on, computed from the register at build and linked to each `/obligations/<id>` , so a date drops out on the first build after it passes.
- **Glossary term pages**: every term has its own canonical page at `/glossary/<term>` with its definition and numbered sources, the sections that develop it, the chapters that use it, contrast cards, related terms and a "Cite this term" block. `/bok/glossary` stays the book index (each term anchored and linked to its page); `/resources/glossary` and `/glossary` redirect to it; hover cards and `/glossary.json` point at the term pages.
- **Harms atlas** (`/resources/harms` , `site/src/data/harms.ts`): harms by level, type, mechanism, failure mode, controlling pattern and stack layers, with verified example incidents (AIID, AIAAIC, OECD AIM) and the domain and subdomain of the MIT AI Risk Repository taxonomy (CC BY 4.0, attributed); a level filter in pure CSS and a JSON export.
- **Cases** (`/cases` , `/cases/<id>` , `site/src/data/cases.ts`): eleven publicly documented cases, each verified against primary sources (judgments, regulators, official reports, the original article) or marked `reported` where only the press covers it, and linked to its AIID (or AIAAIC or OECD AIM) record, with numbered sources.
- **Contract clauses** (`/resources/contracts` , `site/src/data/contracts.ts`): the 18 clauses to check before deploying a third-party AI system (what each governs, the red flag, a fallback position and the evidence to keep) and six licence types, introduced with chapter 15; the vendor due-diligence tool reuses its checklist.
- **Templates and schemas** (`/resources/templates`): a library of JSON Schemas (draft 2020-12) under `/schemas/` with `$id` , required fields and `x-evidences` (obligation ids), `x-layer` , `x-pattern` and `x-lifecycle-stage` annotations, 23 in v1 counting the model card and classification decision record added by the toolkit; one filled example per schema that validates; human templates with the same fields; and a policy kit (`ai-policy.yaml` as the single source with its prose and Rego views, a committee charter, a RACI, a policy gap assessment, a literacy curriculum and the contract-clause checklist), all original. `site/scripts/schemas-check.mjs` validates them at build and the chapter 05 shapes against them.
- **Crosswalk v2** (`site/src/data/crosswalk.ts` , `/resources/crosswalk`): 25 topics (the twelve v0.4 topics keep their ids and `#topic-<id>` anchors; new: prohibited practices, fairness and non-discrimination, privacy and data protection, explainability and right to explanation, AI literacy and competence, conformity assessment and certification, GPAI and foundation models, IP and copyright, agent identity and autonomy, content provenance and deepfakes, sandboxes and real-world testing, environmental impact, deployment, change and decommissioning) and 14 columns (new: GPAI Code of Practice, GDPR, ISO/IEC 42005 · 23894 · 42006, CSA AICM by control id, OWASP LLM 2026 and Agentic 2026 ids, Korea AI Basic Act, United Kingdom (UK GDPR Arts. 22A to 22D and ATRS v4.0), Singapore (generative and agentic frameworks), treaty and soft law (CoE CETS No. 225, OECD, G7 Code), CEN-CENELEC). 493 references, every `crosswalk` entry of the chapter 11 to 22 and harms-atlas handoffs

included; each keeps `strength`, an honest `verified` flag (28 stay unverified with a note: ISO/IEC clauses whose text could not be opened, the preN drafts and two GDPR articles read only secondarily) and a URL; references checked as of 2026-09-24. Obligation rows join by `obligationId` and link `/obligations/<id>`.

- A column chooser on the crosswalk grid (the four v0.4 columns by default, any other on demand, remembered per browser, every column without JavaScript) and a clause-to-clause explorer (`/resources/crosswalk#explore`, `public/crosswalk-explorer.js`): source frameworks and a target side by side per topic, a gap view (target clauses no chosen source reaches), topic and verified-only filters, a shareable URL fragment, and downloads of the selection as CSV, JSON and an OSCAL 1.2.3 mapping collection (NIST Control Mapping model; relationship `intersects-with`, gap summaries). Every export says "illustrative, not a claim of conformity" inside the file.
- **Threat bridge** (`/resources/threats`, `site/src/data/threats.ts`): 51 threats keyed by the ids their catalogues give them (the ten `LLM01:2026` to `LLM10:2026` entries of the OWASP Top 10 for LLM Applications 2026 with their 2025 ids, `ASI01` to `ASI10` of the OWASP Top 10 for Agentic Applications 2026, 18 MITRE ATLAS techniques from data release v2026.09 with the mitigations ATLAS links to them, and 13 NISTAML attack classes of NIST AI 100-2 E2025). Each row names the patterns that control the threat, an example eval (an Inspect task, a promptfoo plugin, a garak probe, or a test to write where none ships one), the obligation ids its evidence helps satisfy, and ISO/IEC 42001 Annex A ids, CSA AICM v1.1 domains, NIST SP 800-218A tasks and NIST COSAIS use cases. Catalogue and layer filters work without JavaScript; the build fails on any broken reference. Illustrative, not a claim of conformity; versions checked on 2026-09-24.
- **Tool catalogue** (`site/src/data/stack.ts`, `/resources/tools`): one typed registry. Every tool carries a checked URL, its licence (SPDX identifier where one exists), an access model (open source, open standard, source-available, commercial, free service), its layers, `lastChecked` 2026-09-24 and, for 22 tools, its OECD.AI Catalogue of Tools & Metrics entry. Seven categories the new chapters cite (data validation and quality; data and experiment versioning; fairness toolkits; explainability libraries; ML and LLM monitoring and drift; progressive delivery and feature flags; model signing and artefact scanning), two policy-as-code categories that cover the learning-path tools (Conftest, OPA Gatekeeper, Kyverno, the Rego Playground) and a curated indexes group: 96 tools in 31 categories. The page is titled "Tool categories" and filters by layer and licence (`public/catalogue-filter.js`, CSP-safe, progressive enhancement); the per-layer categories on `/stack` and `/map` derive from the same registry. The kill switch and circuit breaker examples became named tools (Unleash, Envoy, Resilience4j); workload identity stays under Agent workload identity (SPIFFE/SPIRE); mcp-scan is listed under its current name, Snyk Agent Scan.
- **Reading list** (`bok/10-reading-list.md`, `/resources/reading-list`): 98 new entries (books, courses, canonical papers, regulator guidance and every entry the chapter handoffs proposed, without duplicates), for 162 in 16 themes. Every entry carries audience and jurisdiction tags; the resources view filters on both. The eight existing section headings are unchanged.
- **AIGP coverage map** (`/for/aigp`, `site/src/data/aigp.ts`): the four domains, 13 competencies and 58 performance indicators of the public AIGP Body of Knowledge v2.1 (effective 2026-02-02), each indicator under a positional id with this site's own paraphrase of at most 12 words, the sections, patterns, glossary terms, templates and tools that teach it, and a status on the house criterion (taught, or partly taught with what is missing). A heatmap generated at build shows the whole map; a study path per domain keeps its ticks in the browser only. Every mapped link is resolved at build and the build fails on one that does not exist. No overall score. It carries the notice that AIGP is a registered trademark of the IAPP, that this site is not affiliated with or endorsed by the IAPP, and that the map covers an open body of knowledge and is not exam preparation.
- **Certifications, neutrally** (`/for/certifications`): who owns AIGP, the ISO/IEC 42001 Lead Implementer and Lead Auditor schemes, ISACA AAISM and AAIA, what each owner says the scheme assesses, and how this body of knowledge relates to each, from the owners' own pages, ISO and EUR-Lex (checked 2026-09-24), in line with chapter 06 on certifications as a proxy for capability.
- **Audience hubs** (`/for`, `site/src/data/audiences.ts`): one route through the site for each of six audiences (engineers, CISOs and risk leads, legal counsel and DPOs, executives and boards, the public sector, SMEs and start-ups). Each hub names who it is for, answers the three questions that audience brings with numbered sources and a link to the section that answers it in full, walks chapters, patterns, tools, templates, datasets, figures and cases in reading order, lists "start this week" actions and the obligations that matter most, with status and dates read from the register. The build fails on a broken anchor, an unknown pattern, figure, case, path node or obligation, or an uncited source; a toolkit tool appears on a route only once the toolkit lists it as live. Illustrative, not a claim of conformity.
- **/agents**: a practitioner landing for agent governance with the control plane, the six agent patterns, the ten agentic threats with their controls, the chapter 08 cross-references and the runtime tool categories.
- **Navigation and hubs**. The Body of Knowledge menu, the mobile drawer, the footer site map and the chapter rail group the chapters by the five parts of the book (the discipline, reference, foundations, the lifecycle, law and standards), each with its chapter range, counted from the chapter manifest (`site/src/data/parts.ts`). The navigation reaches every v0.5.0 destination (Practice: Patterns, Toolkit, Agents; Reference: Obligations, Figures, Open data & API, Harms atlas, Cases, Contracts, Templates & schemas and the glossary at `/bok/glossary`, which also lights `/glossary/<slug>`; About: Methodology). The home presents the five parts (title and counts computed, no more "Eleven chapters"), adds the topic crosswalk, the map, the templates and the harms atlas to its resource tiles and a newsletter section before the closing band; the `/bok` index groups the chapter cards by part, with a one-line introduction and a jump list, and the three reading paths run through chapters 11 to 18; `/resources` lists

ten references, each with a count computed from its data. `/resources/reading-list` and `/resources/glossary` declare their canonical page and leave the sitemap.

- **Methodology** (`/about/methodology`): how sources are chosen and tagged, how "as of" dates are kept, the review cadence, what the build checks, how corrections and contributions work, and versioning with DOIs.

Toolkit

- **Foundation** (`/toolkit`): a registry of browser tools built from the Body of Knowledge (`site/src/data/toolkit.ts`), a shared `ToolShell` component with the fixed notice "Indicative, not legal advice and not a conformity claim. Nothing you enter leaves your browser.", a no-JS worksheet mode and print styles, and dependency-free client helpers (`site/public/toolkit/lib.js`: state in the URL fragment, safe storage, JSON, CSV per RFC 4180, Markdown and iCalendar per RFC 5545 downloads, clipboard, SVG to PNG through a `data: URL`); `form-kit.js` (form to fragment and back, accessible error summary, UTC date arithmetic), `builders.js` (the schema subset validator, YAML and CSV) and `schema-form.js` (accessible forms from field specs); `ToolTerms`, `ToolSourceList` and `site/src/lib/tool-anchors.ts`, which fails the build when a chapter heading a tool links to is renamed. Each live tool has its own Open Graph card (`/og/toolkit/<id>.png`). No new dependency and no change to the content security policy. Eleven tools are live:
- **Maturity self-check** (`/toolkit/maturity-self-check`): pick, per stack layer, the highest observable criterion of chapter 07 met today; get the ragged per-layer profile drawn in SVG, the floor and the single next move with its metrics, checklist questions and pattern link. Exports a re-importable JSON profile (`/toolkit/maturity-profile.v1.schema.json`), a Markdown report and an SVG or PNG image; saves profiles in the browser and compares two. `site/src/data/maturity.ts` gains the chapter's criteria table, metrics per level, checklist and typical failures as data (additive; no heading changed).
- **Obligations and deadlines planner** (`/toolkit/obligations-planner`): tick your roles in the EU AI Act value chain (provider, deployer, importer, distributor, authorised representative, GPAI model provider, with or without systemic risk), the system classes (Annex III, Annex I, Article 50) and an optional reference date; get the rows of the register that bind you, each with its artefact, layer, patterns, the date it applies for your classes and its status on your date, plus a timeline and, apart, the importer, distributor and authorised-representative duties the register does not hold as rows (Arts. 22, 23, 24 and 54, from the consolidated text). Exports a Markdown checklist, a CSV, a JSON in the open-data envelope (`/toolkit/obligations-plan.v1.schema.json`) and an `.ics` calendar. The role mapping lives in `site/src/data/obligations-planner.ts`; no register date is restated.
- **EU AI Act role and risk-class triage** (`/toolkit/ai-act-triage`): a versioned question graph (`site/src/data/triage.ts`, question set 1.0.0 as of 2026-09-24, 20 questions in seven steps) that walks an AI system or model through chapter 18: reach (`Art. 2(1)`), the `Art. 3(1)` definition, the `Art. 2` exclusions, the `Art. 25(1)` triggers, the `Art. 5` screen with the Omnibus points (ba) and (bb) from 2026-12-02, `Art. 6(1)` with the narrowed safety component, the eight Annex III areas, the `Art. 6(3)` filter and the profiling override, the `Art. 50` cases and the GPAI track with the 10^{25} FLOP presumption. It returns indicative scope, EU roles and risk classes with the reason and article behind each, the date each class applies from, open points and the meaning of every answer; never a conformity verdict. Every question and rule cites verbatim fragments of chapter 18 and the build fails if one leaves the chapter. Exports a classification decision record in JSON and YAML (new schema `/schemas/classification-decision-record.v1.json`, with a filled example and a human template), a Markdown report and a link that opens the planner with the roles and classes; records re-open with the outcome recomputed. The pure engine (`site/public/toolkit/ai-act-triage-engine.js`) holds no legal logic of its own.
- **Policy Card builder** (`/toolkit/policy-card`): pick one of six governance rules (no unregistered agent in production; an eval score at or above a threshold before deploy; no personal data sent to an external model; human approval for a named tool; a model card present before release; an expired exception blocks the build) or write one condition of your own, then set the owner, scope, review date and the obligation ids the rule answers. The page builds the Policy Card in Markdown, YAML and JSON (valid against `policy-card.v1.json`, checked in the browser), an OPA/Rego module in Rego v1 syntax with a verdict rule and unit tests, a Cedar stub with tests, an example input and a GitHub Actions CI hook, all marked "Illustrative, review before use". The default card of each rule is published under `/templates/policy-cards/`, generated by the same code (`site/scripts/policy-card-samples.mjs`) and checked with `opa check --strict` and `opa test` (OPA 1.21.0) and `cedar run-tests` (cedar-policy-cli 4.13.0).
- **AI register entry builder** (`/toolkit/ai-register-entry`): build AI system and agent register entries that validate against the published schemas, keep a register in the browser, import and export it in bulk as JSON or CSV (RFC 4180, round trip without loss), download a Markdown public summary without the internal fields, and read a field crosswalk (UK ATRS template v4.0, Canada AIA questionnaire, EU database Annex VIII Sections A to C after the Digital Omnibus, model card, ISO/IEC 42001 SoA columns marked "verify"): field names only, so one source record feeds each regime.
- **Impact assessment builder** (`/toolkit/impact-assessment`): one record for a FRIA (the six elements of `Art. 27(1)`), an AI system impact assessment (elements by ISO/IEC 42005 clause id, ids from the DIS, marked "verify") or an AI addendum to a DPIA (`Art. 35(7)` plus the AI-specific fields); every risk has an id and every measure names the risks it addresses, the pattern that implements it and its controls; a risk-to-measure matrix flags loose ends; re-open triggers are part of the record; JSON, YAML and Markdown exports.

- **Model card builder** (`/toolkit/model-card`) and a new schema `model-card.v1.json` (with its example and human template): an obligation coverage checklist (`Art. 11` with Annex IV and `Art. 13(3)` for high-risk systems, `Art. 53(1)` for GPAI models, ISO/IEC 42001 Annex A, NIST AI RMF MAP and MEASURE), each item linked to its obligation page; exports to a Hugging Face style card (YAML front matter and the Hub template's headings) and a CycloneDX 1.7 ML-BOM that validates against the official schema.
- The register entry and impact assessment schemas gain optional fields only (`public_record` , `iso42005_sections` , `risks[].id` , `mitigations[].pattern` , `mitigations[].controls`): every v1 record written before still validates.
- **Vendor due-diligence request** (`/toolkit/vendor-due-diligence`): supply type, use tier, data sensitivity, autonomy and tool access, jurisdictions and sector give a risk tier with its reasons and a tiered, evidence-first request of 20 to 40 questions in the site's own wording (model or system card, AIBOM, evaluation and red-team reports, incident-notice SLA, training-content summary, copyright policy, sub-processors and more), each cross-referenced to crosswalk topics and to CSA AICM control ids the crosswalk already carries, plus the contract-clause checklist. Exports Markdown, CSV and a response record (JSON, `vendor-due-diligence-response.v1`).
- **Incident clock** (`/toolkit/incident-clock`): from the awareness time, roles, system tier and facts, the incident class on chapter 17's severity scale and every clock the chapter states (EU AI Act `Art. 73`, `Art. 26(5)` and `Art. 55(1)(c)` with the GPAI Code of Practice, GDPR `Arts. 33` and `34`, NIS2 `Art. 23`, DORA `Art. 19` with RTS 2025/301) as calendar dates, with who reports to whom, a prominent "verify with counsel or the authority" notice, `.ics` reminders, a Markdown summary and an incident record skeleton (JSON, `incident-record.v1`). The tool never asserts more than the chapter: it applies no period-counting rules and does not decide reportability.
- **Agent control profile** (`/toolkit/agent-control-profile`): describe one agent (autonomy, tools and MCP servers with operation class and scope, data classes, memory, external actions, identity model, approval points) and get the minimum control set of chapter 23 with the pattern behind each control, the gaps to close, an agent register entry (JSON, `agent-register-entry.v1`) and a checklist (Markdown and CSV).
- **Fairness metric chooser** (`/toolkit/fairness-metric-chooser`): the questions chapter 16 says decide the metric (harm type, ground truth, costlier error, legal frame, access to the protected attribute) give the primary metric families, secondary checks, warnings and legal notes, each linked to its chapter 16 section; metrics that depend on an unreliable label are deferred, not dropped. Exports Markdown and JSON.

Figures

- Figures are citable and reusable: a `/figures` gallery grouped by part and chapter (the infographics and the interactive diagrams) and a `/figures/<id>` permalink per infographic with its text alternative, where it appears, downloads, HTML and Markdown embed snippets with the full CC BY credit, a citation with BibTeX and `ImageObject` structured data. Every infographic caption carries a `#figure-<id>` anchor and a link to its figure page.
- Every figure is exported at build as a standalone SVG (light and dark by colour scheme, plus fixed light and dark) and as light and dark PNGs at 1600 and 3200 px, drawn with the site's typefaces, each with the band "aigovernanceengineer.com · CC BY 4.0 · v" and a versioned file name under `/downloads/figures/` . Figure entries gain `asOf` , `reviewBy` , `license` , `kind` , `pages` and a `data` table fallback; a dated figure prints "As of" inside the image (the Article 73 clock reads "As of 2026-09-24"), and the build checks budgets, dates and the stamp.
- Concept figures for the new chapters, each drawn only from what its chapter or data module states, with a text description and a permalink: the agent control plane (chapter 23 and `/agents#control-plane` : registry, identity issuer, tool gateway, runtime guardrail with its failure posture, human checkpoint, per-agent breaker with its six stop levels, the boundary a kill switch cannot cross, telemetry kept as evidence), the governance operating model (chapter 12: board, committee, the three lines and where the AI governance engineer sits), harm at five levels (chapter 13, from the harms atlas), the explanation technique map (chapter 16), how the instruments relate (chapter 22 and `/resources/frameworks` , dated as of 2026-09-24) and AI laws by jurisdiction (chapter 21: a tile map from the jurisdictions dataset, shaded by status, with its table, dated as of 2026-09-24).
- Eleven new figures for existing content, drawn only from what the chapters already state: the five objects of governance (chapter 01), the profession in numbers (02), human oversight designed and where control moves when you buy AI (04), who enforces and the penalty ceilings (08), the committee decides and the gates enforce (12), the risk loop on the stack, the likelihood-by-severity matrix with the S5 override and the mitigation ladder (13), provenance and lineage (14) and the overlapping incident clocks (17). Each has a text description under it.
- Four reference posters, generated at build from the data and printable at any A size (portrait, 1 : √2): the EU AI Act timeline after the Digital Omnibus, one lane per obligation family from 2024 to 2030 (chapters 18 and 08, from the register); the operator roles, seven questions leading to each role with its duties, its evidence and the Article 25 loop (chapter 18); the risk ladder with the Annex I and Annex III routes, the Article 6(3) filter, the GPAI track and notes on Korea, Texas, California and Colorado (chapters 18 and 21); and the model-type by deployment-option matrix (chapter 15). Each carries "As of 2026-09-24" inside the image, sits at the head of its section in a scrollable, labelled region and links to its permalink with SVG and PNG downloads; the timeline and the matrix also publish their data as a table. Spanish editions of the timeline, the roles and the ladder (`/figures/eu-ai-act-timeline-es` , `/figures/eu-ai-act-operator-roles-es` , `/figures/eu-ai-act-risk-ladder-es`) use

the terms of the Spanish text of the Act and the stamp "A fecha de 2026-09-24"; they are listed on `/figures`, not placed in the English chapters.

- Diagrams: the Framework Crosswalk is drawn as one hub with five spokes and evidence on the hub; the Vendor / Model Due-Diligence Gate puts the registry entry straight under the gate and the rejection path last; the Runtime Guardrail keeps its assurance store outside the runtime layer; the Kill Switch greys the revoked agent while the rest of the fleet runs on. The regulatory wave in chapter 02 gains the 2 Dec 2026 stage (new Article 5 bans and Article 50(2) marking) and the 2 Aug 2030 stage (legacy high-risk systems of public authorities).
- `site/VISUAL-GUIDE.md` adds rules for data visualisation, posters and exports, and interactive widgets.

Data and API

- A static open-data API under `/api/v1/`: a catalogue (`index.json`), one file per dataset (obligations, frameworks, crosswalk, glossary, patterns, maturity, path, chapters, jurisdictions, harms, cases, contracts, roles, threats), one file per obligation, an OpenAPI 3.1 description and a JSON Schema (draft 2020-12) per document, all with the same notice, licence and DOI envelope; `/resources/data` documents the endpoints, the id rule, the versioning and stability promise and how to cite. `_headers` opens CORS and sets a one-hour cache on the API and the existing downloads, and serves `/schemas/*` as `application/schema+json`; the Content-Security-Policy is unchanged.
- `/resources/obligations.json` and `/resources/obligations.csv` move to `schemaVersion 2` at the same URLs. `appliesFrom` is an ISO date (or `null` for voluntary instruments without one) and the former free text moved to `appliesNote`; each row gains `id`, `url`, `json`, `frameworkId`, `clause`, `requirement`, `appliesStatus`, `milestones`, `systemClass`, `patterns`, `crosswalkTopics`, `authority`, `scope` and `reviewed`. The CSV keeps its first seven columns in place and appends the new ones.
- `/resources/crosswalk.json` and `/resources/crosswalk.csv` move to schema version 2 at the same URLs: the JSON adds `schemaVersion`, `asOf`, `columns`, `frameworks`, `topic` read links and, per reference, `clauseId`, `column`, `frameworkShort`, `see`, `obligationId` and `obligationUrl`; the CSV keeps its nine columns in order and appends topic, framework, column and clause ids, the BoK section and an `Obligation ID` column.
- `/api/v1/threats.json` (with its schema) and `/resources/threats.csv`; `/resources/harms.json`.
- The citation block serves any page (`kind`: chapter, obligation, figure, dataset or page); chapters keep their existing reference and BibTeX.
- `/llms.txt` lists every v0.5.0 destination with counts taken from the data (`/patterns` and every pattern page, the harms atlas, the cases, the templates and the contract clauses among them); `/llms-full.txt` carries the 24 chapters in reading order with every pattern page in full right after chapter 05, then the Thesis.
- The PDF build (`build/build_pdf.py`) prints every chapter file (00 to the last) and assembles chapter 05 with the full text of every pattern in place of the catalogue summaries.
- A read-only remote MCP server over the open data (`tools/mcp-server/`, to be deployed at `https://mcp.aigovernanceengineer.com/mcp`): ten tools (`search_glossary`, `get_term`, `get_obligations`, `get_obligation`, `map_clause`, `list_patterns`, `get_pattern`, `list_templates`, `get_template`, `search_bok`) and the `/api/v1` datasets as resources, over Streamable HTTP with the official TypeScript SDK v2 (protocol revision 2026-07-28, with a stateless fallback for 2025-era clients). Every answer carries its source URL, the CC BY 4.0 licence and the notice "Illustrative, not legal advice and not a claim of conformity". It reads the public API through a one-hour in-memory cache with conditional revalidation, keeps no data about callers (no IPs, user agents or tool arguments in its logs; the rate limiter holds only keyed hashes until each window closes) and ships a Dockerfile, a compose service, a Caddy site block and connection instructions for Claude and other MCP clients.

Infrastructure

- **Regulatory change monitor** (`tools/reg-monitor/`, `.github/workflows/reg-monitor.yml`): a daily GitHub Actions job (06:17 UTC) reads 34 official pages the site already cites (EUR-Lex and the Digital Omnibus, the AI Act Service Desk, the Commission's AI Act pages, CEN-CENELEC JTC 21, NIST, OWASP GenAI, law.go.kr, the California, New York, Colorado and Texas legislatures, the EDPB, ICO and CNIL, the IAPP AIGP page and the International AI Safety Report), reduces each to stable text, compares a SHA-256 with the previous run and, on a change, opens or comments on an issue labelled `regulatory-change` with a diff excerpt and the files that cite the URL. It never edits or publishes the site; its state lives on the orphan branch `reg-monitor-state`, not on `main`, because every push to `main` deploys. Manual runs default to a dry run. Unit tests run with `node --test`; `tools/reg-monitor/README.md` explains operation and how to add a source.
- Build gates: the content lint fails on any em dash and also scans the published SVG, JSON, CSV, TXT, XML and Markdown files and the text of the PNG downloads; a test fails when a register row still says "applies later" or "deferred" after its date has passed (`site/tests/obligation-status-dates.spec.ts`).
- **Issue forms**: report an error on a page, propose an obligation row, propose a glossary term and propose a case study join the existing forms.
- **Newsletter and analytics**: the sign-up form also closes every chapter and the home. Downloads in the footer and on `/about`, newsletter sign-ups, search opening and citation copying carry declarative Umami event attributes; no new script, and the

newsletter note says the address goes straight to Buttondown. Analytics ignore the URL fragment and query, so toolkit answers never leave the browser.

- Code comments in chapter examples meet WCAG AA contrast.
- Dependabot keeps the MCP server's Docker base image up to date (a `docker` entry for `/tools/mcp-server`, ignoring Node semver-major updates).

Fixes

Fact-check pass of 2026-09-24 and 2026-09-25: every finding was checked against the primary source before it was applied.

- **Thesis and chapter 01.** Vendor sources are no longer presented as fact: the fifth problem sets Gartner's own criterion ("automated policy enforcement at runtime") beside a category comparison published by a competitor in it and IBM's account of its Magic Quadrant placement (June 2026), and the agent-breach figure is a security vendor's 2026 survey; GRC engineering is dated "since about 2024" and "as of today" became "as of 2026-09-24" (Thesis in English and Spanish, preface). Chapter 01 cites Gartner's spending forecast (USD 492 million in 2026, over USD 1 billion by 2030). One model of the three questions runs through chapter 01, `/stack` and the home: Inventory & Transparency answers what is running; Govern-as-Code and Runtime Controls & Observability answer what it may do (the first writes the bound, the second enforces it on the live call); Evals & Red Teaming and Assurance & Continuous Compliance answer what evidence proves it. The three layers inherited from GRC engineering are named as the Thesis and chapter 04 name them.
- **Chapters 00 to 10 (debt and date pass, 2026-09-24).** Dated statements are current as of 2026-09-24. Vendor figures are attributed, not asserted: the runtime-data-path finding is one vendor's comparison published by a competitor in the category, the Magic Quadrant is reported by a vendor named in it, and the agentic-breach figure is a security vendor's 2026 survey (chapters 02, 03 and 05); chapters 02 and 06 no longer cite individual job postings as evidence, and chapter 02 cites primary sources for SB 53 and the Omnibus dates. Chapters 04, 05 and 08, the glossary and the reading list cite EUR-Lex and the Commission for EU texts; the reading list adds the consolidated AI Act, Regulation (EU) 2026/1744 and the International AI Safety Report 2026 and marks the AI Act Explorer as secondary commentary. Chapter 04 cites OSCAL and the harmonised-standards status on primary sources, states the layer-to-question model and the three inherited layers, and gives the guardian agent its Gartner note; chapter 08 names Spain's AESIA with its Royal Decree 729/2023 and dates the NIST drafts it cites as of 2026-09-24.
- **US frontier laws.** California SB 53 and New York's RAISE Act bind every frontier developer (a model trained above 10^{26} operations) to report critical safety incidents; only large frontier developers (annual revenue above USD 500M) must publish a frontier AI framework. RAISE takes the thresholds of its 2026 chapter amendment (S8828, signed 2026-03-27: no USD 100M cost test; reports within 72 hours to a new office within the Department of Financial Services, or within 24 hours to law enforcement or a public safety agency on imminent risk of death or serious injury). Fixed in chapters 02, 08, 09, 17 and 21, the register, `jurisdictions.ts` and the incident clock notes. SB 53's in-force date (1 Jan 2026) now rests on the chaptered statute and the California Constitution (art. IV, §8(c)(1)), not on the Future of Privacy Forum explainer (dated 2025-10-03).
- **US credit.** The CFPB withdrew Circular 2022-03 on 12 May 2025 (90 FR 20084); the Regulation B duty to give specific principal reasons (12 CFR 1002.9) is unchanged. Chapter 20 cites the Regulation B final rule of 2026-04-22 (91 FR 21620, effective 2026-07-21: ECOA does not authorise disparate-impact liability; 1002.9 unchanged). Fixed in chapters 10, 20 and 21 and the Decision Notice & Contest Path pattern.
- **EU AI Act.** Art. 73 was not postponed; only Chapter III, Sections 1 to 3 were (chapter 17, with the consolidated Art. 113). Art. 86 has applied since 2 Aug 2026 but acts on Annex III systems only from 2 Dec 2027. The Art. 111(4) marking grace to 2 Dec 2026 is sourced to the consolidated text, not to the Commission news item. Art. 3(49)(b) reads "serious and irreversible disruption of the management or operation of critical infrastructure". Chapter 18 cites the final Art. 50 guidelines of 20 Jul 2026. The GPAI guidelines are dated by their formal text, C(2025) 7719 final of 19 Nov 2025 (content approved on 18 Jul 2025 by C(2025) 5045 final), and a modifier's duties follow paras. 65 to 68: Art. 53(1) limited to the modification, Art. 54, and Arts. 52 and 55 when the original model has systemic risk (chapters 15 and 18, the glossary, `triage.ts`). Chapter 13: the Omnibus extends the simplified documentation form to small mid-caps (SMEs and start-ups had it since 2024). Chapter 15's AI Act sources cite the EUR-Lex consolidated text instead of the AI Act Service Desk; contract clauses cite EUR-Lex too. `deployment-options.ts` splits the Art. 50 duties between provider and deployer and scopes the Art. 27 FRIA.
- **DORA.** When an incident is classified as major more than 24 hours after awareness, a new 4-hour clock runs from classification (RTS 2025/301, Art. 5(2)): in chapters 08 and 17, the glossary, the incident-clock data, logic and page, with a test.
- **Other law.** Texas HB 149 bans social scoring only for governmental entities, and the AI-use disclosure falls on government agencies and health-care providers (chapter 08, the register, `roles.ts`). Korea's AI Basic Act (Act No. 21311) and Enforcement Decree (No. 36506) cite their current versions, with the officials' liability exemption in the Act (Art. 16(4)). Spain's AESIA remit, Colorado's stipulated non-enforcement order of 27 Apr 2026, Council Decision (EU) 2026/1080 (read on EUR-Lex), the HLEG fallback-plan quote, ISO/IEC 25059's replacement at FDIS, ISO/IEC 22989's generative AI amendment at FDIS, the CEN-CENELEC date, SPIFFE WIT-SVID (incubating), the ACS unauthenticated-wire disclosure (dated) and the TC260 Appendix 2 sentence are corrected in chapters 11, 21, 22 and 23. Chapter 16 cites C-203/22 para. 62 from EUR-Lex, adds ISO/IEC TS 6254:2025 and the Regulation B commentary as sources and corrects the EDRI title.
- **Sources in chapters 12 to 15.** Chapter 12 cites the Whistleblower Directive (EU) 2019/1937 by article; chapter 14 quotes Art. 9(8) and the substantial-modification definition and gives SS1/23 its scope; chapter 15 tags the Product Liability Directive

`primary` and cites DORA `Art. 28` and NIS2 `Art. 21` with their EUR-Lex anchors; the glossary cites `legislation.gov.uk` for UK law.

- **Standards and threat references.** ISO/IEC 42001 crosswalk glosses name the B.x clauses of the guidance annex; NIST AI 100-2 E2025 calls the class "misuse" attacks; EDPB Opinion 28/2024 puts the test at para. 43; NIST SP 800-218A glosses follow the PDF; Illinois laws point to `ilga.gov` and prEN 18229-1 to its CEN stage page.
- **Toolkit and figures.** Calendar exports give each event a unique UID and export timed events with alarms instead of all-day entries (incident clock and planner); the policy-card link and CSV import can no longer write to `Object.prototype`; the schema check fails instead of warning when a chapter 05 shape is missing or invalid; the poster label placement search is bounded; a status region's first announcement waits until it is exposed; the regulatory monitor runs in two jobs so the token that reads third-party pages cannot push.
- **MCP server.** `/mcp` refuses JSON-RPC batches and caps concurrent requests; after a failed revalidation the stale copy is served for up to a minute without asking again; rate limiting keys IPv6 clients by their `/64` and reads `X-Forwarded-For` only from trusted proxies; patterns and terms resolve to their published pages and anchors; the threats dataset is served; the base image is pinned by digest and the README covers a network only Caddy and the server share and rotated logs.

[0.4.0] - 2026-09-19

Minor release: two new patterns, a fuller regulatory map, curated resources, and a visual layer for the whole book. No change to the definition, values or principles.

Added

- `bok/05-patterns.md`: two patterns the outline had promised: **Adversarial Red-Team Suite** (Layer 03) and **Runtime Guardrail** (Layer 04, distinct from Kill Switch / Circuit Breaker). The catalogue now has 17 patterns; `OUTLINE.md` updated. Four illustrative JSON schemas (Policy Card verdict, Eval Gate result, Continuous Assurance evidence record, Agent Registry entry) placed where the prose already specified their fields.
- `bok/04-the-stack.md`: one named, anonymised system carried through the five "In practice" boxes and a short "One system through the five layers" section after the minimum viable stack; bold pattern names now link to the catalogue.
- `bok/08-regulatory-map.md`, `site/src/data/frameworks.ts`: EU AI Act rows for Arts. 6, 43, 47 and 60; the Commission's Art. 55(1)(c) serious-incident template as the named artefact on the Art. 55 row; the Art. 73 windows as a standalone decision table; ISO/IEC 42006:2025 and ISO/IEC 23894; NIST AI Agent Standards Initiative, NIST IR 8596 and NIST AI 800-1 (drafts flagged); CSA AICM supplements; South Korea AI Basic Act, Texas TRAIGA, Colorado, a UK subsection and Singapore's IMDA framework, each dated "as of 2026-09-19" and hedged where rules are still in draft.
- `bok/10-reading-list.md`, `sources/SOURCES.md`: incident and risk repositories (AIID, AIAAIC, OECD.AI, AVID, MIT AI Risk Repository), NIST AI 800-1 and ARIA, UK AISI, US CAISI, and the three frontier-lab safety frameworks; the tools index rebuilt on five verified curated lists.
- `site/src/data/stack.ts`, `site/src/data/path.ts`: illustrative tool names per layer (incl. new categories for MCP / tool-call security, kill switches, model and data cards, FRIA/DPIA tooling and open-source OSCAL tooling) and learning-path resources (IAPP AIGP, Stanford CS120, hands-on labs, a first `template` resource), every URL fetched on 2026-09-19.
- Figures: an archify figure at the head of every pattern (17), openers for chapters 02 and 04, and seven hand-drawn infographics (the three questions, values and principles, the minimum viable stack, the maturity grid, the Art. 73 clock, the pattern map, reading paths by persona), all governed by `site/VISUAL-GUIDE.md`.
- Site: duty-holder and applies-from columns with a duty-holder filter on the obligation table; "Patterns" in the navigation with cross-links between tools, obligations and patterns; CSV/JSON export of the obligation index; a mobile table of contents; pattern links from the maturity model; accessibility and Lighthouse gates in CI; a weekly external link-rot check; opt-in cookieless analytics; `CONTRIBUTING.md`.

Removed

- `github.com/systempromptio/awesome-ai-agent-governance`: cited five times as a curated index; on inspection it is a promotional fork-farm list (64 forks for 41 stars, one-commit contributors each adding their own tool). Replaced by AthenaCore/AwesomeResponsibleAI, EthicalML/awesome-production-machine-learning, open-policy-agent/awesome-opa, oscal-club/awesome-oscsl and trailofbits/awesome-ml-security.

[0.3.1] - 2026-09-19

Patch release: a credibility pass. Facts corrected and re-sourced, co-authorship recorded, and the version single-sourced. No change to the definition, values or principles.

Changed

- `THESIS.md`, `bok/00-preface.md`, `bok/CONTRIBUTORS.md`, `site/src/data/site.ts`, `site/src/components/Citation.astro`, `site/src/pages/about/index.astro`: Aurélie Pols added as co-author (matching the Thesis Authors section and LinkedIn); the

suggested citation now lists both authors. "written by one practitioner" reworded to "started by one practitioner".

- `site/src/data/site.ts` and everywhere the current version is stated: bumped to **v0.3.1**; the version is now single-sourced from `bokVersion`, with prose pointing at this changelog.
- `OUTLINE.md`, `STYLEGUIDE.md`, `sources/SOURCES.md`: all chapters 00–10 marked ****[drafted]****; dead `posts/...` and `RESEARCH-DIGEST.md` pointers removed; the chapter-04 brief lists its five extra sections and its word target updated to ~5,000.
- `THESIS.md`, `bok/CONTRIBUTORS.md`, `README.md`: the placeholder repository URL replaced with the live `github.com/losanchos5/aige`; `README.md` links `CONTRIBUTING.md`.
- `build/build_pdf.py`: PDF output filenames now read the version from `site/src/data/site.ts`, so they carry v0.3.1.
- `site/scripts/content-lint.mjs`: new rule: fail the build when a current-version statement in `THESIS.md`, `README.md`, `bok/00-preface.md` or `OUTLINE.md` disagrees with `bokVersion`.

Fixed (fact-check)

- `bok/08-regulatory-map.md`, `bok/09-glossary.md`, `bok/10-reading-list.md`, `site/src/data/frameworks.ts`, `sources/SOURCES.md`: the New York RAISE Act status corrected: it is enacted (S6953B, signed 19 Dec 2025), effective 1 Jan 2027 after a March 2026 chapter amendment, with oversight in an office within the NY Department of Financial Services. The earlier provisional-status hedge is gone; retagged to primary/secondary and cited to the Governor's release, the NY Senate bill and a law-firm alert.
- `bok/02-why-now.md`, `sources/SOURCES.md`: citation [9], which attributed three job postings to one URL, split into three per-posting citations; downstream markers renumbered.
- `bok/06-the-role.md`, `site/src/data/role.ts`, `sources/SOURCES.md`: the unsourced LinkedIn "+150% YoY" figure removed (it is not in the cited article, nor stated per-skill in a LinkedIn primary); the qualitative demand signal kept.
- `bok/02-why-now.md`, `bok/08-regulatory-map.md`: "as of 2026-09-10" currency markers re-verified and moved to "as of 2026-09-19" (no harmonised standard is yet OJ-cited).

Added

- `bok/09-glossary.md`: seven glossary terms: OPA/Rego, Cedar, GPAI Code of Practice, ISO/IEC 42005, Annex I (EU AI Act), Duty holder, EN 18286.
- `bok/08-regulatory-map.md`, `site/src/data/frameworks.ts`: an EU AI Act **Art. 25** (value-chain responsibilities) row, mirroring the pattern in chapter 05.

[0.3] - 2026-09-15

Editorial pass. The founding document is retitled and its values restated; the substance of the discipline is unchanged.

Changed

- `THESIS.md`: the founding document is now **The AI Governance Engineering Thesis** ("the Thesis"), and the work is *AI Governance Engineering: The Thesis & Body of Knowledge*. Its file is `THESIS.md` and its canonical route is `/thesis`. Bumped to v0.3.
- `THESIS.md`, `bok/03-values-principles.md`: the eight values drop the Agile "X over Y" grammar and are stated as affirmations (e.g. "Governance is code, not a document"); their bodies, anti-patterns and citations are unchanged. The GRC engineering precedent is folded into a short list of influences (SRE, DevSecOps, policy-as-code, software supply-chain security) and no longer leads the document.
- `bok/00-preface.md`, `bok/02-why-now.md`, `bok/04-the-stack.md`, `bok/06-the-role.md`, `bok/10-reading-list.md`, `bok/CONTRIBUTORS.md`, `README.md`, `OUTLINE.md`, `STYLEGUIDE.md`, `sources/SOURCES.md`, `build/build_pdf.py`: refer to the document as "the Thesis" throughout; external work titles (GRC Engineering Manifesto, The Agile Manifesto) are left intact.

[0.2] - 2026-09-10

Peer-review revision. Applies the HIGH and MEDIUM findings of **peer review round 1** (a senior- practitioner review and an adversarial fact-check), plus the cheap LOW findings.

Changed

- `bok/03-values-principles.md`, `THESIS.md`: reworked the six principles into strict commitments to action with no lexical overlap with the eight values (principles renamed accordingly); reframed value 6 from "Practitioner-built open tooling over closed platforms" to **"Inspectable, composable tooling over black boxes"**; noted which values are inherited from GRC engineering.
- `bok/01-definition.md`: added "the limits of the eval gate" (evals necessary, not sufficient; point-in-time, Goodhartable, blind to novelty); strengthened the AI-security-engineering boundary (the deliverable is a governed, evidenced system; overlap is a feature).

- `THESIS.md`, `bok/01-definition.md`, `bok/04-the-stack.md` : conceded that three of the five layers are inherited from GRC engineering and two (evals-as-controls, agent identity/runtime) are what AI forces us to add.
- `bok/04-the-stack.md` : distinguished MCP channel authentication from agent workload identity; presented Policy Cards / the OSCAL-extension preprint / TAIP / AAGATE as "one proposed approach" and named OSCAL's native model as the stable substrate; added Cedar-vs-Rego nuance; added sections on data governance, designing human oversight (Art. 14), third-party and procured AI, and the cost of the stack (FinOps).
- `bok/05-patterns.md` : added the pattern **Vendor / Model Due-Diligence Gate** (CSIRO template); sharpened Agent Identity (channel vs workload identity); tightened Continuous Assurance Telemetry to a concrete evidence schema; hedged the OSCAL-extension and TAIP/AAGATE proposals (now 14 patterns).
- `bok/06-the-role.md` : softened the analyst-vs-engineer table (cadence and artefact, not competence or access); moved named job postings to a footnote, keeping the IAPP bands and skills-demand data.
- `bok/07-maturity-model.md` : added a Level 4 eval-quality criterion (suite coverage / adversarial quality assessed, not just the gate's existence) and a "partial maturity is normal" reading.
- `bok/08-regulatory-map.md` : added a **Duty holder** column (provider / deployer / both); aligned the FRIA layer placement with chapter 05.

Fixed (fact-check round 1)

- `bok/09-glossary.md` : RAISE Act date softened to a reported 1 Jan 2027, pending confirmation of enactment; guardian-agent figure decoupled from the June 2025 project-cancellation release (now a separate Gartner prediction, reported).
- `bok/08-regulatory-map.md` : Regulation (EU) 2026/1744 verified on EUR-Lex and cited as primary.
- `bok/04-the-stack.md` : GPAI Code of Practice source date corrected to 10 Jul 2025.
- `bok/05-patterns.md` : TAIP arXiv date corrected to 2026-02 (submitted 15 Feb 2026).
- OWASP Agentic ASI titles left as drafted; could not be re-confirmed verbatim from the resource page (the enumerated list is in the downloadable PDF, and the web-search budget was exhausted).

Added

- `THESIS.md` : a second, independent source (IBM/Gartner Magic Quadrant, 2026) hedging the Kosmoy "no runtime data path" thesis.

[0.1] - 2026-09

First public draft. Founding release.

Added

- `THESIS.md` : the founding statement: definition and "more than X" clarifier; five fundamental problems with legacy AI governance; eight values (Agile grammar); six principles; what AI governance engineers build; authors and "co-authors wanted"; sign / get involved; CC BY 4.0 licence.
- `STYLEGUIDE.md` : voice and formatting rules; chapter template; CSIRO pattern template; citation format with `primary / secondary / reported` tags; canonical terminology; words to avoid; handling of unverified figures.
- `OUTLINE.md` : full table of contents (chapters 00–10) with a per-chapter brief.
- `bok/00-preface.md` : provenance, audience, what it is not, how to cite, versioning, contributing.
- `bok/01-definition.md` : the definition, three clarifiers, the eight-neighbour disambiguation cluster (table + prose), the object of governance, the three questions.
- `bok/02-why-now.md` : the five problems with the evidence; profession, market, standards-gap, regulatory-wave and agent-shift signals; what changes when governance is engineered.
- `bok/03-values-principles.md` : the eight values and six principles, each expanded with an "In practice" example and an anti-pattern.
- `bok/04-the-stack.md` : the five-layer reference architecture, per layer (what it proves, artefacts, illustrative tools, definition of done, anti-patterns, evidence flow), plus the minimum viable stack.
- `bok/05-patterns.md` : the pattern catalogue: 13 CSIRO-template patterns, each named to a layer.
- `bok/06-the-role.md` : the role by workflow; skills; analyst-vs-engineer; career ladder; entry paths; the market; common JD mistakes.
- `bok/07-maturity-model.md` : the five levels (Documented → Continuous), observable criteria by layer, metrics, self-assessment checklist, relation to ISO 42001 / AIMA / STAR for AI.
- `bok/08-regulatory-map.md` : the reverse index: EU AI Act (post-Omnibus), GPAI Code of Practice, ISO/IEC 42001 and 42005, NIST AI RMF, CSA AICM, OWASP GenAI, US frontier laws, and what is not harmonised yet.
- `bok/09-glossary.md` : canonical definitions, alphabetical, cross-referenced to chapters.
- `bok/10-reading-list.md` : annotated bibliography grouped by theme, each with a verified URL.

- `README.md` , `bok/CONTRIBUTORS.md` (authors + signatories), `bok/CHANGELOG.md` .
- `sources/SOURCES.md` : consolidated verified source table, one section per chapter.
- `build/build_pdf.py` : assembles the Markdown into `dist/site-preview.html` (PDF export available but not shipped).

Notes

- This is a first public draft: chapters 00–10 are drafted, and the catalogue, mappings and arguments remain open for co-authors to extend and sharpen.
- All facts are current as of 2026-09-10 and carry verified citations. The regulatory and standards landscape (EU AI Act Digital Omnibus, CEN-CENELEC JTC 21 harmonised standards, OWASP and CSA releases) is expected to move; chapters will be revised.